

ISC CISSP



Certified Information Systems Security Professional
Version: 11.8

Topic 1, Security Management Practices

QUESTION NO: 1

All of the following are basic components of a security policy EXCEPT the

- A. definition of the issue and statement of relevant terms.
- B. statement of roles and responsibilities
- C. statement of applicability and compliance requirements.
- D. statement of performance of characteristics and requirements.

Answer: D

Explanation: Policies are considered the first and highest level of documentation, from which the lower level elements of standards, procedures, and guidelines flow. This order, however, does not mean that policies are more important than the lower elements. These higher-level policies, which are the more general policies and statements, should be created first in the process for strategic reasons, and then the more tactical elements can follow. -Ronald Krutz The CISSP PREP Guide (gold edition) pg 13

QUESTION NO: 2

A security policy would include all of the following EXCEPT

- A. Background
- B. Scope statement
- C. Audit requirements
- D. Enforcement

Answer: B

Explanation:

QUESTION NO: 3

Which one of the following is an important characteristic of an information security policy?

- A. Identifies major functional areas of information.
- B. Quantifies the effect of the loss of the information.
- C. Requires the identification of information owners.
- D. Lists applications that support the business function.

Answer: A

Explanation: Information security policies are high-level plans that describe the goals of the procedures. Policies are not guidelines or standards, nor are they procedures or controls. Policies describe security in general terms, not specifics. They provide the blueprints for an overall security program just as a specification defines your next product - Roberta Bragg CISSP Certification Training Guide (que) pg 206

QUESTION NO: 4

Ensuring the integrity of business information is the PRIMARY concern of

- A. Encryption Security
- B. Procedural Security.
- C. Logical Security
- D. On-line Security

Answer: B

Explanation: Procedures are looked at as the lowest level in the policy chain because they are closest to the computers and provide detailed steps for configuration and installation issues. They provide the steps to actually implement the statements in the policies, standards, and guidelines...Security procedures, standards, measures, practices, and policies cover a number of different subject areas. - Shon Harris All-in-one CISSP Certification Guide pg 44-45

QUESTION NO: 5

Which of the following would be the first step in establishing an information security program?

- A. Adoption of a corporate information security policy statement
- B. Development and implementation of an information security standards manual
- C. Development of a security awareness-training program
- D. Purchase of security access control software

Answer: A

Explanation:

QUESTION NO: 6

Which of the following department managers would be best suited to oversee the development of an information security policy?

- A. Information Systems
- B. Human Resources
- C. Business operations
- D. Security administration

Answer: C

Explanation:

QUESTION NO: 7

What is the function of a corporate information security policy?

- A. Issue corporate standard to be used when addressing specific security problems.
- B. Issue guidelines in selecting equipment, configuration, design, and secure operations.
- C. Define the specific assets to be protected and identify the specific tasks which must be completed to secure them.
- D. Define the main security objectives which must be achieved and the security framework to meet business objectives.

Answer: D

Explanation: Information security policies are high-level plans that describe the goals of the procedures or controls. Policies describe security in general, not specifics. They provide the blueprint for an overall security program just as a specification defines your next product. - Roberta Bragg CISSP Certification Training Guide (que) pg 587

QUESTION NO: 8

Why must senior management endorse a security policy?

- A. So that they will accept ownership for security within the organization.
- B. So that employees will follow the policy directives.
- C. So that external bodies will recognize the organization's commitment to security.
- D. So that they can be held legally accountable.

Answer: A

Explanation: This really does not have a reference as it should be known. Upper management is legally accountable (up to 290 million fine). External organizations' answer is not really too pertinent (however it stated that other organizations will respect a BCP and disaster recovery plan). Employees need to be bound to the policy regardless of who signs it but it gives validity. Ownership is the correct answer in this statement. However, here is a reference. "Fundamentally important to any security program's success is the senior management's high-level statement of commitment to the information security policy process and a senior management's understanding of how important security controls and protections are to the enterprise's continuity. Senior management must be aware of the importance of security implementation to preserve the organization's viability (and for their own 'due care' protection) and must publicly support that process throughout the enterprise." -Ronald Krutz The CISSP PREP Guide (gold edition) pg 13

QUESTION NO: 9

In which one of the following documents is the assignment of individual roles and responsibilities MOST appropriately defined?

- A. Security policy

- B. Enforcement guidelines
- C. Acceptable use policy
- D. Program manual

Answer: C

Explanation: An acceptable use policy is a document that the employee signs in which the expectations, roles and responsibilities are outlined.

Issue -specific policies address specific security issues that management feels need more detailed explanation and attention to make sure a comprehensive structure is built and all employees understand how they are to comply to these security issues. - Shon Harris All-in-one CISSP Certification Guide pg 62

QUESTION NO: 10

Which of the following defines the intent of a system security policy?

- A. A definition of the particular settings that have been determined to provide optimum security.
- B. A brief, high-level statement defining what is and is not permitted during the operation of the system.
- C. A definition of those items that must be excluded on the system.
- D. A listing of tools and applications that will be used to protect the system.

Answer: A

Explanation: "A system-specific policy presents the management's decisions that are closer to the actual computers, networks, applications, and data. This type of policy can provide an approved software list, which contains a list of applications that can be installed on individual workstations. This policy can describe how databases are to be protected, how computers are to be locked down, and how firewall, intrusion detection systems, and scanners are to be employed." Pg 93 Shon Harris CISSP All-In-One Certification Exam Guide

QUESTION NO: 11

When developing an information security policy, what is the FIRST step that should be taken?

- A. Obtain copies of mandatory regulations.
- B. Gain management approval.
- C. Seek acceptance from other departments.
- D. Ensure policy is compliant with current working practices.

Answer: B

Explanation:

QUESTION NO: 12

Which one of the following should NOT be contained within a computer policy?

- A. Definition of management expectations.
- B. Responsibilities of individuals and groups for protected information.
- C. Statement of senior executive support.
- D. Definition of legal and regulatory controls.

Answer: B

Explanation:

QUESTION NO: 13

Which one of the following is NOT a fundamental component of a Regulatory Security Policy?

- A. What is to be done.
- B. When it is to be done.
- C. Who is to do it.
- D. Why is it to be done

Answer: C

Explanation: Regulatory Security policies are mandated to the organization but it up to them to implement it.

"Regulatory - This policy is written to ensure that the organization is following standards set by a specific industry and is regulated by law. The policy type is detailed in nature and specific to a type of industry. This is used in financial institutions, health care facilities, and public utilities." - Shon Harris All-in-one CISSP Certification Guide pg 93-94

QUESTION NO: 14

Which one of the following statements describes management controls that are instituted to implement a security policy?

- A. They prevent users from accessing any control function.
- B. They eliminate the need for most auditing functions.
- C. They may be administrative, procedural, or technical.
- D. They are generally inexpensive to implement.

Answer: C

Explanation: Administrative, physical, and technical controls should be utilized to achieve the management's directives. - Shon Harris All-in-one CISSP Certification Guide pg 60

QUESTION NO: 15

Which must bear the primary responsibility for determining the level of protection needed for information systems resources?

- A. IS security specialists
- B. Senior Management
- C. Seniors security analysts
- D. system auditors

Answer: B

Explanation:

QUESTION NO: 16

Which of the following choices is NOT part of a security policy?

- A. definition of overall steps of information security and the importance of security
- B. statement of management intend, supporting the goals and principles of information security
- C. definition of general and specific responsibilities for information security management
- D. description of specific technologies used in the field of information security

Answer: D

Explanation:

QUESTION NO: 17

In an organization, an Information Technology security function should:

- A. Be a function within the information systems functions of an organization
- B. Report directly to a specialized business unit such as legal, corporate security or insurance
- C. Be lead by a Chief Security Officer and report directly to the CEO
- D. Be independent but report to the Information Systems function

Answer: C

Explanation:

QUESTION NO: 18

Which of the following embodies all the detailed actions that personnel are required to follow?

- A. Standards
- B. Guidelines
- C. Procedures
- D. Baselines

Answer: C

Explanation:

QUESTION NO: 19

A significant action has a state that enables actions on an ADP system to be traced to individuals who may then be held responsible. The action does NOT include:

- A. Violations of security policy.
- B. Attempted violations of security policy.
- C. Non-violations of security policy.
- D. Attempted violations of allowed actions.

Answer: C

Explanation:

QUESTION NO: 20

Network Security is a

- A. Product
- B. protocols
- C. ever evolving process
- D. quick-fix solution

Answer: C

Explanation:

QUESTION NO: 21

Security is a process that is:

- A. Continuous
- B. Indicative
- C. Examined
- D. Abnormal

Answer: A

Explanation:

Security is a continuous process; as such you must closely monitor your systems on a regular basis. Log files are usually a good way to find an indication of abnormal activities. However some care must be exercise as to what will be logged and how the logs are protected. Having corrupted logs is about as good as not having logs at all.

QUESTION NO: 22

What are the three fundamental principles of security?

- A. Accountability, confidentiality, and integrity
- B. Confidentiality, integrity, and availability
- C. Integrity, availability, and accountability
- D. Availability, accountability, and confidentiality

Answer: B

Explanation:

QUESTION NO: 23

Which of the following prevents, detects, and corrects errors so that the integrity, availability, and confidentiality of transactions over networks may be maintained?

- A. Communications security management and techniques
- B. Networks security management and techniques
- C. Clients security management and techniques
- D. Servers security management and techniques

Answer: A

Explanation:

QUESTION NO: 24

Making sure that the data is accessible when and where it is needed is which of the following?

- A. Confidentiality
- B. integrity
- C. acceptability
- D. availability

Answer: D

Explanation:

QUESTION NO: 25

Which of the following describes elements that create reliability and stability in networks and systems and which assures that connectivity is accessible when needed?

- A. Availability
- B. Acceptability
- C. Confidentiality
- D. Integrity

Answer: A

Explanation:

QUESTION NO: 26

Most computer attacks result in violation of which of the following security properties?

- A. Availability
- B. Confidentiality
- C. Integrity and control
- D. All of the choices.

Answer: D

Explanation:

Most computer attacks only corrupt a system's security in very specific ways. For example, certain attacks may enable a hacker to read specific files but don't allow alteration of any system components. Another attack may allow a hacker to shut down certain system components but doesn't allow access to any files. Despite the varied capabilities of computer attacks, they usually result in violation of only four different security properties: availability, confidentiality, integrity, and control.

QUESTION NO: 27

Which of the following are objectives of an information systems security program?

- A. Threats, vulnerabilities, and risks
- B. Security, information value, and threats
- C. Integrity, confidentiality, and availability.
- D. Authenticity, vulnerabilities, and costs.

Answer: C

Explanation: There are several small and large objectives of a security program, but the main three principles in all programs are confidentiality, integrity, and availability. These are referred to as the CIA triad. - Shon Harris All-in-one CISSP Certification Guide pg 62

QUESTION NO: 28

An area of the Telecommunications and Network Security domain that directly affects the Information Systems Security tenet of Availability can be defined as:

- A. Netware availability
- B. Network availability
- C. Network acceptability
- D. Network accountability

Answer: B

Explanation:

QUESTION NO: 29

The Structures, transmission methods, transport formats, and security measures that are used to provide integrity, availability, and authentication, and confidentiality for transmissions over private and public communications networks and media includes:

- A. The Telecommunications and Network Security domain
- B. The Telecommunications and Netware Security domain
- C. The Technical communications and Network Security domain
- D. The Telnet and Security domain

Answer: A

Explanation: The Telecommunications, Network, and Internet Security Domain encompasses the structures, transmission methods, transport formats, and security measures used to provide integrity, availability, authentication, and confidentiality for transmissions over private and public

communications networks and media.” Pg 515 Hansche: Official (ISC)2 Guide to the CISSP Exam

QUESTION NO: 30

Which one of the following is the MOST crucial link in the computer security chain?

- A. Access controls
- B. People
- C. Management
- D. Awareness programs

Answer: C

Explanation:

QUESTION NO: 31

The security planning process must define how security will be managed, who will be responsible, and

- A. Who practices are reasonable and prudent for the enterprise.
- B. Who will work in the security department.
- C. What impact security will have on the intrinsic value of data.
- D. How security measures will be tested for effectiveness.

Answer: D

Explanation:

QUESTION NO: 32

Information security is the protection of data. Information will be protected mainly based on:

- A. Its sensitivity to the company.
- B. Its confidentiality.
- C. Its value.
- D. All of the choices.

Answer: D

Explanation:

Information security is the protection of data against accidental or malicious disclosure, modification, or destruction. Information will be protected based on its value, confidentiality, and/or sensitivity to the company, and the risk of loss or compromise. At a minimum, information will be update-protected so that only authorized individuals can modify or erase the information.

QUESTION NO: 33

Organizations develop change control procedures to ensure that

- A. All changes are authorized, tested, and recorded.
- B. Changes are controlled by the Policy Control Board (PCB).
- C. All changes are requested, scheduled, and completed on time.
- D. Management is advised of changes made to systems.

Answer: A

Explanation: "Change Control: Changes must be authorized, tested, and recorded. Changed systems may require re-certification and re-accreditation." Pg 699 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 34

Within the organizational environment, the security function should report to an organizational level that

- A. Has information technology oversight.

- B. Has autonomy from other levels.
- C. Is an external operation.
- D. Provides the internal audit function.

Answer: B

Explanation:

QUESTION NO: 35

What is the MAIN purpose of a change control/management system?

- A. Notify all interested parties of the completion of the change.
- B. Ensure that the change meets user specifications.
- C. Document the change for audit and management review.
- D. Ensure the orderly processing of a change request.

Answer: C

Explanation:

QUESTION NO: 36

Which of the following is most relevant to determining the maximum effective cost of access control?

- A. the value of information that is protected
- B. management's perceptions regarding data importance
- C. budget planning related to base versus incremental spending.
- D. the cost to replace lost data

Answer: A

Explanation:

QUESTION NO: 37

Which one of the following is the MAIN goal of a security awareness program when addressing senior management?

- A. Provide a vehicle for communicating security procedures.
- B. Provide a clear understanding of potential risk and exposure.
- C. Provide a forum for disclosing exposure and risk analysis.
- D. Provide a forum to communicate user responsibilities.

Answer: B

Explanation:

When the Security Officer is addressing Senior Management, the focus would not be on user responsibilities, it would be on making sure the Senior Management have a clear understanding of the risk and potential liability is

Not D: Item D would be correct in a situation where Senior Management is addressing organizational staff.

QUESTION NO: 38

In developing a security awareness program, it is MOST important to

- A. Understand the corporate culture and how it will affect security.
- B. Understand employees preferences for information security.
- C. Know what security awareness products are available.
- D. Identify weakness in line management support.

Answer: A

Explanation: The controls and procedures of a security program should reflect the nature of the data being processed...These different types of companies would also have very different cultures. For a security awareness program to be effective, these considerations must be understood and the program should be developed in a fashion that makes sense per environment - Shon Harris All-in-one CISSP Certification Guide pg 109

QUESTION NO: 39

Which of the following would be best suited to provide information during a review of the controls over the process of defining IT service levels?

- A. Systems programmer
- B. Legal stuff
- C. Business unit manager
- D. Programmer

Answer: C

Explanation:

QUESTION NO: 40

Which of the following best explains why computerized information systems frequently fail to meet the needs of users?

- A. Inadequate quality assurance (QA) tools
- B. Constantly changing user needs
- C. Inadequate user participation in defining the system's requirements
- D. Inadequate project management.

Answer: C

Explanation:

QUESTION NO: 41

Which of the following is not a compensating measure for access violations?

- A. Backups
- B. Business continuity planning
- C. Insurance
- D. Security awareness

Answer: D

Explanation:

QUESTION NO: 42

Risk analysis is MOST useful when applied during which phase of the system development process?

- A. Project identification
- B. Requirements definition
- C. System construction
- D. Implementation planning

Answer: A

Reference: pg 684 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 43

Which one of the following is not one of the outcomes of a vulnerability analysis?

- A. Quantative loss assessment
- B. Qualitative loss assessment
- C. Formal approval of BCP scope and initiation document
- D. Defining critical support areas

Answer: C

Explanation:

QUESTION NO: 44

Which of the following is not a part of risk analysis?

- A. Identify risks
- B. Quantify the impact of potential threats
- C. Provide an economic balance between the impact of the risk and the cost of the associated countermeasures
- D. Choose the best countermeasure

Answer: D

Explanation:

QUESTION NO: 45

A new worm has been released on the Internet. After investigation, you have not been able to determine if you are at risk of exposure. Management is concerned as they have heard that a number of their counterparts are being affected by the worm. How could you determine if you are at risk?

- A. Evaluate evolving environment.
- B. Contact your anti-virus vendor.
- C. Discuss threat with a peer in another organization.
- D. Wait for notification from an anti-virus vendor.

Answer: B

Explanation:

QUESTION NO: 46

When conducting a risk assessment, which one of the following is NOT an acceptable social engineering practice?

- A. Shoulder surfing
- B. Misrepresentation
- C. Subversion
- D. Dumpster diving

Answer: A

Explanation:

Shoulder Surfing: Attackers can thwart confidentiality mechanisms by network monitoring, shoulder surfing, stealing password files, and social engineering. These topics will be address more in-depth in later chapters, but shoulder surfing is when a person looks over another person's shoulder and watches keystrokes or data as it appears on the screen. Social engineering is tricking another person into sharing confidential information by posing as an authorized individual to that information. Shon Harris: CISSP Certification pg. 63. Shoulder surfing is not social engineering.

QUESTION NO: 47

Which one of the following risk analysis terms characterizes the absence or weakness of a risk-reducing safeguard?

- A. Threat
- B. Probability
- C. Vulnerability
- D. Loss expectancy

Answer: C

Explanation: A weakness in system security procedures, system design, implementation, internal controls, and so on that could be exploited to violate system security policy. -Ronald Krutz The CISSP PREP Guide (gold edition) pg 927

QUESTION NO: 48

Risk is commonly expressed as a function of the

- A. Systems vulnerabilities and the cost to mitigate.
- B. Types of countermeasures needed and the system's vulnerabilities.
- C. Likelihood that the harm will occur and its potential impact.
- D. Computer system-related assets and their costs.

Answer: C

Explanation: The likelihood of a threat agent taking advantage of a vulnerability. A risk is the loss potential, or probability, that a threat will exploit a vulnerability. - Shon Harris All-in-one CISSP Certification Guide pg 937

QUESTION NO: 49

How should a risk be handled when the cost of the countermeasures outweighs the cost of the risk?

- A. Reject the risk
- B. Perform another risk analysis
- C. Accept the risk
- D. Reduce the risk

Answer: C

Explanation:

QUESTION NO: 50

Which of the following is an advantage of a qualitative over quantitative risk analysis?

- A. It prioritizes the risks and identifies areas for immediate improvement in addressing the vulnerabilities.
- B. It provides specific quantifiable measurements of the magnitude of the impacts
- C. It makes cost-benefit analysis of recommended controls easier

Answer: A

Explanation:

QUESTION NO: 51

The absence or weakness in a system that may possibly be exploited is called a(n)?

- A. Threat
- B. Exposure
- C. Vulnerability
- D. Risk

Answer: C

Explanation:

QUESTION NO: 52

What tool do you use to determine whether a host is vulnerable to known attacks?

- A. Padded Cells
- B. Vulnerability analysis
- C. Honey Pots
- D. IDS

Answer: B

Explanation:

Vulnerability analysis (also known as vulnerability assessment) tools test to determine whether a network or host is vulnerable to known attacks. Vulnerability assessment represents a special case of the intrusion detection process. The information sources used are system state attributes and outcomes of attempted attacks. The information sources are collected by a part of the assessment engine. The timing of analysis is interval-based or batch-mode, and the type of analysis is misuse detection. This means that vulnerability assessment systems are essentially batch mode misuse detectors that operate on system state information and results of specified test routines.

QUESTION NO: 53

Which of the following statements pertaining to ethical hacking is incorrect?

- A. An organization should use ethical hackers who do not sell auditing, consulting, hardware, software, firewall, hosting, and/or networking services
- B. Testing should be done remotely
- C. Ethical hacking should not involve writing to or modifying the target systems
- D. Ethical hackers should never use tools that have potential of exploiting vulnerabilities in the organizations IT system.

Answer: D

Explanation:

QUESTION NO: 54

Why would an information security policy require that communications test equipment be controlled?

- A. The equipment is susceptible to damage
- B. The equipment can be used to browse information passing on a network
- C. The equipment must always be available for replacement if necessary
- D. The equipment can be used to reconfigure the network multiplexers

Answer: B

Explanation:

QUESTION NO: 55

Management can expect penetration tests to provide all of the following EXCEPT

- A. identification of security flaws
- B. demonstration of the effects of the flaws
- C. a method to correct the security flaws.
- D. verification of the levels of existing infiltration resistance

Answer: C

Explanation:

Not B: It is not the objective of the pen tester to supply a method on how to correct the flaws. In fact management may decide to accept the risk and not repair the flaw. They may be able to demonstrate the effects of a flaw – especially if they manage to clobber a system!

Penetration testing is a set of procedures designed to test and possibly bypass security controls of a system. Its goal is to measure an organization's resistance to an attack and to uncover any weaknesses within the environment...The result of a penetration test is a report given to management describing the list of vulnerabilities that were identified and the severity of those vulnerabilities. From here, it is up to management to determine how the vulnerabilities are dealt with and what countermeasures are implemented. - Shon Harris All-in-one CISSP Certification Guide pg 837-839

QUESTION NO: 56

Which one of the following is a characteristic of a penetration testing project?

- A. The project is open-ended until all known vulnerabilities are identified.
- B. The project schedule is plotted to produce a critical path.
- C. The project tasks are to break into a targeted system.
- D. The project plan is reviewed with the target audience.

Answer: C

Explanation: "One common method to test the strength of your security measures is to perform penetration testing. Penetration testing is a vigorous attempt to break into a protected network using any means necessary." Pg 430 Tittel: CISSP Study Guide

QUESTION NO: 57

Which one of the following is the PRIMARY objective of penetration testing?

- A. Assessment
- B. Correction
- C. Detection
- D. Protection

Answer: C

Explanation:

Its goal is to measure an organization's resistance to an attack and to uncover any weakness within the environment...The result of a penetration test is a report given to management describing the list of vulnerabilities that were identified and the severity of those vulnerabilities. - Shon Harris All-in-one CISSP Certification Guide pg 837-839

Not A: Assessment would imply management deciding whether they can live with a given vulnerability.

QUESTION NO: 58

Open box testing, in the Flaw Hypothesis Methodology of Penetration Testing applies to the analysis of

- A. Routers and firewalls
- B. Host-based IDS systems
- C. Network-based IDS systems
- D. General purpose operating systems

Answer: D

Explanation:

Flaw Hypothesis Methodology - A system analysis and penetration technique where specifications and documentation for the system are analyzed and then flaws in the system are hypothesized. The list of hypothesized flaws is then prioritized on the basis of the estimated probability that a flaw actually exists and, assuming a flaw does exist, on the ease of exploiting it and on the extent of control or compromise it would provide. The prioritized list is used to direct the actual testing of the system. <http://www.kernel.org/pub/linux/libs/security/Orange-Linux/refs/Orange/Orange0-5.html>

QUESTION NO: 59

What is the FIRST step that should be considered in a penetration test?

- A. The approval of change control management.
- B. The development of a detailed test plan.
- C. The formulation of specific management objectives.
- D. The communication process among team members.

Answer: C

Explanation:

The type of penetration test depends on the organization, its security objectives, and the management's goals. - Shon Harris All-in-one CISSP Certification Guide pg 838

QUESTION NO: 60

Penetration testing will typically include

- A. Generally accepted auditing practices.
- B. Review of Public Key Infrastructure (PKI) digital certificate, and encryption.
- C. Social engineering, configuration review, and vulnerability assessment.
- D. Computer Emergency Response Team (CERT) procedures.

Answer: C

Explanation:

QUESTION NO: 61

Which of the following is not a valid reason to use external penetration service firms rather than corporate resources?

- A. They are more cost-effective
- B. They offer a lack of corporate bias
- C. They use highly talented ex-hackers
- D. They insure a more complete reporting

Answer: C

Explanation:

QUESTION NO: 62

Which of the following tools can you use to assess your networks vulnerability?

- A. ISS

- B. All of the choices.
- C. SATAN
- D. Ballista

Answer: B

Explanation:

ISS, Ballista and SATAN are all penetration tools.

QUESTION NO: 63

Annualized Loss Expectancy (ALE) value is derived from an algorithm of the product of annual rate of occurrence and

- A. Cost of all losses expected.
- B. Previous year's actual loss.
- C. Average of previous losses.
- D. Single loss expectancy.

Answer: D

Explanation: Single Loss Expectancy (SLE) x Annualized Rate of Occurance (ARO) = ALE pg. 18
Krutz: The CISSP Prep Guide

QUESTION NO: 64

If your property insurance has Actual Cost Evaluation (ACV) clause your damaged property will be compensated:

- A. Based on the value of the item on the date of loss
- B. Based on new item for old regardless of condition of lost item
- C. Based on value of item one month before loss
- D. Based on value of item on the date of loss plus 10 percent

Answer: D

Explanation:

QUESTION NO: 65

How is Annualized Loss Expectancy (ALE) derived from a threat?

- A. $ARO \times (SLE - EF)$
- B. $SLE \times ARO$
- C. SLE/EF
- D. $AV \times EF$

Answer: B

Explanation: " $SLE \times \text{annualized rate of occurrence (ARO)} = ALE$ " pg 70 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 66

Qualitative loss resulting from the business interruption does not include:

- A. Loss of revenue
- B. Loss of competitive advantage or market share
- C. Loss of public confidence and credibility
- D. Public embarrassment

Answer: A

Explanation: "Another method of risk analysis is qualitative, which does not assign numbers and monetary values to components and losses." Pg 72 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 67

Which risk management methodology uses the exposure factor multiplied by the asset value to determine its outcome?

- A. Annualized Loss Expectancy
- B. Single Loss Expectancy
- C. Annualized Rate of Occurrence
- D. Information Risk Management

Answer: B

Explanation: Single Loss Expectancy (SLE) AN SLE is the dollar figure that is assigned to a single event. It represents an organization's loss from a single threat and is derived from the following formula: Asset Value (\$) X Exposure Factor (EF) = SLE -Ronald Krutz The CISSP PREP Guide (gold edition) pg 18

QUESTION NO: 68

Valuable paper insurance coverage does not cover damage to which of the following?

- A. Inscribed, printed and written documents
- B. Manuscripts
- C. Records
- D. Money and Securities

Answer: D

Explanation:

QUESTION NO: 69

What is the window of time for recovery of information processing capabilities based on?

- A. Quality of the data to be processed
- B. Nature of the disaster
- C. Criticality of the operations affected
- D. Applications that are mainframe based

Answer: C

Explanation:

QUESTION NO: 70

What is the Maximum Tolerable Downtime (MTD):

- A. Maximum elapsed time required to complete recovery of application data
- B. Minimum elapsed time required to complete recovery of application data
- C. Maximum elapsed time required to move back to primary site a major disruption
- D. It is maximum delay businesses that can tolerate and still remain viable

Answer: D

Explanation: "The MTD is the period of time a business function or process can remain interrupted before its ability to recover becomes questionable." Pg 678 Hansche: Official (ISC)2 Guide to the CISSP Exam

QUESTION NO: 71

A "critical application" is one that MUST

- A. Remain operational for the organization to survive.
- B. Be subject to continual program maintenance.
- C. Undergo continual risk assessments.
- D. Be constantly monitored by operations management.

Answer: A

Explanation: I am assuming that I don't need to put a reference for this answer. Yeah ok here it is but I cheated and used a earlier reference

"A BIA is performed at the beginning of disaster recovery and continuity planning to identify the areas that would suffer the greatest financial or operational loss in the event of a disaster or disruption. It identifies the company's critical systems needed for survival and estimates the outage time that can be tolerated by the company as a result of disaster or disruption." - Shon Harris All-in-one CISSP Certification Guide pg 597

QUESTION NO: 72

Which of the following questions is less likely to help in assessing physical and environmental protection?

- A. Are entry codes changed periodically?
- B. Are appropriate fire suppression and prevention devices installed and working?
- C. Are there processes to ensure that unauthorized individuals cannot read, copy, alter, or steal printed or electronic information?
- D. Is physical access to data transmission lines controlled?

Answer: C

Explanation:

QUESTION NO: 73

A common Limitation of information classification systems is the INABILITY to

- A. Limit the number of classifications.
- B. Generate internal labels on diskettes.
- C. Declassify information when appropriate.
- D. Establish information ownership.

Answer: C

Explanation: I could not find a reference for this. However I do agree that declassifying information is harder to do the classifying, but use your best judgment based on experience and knowledge.

QUESTION NO: 74

The purpose of information classification is to

- A. Assign access controls.
- B. Apply different protective measures.
- C. Define the parameters required for security labels.
- D. Ensure separation of duties.

Answer: B

Explanation:

QUESTION NO: 75

Who should determine the appropriate access control of information?

- A. Owner
- B. User
- C. Administrator
- D. Server

Answer: A

Explanation:

All information generated, or used must have a designated owner. The owner must determine appropriate sensitivity classifications, and access controls. The owner must also take steps to ensure the appropriate controls for the storage, handling, distribution, and use of the information in a secure manner.

QUESTION NO: 76

What is the main responsibility of the information owner?

- A. making the determination to decide what level of classification the information requires
- B. running regular backups
- C. audit the users when they require access to the information
- D. periodically checking the validity and accuracy for all data in the information system

Answer: A

Explanation:

QUESTION NO: 77

What process determines who is trusted for a given purpose?

- A. Identification
- B. Authorization
- C. Authentication
- D. Accounting

Answer: B

Explanation:

Authorization determines who is trusted for a given purpose. More precisely, it determines whether a particular principal, who has been authenticated as the source of a request to do something, is trusted for that operation. Authorization may also include controls on the time at which something can be done (e.g. only during working hours) or the computer terminal from which it can be requested (e.g. only the one on the system administrator desk).

QUESTION NO: 78

The intent of least privilege is to enforce the most restrictive user rights required

- A. To execute system processes.
- B. By their job description.
- C. To execute authorized tasks.
- D. By their security role.

Answer: C

Explanation: Least Privilege; the security principle that requires each subject to be granted the most restrictive set of privileges needed for the performance of authorized tasks. The application of this principle limits the damage that can result from accident, error, or unauthorized. - Shon Harris All-in-one CISSP Certification Guide pg 933

QUESTION NO: 79

What principle requires that a user be given no more privilege than necessary to perform a job?

- A. Principle of aggregate privilege.
- B. Principle of most privilege.
- C. Principle of effective privilege.
- D. Principle of least privilege.

Answer: D

Explanation:

As described at <http://hissa.nist.gov/rbac/paper/node5.html>, the principle of least privilege has been described as important for meeting integrity objectives. The principle of least privilege requires that a user be given no more privilege than necessary to perform a job.

QUESTION NO: 80

To ensure least privilege requires that _____ is identified.

- A. what the users privilege owns
- B. what the users job is
- C. what the users cost is
- D. what the users group is

Answer: B

Explanation:

Ensuring least privilege requires identifying what the user's job is, determining the minimum set of privileges required to perform that job, and restricting the user to a domain with those privileges and nothing more. By denying to subjects transactions that are not necessary for the performance of their duties, those denied privileges couldn't be used to circumvent the organizational security policy. Although the concept of least privilege currently exists within the context of the TCSEC, requirements restrict those privileges of the system administrator. Through the use of RBAC, enforced minimum privileges for general system users can be easily achieved.

QUESTION NO: 81

The concept of least privilege currently exists within the context of:

- A. ISO
- B. TCSEC
- C. OSI
- D. IEFT

Answer: B

Explanation:

Ensuring least privilege requires identifying what the user's job is, determining the minimum set of privileges required to perform that job, and restricting the user to a domain with those privileges and nothing more. By denying to subjects transactions that are not necessary for the performance of their duties, those denied privileges couldn't be used to circumvent the organizational security policy. Although the concept of least privilege currently exists within the context of the TCSEC, requirements restrict those privileges of the system administrator. Through the use of RBAC, enforced minimum privileges for general system users can be easily achieved.

QUESTION NO: 82

Which of the following rules is less likely to support the concept of least privilege?

- A. The number of administrative accounts should be kept to a minimum
- B. Administrators should use regular accounts when performing routing operations like reading mail
- C. Permissions on tools that are likely to be used by hackers should be as restrictive as possible
- D. Only data to and from critical systems and applications should be allowed through the firewall

Answer: D

Explanation:

QUESTION NO: 83

Which level of "least privilege" enables operators the right to modify data directly in it's original location, in addition to data copied from the original location?

- A. Access Change
- B. Read/Write
- C. Access Rewrite
- D. Access modify

Answer: A

Explanation:

QUESTION NO: 84

This is a common security issue that is extremely hard to control in large environments. It occurs when a user has more computer rights, permissions, and privileges that what is required for the tasks the user needs to fulfill. What best describes this scenario?

- A. Excessive Rights
- B. Excessive Access
- C. Excessive Permissions
- D. Excessive Privileges

Answer: D

Reference: "Excessive Privileges: This is a common security issue that is extremely hard to control in vast, complex environments. It occurs when a user has more computer rights, permissions, and privileges than what is required for the tasks she needs to fulfill." pg 603 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 85

One method to simplify the administration of access controls is to group

- A. Capabilities and privileges
- B. Objects and subjects

- C. Programs and transactions
- D. Administrators and managers

Answer: B

Explanation:

QUESTION NO: 86

Cryptography does not concern itself with:

- A. Availability
- B. Integrity
- C. Confidentiality
- D. Authenticity

Answer: A

Explanation:

QUESTION NO: 87

Which of the following measures would be the BEST deterrent to the theft of corporate information from a laptop which was left in a hotel room?

- A. Store all data on disks and lock them in an in-room safe
- B. Remove the batteries and power supply from the laptop and store them separately from the computer
- C. Install a cable lock on the laptop when it is unattended
- D. Encrypt the data on the hard drive

Answer: D

Explanation:

QUESTION NO: 88

To support legacy applications that rely on risky protocols (e.g., plain text passwords), which one of the following can be implemented to mitigate the risks on a corporate network?

- A. Implement strong centrally generated passwords to control use of the vulnerable applications.
- B. Implement a virtual private network (VPN) with controls on workstations joining the VPN.
- C. Ensure that only authorized trained users have access to workstations through physical access control.
- D. Ensure audit logging is enabled on all hosts and applications with associated frequent log reviews.

Answer: B

Explanation: It makes more sense to provide VPN client to workstations opposed to physically securing workstations.

QUESTION NO: 89

Which of the following computer crime is more often associated with insiders?

- A. IP spoofing
- B. Password sniffing
- C. Data diddling
- D. Denial of Service (DOS)

Answer: C

Explanation:

QUESTION NO: 90

The technique of skimming small amounts of money from multiple transactions is called the

- A. Scavenger technique
- B. Salami technique
- C. Synchronous attack technique
- D. Leakage technique

Answer: B

Explanation:

QUESTION NO: 91

What best describes a scenario when an employee has been shaving off pennies from multiple accounts and depositing the funds into his own bank account?

- A. Data fiddling
- B. Data diddling
- C. Salami techniques
- D. Trojan horses

Answer: C

Explanation:

QUESTION NO: 92

What is the act of willfully changing data, using fraudulent input or removal of controls called?

- A. Data diddling
- B. Data contaminating
- C. Data capturing
- D. Data trashing

Answer: A

Explanation: Data-diddling - the modification of data -Ronald Krutz The CISSP PREP Guide (gold edition) pg 417

QUESTION NO: 93

In the context of computer security, "scavenging" refers to searching

- A. A user list to find a name.
- B. Through storage to acquire information.

- C. Through data for information content.
- D. Through log files for trusted path information.

Answer: C

Explanation: Scavenging is a form of dumpster diving performed electronically. Online scavenging searches for useful information in the remnants of data left over after processes or tasks are completed. This could include audit trails, logs files, memory dumps, variable settings, port mappings, and cached data. - Ed Tittle CISSP Study Guide (sybex) pg 476

QUESTION NO: 94

Which security program exists if a user accessing low-level data is able to draw conclusions about high-level information?

- A. Interference
- B. Inference
- C. Polyinstatiation
- D. Under-classification

Answer: B

Explanation: Main Entry: in*fer*ence

Function: noun

Date: 1594

1 : the act or process of inferring : as a : the act of passing from one proposition, statement, or judgment considered as true to another whose truth is believed to follow from that of the former b : the act of passing from statistical sample data to generalizations (as of the value of population parameters) usually with calculated degrees of certainty

2 : something that is inferred; especially : a proposition arrived at by inference

3 : the premises and conclusion of a process of inferring

<http://www.m-w.com/cgi-bin/dictionary>

QUESTION NO: 95

Which of the following is not a form of a passive attack?

- A. Scavenging
- B. Data diddling
- C. Shoulder surfing
- D. Sniffing

Answer: B

Explanation: Data diddling is an active attack opposed to a passive attack.

Reference: "Data Diddling occurs when an attacker gains access to a system and makes small, random, or incremental changes to data rather than obviously altering file contents or damaging or deleting entire files." Pg 383 Tittel

QUESTION NO: 96

An example of an individual point of verification in a computerized application is

- A. An inference check.
- B. A boundary protection.
- C. A sensitive transaction.
- D. A check digit.

Answer: D

Explanation: Checkdigit: A one-digit checksum.

Checksum: A computed value which depends on the contents of a block of data and which is transmitted or stored along with the data in order to detect corruption of the data. The receiving system recomputes the checksum based upon the received data and compares this value with the one sent with the data. If the two values are the same, the receiver has some confidence that the data was received correctly.

The checksum may be 8 bits (modulo 256 sum), 16, 32, or some other size. It is computed by summing the bytes or words of the data block ignoring overflow. The checksum may be negated so that the total of the data words plus the checksum is zero.

QUESTION NO: 97

Data inference violations can be reduced using

- A. Polyinstantiation technique.
- B. Rules based meditation.
- C. Multi-level data classification.
- D. Correct-state transformation.

Answer: A

Explanation: "Polyinstantiation is the development of a detailed version of an object from another object using different values in the new object. In the database information security, this term is concerned with the same primary key for different relations at different classification levels being stored in the same database. For example, in a relational database, the same of a military unit may be classified Secret in the database and may have an identification number as the primary key. If another user at a lower classification level attempts to create a confidential entry for another military unit using the same identification number as a primary key, a rejection of this attempt would imply to the lower level user that the same identification number existed at a higher level of classification. To avoid this inference channel of information, the lower level user would be issued the same identification number for their unit and the database management system would manage this situation where the same primary key was used for different units." Pg 352-353 Krutz: The CISSP Prep Guide: Gold Edition.

"As with aggregation, the best defense against inference attacks is to maintain constant vigilance over the permissions granted to individual users. Furthermore, intentional blurring of data may be used to prevent the inference of sensitive information." – Ed Tittle CISSP Study Guide (sybex)

The other security issue is inference, which is very similar to aggregation. The inference problem happens when a subject deduces information that is restricted from data he has access to. This is seen when data at a lower security level indirectly portrays data at a higher level...This problem is usually dealt with in the development of the database by implementing content and context-dependent classification rules; this tracks the subject's query requests and restricts patterns that represent inference.

"Polyinstantiation is a process of interactively producing more detailed versions of objects by populating variables with values or other variables"- Shon Harris All-in-one CISSP Certification Guide pg 725-727

Topic 2, Security Architecture and Models

QUESTION NO: 98

What is it called when a computer uses more than one CPU in parallel to execute instructions?

- A. Multiprocessing
- B. Multitasking
- C. Multithreading
- D. Parallel running

Answer: A

Explanation:

QUESTION NO: 99

What is the main purpose of undertaking a parallel run of a new system?

- A. Resolve any errors in the program and file interfaces
- B. Verify that the system provides required business functionality
- C. Validate the operation of the new system against its predecessor
- D. Provide a backup of the old system

Answer: B

Explanation:

QUESTION NO: 100

Which of the following provide network redundancy in a local network environment?

- A. Mirroring
- B. Shadowing
- C. Dual backbones
- D. Duplexing

Answer: C

Explanation:

QUESTION NO: 101

A server farm is an example of:

- A. Server clustering
- B. Redundant servers
- C. Multiple servers
- D. Server fault tolerance

Answer: A

Explanation:

QUESTION NO: 102

In which state must a computer system operate to process input/output instructions?

- A. User mode
- B. Stateful inspection
- C. Interprocess communication
- D. Supervisor mode

Answer: D

Explanation: A computer is in a supervisory state when it is executing these privileged instructions. (privileged instructions are executed by the system administrator or by an individual who is authorized to use those instructions.) . -Ronald Krutz The CISSP PREP Guide (gold edition) pg 254-255

QUESTION NO: 103

What should be the size of a Trusted Computer Base?

- A. Small – in order to permit it to be implemented in all critical system components without using excessive resources.
- B. Small – in order to facilitate the detailed analysis necessary to prove that it meets design requirements.
- C. Large – in order to accommodate the implementation of future updates without incurring the time and expense of recertification.
- D. Large – in order to enable it to protect the potentially large number of resources in a typical

commercial system environment.

Answer: B

Explanation: "It must be small enough to be able to be tested and verified in a complete and comprehensive manner." Shon Harris All-In-One CISSP Certification Guide pg. 232-233.

QUESTION NO: 104

Which one of the following are examples of security and controls that would be found in a "trusted" application system?

- A. Data validation and reliability
- B. Correction routines and reliability
- C. File integrity routines and audit trail
- D. Reconciliation routines and data labels

Answer: C

Explanation: I have no specific reference for this question but the major resources hammer that there needs to be methods to check the data for correctness.

QUESTION NO: 105

Which of the following is an operating system security architecture that provides flexible support for security policies?

- A. OSKit
- B. LOMAC
- C. SE Linux
- D. Flask

Answer: D

Explanation:

Flask is an operating system security architecture that provides flexible support for

security policies. The architecture was prototyped in the Fluke research operating system. Several of the Flask interfaces and components were then ported from the Fluke prototype to the OSKit. The Flask architecture is now being implemented in the Linux operating system (Security-Enhanced Linux) to transfer the technology to a larger developer and user community.

QUESTION NO: 106

Which of the following statements pertaining to the security kernel is incorrect?

- A.** It is made up of mechanisms that fall under the TCB and implements and enforces the reference monitor concept.
- B.** It must provide isolation for the processes carrying out the reference monitor concept and they must be tamperproof
- C.** It must be small enough to be able to be tested and verified in a complete and comprehensive manner
- D.** Is an access control concept, not an actual physical component

Answer: D

Explanation:

QUESTION NO: 107

What is a PRIMARY reason for designing the security kernel to be as small as possible?

- A.** The operating system cannot be easily penetrated by users.
- B.** Changes to the kernel are not required as frequently.
- C.** Due to its compactness, the kernel is easier to formally verify.
- D.** System performance and execution are enhanced.

Answer: C

Explanation: I disagree with the original answer which was B (changes to the kernel) and think it is C (Due to its compactness). However, use your best judgment based on knowledge and experience. Below is why I think it is C.

"There are three main requirements of the security kernel:

It must provide isolation for the processes carrying out the reference monitor concept and they must be tamperproof.

The reference monitor must be invoked for every access attempt and must be impossible to circumvent. Thus the reference monitor must be implemented in a complete and foolproof way.

It must be small enough to be able to be tested and verified in a complete and comprehensive manner." - Shon Harris All-in-one CISSP Certification Guide pg 232-233

QUESTION NO: 108

Which of the following implements the authorized access relationship between subjects and objects of a system?

- A. Security model
- B. Reference kernel
- C. Security kernel
- D. Information flow model

Answer: C

Explanation:

QUESTION NO: 109

The concept that all accesses must be mediated, protected from modification, and verifiable as correct is the concept of

- A. Secure model
- B. Security locking
- C. Security kernel
- D. Secure state

Answer: C

Explanation: A security kernel is defined as the hardware, firmware, and software elements of a trusted computing base that implements the reference monitor concept. A reference monitor is a

system component that enforces access controls on an object. Therefore, the reference monitor concept is an abstract machine that mediates all access of subjects to objects. The Security Kernel must:

Mediate all accesses

Be protected from modification

Be verified as correct.

-Ronald Krutz The CISSP PREP Guide (gold edition) pg 262

QUESTION NO: 110

What is an error called that causes a system to be vulnerable because of the environment in which it is installed?

- A. Configuration error
- B. Environmental error
- C. Access validation error
- D. Exceptional condition handling error

Answer: B

Explanation:

QUESTION NO: 111

Which of the following ensures that security is not breached when a system crash or other system failure occurs?

- A. trusted recovery
- B. hot swappable
- C. redundancy
- D. secure boot

Answer: A

Explanation: "Trusted Recovery

When an operating system or application crashes or freezes, it should not put the system in any time of secure state." Pg 762 Shon Harris: All-In-One CISSP Certification Exam Guide

QUESTION NO: 112

What type of subsystem is an application program that operates outside the operating system and carries out functions for a group of users, maintains some common data for all users in the group, and protects the data from improper access by users in the group?

- A. Prevented subsystem
- B. Protected subsystem
- C. File subsystem
- D. Directory subsystem

Answer: B

Explanation:

QUESTION NO: 113

A 'Pseudo flaw' is which of the following?

- A. An apparent loophole deliberately implanted in an operating system
- B. An omission when generating Pseudo-code
- C. Used for testing for bounds violations in application programming
- D. A Normally generated page fault causing the system halt

Answer: A

Explanation:

QUESTION NO: 114

Which of the following yellow-book defined types of system recovery happens after a system fails in an uncontrolled manner in response to a TCB or media failure and the system cannot be brought to a consistent state?

- A. Recovery restart
- B. System reboot
- C. Emergency system restart
- D. System Cold start

Answer: C

Reference: "Emergency system restart is done after a system fails in an uncontrolled manner in response to a TCB or media failure. In such cases, TCB and user objects on nonvolatile storage belonging to processes active at the time of TCB or media failure may be left in an inconsistent state. The system enters maintenance mode, recovery is performed automatically, and the system restarts with no user processes in progress after bringing up the system in a consistent state."

QUESTION NO: 115

Which one of the following describes a reference monitor?

- A. Access control concept that refers to an abstract machine that mediates all accesses to objects by subjects.
- B. Audit concept that refers to monitoring and recording of all accesses to objects by subjects.
- C. Identification concept that refers to the comparison of material supplied by a user with its reference profile.
- D. Network control concept that distributes the authorization of subject accesses to objects.

Answer: A

Explanation: A reference monitor is a system component that enforces access controls on an object. Therefore, the reference monitor concept is an abstract machine that mediates all access of subjects to objects -Ronald Krutz The CISSP PREP Guide (gold edition) pg 262

QUESTION NO: 116

What can best be described as an abstract machine which must mediate all access to subjects to objects?

- A. A security domain
- B. The reference monitor

- C. The security kernel
- D. The security perimeter

Answer: B

Reference: pg 882 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 117

What is the PRIMARY component of a Trusted Computer Base?

- A. The computer hardware
- B. The security subsystem
- C. The operating system software
- D. The reference monitor

Answer: D

Explanation: "The security kernel is made up of hardware, software, and firmware components that fall within the TCB and implements and enforces the reference monitor concept. The security kernel mediates all access and functions between subjects and objects. The security kernel is the core of the TCB and is the most commonly used approach to building trusted computing systems. There are three main requirements of the security kernel:

- It must provide isolation for the processes carrying out the reference monitor concept, and the processes must be tamperproof.
- It must be invoked for every access attempt and must be impossible to circumvent. Thus, the security kernel must be implemented in a complete and foolproof way.
- It must be small enough to be able to be tested and verified in a complete and comprehensive manner.

These are the requirements of the reference monitor; therefore, they are the requirements of the components that provide and enforce the reference monitor concept—the security kernel." – Shon Harris, "CISSP All-in-One Exam Guide", 3rd Ed, p

QUESTION NO: 118

Which of the following is best defined as a mode of system termination that automatically leaves

system processes and components in a secure state when a failure occurs or is detected in the system?

- A. Fail proof
- B. Fail soft
- C. Fail safe
- D. Fail resilient

Answer: C

Explanation:

QUESTION NO: 119

LOMAC uses what Access Control method to protect the integrity of processes and data?

- A. Linux based EFS.
- B. Low Water-Mark Mandatory Access Control.
- C. Linux based NFS.
- D. High Water-Mark Mandatory Access Control.

Answer: B

Explanation:

LOMAC is a security enhancement for Linux that uses Low Water-Mark Mandatory Access Control to protect the integrity of processes and data from viruses, Trojan horses, malicious remote users and compromised root daemons. LOMAC is implemented as a loadable kernel module - no kernel recompilations or changes to existing applications are required. Although not all the planned features are currently implemented, it presently provides sufficient protection to thwart script-kiddies, and is stable enough for everyday use.

QUESTION NO: 120

On Linux, LOMAC is implemented as:

- A. Virtual addresses
- B. Registers
- C. Kernel built in functions
- D. Loadable kernel module

Answer: D

Explanation:

LOMAC is a security enhancement for Linux that uses Low Water-Mark Mandatory Access Control to protect the integrity of processes and data from viruses, Trojan horses, malicious remote users and compromised root daemons. LOMAC is implemented as a loadable kernel module - no kernel recompilations or changes to existing applications are required. Although not all the planned features are currently implemented, it presently provides sufficient protection to thwart script-kiddies, and is stable enough for everyday use.

"Security Kernel - The hardware, firmware, and software elements of a trusted computing base (TCB) that implements the reference monitor concept. It must mediate all accesses between subjects and objects, be protected from modification, and be verifiable as correct." - Shon Harris All-in-one CISSP Certification Guide pg 355

QUESTION NO: 121

LOMAC is a security enhancement for what operating system?

- A. Linux
- B. Netware
- C. Solaris

Answer: A

Explanation:

LOMAC is a security enhancement for Linux that uses Low Water-Mark Mandatory Access Control to protect the integrity of processes and data from viruses, Trojan horses, malicious remote users and compromised root daemons. LOMAC is implemented as a loadable kernel module - no kernel recompilations or changes to existing applications are required. Although not all the planned features are currently implemented, it presently provides sufficient protection to thwart script-kiddies, and is stable enough for everyday use.

QUESTION NO: 122

What was introduced for circumventing difficulties in classic approaches to computer security by limiting damages produced by malicious programs?

- A. Integrity-preserving
- B. Reference Monitor
- C. Integrity-monitoring
- D. Non-Interference

Answer: B

Explanation:

"reference monitor ... mediates all access subjects have to objects ... protect the objects from unauthorized access and destructive modification" , Ibid p 273

Reference monitor is part of the TCB concept

Not D: "noninterference ... is implemented to ensure that any actions that take place at a higher security level do not affect ... actions that take place at a lower level", Harris, 3rd Ed, p 290.

It is part of the information flow model.

QUESTION NO: 123

A feature deliberately implemented in an operating system as a trap for intruders is called a:

- A. Trap door
- B. Trojan horse
- C. Pseudo flaw
- D. Logic bomb

Answer: C

Explanation:

"An apparent loophole deliberately implanted in an operating system program as a trap for

intruders." As defined by the Aqua Book NCSC-TG-004 a pseudo-flaw is an apparent loophole deliberately implanted in an operating system program as a trap for intruders. Answer from <http://www.cccure.org>

QUESTION NO: 124

Fault tolerance countermeasures are designed to combat threats to

- A. an uninterruptible power supply
- B. backup and retention capability
- C. design reliability
- D. data integrity

Answer: C

Explanation:

QUESTION NO: 125

A 'Psuedo flaw' is which of the following?

- A. An apparent loophole deliberately implanted in an operating system program as a trap for intruders
- B. An omission when generating Psuedo-code
- C. Used for testing for bounds violations in application programming
- D. A normally generated page fault causing the system to halt

Answer: A

Explanation:

QUESTION NO: 126

What Distributed Computing Environment (DCE) component provides a mechanism to ensure that services are made available only to properly designated parties?

- A. Directory Service
- B. Remote Procedure Call Service
- C. Distributed File Service
- D. Authentication and Control Service

Answer: A

Explanation: A directory service has a hierarchical database of users, computers, printers, resources, and attributes of each. The directory is mainly used for lookup operations, which enable users to track down resources and other users...The administrator can then develop access control, security, and auditing policies that dictate who can access these objects, how the objects can be accessed, and audit each of these actions. - Shon Harris All-in-one CISSP Certification Guide pg 436-437

QUESTION NO: 127

What can be accomplished by storing on each subject a list of rights the subject has for every object?

- A. Object
- B. Capabilities
- C. Key ring
- D. Rights

Answer: B

Explanation:

Capabilities are accomplished by storing on each subject a list of rights the subject has for every object. This effectively gives each user a key ring. To remove access to a particular object, every user (subject) that has access to it must be "touched". A touch is an examination of a user's rights to that object and potentially removal of rights. This brings back the problem of sweeping changes in access rights.

QUESTION NO: 128

In the Information Flow Model, what relates two versions of the same object?

- A. Flow
- B. State
- C. Transformation
- D. Successive points

Answer: A

Explanation:

A flow is a type of dependency that relates two versions of the same object, and thus the transformation of one state of that object into another, at successive points in time.

QUESTION NO: 129

What is a security requirement that is unique to Compartmented Mode Workstations (CMW)?

- A. Sensitivity Labels
- B. Object Labels
- C. Information Labels
- D. Reference Monitors

Answer: C

Explanation:

QUESTION NO: 130

The Common Criteria (CC) represents requirements for IT security of a product or system under which distinct categories?

- A. Functional and assurance
- B. Protocol Profile (PP) and Security Target (ST)
- C. Targets of Evaluation (TOE) and Protection Profile (PP)
- D. Integrity and control

Answer: A

Explanation: "Like other evaluation criteria before it, Common Criteria works to answer two basic and general questions about products being evaluated: what does it do (functionality), and how sure are you of that (assurance)?" pg 232 Shon Harris CISSP All-In-One Certification Exam Guide

QUESTION NO: 131

What are the assurance designators used in the Common Criteria (CC)?

- A. EAL 1, EAL 2, EAL 3, EAL 4, EAL 5, EAL 6, and EAL 7
- B. A1, B1, B2, B3, C2, C1, and D
- C. E0, E1, E2, E3, E4, E5, and E6
- D. AD0, AD1, AD2, AD3, AD4, AD5, and AD6

Answer: A

Explanation: Original Answer was C. This is wrong in my view as the original answer confused ITSEC with the CC per the following

The Common criteria terminology for the degree of examination of the product to be tested is the Evaluation Assurance level (EAL). EALs range from EA1 (functional testing to EA7 (detailed testing and formal design verification). -Ronald Krutz The CISSP PREP Guide (gold edition) pg 266-267

Note that Shon Harris All-in-one CISSP Certification Guide uses EAL (not just EA).

EALs are combinations of assurance components. They also can be conveniently compared to TSCEC and ITSEC. Like these security evaluation criteria, EALs are scaled with from EAL1 through EAL7. Other EALs exist, but EAL 7 is the highest with international recognition. - Roberta Bragg Cissp Certification Training Guide (que) pg 368

ITSEC separately evaluates functionality and assurance, and it includes 10 functionality classes (f), eight assurance levels (q), seven levels of correctness (e), and eight basic security functions in its criteria.). -Ronald Krutz The CISSP PREP Guide (gold edition) pg 266

QUESTION NO: 132

Which of the following uses protection profiles and security targets?

- A. ITSEC
- B. TCSEC
- C. CTCPEC
- D. International Standard 15408

Answer: D

Explanation: “For historical and continuity purposes, ISO has accepted the continued use of the term “Common Criteria” (CC) within this document, while recognizing the official ISO name for the new IS 15408 is “Evaluation Criteria for Information Technology Security.” Pg. 552 Krutz: The CISSP Prep Guide: Gold Edition

“The Common Criteria define a Protection Profile (PP), which is an implementation-independent specification of the security requirements and protections of a product that could be built. The Common Criteria terminology for the degree of examination of the product to be tested is the Evaluation Assurance Level (EAL). EALs range from EA1 (functional testing) to EA7 (detailed testing and formal design verification). The Common Criteria TOE refers to the product to be tested. A Security Target (ST) is a listing of the security claims for a particular IT security product. Also, the Common Criteria describe an intermediate grouping of security requirement components as a package.” Pg. 266-267 Krutz: The CISSP Prep Guide: Gold Edition

QUESTION NO: 133

According to Common Criteria, what can be described as an intermediate combination of security requirement components?

- A. Protection profile (PP)
- B. Security target (ST)
- C. Package
- D. The Target of Evaluation (TOE)

Answer: C

Explanation: “The Common Criteria define a Protection Profile (PP), which is an implementation-independent specification of the security requirements and protections of a product that should be built. The Common Criteria terminology for the degree of examination of the product to be tested is the Evaluation Assurance Level (EAL.) EALs range from EA1 (functional testing) to EA7 (detailed testing and formal design verification). The Common Criteria TOE refers to the product to be tested. A Security Target (ST) is a listing of the security claims for a particular IT security product. Also, the Common Criteria describe an intermedicate grouping of security requirement components as a package.”

Pg. 266- 267 Krutz: The CISSP Prep Guide: Gold Edition

QUESTION NO: 134

The Common Criteria construct which allows prospective consumers or developers to create standardized sets of security requirements to meet their needs is

- A.** a Protection Profile (PP).
- B.** a Security Target (ST).
- C.** an evaluation Assurance Level (EAL).
- D.** a Security Functionality Component Catalog (SFCC).

Answer: A

Explanation: Protection Profiles: The Common Criteria uses protection profiles to evaluate products. The protection profile contains the set of security requirements, their meaning and reasoning, and the corresponding EAL rating. The profile describes the environmental assumptions, the objectives, and functional and assurance level expectations. Each relevant threat is listed along with how it is to be controlled by specific objectives. It also justifies the assurance level and requirements for the strength of each protection mechanism. The protection profile provides a means for the consumer, or others, to identify specific security needs; this is the security problem to be conquered.

EAL: An evaluation is carried out on a product and is assigned an evaluation assurance level (EAL). The thoroughness and stringent testing increases in detailed-oriented tasks as the levels increase. The Common Criteria has seven assurance levels. The ranges go from EAL1, where the functionality testing takes place, to EAL7, where thorough testing is performed and the system is verified.

All-In-One CISSP Certification Exam Guide by Shon Harris pg. 262

Note: "The Common Criteria defines a Protection Profile (PP), which is an implementation-independent specification of the security requirements and protections of a product that could be built. The Common Criteria terminology for the degree of examination of the product to be tested is the Evaluation Assurance Level (EAL). EALs range from EA1 (functional testing) to EA7 (detailed testing and formal design verification). The Common Criteria TOE [target of evaluation] refers to the product to be tested. A Security Target (ST) is a listing of the security claims for a particular IT security product." -Ronald Krutz The CISSP PREP Guide (gold edition) pg 266-267

QUESTION NO: 135

The Information Technology Security Evaluation Criteria (ITSEC) was written to address which of the following that the Orange Book did not address?

- A. integrity and confidentiality
- B. confidentiality and availability
- C. integrity and availability
- D. none of the above

Answer: C

Explanation: "ITSECTCSEC (Orange Book)

E0D

F1+E1C1

F2+E2C2

F3+E3B1

F4+E4B2

F5+E5B3

F5+E6A1

F6=Systems that provide high integrity

F7=Systems that provide high availability

F8=Systems that provide data integrity during communication

F9=Systems that provide high confidentiality

F10=Networks with high demands on confidentiality and integrity"

Pg. 230 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 136

Which of the following was developed by the National Computer Security Center (NCSC)?

- A. TCSEC
- B. ITSEC
- C. DITSCAP
- D. NIACAP

Answer: A

Reference: pg 129 Hansche: Official (ISC)2 Guide to the CISSP Exam

QUESTION NO: 137

The Trusted Computer Security Evaluation Criteria (TBSEC) provides

- A.** a basis for assessing the effectiveness of security controls built into automatic data-processing system products
- B.** a system analysis and penetration technique where specifications and document for the system are analyzed.
- C.** a formal static transition model of computer security policy that describes a set of access control rules.
- D.** a means of restricting access to objects based on the identity of subjects and groups to which they belong.

Answer: A

Explanation: TBSEC provides guidelines to be used with evaluating a security product. The TBSEC guidelines address basic security functionality and allow evaluators to measure and rate the functionality of a system and how trustworthy it is. Functionality and assurance are combined and not separated, as in criteria developed later. TCSEC guidelines can be used for evaluating vendor products or by vendors to design necessary functionality into new products. CISSP Study Guide by Tittel pg. 413.

QUESTION NO: 138

Which Orange Book evaluation level is described as "Verified Design"?

- A.** A1
- B.** B3
- C.** B2
- D.** B1

Answer: A

Explanation:

QUESTION NO: 139

Which of the following classes is defined in the TCSEC (Orange Book) as mandatory protection?

- A. B
- B. A
- C. C
- D. D

Answer: A

Explanation:

QUESTION NO: 140

Which Orange Book security rating requires that formal techniques are used to prove the equivalence between the TCB specifications and the security policy model?

- A. B2
- B. B3
- C. A1
- D. A2

Answer: C

Reference: Pg 226 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 141

According to the Orange Book, which security level is the first to require trusted recovery?

- A. A1
- B. B2
- C. B3
- D. B1

Answer: C

Explanation: "Trusted recovery is required only for B3 and A1 level systems." Pg 305 Krutz: CISSP Prep Guide: Gold Edition.

QUESTION NO: 142

According to the Orange Book, which security level is the first to require a system to protect against covert timing channels?

- A. A1
- B. B3
- C. B2
- D. B1

Answer: C

Explanation: http://en.wikipedia.org/wiki/Trusted_Computer_System_Evaluation_Criteria

QUESTION NO: 143

Which of the following is not an Orange Book-defined operational assurance requirement?

- A. System architecture
- B. Trusted facility management
- C. Configuration management
- D. Covert channel analysis

Answer: C

Explanation: Systems Integrity is a part of operational assurance opposed to life cycle assurance.

"The operational assurance requirements specified in the Orange Book are as follows:

System Architecture

System integrity

Covert channel analysis

Trusted facility management

Trusted recovery

The life cycle assurance requirements specified in the Orange Book are as follows:

Security testing

Design specification and testing

Configuration Management

Trusted Distribution"

Pg. 301 Krutz: The CISSP Prep Guide: Gold Edition.

QUESTION NO: 144

Which of the following is least likely to be found in the Orange Book?

- A. Security policy
- B. Documentation
- C. Accountability
- D. Networks and network components

Answer: D

Explanation:

QUESTION NO: 145

According to the Orange Book, which security level is the first to require a system to support separate operator and system administrator rules?

- A. A1
- B. B1
- C. B2
- D. B3

Answer: C

Explanation:

QUESTION NO: 146

Which of the following is not an Orange book-defined life cycle assurance requirement?

- A. Security testing
- B. Design specification and testing
- C. Trusted distribution
- D. System integrity

Answer: D

Explanation: Systems Integrity is a part of operational assurance opposed to life cycle assurance.

"The operational assurance requirements specified in the Orange Book are as follows:

System Architecture

System integrity

Covert channel analysis

Trusted facility management

Trusted recovery

The life cycle assurance requirements specified in the Orange Book are as follows:

Security testing

Design specification and testing

Configuration Management

Trusted Distribution"

Pg. 301 Krutz: The CISSP Prep Guide: Gold Edition.

QUESTION NO: 147

At what Trusted Computer Security Evaluation Criteria (TCSEC) or Information Technology Security Evaluation Criteria (ITSEC) security level are database elements FIRST required to have security labels?

A. A1/E6

B. B1/E3

C. B2/E4

D. C2/E2

Answer: B

Explanation: "B1: Labeled Security

Each data object must contain a classification label and each subject must have a clearance label. When a subject attempts to access an object, the system must compare the subject and object's security labels to ensure the requested actions are acceptable. Data leaving the system must also contain an accurate security label. The security policy is based on an informal statement and the design specifications are reviewed and verified. It is intended for environments that require systems to handle classified data."

" pg. 224-226 Shon Harris: All-In-One CISSP Certification Exam Guide

QUESTION NO: 148

Which of the following statements pertaining to the Trusted Computer System Evaluation Criteria (TCSEC) is incorrect?

- A. With TCSEC, functionality and assurance are evaluated separately.
- B. TCSEC provides a means to evaluate the trustworthiness of an information system
- C. The Orange Book does not cover networks and communications
- D. Database management systems are not covered by the TCSEC

Answer: A

Explanation:

QUESTION NO: 149

Which of the following is the lowest TCSEC class wherein the systems must support separate operator and system administrator roles?

- A. B2
- B. B1
- C. A1
- D. A2

Answer: A

Reference: pg 129 Hansche: Official (ISC)2 Guide to the CISSP Exam

QUESTION NO: 150

Which TCSEC (Orange Book) level requires the system to clearly identify functions of security administrator to perform security-related functions?

- A. C2

- B. B1
- C. B2
- D. B3

Answer: D

Explanation: B1: Labeled Security

Each data object must contain a classification label and each subject must have a clearance label. When a subject attempts to access an object, the system must compare the subject and object's security labels to ensure the requested actions are acceptable. Data leaving the system must also contain an accurate security label. The security policy is based on an informal statement and the design specifications are reviewed and verified. It is intended for environments that require systems to handle classified data.

B2: Structured Protection

The security policy is clearly defined and documented, and the system design and implementation are subjected to more thorough review and testing procedures. This class requires more stringent authentication mechanisms and well-defined interfaces among layers. Subjects and devices require labels, and the system must not allow covert channels. A trusted path for logon and authentication processes must be in place, which means there are no trapdoors. A trusted path means that the subject is communicating directly with the application or operating system. There is no way to circumvent or compromise this communication channel. There is a separation of operator and administration functions within the system to provide more trusted and protected operational functionality. Distinct address spaces must be provided to isolate processes, and a covert channel analysis is conducted. This class adds assurance by adding requirements to the design of the system.

The environment that would require B2 systems could process sensitive data that require a higher degree of security. This environment would require systems that are relatively resistant to penetration and compromise.

(A trusted path means that the user can be sure that he is talking to a genuine copy of the operating system.)

B3: Security Domains

In this class, more granularity is provided in each protection mechanism, and the programming code that is not necessary to support the security policy is excluded. The design and implementation should not provide too much complexity because as the complexity of a system increases, the ability of the individuals who need to test, maintain, and configure it reduces; thus, the overall security can be threatened. The reference monitor components must be small enough to test properly and be tamperproof. The security administrator role is clearly defined, and the system must be able to recover from failures without its security level being compromised. When the system starts up and loads its operating system and components, it must be done in an initial secure state to ensure that any weakness of the system cannot be taken advantage of in this slice of time. " pg. 226 Shon Harris: All-In-One CISSP Certification Exam Guide

QUESTION NO: 151

Which of the following statements pertaining to the trusted computing base (TCB) is false?

- A. It addresses the level of security a system provides
- B. It originates from the Orange Book
- C. It includes hardware, firmware, and software
- D. A higher TCB rating will require that details of their testing procedures and documentation be reviewed with more granularity

Answer: A

Explanation:

QUESTION NO: 152

Which of the following is not an Orange book-defined operational assurance requirement?

- A. System architecture
- B. Trusted facility management
- C. Configuration management
- D. Covert channel analysis

Answer: C

Explanation: Configuration management is a part of life cycle assurance opposed to operational assurance.

"The operational assurance requirements specified in the Orange Book are as follows:

System Architecture

System integrity

Covert channel analysis

Trusted facility management

Trusted recovery

The life cycle assurance requirements specified in the Orange Book are as follows:

Security testing

Design specification and testing
Configuration Management
Trusted Distribution"

Pg. 301 Krutz: The CISSP Prep Guide: Gold Edition.

QUESTION NO: 153

Which of the following focuses on the basic features and architecture of a system?

- A. operational assurance
- B. life cycle assurance
- C. covert channel assurance
- D. level A1

Answer: A

Explanation: "The operational assurance requirements specified in the Orange Book are as follows:

System Architecture
System integrity
Covert channel analysis
Trusted facility management
Trusted recovery"

Pg. 301 Krutz: The CISSP Prep Guide: Gold Edition

QUESTION NO: 154

Which level(s) must protect against both covert storage and covert timing channels?

- A. B3 and A1
- B. B2, B3 and A1
- C. A1
- D. B1, B2, B3 and A1

Answer: A

Reference: pg 302 Krutz: CISSP Prep Guide: Gold Edition

QUESTION NO: 155

According to the Orange Book, trusted facility management is not required for which of the following security levels?

- A. B1
- B. B2
- C. B3
- D. A1

Answer: A

Explanation: B1 does not provide trusted facility management, the next highest level that does is B2.

"Trusted facility management is defined as the assignment of a specific individual to administer the security-related functions of a system. Although trusted facility management is an assurance requirement only for highly secure systems (B2, B3, and A1), many systems evaluated at lower security levels re structured to try to meet this requirement." Pg. 302 Krutz: The CISSP Prep Guide: Gold Edition

QUESTION NO: 156

Which factor is critical in all systems to protect data integrity?

- A. Data classification
- B. Information ownership
- C. Change control
- D. System design

Answer: A

Explanation: A Integrity is dependent on confidentiality, which relies on data classification. Also Biba integrity model relies on data classification.

“There are numerous countermeasures to ensure confidentiality against possible threats. These include the use of encryption, network traffic padding, strict access control, rigorous authentication procedures, data classification, and extensive personnel training.

Confidentiality and integrity are dependent upon each other. Without object integrity, confidentiality cannot be maintained. Other concepts, conditions, and aspects of confidentiality include sensitivity, discretion, criticality, concealment, secrecy, privacy, seclusion, and isolation.” Pg 145 Tittel: CISSP Study Guide.

“Biba Integrity Model

Integrity is usually characterized by the three following goals:

- 1.)The data is protected from modification by unauthorized users.
- 2.)The data is protected from unauthorized modification by authorized users.
- 3.)The data is internally and externally consistent; the data held in a database must balance internally and correspond to the external, real world situation.”

Pg. 277 Krutz: The CISSP Prep Guide: Gold Edition.

QUESTION NO: 157

Which of the following is not a common integrity goal?

- A.** Prevent unauthorized users from making modifications
- B.** Maintain internal and external consistency
- C.** Prevent authorized users from making improper modifications
- D.** Prevent paths that could lead to inappropriate disclosure

Answer: D

Explanation:

QUESTION NO: 158

Which security model introduces access to objects only through programs?

- A. The Biba model
- B. The Bell-LaPadula model
- C. The Clark-Wilson model
- D. The information flow model

Answer: C

Explanation: "The Clark-Wilson model is also an integrity-protecting model. The Clark-Wilson model was developed after Biba and approaches integrity protection from a different perspective. Rather than employing a lattice structure, it uses a three-part relationship of subject/program/object known as a triple. Subjects do not have direct access to objects. Objects can be access only through programs." Pg 347 Tittel: CISSP Study Guide

QUESTION NO: 159

To ensure that integrity is attained through the Clark and Wilson model, certain rules are needed. These rules are:

- A. Processing rules and enforcement rules.
- B. Integrity-bouncing rules.
- C. Certification rules and enforcement rules.
- D. Certification rules and general rules.

Answer: C

Explanation:

To ensure that integrity is attained and preserved, Clark and Wilson assert, certain integrity-monitoring and integrity-preserving rules are needed. Integrity-monitoring rules are called certification rules, and integrity-preserving rules are called enforcement rules.

QUESTION NO: 160

What can be defined as a formal security model for the integrity of subjects and objects in a system?

- A. Biba
- B. Bell LaPadulaLattice
- C. Lattice
- D. Info Flow

Answer: A

Explanation: The Handbook of Information System Management, 1999 Edition, ISBN: 0849399742 presents the following definition:

In studying the two properties of the Bell-LaPadula model, Biba discovered a plausible notion of integrity, which he defined as prevention of unauthorized modification. The resulting Biba integrity model states that maintenance of integrity requires that data not flow from a receptacle of given integrity to a receptacle of higher integrity. For example, if a process can write above its security level, trustworthy data could be contaminated by the addition of less trustworthy data. SANS glossary at <http://www.sans.org/newlook/resources/glossary.htm> define it as:
Formal security model for the integrity of subjects and objects in a system.

QUESTION NO: 161

The Clark Wilson model has its emphasis on:

- A. Security
- B. Integrity
- C. Accountability
- D. Confidentiality

Answer: B

Explanation:

This model attempts to capture security requirements of commercial applications. 'Military' and 'Commercial' are shorthand for different ways of using computers. This model has emphasis on integrity:

Internal consistency: properties of the internal state of a system

External consistency: relation of the internal state of a system to the outside world

QUESTION NO: 162

What does * (star) integrity axiom mean in the Biba model?

- A. No read up
- B. No write down
- C. No read down
- D. No write up

Answer: D

Explanation: "Biba has two integrity axioms:

QUESTION NO: 163

Which access control model states that for integrity to be maintained data must not flow from a receptacle of given integrity to a receptacle of higher integrity?

- A. Lattice Model
- B. Bell-LaPadula Model
- C. Biba Model
- D. Take-Grant Model

Answer: C

Explanation: If implemented and enforced properly, the Biba model prevents data from any integrity level from flowing to a higher integrity level. - Shon Harris All-in-one CISSP Certification Guide pg 244

QUESTION NO: 164

Which one of the following is a KEY responsibility for the "Custodian of Data"?

- A. Data content and backup
- B. Integrity and security of data
- C. Authentication of user access
- D. Classification of data elements

Answer: B

Explanation: Custodian - Preserves the information's CIA (chart) -Ronald Krutz The CISSP PREP Guide (gold edition) pg 15

QUESTION NO: 165

Which one of the following is true about information that is designated with the highest of confidentiality in a private sector organization?

- A. It is limited to named individuals and creates an audit trail.
- B. It is restricted to those in the department of origin for the information.
- C. It is available to anyone in the organization whose work relates to the subject and requires authorization for each access.
- D. It is classified only by the information security officer and restricted to those who have made formal requests for access.

Answer: C

Explanation:

QUESTION NO: 166

Related to information security, confidentiality is the opposite of which of the following?

- A. closure
- B. disclosure
- C. disposal
- D. disaster

Answer: B

Explanation:

QUESTION NO: 167

What is the main concern of the Bell-LaPadula security model?

- A. Accountability
- B. Integrity
- C. Confidentiality
- D. Availability

Answer: C

Explanation: "An important thing to note is that the Bell-LaPadula model was developed to make sure secrets stay secret; thus, it provides and addresses confidentiality only. This model does not address integrity of the data the system maintains – only who can and cannot access the data." Pg 214 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 168

Which of the following are the limitations of the Bell-LaPadula model?

- A. No policies for changing access data control.
- B. All of the choices.
- C. Contains covert channels.
- D. Static in nature.

Answer: B

Explanation:

Limitations of the BLP model:

Have no policies for changing access data control

Intended for systems with static security levels

Contains covert channels: a low subject can detect the existence of a high object when it is denied access. Sometimes it is not enough to hide the content of an object; also their existence may have to be hidden.

Restricted to confidentiality

QUESTION NO: 169

Which of the following is a state machine model capturing confidentiality aspects of access control?

- A. Clarke Wilson
- B. Bell-LaPadula
- C. Chinese Wall
- D. Lattice

Answer: B

Explanation:

Bell-LaPadula is a state machine model capturing confidentiality aspects of access control. Access permissions are defined through an Access Control matrix and through a partial ordering of security levels. Security policies prevent information flowing downwards from a high security level to a low security level. BLP only considers the information flow that occurs when a subject observes or alters an object.

QUESTION NO: 170

With the BLP model, access permissions are defined through:

- A. Filter rules
- B. Security labels
- C. Access Control matrix
- D. Profiles

Answer: C

Explanation:

Bell-LaPadula is a state machine model capturing confidentiality aspects of access control. Access permissions are defined through an Access Control matrix and through a partial ordering of security levels. Security policies prevent information flowing downwards from a high security level to a low security level. BLP only considers the

information flow that occurs when a subject observes or alters an object.

QUESTION NO: 171

With the BLP model, security policies prevent information flowing downwards from a:

- A. Low security level
- B. High security level
- C. Medium security level
- D. Neutral security level

Answer: B

Explanation:

Bell-LaPadula is a state machine model capturing confidentiality aspects of access control. Access permissions are defined through an Access Control matrix and through a partial ordering of security levels. Security policies prevent information flowing downwards from a high security level to a low security level. BLP only considers the information flow that occurs when a subject observes or alters an object.

QUESTION NO: 172

When will BLP consider the information flow that occurs?

- A. When a subject alters on object.
- B. When a subject accesses an object.
- C. When a subject observer an object.
- D. All of the choices.

Answer: D

Explanation:

Bell-LaPadula is a state machine model capturing confidentiality aspects of access control. Access permissions are defined through an Access Control matrix and through a

partial ordering of security levels. Security policies prevent information flowing downwards from a high security level to a low security level. BLP only considers the information flow that occurs when a subject observes or alters an object.

QUESTION NO: 173

In the Bell-LaPadula model, the Star-property is also called:

- A. The simple security property
- B. The confidentiality property
- C. The confinement property
- D. The tranquility property

Answer: C

Explanation:

QUESTION NO: 174

The Lattice Based Access Control model was developed MAINLY to deal with:

- A. Affinity
- B. None of the choices.
- C. Confidentiality
- D. Integrity

Answer: C

Explanation:

Page 349 of Harris' 5th edition references Bell-LaPadula model in the Lattice Based example. Bell-LaPadula is Confidentiality focused, not integrity focused.

QUESTION NO: 175

With the Lattice Based Access Control model, a security class is also called a:

- A. Control factor
- B. Security label
- C. Mandatory number
- D. Serial ID

Answer: B

Explanation:

The Lattice Based Access Control model was developed to deal mainly with information flow in computer systems. Information flow is clearly central to confidentiality but to some extent it also applies to integrity. The basic work in this area was done around 1970 and was driven mostly by the defense sector. Information flow in computer systems is concerned with flow from one security class (also called security label) to another. These controls are applied to objects. An object is a container of information, and an object can be a directory or file.

QUESTION NO: 176

Under the Lattice Based Access Control model, a container of information is a(n):

- A. Object
- B. Model
- C. Label

Answer: A

Explanation:

The Lattice Based Access Control model was developed to deal mainly with information flow in computer systems. Information flow is clearly central to confidentiality but to some extent it also applies to integrity. The basic work in this area was done around 1970 and was driven mostly by the defense sector. Information flow in computer systems is concerned with flow from one security class (also called security label) to another. These controls are applied to objects. An object is a container of information, and an object can be a directory or file.

QUESTION NO: 177

What Access Control model was developed to deal mainly with information flow in computer systems?

- A. Lattice Based
- B. Integrity Based
- C. Flow Based
- D. Area Based

Answer: A

Explanation:

The Lattice Based Access Control model was developed to deal mainly with information flow in computer systems. Information flow is clearly central to confidentiality but to some extent it also applies to integrity. The basic work in this area was done around 1970 and was driven mostly by the defense sector. Information flow in computer systems is concerned with flow from one security class (also called security label) to another. These controls are applied to objects. An object is a container of information, and an object can be a directory or file.

QUESTION NO: 178

The Lattice Based Access Control model was developed to deal mainly with _____ in computer systems.

- A. Access control
- B. Information flow
- C. Message routes
- D. Encryption

Answer: B

Explanation:

Information flow is clearly central to confidentiality but to some extent it also applies to integrity. The basic work in this area was done around 1970 and was driven mostly by the defense sector. Information flow in computer systems is concerned with flow from one security class (also called security label) to another. These controls are applied to objects. An object is a container of information, and an object can be a directory or file.

QUESTION NO: 179

In the Lattice Based Access Control model, controls are applied to:

- A. Scripts
- B. Objects
- C. Models
- D. Factors

Answer: B

Explanation:

Information flow is clearly central to confidentiality but to some extent it also applies to integrity. The basic work in this area was done around 1970 and was driven mostly by the defense sector. Information flow in computer systems is concerned with flow from one security class (also called security label) to another. These controls are applied to objects. An object is a container of information, and an object can be a directory or file.

QUESTION NO: 180

Access control techniques do not include:

- A. Rule-Based Access Controls
- B. Role-Based Access Controls
- C. Mandatory Access Controls
- D. Random Number Based Access Control

Answer: D

Explanation:

QUESTION NO: 181

An access control policy for a bank teller is an example of the implementation of which of the following?

- A. rule-based policy
- B. identity-based policy
- C. user-based policy
- D. role-based policy

Answer: D

Explanation:

QUESTION NO: 182

Access control techniques do not include which of the following choices?

- A. Relevant Access Controls
- B. Discretionary Access Controls
- C. Mandatory Access Controls
- D. Lattice Based Access Controls

Answer: A

Explanation: "Mandatory Access Control. The authorization of a subject's access to an object depends upon labels, which indicate the subject's clearance, and the classification or sensitivity of the object."

"Rule-based access control is a type of mandatory access control because rules determine this access, rather than the identity of the subjects and objects alone."

"Discretionary Access Control. The subject has authority, within certain limitations, to specify what objects are accessible."

"When a user with certain limitations has the right to alter the access control to certain objects, this is termed as user-directed discretionary access control."

"An identity-based access control is a type of a discretionary access control based on an

individual's identity."

"In some instances, a hybrid approach is used, which combines the features of user-based and identity-based discretionary access control."

"Non-discretionary Access Control. A Central authority determines what subjects can have access to certain objects based on the organizational security policy."

"The access controls might be based on the individuals role in the organization (role-based) or the subject's responsibilities and duties (task-based)."

"[Lattice-based] In this type of control, a lattice model is applied."

"Access control can be characterized as context-dependent or content dependent."

Pg. 45-46 Krutz: The CISSP Prep Guide: Gold Edition

QUESTION NO: 183

What is called a type of access control where a central authority determines what subjects can have access to certain objects, based on the organizational security policy?

- A.** Mandatory Access Control
- B.** Discretionary Access Control
- C.** Non-discretionary Access Control
- D.** Rule-based access control

Answer: C

Explanation: Non-Discretionary Access Control. A central authority determines what subjects can have access to certain objects based on organizational security policy. The access controls may be based on the individual's role in the organization (role-based) or the subject's responsibilities and duties (task-based).

Pg. 33 Krutz: The CISSP Prep Guide.

QUESTION NO: 184

In non-discretionary access control, a central authority determines what subjects can have access to certain objects based on the organizational security policy. The access controls may be based

on:

- A. the society's role in the organization
- B. the individual's role in the organization
- C. the group-dynamics as they relate to the individual's role in the organization
- D. the group-dynamics as they relate to the master-slave role in the organization

Answer: B

Explanation: Non-Discretionary Access Control. A central authority determines what subjects can have access to certain objects based on organizational security policy. The access controls may be based on the individual's role in the organization (role-based) or the subject's responsibilities and duties (task-based).

Pg. 33 Krutz: The CISSP Prep Guide.

QUESTION NO: 185

This is a common security issue that is extremely hard to control in large environments. It occurs when a user has more computer rights, permissions, and privileges than what is required for the tasks the user needs to fulfill. What best describes this scenario?

- A. Excessive Rights
- B. Excessive Access
- C. Excessive Permissions
- D. Excessive Privileges

Answer: D

Explanation:

QUESTION NO: 186

The default level of security established for access controls should be

- A. All access
- B. Update access
- C. Read access

D. No access

Answer: D

Explanation: "Need to Know and the Principle of Least Privilege are two standard axioms of high-security environments. A user must have a need-to-know to gain access to data or resources. Even if that user has an equal or greater security classification than the requested information, if they do not have a need-to-know, they are denied access. A need-to-know is the requirement to have access to, knowledge about, or possession of data or a resource to perform specific work tasks. The principle of least privilege is the notion that users should be granted the least amount of access to the secure environment as possible for them to be able to complete their work tasks."

Pg 399 Tittel: CISSP Study Guide

QUESTION NO: 187

Access Control techniques do not include which of the following choices?

- A. Relevant Access Controls**
- B. Discretionary Access Control**
- C. Mandatory Access Control**
- D. Lattice Based Access Controls**

Answer: A

Explanation:

QUESTION NO: 188

Which of the following is a type of mandatory access control?

- A. Rule-based access control**
- B. Role-based access control**
- C. User-directed access control**
- D. Lattice-based access control**

Answer: A

Reference: pg 46 Krutz: CISSP Prep Guide: Gold Edition

QUESTION NO: 189

A central authority determines what subjects can have access to certain objects based on the organizational security policy is called:

- A. Mandatory Access Control
- B. Discretionary Access Control
- C. Non-Discretionary Access Control
- D. Rule-based Access Control

Answer: C

Reference: pg 46 Krutz: CISSP Prep Guide: Gold Edition

QUESTION NO: 190

What can be defined as a table of subjects and objects indicating what actions individual subjects can take upon individual objects?

- A. A capacity table
- B. An access control list
- C. An access control matrix
- D. A capability table

Answer: C

Explanation:

QUESTION NO: 191

What access control methodology facilitates frequent changes to data permissions?

- A. Rule-based
- B. List-based
- C. Role-based
- D. Ticket-based

Answer: A

Explanation: RBAC - This type of model provides access to resources based on the role the users holds within the company or the tasks that user has been assigned. - Shon Harris All-in-one CISSP Certification Guide pg 937

Rule-based access control is a type of mandatory access control because rules determine this access (such as the correspondence of clearances labels to classification labels), rather than the identity of the subjects and objects alone. . -Ronald Krutz The CISSP PREP Guide (gold edition) pg 45-46

QUESTION NO: 192

Which of the following is a means of restricting access to objects based on the identity of the subject to which they belong?

- A. Mandatory access control
- B. Group access control
- C. Discretionary access control
- D. User access control

Answer: C

Explanation: The question does not ask about the identity of the accessing subject, the question refers to the subject to which the object belongs (ie the owner).

The owner setting the access rights is the definition of DAC.

"DAC systems grant or deny access based on the identity of the subject." Harris, 3rd Ed, p 163

QUESTION NO: 193

What is the method of coordinating access to resources based on the listening of permitted IP addresses?

- A. MAC
- B. ACL
- C. DAC
- D. None of the choices.

Answer: B

Explanation:

The definition of ACL: A method of coordinating access to resources based on the listing of permitted (or denied) users, network addresses or groups for each resource.

QUESTION NO: 194

What control is based on a specific profile for each user?

- A. Lattice based access control.
- B. Directory based access control.
- C. Rule based access control.
- D. ID based access control.

Answer: D

Explanation:

The correct answer should be ID based access control. Rule based isn't necessarily identity based.

QUESTION NO: 195

In a very large environment, which of the following is an administrative burden?

- A. Rule based access control.
- B. Directory based access control.
- C. Lattice based access control
- D. ID bases access control

Answer: D

Explanation:

QUESTION NO: 196

Which of the following is a feature of the Rule based access control?

- A. The use of profile.
- B. The use of information flow label.
- C. The use of data flow diagram.
- D. The use of token.

Answer: A

Explanation:

Rule based access control is based on a specific profile for each user. Information can be easily changed for only one user but this scheme may become a burden in a very large environment. A rule-based access control unit will intercept every request to the server and compare the source specific access conditions with the rights of the user in order to make an access decision. A good example could be a firewall. Here a set of rules defined by the network administrator is recorded in a file. Every time a connection is attempted (incoming or outgoing), the firewall software checks the rules file to see if the connection is allowed. If it is not, the firewall closes the connection.

QUESTION NO: 197

What is an access control model?

- A. A formal description of access control ID specification.
- B. A formal description of security policy.
- C. A formal description of a sensibility label.
- D. None of the choices.

Answer: B

Explanation:

What is an access control model? It is a formal description of a security policy. What is a security policy? A security policy captures the security requirements of an enterprise or describes the steps that have to be taken to achieve security. Security models are used in security evaluation, sometimes as proofs of security.

QUESTION NO: 198

Which of the following is true about MAC?

- A. It is more flexible than DAC.
- B. It is more secure than DAC.
- C. It is less secure than DAC.
- D. It is more scalable than DAC.

Answer: B

Explanation:

Mandatory controls are access controls that are based on a policy that the user, and more importantly the processes running with that user's privileges, is not allowed to violate. An example of this is "Top Secret" data is configured so that regardless of what the user does, the data cannot be transmitted to someone who does not have "Top Secret" status. Thus no "trojan horse" program could ever do what the user is not allowed to do anyway. The restrictions of mandatory controls are (at least in normal mode) also applied to the user who in a discretionary system would be "root", or the superuser.

QUESTION NO: 199

Which of the following is true regarding a secure access model?

- A. Secure information cannot flow to a more secure user.

- B. Secure information cannot flow to a less secure user.
- C. Secure information can flow to a less secure user.
- D. None of the choices.

Answer: B

Explanation:

Access restrictions such as access control lists and capabilities sometimes are not enough. In some cases, information needs to be tightened further, sometimes by an authority higher than the owner of the information. For example, the owner of a top-secret document in a government office might deem the information available to many users, but his manager might know the information should be restricted further than that. In this case, the flow of information needs to be controlled -- secure information cannot flow to a less secure user.

QUESTION NO: 200

In the Information Flow Model, what acts as a type of dependency?

- A. State
- B. Successive points
- C. Transformation
- D. Flow

Answer: D

Explanation:

A flow is a type of dependency that relates two versions of the same object, and thus the transformation of one state of that object into another, at successive points in time.

QUESTION NO: 201

A firewall can be classified as a:

- A. Directory based access control.
- B. Rule based access control.
- C. Lattice based access control.
- D. ID based access control.

Answer: B

Explanation:

Rule based access control is based on a specific profile for each user. Information can be easily changed for only one user but this scheme may become a burden in a very large environment. A rule-based access control unit will intercept every request to the server and compare the source specific access conditions with the rights of the user in order to make an access decision. A good example could be a firewall. Here a set of rules defined by the network administrator is recorded in a file. Every time a connection is attempted (incoming or outgoing), the firewall software checks the rules file to see if the connection is allowed. If it is not, the firewall closes the connection.

QUESTION NO: 202

Which of the following are the two most well known access control models?

- A. Lattice and Biba
- B. Bell LaPadula and Biba
- C. Bell LaPadula and Chinese war
- D. Bell LaPadula and Info Flow

Answer: B

Explanation:

The two most well known models are Bell&LaPadula [1973] and Biba[1977]. Both were designed in and for military environments.

QUESTION NO: 203

What security model implies a central authority that determines what subjects can have access to

what objects?

- A. Centralized access control
- B. Discretionary access control
- C. Mandatory access control
- D. Non-discretionary access control

Answer: D

Explanation: A role-based access control (RBAC) model, also called nondiscretionary access control, uses a centrally administrated set of controls to determine how subjects and objects interact. – Shon Harris, "CISSP All-in-One Exam Guide", 3rd Ed, p 165.

QUESTION NO: 204

Which of the following is best known for capturing security requirements of commercial applications?

- A. Lattice
- B. Biba
- C. Bell LaPadula
- D. Clark and Wilson

Answer: D

Explanation:

This model attempts to capture security requirements of commercial applications. 'Military' and 'Commercial' are shorthand for different ways of using computers. This model has emphasis on integrity:
Internal consistency: properties of the internal state of a system
External consistency: relation of the internal state of a system to the outside world

QUESTION NO: 205

Which of the following is a straightforward approach that provides access rights to subjects for objects?

- A. Access Matrix model
- B. Take-Grant Model
- C. Bell-LaPadula Model
- D. Biba Model

Answer: A

Explanation: "The access matrix is a straightforward approach that provides access rights to subjects for objects. Access rights are of the type read, write, and execute. A subject is an active entity that is seeking rights to a resource or object. A subject can be a person, a program, or a process. An object is a passive entity, such as a file or a storage resource." Pg 272 Krutz: CISSP Prep Guide: Gold Edition.

QUESTION NO: 206

What is called the type of access control where there are pairs of elements that have the least upper bound of values and greatest lower bound of values?

- A. Mandatory model
- B. Discretionary model
- C. Lattice model
- D. Rule model

Answer: C

Explanation: Lattice-based access control provides an upper bound and lower bound of access capabilities for every subject and object relationship.

Pg 156 Shon Harris All-In-One CISSP Certification Exam Guide

QUESTION NO: 207

Which access control would a lattice-based access control be an example of?

- A. Mandatory access control
- B. Discretionary access control
- C. Non-discretionary access control
- D. Rule-based access control

Answer: A

Explanation:

QUESTION NO: 208

Who developed one of the first mathematical models of a multilevel-security computer system?

- A. Diffie Hillman
- B. Clark and Wilson
- C. Bell and LaPadula
- D. Gasser and Lipner

Answer: C

Explanation:

QUESTION NO: 209

Which of the following was the first mathematical model of multilevel security policy?

- A. Biba
- B. Take-Grant
- C. Bell-La Padula
- D. Clark Wilson

Answer: C

Explanation: "In the 1970's, the US military used time-sharing mainframe systems and was concerned about these systems and leakage of classified information. The Bell-LaPadula model was developed to address these concerns. It was the first mathematical model of a multilevel security policy used to define the concept of a secure state machine and modes of access and outline rules of access." Pg 212 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 210

Which security model allows the data custodian to grant access privileges to other users?

- A. Mandatory
- B. Bell-LaPadula
- C. Discretionary
- D. Clark-Wilson

Answer: C

Explanation: " Discretionary Access Control. The subject has authority, within certain limitations, to specify what objects are accessible." -Ronald Krutz The CISSP PREP Guide (gold edition) pg 46

QUESTION NO: 211

What is one issue NOT addressed by the Bell-LaPadula model?

- A. Information flow control
- B. Security levels
- C. Covert channels
- D. Access modes

Answer: C

Explanation: As with any model, the Bell-LaPadula model has some weaknesses. These are the major ones. The model considers normal channels of the information exchange and does not address covert channels. -Ronald Krutz The CISSP PREP Guide (gold edition) pg 275-276

QUESTION NO: 212

Which one of the following access control models associates every resource and every user of a resource with one of an ordered set of classes?

- A. Take-Grant model
- B. Biba model
- C. Lattice model
- D. Clark-Wilson model

Answer: C

Explanation: With a lattice model you first have to define a set of security classes that can be assigned to users or objects...After you have defined set of security classes, you define a set flow operations showing when information can flow from one class to another - Roberta Bragg Cissp Certification Training Guide (que) pg 23

QUESTION NO: 213

What scheme includes the requirement that the system maintain the separation of duty requirement expressed in the access control triples?

- A. Bella
- B. Lattice
- C. Clark-Wilson
- D. Bell-LaPadula

Answer: C

Explanation:

Separation of duty is necessarily determined by conditions external to the computer system. The Clark-Wilson scheme includes the requirement that the system maintain the separation of duty requirement expressed in the access control triples. Enforcement is on a per-user basis, using the user ID from the access control triple.

QUESTION NO: 214

The access matrix model consists of which of the following parts? (Choose all that apply)

- A. A function that returns an objects type.

- B. A list of subjects.
- C. A list of objects.

Answer: A,B,C

Explanation:

The access matrix model consists of four major parts:

A list of objects

A list of subjects

A function T that returns an object's type

The matrix itself, with the objects making the columns and the subjects making the rows

Note: This question seems to confuse access control matrix, Harris, 3rd Ed, p 169 with access control types, Ibid, p 188ff

"An access control matrix is a table of subjects and objects indicating what actions ... subjects can take upon ... objects", Harris, 3rd Ed, p 169.

It would be right if item "A" was "a function that returned an access right"

QUESTION NO: 215

The access matrix model has which of the following common implementations?

- A. Access control lists and capabilities.
- B. Access control lists.
- C. Capabilities.
- D. Access control list and availability.

Answer: A

Explanation:

The two most used implementations are access control lists and capabilities. Access control lists are achieved by placing on each object a list of users and their associated rights to that object.

QUESTION NO: 216

The lattice-based model aims at protecting against:

- A. Illegal attributes.
- B. None of the choices.
- C. Illegal information flow among the entities.
- D. Illegal access rights

Answer: C

Explanation:

The lattice-based model aims at protecting against illegal information flow among the entities. One security class is given to each entity in the system. A flow relation among the security classes is defined to denote that information in one class can flow into another class.

QUESTION NO: 217

Which of the following are the components of the Chinese wall model?

- A. Conflict of interest.
- B. All of the choices.
- C. Subject
- D. Company Datasets.

Answer: B

Explanation:

The model has the following component:

COMPONENT EXAMPLE

Subject Analyst

Object Data item for a single client

Company Datasets Give for each company its own company dataset

Conflict of interest classes Give for each object companies that have a conflict of interest

Labels Company dataset + conflict of interest class

Sanitized information No access restriction

QUESTION NO: 218

Enforcing minimum privileges for general system users can be easily achieved through the use of:

- A. TSTEC
- B. RBAC
- C. TBAC
- D. IPSEC

Answer: B

Explanation:

Ensuring least privilege requires identifying what the user's job is, determining the minimum set of privileges required to perform that job, and restricting the user to a domain with those privileges and nothing more. By denying to subjects transactions that are not necessary for the performance of their duties, those denied privileges couldn't be used to circumvent the organizational security policy. Although the concept of least privilege currently exists within the context of the TCSEC, requirements restrict those privileges of the system administrator. Through the use of RBAC, enforced minimum privileges for general system users can be easily achieved.

QUESTION NO: 219

What is necessary for a subject to have write access to an object in a Multi-Level Security Policy?

- A. The subject's sensitivity label must dominate the object's sensitivity label
- B. The subject's sensitivity label subordinates the object's sensitivity label
- C. The subject's sensitivity label is subordinated by the object's sensitivity label
- D. The subject's sensitivity label is dominated by the object's sensitivity label

Answer: A

Explanation:

The correct answer is: The subject's sensitivity label must dominate the object's sensitivity label.

With a Multi-level security policy you have information that has different sensitivity labels. In order to read an object the subject's sensitivity label must be equal to or greater than that of the object. So it would be considered to dominate it, no read up.

The following answers are incorrect:

The subject's sensitivity label subordinates the object's sensitivity label. Is incorrect because if the subject's sensitivity label subordinates the object's sensitivity label that would mean it is lower and the subject should not have read access to the object.

The subject's sensitivity label is subordinated by the object's sensitivity label. Is incorrect because the this would not allow for read access if the sensitivity labels were equal. So the subject's sensitivity label is not subordinated by the object's sensitivity label, the subject's label must dominate the object's label. Remember dominate means equal to or greater than where subordinate means less than.

The subject's sensitivity label is dominated by the object's sensitivity label. Is incorrect because if the object's sensitivity label dominates the subject's sensitivity label then the subject should not have access, it is the subject that must dominate the object and not the other way around. Remember dominate means equal to or greater than so this would mean that the object's sensitivity label is equal to or greater than the subject.

According to the OIG, Multi-level security is defined as a class of system-containing information with different sensitivities that simultaneously permits access by users with different security clearances and need-to-know, but prevents users from obtaining access to information for which they lack authorization. The Subject's sensitivity label must be equal to or greater than the object's sensitivity label in order for the subject to have read access to it, no read up.

QUESTION NO: 220

Which of the following security modes of operation involved the highest risk?

- A.** Compartmented Security Mode
- B.** Multilevel Security Mode
- C.** System-High Security Mode
- D.** Dedicated Security Mode

Answer: B

Explanation: "Security Modes

In a secure environment, information systems are configured to process information in one of four security modes. These modes are set out by the Department of Defense as follows:

Systems running compartmental security mode may process two or more types of compartmented information. All system users must have an appropriate clearance to access all information processed by the system but do not necessarily have a need to know all of the information in the system. Compartments are subcategories or compartments within the different classification levels and extreme care is taken to preserve the information within the different compartments. The system may be classified at the Secret level but contain five different compartments, all classified Secret. If a user has only the need to know about two of the five different compartments to do their job, that user can access the system but can only access the two compartments. Compartmented systems are usually dedicated systems for each specific compartment to prevent the chance of any errors, because compartmentalization is the most secret of all the secrets.

Systems running in the dedicated security mode are authorized to process only a specific classification level at a time, and all system users must have clearance and a need to know that information.

Systems running in multilevel security mode are authorized to process information at more than one level of security even when all system users do not have appropriate clearances or a need to know for all information processed by the system.

Systems running in system-high security mode are authorized to process only information that all system users are cleared to read and to have a valid need to know. These systems are not trusted to maintain separation between security levels, and all information processed by these systems must be handled as if it were classified at the same level as the most highly classified information processed by the system."

Pg. 234 Tittel: CISSP Study Guide

QUESTION NO: 221

Controlled Security Mode is also known as:

- A.** Multilevel Security Mode
- B.** Partitioned Security Mode

- C. Dedicated Security Mode
- D. System-high Security Mode

Answer: A

Reference: pg 264 Krutz: CISSP Prep Guide: Gold Edition

QUESTION NO: 222

The unauthorized mixing of data of one sensitivity level and need-to-know with data of a lower sensitivity level, or different need-to-know, is called data

- A. Contamination
- B. Seepage
- C. Aggregation
- D. Commingling

Answer: A

Explanation: WOW if you are reading these comments then you know I have disagreed with a bunch of the original answers! Well here is another. The original was Seepage. I think it is Contamination.

"The intermixing of data at different sensitivity and need-to-know levels. The lower-level data is said to be contaminated by the higher-level data; thus contaminating (higher-level) data might not receive the required level of protection" -Ronald Krutz The CISSP PREP Guide (gold edition) pg 890

QUESTION NO: 223

Which one of the following should be employed to protect data against undetected corruption?

- A. Non-repudiation
- B. Encryption
- C. Authentication
- D. Integrity

Answer: D

Explanation:**QUESTION NO: 224**

Which of the following is a communication path that is not protected by the system's normal security mechanisms?

- A. A trusted path
- B. A protection domain
- C. A covert channel
- D. A maintenance hook

Answer: C

Explanation:**QUESTION NO: 225**

A channel within a computer system or network that is designed for the authorized transfer of information is identified as a(n)?

- A. Covert channel
- B. Overt channel
- C. Opened channel
- D. Closed channel

Answer: B

Explanation: "An overt channel is a channel of communication that was developed specifically for communication purposes. Processes should be communicating through overt channels, not covert channels." Pg 237 Shon Harris: All-In-One CISSP Certification Guide.

QUESTION NO: 226

Covert channel is a communication channel that can be used for:

- A. Hardening the system.
- B. Violating the security policy.
- C. Protecting the DMZ.
- D. Strengthening the security policy.

Answer: B

Explanation:

Covert channel is a communication channel that allows transfer of information in a manner that violates the system's security policy.

QUESTION NO: 227

What is an indirect way to transmit information with no explicit reading of confidential information?

- A. Covert channels
- B. Backdoor
- C. Timing channels
- D. Overt channels

Answer: A

Explanation:

Covert channels: indirect ways for transmitting information with no explicit reading of confidential information. This kind of difficulties induced some researchers to re-think from scratch the whole problem of guaranteeing security in computer systems.

QUESTION NO: 228

Which one of the following describes a covert timing channel?

- A. Modulated to carry an unintended information signal that can only be detected by special, sensitive receivers.
- B. Used by a supervisor to monitor the productivity of a user without their knowledge.
- C. Provides the timing trigger to activate a malicious program disguised as a legitimate function.

D. Allows one process to signal information to another by modulating its own use of system resources.

Answer: D

Explanation: A covert channel in which one process signals information to another by modulating its own use of system resources (for example, CPU time) in such a way that this manipulation affects the real response time observed by the second process. - Shon Harris All-in-one CISSP Certification Guide pg 929

QUESTION NO: 229

Covert channel analysis is required for

- A.** Systems processing Top Secret or classified information.
- B.** A Trusted Computer Base with a level of trust B2 or above.
- C.** A system that can be monitored in a supervisor state.
- D.** Systems that use exposed communication links.

Answer: B

Explanation: Table 6.6 Standards Comparison

B2 Structured Protection (covert channel, device labels, subject sensitivity labels, trusted path, trusted facility management, configuration management) F4+E4 EAL5 - Roberta Bragg CISSP Certification Training Guide (que) pg 370

QUESTION NO: 230

In multi-processing systems, which one of the following lacks mandatory controls and is NORMALLY AVOIDED for communication?

- A.** Storage channels
- B.** Covert channels
- C.** Timing channels
- D.** Object channels

Answer: B

Explanation: Covert channel - A communication path that enables a process to transmit information in a way that violates the system's security policy. - Shon Harris All-in-one CISSP Certification Guide pg 929

QUESTION NO: 231

What security risk does a covert channel create?

- A. A process can signal information to another process.
- B. It bypasses the reference monitor functions.
- C. A user can send data to another user.
- D. Data can be disclosed by inference.

Answer: B

Explanation: The risk is not that a process can signal another process. The risk is that the signaling bypasses the reference monitor functions (ie the communication is not screened by the security kernel that implements the reference monitor).

QUESTION NO: 232

What is the essential difference between a self-audit and an independent audit?

- A. Tools used
- B. Results
- C. Objectivity
- D. Competence

Answer: C

Explanation:

QUESTION NO: 233

What is called the formal acceptance of the adequacy of a system's overall security by the management?

- A. Certification
- B. Acceptance
- C. Accreditation
- D. Evaluation

Answer: C

Explanation:

QUESTION NO: 234

FIPS-140 is a standard for the security of:

- A. Cryptographic service providers
- B. Smartcards
- C. Hardware and software cryptographic modules
- D. Hardware security modules

Answer: C

Topic 3, Access

QUESTION NO: 235

Which of the following will you consider as the MOST secure way of authentication?

- A. Biometric
- B. Password
- C. Token
- D. Ticket Granting

Answer: A

Explanation:

Biometric authentication systems take advantage of an individual's unique physical characteristics in order to authenticate that person's identity. Various forms of biometric authentication include face, voice, eye, hand, signature, and fingerprint, each have their own advantages and disadvantages. When combined with the use of a PIN it can provide two factors authentication.

QUESTION NO: 236

In biometric identification systems, at the beginning, it was soon apparent that truly positive identification could only be based on physical attributes of a person. This raised the necessity of answering 2 questions:

- A.** what was the sex of a person and his age
- B.** what part of the body to be used and how to accomplish identification to be viable
- C.** what was the age of a person and his income level
- D.** what was the tone of the voice of a person and his habits

Answer: B

Explanation:

QUESTION NO: 237

What is called the percentage of invalid subjects that are falsely accepted?

- A.** False Rejection Rate (FRR) or Type I Error
- B.** False Acceptance Rate (FAR) or Type II Error
- C.** Crossover Error Rate (CER)
- D.** True Acceptance Rate (TAR) or Type III error

Answer: B

Explanation:

QUESTION NO: 238

Which of the following biometrics devices has the high Crossover Error Rate (CER)?

- A. Iris scan
- B. Hand Geometry
- C. Voice pattern
- D. Fingerprints

Answer: C

Explanation:

QUESTION NO: 239

Which of the following biometric parameters are better suited for authentication use over a long period of time?

- A. Iris pattern
- B. Voice pattern
- C. Signature dynamics
- D. Retina pattern

Answer: A

Explanation:

QUESTION NO: 240

Which one of the following is the MOST critical characteristic of a biometrics system?

- A. Acceptability
- B. Accuracy
- C. Throughput
- D. Reliability

Answer: B

Explanation: We don't agree with the original answer, which was throughput. Granted throughput is vital but Krutz lists accuracy is most important.

In addition to the accuracy of the biometric systems, there are OTHER factors that must also be considered. These factors include the enrollment time, the throughput rate, and acceptability. - Ronald Krutz The CISSP PREP Guide (gold edition) pg 51

QUESTION NO: 241

Which of the following biometric devices has the lowest user acceptance level?

- A. Voice recognition
- B. Fingerprint scan
- C. Hand geometry
- D. Signature recognition

Answer: B

Explanation:

QUESTION NO: 242

Biometric performance is most commonly measured in terms of:

- A. FRR and FAR
- B. FAC and ERR
- C. IER and FAR
- D. FRR and GIC

Answer: A

Explanation:

Biometric performance is most commonly measured in two ways: False Rejection Rate (FRR), and False Acceptance Rate (FAR). The FRR is the probability that you are not authenticated to access your account. A strict definition states that the FRR is the probability that a mated comparison (i.e. 2 biometric samples of the same finger) incorrectly determines that there is no match.

QUESTION NO: 243

What is the most critical characteristic of a biometric identifying system?

- A. Perceived intrusiveness
- B. Storage requirements
- C. Accuracy
- D. Reliability

Answer: C

Explanation:

QUESTION NO: 244

Which of the following biometric characteristics cannot be used to uniquely authenticate an individual's identity?

- A. Retina scans
- B. Iris scans
- C. Palm scans
- D. Skin scans

Answer: D

Explanation: Biometrics:

Fingerprints

Palm Scan

Hand Geometry

Retina Scan

Iris Scan

Signature Dynamics

Keyboard Dynamic

Voice Print

Facial Scan

Hand Topology

Pg. 128-130 Shon Harris All-In-One CISSP Certification Exam Guide

QUESTION NO: 245

In biometric identification systems, at the beginning, it was soon apparent that truly positive identification could only be based on physical attributes of a person. This raised the necessity of answering 2 questions:

- A. What was the sex of a person and his age
- B. what part of body to be used and how to accomplish identification to be viable
- C. what was the age of a person and his income level
- D. what was the tone of the voice of a person and his habits

Answer: B

Explanation:

QUESTION NO: 246

You are comparing biometric systems. Security is the top priority. A low _____ is most important in this regard.

- A. FAR
- B. FRR
- C. MTBF
- D. ERR

Answer: A

Explanation:

When comparing biometric systems, a low false acceptance rate is most important when security is the priority. Whereas, a low false rejection rate is most important when convenience is the priority. All biometric implementations balance these two criteria. Some systems use very high FAR's such as 1 in 300. This means that the likelihood that the system will accept someone other than the enrolled user is 1 in 300. However, the likelihood that the system will reject the enrolled user (its FRR) is very low, giving them ease of use, but with low security. Most fingerprint systems should be able to run with FARs of 1 in 10,000 or better.

QUESTION NO: 247

Almost all types of detection permit a system's sensitivity to be increased or decreased during an inspection process. To have a valid measure of the system performance:

- A. The CER is used.
- B. the FRR is used
- C. the FAR is used
- D. none of the above choices is correct

Answer: A

Explanation: "When a biometric system reject an authorized individual, it is called a Type 1 error. When the system accepts impostors who should be rejected, it is called a Type II error. The goal is to obtain low numbers for each type of error. When comparing different biometric systems, many different variables are used, but one of the most important variables is the crossover error rate (CER). This rating is stated in a percentage and represents the point at which the false rejection rate equals the false acceptance rate. This rating is the most important measurement when determining the system's accuracy." Pg 113 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 248

The quality of finger prints is crucial to maintain the necessary:

- A. FRR
- B. ERR and FAR
- C. FAR
- D. FRR and FAR

Answer: D

Explanation:

Another factor that must be taken into account when determining the necessary FAR and FRR for your organization is the actual quality of the fingerprints in your user population. ABC's experience with several thousand users, and the experience of its customers, indicates that a percentage of the populations do not have fingerprints of sufficient quality to allow for authentication of the individual. Approximately 2.5% of

employees fall into this group in the general office worker population. For these users, a smart card token with password authentication is recommended.

QUESTION NO: 249

By requiring the user to use more than one finger to authenticate, you can:

- A. Provide statistical improvements in EAR.
- B. Provide statistical improvements in MTBF.
- C. Provide statistical improvements in FRR.
- D. Provide statistical improvements in ERR.

Answer: C

Explanation:

Statistical improvements in false rejection rates can also be achieved by requiring the user to use more than one finger to authenticate. Such techniques are referred to as flexible verification.

QUESTION NO: 250

Which of the following is being considered as the most reliable kind of personal identification?

- A. Token
- B. Finger print
- C. Password
- D. Ticket Granting

Answer: B

Explanation:

Every person's fingerprint is unique and is a feature that stays with the person throughout his/her life. This makes the fingerprint the most reliable kind of personal identification because it cannot be forgotten, misplaced, or stolen. Fingerprint authorization is potentially the most affordable and convenient method of verifying a

person's identity.

QUESTION NO: 251

Which of the following methods is more microscopic and will analyze the direction of the ridges of the fingerprints for matching?

- A. None of the choices.
- B. Flow direct
- C. Ridge matching
- D. Minutia matching

Answer: D

Explanation:

There are two approaches for capturing the fingerprint image for matching: minutia matching and global pattern matching. Minutia matching is a more microscopic approach that analyzes the features of the fingerprint, such as the location and direction of the ridges, for matching. The only problem with this approach is that it is difficult to extract the minutiae points accurately if the fingerprint is in some way distorted. The more macroscopic approach is global pattern matching where the flow of the ridges is compared at all locations between a pair of fingerprint images; however, this can be affected by the direction that the image is rotated.

QUESTION NO: 252

Which of the following are the types of eye scan in use today?

- A. Retinal scans and body scans.
- B. Retinal scans and iris scans.
- C. Retinal scans and reflective scans.
- D. Reflective scans and iris scans.

Answer: B

Explanation:

There are two types of eye scan in use today for authentication purposes: retinal scans and iris scans. Retinal Scan technology maps the capillary pattern of the retina, a thin (1/50th inch) nerve on the back of the eye. To enroll, a minimum of five scans is required, which takes 45 seconds. The subject must keep his head and eye motionless within 1/2" of the device, focusing on a small rotating point of green light. 320 - 400 points of reference are captured and stored in a 35-byte field, ensuring the measure is accurate with a negligible false rejection rate.

This compares to 30-70 points of reference for a finger scan. Unfortunately a retinal scan is considerably more intrusive than an iris scans and many people are hesitant to use the device [Retina-scan]. In addition a significant number of people may be unable to perform a successful enrolment, and there exist degenerative diseases of the retina that alter the scan results over time. Despite these disadvantages, there are several successful implementations of this technology [Retina-scan].

QUESTION NO: 253

Which of the following eye scan methods is considered to be more intrusive?

- A. Iris scans
- B. Retinal scans
- C. Body scans
- D. Reflective scans

Answer: B

Explanation:

There are two types of eye scan in use today for authentication purposes: retinal scans and iris scans. Retinal Scan technology maps the capillary pattern of the retina, a thin (1/50th inch) nerve on the back of the eye. To enroll, a minimum of five scans is required, which takes 45 seconds. The subject must keep his head and eye motionless within 1/2" of the device, focusing on a small rotating point of green light. 320 - 400 points of reference are captured and stored in a 35-byte field, ensuring the measure is accurate with a negligible false rejection rate.

This compares to 30-70 points of reference for a finger scan. Unfortunately a retinal scan is considerably more intrusive than an iris scans and many people are hesitant to use the device [Retina-scan]. In addition a significant number of people may be unable

to perform a successful enrolment, and there exist degenerative diseases of the retina that alter the scan results over time. Despite these disadvantages, there are several successful implementations of this technology [Retina-scan].

QUESTION NO: 254

Which of the following offers greater accuracy than the others?

- A. Facial recognition
- B. Iris scanning
- C. Finger scanning
- D. Voice recognition

Answer: B

Explanation:

Iris scanning offers greater accuracy than finger scanning, voice or facial recognition, hand geometry or keystroke analysis. It is safer and less invasive than retinal scanning, an important legal consideration [Nugent]. Any company thinking of using biometrics would do well to ensure that they comply with existing privacy laws.

QUESTION NO: 255

In addition to the accuracy of the biometric systems, there are other factors that must also be considered:

- A. These factors include the enrollment time and the throughput rate, but not acceptability.
- B. These factors do not include the enrollment time, the throughput rate, and acceptability.
- C. These factors include the enrollment time, the throughput rate, and acceptability.
- D. These factors include the enrollment time, but not the throughput rate, neither the acceptability.

Answer: C

Explanation: In addition to the accuracy of the biometric systems, there are OTHER factors that must also be considered. These factors include the enrollment time, the throughput rate, and acceptability. -Ronald Krutz The CISSP PREP Guide (gold edition) pg 51

QUESTION NO: 256

What physical characteristics does a retinal scan biometric device measure?

- A. The amount of light reaching the retina
- B. The amount of light reflected by the retina
- C. The size, curvature, and shape of the retina
- D. The pattern of blood vessels at the back of the eye

Answer: D

Explanation:

QUESTION NO: 257

Type II errors occur when which of the following biometric system rates is high?

- A. False accept rate
- B. False reject rate
- C. Crossover error rate
- D. Speed and throughput rate

Answer: A

Explanation: There are three main performance issues in biometrics. These measures are as follows:

False Rejection Rate (FRR) or Type 1 Error. The percentage of valid subjects that are falsely rejected.

False Acceptance Rate (FAR) or Type 2 Error. The percentage of invalid subjects that are falsely accepted.

Crossover Error Rate (CER). The percent in which the False Rejection Rate equals the False Acceptance Rate.

QUESTION NO: 258

Which of the following are the valid categories of hand geometry scanning?

- A. Electrical and image-edge detection.
- B. Mechanical and image-edge detection.
- C. Logical and image-edge detection.
- D. Mechanical and image-ridge detection.

Answer: B

Explanation:

Hand geometry reading (scanning) devices usually fall into one of two categories: mechanical or image-edge detection. Both methods are used to measure specific characteristics of a person's hand such as length of fingers and thumb, widths, and depth.

QUESTION NO: 259

In the world of keystroke dynamics, what represents the amount of time you hold down in a particular key?

- A. Dwell time
- B. Flight time
- C. Dynamic time
- D. Systems time

Answer: A

Explanation:

Keystroke dynamics looks at the way a person types at a keyboard. Specifically, keyboard dynamics measures two distinct variables: "dwell time" which is the amount of time you hold down a particular key and "flight time" which is the amount of time it

takes a person to switch between keys. Keyboard dynamics systems can measure one's keyboard input up to 1000 times per second.

QUESTION NO: 260

In the world of keystroke dynamics, what represents the amount of time it takes a person to switch between keys?

- A. Dynamic time
- B. Flight time
- C. Dwell time
- D. Systems time.

Answer: B

Explanation:

Keystroke dynamics looks at the way a person types at a keyboard. Specifically, keyboard dynamics measures two distinct variables: "dwell time" which is the amount of time you hold down a particular key and "flight time" which is the amount of time it takes a person to switch between keys. Keyboard dynamics systems can measure one's keyboard input up to 1000 times per second.

QUESTION NO: 261

Which of the following are the benefits of Keystroke dynamics?

- A. Low cost
- B. Unintrusive device
- C. Transparent
- D. All of the choices.

Answer: D

Explanation:

Keystroke dynamics is behavioral in nature. It works well with users that can "touch type". Key advantages in applying keyboard dynamics are that the device used in this system, the keyboard, is unintrusive and does not detract from one's work. Enrollment as well as identification goes undetected by the user. Another inherent benefit to using keystroke dynamics as an identification device is that the hardware (i.e. keyboard) is inexpensive. Currently, plug-in boards, built-in hardware and firmware, or software can represent keystroke dynamics systems.

QUESTION NO: 262

DSV as an identification method check against users:

- A. Fingerprints
- B. Signature
- C. Keystrokes
- D. Facial expression

Answer: B

Explanation:

Signature identification, also known as Dynamic Signature Verification (DSV), is another natural fit in the world of biometrics since identification through one's signature occurs during many everyday transactions. Any process or transaction that requires an individual's signature is a prime contender for signature identification.

QUESTION NO: 263

Signature identification systems analyze what areas of an individual's signature?

- A. All of the choices EXCEPT the signing rate.
- B. The specific features of the signature.
- C. The specific features of the process of signing one's signature.
- D. The signature rate.

Answer: A

Explanation:

Signature identification systems analyze two different areas of an individual's signature: the specific features of the signature and specific features of the process of signing one's signature. Features that are taken into account and measured include speed, pen pressure, directions, stroke length, and the points in time when the pen is lifted from the paper.

QUESTION NO: 264

What are the advantages to using voice identification?

- A. All of the choices.
- B. Timesaving
- C. Reliability
- D. Flexibility

Answer: A

Explanation:

The many advantages to using voice identification include:

Considered a "natural" biometric technology

Provides eyes and hands-free operation

Reliability

Flexibility

Timesaving data input

Eliminate spelling errors

Improved data accuracy

QUESTION NO: 265

What are the methods used in the process of facial identification?

- A. None of the choices.
- B. Detection and recognition.
- C. Scanning and recognition.
- D. Detection and scanning.

Answer: B

Explanation:

The process of facial identification incorporates two significant methods: detection and recognition.

QUESTION NO: 266

In the process of facial identification, the basic underlying recognition technology of facial identification involves:

- A. Eigenfeatures of eigenfaces.
- B. Scanning and recognition.
- C. Detection and scanning.
- D. None of the choices.

Answer: A

Explanation:

Recognition is comparing the captured face to other faces that have been saved and stored in a database. The basic underlying recognition technology of facial feature identification involves either eigenfeatures (facial metrics) or eigenfaces. The German word "eigen" refers to recursive mathematics used to analyze unique facial characteristics.

QUESTION NO: 267

What is known as the probability that you are not authenticated to access your account?

- A. ERR

- B. FRR
- C. MTBF
- D. FAR

Answer: B

Explanation:

Biometric performance is most commonly measured in two ways: False Rejection Rate (FRR), and False Acceptance Rate (FAR). The FRR is the probability that you are not authenticated to access your account. A strict definition states that the FRR is the probability that a mated comparison (i.e. 2 biometric samples of the same finger) incorrectly determines that there is no match.

QUESTION NO: 268

What is known as the chance that someone other than you is granted access to your account?

- A. ERR
- B. FAR
- C. FRR
- D. MTBF

Answer: B

Explanation:

The FAR is the chance that someone other than you is granted access to your account, in other words, the probability that a non-mated comparison (i.e. two biometric samples of different fingers) match. FAR and FRR numbers are generally expressed in terms of probability.

Note:

false accept rate or false match rate (FAR or FMR): the probability that the system incorrectly matches the input pattern to a non-matching template in the database. It measures the percent of invalid inputs which are incorrectly accepted.

*** false reject rate or false non-match rate (FRR or FNMR):** the probability that the system fails to detect a match between the input pattern and a matching template in the database. It measures the percent of valid inputs which are incorrectly rejected.

FRR is a Type 1 error

FAR is a Type 2 error

QUESTION NO: 269

What is typically used to illustrate the comparative strengths and weaknesses of each biometric technology?

- A. Decipher Chart
- B. Zephyr Chart
- C. Cipher Chart
- D. Zapper Chart

Answer: B

Explanation:

The Zephyr Chart illustrates the comparative strengths and weaknesses of each biometric technology. The eight primary biometric technologies are listed around the outer border, and for each technology the four major evaluation criteria are ranked from outside (better) to inside (worse). Looking at dynamic signature verification (DSV) will illustrate how the Zephyr Chart works.

QUESTION NO: 270

In terms of the order of effectiveness, which of the following technologies is the most affective?

- A. Fingerprint
- B. Iris scan
- C. Keystroke pattern
- D. Retina scan

Answer: B

Explanation:

The order of effectiveness has not changed for a few years. It is still the same today as it was three years ago. The list below present them from most effective to list effective:

Iris scan
Retina scan
Fingerprint
Hand geometry
Voice pattern
Keystroke pattern
Signature

QUESTION NO: 271

In terms of the order of effectiveness, which of the following technologies is the least effective?

- A. Voice pattern
- B. Signature
- C. Keystroke pattern
- D. Hand geometry

Answer: B

Explanation:

The order of effectiveness has not changed for a few years. It is still the same today as it was three years ago. The list below present them from most effective to list effective:

Iris scan
Retina scan
Fingerprint
Hand geometry
Voice pattern
Keystroke pattern
Signature

QUESTION NO: 272

In terms of the order of acceptance, which of the following technologies is the MOST accepted?

- A. Hand geometry
- B. Keystroke pattern
- C. Voice Pattern
- D. Signature

Answer: C

Explanation:

The order of acceptance has slightly changed in the past years. It was Iris that was the most accepted method three years ago but today we have Voice Pattern that is by far the most accepted. Here is the list from most accepted first to least accepted at the bottom of the list:

Voice Pattern

Keystroke pattern

Signature

Hand geometry

Handprint

Fingerprint

Iris

Retina pattern

QUESTION NO: 273

In terms of the order of acceptance, which of the following technologies is the LEAST accepted?

- A. Fingerprint
- B. Iris
- C. Handprint
- D. Retina patterns

Answer: D

Explanation:

The order of acceptance has slightly changed in the past years. It was Iris that was the most accepted method three years ago but today we have Voice Pattern that is by far the most accepted. Here is the list from most accepted first to least accepted at the bottom of the list:

Voice Pattern

Keystroke pattern

Signature

Hand geometry
Handprint
Fingerprint
Iris
Retina pattern

QUESTION NO: 274

Which of the following biometric characteristics cannot be used to uniquely authenticate an individual's identity?

- A. Retina scans
- B. Iris scans
- C. Palm scans
- D. Skin scans

Answer: D

Explanation:

QUESTION NO: 275

Which of the following is true of two-factor authentication?

- A. It uses the RSA public-key signature based algorithm on integers with large prime factors
- B. It requires two measurements of hand geometry
- C. It does not use single sign-on technology
- D. It relies on two independent proofs of identity

Answer: D

Explanation:

QUESTION NO: 276

What is Kerberos?

- A. A three-headed dog from Egyptian Mythology
- B. A trusted third-party authentication protocol
- C. A security model
- D. A remote authentication dial in user server

Answer: B

Explanation:

QUESTION NO: 277

Which of the following is true about Kerberos?

- A. It utilized public key cryptography
- B. It encrypts data after a ticket is granted, but passwords are exchanged in plain text
- C. It depends upon symmetric ciphers
- D. It is a second party authentication system

Answer: C

Explanation: "Kerberos relies upon symmetric key cryptography, specifically Data Encryption Standard (DES), and provides end-to-end security for authentication traffic between the client and the Key Distribution Center (KDC)." Pg. 15 Tittel: CISSP Study Guide

QUESTION NO: 278

Kerberos depends upon what encryption method?

- A. Public Key cryptography
- B. Private Key cryptography
- C. El Gamal cryptography
- D. Blowfish cryptography

Answer: B

Explanation: Kerberos uses symmetric key cryptography and provides end-to-end security, meaning that information being passed between a user and a service is protected without the need of an intermediate component. Although it allows the use of passwords for authentication, it was designed specifically to eliminate the need for transmitting passwords over the network. Most

Kerberos implementations work with cryptography keys and shared secret keys (private keys) instead of passwords. Pg 148 Shon Harris All-In-One CISSP Certification Exam Guide

QUESTION NO: 279

The primary service provided by Kerberos is which of the following?

- A. non-repudiation
- B. confidentiality
- C. authentication
- D. authorization

Answer: C

Explanation:

QUESTION NO: 280

Which of the following are authentication server systems with operational modes that can implement SSO?

- A. Kerberos, SESAME and KryptoKnight
- B. SESAME, KryptoKnight and NetSP
- C. Kerberos and SESAME
- D. Kerberos, SESAME, KryptoKnight, and NetSP

Answer: D

Explanation: "Scripts, directory services, thin clients, Kerberos, SESAME, NetSP, scripted access, and KryptoKnight are examples of SSO(single sign on) mechanisms."

Pg. 14 Tittel: CISSP Study Guide Second Edition

QUESTION NO: 281

Which of the following is a trusted, third party authentication protocol that was developed under Project Athena at MIT?

- A. Kerberos
- B. SESAME
- C. KryptoKnight
- D. NetSP

Answer: A

Explanation: "Kerberos is an authentication protocol and was designed in the mid-1980s as part of MIT's Project Athena." Pg 129 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 282

Which of the following is true about Kerberos?

- A. It utilizes public key cryptography
- B. It encrypts data after a ticket is granted, but passwords are exchanged in plain text.
- C. It depends upon symmetric ciphers
- D. It is a second party authentication system

Answer: C

Explanation:

QUESTION NO: 283

One of the differences between Kerberos and KryptoKnight is that there is:

- A. a mapped relationship among the parties takes place
- B. there is a peer-to-peer relationship among the parties with themselves.
- C. there is no peer-to-peer relationship among the parties and the KDC
- D. a peer-to-peer relationship among the parties and the KDC

Answer: D

Explanation: "Krytponight

The IBM Kryptonight system provides authentication, SSO, and key distribution services. It was

designed to support computers with widely varying computational capabilities. KryptoKnight uses a trusted Key Distribution Center (KDC) that knows the secret key of each party. One of the differences between Kerberos and KryptoKnight is that there is a peer-to-peer relationship among the parties and the KDC."

Pg. 58 Krutz: The CISSP Prep Guide: Gold Edition

QUESTION NO: 284

Which of the following is the MOST secure network access control procedure to adopt when using a callback device?

- A. The user enters a userid and PIN, and the device calls back the telephone number that corresponds to the userid.
- B. The user enters a userid, PIN, and telephone number, and the device calls back the telephone number entered.
- C. The user enters the telephone number, and the device verifies that the number exists in its database before calling back.
- D. The user enters the telephone number, and the device responds with a challenge.

Answer: A

Explanation: Usually a request for a username and password takes place and the NAS may hang up the call in order to call the user back at a predefined phone number. This is a security activity that is used to try and ensure that only authenticated users are given access to the network and it reverse the long distance charges back to the company...However, this security measure can be compromised if someone implements call forwarding. - Shon Harris All-in-one CISSP Certification Guide pg 463

QUESTION NO: 285

What is called the access protection system that limits connections by calling back the number of a previously authorized location?

- A. Sendback system
- B. Callback forward systems

- C. Callback systems
- D. Sendback forward systems

Answer: C

Explanation: "Callback systems provide access protection by calling back the number of a previously authorized location, but this control can be compromised by call forwarding." Pg 48 Krutz: CISSP Prep Guide: Gold Edition.

QUESTION NO: 286

A confidential number to verify a user's identity is called a:

- A. PIN
- B. userid
- C. password
- D. challenge

Answer: A

Explanation:

QUESTION NO: 287

How are memory cards and smart cards different?

- A. Memory cards normally hold more memory than smart cards
- B. Smart cards provide a two-factor authentication whereas memory cards don't
- C. Memory cards have no processing power
- D. Only smart cards can be used for ATM cards

Answer: C

Explanation: "The main difference between memory cards and smart cards is the processing power. A memory card holds information, but does not process information. A smart card has the necessary hardware and logic to actually process information." Pg 121 Shon Harris CISSP All-In-One Exam Guide

QUESTION NO: 288

They in form of credit card-size memory cards or smart cards, or those resembling small calculators, are used to supply static and dynamic passwords are called:

- A. Tickets
- B. Tokens
- C. Token passing networks
- D. Coupons

Answer: B

Explanation:

QUESTION NO: 289

Tokens, as a way to identify users are subject to what type of error?

- A. Token error
- B. Decrypt error
- C. Human error
- D. Encrypt error

Answer: C

Explanation:

Tokens are a fantastic way of ensuring the identity of a user. However, you must remember that no system is immune to "human error". If the token is lost with it's pin written on it, or if it were loaned with the corresponding pin it would allow for masquerading. This is one of the greatest threats that you have with tokens.

QUESTION NO: 290

Which of the following factors may render a token based solution unusable?

- A. Token length
- B. Card size
- C. Battery lifespan
- D. None of the choices.

Answer: C

Explanation:

Another limitation of some of the tokens is their battery lifespan. For example, in the case of SecurID you have a token that has a battery that will last from 1 to 3 years depending on the type of token you acquired. Some token companies such as Cryptocard have introduced tokens that have a small battery compartment allowing you to change the battery when it is discharged.

QUESTION NO: 291

Memory only cards work based on:

- A. Something you have.
- B. Something you know.
- C. None of the choices.
- D. Something you know and something you have.

Answer: D

Explanation:

Memory Only Card - This type of card is the most common card. It has a magnetic stripe on the back. These cards can offer two-factor authentication, the card itself (something you have) and the PIN (something you know). Everyone is familiar with the use of an ATM (Automated Teller Machine) card. These memory cards are very easy to counterfeit. There was a case in Montreal where a storeowner would swipe the card through for the transaction; he would then swipe it through a card reader to get a copy, while a small hidden camera was registering the PIN as the user was punching it on the pad. This scheme was quickly identified as the victims had one point in common; they all visited the same store.

QUESTION NO: 292

Which of the following is a disadvantage of a memory only card?

- A. High cost to develop.
- B. High cost to operate.
- C. Physically infeasible.
- D. Easy to counterfeit.

Answer: D

Explanation:

Memory Only Card - This type of card is the most common card. It has a magnetic stripe on the back. These cards can offer two-factor authentication, the card itself (something you have) and the PIN (something you know). Everyone is familiar with the use of an ATM (Automated Teller Machine) card. These memory cards are very easy to counterfeit. There was a case in Montreal where a storeowner would swipe the card through for the transaction; he would then swipe it through a card reader to get a copy, while a small hidden camera was registering the PIN as the user was punching it on the pad. This scheme was quickly identified as the victims had one point in common; they all visited the same store.

QUESTION NO: 293

The word "smart card" has meanings of:

- A. Personal identity token containing IC-s.
- B. Processor IC card.
- C. IC card with ISO 7816 interface.
- D. All of the choices.

Answer: D

Explanation:

The word "smart card" has four different meanings (in order of usage frequency):

IC card with ISO 7816 interface

Processor IC card

Personal identity token containing IC-s

Integrated Circuit(s) Card is an ID-1 type (specified in ISO 7810) card, into which has been inserted one or more integrated circuits. [ISO 7816]

QUESTION NO: 294

Processor card contains which of the following components?

- A. Memory and hard drive.
- B. Memory and flash.
- C. Memory and processor.
- D. Cache and processor.

Answer: C

Explanation:

Processor cards contain memory and a processor. They have remarkable data processing capabilities. Very often the data processing power is used to encrypt/decrypt data, which makes this type of card a very unique personal identification token. Data processing also permits dynamic storage management, which enables the realization of flexible multifunctional cards.

QUESTION NO: 295

Which of the following offers advantages such as the ability to use stronger passwords, easier password administration, and faster resource access?

- A. Smart cards
- B. Single Sign-on (SSO)
- C. Kerberos
- D. Public Key Infrastructure (PKI)

Answer: B

Explanation:

QUESTION NO: 296

What is the main concern with single sign-on?

- A.** Maximum unauthorized access would be possible if a password is disclosed
- B.** The security administrator's workload would increase
- C.** The users' password would be too hard to remember
- D.** User access rights would be increased

Answer: A

Explanation:

QUESTION NO: 297

Which of the following describes the major disadvantage of many SSO implementations?

- A.** Once a user obtains access to the system through the initial log-on they can freely roam the network resources without any restrictions
- B.** The initial logon process is cumbersome to discourage potential intruders
- C.** Once a user obtains access to the system through the initial log-on, they only need to logon to some applications.
- D.** Once a user obtains access to the system through the initial log-on, he has to logout from all other systems

Answer: A

Reference: "The major disadvantage of many SSO implementations is that once a user obtains access to the system through the initial logon, the user can freely roam the network resources without any restrictions." pg 53 Krutz: CISSP Prep Guide: Gold Edition

QUESTION NO: 298

Which of the following addresses cumbersome situations where users need to log on multiple times to access different resources?

- A.** Single Sign-On (SSO) systems

- B. Dual Sign-On (DSO) systems
- C. Double Sign-On (DSO) systems
- D. Triple Sign-On (TSO) systems

Answer: A

Explanation:

QUESTION NO: 299

A method for a user to identify and present credentials only once to a system is known as:

- A. SEC
- B. IPSec
- C. SSO
- D. SSL

Answer: C

Explanation:

Single Sign-On (SSO) - This is a method for a users to identify and present credentials only once to a system. Information needed for future system access to resources is forwarded by the initial System.

BENEFITS

More efficient user log-on process

Users select stronger passwords

Inactivity timeout and attempt thresholds applied uniformly closer to user point of entry

Improved timely disabling of all network/computer accounts for terminated users

QUESTION NO: 300

Which of the following correctly describe the features of SSO?

- A. More efficient log-on.

- B. More costly to administer.
- C. More costly to setup.
- D. More key exchanging involved.

Answer: A

Explanation:

Single Sign-On (SSO) - This is a method for a users to identify and present credentials only once to a system. Information needed for future system access to resources is forwarded by the initial System.

BENEFITS

More efficient user log-on process

Users select stronger passwords

Inactivity timeout and attempt thresholds applied uniformly closer to user point of entry

Improved timely disabling of all network/computer accounts for terminated users

QUESTION NO: 301

What is the PRIMARY advantage of using a separate authentication server (e.g., Remote Access Dial-In User System, Terminal Access Controller Access Control System) to authenticate dial-in users?

- A. Single user logons are easier to manage and audit.
- B. Each session has a unique (one-time) password assigned to it.
- C. Audit and access information are not kept on the access server.
- D. Call-back is very difficult to defeat.

Answer: C

Explanation:

TACACS integrates the authentication and authorization processes. XTACACS keeps the authentication, authorization and accounting processes separate. TACACS+ improves XTACACS by adding two-factor authentication. - Ed Tittle CISSP Study Guide (sybex) pg 745

QUESTION NO: 302

Within the Open Systems Interconnection (OSI) Reference Model, authentication addresses the need for a network entity to verify both

- A.** The identity of a remote communicating entity and the authenticity of the source of the data that are received.
- B.** The authenticity of a remote communicating entity and the path through which communications are received.
- C.** The location of a remote communicating entity and the path through which communications are received.
- D.** The identity of a remote communicating entity and the level of security of the path through which data are received.

Answer: A

Explanation:

OSI model needs to know the source of the data and that it is who it says it is. Path it the data take is not cared about unless source routing is used. The level of security is not cared about inherently by the receiving node (in general) unless configured. A is the best option in this question.

QUESTION NO: 303

Which of the following is the most reliable authentication device?

- A.** Variable callback system
- B.** Smart card system
- C.** fixed callback system
- D.** Combination of variable and fixed callback system

Answer: B

Explanation:

QUESTION NO: 304

Which of the following are proprietarily implemented by CISCO?

- A. RADIUS+
- B. TACACS
- C. XTACACS and TACACS+
- D. RADIUS

Answer: C

Explanation:

Cisco implemented an enhanced version of TACACS, known as XTACACS (extended TACACS), which was also compatible with TACACS. It allowed for UDP and TCP encoding. XTACACS contained several improvements: It provided accounting functionality to track length of login and which hosts a user connected to, and it also separated the authentication, authorization, and accounting processes such that they could be independently implemented. None of the three functions are mandatory. XTACACS is described in RFC 1492.

TACACS+ is the latest Cisco implementation. It is best described as XTACACS with improved attribute control (authorization) and accounting.

QUESTION NO: 305

What is a protocol used for carrying authentication, authorization, and configuration information between a Network Access Server and a shared Authentication Server?

- A. IPSec
- B. RADIUS
- C. L2TP
- D. PPTP

Answer: B

Explanation:

RADIUS is a protocol for carrying authentication, authorization, and configuration information between a Network Access Server, which desires to authenticate its links and a shared Authentication Server. RADIUS is a standard published in RFC2138 as mentioned above.

QUESTION NO: 306

RADIUS is defined by which RFC?

- A. 2168
- B. 2148
- C. 2138
- D. 2158

Answer: C

Explanation:

RADIUS is a protocol for carrying authentication, authorization, and configuration information between a Network Access Server, which desires to authenticate its links and a shared Authentication Server. RADIUS is a standard published in RFC2138 as mentioned above.

QUESTION NO: 307

In a RADIUS architecture, which of the following acts as a client?

- A. A network Access Server.
- B. None of the choices.
- C. The end user.
- D. The authentication server.

Answer: A

Explanation:

A Network Access Server (NAS) operates as a client of RADIUS. The client is responsible for passing user information to designated RADIUS servers, and then acting on the response, which is returned.

QUESTION NO: 308

In a RADIUS architecture, which of the following can act as a proxy client?

- A. The end user.
- B. A Network Access Server.
- C. The RADIUS authentication server.
- D. None of the choices.

Answer: C

Explanation:

A RADIUS server can act as a proxy client to other RADIUS servers or other kinds of authentication servers.

QUESTION NO: 309

Which of the following statements pertaining to RADIUS is incorrect?

- A. A RADIUS server can act as a proxy server, forwarding client requests to other authentication domains.
- B. Most of RADIUS clients have a capability to query secondary RADIUS servers for redundancy
- C. Most RADIUS servers have built-in database connectivity for billing and reporting purposes
- D. Most RADIUS servers can work with DIAMETER servers.

Answer: D

Explanation:

QUESTION NO: 310

Which of the following is the weakest authentication mechanism?

- A. Passphrases
- B. Passwords
- C. One-time passwords
- D. Token devices

Answer: B

Explanation:

QUESTION NO: 311

What is the PRIMARY use of a password?

- A. Allow access to files
- B. Identify the user
- C. Authenticate the user
- D. Segregate various user's accesses

Answer: C

Explanation:

QUESTION NO: 312

Software generated passwords have what drawbacks?

- A. Passwords are not easy to remember.
- B. Password are too secure.
- C. None of the choices.
- D. Passwords are unbreakable.

Answer: A

Explanation:

Passwords generated by a software package or some operating systems. These password generators are good at producing unique and hard to guess passwords, however you must ensure that they are not so hard that people can't remember them. If you force your users to write their passwords down then you are defeating the purpose of having strong password management.

QUESTION NO: 313

What are the valid types of one time password generator?

- A. All of the choices.
- B. Transaction synchronous
- C. Synchronous/PIN synchronous
- D. Asynchronous/PIN asynchronous

Answer: A

Explanation:

One-time Passwords are changed after every use. Handheld password generator (tokens) 3 basic types: Synchronous/PIN synchronous, Transaction synchronous, Asynchronous/PIN asynchronous.

QUESTION NO: 314

Which of the following will you consider as most secure?

- A. Password
- B. One time password
- C. Login phrase
- D. Login ID

Answer: B

Explanation:

Each time the user logs in, the token generates a unique password that is synchronized with the network server. If anyone tries to reuse this dynamic password, access is denied, the event is logged and the network remains secure.

QUESTION NO: 315

What type of password makes use of two totally unrelated words?

- A. Login phrase
- B. One time password
- C. Composition
- D. Login ID

Answer: C

Explanation:

Usage of two totally unrelated words or a series of unrelated characters, such as pizza!wood for example. Such a password is easy to remember but very hard to guess. It would require a cracker quite a bit of time to do a brute force attack on a password that is that long and that uses an extended character as well.

QUESTION NO: 316

Which of the following is the correct account policy you should follow?

- A. All of the choices.
- B. All active accounts must have a password.
- C. All active accounts must have a long and complex pass phrase.
- D. All inactive accounts must have a password.

Answer: B

Explanation:

All active accounts must have a password. Unless you are using an application or service designed to be accessed without the need of a proper ID and password. Such service must however be monitored by other means (not a recommended practice.)

QUESTION NO: 317

Which of the following are the advantages of using passphrase?

- A. Difficult to crack using brute force.
- B. Offers numerous characters.
- C. Easier to remember.
- D. All of the choices.

Answer: D

Explanation:

The use of passphrases is a good way of having very strong passwords. A passphrase is easier to remember, it offers numerous characters, and it is almost impossible to crack using brute force with today's processing power. An example of a passphrase could be: "Once upon a time in the CISSP world"

QUESTION NO: 318

Which of the following are the correct guidelines of password deployment?

- A. Passwords must be masked.
- B. All of the choices.
- C. Password must have a minimum of 8 characters.
- D. Password must contain a mix of both alphabetic and non-alphabetic characters.

Answer: B

Explanation:

Passwords must not be displayed in plain text while logging on. Passwords must be masked. Password must have a minimum of 8 characters. Password must contain a mix of both alphabetic and non-alphabetic characters. Passwords must be kept private, e.g. not shared, coded into programs, or written down.

QUESTION NO: 319

Why would a 16 characters password not desirable?

- A. Hard to remember

- B. Offers numerous characters.
- C. Difficult to crack using brute force.
- D. All of the choices.

Answer: A

Explanation:

When the password is too hard to memorize, the user will actually write it down, which is totally insecure and unacceptable.

QUESTION NO: 320

Which of the following is NOT a good password deployment guideline?

- A. Passwords must not be the same as user id or login id.
- B. Password aging must be enforced on all systems.
- C. Password must be easy to memorize.
- D. Passwords must be changed at least once every 60 days, depending on your environment.

Answer: C

Explanation:

Passwords must be changed at least once every 60 days (depending on your environment). Password aging or expiration must be enforced on all systems. Upon password expiration, if the password is not changed, only three grace logins must be allowed then the account must be disabled until reset by an administrator or the help desk. Password reuse is not allowed (rotating passwords).

QUESTION NO: 321

Rotating password can be restricted by the use of:

- A. Password age
- B. Password history
- C. Complex password
- D. All of the choices

Answer: B

Explanation:

Passwords must be changed at least once every 60 days (depending on your environment). Password aging or expiration must be enforced on all systems. Upon password expiration, if the password is not changed, only three grace logins must be allowed then the account must be disabled until reset by an administrator or the help desk. Password reuse is not allowed (rotating passwords).

QUESTION NO: 322

What should you do immediately if the root password is compromised?

- A. Change the root password.
- B. Change all passwords.
- C. Increase the value of password age.
- D. Decrease the value of password history.

Answer: B

Explanation:

All passwords must be changed if the root password is compromised or disclosure is suspected. (This is a separate case; the optimal solution would be to reload the compromised computer. A computer that has been downgraded can never be upgraded to higher security level)

QUESTION NO: 323

Which of the following is the most secure way to distribute password?

- A. Employees must send in an email before obtaining a password.
- B. Employees must show up in person and present proper identification before obtaining a password.
- C. Employees must send in a signed email before obtaining a password.

D. None of the choices.

Answer: B

Explanation:

Employees must show up in person and present proper identification before obtaining a new or changed password (depending on your policy). After three unsuccessful attempts to enter a password, the account will be locked and only an administrator or the help desk can reactivate the involved user ID.

QUESTION NO: 324

Which of the following does not apply to system-generated passwords?

- A.** Passwords are harder to remember for users
- B.** If the password-generating algorithm gets to be known, the entire system is in jeopardy
- C.** Passwords are more vulnerable to brute force and dictionary attacks.
- D.** Passwords are harder to guess for attackers

Answer: C

Explanation:

QUESTION NO: 325

Passwords can be required to change monthly, quarterly, or any other intervals:

- A.** depending on the criticality of the information needing protection
- B.** depending on the criticality of the information needing protection and the password's frequency of use
- C.** depending on the password's frequency of use
- D.** not depending on the criticality of the information needing protection but depending on the password's frequency of use

Answer: B

Explanation:

QUESTION NO: 326

In SSL/TLS protocol, what kind of authentication is supported?

- A. Peer-to-peer authentication
- B. Only server authentication (optional)
- C. Server authentication (mandatory) and client authentication (optional)
- D. Role based authentication scheme

Answer: C

Explanation: "The server sends a message back to the client indicating that a secure session needs to be established, and the client sends it security parameters. The server compares those security parameters to its own until it finds a match. This is the handshaking phase. The server authenticates to the client by sending it a digital certificate, and if the client decides to trust the server the process continues. The server can require the client to send over a digital certificate for mutual authentication, but that is rare."

Pg. 523 Shon Harris: All-In-One CISSP Certification Exam Guide

QUESTION NO: 327

Which of the following correctly describe the difference between identification and authentication?

- A. Authentication is a means to verify who you are, while identification is what you are authorized to perform.
- B. Identification is a means to verify who you are, while authentication is what you are authorized to perform.
- C. Identification is another name of authentication.
- D. Identification is the child process of authentication.

Answer: D

Explanation:

Not B: Authentication is not what you are authorized to perform

QUESTION NO: 328

Identification establishes:

- A. Authentication
- B. Accountability
- C. Authorization
- D. None of the choices.

Answer: B

Explanation:

Identification is a means to verify who you are. Authentication is what you are authorized to perform, access, or do. User identification enables accountability. It enables you to trace activities to individual users that may be held responsible for their actions. Identification usually takes the form of Logon ID or User ID. Some of the Logon ID characteristics are: they must be unique, not shared, and usually non descriptive of job function.

QUESTION NO: 329

Identification usually takes the form of:

- A. Login ID.
- B. User password.
- C. None of the choices.
- D. Passphrase

Answer: A

Explanation:

Identification is a means to verify who you are. Authentication is what you are authorized to perform, access, or do. User identification enables accountability. It enables you to trace activities to individual users that may be held responsible for their actions. Identification usually takes the form of Logon ID or User ID. Some of the Logon ID characteristics are: they must be unique, not shared, and usually non descriptive of job function

QUESTION NO: 330

What is called the act of a user professing an identity to a system, usually in the form of a log-on ID?

- A. Authentication
- B. Identification
- C. Integrity
- D. Confidentiality

Answer: B

Explanation: "Identification is the act of a user professing an identity to a system, usually in the form of a logon ID to the system." Pg 49 Krutz The CISSP Prep Guide.

"Identification describes a method of ensuring that a subject (user, program, or process) is the entity it claims to be. Identification can be provided with the use of a username or account number. To be properly authenticated, the subject is usually required to provide a second piece to the credential set. This piece could be a password, passphrase, cryptographic key, personal identification number (PIN), anatomical attribute, or token." Pg 110 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 331

What is called the verification that the user's claimed identity is valid and is usually implemented through a user password at log-on time?

- A. Authentication
- B. Identification
- C. Integrity
- D. Confidentiality

Answer: A

Explanation:

QUESTION NO: 332

Identification and authentication are the keystones of most access control systems. Identification establishes:

- A. user accountability for the actions on the system
- B. top management accountability for the actions on the system
- C. EDP department accountability for the actions of users on the system
- D. authentication for actions on the system

Answer: A

Explanation:

QUESTION NO: 333

Which one of the following authentication mechanisms creates a problem for mobile users?

- A. address-based mechanism
- B. reusable password mechanism
- C. one-time password mechanism
- D. challenge response mechanism

Answer: A

Explanation:

QUESTION NO: 334

Which of the following centralized access control mechanisms is not appropriate for mobile workers access the corporate network over analog lines?

- A. TACACS
- B. Call-back
- C. CHAP
- D. RADIUS

Answer: B

Explanation:

QUESTION NO: 335

Authentication is typically based upon:

- A. Something you have.
- B. Something you know.
- C. Something you are.
- D. All of the choices.

Answer: D

Explanation:

Authentication is a means of verifying the eligibility of an entity to receive specific categories of information. The entity could be individual user, machine, or software component. Authentication is typically based upon something you know, something you have, or something you are.

QUESTION NO: 336

A password represents:

- A. Something you have.
- B. Something you know.
- C. All of the choices.
- D. Something you are.

Answer: B

Explanation:

The canonical example of something you know is a password or pass phrase. You might type or speak the value. A number of schemes are possible for obtaining what you know. It might be assigned to you, or you may have picked the value yourself. Constraints may exist regarding the form the value can take, or the alphabet from which you are allowed to construct the value might be limited to letters only. If you forget the value, you

may not be able to authenticate yourself to the system.

QUESTION NO: 337

A smart card represents:

- A. Something you are.
- B. Something you know.
- C. Something you have.
- D. All of the choices.

Answer: C

Explanation:

Another form of authentication requires possession of something such as a key, a smart card, a disk, or some other device. Whatever form it takes, the authenticating item should be difficult to duplicate and may require synchronization with systems other than the one to which you are requesting access. Highly secure environments may require you to possess multiple things to guarantee authenticity.

QUESTION NO: 338

Which of the following is the most commonly used check on something you know?

- A. One time password
- B. Login phrase
- C. Retinal
- D. Password

Answer: D

Explanation:

Passwords even though they are always mentioned as being unsecured, necessary evils, that put your infrastructure at risk, are still commonly used and will probably be used

for quite a few years. Good passwords can provide you with a good first line of defense. Passwords are based on something the user knows. They are used to authenticate users before they can access specific resources.

QUESTION NO: 339

Retinal scans check for:

- A. Something you are.
- B. Something you have.
- C. Something you know.
- D. All of the choices.

Answer: A

Explanation:

Something you are is really a special case of something you have. The usual examples given include fingerprint, voice, or retinal scans.

QUESTION NO: 340

What type of authentication takes advantage of an individual's unique physical characteristics in order to authenticate that person's identity?

- A. Password
- B. Token
- C. Ticket Granting
- D. Biometric

Answer: D

Explanation:

Biometric authentication systems take advantage of an individual's unique physical characteristics in order to authenticate that person's identity. Various forms of biometric authentication include face, voice, eye, hand, signature, and fingerprint,

each have their own advantages and disadvantages. When combined with the use of a PIN it can provide two factors authentication.

QUESTION NO: 341

What is called an automated means of identifying or authenticating the identity of a living person based on physiological or behavioral characteristics?

- A. Biometrics
- B. Micrometrics
- C. Macrometrics
- D. MicroBiometrics

Answer: A

Explanation:

QUESTION NO: 342

Which of the following forms of authentication would most likely apply a digital signature algorithm to every bit of data that is sent from the claimant to the verifier?

- A. Dynamic authentication
- B. Continuous authentication
- C. Encrypted authentication
- D. Robust authentication

Answer: B

Explanation: See also www.rxn.com/services/faq/internet/ISPTG-5.html

Continuous Authentication This type of authentication provides protection against impostors who can see, alter, and insert information passed between the claimant and verifier even after the claimant/verifier authentication is complete. These are typically referred to as active attacks, since they assume that the imposter can actively influence the connection between claimant and verifier. One way to provide this form of authentication is to apply a digital signature algorithm to every bit of data that is sent from the claimant to the verifier.

QUESTION NO: 343

In which situation would TEMPEST risks and technologies be of MOST interest?

- A. Where high availability is vital.
- B. Where the consequences of disclosure are very high.
- C. Where countermeasures are easy to implement
- D. Where data base integrity is crucial

Answer: B

Explanation: Emanation eavesdropping. Receipt and display of information, which is resident on computers or terminals, through the interception of radio frequency (RF) signals generated by those computers or terminals. The US government established a program called TEMPEST that addressed this problem by requiring a shielding and other emanation-reducing mechanisms to be employed on computers processing sensitive and classified government information. . -Ronald Krutz The CISSP PREP Guide (gold edition) pg 416

QUESTION NO: 344

Which one of the following addresses the protection of computers and components from electromagnetic emissions?

- A. TEMPEST
- B. ISO 9000
- C. Hardening
- D. IEEE 802.2

Answer: A

Explanation: Receipt and Display of information, which is resident on computers or terminals, through the interception of Radio Frequency (RF) signals generated by those computers or terminals. The US government established a program called Tempest that addressed this problem by requiring shielding and other emanation-reducing mechanisms to be employed on

computers processing sensitive and classified government information. -Ronald Krutz The CISSP PREP Guide (gold edition) pg 416

QUESTION NO: 345

Monitoring electromagnetic pulse emanations from PCs and CRTs provides a hacker with that significant advantage?

- A. Defeat the TEMPEST safeguard
- B. Bypass the system security application.
- C. Gain system information without trespassing
- D. Undetectable active monitoring.

Answer: D

Explanation: Tempest equipment is implemented to prevent intruders from picking up information through the airwaves with listening devices. - Shon Harris All-in-one CISSP Certification Guide pg 192. In Harris's other book CISSP PASSPORT, she talks about tempest in terms of spy movies and how a van outside is listening or monitoring to the activities of someone. This lends credence to the answer of C (trespassing) but I think D is more correct. In that all the listener must do is listen to the RF. Use your best judgment based on experience and knowledge.

QUESTION NO: 346

What name is given to the study and control of signal emanations from electrical and electromagnetic equipment?

- A. EMI
- B. Cross Talk
- C. EMP
- D. TEMPEST

Answer: D

Explanation:

QUESTION NO: 347

TEMPEST addresses

- A. The vulnerability of time-dependent transmissions.
- B. Health hazards of electronic equipment.
- C. Signal emanations from electronic equipment.
- D. The protection of data from high energy attacks.

Answer: C

Explanation: "Tempest is the study and control of spurious electrical signals that are emitted by electrical equipment." Pg 167 Shon Harris: All-In-One CISSP Certification Exam Guide

QUESTION NO: 348

Which one of the following is the MOST solid defense against interception of a network transmission?

- A. Frequency hopping
- B. Optical fiber
- C. Alternate routing
- D. Encryption

Answer: B

Explanation: An alternative to conductor-based network cabling is fiber-optic cable. Fiber-optic cables transmit pulses of light rather than electricity. This has the advantage of being extremely fast and near impervious to tapping.

Pg 85 Tittel: CISSP Study Guide.

QUESTION NO: 349

Which of the following media is MOST resistant to tapping?

- A. Microwave
- B. Twisted pair
- C. Coaxial cable
- D. Fiber optic

Answer: D

Explanation:

QUESTION NO: 350

What type of wiretapping involves injecting something into the communications?

- A. Aggressive
- B. Captive
- C. Passive
- D. Active

Answer: D

Explanation: Most communications are vulnerable to some type of wiretapping or eavesdropping. It can usually be done undetected and is referred to as a passive attack versus an active attack. - Shon Harris All-in-one CISSP Certification Guide pg 649

"(I) An attack that intercepts and accesses data and other information contained in a flow in a communication system. (C) Although the term originally referred to making a mechanical connection to an electrical conductor that links two nodes, it is now used to refer to reading information from any sort of medium used for a link or even directly from a node, such as gateway or subnetwork switch. (C) "Active wiretapping" attempts to alter the data or otherwise affect the flow; "passive wiretapping" only attempts to observe the flow and gain knowledge of information it contains. (See: active attack, end-to-end encryption, passive attack.)"

<http://www.linuxsecurity.com/dictionary/dict-455.html>

QUESTION NO: 351

Why would an Ethernet LAN in a bus topology have a greater risk of unauthorized disclosure than switched Ethernet in a hub-and-spoke or star topology?

- A. IEEE 802.5 protocol for Ethernet cannot support encryption.
- B. Ethernet is a broadcast technology.
- C. Hub and spoke connections are highly multiplexed.
- D. TCP/IP is an insecure protocol.

Answer: B

Explanation: Ethernet is broadcast and the question asks about a bus topology vs a SWITCHED Ethernet. Most switched Ethernet lans are divided by vlans which contain broadcasts to a single vlan, but remember only a layer 3 device can stop a broadcast.

QUESTION NO: 352

What type of attacks occurs when a smartcard is operating under normal physical conditions, but sensitive information is gained by examining the bytes going to and from the smartcard?

- A. Physical attacks.
- B. Logical attacks.
- C. Trojan Horse attacks.
- D. Social Engineering attacks.

Answer: B

Explanation:

Logical attacks occur when a smartcard is operating under normal physical conditions, but sensitive information is gained by examining the bytes going to and from the smartcard. One example is the so-called "timing attack" described by Paul Kocher. In this attack, various byte patterns are sent to the card to be signed by the private key. Information such as the time required to perform the operation and the number of zeroes and ones in the input bytes are used to eventually obtain the private key. There are logical countermeasures to this attack but not all smartcard manufacturers have implemented them. This attack does require that the PIN to the card be known, so that many private key operations can be performed on chosen input bytes.

QUESTION NO: 353

What is an effective countermeasure against Trojan horse attack that targets smart cards?

- A. Single-access device driver architecture.
- B. Handprint driver architecture.
- C. Fingerprint driver architecture.
- D. All of the choices.

Answer: A

Explanation:

The countermeasure to prevent this attack is to use "single-access device driver" architecture. With this type of architecture, the operating system enforces that only one application can have access to the serial device (and thus the smartcard) at any given time. This prevents the attack but also lessens the convenience of the smartcard because multiple applications cannot use the services of the card at the same time. Another way to prevent the attack is by using a smartcard that enforces a "one private key usage per PIN entry" policy model. In this model, the user must enter their PIN every single time the private key is to be used and therefore the Trojan horse would not have access to the key.

QUESTION NO: 354

Which of the following could illegally capture network user passwords?

- A. Data diddling
- B. Sniffing
- C. Spoofing
- D. Smurfing

Answer: B

Explanation:

QUESTION NO: 355

Which of the following statements is incorrect?

- A. Since the early days of mankind humans have struggled with the problems of protecting assets
- B. The addition of a PIN keypad to the card reader was a solution to unreported card or lost cards problems
- C. There has never been a problem of lost keys
- D. Human guard is an inefficient and sometimes ineffective method of protecting resources

Answer: C

Explanation:

QUESTION NO: 356

A system uses a numeric password with 1-4 digits. How many passwords need to be tried before it is cracked?

- A. 1024
- B. 10000
- C. 100000
- D. 1000000

Answer: B

Explanation: The largest 4 digit number is 9999. So 0000 – 9999 provides 10000 possible combinations.

QUESTION NO: 357

Which of the following can be used to protect your system against brute force password attack?

- A. Decrease the value of password history.
- B. Employees must send in a signed email before obtaining a password.

- C. After three unsuccessful attempts to enter a password, the account will be locked.
- D. Increase the value of password age.

Answer: C

Explanation:

Employees must show up in person and present proper identification before obtaining a new or changed password (depending on your policy). After three unsuccessful attempts to enter a password, the account will be locked and only an administrator or the help desk can reactivate the involved user ID.

QUESTION NO: 358

Which of the following is an effective measure against a certain type of brute force password attack?

- A. Password used must not be a word found in a dictionary.
- B. Password history is used.
- C. Password reuse is not allowed.
- D. None of the choices.

Answer: A

Explanation:

Password reuse is not allowed (rotating passwords). Password history must be used to prevent users from reusing passwords. On all systems with such a facility the last 12 passwords used will be kept in the history. All computer system users must choose passwords that cannot be easily guessed. Passwords used must not be a word found in a dictionary.

QUESTION NO: 359

Which type of attack will most likely provide an attacker with multiple passwords to authenticate to a system?

- A. Password sniffing

- B. Dictionary attack
- C. Dumpster diving
- D. Social engineering

Answer: A

Explanation:

QUESTION NO: 360

Which of the following are measures against password sniffing?

- A. Passwords must not be sent through email in plain text.
- B. Passwords must not be stored in plain text on any electronic media.
- C. You may store passwords electronically if it is encrypted.
- D. All of the choices.

Answer: D

Explanation:

Passwords must not be sent through email in plain text. Passwords must not be stored in plain text on any electronic media. It is acceptable to store passwords in a file if it is encrypted with PGP or equivalent strong encryption (once again depending on your organization policy). All vendor supplied default passwords must be changed.

QUESTION NO: 361

Which one of the following conditions is NOT necessary for a long dictionary attack to succeed?

- A. The attacker must have access to the target system.
- B. The attacker must have read access to the password file.
- C. The attacker must have write access to the password file.
- D. The attacker must know the password encryption mechanism and key variable.

Answer: C

Explanation:

The program encrypts the combination of characters and compares them to the encrypted entries in the password file. If a match is found, the program has uncovered a password. - Shon Harris All-in-one CISSP Certification Guide pg 199

QUESTION NO: 362

What is an important factor affecting the time required to perpetrate a manual trial and error attack to gain access to a target computer system?

- A. Keyspace for the password.
- B. Expertise of the person performing the attack.
- C. Processing speed of the system executing the attack.
- D. Encryption algorithm used for password transfer.

Answer: A

Explanation:

I am not sure of the answer on this question. B seems good but the reference below states that Keyspace (or length of password) is the main deterrent. I did not come across something that directly relates in my readings.

"If an attacker mounts a trial-and-error attack against your password, a longer password gives the attacker a larger number of alternatives to try. If each character in the password may take on 96 different values (typical of printable ASCII characters) then each additional character presents the attacker with 96 times as many passwords to try. If the number of alternatives is large enough, the trial-and-error attack might discourage the attacker, or lead to the attacker's detection."

<http://www.smat.us/sanity/riskyrules.html>

QUESTION NO: 363

Which one of the following BEST describes a password cracker?

- A. A program that can locate and read a password file.

- B. A program that provides software registration passwords or keys.
- C. A program that performs comparative analysis.
- D. A program that obtains privileged access to the system.

Answer: C

Explanation:

In a dictionary crack, L0phtCrack encrypts (i.e., hashes) all the passwords in a dictionary file you specify and compares every result with the password hash. If L0phtCrack finds any matches, it knows the password is the dictionary word. L0phtCrack comes with a default dictionary file, words-english. You can download additional files from the Internet or create a custom file. In the Tools Options dialog box, you can choose to run the dictionary attack against the LANMAN password hash, the NT LAN Manager (NTLM) password hash, or both (which is the default).

In a hybrid crack, L0phtCrack extends the dictionary crack by appending numbers or symbols to each word in the dictionary file. For example, in addition to trying "Galileo," L0phtCrack also tries "Galileo24," "13Galileo," "?Galileo," "Galileo!," and so on. The default number of characters L0phtCrack tries is two, and you can change this number in the Tools Options dialog box.

In a brute-force crack, L0phtCrack tries every possible combination of characters in a character set. L0phtCrack offers four character sets, ranging from alpha only to all alphanumeric plus all symbol characters. You can choose a character set from the Character Set drop-down box in the Tools Options dialog box or type a custom character set in the Character Set drop-down box. L0phtCrack saves custom sets in files with an .lc extension. You can also specify a character set in the password file, as the example in Figure 2 shows.

Not B: A key generator is what is being described by the registration password or key answer.

QUESTION NO: 364

If a token and 4-digit personal identification number (PIN) are used to access a computer system and the token performs off-line checking for the correct PIN, what type of attack is possible?

- A. Birthday
- B. Brute force
- C. Man-in-the-middle
- D. Smurf

Answer: B

Explanation:

Brute force attacks are performed with tools that cycle through many possible character, number,

and symbol combinations to guess a password. Pg 134 Shon Harris CISSP All-In-One Certification Exam Guide. Since the token allows offline checking of PIN, the cracker can keep trying PINS until it is cracked.

QUESTION NO: 365

Which of the following actions can increase the cost of an exhaustive attack?

- A. Increase the age of a password.
- B. Increase the length of a password.
- C. None of the choices.
- D. Increase the history of a password.

Answer: B

Explanation:

Defenses against exhaustive attacks involve increasing the cost of the attack by increasing the number of possibilities to be exhausted. For example, increasing the length of a password will increase the cost of an exhaustive attack. Increasing the effective length of a cryptographic key variable will make it more resistant to an exhaustive attack.

QUESTION NO: 366

Which of the following attacks focus on cracking passwords?

- A. SMURF
- B. Spamming
- C. Teardrop
- D. Dictionary

Answer: D

Explanation:

Dictionaries may be used in a cracking program to determine passwords. A short dictionary attack involves trying a list of hundreds or thousands of words that are frequently chosen as passwords against several systems. Although most systems resist such attacks, some do not. In one case, one system in five yielded to a particular dictionary attack.

QUESTION NO: 367

Which of the following can best eliminate dial-up access through a Remote Access Server as a hacking vector?

- A. Using TACACS+ server
- B. Installing the Remote Access Server outside the firewall and forcing legitimate users to authenticate to the firewall.
- C. Setting modem ring count to at least 5
- D. Only attaching modems to non-networked hosts.

Answer: B

Explanation:

QUESTION NO: 368

What is known as decoy system designed to lure a potential attacker away from critical systems?

- A. Honey Pots
- B. Vulnerability Analysis Systems
- C. File Integrity Checker
- D. Padded Cells

Answer: A

Explanation:

Honey pots are decoy systems that are designed to lure a potential attacker away from critical systems. Honey pots are designed to:

Divert an attacker from accessing critical systems,

Collect information about the attacker's activity, and encourage the attacker to stay

on the system long enough for administrators to respond.

QUESTION NO: 369

Which of the following will you consider as a program that monitors data traveling over a network?

- A. Smurfer
- B. Sniffer
- C. Fragmenter
- D. Spoofer

Answer: B

Explanation:

A sniffer is a program and/or device that monitor data traveling over a network. Sniffers can be used both for legitimate network management functions and for stealing information off a network. Unauthorized sniffers can be extremely dangerous to a network's security because they are virtually impossible to detect

QUESTION NO: 370

Which of the following is NOT a system-sensing wireless proximity card?

- A. magnetically striped card
- B. passive device
- C. field-powered device
- D. transponder

Answer: A

Explanation:

QUESTION NO: 371

Attacks on smartcards generally fall into what categories?

- A. Physical attacks.
- B. Trojan Horse attacks.
- C. Logical attacks.
- D. All of the choices, plus Social Engineering attacks.

Answer: D

Explanation:

Attacks on smartcards generally fall into four categories: Logical attacks, Physical attacks, Trojan Horse attacks and Social Engineering attacks.

QUESTION NO: 372

Which of the following attacks could be the most successful when the security technology is properly implemented and configured?

- A. Logical attacks
- B. Physical attacks
- C. Social Engineering attacks
- D. Trojan Horse attacks

Answer: C

Explanation:

Social Engineering attacks - In computer security systems, this type of attack is usually the most successful, especially when the security technology is properly implemented and configured. Usually, these attacks rely on the faults in human beings. An example of a social engineering attack has a hacker impersonating a network service technician. The serviceman approaches a low-level employee and requests their password for network servicing purposes. With smartcards, this type of attack is a bit more difficult. Most people would not trust an impersonator wishing to have their smartcard and PIN for service purposes.

QUESTION NO: 373

What type of attacks occurs when normal physical conditions are altered in order to gain access to sensitive information on the smartcard?

- A. Physical attacks
- B. Logical attacks
- C. Trojan Horse attacks
- D. Social Engineering attacks

Answer: A

Explanation:

Physical attacks occur when normal physical conditions, such as temperature, clock frequency, voltage, etc, are altered in order to gain access to sensitive information on the smartcard. Most smartcard operating systems write sensitive data to the EEPROM area in a proprietary, encrypted manner so that it is difficult to obtain clear text keys by directly hacking into the EEPROM. Other physical attacks that have proven to be successful involve an intense physical fluctuation at the precise time and location where the PIN verification takes place. Thus, sensitive card functions can be performed even though the PIN is unknown. This type of attack can be combined with the logical attack mentioned above in order to gain knowledge of the private key. Most physical attacks require special equipment.

QUESTION NO: 374

Which one of the following is an example of electronic piggybacking?

- A. Attaching to a communications line and substituting data.
- B. Abruptly terminating a dial-up or direct-connect session.
- C. Following an authorized user into the computer room.
- D. Recording and playing back computer transactions.

Answer: C

Explanation: Ok this is a weird little question. The term electronic is kinda of throwing me a bit. A

lot of times piggybacking can be used in terms of following someone in a building.

Piggyback - Gaining unauthorized access to a system via another user's legitimate connection.
(see between-the-lines entry)

Between-the-lines entry 0 Unauthorized access obtained by tapping the temporarily inactive terminal of a legitimate user. -Ronald Krutz The CISSP PREP Guide (gold edition) pg 914, 885

QUESTION NO: 375

A system using Discretionary Access Control (DAC) is vulnerable to which one of the following attacks?

- A. Trojan horse
- B. Phreaking
- C. Spoofing
- D. SYN flood

Answer: C

Explanation: An attempt to gain access to a system by posing as an authorized user.

Synonymous with impersonating, masquerading, or mimicking. -Ronald Krutz The CISSP PREP Guide (gold edition) pg 921

"Spoofing - The act of replacing the valid source and/or destination IP address and node numbers with false ones.

Spoofing attack - any attack that involves spoofed or modified packets." - Ed Tittle CISSP Study Guide (sybex)

QUESTION NO: 376

Which of the following is an example of an active attack? Select one.

- A. Traffic analysis
- B. Masquerading
- C. Eavesdropping
- D. Shoulder surfing

Answer: B

Explanation:

Shoulder surfing is passive, like eavesdropping and traffic analysis.

Masquerading is the only one where you are actually doing something by changing something – actively doing something.

QUESTION NO: 377

What attack involves actions to mimic one's identity?

- A. Brute force
- B. Exhaustive
- C. Social engineering
- D. Spoofing

Answer: D

Explanation:

Spoofing is an attack in which one person or process pretends to be a person or process that has more privileges. For example, user A can mimic behavior to make process B believe user A is user C. In the absence of any other controls, B may be duped into giving to user A the data and privileges that were intended for user C.

QUESTION NO: 378

Which access control model enables the owner of the resource to specify what subjects can access specific resources?

- A. Discretionary Access Control
- B. Mandatory Access Control
- C. Sensitive Access Control
- D. Role-based Access Control

Answer: A

Explanation:**QUESTION NO: 379**

The type of discretionary access control that is based on an individual's identity is called:

- A. Identity-based access control
- B. Rule-based access control
- C. Non-Discretionary access control
- D. Lattice-based access control

Answer: A

Explanation:**QUESTION NO: 380**

Which of the following access control types gives "UPDATE" privileges on Structured Query Language (SQL) database objects to specific users or groups?

- A. Supplemental
- B. Discretionary
- C. Mandatory
- D. System

Answer: C

Explanation: Supplemental and System are not access control types. The most correct answer is mandatory opposed to discretionary. The descriptions below sound typical of how a sql accounting database controls access.

"In a mandatory access control (MAC) model, users and data owners do not have as much freedom to determine who can access their files. Data owners can allow others to have access to their files, but it is the operating system that will make the final decision and can override the data owner's wishes." Pg. 154 Shon Harris CISSP All-In-One Certification Exam Guide

"Rule-based access controls are a variation of mandatory access controls. A rule based systems uses a set of rules, restrictions or filters to determine what can and cannot occur on the system, such as granting subject access, performing an action on an object, or accessing a resource. Pg 16 Tittle: CISSP Study Guide.

QUESTION NO: 381

With Discretionary access controls, who determines who has access and what privilege they have?

- A. End users.
- B. None of the choices.
- C. Resource owners.
- D. Only the administrators.

Answer: C

Explanation:

Discretionary access controls can extend beyond limiting which subjects can gain what type of access to which objects. Administrators can limit access to certain times of day or days of the week. Typically, the period during which access would be permitted is 9 a.m. to 5 p.m. Monday through Friday. Such a limitation is designed to ensure that access takes place only when supervisory personnel are present, to discourage unauthorized use of data. Further, subjects' rights to access might be suspended when they are on vacation or leave of absence. When subjects leave an organization altogether, their rights must be terminated rather than merely suspended. Under this type of control, the owner determines who has access and what privilege they have.

QUESTION NO: 382

What defines an imposed access control level?

- A. MAC
- B. DAC
- C. SAC
- D. CAC

Answer: A

Explanation:

MAC is defined as follows in the Handbook of Information Security Management: With mandatory controls, only administrators and not owners of resources may make decisions that bear on or derive from policy. Only an administrator may change the category of a resource, and no one may grant a right of access that is explicitly forbidden in the access control policy.

QUESTION NO: 383

Under MAC, who can change the category of a resource?

- A. All users.
- B. Administrators only.
- C. All managers.
- D. None of the choices.

Answer: B

Explanation:

MAC is defined as follows in the Handbook of Information Security Management: With mandatory controls, only administrators and not owners of resources may make decisions that bear on or derive from policy. Only an administrator may change the category of a resource, and no one may grant a right of access that is explicitly forbidden in the access control policy.

QUESTION NO: 384

Under MAC, who may grant a right of access that is explicitly forbidden in the access control policy?

- A. None of the choices.
- B. All users.

- C. Administrators only.
- D. All managers.

Answer: A

Explanation:

MAC is defined as follows in the Handbook of Information Security Management: With mandatory controls, only administrators and not owners of resources may make decisions that bear on or derive from policy. Only an administrator may change the category of a resource, and no one may grant a right of access that is explicitly forbidden in the access control policy.

QUESTION NO: 385

You may describe MAC as:

- A. Opportunistic
- B. Prohibitive
- C. None of the choices.
- D. Permissive

Answer: B

Explanation:

It is important to note that mandatory controls are prohibitive (i.e., all that is not expressly permitted is forbidden), not permissive. Only within that context do discretionary controls operate, prohibiting still more access with the same exclusionary principle. In this type of control system decisions are based on privilege (clearance) of subject (user) and sensitivity (classification) of object (file). It requires labeling.

QUESTION NO: 386

Under MAC, which of the following is true?

- A. All that is expressly permitted is forbidden.
- B. All that is not expressly permitted is forbidden.
- C. All that is not expressly permitted is not forbidden.
- D. None of the choices.

Answer: B

Explanation:

It is important to note that mandatory controls are prohibitive (i.e., all that is not expressly permitted is forbidden), not permissive. Only within that context do discretionary controls operate, prohibiting still more access with the same exclusionary principle. In this type of control system decisions are based on privilege (clearance) of subject (user) and sensitivity (classification) of object (file). It requires labeling.

QUESTION NO: 387

Under MAC, a clearance is a:

- A. Sensitivity
- B. Subject
- C. Privilege
- D. Object

Answer: C

Explanation:

It is important to note that mandatory controls are prohibitive (i.e., all that is not expressly permitted is forbidden), not permissive. Only within that context do discretionary controls operate, prohibiting still more access with the same exclusionary principle. In this type of control system decisions are based on privilege (clearance) of subject (user) and sensitivity (classification) of object (file). It requires labeling.

QUESTION NO: 388

Under MAC, a file is a(n):

- A. Privilege
- B. Subject
- C. Sensitivity
- D. Object

Answer: D

Explanation:

It is important to note that mandatory controls are prohibitive (i.e., all that is not expressly permitted is forbidden), not permissive. Only within that context do discretionary controls operate, prohibiting still more access with the same exclusionary principle. In this type of control system decisions are based on privilege (clearance) of subject (user) and sensitivity (classification) of object (file). It requires labeling.

QUESTION NO: 389

Under MAC, classification reflects:

- A. Sensitivity
- B. Subject
- C. Privilege
- D. Object

Answer: A

Explanation:

It is important to note that mandatory controls are prohibitive (i.e., all that is not expressly permitted is forbidden), not permissive. Only within that context do discretionary controls operate, prohibiting still more access with the same exclusionary principle. In this type of control system decisions are based on privilege (clearance) of subject (user) and sensitivity (classification) of object (file). It requires labeling.

QUESTION NO: 390

MAC is used for:

- A. Defining imposed access control level.
- B. Defining user preferences.
- C. None of the choices.
- D. Defining discretionary access control level.

Answer: A

Explanation:

As the name implies, the Mandatory Access Control defines an imposed access control level. MAC is defined as follows in the Handbook of Information Security Management: With mandatory controls, only administrators and not owners of resources may make decisions that bear on or derive from policy. Only an administrator may change the category of a resource, and no one may grant a right of access that is explicitly forbidden in the access control policy.

QUESTION NO: 391

With MAC, who may make decisions that bear on policy?

- A. None of the choices.
- B. All users.
- C. Only the administrator.
- D. All users except guests.

Answer: C

Explanation:

As the name implies, the Mandatory Access Control defines an imposed access control level. MAC is defined as follows in the Handbook of Information Security Management: With mandatory controls, only administrators and not owners of resources may make decisions that bear on or derive from policy. Only an administrator may change the category of a resource, and no one may grant a right of access that is explicitly forbidden in the access control policy.

QUESTION NO: 392

With MAC, who may NOT make decisions that derive from policy?

- A. All users except the administrator.
- B. The administrator.
- C. The power users.
- D. The guests.

Answer: A

Explanation:

As the name implies, the Mandatory Access Control defines an imposed access control level. MAC is defined as follows in the Handbook of Information Security Management: With mandatory controls, only administrators and not owners of resources may make decisions that bear on or derive from policy. Only an administrator may change the category of a resource, and no one may grant a right of access that is explicitly forbidden in the access control policy.

QUESTION NO: 393

Under the MAC control system, what is required?

- A. Performance monitoring
- B. Labeling
- C. Sensing
- D. None of the choices

Answer: B

Explanation:

It is important to note that mandatory controls are prohibitive (i.e., all that is not expressly permitted is forbidden), not permissive. Only within that context do discretionary controls operate, prohibiting still more access with the same exclusionary principle. In this type of control system decisions are based on privilege (clearance) of subject (user) and sensitivity (classification) of object (file). It requires labeling.

QUESTION NO: 394

Access controls that are not based on the policy are characterized as:

- A. Secret controls
- B. Mandatory controls
- C. Discretionary controls
- D. Corrective controls

Answer: C

Explanation:

Access controls that are not based on the policy are characterized as discretionary controls by the US government and as need-to-know controls by other organizations. The latter term connotes least privilege - those who may read an item of data are precisely those whose tasks entail the need.

QUESTION NO: 395

DAC are characterized by many organizations as:

- A. Need-to-know controls
- B. Preventive controls
- C. Mandatory adjustable controls
- D. None of the choices

Answer: A

Explanation:

Access controls that are not based on the policy are characterized as discretionary controls by the US government and as need-to-know controls by other organizations. The latter term connotes least privilege - those who may read an item of data are precisely those whose tasks entail the need.

QUESTION NO: 396

Which of the following correctly describe DAC?

- A. It is the most secure method.
- B. It is of the B2 class.
- C. It can extend beyond limiting which subjects can gain what type of access to which objects.
- D. It is of the B1 class.

Answer: C

Explanation:

With DAC, administrators can limit access to certain times of day or days of the week. Typically, the period during which access would be permitted is 9 a.m. to 5 p.m. Monday through Friday. Such a limitation is designed to ensure that access takes place only when supervisory personnel are present, to discourage unauthorized use of data. Further, subjects' rights to access might be suspended when they are on vacation or leave of absence. When subjects leave an organization altogether, their rights must be terminated rather than merely suspended.

QUESTION NO: 397

Under DAC, a subjects rights must be _____ when it leaves an organization altogether.

- A. recycled
- B. terminated
- C. suspended
- D. resumed

Answer: B

Explanation:

Discretionary access controls can extend beyond limiting which subjects can gain what type of access to which objects. Administrators can limit access to certain times of day or days of the week. Typically, the period during which access would be permitted is 9 a.m. to 5 p.m. Monday through Friday. Such a limitation is designed to ensure that access takes place only when supervisory personnel are present, to discourage unauthorized use of data. Further, subjects' rights to access might be suspended when they are on vacation or leave of absence. When subjects leave an organization altogether, their rights must be terminated rather than merely suspended.

QUESTION NO: 398

In a discretionary mode, which of the following entities is authorized to grant information access to other people?

- A. manager
- B. group leader
- C. security manager
- D. user
- E. Data Owner

Answer: E

Explanation:

QUESTION NO: 399

With RBAC, each user can be assigned:

- A. One or more roles.
- B. Only one role.
- C. A token role.
- D. A security token.

Answer: A

Explanation:

With RBAC, security is managed at a level that corresponds closely to the organization's structure. Each user is assigned one or more roles, and each role is assigned one or more privileges that are permitted to users in that role. Roles can be hierarchical.

QUESTION NO: 400

With RBAC, roles are:

- A. Based on labels.
- B. All equal
- C. Hierarchical
- D. Based on flows.

Answer: C

Explanation:

With RBAC, security is managed at a level that corresponds closely to the organization's structure. Each user is assigned one or more roles, and each role is assigned one or more privileges that are permitted to users in that role. Roles can be hierarchical.

QUESTION NO: 401

With _____, access decisions are based on the roles that individual users have as part of an organization.

- A. Server based access control.
- B. Rule based access control.
- C. Role based access control.
- D. Token based access control.

Answer: C

Explanation:

With role-based access control, access decisions are based on the roles that individual users have as part of an organization. Users take on assigned roles (such as doctor, nurse, teller, manager). The process of defining roles should be based on a thorough analysis of how an organization operates and should include input from a wide spectrum of users in an organization.

QUESTION NO: 402

Under Role based access control, access rights are grouped by:

- A. Policy name
- B. Rules
- C. Role name
- D. Sensitivity label

Answer: C

Explanation:

With role-based access control, access rights are grouped by role name, and the use of resources is restricted to individuals authorized to assume the associated role. For example, within a hospital system the role of doctor can include operations to perform diagnosis, prescribe medication, and order laboratory tests; and the role of researcher can be limited to gathering anonymous clinical information for studies.

QUESTION NO: 403

Which of the following will you consider as a “role” under a role based access control system?

- A. Bank rules
- B. Bank computer
- C. Bank teller
- D. Bank network

Answer: C

Explanation:

With role-based access control, access rights are grouped by role name, and the use of resources is restricted to individuals authorized to assume the associated role. For example, within a hospital system the role of doctor can include operations to perform diagnosis, prescribe medication, and order laboratory tests; and the role of researcher can be limited to gathering anonymous clinical information for studies.

QUESTION NO: 404

Role based access control is attracting increasing attention particularly for what applications?

- A. Scientific
- B. Commercial
- C. Security
- D. Technical

Answer: B

Explanation:

Role based access control (RBAC) is a technology that is attracting increasing attention, particularly for commercial applications, because of its potential for reducing the complexity and cost of security administration in large networked applications.

QUESTION NO: 405

What is one advantage of deploying Role based access control in large networked applications?

- A. Higher security
- B. Higher bandwidth
- C. User friendliness
- D. Lower cost

Answer: D

Explanation:

Role based access control (RBAC) is an alternative to traditional discretionary (DAC) and mandatory access control (MAC) policies. The principle motivation behind RBAC is the desire to specify and enforce enterprise-specific security policies in a way that maps naturally to an organization's structure. Traditionally, managing security has required mapping an organization's security policy to a relatively low-level set of controls, typically access control lists.

QUESTION NO: 406

DAC and MAC policies can be effectively replaced by:

- A. Rule based access control.
- B. Role based access control.
- C. Server based access control.
- D. Token based access control

Answer: B

Explanation:

Role based access control (RBAC) is an alternative to traditional discretionary (DAC) and mandatory access control (MAC) policies. The principle motivation behind RBAC is the desire to specify and enforce enterprise-specific security policies in a way that maps naturally to an organization's structure. Traditionally, managing security has required mapping an organization's security policy to a relatively low-level set of controls, typically access control lists.

QUESTION NO: 407

Which of the following correctly describe Role based access control?

- A. It allows you to specify and enforce enterprise-specific security policies in a way that maps to your user profile groups.
- B. It allows you to specify and enforce enterprise-specific security policies in a way that maps to your organizations structure.
- C. It allows you to specify and enforce enterprise-specific security policies in a way that maps to your ticketing system.
- D. It allows you to specify and enforce enterprise-specific security policies in a way that maps to your ACL.

Answer: B

Explanation:

Role based access control (RBAC) is an alternative to traditional discretionary (DAC) and mandatory access control (MAC) policies. The principle motivation behind RBAC is the desire to specify and enforce enterprise-specific security policies in a way that maps naturally to an organization's structure. Traditionally, managing security has required mapping an organization's security policy to a relatively low-level set of controls, typically access control lists.

QUESTION NO: 408

Which of the following RFC talks about Rule Based Security Policy?

- A. 1316
- B. 1989
- C. 2717
- D. 2828

Answer: D

Explanation:

The RFC 2828 - Internet Security Glossary talks about Rule Based Security Policy: A security policy based on global rules imposed for all users. These rules usually rely on comparison of the sensitivity of the resource being accessed and the possession of corresponding attributes of users, a group of users, or entities acting on behalf of users.

QUESTION NO: 409

With Rule Based Security Policy, a security policy is based on:

- A. Global rules imposed for all users.
- B. Local rules imposed for some users.
- C. Global rules imposed for no body.
- D. Global rules imposed for only the local users.

Answer: A

Explanation:

The RFC 2828 - Internet Security Glossary talks about Rule Based Security Policy: A security policy based on global rules imposed for all users. These rules usually rely on comparison of the sensitivity of the resource being accessed and the possession of corresponding attributes of users, a group of users, or entities acting on behalf of users.

QUESTION NO: 410

With Rule Based Security Policy, global rules usually rely on comparison of the _____ of the resource being accessed.

- A. A group of users.
- B. Users
- C. Sensitivity
- D. Entities

Answer: C

Explanation:

The RFC 2828 - Internet Security Glossary talks about Rule Based Security Policy: A security policy based on global rules imposed for all users. These rules usually rely on comparison of the sensitivity of the resource being accessed and the possession of corresponding attributes of users, a group of users, or entities acting on behalf of users.

Topic 4, Application Development Security**QUESTION NO: 411**

Which of the following is a facial feature identification product that can employ artificial intelligence and can require the system to learn from experience?

- A. All of the choices.
- B. Digital nervous system.
- C. Neural networking
- D. DSV

Answer: C

Explanation:

There are facial feature identification products that are on the market that use other technologies or methods to capture one's face. One type of method used is neural networking technology. This type of technology can employ artificial intelligence that requires the system to "learn" from experience. This "learning" experience helps the system to close in on an identification of an individual. Most facial feature identification systems today only allow for two-dimensional frontal images of one's face.

Not DSV:

Signature biometrics are often referred to dynamic signature verification (DSV) and look at the way we sign our names. [15] The dynamic nature differentiates it from the study of static signatures on paper. Within DSV a number of characteristics can be extracted from the physical signing process. Examples of these behavioral characteristics are the angle of the pen is held, the time taken to sign, velocity and acceleration of the tip of the pen, number of times the pen is lifted from the paper. Despite the fact that the way we sign is mostly learnt during the years it is very hard to forge and replicate.

QUESTION NO: 412

Which option is NOT a benefit derived from the use of neural networks?

- A. Linearity
- B. Input-Output Mapping
- C. Adaptivity
- D. Fault Tolerance

Answer: D

Explanation: Linearity: "If the sum of the weighted inputs then exceeds the threshold, the neuron will "fire" and there will be an output from that neuron. An alternative approach would be to have the output of the neuron be a linear function of the sum of the artificial neuron inputs."

Input-Output Mapping: "For example, if a specific output vector was required for a specific input where the relationship between input and output was non-linear, the neural network would be trained by applying a set of input vector."

Adaptivity: "The neural network would have then be said to have learned to provide the correct response for each input vector."

QUESTION NO: 413

Which of the following is a characteristic of a decision support system (DSS)?

- A. DSS is aimed at solving highly structured problems
- B. DSS emphasizes flexibility in the decision making approach of users
- C. DSS supports only structured decision-making tasks
- D. DSS combines the use of models with non-traditional data access and retrieval functions

Answer: B

Explanation:

QUESTION NO: 414

Which of the following is a communication mechanism that enables direct conversation between two applications?

- A. DDE
- B. OLE
- C. ODBC
- D. DCOM

Answer: A

Explanation: "Dynamic Data Exchange (DDE) enables applications to share data by providing IPC. It is based on the client/server model and enables two programs to send commands to each other directly. DDE is a communication mechanism that enables direct conversation between two applications. The source of the data is called the server, and the receiver of the data is the client."

Pg. 718 Shon Harris: All-In-One CISSP Certification Exam Guide

QUESTION NO: 415

Which expert system operating mode allows determining if a given hypothesis is valid?

- A. Vertical chaining
- B. Lateral chaining
- C. Forward chaining
- D. Backward chaining

Answer: D

Explanation: "The expert system operates in either a forward-chaining or backward-chaining mode. In a forward-chaining mode, the expert system acquires information and comes to a conclusion based on that information. Forward-chaining is the reasoning approach that can be used when there is a small number of solutions relative to the number of inputs. In a backward-chaining mode, the expert system backtracks to determine if a given hypothesis is valid. Backward-chaining is generally used when there are a large number of possible solutions relative to the number of inputs. Another type of expert system is the blackboard. A blackboard is an expert system-reasoning methodology in which a solution is generated by the use of a virtual "blackboard," wherein information or potential solutions are placed on the blackboard by the plurality of individuals or expert knowledge sources. As more information is placed on the blackboard in an iterative process, a solution is generated." Pg 354 Krutz: The CISSP Prep Guide: Gold Edition

QUESTION NO: 416

Which one of the following is a security issue related to aggregation in a database?

- A. Polyinstantiation
- B. Inference
- C. Partitioning
- D. Data swapping

Answer: B

Explanation: Inference is the ability of users to infer or deduce information about data at sensitivity levels for which they do not have access privileges. –Ronald Krutz The CISSP PREP Guide (gold edition) pg 358

The other security issue is inference, which is very similar to aggregation. – Shon Harris All-in-one CISSP Certification Guide pg 727

Partitioning a database involves dividing the database into different parts, which makes it much

harder for an unauthorized individual to find connecting pieces of data that can be brought together and other information that can be deduced or uncovered. – Shon Harris All-in-one CISSP Certification Guide pg 726

Polyinstantiation- This enables a relation to contain multiple tuples with the same primary keys with each instance distinguished by a security level. – Shon Harris All-in-one CISSP Certification Guide pg 727

QUESTION NO: 417

How is polyinstantiation used to secure a multilevel database?

- A. It prevents low-level database users from inferring the existence of higher level data.
- B. It confirms that all constrained data items within the system conform to integrity specifications.
- C. It ensures that all mechanism in a system are responsible for enforcing the database security policy.
- D. Two operations at the same layer will conflict if they operate on the same data item and at least one of them is an update.

Answer: A

Explanation: “Polyinstantiation is the development of a detailed version of an object from another object using different values in the new object. In the database information security, this term is concerned with the same primary key for different relations at different classification levels being stored in the same database. For example, in a relational database, the same of a military unit may be classified Secret in the database and may have an identification number as the primary key. If another user at a lower classification level attempts to create a confidential entry for another military unit using the same identification number as a primary key, a rejection of this attempt would imply to the lower level user that the same identification number existed at a higher level of classification. To avoid this inference channel of information, the lower level user would be issued the same identification number for their unit and the database management system would manage this situation where the same primary key was used for different units.” Pg 352-353 Krutz: The CISSP Prep Guide: Gold Edition.

“Polyinstantiation occurs when two or more rows in the same table appear to have identical primary key elements but contain different data for use at differing classification levels. Polyinstantiation is often used as a defense against some types of inference attacks.

For example, consider a database table containing the location of various naval ships on patrol.

Normally, this database contains the exact position of each ship stored at the level with secret classification. However, on particular ship, the USS UpToNoGood, is on an undercover mission to a top-secret location. Military commanders do not want anyone to know that the ship deviated from its normal patrol. If the database administrators simply change the classification of the UpToNoGood's location to top secret, a user with secret clearance would know that something unusual was going on when they couldn't query the location of the ship. However, if polyinstantiation is used, two records could be inserted into the table. The first one, classified at the top secret level, would reflect the true location of the ship and be available only to users with the appropriate top secret security clearance. The second record, classified at the secret level, would indicate that the ship was on routine patrol and would be returned to users with a secret clearance."

Pg. 191 Tittel: CISSP Study Guide Second Edition

QUESTION NO: 418

Which of the following defines the software that maintains and provides access to the database?

- A. database management system (DBMS)
- B. relational database management systems (RDBMS)
- C. database identification system (DBIS)
- D. Interface Definition Language system (IDLS)

Answer: A

Explanation:

QUESTION NO: 419

Which of the following is not a responsibility of a database administrator?

- A. Maintaining databases
- B. Implementing access rules to databases
- C. Reorganizing databases
- D. Providing access authorization to databases

Answer: D

Explanation:

QUESTION NO: 420

SQL commands do not include which of the following?

- A. Select, Update
- B. Grant, Revoke
- C. Delete, Insert
- D. Add, Replace

Answer: D

Explanation: "SQL commands include Select, Update, Delete, Insert, Grant, and Revoke." Pg 62
Krutz: CISSP Prep Guide: Gold Edition

QUESTION NO: 421

A persistent collection of interrelated data items can be defined as which of the following?

- A. database
- B. database management system
- C. database security
- D. database shadowing

Answer: A

Explanation:

QUESTION NO: 422

Which one of the following is commonly used for retrofitting multilevel security to a Database Management System?

- A. Trusted kernel
- B. Kernel controller
- C. Front end controller
- D. Trusted front-end

Answer: D

Explanation:

QUESTION NO: 423

Which of the following is the marriage of object-oriented and relational technologies combining the attributes of both?

- A. object-relational database
- B. object-oriented database
- C. object-linking database
- D. object-management database

Answer: A

Explanation:

QUESTION NO: 424

A department manager has read access to the salaries of the employees in his/her department but not to the salaries of employees in other departments. A database security mechanism that enforces this policy would typically be said to provide which of the following?

- A. content-dependent access control
- B. context-dependent access control
- C. least privileges access control
- D. ownership-based access control

Answer: A

Explanation: "Database security takes a different approach than operating system security. In an operating system, the identity and authentication of the subject controls access. This is done through access control lists (ACLs), capability tables, roles, and security labels. The operating system only makes decisions about where a subject can access a file; it does not make this decision based on the contents of the file itself. If Mitch can access file A, it does not matter if that file contains information about a cookie recipe or secret information from the Cold War. On the other hand, database security does look at the contents of a file when it makes an access control decision, which is referred to as content-dependent access control. This type of access control increases processing overhead, but it provides higher granular control." Pg. 677 Shon Harris:

CISSP Certification All-in-One Exam Guide

QUESTION NO: 425

Which of the following is an important part of database design that ensures that attributes in a table depend only on the primary key?

- A. Normalization
- B. Assimilation
- C. Reduction
- D. Compaction

Answer: A

Explanation:

QUESTION NO: 426

Which of the following does not address Database Management Systems (DBMS) Security?

- A. Perturbation
- B. Cell suppression
- C. Padded Cells
- D. Partitioning

Answer: C

Explanation:

QUESTION NO: 427

Which of the following is commonly used for retrofitting multilevel security to a database management system?

- A. trusted front-end
- B. trusted back-end
- C. controller

D. kernel

Answer: A

Explanation:

QUESTION NO: 428

Normalizing data within a database includes all of the following except which?

- A. Eliminating repeating groups by putting them into separate tables
- B. Eliminating redundant data
- C. Eliminating attributes in a table that are not dependent on the primary key of that table
- D. Eliminating duplicate key fields by putting them into separate tables

Answer: D

Explanation: "Data Normalization

Normalization is an important part of database design that ensures that attributes in a table depend only on the primary key. This process makes it easier to maintain data and have consistent reports.

Normalizing data in the database consists of three steps:

- 1.)Eliminating any repeating groups by putting them into separate tables
- 2.)Eliminating redundant data (occurring in more than one table)
- 3.)Eliminating attributes in a table that are not dependent on the primary key of that table"

Pg. 62 Krutz: The CISSP Prep Guide: Gold Edition

QUESTION NO: 429

SQL commands do not include which of the following?

- A. Select, Update
- B. Grant, Revoke
- C. Delete, Insert
- D. Add, Replace

Answer: D

Explanation: "SQL commands include Select, Update, Delete, Grant, and Revoke." Pg. 62 Krutz: The CISSP Prep Guide: Gold Edition

"Developed by IBM, SQL is a standard data manipulation and relational database definition language. The SQL Data Definition Language creates and deletes views and relations (tables). SQL commands include Select, Update, Delete, Insert, Grant, and Revoke. The latter two commands are used in access control to grant and revoke privileges to resources. Usually, the owner of an object can withhold or transfer GRANT privileges to an object to another subject. If the owner intentionally does not transfer the GRANT privileges, however, which are relative to an object to the individual A, A cannot pass on the GRANT privileges to another subject. In some instances, however, this security control can be circumvented. For example, if A copies the object, A essentially becomes the owner of that object and thus can transfer the GRANT privileges to another user, such as user B.

SQL security issues include the granularity of authorization and the number of different ways you can execute the same query.

Pg. 63 Krutz: The CISSP Prep Guide: Gold Edition.

QUESTION NO: 430

SQL security issues include which of the following?

- A. The granularity of authorizations
- B. The size of databases
- C. The complexity of key structures
- D. The number of candidate key elements

Answer: A

Explanation: Developed by IBM, SQL is a standard data manipulation and relational database definition language. The SQL Data Definition Language creates and deletes views and relations (tables). SQL commands include Select, Update, Delete, Insert, Grant, and Revoke. The latter two commands are used in access control to grant and revoke privileges to resources. Usually, the owner of an object can withhold or transfer GRANT privileges to an object to another subject. If the owner intentionally does not transfer the GRANT privileges, however, which are relative to an object to the individual A, A cannot pass on the GRANT privileges to another subject. In some instances, however, this security control can be circumvented. For example, if A copies the object, A essentially becomes the owner of that object and thus can transfer the GRANT privileges to

another user, such as user B.

SQL security issues include the granularity of authorization and the number of different ways you can execute the same query.

Pg. 63 Krutz: The CISSP Prep Guide: Gold Edition.

QUESTION NO: 431

Which of the following are placeholders for literal values in a Structured Query Language (SQL) query being sent to the database on a server?

- A. Bind variables
- B. Assimilation variables
- C. Reduction variables
- D. Resolution variables

Answer: A

Explanation:

QUESTION NO: 432

What ensures that attributes in a table depend only on the primary key?

- A. Referential integrity
- B. The database management system (DBMS)
- C. Data Normalization
- D. Entity integrity

Answer: C

Explanation:

QUESTION NO: 433

Which of the following represent the rows of the table in a relational database?

- A. attributes
- B. records or tuples
- C. record retention
- D. relation

Answer: B

Explanation:

QUESTION NO: 434

With regard to databases, which of the following has characteristics of ease of reusing code and analysis and reduced maintenance?

- A. Object-Oriented Data Bases (OODB)
- B. Object-Relational Data Bases (ORDB)
- C. Relational Data Bases
- D. Data Base management systems (DBMS)

Answer: A

Explanation:

QUESTION NO: 435

Complex applications involving multimedia, computer aided design, video, graphics, and expert systems are more suited to which of the following?

- A. Object-Oriented Data Bases (OODB)
- B. Object-Relational Data Bases
- C. Relational Data Bases
- D. Data base management systems (DBMS)

Answer: A

Explanation:

QUESTION NO: 436

Which of the following refers to the number of columns in a table?

- A. Schema
- B. Relation
- C. Degree
- D. Cardinality

Answer: C

Explanation:

QUESTION NO: 437

Which of the following refers to the number of rows in a relation?

- A. cardinality
- B. degree
- C. depth
- D. breadth

Answer: A

Explanation:

QUESTION NO: 438

Which of the following refers to the number of columns in a relation?

- A. degree
- B. cardinality
- C. depth
- D. breadth

Answer: A

Explanation:

QUESTION NO: 439

What is one disadvantage of content-dependent protection of information?

- A. It increases processing overhead
- B. It requires additional password entry
- C. It exposes the system to data locking
- D. It limits the user's individual address space

Answer: A

Explanation: Content-Dependent Access Control

"Just like the name sounds, access to objects is determined by the content within the object. This is used many times in databases and the type of Web-based material a firewall allows...If a table within the database contains information about employees' salaries, the managers were not allowed to view it, but they could view information about an employee's work history. The content of the database fields dictates which user can see specific information within the database tables." pg 161 Shon Harris: All-In-One CISSP Certification. Decisions will have to be made about the content, therefore increasing processing overhead.

QUESTION NO: 440

Which one of the following control steps is usually NOT performed in data warehousing applications?

- A. Monitor summary tables for regular use.
- B. Control meta data from being used interactively.
- C. Monitor the data purging plan.
- D. Reconcile data moved between the operations environment and data warehouse.

Answer: A

Explanation: Not B: It is important to control meta data from being used interactively by unauthorized users. "Data warehouses and data mining are significant to security professionals for two reasons. First, as previously mentioned, data warehouses contain large amounts of potentially sensitive information vulnerable to aggregation and inference attacks, and security practitioners must ensure that adequate access controls and other security measures are in place to safeguard this data." Pg 192 Tittel: CISSP Study Guide

Not C: "The data in the data warehouse must be maintained to ensure that it is timely and valid. The term data scrubbing refers to maintenance of the data warehouse by deleting information that is unreliable or no longer relevant." Pg 358-359 Krutz: The CISSP Prep Guide: Gold Edition

Not D: "To create a data warehouse, data is taken from an operational database, redundancies are removed, and the data is "cleaned up" in general." Pg 358 Krutz: The CISSP Prep Guide: Gold Edition

QUESTION NO: 441

A storage information architecture does not address which of the following?

- A. archiving of data
- B. collection of data
- C. management of data
- D. use of data

Answer: A

Explanation:

QUESTION NO: 442

Which of the following can be defined as the set of allowable values that an attribute can take?

- A. domain of a relation
- B. domain name service of a relation
- C. domain analysis of a relation
- D. domains, in database of a relation

Answer: A

Explanation:

QUESTION NO: 443

Programmed procedures which ensure that valid transactions are processed accurately and only once in the current timescale are referred to as

- A. Data installation controls
- B. Application controls
- C. Operation controls
- D. Physical controls

Answer: B

Explanation:

QUESTION NO: 444

What is the most effective means of determining how controls are functioning within an operating system?

- A. Interview with computer operator
- B. Review of software control features and/or parameters
- C. Review of operating system manual
- D. Interview with product vendor

Answer: B

Explanation:

QUESTION NO: 445

What is the most effective means of determining how controls are functioning within an operating system?

- A. Interview with computer operator
- B. Review of software control features and/or parameters
- C. Review of operating system manual
- D. Interview with product vendor

Answer: B

Explanation:

QUESTION NO: 446

Program change controls must ensure that all changes are

- A. Audited to verify intent.
- B. Tested to ensure correctness.
- C. Implemented into production systems.
- D. Within established performance criteria.

Answer: B

Explanation: Document of the change. Once the change is approved, it should be entered into a change log and the log should be updated as the process continues toward completion.

Tested and presented. The change must be fully tested to uncover any unforeseen results.

Depending on the severity of the change and the company's organization, the change and implementation may need to be presented to a change control committee. This helps show different sides to the purpose and outcome of the change and the possible ramifications. - Shon Harris All-in-one CISSP Certification Guide pg 815

QUESTION NO: 447

Which question is NOT true concerning Application Control?

- A. It limits end users use of applications in such a way that only particular screens are visible
- B. Only specific records can be requested choice
- C. Particular uses of application can be recorded for audit purposes
- D. Is non-transparent to the endpoint applications so changes are needed to the applications involved

Answer: D

Explanation:

QUESTION NO: 448

A computer program used to process the weekly payroll contains an instruction that the amount of the gross pay cannot exceed \$2,500 for any one employee. This instruction is an example of a control that is referred to as a:

- A. sequence check
- B. check digit
- C. limit check
- D. record check

Answer: C

Explanation:

QUESTION NO: 449

What are edit controls?

- A. Preventive controls
- B. Detective controls
- C. Corrective controls
- D. Compensating controls

Answer: A

Explanation:

"Edit control" / concurrency – a preventative security mechanism to help ensure database is correct (integrity & availability protected).

QUESTION NO: 450

Which one of the following properties of a transaction processing system ensures that once a transaction completes successfully (commits), the update service even if there is a system failure?

- A. Atomicity
- B. Consistency
- C. Isolation
- D. Durability

Answer: D

Explanation:**QUESTION NO: 451**

To ensure integrity, a payroll application program may record transactions in the appropriate accounting period by using

- A. Application checkpoints
- B. Time and date stamps
- C. Accrual journal entries
- D. End of period journals

Answer: B

Explanation:**QUESTION NO: 452**

What ensures that the control mechanisms correctly implement the security policy for the entire life cycle of an information system?

- A. Accountability controls
- B. Mandatory access controls
- C. Assurance procedures
- D. Administrative controls

Answer: C

Explanation: Assurance procedures ensure that the control mechanisms correctly implement the security policy for the entire life cycle of an information system.

Pg 33 Krutz: The CISSP Prep Guide.

QUESTION NO: 453

Development staff should:

- A. Implement systems
- B. Support production data
- C. Perform unit testing
- D. Perform acceptance testing

Answer: C

Explanation:

QUESTION NO: 454

Which of the following is not used as a cost estimating technique during the project planning stage?

- A. Delphi technique
- B. Expert Judgment
- C. Program Evaluation Review Technique (PERT) charts
- D. Function points (FP)

Answer: C

Explanation:

“Methods and techniques for cost estimation:

Experts' evaluation

Delphi

Bottom-up approaches

Empirical models

COCOMO

Function Points

Combining Methods”

QUESTION NO: 455

Which of the following methodologies is appropriate for planning and controlling activities and resources in a system project?

- A. Gantt charts
- B. Program evaluation review technique (PERT)
- C. Critical path methodology (CPM)
- D. Function point analysis (FP)

Answer: A

Explanation: A Gantt chart is a popular type of bar chart showing the interrelationships of how projects, schedules, and other time-related systems progress over time.

Not B:

Program Evaluation and Review Technique - (PERT) A method used to size a software product and calculate the Standard Deviation (SD) for risk assessment. The PERT equation (beta distribution) estimates the Equivalent Delivered Source Instructions (EDSIs) and the SD based on the analyst's estimates of the lowest possible size, the most likely size, and the highest possible size of each computer program component (CPC).

<http://computing-dictionary.thefreedictionary.com/>

QUESTION NO: 456

Which of the following is an advantage of using a high-level programming language?

- A. It decreases the total amount of code writers
- B. It allows programmers to define syntax
- C. It requires programmer-controlled storage management
- D. It enforces coding standards

Answer: A

Explanation:

QUESTION NO: 457

The design phase in a system development life cycle includes all of the following EXCEPT

- A. Determining sufficient security controls.
- B. Conducting a detailed design review.
- C. Developing an operations and maintenance manual.
- D. Developing a validation, verification, and testing plan.

Answer: C

Explanation: Systems Development Life Cycle

Conceptual Definition

Functional Requirements Determination

Protection Specifications Development

Design Review

Code Review Walk-Through

System Test Review

Certification and Accreditation

Maintenance

Pg 224-228 Tittel: CISSP Study Guide.

QUESTION NO: 458

By far, the largest security exposure in application system development relates to

- A.** Maintenance and debugging hooks.
- B.** Deliberate compromise.
- C.** Change control.
- D.** Errors and lack of training

Answer: A

Explanation: Maintenance hook - instructions within a program's code that enable the developer or maintainer to enter the program without having to go through the usual access control and authentication processes. They should be removed from the code before being released for production; otherwise, they can cause serious security risks. They are also referred to as trapdoors. - Shon Harris All-in-one CISSP Certification Guide pg 933

QUESTION NO: 459

Which of the following is a 5th Generation Language?

- A. LISP
- B. BASIC
- C. NATURAL
- D. Assembly Language

Answer: A

Explanation:

QUESTION NO: 460

When considering the IT Development Life-Cycle, security should be:

- A. Mostly considered during the initiation phase.
- B. Mostly considered during the development phase.
- C. Treated as an integral part of the overall system design.
- D. Add once the design is completed.

Answer: C

Explanation:

QUESTION NO: 461

Which of the following represents the best programming?

- A. Low cohesion, low coupling
- B. Low cohesion, high coupling
- C. High cohesion, low coupling
- D. High cohesion, high coupling

Answer: C

Explanation:

QUESTION NO: 462

The INITIAL phase of the system development life cycle would normally include

- A. Cost-benefit analysis
- B. System design review
- C. Executive project approval
- D. Project status summary

Answer: C

Explanation: Project management is an important part of product development and security management is an important part of project management. - Shon Harris All-in-one CISSP Certification Guide pg 732

QUESTION NO: 463

Which of the following computer design approaches is based on the fact that in earlier technologies, the instruction fetch was the longest part of the cycle?

- A. Pipelining
- B. Reduced Instruction Set Computers (RISC)
- C. Complex Instruction Set Computers (CISC)
- D. Scalar processors

Answer: C

Reference: pg 255 Krutz: CISSP Prep Guide: Gold Edition

QUESTION NO: 464

Which one of the following tests determines whether the content of data within an application program falls within predetermined limits?

- A. Parity check
- B. Reasonableness check
- C. Mathematical accuracy check
- D. Check digit verification

Answer: B

Explanation: Reasonableness check: A test to determine whether a value conforms to specified criteria. Note: A reasonableness check can be used to eliminate questionable data points from subsequent processing.

QUESTION NO: 465

Buffer overflow and boundary condition errors are subsets of:

- A. Race condition errors
- B. Access validation errors
- C. Exceptional condition handling errors
- D. Input validation errors

Answer: D

Explanation:

QUESTION NO: 466

Which of the following statements pertaining to software testing approaches is correct?

- A. A bottom-up approach allows interface errors to be detected earlier
- B. A top-down approach allows errors in critical modules to be detected earlier
- C. The test plan and results should be retained as part of the system's permanent documentation
- D. Black box testing is predicated on a close examination of procedural detail

Answer: C

Explanation:

QUESTION NO: 467

Which of the following phases of a system development life-cycle is most concerned with authenticating users and processes to ensure appropriate access control decisions?

- A. Development/acquisition
- B. Implementation
- C. Operation/Maintenance
- D. Initiation

Answer: C

Explanation:**QUESTION NO: 468**

Which of the following would be the most serious risk where a systems development life cycle methodology is inadequate?

- A. The project will be completed late
- B. The project will exceed the cost estimates
- C. The project will be incompatible with existing systems
- D. The project will fail to meet business and user needs

Answer: D

Explanation:**QUESTION NO: 469**

Which of the following would best describe the difference between white-box testing and black-box testing?

- A. White-box testing is performed by an independent programmer team
- B. Black-box testing uses the bottom-up approach
- C. White-box testing examines the program internal logical structure
- D. Black-box testing involves the business units

Answer: C

Explanation:**QUESTION NO: 470**

Which of the following refers to the work product satisfying the real-world requirements and concepts?

- A. validation
- B. verification
- C. concurrence

D. accuracy

Answer: A

Reference: pg 820 Hansche: Official (ISC)2 Guide to the CISSP Exam

QUESTION NO: 471

Which model, based on the premise that the quality of a software product is a direct function of the quality of its associated software development and maintenance processes, introduced five levels with which the maturity of an organization involved in the software process is evaluated?

- A. The total Quality Model (TQM)
- B. The IDEAL Model
- C. The Software Capability Maturity Model
- D. The Spiral Model

Answer: C

Explanation:

QUESTION NO: 472

Which of the following would provide the best stress testing environment?

- A. Test environment using test data
- B. Test environment using live workloads
- C. Production environment using test data
- D. Production environment using live workloads

Answer: B

Explanation:

QUESTION NO: 473

In a change control environment, which one of the following REDUCES the assurance of proper changes to source programs in production status?

- A. Authorization of the change.
- B. Testing of the change.
- C. Programmer access.
- D. Documentation of the change.

Answer: C

Explanation: I think I am going to disagree with the original answer (B testing of the change) here. The question has REDUCES the assurance.

"Personnel separate from the programmers should conduct this testing." -Ronald Krutz The CISSP PREP Guide (gold edition) pg 345

QUESTION NO: 474

Why should batch files and scripts be stored in a protected area?

- A. Because of the least privilege concept
- B. Because they cannot be accessed by operators
- C. Because they may contain credentials
- D. Because of the need-to-know concept

Answer: C

Topic 5, Operations Security

QUESTION NO: 475

The PRIMARY purpose of operations security is

- A. Protect the system hardware from environment damage.
- B. Monitor the actions of vendor service personnel.
- C. Safeguard information assets that are resident in the system.
- D. Establish thresholds for violation detection and logging.

Answer: C

Explanation: I think A or C could be the answers. I am leaning towards the C answer but use your

best judgment.

"Operations Security can be described as the controls over the hardware in a computing facility, the data media used in a facility, and the operators using these resources in a facility...A Cissp candidate will be expected to know the resources that must be protected, the privileges that must be restricted, the control mechanisms that are available, the potential for access abuse, the appropriate controls, and the principles of good practice." -Ronald Krutz The CISSP PREP Guide (gold edition) pg 297

QUESTION NO: 476

Which of the following is not a component of a Operations Security "triples"?

- A. Asset
- B. Threat
- C. Vulnerability
- D. Risk

Answer: D

Reference: pg 298 Krutz: CISSP Study Guide: Gold Edition

QUESTION NO: 477

A periodic review of user account management should not determine:

- A. Conformity with the concept of least privilege
- B. Whether active accounts are still being used
- C. Strength of user-chosen passwords
- D. Whether management authorizations are up-to-date

Answer: C

Explanation:

QUESTION NO: 478

Which of the following functions is less likely to be performed by a typical security administrator?

- A. Setting user clearances and initial passwords
- B. Adding and removing system users
- C. Setting or changing file sensitivity labels
- D. Reviewing audit data

Answer: B

Explanation:

QUESTION NO: 479

Who is responsible for setting user clearances to computer-based information?

- A. Security administrators
- B. Operators
- C. Data owners
- D. Data custodians

Answer: A

Explanation:

QUESTION NO: 480

Who is the individual permitted to add users or install trusted programs?

- A. Database Administrator
- B. Computer Manager
- C. Security Administrator
- D. Operations Manager

Answer: D

Explanation: Typical system administrator or enhanced operator functions can include the following

Installing system software

Starting up (booting) and shutting down a system

Adding and removing system users

Performing back-ups and recovery

Handling printers and managing print queues -Ronald Krutz The CISSP PREP Guide (gold edition) pg 305-304

QUESTION NO: 481

In Unix, which file is required for you to set up an environment such that every user on the other host is a trusted user that can log into this host without authentication?

- A. /etc/shadow
- B. /etc/host.equiv
- C. /etc/passwd
- D. None of the choices.

Answer: B

Explanation:

The /etc/hosts.equiv file is saying that every user on the other host is a trusted user and allowed to log into this host without authentication (i.e. NO PASSWORD). The only thing that must exist for a user to log in to this system is an /etc/passwd entry by the same login name the user is currently using. In other words, if there is a user trying to log into this system whose login name is "bhope", then there must be a "bhope" listed in the /etc/passwd file.

QUESTION NO: 482

For what reason would a network administrator leverage promiscuous mode?

- A. To screen out all network errors that affect network statistical information.
- B. To monitor the network to gain a complete statistical picture of activity.
- C. To monitor only unauthorized activity and use.
- D. To capture only unauthorized internal/external use.

Answer: B

Explanation:

QUESTION NO: 483

Which of the following questions is less likely to help in assessing controls over hardware and software maintenance?

- A.** Is access to all program libraries restricted and controlled?
- B.** Are integrity verification programs used by applications to look for evidences of data tampering, errors, and omissions?
- C.** Is there version control?
- D.** Are system components tested, documented, and approved prior to promotion to production?

Answer: B

Explanation:

QUESTION NO: 484

Which of the following correctly describe "good" security practice?

- A.** Accounts should be monitored regularly.
- B.** You should have a procedure in place to verify password strength.
- C.** You should ensure that there are no accounts without passwords.
- D.** All of the choices.

Answer: D

Explanation:

In many organizations accounts are created and then nobody ever touches those accounts again. This is a very poor security practice. Accounts should be monitored regularly, you should look at unused accounts and you should have a procedure in place to ensure that departing employees have their rights revoke prior to leaving the company. You should also have a procedure in place to verify password strength or to ensure that there are no accounts without passwords.

QUESTION NO: 485

Access to the _____ account on a Unix server must be limited to only the system administrators that must absolutely have this level of access.

- A. Superuser of inetd.
- B. Manager or root.
- C. Fsf or root
- D. Superuser or root.

Answer: D

Explanation:

Access to the superuser or root account on a server must be limited to only the system administrators that must absolutely have this level of access. Use of programs such as SUDO is recommended to give limited and controlled root access to administrators that have a need for such access.

QUESTION NO: 486

Which of the following files should the security administrator be restricted to READ only access?

- A. Security parameters
- B. User passwords
- C. User profiles
- D. System log

Answer: D

Explanation:

QUESTION NO: 487

Root login should only be allowed via:

- A. Rsh
- B. System console
- C. Remote program
- D. VNC

Answer: B

Explanation:

The root account must be the only account with a user ID of 0 (zero) that has open access to the UNIX shell. It must not be possible for root to sign on directly except at the system console. All other access to the root account must be via the 'su' command.

QUESTION NO: 488

What does "System Integrity" mean?

- A. The software of the system has been implemented as designed.
- B. Users can't tamper with processes they do not own
- C. Hardware and firmware have undergone periodic testing to verify that they are functioning properly
- D. Design specifications have been verified against the formal top-level specification

Answer: C

Explanation:

QUESTION NO: 489

Operations Security seeks to primarily protect against which of the following?

- A. object reuse
- B. facility disaster
- C. compromising emanations
- D. asset threats

Answer: D

Explanation:

QUESTION NO: 490

In order to avoid mishandling of media or information, you should consider using:

- A. Labeling
- B. Token
- C. Ticket
- D. SLL

Answer: A

Explanation:

In order to avoid mishandling of media or information, proper labeling must be used. All tape, floppy disks, and other computer storage media containing sensitive information must be externally marked with the appropriate sensitivity classification. All tape, floppy disks, and other computer storage media containing unrestricted information must be externally marked as such. All printed copies, printouts, etc., from a computer system must be clearly labeled with the proper classification.

QUESTION NO: 491

In order to avoid mishandling of media or information, which of the following should be labeled?

- A. All of the choices.
- B. Printed copies
- C. Tape
- D. Floppy disks

Answer: A

Explanation:

In order to avoid mishandling of media or information, proper labeling must be used.

All tape, floppy disks, and other computer storage media containing sensitive information must be externally marked with the appropriate sensitivity classification.

All tape, floppy disks, and other computer storage media containing unrestricted information must be externally marked as such.

All printed copies, printouts, etc., from a computer system must be clearly labeled with the proper classification.

As a rule of thumb, you should have an indication of the classification of the document. The classification is based on the sensitivity of information. It is usually marked at the minimum on the front and back cover, title, and first pages.

QUESTION NO: 492

Compact Disc (CD) optical media types is used more often for:

- A. very small data sets
- B. very small files data sets
- C. larger data sets
- D. very aggregated data sets

Answer: A

Explanation:

QUESTION NO: 493

At which temperature does damage start occurring to magnetic media?

- A. 100 degrees
- B. 125 degrees
- C. 150 degrees
- D. 175 degrees

Answer: A

Explanation:

QUESTION NO: 494

Which of the following statements pertaining to air conditioning for an information processing facility is correct?

- A.** The AC units must be controllable from outside the area
- B.** The AC units must keep negative pressure in the room so that smoke and other gases are forced out of the room
- C.** The AC units must be on the same power source as the equipment in the room to allow for easier shutdown
- D.** The AC units must be dedicated to the information processing facilities

Answer: D

Explanation:

QUESTION NO: 495

Removing unnecessary processes, segregating inter-process communications, and reducing executing privileges to increase system security is commonly called

- A.** Hardening
- B.** Segmenting
- C.** Aggregating
- D.** Kerneling

Answer: A

Explanation: What is hardening? Naturally, there is more than one definition, but in general, one tightens control using policies which affect authorization, authentication and permissions. Nothing happens by default. You only give out permission after thinking about it, something like "deny all" to everyone, then "allow" with justification. Shut off everything, then only turn on that which must be turned on. It is not unlike locking every single door, window and access point in your house, then unlocking only those that need to be. It is quite common for users to take all the defaults when their new system gets turned on making for instant vulnerability. A major problem is trying to figure out where all those details are that need to be turned off, without making the system unusable.

QUESTION NO: 496

RAID levels 3 and 5 run:

- A. faster on hardware
- B. slower on hardware
- C. faster on software
- D. at the same speed on software and hardware

Answer: A

Explanation:

QUESTION NO: 497

Which of the following RAID levels functions as a single virtual disk?

- A. RAID Level 7
- B. RAID Level 5
- C. RAID Level 10
- D. RAID Level 2

Answer: D

Explanation:

RAID level 2 would be our guess, but all of them can function as a single virtual disk, that is what logical drives present.

QUESTION NO: 498

Which of the following takes the concept of RAID 1 (mirroring) and applies it to a pair of servers?

- A. A redundant server implementation
- B. A redundant client implementation
- C. A redundant guest implementation
- D. A redundant host implementation

Answer: A

Explanation:

QUESTION NO: 499

Which of the following enables the drive array to continue to operate if any disk or any path to any disk fails?

- A. RAID Level 7
- B. RAID Level 1
- C. RAID Level 2
- D. RAID Level 5

Answer: A

Explanation: "RAID Level 7 is a variation of RAID 5 wherein the array functions as a single virtual disk in the hardware. This is sometimes simulated by software running over a RAID level 5 hardware implementation, which enables the drive array to continue to operate if any disk or any path to any disk fails. It also provides parity protection." Pg 91 Krutz: CISSP Prep Guide: Gold Edition.

QUESTION NO: 500

Depending upon the volume of data that needs to be copied, full backups to tape can take:

- A. an incredible amount of time
- B. a credible amount of time
- C. an ideal amount of time
- D. an exclusive amount of time

Answer: A

Explanation:

QUESTION NO: 501

Which one of the following entails immediately transmitting copies of on-line transactions to a remote computer facility for backup?

- A. Archival storage management (ASM)
- B. Electronic vaulting
- C. Hierarchical storage management (HSM)
- D. Data compression

Answer: B

Explanation: "Electronic vaulting makes an immediate copy of a changed file or transaction and sends it to a remote location where the original backup is stored....Another technology used for automated backups is hierarchical storage management (HSM). In this situation, the HSM system dynamically manages the storage and cover of files, which are copied to storage media devices that vary in speed and cost. The faster media hold the data that is accessed more often and the seldom-used files are stored on the slower devices, or near-line devices. The different storage media range from optical disk, magnetic disks, and tapes. Pg. 619 Shon Harris CISSP All-In-One Certification Exam Guide

QUESTION NO: 502

When continuous availability (24 hours-a-day processing) is required, which one of the following provides a good alternative to tape backups?

- A. Disk mirroring
- B. Backup to jukebox
- C. Optical disk backup
- D. Daily archiving

Answer: B

Explanation: Hierarchical Storage Management (HSM). HSM provides continuous on-line backup by using optical or tape 'jukeboxes,' similar to WORMs. It appears as an infinite disk to the system, and can be configured to provide the closest version of an available real-time backup. This is commonly employed in very large data retrieval systems." Pg. 71 Krutz: The CISSP Prep Guide.

QUESTION NO: 503

Zip/Jaz drives are frequently used for the individual backups of small data sets of:

- A. specific application data
- B. sacrificial application data
- C. static application data
- D. dynamic application data

Answer: A

Explanation:

QUESTION NO: 504

With non-continuous backup systems, data that was entered after the last backup prior to a system crash will have to be:

- A. recreated
- B. created
- C. updated
- D. deleted

Answer: A

Explanation:

QUESTION NO: 505

The alternate processing strategy in a business continuity plan can provide for required backup computing capacity through a hot site, a cold site, or

- A. A dial-up services program.
- B. An off-site storage replacement.
- C. An online backup program.
- D. A crate and ship replacement.

Answer: C

Explanation: What I believe is being wanted here is not the other data center backup alternatives but transaction redundancy implementation.

The CISSP candidate should understand the three concepts used to create a level of fault tolerance and redundancy in transaction processing. While these processes are not used solely for disaster recovery, they are often elements of a larger disaster recovery plan. If one or more of these processes are employed, the ability of a company to get back online is greatly enhanced. -

Ronald Krutz The CISSP PREP Guide (gold edition) pg 394 (they are Electronic Vaulting, Remote journaling, and Database shadowing)

QUESTION NO: 506

The 8mm tape format is commonly used in Helical Scan tape drives, but was superseded by:

- A. Digital Linear Tape (DLT)
- B. Analog Linear Tape (ALT)
- C. Digital Signal Tape (DST)
- D. Digital Coded Tape (DCT)

Answer: A

Explanation: "8mm Tape. This format was commonly used in Helical Scan tape drives, but was superseded by Digital Linear Tape (DLT)." Pg 95 Krutz: CISSP Prep Guide: Gold Edition.

QUESTION NO: 507

The spare drives that replace the failed drives are usually hot swappable, meaning they can be replaced on the server in which of the following scenarios?

- A. system is up and running
- B. system is quiesced but operational
- C. system is idle but operational
- D. system is up and in single-user-mode

Answer: A

Explanation:

QUESTION NO: 508

Primarily run when time and tape space permits, and is used for the system archive or baselined tape sets is the:

- A. full backup method
- B. Incremental backup method
- C. differential backup method
- D. tape backup method

Answer: A

Explanation:

QUESTION NO: 509

This backup method makes a complete backup of every file on the server every time it is run by:

- A. full backup method
- B. incremental backup method
- C. differential backup method
- D. tape backup method

Answer: A

Explanation:

QUESTION NO: 510

A backup of all files that are new or modified since the last full backup is

- A. In incremental backup
- B. A father/son backup
- C. A differential backup
- D. A full backup

Answer: C

Explanation: "Incremental backup -A procedure that backs up only those files that have been modified since the previous backup of any sort. It does remove the archive attribute.

Differential backup - A procedure that backs up all files that have been modified since the last full backup. It does not remove the archive attribute." - Shon Harris All-in-one CISSP Certification Guide pg 618

QUESTION NO: 511

What two factors should a backup program track to ensure the serviceability of backup tape media?

- A. The initial usage data of the media and the number of uses.
- B. The physical characteristics and rotation cycle of the media.
- C. The manufactured and model number of the tape media.
- D. The frequency of usage and magnetic composition.

Answer: B

Explanation: The answer should be B. The physical characteristics (what type of tape drive) and rotation cycle. (Frequency of backup cycles and retention time.)

QUESTION NO: 512

Which of the following virus types changes some of its characteristics as it spreads?

- A. boot sector
- B. parasitic
- C. stealth
- D. polymorphic

Answer: D

Explanation:

QUESTION NO: 513

Which one of the following is a good defense against worms?

- A. Differentiating systems along the lines exploited by the attack.
- B. Placing limits on sharing, writing, and executing programs.

- C. Keeping data objects small, simple, and obvious as to their intent.
- D. Limiting connectivity by means of well-managed access controls.

Answer: B

Explanation: Take as general information regarding worms

"Although the worm is not technically malicious, opening the attachment allows the file to copy itself to the user's PC Windows folder and then send the .pif-based program to any e-mail address stored on the hard drive.

Ducklin said the huge risks associated with accepting program files such as .pif, .vbs (visual basic script) or the more common .exe (executable) as attachments via e-mail outweighs the usefulness of distributing such files in this manner.

"There's no business sense for distributing programs via e-mail," he said.

To illustrate the point, Ducklin said six of the top 10 viruses reported to Sophos in April spread as Windows programs inside e-mails."

http://security.itworld.com/4340/030521stopworms/page_1.html

QUESTION NO: 514

An active content module, which attempts to monopolize and exploits system resources is called a

- A. Macro virus
- B. Hostile applet
- C. Plug-in worm
- D. Cookie

Answer: B

Explanation: This applet can execute in the network browser and may contain malicious code.

The types of downloadable programs are also known as mobile code. -Ronald Krutz The CISSP PREP Guide (gold edition) pg 361

"ActiveX Controls are Microsoft's answer to Sun's Java applets. They operate in a very similar fashion, but they are implemented using any on of a variety of languages, including Visual Basic, C, C++ and Java. There are two key distinctions between Java applets and ActiveX controls. First, ActiveX controls use proprietary Microsoft technology and, therefore, can only execute on systems running Microsoft operating systems. Second, ActiveX controls are not subject to the sandbox restrictions placed on Java applets. They have full access to the Windows operating environment and can perform a number of privileged actions. Therefore, special precautions must be taken when deciding which ActiveX controls to download and execute. Many security administrators

have taken the somewhat harsh position of prohibiting the download of any ActiveX content from all but a select handful of trusted sites.” Pg. 214 Tittel: CISSP Study Guide

QUESTION NO: 515

Macro viruses written in Visual Basic for Applications (VBA) are a major problem because

- A. Floppy disks can propagate such viruses.
- B. These viruses can infect many types of environments.
- C. Anti-virus software is usable to remove the viral code.
- D. These viruses almost exclusively affect the operating system.

Answer: D

Explanation:

VBA is typically Windows OS base, so Unlikely many types of environments, but impact the OS (need a real reference source to justify this though).

QUESTION NO: 516

What is the term used to describe a virus that can infect both program files and boot sectors?

- A. Polymorphic
- B. Multipartite
- C. Stealth
- D. Multiple encrypting

Answer: B

Explanation:

QUESTION NO: 517

Why are macro viruses easy to write?

- A. Active contents controls can make direct system calls
- B. The underlying language is simple and intuitive to apply.
- C. Only a few assembler instructions are needed to do damage.
- D. Office templates are fully API compliant.

Answer: B

Explanation: Macro Languages enable programmers to edit, delete, and copy files. Because these languages are so easy to use, many more types of macro viruses are possible. - Shon Harris All-in-one CISSP Certification Guide pg 785

QUESTION NO: 518

Which one of the following traits allows macro viruses to spread more effectively than other types?

- A. They infect macro systems as well as micro computers.
- B. They attach to executable and batch applications.
- C. They can be transported between different operating systems.
- D. They spread in distributed systems without detection

Answer: C

Explanation: Macro virus is a virus written in one of these programming languages and is platform independent. They infect and replicate in templates and within documents. - Shon Harris All-in-one CISSP Certification Guide pg 784

QUESTION NO: 519

In what way could Java applets pose a security threat?

- A. Their transport can interrupt the secure distribution of World Wide Web pages over the Internet by removing SSL and S-HTTP
- B. Java interpreters do not provide the ability to limit system access that an applet could have on a client system
- C. Executables from the Internet may attempt an intentional attack when they are downloaded on a client system

D. Java does not check the bytecode at runtime or provide other safety mechanisms for program isolation from the client system.

Answer: C

Explanation:

"Java Security

Java applets use a security scheme that employs a sandbox to limit the applet's access to certain specific areas within the user's system and protects the system from malicious or poorly written applets. The applet is supposed to run only within the sandbox. The sandbox restricts the applet's environment by restricting access to a user's hard drives and system resources. If the applet does not go outside the sandbox, it is considered safe.

However, as with many other things in the computing world, the bad guys have figured out how to escape their confines and restrictions. Programmers have figured out how to write applets that enable the code to access hard drives and resources that are supposed to be protected by the Java security scheme. This code can be malicious in nature and cause destruction and mayhem to the user and her system.

Java employs a sandbox in its security scheme, but if an applet can escape the confines of the sandbox, the system can be easily compromised." Pg 726 Shon Harris: All-In-One CISSP Certification Guide.

QUESTION NO: 520

What setup should an administrator use for regularly testing the strength of user passwords?

- A.** A networked workstation so that the live password database can easily be accessed by the cracking program
- B.** A networked workstation so the password database can easily be copied locally and processed by the cracking program
- C.** A standalone workstation on which the password database is copied and processed by the cracking program
- D.** A password-cracking program is unethical; therefore it should not be used.

Answer: C

Explanation:

QUESTION NO: 521

On UNIX systems, passwords shall be kept:

- A. In any location on behalf of root.
- B. In a shadow password file.
- C. In the /etc/passwd file.
- D. In root.

Answer: B

Explanation:

When possible, on UNIX systems, passwords shall not be kept in the /etc/passwd file, but rather in a shadow password file which can be modified only by root or a program executing on behalf of root.

QUESTION NO: 522

Which of the following would constitute the best example of a password to use for access to a system by a network administrator?

- A. holiday
- B. Christmas12
- C. Jenny&30
- D. TrZc&45g

Answer: D

Explanation:

QUESTION NO: 523

Which of the following is not a media viability control used to protect the viability of data storage media?

- A. clearing
- B. marking
- C. handling

D. storage

Answer: A

Explanation:

Handling – how it can be transported / under what controls

Storage – where and how it can be stored

Marking – how the media should be labeled

Reference: pg 315 Krutz: CISSP Study Guide: Gold Edition

QUESTION NO: 524

Which of the following refers to the data left on the media after the media has been erased?

- A. remanence**
- B. recovery**
- C. sticky bits**
- D. semi-hidden**

Answer: A

Explanation:

QUESTION NO: 525

What is the main issue with media reuse?

- A. Degaussing**
- B. Data remanence**
- C. Media destruction**
- D. Purging**

Answer: B

Explanation:

QUESTION NO: 526

What should a company do first when disposing of personal computers that once were used to

store confidential data?

- A. Overwrite all data on the hard disk with zeroes
- B. Delete all data contained on the hard disk
- C. Demagnetize the hard disk
- D. Low level format the hard disk

Answer: C

Explanation:

QUESTION NO: 527

Which of the following is not a critical security aspect of Operations Controls?

- A. Controls over hardware
- B. data media used
- C. Operations using resources
- D. Environment controls

Answer: D

Explanation:

Handling – how it can be transported / under what controls

Storage – where and how it can be stored

Marking – how the media should be labeled

Reference: pg 311 Krutz: CISSP Prep Guide: Gold Edition

QUESTION NO: 528

What tool is being used to determine whether attackers have altered system files of executables?

- A. File Integrity Checker
- B. Vulnerability Analysis Systems
- C. Honey Pots
- D. Padded Cells

Answer: A

Explanation:

Although File Integrity Checkers are most often used to determine whether attackers have altered system files or executables, they can also help determine whether vendor-supplied bug patches or other desired changes have been applied to system binaries. They are extremely valuable to those conducting a forensic examination of systems that have been attacked, as they allow quick and reliable diagnosis of the footprint of an attack. This enables system managers to optimize the restoration of service after incidents occur.

QUESTION NO: 529

A system file that has been patched numerous times becomes infected with a virus. The anti-virus software warns that disinfecting the file can damage it. What course of action should be taken?

- A.** Replace the file with the original version from master media
- B.** Proceed with automated disinfection
- C.** Research the virus to see if it is benign
- D.** Restore an uninfected version of the patched file from backup media

Answer: A

Explanation:

QUESTION NO: 530

In an on-line transaction processing system, which of the following actions should be taken when erroneous or invalid transactions are detected?

- A.** The transactions should be dropped from processing
- B.** The transactions should be processed after the program makes adjustments
- C.** The transactions should be written to a report and reviewed
- D.** The transactions should be corrected and reprocessed

Answer: C

Explanation:

QUESTION NO: 531

Which of the following is a reasonable response from the intrusion detection system when it detects Internet Protocol (IP) packets where the IP source address is the same as the IP destination address?

- A. Allow the packet to be processed by the network and record the event.
- B. Record selected information about the item and delete the packet.
- C. Resolve the destination address and process the packet.
- D. Translate the source address and resend the packet.

Answer: B

Explanation: RFC 1918 and RFC 2827 state about private addressing and ip spoofing using the same source address as destination address. Drop the packet.

QUESTION NO: 532

Which of the following is not a good response to a detected intrusion?

- A. Collect additional information about the suspected attack
- B. Inject TCP reset packets into the attacker's connection to the victim system
- C. Reconfigure routers and firewalls to block packets from the attacker's apparent connection
- D. Launch attacks or attempt to actively gain information about the attacker's host

Answer: D

Explanation:

QUESTION NO: 533

Once an intrusion into your organizations information system has been detected, which of the following actions should be performed first?

- A. Eliminate all means of intruder access

- B. Contain the intrusion
- C. Determine to what extent systems and data are compromised
- D. Communicate with relevant parties

Answer: B

Explanation:

QUESTION NO: 534

After an intrusion has been contained and the compromised systems having been reinstalled, which of the following need not be reviewed before bringing the systems back to service?

- A. Access control lists
- B. System services and their configuration
- C. Audit trails
- D. User accounts

Answer: C

Explanation:

QUESTION NO: 535

Which of the following includes notifying the appropriate parties to take action in order to determine the extent of the severity of an incident and to remediate the incident's effects?

- A. Intrusion Evaluation (IE) and Response
- B. Intrusion Recognition (IR) and Response
- C. Intrusion Protection (IP) and Response
- D. Intrusion Detection (ID) and Response

Answer: D

Explanation: "Intrusion Detection (ID) and Response is the task of monitoring systems for evidence of an intrusion or an inappropriate usage. This includes notifying the appropriate parties to take action in order to determine the extent of the severity of an incident and to remediate the incident's effects." Pg 86 Krutz: CISSP Prep Guide: Gold Edition.

QUESTION NO: 536

Which of the following is used to monitor network traffic or to monitor host audit logs in order to determine violations of security policy that have taken place?

- A. Intrusion Detection System
- B. Compliance Validation System
- C. Intrusion Management System
- D.)Compliance Monitoring System

Answer: A

Explanation:

QUESTION NO: 537

Which of the following is not a technique used for monitoring?

- A. Penetration testing
- B. Intrusion detection
- C. Violation processing (using clipping levels)
- D. Countermeasures testing

Answer: D

Explanation:

QUESTION NO: 538

Which one of the following is NOT a characteristic of an Intrusion Detection System? (IDS)

- A. Determines the source of incoming packets.
- B. Detects intruders attempting unauthorized activities.
- C. Recognizes and report alterations to data files.
- D. Alerts to known intrusion patterns.

Answer: C

Explanation: Software employed to monitor and detect possible attacks and behaviors that vary from the normal and expected activity. The IDS can be network-based, which monitors network traffic, or host-based, which monitors activities of a specific system and protects system files and control mechanisms. - Shon Harris All-in-one CISSP Certification Guide pg 932

QUESTION NO: 539

An IDS detects an attack using which of the following?

- A. an event-based ID or a statistical anomaly-based ID
- B. a discrete anomaly-based ID or a signature-based ID
- C. a signature-based ID or a statistical anomaly-based ID
- D. a signature-based ID or an event-based ID

Answer: C

Explanation:

QUESTION NO: 540

Which of the following monitors network traffic in real time?

- A. network-based IDS
- B. host-based IDS
- C. application-based IDS
- D. firewall-based IDS

Answer: A

Explanation:

QUESTION NO: 541

What technology is being used to detect anomalies?

- A. IDS
- B. FRR
- C. Sniffing
- D. Capturing

Answer: A

Explanation:

Intrusion Detection is a quickly evolving domain of expertise. In the past year we have seen giant steps forward in this area. We are now seeing IDS engines that will detect anomalies, and that have some built-in intelligence. It is no longer a simple game of matching signatures in your network traffic.

QUESTION NO: 542

IDSs verify, itemize, and characterize threats from:

- A. Inside your organization's network.
- B. Outside your organization's network.
- C. Outside and inside your organization's network.
- D. The Internet.

Answer: C

Explanation:

IDSs verify, itemize, and characterize the threat from both outside and inside your organization's network, assisting you in making sound decisions regarding your allocation of computer security resources. Using IDSs in this manner is important, as many people mistakenly deny that anyone (outsider or insider) would be interested in breaking into their networks. Furthermore, the information that IDSs give you regarding the source and nature of attacks allows you to make decisions regarding security strategy driven by demonstrated need, not guesswork or folklore.

QUESTION NO: 543

IDS can be described in terms of what fundamental functional components?

- A. Response
- B. Information Sources
- C. Analysis
- D. All of the choices.

Answer: D

Explanation:

Many IDSs can be described in terms of three fundamental functional components: Information Sources - the different sources of event information used to determine whether an intrusion has taken place. These sources can be drawn from different levels of the system, with network, host, and application monitoring most common.

Analysis - the part of intrusion detection systems that actually organizes and makes sense of the events derived from the information sources, deciding when those events indicate that intrusions are occurring or have already taken place. The most common analysis approaches are misuse detection and anomaly detection.

Response - the set of actions that the system takes once it detects intrusions. These are typically grouped into active and passive measures, with active measures involving some automated intervention on the part of the system, and passive measures involving reporting IDS findings to humans, who are then expected to take action based on those reports.

QUESTION NO: 544

What are the primary goals of intrusion detection systems? (Select all that apply.)

- A. Accountability
- B. Availability
- C. Response
- D. All of the choices

Answer: A,C

Explanation:

Although there are many goals associated with security mechanisms in general, there are two overarching goals usually stated for intrusion detection systems.

Accountability is the capability to link a given activity or event back to the party responsible for initiating it. This is essential in cases where one wishes to bring criminal charges against an attacker. The goal statement associated with accountability is: "I can deal with security attacks that occur on my systems as long as I know who

did it (and where to find them.)" Accountability is difficult in TCP/IP networks, where the protocols allow attackers to forge the identity of source addresses or other source identifiers. It is also extremely difficult to enforce accountability in any system that employs weak identification and authentication mechanisms.

Response is the capability to recognize a given activity or event as an attack and then taking action to block or otherwise affect its ultimate goal. The goal statement associated with response is "I don't care who attacks my system as long as I can recognize that the attack is taking place and block it." Note that the requirements of detection are quite different for response than for accountability.

QUESTION NO: 545

What is the most common way to classify IDSs?

- A.** Group them by information source.
- B.** Group them by network packets.
- C.** Group them by attackers.
- D.** Group them by signs of intrusion.

Answer: A

Explanation:

The most common way to classify IDSs is to group them by information source. Some IDSs analyze network packets, captured from network backbones or LAN segments, to find attackers. Other IDSs analyze information sources generated by the operating system or application software for signs of intrusion.

QUESTION NO: 546

The majority of commercial intrusion detection systems are:

- A.** Identity-based
- B.** Network-based

- C. Host-based
- D. Signature-based

Answer: B

Explanation:

The majority of commercial intrusion detection systems are network-based. These IDSs detect attacks by capturing and analyzing network packets. Listening on a network segment or switch, one network-based IDS can monitor the network traffic affecting multiple hosts that are connected to the network segment, thereby protecting those hosts.

QUESTION NO: 547

Which of the following is a drawback of Network-based IDSs?

- A. It cannot analyze encrypted information.
- B. It is very costly to setup.
- C. It is very costly to manage.
- D. It is not effective.

Answer: A

Explanation:

Network-based IDSs cannot analyze encrypted information. This problem is increasing as more organizations (and attackers) use virtual private networks. Most network-based IDSs cannot tell whether or not an attack was successful; they can only discern that an attack was initiated. This means that after a network-based IDS detects an attack, administrators must manually investigate each attacked host to determine whether it was indeed penetrated.

QUESTION NO: 548

Host-based IDSs normally utilize information from which of the following sources?

- A. Operating system audit trails and system logs.
- B. Operating system audit trails and network packets.
- C. Network packets and system logs.
- D. Operating system alarms and system logs.

Answer: A

Explanation:

Host-based IDSs normally utilize information sources of two types, operating system audit trails, and system logs. Operating system audit trails are usually generated at the innermost (kernel) level of the operating system, and are therefore more detailed and better protected than system logs. However, system logs are much less obtuse and much smaller than audit trails, and are furthermore far easier to comprehend. Some host-based IDSs are designed to support a centralized IDS management and reporting infrastructure that can allow a single management console to track many hosts. Others generate messages in formats that are compatible with network management systems.

QUESTION NO: 549

When comparing host based IDS with network based ID, which of the following is an obvious advantage?

- A. It is unaffected by switched networks.
- B. It cannot analyze encrypted information.
- C. It is not costly to setup.
- D. It is not costly to manage.

Answer: A

Explanation:

Host-based IDSs are unaffected by switched networks. When Host-based IDSs operate on OS audit trails, they can help detect Trojan horse or other attacks that involve software integrity breaches. These appear as inconsistencies in process execution.

QUESTION NO: 550

You are comparing host based IDS with network based ID. Which of the following will you consider as an obvious disadvantage of host based IDS?

- A. It cannot analyze encrypted information.
- B. It is costly to remove.
- C. It is affected by switched networks.
- D. It is costly to manage.

Answer: D

Explanation:

Host-based IDSs are harder to manage, as information must be configured and managed for every host monitored. Since at least the information sources (and sometimes part of the analysis engines) for host-based IDSs reside on the host targeted by attacks, the IDS may be attacked and disabled as part of the attack.

Host-based IDSs are not well suited for detecting network scans or other such surveillance that targets an entire network, because the IDS only sees those network packets received by its host. Host-based IDSs can be disabled by certain denial-of-service attacks.

QUESTION NO: 551

Which of the following IDS inflict a higher performance cost on the monitored systems?

- A. Encryption based
- B. Host based
- C. Network based
- D. Trusted based

Answer: B

Explanation:

Host-based IDSs use the computing resources of the hosts they are monitoring, therefore inflicting a performance cost on the monitored systems.

QUESTION NO: 552

Application-based IDSs normally utilize information from which of the following sources?

- A. Network packets and system logs.
- B. Operating system audit trails and network packets.
- C. Operating system audit trails and system logs.
- D. Application's transaction log files.

Answer: D

Explanation:

Application-based IDSs are a special subset of host-based IDSs that analyze the events transpiring within a software application. The most common information sources used by application-based IDSs are the application's transaction log files.

QUESTION NO: 553

Which of the following are the major categories of IDSs response options?

- A. Active responses
- B. Passive responses
- C. Hybrid
- D. All of the choices.

Answer: D

Explanation:

Once IDSs have obtained event information and analyzed it to find symptoms of attacks, they generate responses. Some of these responses involve reporting results and findings to a pre-specified location. Others involve more active automated responses. Though researchers are tempted to underrate the importance of good response functions in IDSs, they are actually very important. Commercial IDSs support a wide range of response options, often categorized as active responses, passive responses, or some mixture of the two.

QUESTION NO: 554

Alarms and notifications are generated by IDSs to inform users when attacks are detected. The most common form of alarm is:

- A. Onscreen alert
- B. Email
- C. Pager
- D. Icq

Answer: A

Explanation:

Alarms and notifications are generated by IDSs to inform users when attacks are detected. Most commercial IDSs allow users a great deal of latitude in determining how and when alarms are generated and to whom they are displayed.

The most common form of alarm is an onscreen alert or popup window. This is displayed on the IDS console or on other systems as specified by the user during the configuration of the IDS. The information provided in the alarm message varies widely, ranging from a notification that an intrusion has taken place to extremely detailed messages outlining the IP addresses of the source and target of the attack, the specific attack tool used to gain access, and the outcome of the attack. Another set of options that are of utility to large or distributed organizations are those involving remote notification of alarms or alerts. These allow organizations to configure the IDS so that it sends alerts to cellular phones and pagers carried by incident response teams or system security personnel.

QUESTION NO: 555

Which of the following is a valid tool that complements IDSs?

- A. All of the choices.
- B. Padded Cells
- C. Vulnerability Analysis Systems
- D. Honey Pots

Answer: A

Explanation:

Several tools exist that complement IDSs and are often labeled as intrusion detection products by vendors since they perform similar functions. They are Vulnerability Analysis Systems, File Integrity Checkers, Honey Pots, and Padded Cells.

“IDS-Related Tools

Intrusion detection systems are often deployed in concert with several other components. These IDS-related tools expand the usefulness and capabilities of IDSs and make IDSs more efficient and less prone to false positives. These tools include honey pots, padded cells, and vulnerability scanners.” Pg. 46 Tittel: CISSP Study Guide

QUESTION NO: 556

A problem with a network-based ID system is that it will not detect attacks against a host made by an intruder who is logged in at which of the following?

- A. host's terminal
- B. guest's terminal
- C. client's terminal
- D. server's terminal

Answer: A

Explanation:

QUESTION NO: 557

When the IDS detect attackers, the attackers are seamlessly transferred to a special host. This method is called:

- A. Vulnerability Analysis Systems
- B. Padded Cell
- C. Honey Pot
- D. File Integrity Checker

Answer: B

Explanation:

Padded cells take a different approach. Instead of trying to attract attackers with tempting data, a padded cell operates in tandem with traditional IDS. When the IDS detect attackers, it seamlessly transfers them to a special padded cell host.

QUESTION NO: 558

Which of the following is a weakness of both statistical anomaly detection and pattern matching?

- A.** Lack of ability to scale.
- B.** Lack of learning model.
- C.** Inability to run in real time.
- D.** Requirement to monitor every event.

Answer: B

Explanation: Disadvantages of Knowledge-based ID systems:

This system is resource-intensive; the knowledge database continually needs maintenance and updates

New, unique, or original attacks often go unnoticed. Disadvantages of Behavior-based ID systems: The system is characterized by high false alarm rates. High positives are the most common failure of ID systems and can create data noise that makes the system unusable.

The activity and behavior of the users while in the networked system might not be static enough to effectively implement a behavior-based ID system. -Ronald Krutz The CISSP PREP Guide (gold edition) pg 88

QUESTION NO: 559

The two most common implementations of Intrusion Detection are which of the following?

- A.** They commonly reside on a discrete network segment and monitor the traffic on that network segment
- B.** They commonly will not reside on a discrete network segment and monitor the traffic on that

network segment

- C.** They commonly reside on a discrete network segment but do not monitor the traffic on that network segment
- D.** They commonly do not reside on a discrete network segment and monitor the traffic on that network segment

Answer: A

Explanation:

QUESTION NO: 560

What are the primary approaches IDS takes to analyze events to detect attacks?

- A.** Misuse detection and anomaly detection.
- B.** Log detection and anomaly detection.
- C.** Misuse detection and early drop detection.
- D.** Scan detection and anomaly detection.

Answer: A

Explanation:

There are two primary approaches to analyzing events to detect attacks: misuse detection and anomaly detection. Misuse detection, in which the analysis targets something known to be "bad", is the technique used by most commercial systems. Anomaly detection, in which the analysis looks for abnormal patterns of activity, has been, and continues to be, the subject of a great deal of research. Anomaly detection is used in limited form by a number of IDSs. There are strengths and weaknesses associated with each approach, and it appears that the most effective IDSs use mostly misuse detection methods with a smattering of anomaly detection components.

QUESTION NO: 561

Misuse detectors analyze system activity and identify patterns. The patterns corresponding to known attacks are called:

- A.** Attachments

- B. Signatures
- C. Strings
- D. Identifications

Answer: B

Explanation:

Misuse detectors analyze system activity, looking for events or sets of events that match a predefined pattern of events that describe a known attack. As the patterns corresponding to known attacks are called signatures, misuse detection is sometimes called "signature-based detection." The most common form of misuse detection used in commercial products specifies each pattern of events corresponding to an attack as a separate signature. However, there are more sophisticated approaches to doing misuse detection (called "state-based" analysis techniques) that can leverage a single signature to detect groups of attacks.

QUESTION NO: 562

Which of the following is an obvious disadvantage of deploying misuse detectors?

- A. They are costly to setup.
- B. They are not accurate.
- C. They must be constantly updated with signatures of new attacks.
- D. They are costly to use.

Answer: C

Explanation:

Misuse detectors can only detect those attacks they know about - therefore they must be constantly updated with signatures of new attacks. Many misuse detectors are designed to use tightly defined signatures that prevent them from detecting variants of common attacks. State-based misuse detectors can overcome this limitation, but are not commonly used in commercial IDSs.

QUESTION NO: 563

What detectors identify abnormal unusual behavior on a host or network?

- A. None of the choices.
- B. Legitimate detectors.
- C. Anomaly detectors.
- D. Normal detectors.

Answer: C

Explanation:

Anomaly detectors identify abnormal unusual behavior (anomalies) on a host or network. They function on the assumption that attacks are different from "normal" (legitimate) activity and can therefore be detected by systems that identify these differences. Anomaly detectors construct profiles representing normal behavior of users, hosts, or network connections. These profiles are constructed from historical data collected over a period of normal operation. The detectors then collect event data and use a variety of measures to determine when monitored activity deviates from the norm.

QUESTION NO: 564

A network-based IDS is which of the following?

- A. active while it acquires data
- B. passive while it acquires data
- C. finite while it acquires data
- D. infinite while it acquires data

Answer: B

Explanation:

QUESTION NO: 565

Which of the following usually provides reliable, real-time information without consuming network or host resources?

- A. network-based IDS
- B. host-based IDS
- C. application-based IDS
- D. firewall-based IDS

Answer: A

Explanation: "A network-based IDS has little negative affect on overall network performance, and because it is deployed on a single-purpose system, it doesn't adversely affect the performance of any other computer." Pg 34 Krutz: CISSP Prep Guide: Gold Edition.

QUESTION NO: 566

Which of the following would assist in intrusion detection?

- A. audit trails
- B. access control lists
- C. security clearances
- D. host-based authentication

Answer: A

Explanation:

QUESTION NO: 567

Using clipping levels refers to:

- A. setting allowable thresholds on reported activity
- B. limiting access to top management staff
- C. setting personnel authority limits based on need-to-know basis
- D. encryption of data so that it cannot be stolen

Answer: A

Explanation:

QUESTION NO: 568

In what way can violation clipping levels assist in violation tracking and analysis?

- A.** Clipping levels set a baseline for normal user errors, and violations exceeding that threshold will be recorded for analysis of why the violations occurred
- B.** Clipping levels enable a security administrator to customize the audit trail to record only those violations which are deemed to be security relevant
- C.** Clipping levels enable the security administrator to customize the audit trail to record only actions for users with access to usercodes with a privileged status
- D.** Clipping levels enable a security administrator to view all reductions in security levels which have been made to usercodes which have incurred violations

Answer: A

Explanation:

QUESTION NO: 569

When establishing a violation tracking and analysis process, which one of the following parameters is used to keep the quantity of data to manageable levels?

- A.** Quantity baseline
- B.** Maximum log size
- C.** Circular logging
- D.** Clipping levels

Answer: D

Explanation: To make violation tracking effective, clipping levels must be established. A clipping level is a baseline of user activity that is considered a routine level of user errors. When a clipping level is exceeded, a violation record is then produced. Clipping levels are also used for variance detection. -Ronald Krutz The CISSP PREP Guide (gold edition) pg 318

QUESTION NO: 570

Audit trails based upon access and identification codes establish...

- A.** intrusion detection thresholds
- B.** individual accountability
- C.** audit review criteria
- D.** individual authentication

Answer: B

Explanation: Accountability is another facet of access control. Individuals on a system are responsible for their actions. This accountability property enables system activities to be traced to the proper individuals. Accountability is supported by audit trails that record events on the system and on the network. Audit trails can be used for intrusion detection and for the reconstruction of past events. -Ronald Krutz The CISSP PREP Guide (gold edition) pg 65

QUESTION NO: 571

The primary reason for enabling software audit trails is which of the following?

- A. Improve system efficiency
- B. Improve response time for users
- C. Establish responsibility and accountability
- D. Provide useful information to track down processing errors

Answer: C

Explanation: "Auditing capabilities ensure that users are accountable for their actions, verify that the security policies are enforced, and are used as investigation tools." Pg 161 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 572

Tracing violations, or attempted violations of system security to the user responsible is a function of?

- A. authentication
- B. access management
- C. integrity checking
- D. accountability

Answer: D

Explanation: Auditing capabilities ensure that users are accountable for their actions, verify that the security policies are enforced, worked as a deterrent to improper actions, and are used as

QUESTION NO: 573

According to the Minimum Security Requirements (MSR) for Multi-User Operating Systems (NISTIR 5153) document, which of the following statements pertaining to audit data recording is incorrect?

- A.** The system shall provide end-to-end user accountability for all security-relevant events
- B.** The system shall protect the security audit trail from unauthorized access
- C.** For maintenance purposes, it shall be possible to disable the recording of activities that require privileges.
- D.** The system should support an option to maintain the security audit trail data in encrypted format

Answer: C

Explanation:

QUESTION NO: 574

Which of the following questions is less likely to help in assessing controls over audit trails?

- A.** Does the audit trail provide a trace of user actions?
- B.** Are incidents monitored and tracked until resolved?
- C.** Is access to online logs strictly controlled?
- D.** Is there separation of duties between security personnel who administer the access control function and those who administer the audit trail?

Answer: B

Explanation:

QUESTION NO: 575

You should keep audit trail on which of the following items?

- A. Password usage.
- B. All unsuccessful logon.
- C. All of the choices.
- D. All successful logon.

Answer: C

Explanation:

Keep audit trail of password usage; log all Successful logon, Unsuccessful logon, Date, Time, ID, Login name. Control maximum logon attempt rate where possible. Where possible users must be automatically logged off after 30 minutes of inactivity.

QUESTION NO: 576

In addition to providing an audit trail required by auditors, logging can be used to

- A. provide backout and recovery information
- B. prevent security violations
- C. provide system performance statistics
- D. identify fields changed on master files.

Answer: B

Explanation: Auditing tools are technical controls that track activity within a network on a network device or on a specific computer. Even though auditing is not an activity that will deny an entity access to a network or computer, it will track activities so a network administrator can understand the types of access that took place, identify a security breach, or warn the administrator of suspicious activity. This can be used to point out weakness of their technical controls and help administrators understand where changes need to be made to preserve the necessary security level within the environment. . - Shon Harris All-in-one CISSP Certification Guide pg 179-180

QUESTION NO: 577

Which of the following should NOT be logged for performance problems?

- A. CPU load.
- B. Percentage of use.
- C. Percentage of idle time.
- D. None of the choices.

Answer: D

Explanation:

The level of logging will be according to your company requirements. Below is a list of items that could be logged, please note that some of the items may not be applicable to all operating systems. What is being logged depends on whether you are looking for performance problems or security problems. However you have to be careful about performance problems that could affect your security.

QUESTION NO: 578

Which of the following should be logged for security problems?

- A. Use of mount command.
- B. Percentage of idle time.
- C. Percentage of use.
- D. None of the choices.

Answer: A

Explanation:

The level of logging will be according to your company requirements. Below is a list of items that could be logged, please note that some of the items may not be applicable to all operating systems. What is being logged depends on whether you are looking for performance problems or security problems. However you have to be careful about performance problems that could affect your security.

QUESTION NO: 579

Which of the following services should be logged for security purpose?

- A. bootp
- B. All of the choices.
- C. sunrpc
- D. tftp

Answer: B

Explanation:

Request for the following services should be logged: systat, bootp, tftp, sunrpc, snmp, snmp-trap, nfs.

QUESTION NO: 580

The auditing method that assesses the extent of the system testing, and identifies specific program logic that has not been tested is called

- A. Decision process analysis
- B. Mapping
- C. Parallel simulation
- D. Test data method

Answer: D

Explanation: "Testing of software modules or unit testing should be addressed when the modules are being designed. Personnel separate from the programmers should conduct this testing. The test data is part of the specifications. Testing should not only check the modules using normal and valid input data, but it should also check for incorrect types, out-of-range values, and other bounds and/or conditions. Live or actual field data is not recommended for use in the testing procedures because both data types might not cover out-of-range situations and the correct outputs of the test are unknown. Special test suites of data that exercise all paths of the software to the fullest extent possible and whose corrected resulting outputs are known beforehand should be used." Pg. 345 Krutz: The CISSP Prep Guide: Gold Edition.

QUESTION NO: 581

Who should NOT have access to the log files?

- A. Security staff.
- B. Internal audit staff.
- C. System administration staff.
- D. Manager's secretary.

Answer: D

Explanation:

Logs must be secured to prevent modification, deletion, and destruction. Only authorized persons should have access or permission to read logs. A person is authorized if he or she is a member of the internal audit staff, security staff, system administration staff, or he or she has a need for such access to perform regular duties.

QUESTION NO: 582

Which of the following correctly describe the use of the collected logs?

- A. They are used in the passive monitoring process only.
- B. They are used in the active monitoring process only.
- C. They are used in the active and passive monitoring process.
- D. They are used in the archiving process only.

Answer: C

Explanation:

All logs collected are used in the active and passive monitoring process. All logs are kept on archive for a period of time. This period of time will be determined by your company policies. This allows the use of logs for regular and annual audits if retention is longer than a year. Logs must be secured to prevent modification, deletion, and destruction.

QUESTION NO: 583

All logs are kept on archive for a period of time. What determines this period of time?

- A. Administrator preferences.
- B. MTTR
- C. Retention policies
- D. MTTF

Answer: C

Explanation:

All logs collected are used in the active and passive monitoring process. All logs are kept on archive for a period of time. This period of time will be determined by your company policies. This allows the use of logs for regular and annual audits if retention is longer than a year. Logs must be secured to prevent modification, deletion, and destruction.

QUESTION NO: 584

Logs must be secured to prevent:

- A. Creation, modification, and destruction.
- B. Modification, deletion, and initialization.
- C. Modification, deletion, and destruction.
- D. Modification, deletion, and inspection.

Answer: C

Explanation:

All logs collected are used in the active and passive monitoring process. All logs are kept on archive for a period of time. This period of time will be determined by your company policies. This allows the use of logs for regular and annual audits if retention is longer than a year. Logs must be secured to prevent modification, deletion, and destruction.

QUESTION NO: 585

To ensure dependable and secure logging, all computers must have their clock synchronized to:

- A. A central timeserver.
- B. The log time stamp.
- C. The respective local times.
- D. None of the choices.

Answer: A

Explanation:

The following pre-requisite must be met to ensure dependable and secure logging:
All computers must have their clock synchronized to a central timeserver to ensure accurate time on events being logged.

If possible all logs should be centralized for easy analysis and also to help detect patterns of abuse across servers.

Logging information traveling on the network must be encrypted if possible.

Log files are stored and protected on a machine that has a hardened shell.

Log files must not be modifiable without a trace or record of such modification.

QUESTION NO: 586

To ensure dependable and secure logging, logging information traveling on the network should be:

- A. Stored
- B. Encrypted
- C. Isolated
- D. Monitored

Answer: B

Explanation:

The following pre-requisite must be met to ensure dependable and secure logging:
All computers must have their clock synchronized to a central timeserver to ensure accurate time on events being logged.

If possible all logs should be centralized for easy analysis and also to help detect patterns of abuse across servers.

Logging information traveling on the network must be encrypted if possible.

Log files are stored and protected on a machine that has a hardened shell.

Log files must not be modifiable without a trace or record of such modification.

QUESTION NO: 587

The activity that consists of collecting information that will be used for monitoring is called:

- A. Logging
- B. Troubleshooting
- C. Auditing
- D. Inspecting

Answer: A

Explanation:

Logging is the activity that consists of collecting information that will be used for monitoring and auditing. Detailed logs combined with active monitoring allow detection of security issues before they negatively affect your systems.

QUESTION NO: 588

How often should logging be run?

- A. Once every week.
- B. Always
- C. Once a day.
- D. During maintenance.

Answer: B

Explanation:

Usually logging is done 24 hours per day, 7 days per week, on all available systems and services except during the maintenance window where some of the systems and services may not be available while maintenance is being performed.

QUESTION NO: 589

Which of the following are security events on Unix that should be logged?

- A. All of the choices.
- B. Use of Setgid.
- C. Change of permissions on system files.
- D. Use of Setuid.

Answer: A

Explanation:

The following file changes, conditions, and events are logged:

rhosts.

UNIX Kernel.

/etc/passwd.

rc directory structure.

bin files.

lib files.

Use of Setuid.

Use of Setgid.

Change of permission on system or critical files.

QUESTION NO: 590

Which of the following are potential firewall problems that should be logged?

- A. Reboot
- B. All of the choices.
- C. Proxies restarted.
- D. Changes to configuration file.

Answer: B

Explanation:

The following firewall configuration problem are logged:

Reboot of the firewall.

Proxies that cannot start (e.g. Within TIS firewall).

Proxies or other important services that have died or restarted.
Changes to firewall configuration file.
A configuration or system error while firewall is running.

QUESTION NO: 591

Which of the following is required in order to provide accountability?

- A. Authentication
- B. Integrity
- C. Confidentiality
- D. Audit trails

Answer: A

Reference: pg 5 Tittel: CISSP Study Guide

QUESTION NO: 592

The principle of accountability is a principle by which specific action can be traced back to:

- A. A policy
- B. An individual
- C. A group
- D. A manager

Answer: B

Explanation:

The principle of accountability has been described in many references; it is a principle by which specific action can be traced back to an individual. As mentioned by Idrach, any significant action should be traceable to a specific user. The definition of "Significant" is entirely dependant on your business circumstances and risk management model. It was also mentioned by Rino that tracing the actions of a specific user is fine but we must also be able to ascertain that this specific user was responsible for the uninitiated action.

QUESTION NO: 593

The principle of _____ is a principle by which specific action can be traced back to anyone of your users.

- A. Security
- B. Integrity
- C. Accountability
- D. Policy

Answer: C

Explanation:

The principle of accountability has been described in many references; it is a principle by which specific action can be traced back to an individual. As mentioned by Idrach, any significant action should be traceable to a specific user. The definition of "Significant" is entirely dependant on your business circumstances and risk management model. It was also mentioned by Rino that tracing the actions of a specific user is fine but we must also be able to ascertain that this specific user was responsible for the uninitiated action.

QUESTION NO: 594

According to the principle of accountability, what action should be traceable to a specific user?

- A. Material
- B. Intangible
- C. Tangible
- D. Significant

Answer: D

Explanation:

The principle of accountability has been described in many references; it is a principle by which specific action can be traced back to an individual. As mentioned by Idrach, any significant action should be traceable to a specific user. The definition of "Significant" is entirely dependant on your business circumstances and risk management model. It was also mentioned by Rino that tracing the actions of a specific user is fine but we must also be able to ascertain that this specific user was responsible for the uninitiated action.

QUESTION NO: 595

Which of the following best ensures accountability of users for actions taken within a system or domain?

- A. Identification
- B. Authentication
- C. Authorization
- D. Credentials

Answer: A

Explanation: "Identification is the process by which a subject professes an identify and accountability is initiated." Pg 149 Tittel: CISSP Study Guide

"Identification and authentication are the keystones of most access control systems. Identification is the act of a user professing an identify to a system, usually in the form of a log-on ID to the system. Identification establishes user accountability for the actions on the system. Authentication is verification that the user's claimed identity is valid and is usually implemented through a user password at log-on time." Pg 36 Krutz: The CISSP Prep Guide

QUESTION NO: 596

Individual accountability does not include which of the following?

- A. unique identifiers
- B. policies & procedures
- C. access rules

D. audit trails

Answer: B

Explanation:

QUESTION NO: 597

Controls provide accountability for individuals who are accessing sensitive information. This accountability is accomplished:

- A.** through access control mechanisms that require identification and authentication and through the audit function.
- B.** through logical or technical controls involving the restriction of access to systems and the protection of information
- C.** through logical or technical controls but not involving the restriction of access to systems and the protection of information.
- D.** through access control mechanisms that do not require identification and authentication and do not operate through the audit function.

Answer: A

Explanation:

QUESTION NO: 598

What types of computer attacks are most commonly reported by IDSs?

- A.** System penetration
- B.** Denial of service
- C.** System scanning
- D.** All of the choices

Answer: D

Explanation:

Three types of computer attacks are most commonly reported by IDSs: system scanning, denial of service (DOS), and system penetration. These attacks can be launched locally, on the attacked machine, or remotely, using a network to access the target. An IDS operator must understand the differences between these types of attacks, as each

requires a different set of responses.

QUESTION NO: 599

Operation security requires the implementation of physical security to control which of the following?

- A. unauthorized personnel access
- B. incoming hardware
- C. contingency conditions
- D. evacuation procedures

Answer: A

Explanation:

QUESTION NO: 600

Configuration Management is a requirement for the following level(s)?

- A. B3 and A1
- B. B1, B2 and B3
- C. A1
- D. B2, B3, and A1

Answer: D

Reference: pg 306 Krutz: CISSP Study Guide: Gold Edition

QUESTION NO: 601

Which of the following is not concerned with configuration management?

- A. Hardware
- B. Software
- C. Documentation

D. They all are concerned with configuration management

Answer: D

Explanation:

QUESTION NO: 602

Configuration Management controls what?

- A. Auditing of changes to the Trusted Computing Base
- B. Control of changes to the Trusted Computing Base
- C. Changes in the configuration access to the Trusted Computing Base
- D. Auditing and controlling any changes to the Trusted Computing Base

Answer: D

Explanation: "Official Definition of Configuration Management

Identifying, controlling, accounting for and auditing changes made to the baseline TCB, which includes changes to hardware, software, and firmware.

A System that will control changes and test documentation through the operational life cycle of a system." Pg 698 Shon Harris: All-in-One CISSP Certification

"[B3] The security administrator role is clearly defined, and the system must be able to recover from failures without its security level being compromised." Pg. 226 Shon Harris CISSP All-In-One Exam Guide

QUESTION NO: 603

In addition to ensuring that changes to the computer system take place in an identifiable and controlled environment, configuration management provides assurance that future changes:

- A. The application software cannot bypass system security features.
- B. Do not adversely affect implementation of the security policy.
- C. The operating system is always subjected to independent validation and verification.

D. In technical documentation maintain an accurate description of the Trusted Computer Base.

Answer: B

Explanation: "The primary security goal of configuration management is to ensure that changes to the system do not unintentionally diminish security." Pg 306 Krutz: CISSP Prep Guide: Gold Edition.

QUESTION NO: 604

Which set of principal tasks constitutes configuration management?

- A.** Program management, system engineering, and quality assurance.
- B.** Requirements verification, design, and system integration and testing.
- C.** Independent validation and verification of the initial and subsequent baseline.
- D.** Identification, control, status accounting, and auditing of changes.

Answer: D

Explanation: Configuration management is the process of tracking and approving changes to a system. It involves identifying, controlling, and auditing all changes made to the system.

Pg. 223 Krutz: The CISSP Prep Guide

QUESTION NO: 605

If the computer system being used contains confidential information, users must not:

- A.** Leave their computer without first logging off.
- B.** Share their desks.
- C.** Encrypt their passwords.
- D.** Communicate

Answer: A

Explanation:

If the computer system being used or to which a user is connected contains sensitive or confidential information, users must not leave their computer, terminal, or workstation

without first logging off. Users should be reminded frequently to follow this rule.

QUESTION NO: 606

Separation of duties is valuable in deterring:

- A. DoS
- B. external intruder
- C. fraud
- D. trojan house

Answer: C

Explanation:

Separation of duties is considered valuable in deterring fraud since fraud can occur if an opportunity exists for collaboration between various jobs related capabilities. Separation of duty requires that for particular sets of transactions, no single individual be allowed to execute all transactions within the set. The most commonly used examples are the separate transactions needed to initiate a payment and to authorize a payment. No single individual should be capable of executing both transactions.

QUESTION NO: 607

What principle requires that for particular sets of transactions, no single individual be allowed to execute all transactions within the set?

- A. Use of rights
- B. Balance of power
- C. Separation of duties
- D. Fair use

Answer: C

Explanation:

Separation of duties is considered valuable in deterring fraud since fraud can occur if

an opportunity exists for collaboration between various jobs related capabilities. Separation of duty requires that for particular sets of transactions, no single individual be allowed to execute all transactions within the set. The most commonly used examples are the separate transactions needed to initiate a payment and to authorize a payment. No single individual should be capable of executing both transactions.

QUESTION NO: 608

Separation of duty can be:

- A. Dynamic only
- B. Encrypted
- C. Static only
- D. Static or dynamic

Answer: D

Explanation:

Separation of duty can be either static or dynamic. Compliance with static separation requirements can be determined simply by the assignment of individuals to roles and allocation of transactions to roles. The more difficult case is dynamic separation of duty where compliance with requirements can only be determined during system operation. The objective behind dynamic separation of duty is to allow more flexibility in operations.

QUESTION NO: 609

What is the company benefit, in terms of risk, for people taking a vacation of a specified minimum length?

- A. Reduces stress levels, thereby lowering insurance claims.
- B. Improves morale, thereby decreasing errors.

- C. Increases potential for discovering frauds.
- D. Reduces dependence on critical individuals.

Answer: C

Explanation: Mandatory vacations are another type of administrative control that may sound a bit odd at first. Chapter 3 touches on reasons to make sure that employees take their vacations; this has to do with being able to identify fraudulent activities and enable job rotation to take place. - Shon Harris All-in-one CISSP Certification Guide pg 810

QUESTION NO: 610

Which of the following would be less likely to prevent an employee from reporting an incident?

- A. They are afraid of being pulled into something they don't want to be involved with
- B. The process of reporting incidents is centralized
- C. They are afraid of being accused of something they didn't do
- D. They are unaware of the company's security policies and procedures

Answer: B

Explanation:

Reasons why a user won't report an incident (page 882 of Shon Harris 5th edition)

- Afraid of being pulled into something
- afraid of being accused

Logically, they may be unaware of the procedure

No reason that reporting incidents to a centralized location would be a problem so that leaves that as the answer.

QUESTION NO: 611

Employee involuntary termination processing should include

- A. A list of all passwords used by the individual.
- B. A report on outstanding projects.

- C. The surrender of any company identification.
- D. Signing a non-disclosure agreement.

Answer: C

Explanation: "Before the employee is released, all organization-specific identification, access, or security badges as well as cards, keys, and access tokens should be collected."

Pg. 173 Tittel: CISSP Study Guide

QUESTION NO: 612

Which trusted facility management concept implies that two operators must review and approve the work of each other?

- A. Two-man control
- B. Dual control
- C. Double control
- D. Segregation control

Answer: A

Explanation:

"In the concept of two-man control, two operators review and approve the work of each other. The purpose of two-man control is to provide accountability and to minimize fraud in highly sensitive or high-risk transactions. The concept of dual control means that both operators are needed to complete a sensitive task." Pg. 303 Krutz: The CISSP Prep Guide: Gold Edition.

QUESTION NO: 613

When two operators review and approve the work of each other, this is known as?

- A. Dual control
- B. Two-man control
- C. Two-fold control
- D. Twin control

Answer: B

Explanation:

QUESTION NO: 614

What security procedure forces an operator into collusion with an operator of a different category to have access to unauthorized data?

- A. Enforcing regular password changes
- B. Management monitoring of audit logs
- C. Limiting the specific accesses of operations personnel
- D. Job rotation of people through different assignments

Answer: C

Explanation:

QUESTION NO: 615

Which of the following user items can be shared?

- A. Password
- B. Home directory
- C. None of the choices.

Answer: C

Explanation:

Each user assigned directory (home directory) is not to be shared with others. None of the choices is correct.

QUESTION NO: 616

What should you do to the user accounts as soon as employment is terminated?

- A. Disable the user accounts and erase immediately the data kept.
- B. Disable the user accounts and have the data kept for a specific period of time.
- C. None of the choices.
- D. Maintain the user accounts and have the data kept for a specific period of time.

Answer: B

Explanation:

A record of user logins with time and date stamps must be kept. User accounts shall be disabled and data kept for a specified period of time as soon as employment is terminated. All users must log on to gain network access.

QUESTION NO: 617

What is the main objective of proper separation of duties?

- A. To prevent employees from disclosing sensitive information
- B. To ensure access controls are in place
- C. To ensure that no single individual can compromise a system
- D. To ensure that audit trails are not tampered with

Answer: C

Explanation: "Separation of duties (also called segregation of duties) assigns parts of tasks to different personnel. Thus if no single person has total control of the system's security mechanisms, the theory is that no single person can completely compromise the system."

Pg. 303 Krutz: The CISSP Prep Guide: Gold Edition

QUESTION NO: 618

What are the benefits of job rotation?

- A. All of the choices.
- B. Trained backup in case of emergencies.
- C. Protect against fraud.

D. Cross training to employees.

Answer: A

Explanation:

Job assignments should be changed periodically so that it is more difficult for users to collaborate to exercise complete control of a transaction and subvert it for fraudulent purposes. This principle is effective when used in conjunction with a separation of duties. Problems in effectively rotating duties usually appear in organizations with limited staff resources and inadequate training programs. Rotation of duties will protect you against fraud; provide cross training to your employees, as well as assuring trained backup in case of emergencies.

QUESTION NO: 619

Which of the following control pairing include organizational policies and procedures, pre-employment background checks, strict hiring practices, employment agreements, friendly and unfriendly employee termination procedures, vacation scheduling, labeling of sensitive materials, increased supervision, security awareness training, behavior awareness, and sign-up procedures to obtain access to information systems and networks in?

- A.** Preventive/Administrative Pairing
- B.** Preventive/Technical Pairing
- C.** Preventive/Physical Pairing
- D.** Detective/Administrative Pairing

Answer: A

Explanation:

QUESTION NO: 620

Which of the following are functions that are compatible in a properly segregated environment?

- A.** Application programming and computer operation
- B.** Systems programming and job control analysis
- C.** Access authorization and database administration
- D.** Systems development and systems maintenance

Answer: D

Explanation:

QUESTION NO: 621

Which of the following are functions that are compatible in a properly segregated environment?

- A.** Security administration and quality assurance
- B.** Security administration and data entry
- C.** Security administration and application programming
- D.** Application programming and data entry

Answer: A

Explanation:

Security Administration and Quality Assurance are the most similar tasks.

Administrative Management: Administrative management is a very important piece of operational security. One aspect of administrative management is dealing with personnel issues. This includes separation of duties and job rotation. The objective of separation of duties is to ensure that one person acting alone cannot compromise the company's security in any way. High-risk activities should be broken up into different parts and distributed to different individuals. This way the company does not need to put a dangerously high level of trust on certain individuals and if fraud were to take place, collusion would need to be committed, meaning more than one person would have to be involved in the fraudulent activity.

Separation of duties also helps to prevent many different types of mistakes that can take place if one person is performing a task from the beginning to the end. For instance, a programmer should not be the one to test her own code. A different person with a different job and agenda should perform functionality and integrity testing on the programmer's code because the programmer may have a focused view of what the program is supposed to accomplish and only test certain functions, input values, and in certain environments.

Another example of separation of duties is the difference between the functions of a computer operator versus the functions of a system administrator. There must be clear cut lines drawn between system administrator duties and computer operator duties. This will vary from environment to environment and will depend on the level of security required within the environment. The system administrators usually have responsibility of performing backups and recovery procedures, setting permissions, adding and removing users, setting user clearance, and developing user profiles. The computer operator on the other hand, may be allowed to install

software, set an initial password, alter desktop configurations, and modify certain system parameters. The computer operator should not be able to modify her own security profile, add and remove users globally, or set user security clearance. This would breach the concept of separation of duties.

Pg 808-809 Shon Harris: All-In-One CISSP Certification

QUESTION NO: 622

Which of the following are functions that are compatible in a properly segregated environment?

- A. Data entry and job scheduling
- B. Database administration and systems security
- C. Systems analyst and application programming
- D. Security administration and systems programming

Answer: A

Explanation: The two most similar jobs are Data Entry and Job Scheduling, so they need not be segregated.

Administrative Management: Administrative management is a very important piece of operational security. One aspect of administrative management is dealing with personnel issues. This includes separation of duties and job rotation. The objective of separation of duties is to ensure that one person acting alone cannot compromise the company's security in any way. High-risk activities should be broken up into different parts and distributed to different individuals. This way the company does not need to put a dangerously high level of trust on certain individuals and if fraud were to take place, collusion would need to be committed, meaning more than one person would have to be involved in the fraudulent activity.

Separation of duties also helps to prevent many different types of mistakes that can take place if one person is performing a task from the beginning to the end. For instance, a programmer should not be the one to test her own code. A different person with a different job and agenda should perform functionality and integrity testing on the programmer's code because the programmer may have a focused view of what the program is supposed to accomplish and only test certain functions, input values, and in certain environments.

Another example of separation of duties is the difference between the functions of a computer operator versus the functions of a system administrator. There must be clear cut lines drawn

between system administrator duties and computer operator duties. This will vary from environment to environment and will depend on the level of security required within the environment. The system administrators usually have responsibility of performing backups and recovery procedures, setting permissions, adding and removing users, setting user clearance, and developing user profiles. The computer operator on the other hand, may be allowed to install software, set an initial password, alter desktop configurations, and modify certain system parameters. The computer operator should not be able to modify her own security profile, add and remove users globally, or set user security clearance. This would breach the concept of separation of duties.

Pg 808-809 Shon Harris: All-In-One CISSP Certification Exam Guide

QUESTION NO: 623

Which of the following are functions that are compatible in a properly segregated environment?

- A.** Application programming and computer operation
- B.** Systems programming and job control analysis
- C.** Access authorization and database administration
- D.** System development and systems maintenance

Answer: D

Explanation: If you think about it, System development and system maintenance are perfectly compatible, you can develop in the systems for certain time, and when it time for a maintenance, you stop the development process an make the maintenance. It's a pretty straight forward process. The other answer do not provide the simplicity and freedom of this option.

Incorrect answer:

Access authorization and database administration are NEVER compatible.

QUESTION NO: 624

Controls are implemented to:

- A. eliminate risk and reduce potential for loss
- B. mitigate risk and eliminate the potential for loss
- C. mitigate risk and reduce the potential for loss
- D. eliminate risk and eliminate the potential for loss

Answer: C

Explanation:

QUESTION NO: 625

A timely review of system access audit records would be an example of which of the basic security functions?

- A. avoidance
- B. deterrence
- C. prevention
- D. detection

Answer: D

Explanation:

QUESTION NO: 626

A security control should

- A. Allow for many exceptions.
- B. Cover all contingencies.
- C. Not rely on the security of its mechanism.
- D. Change frequently.

Answer: C

Explanation:

QUESTION NO: 627

What set of principles is the basis for information systems controls?

- A. Authentication, audit trails, and awareness briefings
- B. Individual accountability, auditing, and separation of duties
- C. Need to know, identification, and authenticity
- D. Audit trails, limited tenure, and awareness briefings

Answer: C

Explanation: "In addition to the CIA Triad, there is a plethora of other security-related concepts, principles, and tenants that should be considered and addressed when designing a security policy and deploying a security solution. This section discusses privacy, identification, authentication, authorization, accountability, nonrepudiation, and auditing." Pg. 133 Tittel: CISSP Study Guide

QUESTION NO: 628

An audit trail is a category of what control?

- A. System, Manual
- B. Detective, Technical
- C. User, Technical
- D. Detective, Manual

Answer: B

Explanation:

Detective Technical Controls warn of technical Access Control violations. Under this category you would find the following:

Audit trails

Violation reports

Intrusion detection system

Honeypot

QUESTION NO: 629

An IDS is a category of what control?

- A. Detective, Manual
- B. Detective, Technical
- C. User, Technical
- D. System, Manual

Answer: B

Explanation:

Detective Technical Controls warn of technical Access Control violations. Under this category you would find the following:

Audit trails

Violation reports

Intrusion detection system

Honeypot

QUESTION NO: 630

Technical controls such as encryption and access control can be built into the operating system, be software applications, or can be supplemental hardware/software units. Such controls, also known as logical controls, represent which pairing?

- A. Preventive/Administrative Pairing
- B. Preventive/Technical Pairing
- C. Preventive/Physical Pairing
- D. Detective/Technical Pairing

Answer: B

Explanation:

QUESTION NO: 631

Which one of the following can be identified when exceptions occur using operations security detective controls?

- A. Unauthorized people seeing confidential reports.
- B. Unauthorized people destroying confidential reports.
- C. Authorized operations people performing unauthorized functions.
- D. Authorized operations people not responding to important console messages.

Answer: C

Explanation: C is the one that makes the most sense.

[Operation Security] Detective Controls are used to detect an error once it has occurred. Unlike preventative controls, these controls operate after the fact and can be used to track an unauthorized transaction for prosecution, or to lessen an error's impact on the system by identifying it quickly. An example of this type of control is an audit trail. -Ronald Krutz The CISSP PREP Guide (gold edition) pg 299

QUESTION NO: 632

Which of the following is not an example of an operation control?

- A. backup and recovery
- B. audit trails
- C. contingency planning
- D. operations procedures

Answer: C

Explanation: "Operation controls are the mechanisms and daily procedures that provide protection for systems."

When designing a protection scheme for resources, it is important to keep the following aspects or elements of the IT infrastructure in mind:

Communication hardware/software

Boundary devices

Processing equipment

Password files

Application program libraries

Application source code

Vendor software

Operating System

System Utilities

Directories and address tables

Proprietary packages

Main storage

Removable storage
Sensitive/critical data
System logs/audit trails
Violation reports
Backup files and media
Sensitive forms and printouts
Isolated devices, such as printers and faxes
Telephone network"

Pg 406-407 Tittel: CISSP Study Guide

QUESTION NO: 633

Which of the following is not an example of an operational control?

- A. backup and recovery
- B. audit trails
- C. contingency planning
- D. operations procedures

Answer: B

Explanation: Audit Trails are under Operations Security Auditing opposed to Operations Security Operations Controls.

"Operations Controls embody the day-to-day procedures used to protect computer operations. The concepts of resource protection, hardware/software control, and privileged entity must be understood by the CISSP candidate." Pg. 311 Krutz: The CISSP Prep Guide: Gold Edition

QUESTION NO: 634

Access control allows you to exercise directing influence over which of the following aspects of a system?

- A. Behavior, user, and content provider.
- B. Behavior, use, and content.
- C. User logs and content.
- D. None of the choices.

Answer: B

Explanation:

Access control is the collection of mechanisms that permits managers of a system to exercise a directing or restraining influence over the behavior, use, and content of a system. It permits management to specify what users can do, which resources they can access, and what operations they can perform on a system.

QUESTION NO: 635

_____ is the means by which the ability to do something with a computer resource is explicitly enabled or restricted.

- A. Access control
- B. Type of access
- C. System resource
- D. Work permit

Answer: A

Explanation:

Access is the ability to do something with a computer resource (e.g., use, change, or view). Access control is the means by which the ability is explicitly enabled or restricted in some way (Usually through physical and system-based controls). Computer-based access controls can prescribe not only who or what process may have access to a specific system resource, but also the type of access that is permitted. These controls may be implemented in the computer system or in external devices.

QUESTION NO: 636

The ability to do something with a computer resource can be explicitly enabled or restricted

through:

- A. Physical and system-based controls.
- B. Theoretical and system-based controls.
- C. Mental and system-based controls.
- D. Physical and trap-based controls.

Answer: A

Explanation:

Access is the ability to do something with a computer resource (e.g., use, change, or view). Access control is the means by which the ability is explicitly enabled or restricted in some way (Usually through physical and system-based controls). Computer-based access controls can prescribe not only who or what process may have access to a specific system resource, but also the type of access that is permitted. These controls may be implemented in the computer system or in external devices.

QUESTION NO: 637

The main categories of access control do NOT include:

- A. Administrative Access Control
- B. Logical Access Control
- C. Random Access Control
- D. Physical Access Control

Answer: C

Explanation:

There are several different categories of access control. The main categories are:

- Physical Access Control
- Administrative Access Control
- Logical Access Control
- Data Access Control

QUESTION NO: 638

You have very strict Physical Access controls. At the same time you have loose Logical Access Controls. What is true about this setting?

- A. None of the choices.
- B. It can 100% secure your environment.
- C. It may secure your environment.
- D. It may not secure your environment.

Answer: D

Explanation:

Access control is a bit like the four legs of a chair. Each of the legs must be equal or else an imbalance will be created. If you have very strict Physical Access controls but very poor Logical Access Controls then you may not succeed in securing your environment.

QUESTION NO: 639

Which of the following is not a detective technical control?

- A. Intrusion detection system
- B. Violation reports
- C. Honeypot
- D. None of the choices.

Answer: D

Explanation:

Detective Technical Controls warn of technical Access Control violations. Under this category you would find the following:

Audit trails

Violation reports

Intrusion detection system

Honeypot

QUESTION NO: 640

A business continuity plan is an example of which of the following?

- A. Corrective Control
- B. Detective Control
- C. Preventive Control
- D. Compensating Control

Answer: A

Explanation:

QUESTION NO: 641

_____ Technical Controls warn of technical Access Control violations.

- A. Elusive
- B. Descriptive
- C. Corrective
- D. Detective

Answer: D

Explanation:

Detective Technical Controls warn of technical Access Control violations. Under this category you would find the following:

Audit trails

Violation reports

Intrusion detection system

Honeypot

QUESTION NO: 642

A two factor authentication method is considered a:

- A. Technical control
- B. Patching control
- C. Corrective control
- D. Systematic control

Answer: A

Explanation:

By technical controls we mean some or all of the following:

Access Control software
Antivirus Software
Passwords
Smart Cards
Encryption
Call-back systems
Two factor authentication

Note: logical & technical controls are used interchangeably (pg 158 of CISSP / Shon Harris / 5th edition)

QUESTION NO: 643

Which of the following are NOT considered technical controls?

- A. Access Control software
- B. Man trap
- C. Passwords
- D. Antivirus Software

Answer: B

Explanation:

By technical controls we mean some or all of the following:

Access Control software
Antivirus Software
Passwords
Smart Cards
Encryption
Call-back systems
Two factor authentication

QUESTION NO: 644

_____ are the technical ways of restricting who or what can access system resources.

- A. Preventive Manual Controls
- B. Detective Technical Controls
- C. Preventive Circuit Controls
- D. Preventive Technical Controls

Answer: D

Explanation:

Preventive Technical Controls are the technical ways of restricting who or what can access system resources and what type of access is permitted. Its purpose is to protect the OS and other systems from unauthorized modification or manipulation. It is usually built into an operating system, or it can be a part of an application or program, or an add-on security package, or special components to regulate communication between computers. It also protects the integrity and availability by limiting the number of users and/or processes. These controls also protect confidential information from being disclosed to unauthorized persons.

QUESTION NO: 645

Which of the following is not a form of detective administrative control?

- A. Rotation of duties
- B. Required vacations
- C. Separation of duties
- D. Security reviews and audits

Answer: C

Explanation:

Separation of duties is a PREVENTIVE Administrative Control.
The other 3 are DETECTIVE Administrative Controls.

Detective Administrative Controls

Detective administrative controls are used to determine how well security policies and procedures are complied with, to detect fraud, and to avoid employing persons that represent an unacceptable security risk. This type of control includes:

- Security reviews and audits.
- Performance evaluations.
- Required vacations.
- Background investigations.
- Rotation of duties.

Reference: <http://cccure.org/Documents/HISM/015-019.html>

QUESTION NO: 646

Preventive Technical Controls are usually built:

- A. By using MD5.
- B. Into an operating system.
- C. By security officer.
- D. By security administrator.

Answer: B

Explanation:

Preventive Technical Controls are the technical ways of restricting who or what can access system resources and what type of access is permitted. Its purpose is to protect the OS and other systems from unauthorized modification or manipulation. It is usually built into an operating system, or it can be a part of an application or program, or an add-on security package, or special components to regulate communication between computers. It also protects the integrity and availability by limiting the number of users and/or processes. These controls also protect confidential information from being disclosed to unauthorized persons.

QUESTION NO: 647

Preventive Technical Controls cannot:

- A. Protect the OS from unauthorized modification.
- B. Protect confidential information from being disclosed to unauthorized persons.
- C. Protect the OS from unauthorized manipulation.
- D. Protect users from being monitored.

Answer: D

Explanation:

Preventive Technical Controls are the technical ways of restricting who or what can access system resources and what type of access is permitted. Its purpose is to protect the OS and other systems from unauthorized modification or manipulation. It is usually built into an operating system, or it can be a part of an application or program, or an add-on security package, or special components to regulate communication between computers. It also protects the integrity and availability by limiting the number of users and/or processes. These controls also protect confidential information from being disclosed to unauthorized persons.

QUESTION NO: 648

How do Preventive Technical Controls protect system integrity and availability?

- A. By limiting the number of threads only.
- B. By limiting the number of system variables.
- C. By limiting the number of function calls only.
- D. By limiting the number of users and/or processes.

Answer: D

Explanation:

Preventive Technical Controls are the technical ways of restricting who or what can access system resources and what type of access is permitted. Its purpose is to protect the OS and other systems from unauthorized modification or manipulation. It is usually

built into an operating system, or it can be a part of an application or program, or an add-on security package, or special components to regulate communication between computers. It also protects the integrity and availability by limiting the number of users and/or processes. These controls also protect confidential information from being disclosed to unauthorized persons.

QUESTION NO: 649

Which of the following is NOT a type of access control?

- A. Intrusive
- B. Deterrent
- C. Detective
- D. Preventive

Answer: A

Explanation:

There are different types of access control. Access controls can be categorized as follows:

- Preventive (in order to avoid occurrence)
- Detective (in order to detect or identify occurrences)
- Deterrent (in order to discourage occurrences)
- Corrective (In order to correct or restore controls)
- Recovery (in order to restore resources, capabilities, or losses)

QUESTION NO: 650

As a type of access control, which of the following asks for avoiding occurrence?

- A. Preventive
- B. Deterrent
- C. Intrusive
- D. Detective

Answer: A

Explanation:

There are different types of access control. Access controls can be categorized as follows:

Preventive (in order to avoid occurrence)

Detective (in order to detect or identify occurrences)

Deterrent (in order to discourage occurrences)

Corrective (In order to correct or restore controls)

Recovery (in order to restore resources, capabilities, or losses)

QUESTION NO: 651

As a type of access control, which of the following asks for identifying occurrences?

- A. Deterrent
- B. Preventive
- C. Detective
- D. Intrusive

Answer: C

Explanation:

There are different types of access control. Access controls can be categorized as follows:

Preventive (in order to avoid occurrence)

Detective (in order to detect or identify occurrences)

Deterrent (in order to discourage occurrences)

Corrective (In order to correct or restore controls)

Recovery (in order to restore resources, capabilities, or losses)

QUESTION NO: 652

As a type of access control, which of the following asks for discouraging occurrence?

- A. Detective
- B. Intrusive
- C. Deterrent
- D. Preventive

Answer: C

Explanation:

There are different types of access control. Access controls can be categorized as follows:

- Preventive (in order to avoid occurrence)
- Detective (in order to detect or identify occurrences)
- Deterrent (in order to discourage occurrences)
- Corrective (In order to correct or restore controls)
- Recovery (in order to restore resources, capabilities, or losses)

QUESTION NO: 653

As a type of access control, which of the following asks for restoring controls?

- A. Deterrent
- B. Intrusive
- C. Corrective
- D. Preventive

Answer: C

Explanation:

There are different types of access control. Access controls can be categorized as follows:

- Preventive (in order to avoid occurrence)
- Detective (in order to detect or identify occurrences)
- Deterrent (in order to discourage occurrences)
- Corrective (In order to correct or restore controls)
- Recovery (in order to restore resources, capabilities, or losses)

QUESTION NO: 654

What type of access control focuses on restoring resources?

- A. Recovery
- B. Preventive
- C. Intrusive
- D. Corrective

Answer: A

Explanation:

There are different types of access control. Access controls can be categorized as follows:

- Preventive (in order to avoid occurrence)
- Detective (in order to detect or identify occurrences)
- Deterrent (in order to discourage occurrences)
- Corrective (In order to correct or restore controls)
- Recovery (in order to restore resources, capabilities, or losses)

QUESTION NO: 655

Access control is the collection of mechanisms that permits managers of a system to exercise influence over the use of:

- A. A man guard
- B. An IS system
- C. A threshold
- D. A Trap

Answer: B

Explanation:

Access control is the collection of mechanisms that permits managers of a system to exercise a directing or restraining influence over the behavior, use, and content of a system. It permits management to specify what users can do, which resources they can access, and what operations they can perform on a system.

Topic 6, Physical Security

QUESTION NO: 656

What fencing height is likely to stop a determined intruder?

- A. 3' to 4' high
- B. 6' to 7' high
- C. 8' high and above with strands of barbed wire
- D. No fence can stop a determined intruder

Answer: C

Explanation:

QUESTION NO: 657

Lock picking is classified under which one of the following lock mechanism attacks?

- A. Illicit key
- B. Circumvention
- C. Manipulation
- D. Shimming

Answer: C

Explanation:

Lock picking is manipulation of the tumblers.

QUESTION NO: 658

The Physical Security domain addresses three areas that can be utilized to physically protect an enterprise's resources and sensitive information. Which of the following is not one of these areas?

- A. Threats
- B. Countermeasures

- C. Vulnerabilities
- D. Risks

Answer: B

Explanation:

QUESTION NO: 659

Which issue when selecting a facility site deals with the surrounding terrain, building markings and signs, and high or low population in the area?

- A. surrounding area and external entities
- B. natural disasters
- C. accessibility
- D. visibility

Answer: D

Explanation:

QUESTION NO: 660

Which of the following is not a physical control for physical security?

- A. lighting
- B. fences
- C. training
- D. facility construction materials

Answer: C

Explanation:

QUESTION NO: 661

The main risks that physical security components combat are all of the following EXCEPT:

- A. SYN flood
- B. physical damage
- C. theft
- D. availability

Answer: A

Explanation:

QUESTION NO: 662

What mechanism automatically causes an alarm originating in a data center to be transmitted over the local municipal fire or police alarm circuits for relaying to both the local police/fire station and the appropriate headquarters?

- A. Central station alarm
- B. Proprietary alarm
- C. A remote station alarm
- D. An auxiliary station alarm

Answer: D

Explanation:

The Auxiliary Station should be the Correct answer.

Transmitted over Muniple system and rings at police/fire station. See the highlighted txt from "The CISSP Prep Guide Gold Edition" by Wiley page 511.

Auxiliary Station Systems. Any of the previous three systems may have auxiliary alarms that ring at the local fire or police stations. Most central station systems include this feature, which requires permission from the local authorities before implementation.

QUESTION NO: 663

Examples of types of physical access controls include all except which of the following?

- A. badges
- B. locks
- C. guards
- D. passwords

Answer: D

Explanation:

QUESTION NO: 664

Which of the following is the most costly countermeasures to reducing physical security risks?

- A. procedural controls
- B. hardware devices
- C. electronic systems
- D. personnel

Answer: D

Explanation:

QUESTION NO: 665

Which of the following protection devices is used for spot protection within a few inches of the object, rather than for overall room security monitoring?

- A. Wave pattern motion detectors
- B. Capacitance detectors
- C. Field-powered devices
- D. Audio detectors

Answer: B

Explanation:

"Capacitance. Capacitance detectors monitor an electrical field surrounding the object being monitored. They are used for spot protection within a few inches of the object, rather than for overall room security monitoring used by wave detectors. Penetration of this field changes the electrical capacitance of the field enough to generate an alarm" - The CISSP® Prep Guide: Gold Edition by Wiley Publishing Page 480.

QUESTION NO: 666

Which of the following questions is less likely to help in assessing physical access controls?

- A.** Does management regularly review the list of persons with physical access to sensitive facilities?
- B.** Is the operating system configured to prevent circumvention of the security software and application controls?
- C.** Are keys or other access devices needed to enter the computer room and media library?
- D.** Are visitors to sensitive areas signed in and escorted?

Answer: B

Explanation:

QUESTION NO: 667

The concentric circle approach is used to

- A.** Evaluate environmental threats.
- B.** Assess the physical security facility,
- C.** Assess the communications network security.
- D.** Develop a personnel security program.

Answer: B

Explanation: The original answer for this question was C (assess the communications network security) however I think the concentric circle is defining what in the krutz book is know as the security perimeter. To this end this is a reference

"A circular security perimeter that is under the access control defines the area or zone to be protected. Preventive/physical controls include fences, badges, multiple doors (man-traps that consists of two doors physically separated so that an individual can be 'trapped' in the space between the doors after entering one of the doors), magnetic card entry systems, biometrics (for identification), guards, dogs, environmental control systems (temperature, humidity, and so forth), and building and access area layout." -Ronald Krutz The CISSP PREP Guide (gold edition) pg 13

This is a standard concentric circle model shown in Figure 1 . If you've never seen this, you haven't had a security lecture.

On the outside is our perimeter. We are fortunate to have some defenses on our base. Although some bases don't have people guarding the gates and checking IDs any longer, there's still the perception that it's tougher to commit a crime on a Naval base than it would be at GM.

The point is: How much control do we have over fencing and guards? The answer: Not much.

The next circle, the red circle, contains your internal access controls. For our purposes, the heart of the red circle is the computer. That's what I want to zero in on. The internal controls are the things you can do to keep people out of your PCs and off your network.

http://www.chips.navy.mil/archives/96_oct/file5.htm

QUESTION NO: 668

The MAIN reason for developing closed-circuit television (CCTV) as part of your physical security program is to

- A.** Provide hard evidence for criminal prosecution.
- B.** Apprehend criminals.
- C.** Deter criminal activity.
- D.** Increase guard visibility.

Answer: D

Explanation: A CCTV enables a guard to monitor many different areas at once from a centralized location. - Shon Harris All-in-one CISSP Certification Guide pg 179-180

QUESTION NO: 669

Closed circuit TV is a feature of:

- A.** Detective Physical Controls
- B.** Corrective Physical Controls
- C.** Corrective Logical Controls
- D.** Logical Physical Controls

Answer: A

Explanation:

Detective Physical Controls would use the following: motion detectors, closed circuit TV, sensors, and alarms.

QUESTION NO: 670

Motion detector is a feature of:

- A. Corrective Logical Controls.
- B. Logical Physical Controls.
- C. Corrective Physical Controls.
- D. Detective Physical Controls.

Answer: D

Explanation:

Detective Physical Controls would use the following: motion detectors, closed circuit TV, sensors, and alarms.

QUESTION NO: 671

Which of the following is a physical control?

- A. Monitoring of system activity
- B. Environmental controls
- C. Identification and authentication methods
- D. Logical access control mechanisms

Answer: B

Explanation:

QUESTION NO: 672

Which of the following is a detective control?

- A. Segregation of duties
- B. Back-up procedures
- C. Audit trails
- D. Physical access control

Answer: C

Explanation:

QUESTION NO: 673

The basic Electronic Access Control (EAC) components required for access doors are an electromagnetic lock,

- A. A credential reader, and a door closed sensor.
- B. A card reader, and a door open sensor.
- C. A biometric reader, and a door open sensor.
- D. A card reader, and door motion detector.

Answer: A

Explanation: We have not been able to find any reference to this question really. So we are going with "A credential reader, and a door closed sensor".

"In addition to smart and dumb cards, proximity readers can be used to control physical access. A proximity reader can be passive device, a field-powered device, or a transponder." - Ed Tittle
CISSP Study Guide (sybex) pg 650

QUESTION NO: 674

Which of the following control pairing places emphasis on "soft" mechanisms that support the access control objectives?

- A. Preventive/Technical Pairing
- B. Preventive/Administrative Pairing
- C. Preventive/Physical Pairing
- D. Detective/Administrative Pairing

Answer: B

Explanation: "Preventive-Administrative

The following are the soft mechanisms that are put into place to enforce access control and protection for the company as a whole:

Policies and procedures

Effective hiring practices

Pre-employment background checks

Controlled termination processes

Data classification and labeling

Security awareness"

Pg. 157 Shon Harris: All-In-One CISSP Certification Guide.

QUESTION NO: 675

Controls like guards and general steps to maintain building security, securing of server rooms or laptops, the protection of cables, and the backing up of files are some of the examples of:

- A. Administrative controls
- B. Logical controls
- C. Technical controls
- D. Physical controls

Answer: D

Explanation:

QUESTION NO: 676

Which of the following is NOT a type of motion detector?

- A. photoelectric sensor

- B. wave pattern
- C. capacitance
- D. audio detector

Answer: D

Explanation: Audio detector detects sound not motion

Not A: A photoelectric sensor is a motion sensor that's what it was designed to do.

QUESTION NO: 677

Which of the following measures would be the BEST deterrent to the theft of corporate information from a laptop which was left in a hotel room?

- A. Store all data on disks and lock them in an in-room safe
- B. Remove the batteries and power supply from the laptop and store them separately from the computer
- C. Install a cable lock on the laptop when it is unattended
- D. Encrypt the data on the hard drive

Answer: D

Explanation: To encrypt the data on the hard drive is the best deterrent for information theft (not however the best for physical theft).

QUESTION NO: 678

Guards are appropriate whenever the function required by the security program involves which of the following?

- A. The use of discriminating judgment
- B. The use of physical force
- C. The operation of access control devices
- D. The need to detect unauthorized access

Answer: A

Explanation:

QUESTION NO: 679

Which of the following floors would be most appropriate to locate information processing facilities in a 6-stories building?

- A. Basement
- B. Ground floor
- C. Third floor
- D. Sixth floor

Answer: C

Explanation:

QUESTION NO: 680

Which of the following risk will most likely affect confidentiality, integrity and availability?

- A. Physical damage
- B. Unauthorized disclosure of information
- C. Loss of control over system
- D. Physical theft

Answer: D

Explanation:

QUESTION NO: 681

Which is the last line of defense in a physical security sense?

- A. people
- B. interior barriers
- C. exterior barriers
- D. perimeter barriers

Answer: A

Explanation:

QUESTION NO: 682

The recording of events with a closed-circuit TV camera is considered a:

- A. Preventative control
- B. Detective control
- C. Compensating control
- D. Corrective Control

Answer: B

Explanation:

QUESTION NO: 683

Sensor is:

- A. Logical, Physical
- B. Corrective, Logical
- C. Detective, Physical
- D. Corrective, Physical

Answer: C

Explanation:

Detective Physical Controls would use the following: motion detectors, closed circuit TV, sensors, and alarms.

QUESTION NO: 684

What fencing height is likely to stop a determined intruder?

- A. 3' to 4' high
- B. 6' to 7' high

- C. 8' high and above with strands of barbed wire
- D. No fence can stop a determined intruder

Answer: C

Reference: "2.4 meters/8 feet with top guard: Deters determined intruder". Pg 467 Hansche: Official (ISC)2 Guide to the CISSP Exam

QUESTION NO: 685

A controlled light fixture mounted on a 5-meter pole can illuminate an area 30 meter in diameter.

For security lighting purposes, what would be the proper distance between fixtures?

- A. 25 meters
- B. 30 meters
- C. 35 meters
- D. 40 meters

Answer: A

Explanation:

The answer should be 25 meters:

If a lamp provides a 30 foot illumination, the lamps should be placed less than 30 feet apart to provide an overlap. A 30 meter coverage area mean the next light should be less than 30 meters away, and the only answer that fits is 25 meters.

Chapter 6, page 459 of Shon Harris CISSP 5th edition book.

light poles must be positioned within the correct distance of each other to eliminate any dead spots. If the lamps that will be used provide a 30-foot radius of illumination, then the light poles should be erected less than 30 feet apart so there is an overlap between the areas of illumination.

QUESTION NO: 686

Critical areas should be lighted:

- A. Eight feet high and two feet out
- B. Eight feet high and four feet out

- C. Ten feet high and four feet out
- D. Ten feet high and six feet out

Answer: A

Explanation:

QUESTION NO: 687

Which of the following statements regarding an off-site information processing facility is TRUE?

- A. It should have the same amount of physical access restrictions as the primary processing unit
- B. It should be located in proximity to the originating site so that it can quickly be made operational
- C. It should be easily identified from the outside so in the event of an emergency it can be easily found
- D. Need not have the same level of environmental monitoring as the originating site since this would be cost prohibitive

Answer: A

Explanation:

QUESTION NO: 688

Which of the following is electromagnetic interference (EMI) that is noise from the radiation generated by the difference between the hot and ground wires?

- A. common-mode noise
- B. traverse-mode noise
- C. transversal-mode noise
- D. crossover-mode noise

Answer: A

Explanation:

QUESTION NO: 689

Which of the following is NOT a precaution you can take to reduce static electricity?

- A. power line conditioning
- B. anti-static sprays
- C. maintain proper humidity levels
- D. anti-static flooring

Answer: A

Explanation:

QUESTION NO: 690

Devices that supply power when the commercial utility power system fails are called which of the following?

- A. power conditioners
- B. uninterruptible power supplies
- C. power filters
- D. power dividers

Answer: B

Explanation:

QUESTION NO: 691

A prolonged high voltage is a:

- A. spike
- B. blackout
- C. surge
- D. fault

Answer: C

Explanation:

QUESTION NO: 692

A prolonged power supply that is below normal voltage is a:

- A. brownout
- B. blackout
- C. surge
- D. fault

Answer: A

Explanation:

QUESTION NO: 693

A prolonged power outage is a:

- A. brownout
- B. blackout
- C. surge
- D. fault

Answer: B

Explanation:

QUESTION NO: 694

A momentary power outage is a:

- A. spike
- B. blackout
- C. surge
- D. fault

Answer: D

Explanation:

QUESTION NO: 695

What can be defined as a momentary low voltage?

- A. Spike
- B. Sag
- C. Fault
- D.) Brownout

Answer: B

Explanation:

QUESTION NO: 696

Electrical systems are the lifeblood of computer operations. The continued supply of clean, steady power is required to maintain the proper personnel environment as well as to sustain data operations. Which of the following is not an element that can threaten power systems?

- A. Noise
- B. Humidity
- C. Brownouts
- D. UPS

Answer: D

Explanation:

QUESTION NO: 697

Under what conditions would use of a "Class C" hand-held fire extinguisher be preferable to use of a "Class A" hand-held fire extinguisher?

- A. When the fire is in its incipient stage
- B. When the fire involves electrical equipment
- C. When the fire is located in an enclosed area
- D. When the fire is caused by flammable products

Answer: B

Explanation:

QUESTION NO: 698

Which of the following is a class C fire?

- A. electrical
- B. liquid
- C. common combustibles
- D. soda acid

Answer: A

Explanation:

QUESTION NO: 699

Which of the following is not a EPA-approved replacement for Halon?

- A. Water
- B. Argon
- C. NAF-S-III
- D. Bromine

Answer: D

Explanation:

QUESTION NO: 700

Which of the following suppresses combustion through a chemical reaction that kills the fire?

- A. Halon
- B. Co₂
- C. water
- D. soda acid

Answer: A

Explanation:

QUESTION NO: 701

Which of the following is a class A fire?

- A. common combustibles
- B. liquid
- C. electrical
- D. Halon

Answer: A

Explanation:

QUESTION NO: 702

To be in compliance with the Montreal Protocol, which of the following options can be taken to refill a Halon flooding system in the event that Halon is fully discharged in the computer room?

- A. Order an immediate refill with Halon 1201 from the manufacture
- B. Contact a Halon recycling bank to make arrangements for a refill
- C. Order a different chlorofluorocarbon compound from the manufacture
- D. Order an immediate refill with Halon 1301 from the manufacture

Answer: B

Explanation:

QUESTION NO: 703

Under what conditions would the use of a Class C fire extinguisher be preferable to a Class A extinguisher?

- A. When the fire involves paper products
- B. When the fire is caused by flammable products
- C. When the fire involves electrical equipment
- D. When the fire is in an enclosed area

Answer: C

Explanation:

QUESTION NO: 704

Which of the following is true about a “dry pipe” sprinkler system?

- A. It is a substitute for carbon dioxide systems
- B. It maximizes chances of accidental discharge of water
- C. it minimizes chances of accidental discharge of water
- D. It uses less water than “wet pipe” systems

Answer: C

Explanation:

QUESTION NO: 705

Under what conditions would use of a “Class C” hand-held fire extinguisher be preferable to use of a “Class A” hand-held fire extinguisher?

- A. When the fire is in its incipient stage
- B. When the fire involves electrical equipment
- C. When the fire is located in an enclosed area
- D. When the fire is caused by flammable products

Answer: B

Explanation:

QUESTION NO: 706

Which fire class can water be most appropriate for?

- A. Class A fires
- B. Class B fires
- C. Class C fires
- D. Class D fires

Answer: A

Explanation:

QUESTION NO: 707

What category of water sprinkler system is currently the most recommended water system for a computer room?

- A. Dry Pipe sprinkler system
- B. Wet Pipe sprinkler system
- C. Pre-action sprinkler system
- D. Deluge sprinkler system

Answer: C

Explanation:

QUESTION NO: 708

Which of the following is currently the most recommended water system for a computer room?

- A. pre-action
- B. wet pipe
- C. dry pipe
- D. deluge

Answer: A

Reference: pg 496 Hansche: Official (ISC)2 Guide to the CISSP Exam

QUESTION NO: 709

According to the ISC2, what should be the fire rating for the walls of an information processing facility?

- A. All walls must have a one-hour minimum fire rating
- B. All walls must have a one-hour minimum fire rating, except for walls to adjacent rooms where records such as paper and media are stored, which should have a two-hour minimum fire rating
- C. All walls must have a two-hour minimum fire rating
- D. All walls must have a two-hour minimum fire rating, except for walls to adjacent rooms where records such as paper and media are stored, which should have a three-hour minimum fire rating.

Answer: C

Explanation:

QUESTION NO: 710

Which of the following suppresses the fuel supply of the fire?

- A. soda acid
- B. Co₂
- C. Halon
- D. water

Answer: A

Explanation:

QUESTION NO: 711

Which of the following is true about a “dry pipe” sprinkler system?

- A. It is a substitute for carbon dioxide systems
- B. It maximizes chances of accidental discharge of water
- C. It minimizes chances of accidental discharge of water
- D. It uses less water than “wet pipe” systems

Answer: C

Explanation:

QUESTION NO: 712

The most prevalent cause of computer center fires is which of the following?

- A. AC equipment
- B. electrical distribution systems
- C. heating systems
- D. natural causes

Answer: B

Explanation:

QUESTION NO: 713

What fire suppression system can be used in computer rooms that will not damage computers and is safe for humans?

- A. Water
- B. FM200
- C. Halon
- D. CO2

Answer: B

Reference: http://www.fireline.com/fl_fm200firesuppression.html

FM-200 Systems

FM-200 Fire Suppression Systems - Halon Alternatives Fire Protection Systems

FM200 is a fire suppression system agent manufactured by Great Lakes Chemical.

How FM200 Suppresses Fire

FM200 suppresses fire by discharging as a gas onto the surface of combusting materials. Large amounts of heat energy are absorbed from the surface of the burning material, lowering its temperature below the ignition point.

FM200 Fire Suppression Systems and the Environment

FM200 fire suppression systems have low atmospheric lifetimes, global warming, and ozone depletion potentials. Unlike Halon 1301 fire suppression systems, FM200 systems are environmentally friendly. They

provide an effective, safe method of special hazards fire suppression

where a non-residue producing clean agent is essential.

QUESTION NO: 714

The following are fire detector types EXCEPT:

- A. smoke activated
- B. flame actuated
- C. acoustical-seismic detection system
- D. heat activated

Answer: C

Explanation:

QUESTION NO: 715

Which fire class can water be most appropriate for?

- A. Class A fires
- B. Class B fires
- C. Class C fires
- D. Class D fires

Answer: A

Explanation: "Fire Extinguisher Classes

ClassTypeSuppression Material

ACommon combustiblesWater, soda acid (dry powder)

BLiquidsCO₂ , Halon, soda acid

CElectricalCO₂, Halon"

Pg. 578 Tittel: CISSP Study Guide

QUESTION NO: 716

Which one of the following actions should be taken FIRST after a fire has been detected?

- A. Turn off power to the computers
- B. Call the fire department
- C. Notify management
- D. Evacuate all personnel

Answer: D

Explanation: Protection of life is of the utmost importance and should be dealt with first before looking to save material objects. . - Shon Harris All-in-one CISSP Certification Guide pg 625

QUESTION NO: 717

Which of the following provides coordinated procedures for minimizing loss of life or injury and protecting property damage in response to a physical threat?

- A. Business continuity plan
- B. Incident response plan
- C. Disaster recovery plan
- D. Occupant emergency plan

Answer: D

Explanation: "Occupant Emergency Plan (OEP). The OEP is a document providing coordinated procedures for minimizing loss of life or injury and protecting property damage in response to a physical threat. It does not necessarily deal with business systems or IT system functionality, but rather focuses on personnel and property at a specific facility." Pg 666 Hansche: Official (ISC)2 Guide to the CISSP Exam

QUESTION NO: 718

Disaster Recovery Plan emergency produces is a plan of action that commences immediately to prevent or minimize property damage and to:

- A. Prevent interruption of service.
- B. Minimize embarrassment.
- C. Prevent loss of life.
- D. Evacuate the facility.

Answer: C

Explanation: Protection of life is of the utmost importance and should be dealt with first before looking to save material objects. - Shon Harris All-in-one CISSP Certification Guide pg 625

QUESTION NO: 719

What is the PRIMARY concern during a disaster?

- A. Recover of the critical functions.
- B. Availability of a hot site.
- C. Acceptable outage duration.
- D. Personnel safety.

Answer: D

Explanation: Personal safety goes way above and beyond all other things, unless you're a rescue worker, and even then safety is still priority #1. Recovering critical functions and down time are not the MOST important concerns; Data can be recovered, a potential life loss cannot be. Making Personal safety of the utmost important.

Topic 7, Cryptography

QUESTION NO: 720

Which of the following elements is not included in a Public Key Infrastructure (PKI)?

- A. Timestamping
- B. Lightweight Directory Access Protocol (LDAP)
- C. Certificate revocation
- D. Internet Key Exchange (IKE)

Answer: D

Explanation:

QUESTION NO: 721

In a Public Key Infrastructure (PKI) context, which of the following is a primary concern with LDAP servers?

- A. Availability
- B. Accountability
- C. Confidentiality
- D. Flexibility

Answer: A

Explanation:

QUESTION NO: 722

What is NOT true with pre shared key authentication within IKE/IPsec protocol:

- A. pre shared key authentication is normally based on simple passwords
- B. needs a PKI to work
- C. Only one preshared key for all VPN connections is needed
- D. Costly key management on large user groups

Answer: B

Explanation:

QUESTION NO: 723

What is the role of IKE within the IPsec protocol:

- A. peer authentication and key exchange
- B. data encryption
- C. data signature
- D. enforcing quality of service

Answer: A

Explanation: "In order to set up and manage SAs on the Internet, a standard format called the Internet Security Association and Key Management Protocol (ISAKMP) was established. ISAKMP provides for secure key exchange and data authentication. However, ISAKMP is independent of the authentication protocols, security protocols, and encryption algorithms. Strictly speaking, a combination of three protocols is used to define key management for IPSEC. These protocols are ISAKMP, Secure Key Exchange Mechanism (SKEME) and Oakley. When combined and applied to IPSEC, these protocols are called the Internet Key Exchange (IKE) protocol." Pg. 222 Krutz: The CISSP Prep Guide: Gold Edition

QUESTION NO: 724

In a Public Key Infrastructure, how are public keys published?

- A. They are sent via e-mail
- B. Through digital certificates
- C. They are sent by owners
- D. They are not published

Answer: B

Explanation:

QUESTION NO: 725

Which of the following is defined as a key establishment protocol based on the Diffie-Hellman algorithm proposed for IPsec but superseded by IKE?

- A. Diffie-Hellman Key Exchange Protocol
- B. Internet Security Association and Key Management Protocol (ISAKMP)

- C. Simple Key-management for Internet Protocols (SKIP)
- D. OAKLEY

Answer: D

Explanation:

QUESTION NO: 726

Which of the following defines the key exchange for Internet Protocol Security (IPSEC)?

- A. Internet Security Association Key Management Protocol (ISAKMP)
- B. Internet Key Exchange (IKE)
- C. Security Key Exchange (SKE)
- D. Internet Communication Messaging Protocol (ICMP)

Answer: A

Explanation: Because Ipsec is a framework, it does not dictate what hashing and encryption algorithms are to be used or how keys are to be exchanged between devices. Key management can be handled through manual process or automated a key management protocol. The Internet Security Association and Key management Protocol (ISAKMP) is an authentication and key exchange architecture that is independent of the type of keying mechanisms used.

Pg 577 Shon Harris All-In-One CISSP Certification Exam Guide

QUESTION NO: 727

A network of five nodes is using symmetrical keys to securely transmit data. How many new keys are required to re-establish secure communications to all nodes in the event there is a key compromise?

- A. 5
- B. 10
- C. 20
- D. 25

Answer: B

Explanation:

Per Sybex CISSP Study Guide 3rd Edition (page #314)

total # of symmetrical keys needed is expressed as:

$$[\text{number of participants} * (\text{number of participants}-1)]/2$$

s/b B. 10 not A. 5

QUESTION NO: 728

What is the effective key size of DES?

- A. 56 bits
- B. 64 bits
- C. 128 bits
- D. 1024 bits

Answer: A

Explanation:

QUESTION NO: 729

Matches between which of the following are important because they represent references from one relation to another and establish the connection among these relations?

- A. foreign key to primary key
- B. foreign key to candidate key
- C. candidate key to primary key
- D. primary key to secondary key

Answer: A

Explanation:

QUESTION NO: 730

Which of the following can best be defined as a key distribution protocol that uses hybrid encryption to convey session keys that are used to encrypt data in IP packets?

- A. Internet Security Association and Key Management Protocol (ISKAMP)
- B. Simple Key-Management for Internet Protocols (SKIP)
- C. Diffie-Hellman Key Distribution Protocol
- D. IPsec Key Exchange (IKE)

Answer: B

Reference: pg 117 Krutz

QUESTION NO: 731

What is the PRIMARY advantage of secret key encryption systems as compared with public key systems?

- A. Faster speed encryption
- B. Longer key lengths
- C. Easier key management
- D. Can be implemented in software

Answer: A

Explanation: "The major strength of symmetric key cryptography is the great speed at which it can operate. By the nature of the mathematics involved, symmetric key cryptography also naturally lends itself to hardware implementations, creating the opportunity for even higher-speed operations." Pg. 309 Tittel: CISSP Study Guide

QUESTION NO: 732

In a cryptographic key distribution system, the master key is used to exchange?

- A. Session keys
- B. Public keys
- C. Secret keys
- D. Private keys

Answer: A

Explanation: “The Key Distribution Center (KDC) is the most important component within a Kerberos environment. The KDC holds all users’ and services’ cryptographic keys. It provides authentication services, as well as key distribution functionality. The clients and services trust the integrity of the KDC, and this trust is the foundation of Kerberos security.” Pg. 148 Shon Harris CISSP All-In-One Certification Exam Guide

‘The basic principles of Kerberos operation are as follows:

- 1.)The KDC knows the secret keys of all clients and servers on the network.
- 2.)The KDC initially exchanges information with the client and server by using these secret keys.
- 3.)Kerberos authenticates a client to a requested service on a server through TGS, and by using temporary symmetric session keys for communications between the client and KDC, the server and the KDC, and the client and server.
- 4.)Communication then takes place between the client and the server using those temporary session keys.”

Pg. 40 Krutz: The CISSP Prep Guide

QUESTION NO: 733

Which Application Layer security protocol requires two pair of asymmetric keys and two digital certificates?

- A. PEM
- B. S/HTTP
- C. SET
- D. SSL

Answer: C

Explanation: SET – Secure Electronic Transaction
Page 753 of Shon Harris’ book (5th edition)

QUESTION NO: 734

Which of the following can be defined as an attribute in one relation that has values matching the primary key in another relation?

- A. foreign key
- B. candidate key
- C. Primary key
- D. Secondary key

Answer: A

Reference: pg 243 Hansche: Official (ISC)2 Guide to the CISSP Exam

QUESTION NO: 735

What key size is used by the Clipper Chip?

- A. 40 bits
- B. 56 bits
- C. 64 bits
- D. 80 bits

Answer: D

Explanation: "Each Clipper Chip has a unique serial number and an 80-bit unique unit or secret key. The unit key is divided into two parts and is stored at two separate organizations with the serial number that uniquely identifies that particular Clipper Chip." Pg 166 Krutz: The CISSP Prep Guide

QUESTION NO: 736

What uses a key of the same length as the message?

- A. Running key cipher
- B. One-time pad
- C. Steganography
- D. Cipher block chaining

Answer: B

Reference:

"A one-time pad is an extremely powerful type of substitution cipher. One-time pads use a different alphabet for each letter of the plaintext message.

Normally, one-time pads are written as a very long series of numbers to be plugged into the function.

The great advantage to one-time pads is that, when used properly, they are an unbreakable encryption scheme. There is no repeating pattern of alphabetic substitution, rendering cryptanalytic efforts useless. However, several requirements must be met to ensure the integrity of the algorithm:

The encryption key must be randomly generated. Using a phrase or a passage from a book would introduce the possibility of cryptanalysts breaking the code.

The one-time pad must be physically secured against disclosure. If the enemy has a copy of the pad, they can easily decrypt the enciphered messages.

Each one-time pad must be used only once. If pads are reused, cryptanalysts can compare similarities in multiple messages encrypted with the same pad and possibly determine the key values used.

The key must be at least as long as the message to be encrypted. This is because each key element is used to encode only one character of the message.

Pg. 304-305 Tittel: CISSP Study Guide

QUESTION NO: 737

Which of the following statements related to a private key cryptosystem is FALSE?

- A.** The encryption key should be secure
- B.** Data Encryption Standard (DES) is a typical private key cryptosystem
- C.** The key used for decryption is known to the sender
- D.** Two different keys are used for the encryption and decryption

Answer: D

Explanation: "In symmetric key cryptography, a single secret key is used between entities, whereas in public key systems, each entity has different keys, or asymmetric keys." Pg 476 Shon

QUESTION NO: 738

Simple Key Management for Internet Protocols (SKIP) is similar to Secure Sockets Layer (SSL), except that it requires no prior communication in order to establish or exchange keys on a:

- A. Secure Private keyring basis
- B. response-by-session basis
- C. Remote Server basis
- D. session-by-session basis

Answer: D

Reference: pg 117 Krutz: CISSP Prep Guide: Gold Edition

QUESTION NO: 739

A weak key of an encryption algorithm has which of the following properties?

- A. It is too short, and thus easily crackable
- B. It facilitates attacks against the algorithm
- C. It has much more zeroes than ones
- D. It can only be used as a public key

Answer: B

Explanation:

QUESTION NO: 740

Security measures that protect message traffic independently on each communication path are called:

- A. Link oriented
- B. Procedure oriented
- C. Pass-through oriented
- D. End-to-end oriented

Answer: A

Explanation: Link encryption encrypts all the data along a specific communication path like a satellite link, T3 line, or telephone circuit. Not only is the user information encrypted, but the header, trailers, addresses, and routing data that are part of the packets are also encrypted. This provides extra protection against packet sniffers and eavesdroppers. - Shon Harris All-in-one CISSP Certification Guide pg 560

QUESTION NO: 741

Who is responsible for the security and privacy of data during a transmission on a public communications link?

- A. The carrier
- B. The sending party
- C. The receiving party
- D. The local service provider

Answer: B

Explanation: The sender of an email is responsible for encryption if security is desired. A bank that sends data across web is responsible to utilize a secure protocol.

QUESTION NO: 742

Which of the following best provides e-mail message authenticity and confidentiality?

- A. Signing the message using the sender's public key and encrypting the message using the receiver's private key
- B. Signing the message using the sender's private key and encrypting the message using the receiver's public key

- C. Signing the message using the receiver's private key and encrypting the message using the sender's public key
- D. Signing the message using the receiver's public key and encrypting the message with the sender's private key

Answer: B

Explanation:

QUESTION NO: 743

Cryptography does not help in:

- A. Detecting fraudulent insertion
- B. Detecting fraudulent deletion
- C. Detecting fraudulent modifications
- D. Detecting fraudulent disclosure

Answer: D

Explanation:

QUESTION NO: 744

Which of the following is NOT a property of a one-way hash function?

- A. It converts a message of a fixed length into a message digest of arbitrary length
- B. It is computationally infeasible to construct two different messages with the same digest
- C. It converts a message of arbitrary length into a message digest of a fixed length
- D. Given a digest value, it is computationally infeasible to find the corresponding message

Answer: A

Explanation:

QUESTION NO: 745

How much more secure is 56 bit encryption opposed to 40 bit encryption?

- A. 16 times
- B. 256 times
- C. 32768 times
- D. 65,536 times

Answer: D

Explanation: 2 to the (56-40)th power – 2 to the 16th power = 65536

Note:

2 to the power of 40 = 1099511627776

2 to the power of 56 = 72057594037927936

$72057594037927936 / 1099511627776 = 65,536$

QUESTION NO: 746

Which of the following statements is true about data encryption as a method of protecting data?

- A. It should sometimes be used for password files
- B. It is usually easily administered
- C. It makes few demands on system resources
- D. It requires careful key Management

Answer: D

Explanation: "Cryptography can be used as a security mechanism to provide confidentiality, integrity, and authentication, but not if the keys are compromised in any way. The keys can be captured, modified, corrupted, or disclosed to unauthorized individuals. Cryptography is based on a trust mode. Individuals trust each other to protect their own keys, they trust the administrator who is maintaining the keys, and they trust a server that holds, maintains and distributes the keys.

Many administrators know that key management causes one of the biggest headaches in cryptographic implementation. There is more to key maintenance than using them to encrypt messages. The keys have to be distributed securely to the right entities and updated continuously. The keys need to be protected as they are being transmitted and while they are being stored on each workstation and server. The keys need to be generated, destroyed, and recovered properly, Key management can be handled through manual or automatic processes.

Unfortunately, many companies use cryptographic keys, but rarely if ever change them. This is because of the hassle of key management and because the network administrator is already overtaxed with other tasks or does not realize the task actually needs to take place. The frequency

of use of a cryptographic key can have a direct correlation to often the key should be changed. The more a key is used, the more likely it is to be captured and compromised. If a key is used infrequently, then this risk drops dramatically. The necessary level of security and the frequency of use can dictate the frequency of the key updates.

Key management is the most challenging part of cryptography and also the most crucial. It is one thing to develop a very complicated and complex algorithm and key method, but if the keys are not securely stored and transmitted, it does not really matter how strong the algorithm is. Keeping keys secret is a challenging task." Pg 512-513 Shon Harris CISSP Certification All-In-One Exam Guide

QUESTION NO: 747

The primary purpose for using one-way encryption of user passwords within a system is which of the following?

- A. It prevents an unauthorized person from trying multiple passwords in one logon attempt
- B. It prevents an unauthorized person from reading or modifying the password list
- C. It minimizes the amount of storage required for user passwords
- D. It minimizes the amount of processing time used for encrypting password

Answer: B

Explanation:

QUESTION NO: 748

Which of the following is not a known type of Message Authentication Code (MAC)?

- A. Hash function-based MAC
- B. Block cipher-based MAC
- C. Signature-based MAC
- D. Stream cipher-based MAC

Answer: C

Explanation:

QUESTION NO: 749

Which of the following was developed in order to protect against fraud in electronic fund transfers (EFT)?

- A. Secure Electronic Transaction (SET)
- B. Message Authentication Code (MAC)
- C. Cyclic Redundancy Check (CRC)
- D. Secure Hash Standard (SHS)

Answer: B

Reference: pg 218 Krutz: CISSP Prep Guide: Gold Edition

QUESTION NO: 750

Where parties do not have a shared secret and large quantities of sensitive information must be passed, the most efficient means of transferring information is to use a hybrid encryption technique. What does this mean?

- A. Use of public key encryption to secure a secret key, and message encryption using the secret key
- B. Use of the recipient's public key for encryption and decryption based on the recipient's private key
- C. Use of software encryption assisted by a hardware encryption accelerator
- D. Use of elliptic curve encryption

Answer: A

Explanation:

QUESTION NO: 751

One-way hash provides:

- A. Confidentiality
- B. Availability
- C. Integrity

D. Authentication

Answer: C

Explanation: "Hash Functions

....how cryptosystems implement digital signatures to provide proof that a message originated from a particular user of a cryptosystem and to ensure that the message was not modified while in transit between the two parties."

Pg. 292 Tittel: CISSP Study Guide Second Edition

"integrity A state characterized by the assurance that modifications are not made by unauthorized users and authorized users do not make unauthorized modifications."

Pg. 616 Tittel: CISSP Study Guide Second Edition

QUESTION NO: 752

What size is an MD5 message digest (hash)?

- A.** 128 bits
- B.** 160 bits
- C.** 256 bits
- D.** 128 bytes

Answer: A

Explanation: "MD4

MD4 is a one-way hash function designed by Ron Rivest. It produces 128-bit hash, or message digest, values. It is used for high-speed computation in software implementations and is optimized for microprocessors.

MD5

MD5 is the newer version of MD4. It still produces a 128-bit hash, but the algorithm is more complex, which makes it harder to break. MD5 added a fourth round of operations to be performed during the hashing functions and makes several of its mathematical operations carry out more steps or more complexity to provide a higher level of security.

MD2

MD2 is also a 128-bit one-way hash designed by Ron Rivest. It is not necessarily any weaker than the previously mentioned hash functions, but is much slower.

SHA

SHA was designed by NIST and NSA to be used with DSS. The SHA was designed to be used with digital signatures and was developed when a more secure hashing algorithm was required for federal application.

SHA produces a 160-bit hash value, or message digest. This is then inputted into the DSA, which computes the signature for a message. The message digest is signed instead of the whole message because it is a much quicker process. The sender computes a 160-bit hash value, encrypts it with his private key (signs it), appends it to the message, and sends it. The receiver decrypts the value with the sender's public key, runs the same hashing function, and compares the two values. If the values are the same, the receiver can be sure that the message has not been tampered with in transit.

SHA is similar to MD4. It has some extra mathematical functions and produces a 160-bit hash instead of 128-bit, which makes it more resistant to brute force attacks, including birthday attacks.

HAVAL

HAVAL is a variable-length one-way hash function and is the modification of MD5. It processes message blocks twice the size of those used in MD5; thus it processes blocks of 1,024 bits.

Pg. 508-509 Shon Harris CISSP Certification All-In-One Exam Guide

QUESTION NO: 753

Which of the following is NOT a property of a one-way hash function?

- A. It converts a message of a fixed length into a message digest of arbitrary length.
- B. It is computationally infeasible to construct two different messages with the same digest
- C. It converts a message of arbitrary length into a message digest of a fixed length
- D. Given a digest value, it is computationally infeasible to find the corresponding message

Answer: A

Explanation:

QUESTION NO: 754

Which of the following would best describe a Concealment cipher?

- A. Permutation is used, meaning that letters are scrambled
- B. Every X number of words within a text, is a part of the real message
- C. Replaces bits, characters, or blocks of characters with different bits, characters, or blocks.
- D. Hiding data in another message so that the very existence of the data is concealed.

Answer: B

Reference: pg 468 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 755

Which of the following ciphers is a subset of the Vignere polyalphabetic cipher?

- A. Caesar
- B. Jefferson
- C. Alberti
- D. SIGABA

Answer: A

Explanation: "The Caesar Cipher,...., is a simple substitution cipher that involves shifting the alphabet three positions to the right. The Caesar Cipher is a subset of the Vigenere polyalphabetic cipher. In the Caesar cipher, the message's characters and repetitions of the key are added together, modulo 26. In modulo 26, the letters A to Z of the alphabet are given a value of 0 to 25, respectively."

Pg. 189 Krutz: The CISSP Prep Guide: Gold Edition

QUESTION NO: 756

Which of the following is not a property of the Rijndael block cipher algorithm?

- A. Resistance against all known attacks
- B. Design simplicity
- C. 512 bits maximum key size
- D. Code compactness on a wide variety of platforms

Answer: C

Explanation:

QUESTION NO: 757

What are two types of ciphers?

- A. Transposition and Permutation
- B. Transposition and Shift
- C. Transposition and Substitution
- D. Substitution and Replacement

Answer: C

Explanation: "Classical Ciphers:
Substitution
Transposition (Permutation)
Vernam (One-Time Pad)
Book or Running Key
Codes
Steganography"

Pg 189-193 Krutz: CISSP Prep Guide: Gold Edition.

QUESTION NO: 758

Which one of the following, if embedded within the ciphertext, will decrease the likelihood of a message being replayed?

- A. Stop bit
- B. Checksum
- C. Timestamp
- D. Digital signature

Answer: C

Explanation: CBC is the CBC mode of some block cipher, HMAC is a keyed message digest, MD is a plain message digest, and timestamp is to protect against replay attacks. From the OpenSSL project <http://www.mail-archive.com/openssl-users@openssl.org/msg23576.html>

QUESTION NO: 759

Which of the following statements pertaining to block ciphers is incorrect?

- A.** it operates on fixed-size blocks of plaintext
- B.** it is more suitable for software than hardware implementation
- C.** Plain text is encrypted with a public key and decrypted with a private key
- D.** Block ciphers can be operated as a stream

Answer: C

Explanation: "Strong and efficient block cryptosystems use random key values so an attacker cannot find a pattern as to which S-boxes are chosen and used." Pg. 481 Shon Harris CISSP Certification All-in-One Exam Guide

Not A:

"When a block cipher algorithm is used for encryption and decryption purposes, the message is divided into blocks of bits. These blocks are then put through substitution, transposition, and other mathematical functions, on block at a time." Pg. 480 Shon Harris CISSP Certification All-in-One Exam Guide

Not B:

"Block ciphers are easier to implement in software because they work with blocks of data that the software is used to work with." Pg 483 Shon Harris CISSP Certification All-in-One Exam Guide

Not D:

"This encryption continues until the plaintext is exhausted." Pg. 196 Krutz The CISSP Prep Guide.

Not A or D:

"When a block a block cipher algorithm is used for encryption and decryption purposes, the message is divided into blocks of bits. These blocks are then put through substitution, transposition, and other mathematical functions, one block at a time." Pg 480 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 760

The repeated use of the algorithm to encipher a message consisting of many blocks is called

- A. Cipher feedback
- B. Elliptical curve
- C. Cipher block chaining
- D. Triple DES

Answer: C

Explanation: "There are two main types of symmetric algorithms: stream and block ciphers. Like their names sound, block ciphers work on blocks of plaintext and ciphertext, whereas stream ciphers work on streams of plaintext and ciphertext, on bit or byte at a time. Pg 521. Shon Harris CISSP All-In-One Certification Exam Guide

Cipher Block Chaining (CBC) operates with plaintext blocks of 64 bits.Note that in this mode, errors propagate." Pg 149 Krutz: The CISSP Prep Guide

QUESTION NO: 761

When block chaining cryptography is used, what type of code is calculated and appended to the data to ensure authenticity?

- A. Message authentication code.
- B. Ciphertext authentication code
- C. Cyclic redundancy check
- D. Electronic digital signature

Answer: A

Explanation: The original Answer was B. This is incorrect as ciphertext is the result not an authentication code.

"If meaningful plaintext is not automatically recognizable, a message authentication code (MAC)

can be computed and appended to the message. The computation is a function of the entire message and a secret key; it is practically impossible to find another message with the same authenticator. The receiver checks the authenticity of the message by computing the MAC using the same secret key and then verifying that the computed value is the same as the one transmitted with the message. A MAC can be used to provide authenticity for unencrypted messages as well as for encrypted ones. The National Institute of Standards and Technology (NIST) has adopted a standard for computing a MAC. (It is found in Computer Data Authentication, Federal Information Processing Standards Publication (FIPS PUB) 113.)" <http://www.cccure.org/Documents/HISM/637-639.html> from the Handbook of Information Security Management by Micki Krause

QUESTION NO: 762

Which of the following statements pertaining to block ciphers is incorrect?

- A. It operates on fixed-size blocks of plaintext
- B. It is more suitable for software than hardware implementations
- C. Plain text is encrypted with a public key and decrypted with a private key
- D. Block ciphers can be operated as a stream

Answer: C

Explanation: "Strong and efficient block cryptosystems use random key values so an attacker cannot find a pattern as to which S-boxes are chosen and used." Pg. 481 Shon Harris CISSP Certification All-in-One Exam Guide

Not A:

"When a block cipher algorithm is used for encryption and decryption purposes, the message is divided into blocks of bits. These blocks are then put through substitution, transposition, and other mathematical functions, on block at a time." Pg. 480 Shon Harris CISSP Certification All-in-One Exam Guide

Not B:

"Block ciphers are easier to implement in software because they work with blocks of data that the software is used to work with." Pg 483 Shon Harris CISSP Certification All-in-One Exam Guide

Not D:

"This encryption continues until the plaintext is exhausted." Pg. 196 Krutz The CISSP Prep Guide.

QUESTION NO: 763

Which of the following is a symmetric encryption algorithm?

- A. RSA
- B. Elliptic Curve
- C. RC5
- D. El Gamal

Answer: C

Explanation:

QUESTION NO: 764

How many bits is the effective length of the key of the Data Encryption Standard Algorithm?

- A. 16
- B. 32
- C. 56
- D. 64

Answer: C

Explanation:

QUESTION NO: 765

Compared to RSA, which of the following is true of elliptic curve cryptography?

- A. It has been mathematically proved to be the more secure
- B. It has been mathematically proved to be less secure

- C. It is believed to require longer keys for equivalent security
- D. It is believed to require shorter keys for equivalent security

Answer: D

Explanation: CISSP All-In-One - page 491: "In most cases, the longer the key length, the more protection provided, but ECC can provide the same level of protection with a key size that is smaller than what RSA requires."

CISSP Prep Guide (not Gold edition) - page 158: "... smaller key sizes in the elliptic curve implementation can yield higher levels of security. For example, an elliptic curve key of 160 bits is equivalent to 1024-bit RSA key."

QUESTION NO: 766

Which of the following is not a one-way algorithm?

- A. MD2
- B. RC2
- C. SHA-1
- D. DSA

Answer: B

Explanation: Not: A, C or D.

"Hash Functions

SHA
MD2
MD4
MD5"

Pg. 337- 340 Tittel: CISSP Study Guide

DSA, Digital Signature Algorithm, is a approved standard for Digital Signatures that utilizes SHA-1 hashing function.

Pg. 342-343 Tittel: CISSP Study Guide

QUESTION NO: 767

A public key algorithm that does both encryption and digital signature is which of the following?

- A. RSA
- B. DES
- C. IDEA
- D. DSS

Answer: A

Explanation: "RSA, named after its inventors Ron Rivest, Adi Shamir, and Leonard Adleman, is a public key algorithm that is the most popular when it comes to asymmetric algorithms. RSA is a worldwide de facto standard and can be used for digital signatures, key exchange, and encryption."

Pg. 489 Shon Harris: All-In-One CISSP Certification Exam Guide

QUESTION NO: 768

Which of the following encryption algorithms does not deal with discrete logarithms?

- A. El Gamal
- B. Diffie-Hellman
- C. RSA
- D. Elliptic Curve

Answer: C

Explanation:

QUESTION NO: 769

The RSA algorithm is an example of what type of cryptography?

- A. Asymmetric key

- B. Symmetric key
- C. Secret Key
- D. Private Key

Answer: A

Explanation:

QUESTION NO: 770

How many rounds are used by DES?

- A. 16
- B. 32
- C. 64
- D. 48

Answer: A

Explanation: "When the DES algorithm is applied to data, it divides the message into blocks and operates on them one at a time. A block is made of 64 bits and is divided in half and each character is encrypted one at a time. The characters are put through 16 rounds of transposition and substitution functions. The order and type of transposition and substitution function depend on the value of the key that is inputted into the algorithm. The result is the 64-bit block of ciphertext."

Pg. 526 Shon Harris: CISSSP All-In-One Certification Guide

QUESTION NO: 771

Which of the following is the most secure form of triple-DES encryption?

- A. DES-EDE3
- B. DES-EDE1
- C. DES-EEE4
- D. DES-EDE2

Answer: A

Explanation:

The reason is that it uses three keys.

Four keys cannot be used.

The other alternatives do not use as many keys so less secure.

We do not believe there is such a thing as DES-EDE1, but it would still be less secure if it would exist.

QUESTION NO: 772

Which of the following algorithms does *NOT* provide hashing?

- A. SHA-1
- B. MD2
- C. RC4
- D. MD5

Answer: C

Explanation: Hashed Algorithms

SHA-1

HMAC-SHA-1

MD5

HMAC-MD5

Pg 426 Hansche: Official (ISC)2 Guide to the CISSP Exam

Note: MD2 is also a one-way hash, like MD5, but slower

QUESTION NO: 773

Which of the following is unlike the other three?

- A. El Gamal
- B. Teardrop
- C. Buffer Overflow
- D. Smurf

Answer: A

Explanation:

QUESTION NO: 774

Which of the following is not an encryption algorithm?

- A. Skipjack
- B. SHA-1
- C. Twofish
- D. DEA

Answer: B

Explanation: SHA-1 is a hash algorithm opposed to encryption algorithm.

Reference: pg 293 Tittel: CISSP Study Guide

QUESTION NO: 775

Which one of the following is an asymmetric algorithm?

- A. Data Encryption Algorithm.
- B. Data Encryption Standard
- C. Enigma
- D. Knapsack

Answer: D

Explanation: Merkle-Hellman Knapsack is a Public Key Algorithm Pg 206 Krutz: CISSP Prep Guide: Gold Edition.

Not A:

"DES describes the Data Encryption Algorithm (DEA) and is the name of the Federal Information Processing Standard (FIPS) 46-1 that was adopted in 1977..." pg 195 Krutz: CISSP Prep Guide: Gold Edition.

Not B:

"The best-known symmetric key system is probably the Data Encryption Standard (DES)." pg 195 Krutz: CISSP Prep Guide: Gold Edition.

Not C:

"The German military used a polyalphabetic substitution cipher machine called the Enigma as its principal encipherment system during World War II." Pg 185 Krutz: CISSP Prep Guide: Gold Edition.

QUESTION NO: 776

Which of the following is *NOT* a symmetric key algorithm?

- A. Blowfish
- B. Digital Signature Standard (DSS)
- C. Triple DES (3DES)
- D. RC5

Answer: B

Reference: pg 489 Shon Harris

QUESTION NO: 777

Which of the following layers is not used by the Rijndael algorithm?

- A. Non-linear layer
- B. Transposition layer
- C. Key addition layer
- D. The linear mixing layer

Answer: B

Reference: pg 201 Krutz: CISSP Prep Guide: Gold Edition

QUESTION NO: 778

What is the basis for the Rivest-Shamir-Adelman (RSA) algorithm scheme?

- A. Permutations
- B. Work factor
- C. Factorability
- D. Reversibility

Answer: C

Explanation: This algorithm is based on the difficulty of factoring a number, N, which is the product of two large prime numbers. -Ronald Krutz The CISSP PREP Guide (gold edition) pg 204

QUESTION NO: 779

Which of the following encryption algorithms does not deal with discrete logarithms?

- A. El Gamal
- B. Diffie-Hellman
- C. RSA
- D. Elliptic Curve

Answer: C

Reference: pg 416 Hansche: Official (ISC)2 Guide to the CISSP Exam

QUESTION NO: 780

The RSA Algorithm uses which mathematical concept as the basis of its encryption?

- A. Geometry
- B. Irrational numbers
- C. PI (3.14159...)
- D. Large prime numbers

Answer: D

Explanation:

QUESTION NO: 781

PGP provides which of the following?(Choose three)

- A. Confidentiality
- B. Accountability
- C. Accessibility
- D. Integrity
- E. Interest
- F. Non-repudiation
- G. Authenticity

Answer: A,D,G

Explanation: PGP provides confidentiality, integrity, and authenticity.

QUESTION NO: 782

PGP uses which of the following to encrypt data?

- A. An asymmetric scheme
- B. A symmetric scheme
- C. a symmetric key distribution system
- D. An asymmetric key distribution

Answer: B

Explanation:

QUESTION NO: 783

Which of the following mail standards relies on a "Web of Trust"?

- A. Secure Multipurpose Internet Mail extensions (S/MIME)
- B. Pretty Good Privacy (PGP)
- C. MIME Object Security Services (MOSS)
- D. Privacy Enhanced Mail (PEM)

Answer: B

Explanation: "PGP does not use a hierarchy of CAs, or any type of formal trust certificates, but relies on a "web of trust" in its key management approach. Each user generates and distributes his or her public key, and users sign each other's public keys, which creates a community of users who trust each other. This is different than the CA approach where no one trusts each other, they

only trust the CA.

QUESTION NO: 784

Which of the following offers confidentiality to an e-mail message?

- A. The sender encrypting it with it's private key
- B. The sender encrypting it with it's public key
- C. The sender encrypting it with it's receiver's public key
- D. The sender encrypting it with the receiver's private key

Answer: C

Explanation:

QUESTION NO: 785

Which of the following items should not be retained in an E-mail directory?

- A. drafts of documents
- B. copies of documents
- C. permanent records
- D. temporary documents

Answer: C

Explanation: This is another matter of common sense; the CISSP exam has many situations like this. It is not a good practice to have Permanent documents in your e-mail, this is because you don't know if your e-mail is always backed up, and maybe the document must be available in a corporate repository. There is no problem to have Copies, draft or temporary documents in your e-mail. The important ones for the company are the Permanent documents.

QUESTION NO: 786

In a Secure Electronic Transaction (SET), how many certificates are required for a payment gateway to support multiple acquires?

- A. Two certificates for the gateway only.
- B. Two certificates for the gateway and two for the acquirers.
- C. Two certificates for each acquirer.
- D. Two certificates for the gateway and two for each acquirer.

Answer: B

Explanation: I think it may be D two for each acquirer. Which unless I read it wrong it means each person must have 2 certificates exchanged with the gateway.

"SET uses a des symmetric key system for encryption of the payment information and uses rsa for the symmetric key exchange and digital signatures. SET covers the end-to-end transaction from the cardholder to the financial institution". -Ronald Krutz The CISSP PREP Guide (gold edition) pg 219-220

In the SET environment, there exists a hierarchy of Certificate Authorities. The SET protocol specifies a method of entity authentication referred to as trust chaining. This method entails the exchange of digital certificates and verification of the public keys by validating the digital signatures of the issuing CA. This trust chain method continues all the way up to the CA at the top of the hierarchy, which is referred to as the SET Root CA. The SET Root CA is owned and maintained by SET Secure Electronic Transaction LLC. <http://setco.org/certificates.html>

QUESTION NO: 787

Which protocol makes use of an electronic wallet on a customer's PC and sends encrypted credit card information to merchant's Web server, which digitally signs it and sends it on to its processing bank?

- A. SSH
- B. S/MIME
- C. SET
- D. SSL

Answer: C

Explanation:

QUESTION NO: 788

Which of the following best describes the Secure Electronic Transaction (SET) protocol?

- A. Originated by VISA and MasterCard as an Internet credit card protocol
- B. Originated by VISA and MasterCard as an Internet credit card protocol using digital signatures
- C. Originated by VISA and MasterCard as an Internet credit card protocol using the transport layer
- D. Originated by VISA and MasterCard as an Internet credit card protocol using SSL

Answer: B

Explanation:

QUESTION NO: 789

Which of the following would best define the "Wap Gap" security issue?

- A. The processing capability gap between wireless devices and PC's
- B. The fact that WTLS transmissions have to be decrypted at the carrier's WAP gateway to be re-encrypted with SSL for use over wired networks.
- C. The fact that Wireless communications are far easier to intercept than wired communications
- D. The inability of wireless devices to implement strong encryption

Answer: B

Explanation:

QUESTION NO: 790

What encryption algorithm is best suited for communication with handheld wireless devices?

- A. ECC
- B. RSA
- C. SHA
- D. RC4

Answer: A

Explanation: "Eliptic curves are rich mathematical structures that have shown usefulness in many different types of applications. An Elliptic Curve Cryptosystem (ECC) provides much of the same functionality that RSA provides: digital signatures, secure key distribution, and encryption. One differing factor is ECC's efficiency. Some devices have limited processing capacity, storage, power supply, and bandwidth like wireless devices and cellular telephones. With these types of devices, efficiency of resource use is very important. ECC provides encryption functionality requiring a smaller percentage of resources required by RSA and other algorithms, so it is used in these types of devices. In most cases, the longer the key length, the protection provided, but ECC can provide

the same level of protection with a key size that is smaller than what RSA requires. Because longer keys require more resources to perform mathematical tasks, the smaller keys used in ECC require fewer resources of the device." Pg. 491 Shon Harris: All-In-One CISSP Certification Guide.

QUESTION NO: 791

Which security measure BEST provides non-repudiation in electronic mail?

- A. Digital signature
- B. Double length Key Encrypting Key (KEK)
- C. Message authentication
- D. Triple Data Encryption Standard (DES)

Answer: A

Explanation: A tool used to provide the authentication of the sender of a message. It can verify the origin of the message along with the identity of the sender. IT is unique for every transaction and created with a private key. - Shon Harris All-in-one CISSP Certification Guide pg 930

"Secure Multipurpose Internet Mail Extensions (S/MIME) offers authentication and privacy to e-mail through secured attachments. Authentication is provided through X.509 digital certificates. Privacy is provided through the use of Public Key Cryptography Standard (PKCS) Encryption. Two types of messages can be formed using S/MIME: signed messages and enveloped messages. A signed message provides integrity and sender authentication. An enveloped message provides integrity, sender authentication, and confidentiality." Pg 123 Tittle: CISSP Study Guide

QUESTION NO: 792

Which of the following services is not provided by the digital signature standard (DSS)?

- A. Encryption
- B. Integrity
- C. Digital signature
- D. Authentication

Answer: A

Explanation:

QUESTION NO: 793

Public key cryptography provides integrity verification through the use of public key signature and?

- A. Secure hashes
- B. Zero knowledge
- C. Private key signature
- D. Session key

Answer: A

Explanation:

QUESTION NO: 794

Electronic signatures can prevent messages from being:

- A. Erased
- B. Disclosed
- C. Repudiated
- D. Forwarded

Answer: C

Explanation:

QUESTION NO: 795

Why do vendors publish MD5 hash values when they provide software patches for their customers to download from the Internet?

- A. Recipients can verify the software's integrity after downloading.
- B. Recipients can confirm the authenticity of the site from which they are downloading the patch.
- C. Recipients can request future updates to the software by using the assigned hash value.
- D. Recipients need the hash value to successfully activate the new software.

Answer: A

Explanation: If the two values are different, Maureen knows that the message was altered, either intentionally or unintentionally, and she discards the message...As stated in an earlier section, the goal of using a one-way hash function is to provide a fingerprint of the message. MD5 is the newer version of MD4. IT still produces a 128-bit hash, but the algorithm is a bit more complex to make it harder to break than MD4. The MD5 added a fourth round of operations to be performed during the hash functions and makes several of its mathematical operations carry steps or more complexity to provide a higher level of security . - Shon Harris All-in-one CISSP Certification Guide pg 182-185

QUESTION NO: 796

What attribute is included in a X.509-certificate?

- A. Distinguished name of subject
- B. Telephone number of the department
- C. secret key of the issuing CA
- D. the key pair of the certificate holder

Answer: A

Explanation: The key word is 'In create the certificate..' Certificates that conform to X.509 contain the following data: Version of X.509 to which the certificate conforms; Serial number (from the certificate creator); Signature algorithm identifier (specifies the technique used by the certificate authority to digitally sign the contents of the certificate); Issuer name (identification of the certificate authority that issues the certificate) Validity period (specifies the dates and times - a starting date and time and an ending date and time - during which the certificate is valid); Subject's name (contains the distinguished name, or DN, of the entity that owns the public key contained in the certificate); Subject's public key (the meat of the certificate - the actual public key of the certificate owner used to setup secure communications) pg 343-344 CISSP Study Guide by Tittel

QUESTION NO: 797

What is used to bind a document to its creation at a particular time?

- A. Network Time Protocol (NTP)
- B. Digital Signature
- C. Digital Timestamp
- D. Certification Authority (CA)

Answer: C

Explanation:

QUESTION NO: 798

What attribute is included in a X-509-certificate?

- A. Distinguished name of the subject
- B. Telephone number of the department
- C. Secret key of the issuing CA
- D. The key pair of the certificate holder

Answer: A

Explanation: "Certificates that conform to X.509 contain the following data:

Version of X.509 to which the certificate conforms

Serial number

Signature algorithm identifier

Issuer name

Validity period

Subject's name (contains the distinguished name, or DN of the entity that owns the public key contained in the certificate)

Subject's Public Key"

Pg. 297 Tittel: CISSP Study Guide

QUESTION NO: 799

Which of the following standards concerns digital certificates?

- A. X.400
- B. X.25
- C. X.509
- D. X.75

Answer: C

Explanation:

QUESTION NO: 800

What level of assurance for a digital certificate only requires an e-mail address?

- A. Level 0
- B. Level 1
- C. Level 2
- D. Level 3

Answer: B

Reference: http://csrc.nist.gov/publications/nistpubs/800-63/SP800-63V1_0_2.pdf

QUESTION NO: 801

The "revocation request grace period" is defined as:

- A. The period for to the user within he must make a revocation request upon a revocation reason
- B. Minimum response time for performing a revocation by the CA
- C. Maximum response time for performing a revocation by the CA
- D. Time period between the arrival of a revocation reason and the publication of the revocation information

Answer: C

Explanation:

QUESTION NO: 802

What enables users to validate each other's certificate when they are certified under different certification hierarchies?

- A. Cross-certification
- B. Multiple certificates
- C. Redundant certificate authorities
- D. Root certification authorities

Answer: A

Explanation:

QUESTION NO: 803

Digital signature users register their public keys with a certification authority, which distributes a certificate containing the user's public key and digital signature of the certification authority. In creating the certificate, the user's public key and the validity period are combined with what other information before computing the digital signature?

- A. Certificate issuer and the Digital Signature Algorithm identifier
- B. User's private key and the identifier of the master key code
- C. Name of secure channel and the identifier of the protocol type
- D. Key authorization and identifier of key distribution center

Answer: A

Explanation: The key word is 'In create the certificate..' Certificates Certificates that conform to X.509 contain the following data: Version of X.509 to which the certificate conforms; Serial number (from the certificate creator); Signature algorithm identifier (specifies the technique used by the certificate authority to digitally sign the contents of the certificate); Issuer name (identification of the certificate authority that issues the certificate) Validity period (specifies the dates and times - a starting date and time and an ending date and time - during which the certificate is validated); Subject's name (contains the distinguished name, or DN, of the entity that owns the public key contained in the certificate); Subject's public key (the meat of the certificate - the actual public key of the certificate owner used to setup secure communications) pg 343-344 CISSP Study Guide by Tittel

QUESTION NO: 804

What level of assurance for digital certificate verifies a user's name, address, social security number, and other information against a credit bureau database?

- A. Level 1
- B. Level 2
- C. Level 3
- D. Level 4

Answer: B

Explanation:

QUESTION NO: 805

Which one of the following security technologies provides safeguards for authentication before securely sending information to a web server?

- A. Secure/Multipurpose Internet Mail Extension (S/MIME)
- B. Common Gateway Interface (CGI) scripts
- C. Applets
- D. Certificates

Answer: D

Explanation: Digital certificates provide communicating parties with the assurance that they are communicating with people who truly are who they claim to be." Titel: CISSP Study Guide. pg 343. In this case, if the web server was a bank, you want to have a certificate confirming that they really are the bank before you authenticate with your username and password.

QUESTION NO: 806

The primary role of cross certification is:

- A. Creating trust between different PKIs
- B. Build an overall PKI hierarchy
- C. set up direct trust to a second root CA
- D. Prevent the nullification of user certifications by CA certificate revocation

Answer: A

Explanation:

QUESTION NO: 807

Windows 98 includes the ability to check the digitally signed hardware drivers. Which of the following are true?

- A.** Drivers are the only files supplied with W98 that can be checked for digital signatures and all drivers included with W98 have been digitally signed
- B.** If a file on a Windows W98 has been digitally signed it means that the file has passed quality testing by Microsoft.
- C.** The level to which signature checking is implemented could only be changed by editing the registry
- D.** All of the statements are true

Answer: B

Explanation: Windows device drivers and operating system files have been digitally signed by Microsoft to ensure their quality. A Microsoft digital signature is your assurance that a particular file has met a certain level of testing, and that the file has not been altered or overwritten by another program's installation process.

Depending on how your administrator has configured your computer, Windows either ignores device drivers that are not digitally signed, displays a warning when it detects device drivers that are not digitally signed (the default behavior), or prevents you from installing device drivers without digital signatures.

Windows includes the following features to ensure that your device drivers and system files remain in their original, digitally-signed state:

- Windows File Protection
- System File Checker
- File Signature Verification

Windows XP help.

Not A: operating system files are included.

Not C: the setting can be changed in the GUI.

QUESTION NO: 808

What is the purpose of certification path validation?

- A. Checks the legitimacy of the certificates in the certification path.
- B. Checks that all certificates in the certification path refer to same certification practice statement.
- C. Checks that no revoked certificates exist outside the certification path.
- D. Checks that the names in the certification path are the same.

Answer: A

Explanation: Not C. Revoked certificates are not checked outside the certification path.

“A Transaction with Digital Certificates

- 1.)Subscribing entity sends Digital Certificate Application to Certificate Authority.
- 2.)Certificate Authority issues Signed Digital Certificate to Subscribing Entity.
- 3.)Certificate Authority sends Certificate Transaction to Repository.
- 4.)Subscribing Entity Signs and sends to Party Transacting with Subscriber.
- 5.)Party Transacting with Subscriber queries Repository to verify Subscribers Public Key.
- 6.)Repository responds to Party Transacting with Subscriber the verification request.”

Pg. 214 Krutz: The CISSP Prep Guide: Gold Edition.

“John needs to obtain a digital certificate for himself so that he can participate in a PKI, so he makes a request to the RA. The RA requests certain identification from John, like a copy of his driver’s licens, his phone number, address, and other identification information. Once the RA receives the required informoration from John and verifies it, the RA sends his certificate request to the CA. The CA creates a certificate with John’s public key and identify information embedded. (The private/public key pair is either generated by the CA or on John’s machine, which depends on the systems’ configurations. If it is created at the CA, his private key needs to be sent to him by secure means. In most cases the user generates this pair and sends in his public key during the registration process.) Now John is registered and can participate in PKI. John decides he wants to communicate with Diane, so he requests Diane’s public key from a public directory. The directory, sometimes called a repository, sends Diane’s public key, and John uses this to encrypt a session key that will be used to encrypt their messages. John sends the encrypted session key to Diane. Jon then sends his certificate, containing his public key, to Diane. When Diane receives John’s certificate, her browser looks to see if it trusts the CA that digitally signed this certificate. Diane’s browser trusts this CA, and she makes a reques to the CA to see if this certificate is still valid. The CA responds that the certificate is valid, so Diane decrypts the session key with her private key. Now they can both communicate using encryption.” Pg 499 Shon Harris: All-In-One CISSP Certification Guide.

QUESTION NO: 809

In what type of attack does an attacker try, from several encrypted messages, to figure out the key using the encryption process?

- A. Known-plaintext attack
- B. Ciphertext-only attack
- C. Chosen-Ciphertext attack
- D. Known Ciphertext attack

Answer: B

Explanation: "Ciphertext-Only Attack

In this type of attack, the attacker has the ciphertext of several messages. Each of the messages has been encrypted using the same encryption algorithm. The attacker's goal is to discover the key that was used in the encryption process. Once the attacker figures out the key, she can decrypt all other messages encrypted with the same key.

A ciphertext-only attack is the most common because it is very easy to get ciphertext by sniffing someone's traffic, but it is the hardest attack to actually be successful at because the attacker has so little information about the encryption process." Pg 531 Shon Harris CISSP All-In-One Exam Guide

QUESTION NO: 810

When combined with unique session values, message authentication can protect against which of the following?

- A. Reverse engineering, frequency analysis, factoring attacks, and ciphertext-only attack.
- B. Masquerading, frequency analysis, sequence manipulation, and ciphertext-only attack.
- C. Reverse engineering, content modification, factoring attacks, and submission notification.
- D. Masquerading, content modification, sequence manipulation, and submission notification.

Answer: C

Explanation: Unique session values: "IPSec:Each device will have one security association (SA) for each session that it uses. The SA is critical to the IPSec architecture and is a record of the configuration the device needs to support an IPSec connection. Pg 575 Shon Harris All-In-One CISSP Certification Exam Guide.

Message authentication and content modification: "Hashed Message Authentication Code

(HMAC): An HMAC is a hashed algorithm that uses a key to generate a Message Authentication Code (MAC). A MAC is a type of check sum that is a function of the information in the message. The MAC is generated before the message is sent, appended to the message, and then both are transmitted. At the receiving end, a MAC is generated from the message alone using the same algorithm as used by the sender and this MAC is compared to the MAC sent with the message. If they are not identical, the message was modified en route. Hashing algorithms can be used to generate the MAC and hash algorithms using keys provide stronger protection than ordinary MAC generation.

Frequency analysis: Message authentication and session values do not protect against Frequency Analysis so A and B are eliminated.

"Simple substitution and transposition ciphers are vulnerable to attacks that perform frequency analysis. In every language, there are words and patterns that are used more often than others. For instance, in the English language, the words "the," "and," "that," and "is" are very frequent patterns of letters used in messages and conversation. The beginning of messages usually starts "Hello" or "Dear" and ends with "Sincerely" or "Goodbye." These patterns help attackers figure out the transformation between plaintext to ciphertext, which enables them to figure out the key that was used to perform the transformation. It is important for cryptosystems to not reveal these patterns." Pg. 507 Shon Harris All-In-One CISSP Certification Exam Guide

Ciphertext-Only Attack: Message authentication and session values do not protect against Ciphertext so A and B are again eliminated.

"Ciphertext-Only Attack: In this type of an attack, an attacker has the ciphertext of several messages. Each of the messages has been encrypted using the same encryption algorithm. The attacker's goal is to discover the plaintext of the messages by figuring out the key used in the encryption process. Once the attacker figures out the key, she can now decrypt all other messages encrypted with the same key." Pg 577 Shon Harris All-In-One CISSP Certification Exam Guide.

Birthday attack: "...refer to an attack against the hash function known as the birthday attack." Pg 162 Krutz: The CISSP Prep Guide. MAC utilizes a hashing function and is therefore susceptible to birthday attack.

Masquerading Attacks: Session values (IPSec) does protect against session hijacking but not spoofing so C is eliminated.

"Masquerading Attacks:we'll look at two common masquerading attacks - IP Spoofing and session hijacking." Pg 275 Tittel: CISSP Study Guide.

Session hijacking: "If session hijacking is a concern on a network, the administrator can implement a protocol that requires mutual authentication between users like IPSec. Because the attacker will not have the necessary credentials to authenticate to a user, she cannot act as an imposter and hijack sessions." Pg 834 Shon Harris All-In-One CISSP Certification Exam Guide

Reverse engineering: Message authentication protects against reverse engineering.

Reverse engineering: "The hash function is considered one-way because the original file cannot be created from the message digest." Pg. 160 Krutz: The CISSP Prep Guide

Content modification: Message authentication protects against content modification.

Factoring attacks: Message authentication protects against factoring attacks.

QUESTION NO: 811

The relative security of a commercial cryptographic system can be measured by the?

- A. Rating value assigned by the government agencies that use the system.
- B. Minimum number of cryptographic iterations required by the system.
- C. Size of the key space and the available computational power.
- D. Key change methodology used by the cryptographic system.

Answer: C

Explanation: The strength of the encryption method comes from the algorithm, secrecy of the key, length of the key, initialization vectors, and how they all work together. - Shon Harris All-in-one CISSP Certification Guide pg 504

QUESTION NO: 812

Which one of the following describes Kerchoff's Assumption for cryptoanalytic attack?

- A. Key is secret; algorithm is known
- B. Key is known; algorithm is known
- C. Key is secret; algorithm is secret
- D. Key is known; algorithm is secret

Answer: A

Explanation: Kerhckoff's laws were intended to formalize the real situation of ciphers in the field. Basically, the more we use any particular cipher system, the more likely it is that it will "escape" into enemy hands. So we start out assuming that our opponents know "all the details" of the cipher system, except the key. <http://www.ciphersbyritter.com/NEWS4/LIMCRYPT.HTM>

QUESTION NO: 813

Which of the following actions can make a cryptographic key more resistant to an exhaustive attack?

- A. None of the choices.
- B. Increase the length of a key.
- C. Increase the age of a key.
- D. Increase the history of a key.

Answer: B

Explanation:

Defenses against exhaustive attacks involve increasing the cost of the attack by increasing the number of possibilities to be exhausted. For example, increasing the length of a password will increase the cost of an exhaustive attack. Increasing the effective length of a cryptographic key variable will make it more resistant to an exhaustive attack.

QUESTION NO: 814

Which type of attack is based on the probability of two different messages using the same hash function producing a common message digest?

- A. Differential cryptanalysis
- B. Differential linear cryptanalysis
- C. Birthday attack
- D. Statistical attack

Answer: C

Explanation: Attacks Against One-Way Hash Functions: A good hashing algorithm should not produce the same hash value for two different messages. If the algorithm does produce the same value for two distinctly different messages, this is referred to as a collision. If an attacker finds an instance of a collision, he has more information to use when trying to break the cryptographic methods used. A complex way of attacking a one-way hash function is called the birthday attack. Now hold on to your hat while we go through this -- it is a bit tricky. In standard statistics, a birthday paradox exists. It goes something like this:

How many people must be in the same room for the chance to be greater than even that another person has the same birthday as you?

Answer: 253

How many people must be in the same room for the chance to be greater than even that at least two people share the same birthday?

Answer: 23

This seems a bit backwards, but the difference is that in the first instance, you are looking for someone with a specific birthday date, which matches yours. In the second instance, you are looking for any two people who share the same birthday. There is a higher probability of finding two people who share a birthday than you finding another person sharing your birthday -- thus, the birthday paradox.

This means that if an attacker has one hash value and wants to find a message that hashes to the same hash value, this process could take him years. However, if he just wants to find any two messages with the same hashing value, it could take him only a couple hours.The main point of this paradox and this section is to show how important longer hashing values truly are. A hashing algorithm that has a larger bit output is stronger and less vulnerable to brute force attacks like a birthday attack.

Pg 554-555 Shon Harris: All-In-One Certification Exam Guide

Topic 8, Telecommunications, Network, and Internet Security

QUESTION NO: 815

Frame-relay uses a public switched network to provide:

- A. Local Area Network (LAN) connectivity
- B. Metropolitan Area Network (MAN) connectivity
- C. Wide Area Network (WAN) connectivity
- D. World Area Network (WAN) connectivity

Answer: C

Explanation:

QUESTION NO: 816

Which of the following technologies has been developed to support TCP/IP networking over low-speed serial interfaces?

- A. ISDN
- B. SLIP
- C. xDSL
- D. T1

Answer: B

Explanation:

SLIP, Serial Line IP, is a currently a de facto standard, commonly used for point-to-point serial connections running TCP/IP.

Reference: <http://tools.ietf.org/html/rfc1055>

QUESTION NO: 817

Which of the following provide network redundancy in a local network environment?

- A. Mirroring
- B. Shadowing
- C. Dual backbones
- D. Duplexing

Answer: C

Explanation:

QUESTION NO: 818

Which of the following is a Wide Area Network that was originally funded by the Department of Defense, which uses TCP/IP for data interchange?

- A. the Internet
- B. the Intranet
- C. the Extranet
- D. The Ethernet

Answer: A

Explanation:

QUESTION NO: 819

Internet specifically refers to the global network of:

- A. public networks and Internet Service Providers (ISPs) throughout the world
- B. private networks and Internet Services Providers (ISPs) through the world
- C. limited networks and Internet Service Providers (ISPs) throughout the world
- D. point networks and Internet Service Providers (ISPs) throughout the world

Answer: A

Explanation:

QUESTION NO: 820

To improve the integrity of asynchronous communications in the realm of personal computers, the Microcom Networking Protocol (MNP) uses a highly effective communications error-control technique known as

- A. Cyclic redundancy check.
- B. Vertical redundancy check.
- C. Checksum.
- D. Echoplex.

Answer: D

Explanation:

QUESTION NO: 821

Organizations should consider which of the following first before connecting their LANs to the Internet?

- A. plan for implementing W/S locking mechanisms
- B. plan for protecting the modem pool
- C. plan for providing the user with his account usage information
- D. plan for considering all authentication options

Answer: D

Explanation:

QUESTION NO: 822

Which xDSL flavour delivers both downstream and upstream speeds of 1.544 Mbps over two copper twisted pairs?

- A. HDSL
- B. SDSL
- C. ADSL
- D. VDSL

Answer: A

Explanation:

HDSL – High-Data-Rate Digital Subscriber Line – 1.544 Mbps each way over 2 copper twisted pair (http://www.cisco.com/en/US/tech/tk175/tk318/tsd_technology_support_protocol_home.html)

QUESTION NO: 823

Which of the following statements pertaining to Asynchronous Transfer Mode (ATM) is false?

- A. It can be used for voice
- B. It can be used for data
- C. It carries various sizes of packets
- D. It can be used for video

Answer: C

Explanation: "Asynchronous transfer mode (ATM) is a cell-switching technology, as opposed to a packet-switching technology like Frame Relay. ATM uses virtual circuits much like Frame Relay, but because it uses fixed-size frames or cells, it can guarantee throughput. This makes ATM an excellent WAN technology for voice and video conferencing." Pg 87 Tittel: CISSP Study Guide

QUESTION NO: 824

Satellite communications are easily intercepted because__

- A. transmissions are continuous 24 hours per day.
- B. a satellite footprint is narrowly focused.
- C. a satellite footprint is very large.
- D. a satellite footprint does not change.

Answer: C

Explanation: I think it may have to do with the footprint of the satellite.

Footprint - The area of Earth with sufficient antenna gain to receive a signal from a satellite. -

<http://www.aero.org/publications/crosslink/winter2002/backpage.html>

Not A: Granted Satellites transmit but they may not do it 24x7 as it could be only when traffic is sent.

QUESTION NO: 825

Which one of the following protocols CANNOT be used for full duplex Wide Area Network (WAN) communications?

- A. Synchronous Data Link Control (SDLC)
- B. Serial Line Internet Protocol (SLIP)
- C. Point-to-Point Protocol (PPP)
- D. High-Level Data Link Control (HDLC)

Answer: B

Explanation: By exclusion SLIP is the correct answer.

Note:

Serial Line Internet Protocol (SLIP) is an older technology developed to support TCP/IP communications over asynchronous serial connections, such as serial cables or modem dial-up. Pg 96. Tittel: CISSP Study Guide. SLIP is serial protocol opposed to WAN protocol.

Not SDLC: SDLC is full duplex.

"SDLC was developed to enable mainframes to communicate with remote locations." Pg 456 Shon Harris CISSP Certification Exam Guide. This is a WAN protocol.

Not C.

"PPP is a full-duplex protocol that provides bi-directional links over synchronous, asynchronous, ISDN, frame relay and SONET connections." Pg. 472 Shon Harris CISSP All-In-One Certification Exam Guide. PPP is full-duplex.

Not D.

"HDLC is an extension of SDLC, which is mainly used in SNA environments. HDLC provides high throughput because it supports full-duplex transmissions and is used in point-to-point and multipoint connections." Pg 456 Shon Harris CISSP All-In-One Certification Exam Guide. PPP is full-duplex.

QUESTION NO: 826

Fast ethernet operates at which of the following?

- A. 10 Mbps
- B. 100 Mbps
- C. 1000 Mbps
- D. All of the above

Answer: B

Explanation: "Fast Ethernet 100Mbps – IEE 802.3u" pg 810 Shon Harris CISSP All-In-One Exam

QUESTION NO: 827

Which of the following statements about the "Intranet" is NOT true?

- A. It is an add-on to a local area network.
- B. It is unrestricted and publicly available.
- C. It is usually restricted to a community of users
- D. it can work with MANS or WANS

Answer: B

Explanation:

"An intranet is a 'private' network that uses Internet technologies, such as TCP/IP. The company has Web servers and client machines using Web browsers, and it uses the TCP/IP protocol suite. The Web pages are written in Hypertext Markup Language (HTML) or Extensible Markup Language (XML) and are accessed via HTTP." Pg 395 Shon Harris: All-In-One CISSP Certification Guide.

QUESTION NO: 828

Frame relay and X.25 networks are part of which of the following?

- A. Circuit-switched services
- B. Cell-switched services
- C. Packet-switched services
- D. Dedicated digital services

Answer: C

Explanation: Packet-Switched Technologies:

X.25

Link Access Procedure-Balanced (LAPB)

Frame Relay

Switched Multimegabit Data Service (SMDS)

Asynchronous Transfer Mode (ATM)

Voice over IP (VoIP)

QUESTION NO: 829

A Wide Area Network (WAN) may be privately operated for a specific user community, may support multiple communication protocols, or may provide network connectivity and services via:

- A. interconnected network segments (extranets, intranets, and Virtual Private Networks)
- B. interconnected network segments (extranets, internets, and Virtual Private Networks)
- C. interconnected netBIOS segments (extranets, intranets, and Virtual Private Networks)
- D. interconnected NetBIOS segments (extranets, interest, and Virtual Private Networks)

Answer: A

Explanation:

QUESTION NO: 830

What is the proper term to refer to a single unit of Ethernet data?

- A. Ethernet segment
- B. Ethernet datagram
- C. Ethernet frame
- D. Ethernet packet

Answer: C

Explanation: When the Ethernet software receives a datagram from the Internet layer, it performs the following steps: 1.) Breaks IP layer data into smaller chunks if necessary which will be in the data field of ethernet frames. Pg. 40 Sams Teach Yourself TCP/IP in 24 hrs.

QUESTION NO: 831

Which of the following is a LAN transmission protocol?

- A. Ethernet
- B. Ring Topology
- C. Unicast
- D. Polling

Answer: C

Reference: "LAN Transmission Methods. LAN data is transmitted from the sender to one or more receiving stations using either a unicast, multicast, or broadcast transmission." pg 528 Hansche: Official (ISC)2 Guide to the CISSP Exam

QUESTION NO: 832

Which of the following access methods is used by Ethernet?

- A. CSMA/CD
- B. CSU/DSU
- C. TCP/IP
- D. FIFO

Answer: A

Explanation: "Under the Ethernet CSMA/CD media-access process, any computer on a CSMA/CD LAN can access the network at any time." Pg. 103 Krutz: The CISSP Prep Guide.

QUESTION NO: 833

Which one of the following data transmission technologies is NOT packet-switch based?

- A. X.25
- B. ATM (Asynchronous Transfer Mode)
- C. CSMA/CD (Carrier Sense Multiple Access/Collision Detection)
- D. Frame Relay

Answer: B

Explanation:

"Examples of packet-switching networks are X.25, Link Access Procedure-Balanced (LAPB),

Frame Relay, Switched Multimegabit Data Systems (SMDS), Asynchronous Transfer Mode (ATM), and Voice over IP (VoIP).” Pg 146 Krutz: CISSP Prep Guide: Gold Edition.
http://en.wikipedia.org/wiki/Virtual_circuit

QUESTION NO: 834

Unshielded (UTP) does not require the fixed spacing between connections that is:

- A. necessary with telephone-type connections
- B. necessary with coaxial-type connections
- C. necessary with twisted pair-type connections
- D. necessary with fiber optic-type connections

Answer: B

Explanation:

“Fixed spacing between connections” is referring to the fixed-sized insulation that separates the inner wire from the shielding.

QUESTION NO: 835

What type of cable is used with 100Base-TX Fast Ethernet?

- A. Fiber-optic cable
- B. Four pairs of Category 3, 4, or 5 unshielded twisted-pair (UTP) wires.
- C. Two pairs of Category 5 unshielded twisted-pair (UTP) or Category 1 shielded twisted-pair (STP) wires
- D. RG-58 Cable

Answer: C

Explanation:

QUESTION NO: 836

Which cable technology refers to the CAT 3 and Cat5 Categories?

- A. Coaxial cables
- B. Fiber Optic cables
- C. Axial cables
- D. Twisted Pair cables

Answer: D

Explanation:

QUESTION NO: 837

On which Open System Interconnection (OSI) Reference Model layer are repeaters used as communications transfer devices?

- A. Data-link
- B. Physical
- C. Network
- D. Transport

Answer: B

Explanation: This original answer is wrong (network) repeater is physical layer. Repeaters just regenerates the signal

"Hubs are multi port repeaters, and as such they obey the same rules as repeaters (See previous section OSI Operating Layer). They operate at the OSI Model Physical Layer."

http://www.thelinuxreview.com/howto/intro_to_networking/c5434.htm

QUESTION NO: 838

In the OSI/ISO model, at what layer are some of the SLIP, CSLIP, PPP, control functions are provided?

- A. Data Link
- B. Transport
- C. Presentation

D. Application

Answer: A

Explanation:

QUESTION NO: 839

In the OSI/ISO model, at what level are TCP and UDP provided?

- A. Transport**
- B. Network**
- C. Presentation**
- D. Application**

Answer: A

Explanation: Transport Layer. TCP and UDP operate on this layer.' Pg 82. Krutz: The CISSP Prep Guide.

QUESTION NO: 840

DNS, FTP, TFTP, SNMP are provided at what level of the OSI/ISO model?

- A. Application**
- B. Network**
- C. Presentation**
- D. Transport**

Answer: A

Explanation:

QUESTION NO: 841

Which of the following OSI layers does not provide confidentiality?

- A. Presentation**
- B. Network**

- C. Transport
- D. Session

Answer: C

Explanation:

1.
Reference: "[Network Layer] The routing protocols are located at this layer and include the following:Internet Protocol Security (IPSec)". "The following protocols operate within the Session layer: Secure Sockets Layer (SSL)". "The Presentation layer is also responsible for encryption and compression." Pg 61-62 Tittel: CISSP Study Guide

2.

According to this chart:

http://en.wikipedia.org/wiki/OSI_model

Network - IPSEC

Presentation – SSL/TLS

Session – L2TP

Transport – remains an answer.

3. According to Shon Harris / CISSP 5th edition, SSL is at the TRANSPORT layer

Conclusion:

So, 3 different sources put SSL at 3 completely different layers. But using 1 of the 2 sources does get you with 'transport' as being the answer.

QUESTION NO: 842

Which of the following OSI layers provides routing and related services?

- A. Network
- B. Presentation
- C. Session
- D. Physical

Answer: A

Explanation:

QUESTION NO: 843

The International Standards Organization/Open Systems Interconnection (ISO/OSI) Layers does NOT have which of the following characteristics?

- A. Standard model for network communications
- B. Used to gain information from network devices such as count of packets received and routing tables
- C. Allows dissimilar networks to communicate
- D. Defines 7 protocol layers (a.k.a. protocol stacks)

Answer: B

Explanation: Not A.

“The Open System Interconnect (OSI) is a worldwide federation that works to provide international standards. “

Not C.

“A protocol is a standard set of rules that determine how systems will communicate across networks. Two different systems can communicate and understand each other because they use the same protocols in spite of their differences.”

Pg. 343-344 Shon Harris: CISSP All-In-One Certification Exam Guide

QUESTION NO: 844

Which of the following layers supervises the control rate of packet transfers in an Open Systems Interconnections (OSI) implementation?

- A. Physical
- B. Session
- C. Transport
- D. Network

Answer: C

Explanation: The transport layer defines how to address the physical locations and /or devices on the network, how to make connections between nodes, and how to handle the networking of messages. It is responsible for maintaining the end-to-end integrity and control of the session.

Services located in the transport layer both segment and reassemble the data from upper-layer applications and unite it onto the same data stream, which provides end-to-end data transport services and establishes a logical connection between the sending host and destination host on a network. The transport layer is also responsible for providing mechanisms for multiplexing upper-layer applications, session establishment, and the teardown of virtual circuits. -Ronald Krutz The CISSP PREP Guide (gold edition) pg 275-276

“Transport Layer The agreement on these issues before transferring data helps provide more reliable data transfer, error detection and correction, and flow control and it optimizes network services needed to perform these tasks.” Pg. 318 – 319 Shon Harris: All-In-One CISSP Certification Guide.

QUESTION NO: 845

Which Open Systems Interconnect (OSI) layers provide Transport Control Protocol/Internet Protocol (TCP/IP) end-to-end security?

- A. Application and presentation
- B. Presentation and session
- C. Network and application
- D. Application and transport

Answer: B

Explanation: “The Session layer (layer 5) is responsible for establishing, maintaining, and terminating communication sessions between two computers. The primary technology within layer 5 is a gateway. The following protocols operate within the Session layer:

Secure Sockets Layer (SSL)

Network File System (NFS)

Structured Query Language (SQL)

Remote Procedure Call (RPC)

The presentation layer (layer 6) is responsible for transforming data received from the application layer into a format that any system following the OSI model can understand. It imposes common or standardized structure and formatting rules onto the data. The Presentation layer is also responsible for encryption and compression.” Pg. 79-80 Tittel: CISSP Study Guide.

QUESTION NO: 846

Which one of the following is a TRUE statement about the bottom three layers of the Open Systems Interconnection (OSI) Reference Model?

- A. They generally pertain to the characteristics of the communicating end systems.
- B. They cover synchronization and error control of network data transmissions.
- C. They support and manage file transfer and distribute process resources.
- D. They support components necessary to transmit network messages.

Answer: D

Explanation: By exclusion:

Not A.

"The Session layer (layer 5) is responsible for establish, maintaining, and terminating communication sessions between two computers." Pg 79 Tittel: CISSP Study Guide.

Not B.

"The Transport layer (layer 4)This layer includes mechanisms for segmentation, sequencing, error checking, controlling the flow of data, error correction and network service optimization." Pg 79 Tittel: CISSP Study Guide.

Not C.

"The Application itself it is not located within this layer [Application]; rather the protocols and services required to transmit files, exchange messages, connect to remote terminals, and so on are here." Pg. 80 Tittel: CISSP Study Guide.

QUESTION NO: 847

ICMP and IGMP belong to which layer of the OSI model?

- A. Datagram
- B. Network

- C. Transport
- D. Link

Answer: B

Explanation: The Network layer (layer 3) is responsible for adding routing information to the data. The Network layer accepts the segment from the Transport layer and adds information to it to create a packet. The packet includes the source and destination IP addresses. T

The routing protocols are located at this layer and include the following:

Internet Control Message Protocol (ICMP)

Routing Information Protocol (RIP)

Open Shortest Path First (OSPF)

Border Gateway Protocol (BGP)

Internet Group Management Protocol (IGMP)

Internet Protocol (IP)

Internet Packet Exchange (IPX)

Pg. 78 Tittel: CISSP Study Guide

QUESTION NO: 848

The International Standards Organization / Open Systems Interconnection (ISO/OSI) Layers 6 is which of the following?

- A. Application Layer
- B. Presentation Layer
- C. Data Link Layer
- D. Network Layer

Answer: B

Explanation: "Presentation Layer (Layer 6)." Pg 81 Krutz The CISSP Prep Guide.

QUESTION NO: 849

Which OSI/ISO layer is IP implemented at?

- A. Session layer
- B. Transport layer
- C. Network layer
- D. Data link layer

Answer: C

Explanation:

QUESTION NO: 850

Which of the following security-focused protocols operates at a layer different from the others?

- A. Secure HTTP
- B. Secure shell (SSH-2)
- C. Secure socket layer (SSL)
- D. Simple Key Management for Internet Protocols (SKIP)

Answer: A

Explanation:

QUESTION NO: 851

In the OSI/ISO model, at what layer are some of the SLIP, CSLIP, PPP control functions are provided?

- A. Data Link
- B. Transport
- C. Presentation
- D. Application

Answer: A

Explanation:

QUESTION NO: 852 CORRECT TEXT

ICMP and IGMP belong to which layer of the OSI Model? (Fill in the blank)

Answer: Network

QUESTION NO: 853 CORRECT TEXT

The International Standards Organization / Open Systems Interconnection (ISO/OSI) Layers 6 is which of the following? (Fill in the blank)

Answer: Presentation

QUESTION NO: 854 CORRECT TEXT

Which of the following OSI layers provides non-repudiation services? (Fill in the blank)

Answer: Application

QUESTION NO: 855

The OSI model contains seven layers. TCP/IP is generally accepted as having how many layers?

- A. four
- B. five
- C. six
- D. eight

Answer: A

Explanation: The TCP/IP Protocol Model is similar to the OSI model, but it defines only the following four layers instead of seven: Application Layer, Host-to-Host Transport Layer, Internet Layer, Network Access or Link Layer.

Pg. 84 Krutz: The CISSP Prep Guide.

QUESTION NO: 856

Which of the following layers provides end-to-end service?

- A. Network Layer
- B. Link Layer
- C. Transport Layer
- D. Presentation Layer

Answer: C

Explanation: Session services located in the Transport Layer both segment and reassemble the data from upper-layer applications and unite it onto the same data stream, which provides end-to-end data transport services and establishes a logical connection between the sending host and destination host on a network.

Pg. 82 Krutz: The CISSP Prep Guide.

QUESTION NO: 857

Both TCP and UDP use port numbers of what length?

- A. 32 bits
- B. 16 bits
- C. 8 bits
- D. 4 bits

Answer: B

Explanation:

QUESTION NO: 858

Which one of the following is an effective communications error-control technique usually implemented in software?

- A. Redundancy check
- B. Packet filtering
- C. Packet checksum
- D. Bit stuffing

Answer: C

Explanation:

QUESTION NO: 859 CORRECT TEXT

What is the proper term to refer to a single unit of IP data? (Fill in the blank)

Answer: Datagram

“When the Ethernet software receives a datagram from the Internet layer, it performs the following steps: 1.) Breaks IP layer data into smaller chunks if necessary which will be in the data field of ethernet frames.” Pg. 40 Sams Teach Yourself TCP/IP in 24 hrs.

QUESTION NO: 860

What is the proper term to refer to a single unit of TCP data at the transport layer?

- A. TCP segment
- B. TCP datagram
- C. TCP frame
- D. TCP packet

Answer: A

Explanation: The data package created at the transport layer, which encapsulates the Application layer message is called a segment if it comes from TCP/IP.” Pg. 27 Pg. 55 Casad: Sams Teach Yourself TCP/IP in 24 hrs.

QUESTION NO: 861

Each data packet is assigned the IP address of the sender and the IP address of the:

- A. recipient
- B. host
- C. node
- D. network

Answer: A

Explanation:

QUESTION NO: 862

Both TCP and UDP use port numbers of what length?

- A. 32 bits
- B. 16 bits
- C. 8 bits
- D. 4 bits

Answer: B

Explanation: 2 to 16th power = 65,536

"TCP and UDP each have 65,536 ports". Pg 75 Tittel: CISSP Study Guide

QUESTION NO: 863

Which of the following type of packets can *easily* be denied with a stateful packet filter?

- A. ICMP
- B. TCP
- C. UDP
- D. IP

Answer: B

Explanation:

QUESTION NO: 864

Which ports are the "Register ports", registered by the IANA?

- A. Ports 128 to 255
- B. Ports 1024 to 49151
- C. Ports 1023 to 65535

D. Ports 1024 to 32767

Answer: B

Explanation:

- * the System Ports, also known as the Well Known Ports, from 0-1023 (assigned by IANA)
- * the User Ports, also known as the Registered Ports, from 1024- 49151 (assigned by IANA)
- * the Dynamic Ports, also known as the Private or Ephemeral Ports, from 49152-65535 (never assigned)

Reference: <http://tools.ietf.org/html/draft-ietf-tsvwg-iana-ports-10>

QUESTION NO: 865

What protocol was UDP based and mainly intended to provide validation of dial up user login passwords?

- A. PPTP**
- B. L2TP**
- C. IPsec**
- D. TACACS**

Answer: D

Explanation:

The original TACACS protocol was developed by BBN for MILNET. It was UDP based and mainly intended to provide validation of dial up user login passwords. The TACACS protocol was formally specified, but the spec is not generally available.

QUESTION NO: 866

On which port is POP3 usually run?

- A. 110**
- B. 109**
- C. 139**

D. 119

Answer: A

Explanation:

QUESTION NO: 867

The primary function of this protocol is to send messages between network devices regarding the health of the network:

- A. Internet Control Message Protocol (ICMP)**
- B. Reverse Address Resolution Protocol (RARP)**
- C. Address Resolution Protocol (AR)**
- D. Internet Protocol (IP)**

Answer: A

Explanation:

QUESTION NO: 868

Telnet and rlogin use which protocol?

- A. UDP**
- B. SNMP**
- C. TCP**
- D. IGP**

Answer: C

Explanation:

QUESTION NO: 869

The IP header contains a protocol field. If this field contains the value of 2, what type of data is contained within the IP datagram?

- A. TCP**

- B. ICMP
- C. UDP
- D. IGMP

Answer: D

Explanation:

ICMP = 1

IGMP = 2

TCP = 6

UDP = 17

Pg. 55 Casad: Sams Teach Yourself TCP/IP in 24 hrs.

QUESTION NO: 870

The IP header contains a protocol field. If this field contains the value of 17, what type of data is contained within the ip datagram?

- A. TCP
- B. ICMP
- C. UDP
- D. IGMP

Answer: C

Explanation:

ICMP = 1

IGMP = 2

TCP = 6

UDP = 17

Pg. 55 Casad: Sams Teach Yourself TCP/IP in 24 hrs.

QUESTION NO: 871

Why do some sites choose not to implement Trivial File Transfer Protocol (TFTP)?

- A. list restrictions
- B. inherent security risks
- C. user authentication requirement
- D. directory restriction

Answer: B

Explanation:

QUESTION NO: 872

The IP header contains a protocol field. If this field contains the value of 6, what type of data is contained within the ip datagram?

- A. TCP
- B. ICMP
- C. UDP
- D. IGMP

Answer: A

Explanation: ICMP = 1

TCP = 6

UDP = 17

Pg. 55 Casad: Sams Teach Yourself TCP/IP in 24 hrs.

QUESTION NO: 873

Which of the following is not a basic security service defined by the OSI?

- A. Routing control
- B. Authentication
- C. Data Confidentiality
- D. Logging and monitoring

Answer: D

Explanation:

Routing control IS defined, but no mention of Logging & Monitoring.

Reference:

[http://en.wikipedia.org/wiki/Security_service_\(telecommunication\)](http://en.wikipedia.org/wiki/Security_service_(telecommunication))

And

http://www.itu.int/rec/dologin_pub.asp?lang=e&id=T-REC-X.800-199103-!!!PDF-E&type=items

QUESTION NO: 874

Which of the following is not an OSI architecture-defined broad category of security standards?

- A. Security techniques standards
- B. Layer security protocol standards
- C. Application-specific security
- D. Firewall security standards

Answer: D

Explanation:

QUESTION NO: 875

Which one of the following is the Open Systems Interconnection (OSI) protocol for message handling?

- A. X.25
- B. X.400
- C. X.500
- D. X.509

Answer: B

Explanation: An ISO and ITU standard for addressing and transporting e-mail messages. It conforms to layer 7 of the OSI model and supports several types of transport mechanisms, including Ethernet, X.25, TCP/IP, and dial-up lines. -

http://www.webopedia.com/TERM/X/X_400.html

QUESTION NO: 876

The IP header contains a protocol field. If this field contains the value of 1, what type of data is contained within the IP datagram?

- A. TCP
- B. ICMP
- C. UDP
- D. IGMP

Answer: B

Explanation:

ICMP = 1

IGMP = 2

TCP = 6

UDP = 17

Pg. 55 Casad: Sams Teach Yourself TCP/IP in 24 hrs.

QUESTION NO: 877

Which of the following is true?

- A. TCP is connection-oriented. UDP is not
- B. UDP provides for Error Correction. TCP does not.
- C. UDP is useful for longer messages
- D. UDP guarantees delivery of data. TCP does not guarantee delivery of data.

Answer: A

Explanation:

QUESTION NO: 878

What works as an E-mail message transfer agent?

- A. SMTP
- B. SNMP
- C. S-RPC
- D. S/MIME

Answer: A

Explanation:

QUESTION NO: 879

A common way to create fault tolerance with leased lines is to group several T-1's together with an inverse multiplexer placed:

- A. at one end of the connection
- B. at both ends of the connection
- C. somewhere between both end points
- D. in the middle of the connection

Answer: B

Explanation:

QUESTION NO: 880

Several methods provide telecommunications continuity, which of the following is a method of routing traffic through split cable or duplicate cable facilities?

- A. diverse routing
- B. alternative routing
- C. last mile circuit protection
- D. long haul network diversity

Answer: A

Explanation:

QUESTION NO: 881

Which of the following is the primary security feature of a proxy server?

- A. Client hiding
- B. URL blocking
- C. Route blocking
- D. Content filtering

Answer: A

Explanation:

QUESTION NO: 882

Which of the following Common Data Network Services is used to send and receive email internally or externally through an email gateway device?

- A. File services
- B. Mail services
- C. Print Services
- D. Client/Server services

Answer: B

Explanation:

QUESTION NO: 883

Which one of the following is a technical solution for the quality of service, speed, and security problems facing the Internet?

- A. Random Early Detection (RED) queuing
- B. Multi-protocol label-switching (MPLS)
- C. Public Key Cryptography Standard (PKCS)
- D. Resource Reservation Protocol (RSVP)

Answer: B

Explanation: The original answer to this question was RED however I think this is incorrect because of this reason. Both Red and MPLS deal with qos/cos issues, there by increasing speed. Mpls more so the RED. However I have not been able to find any documents that state RED is a

security implementation while MPLS is heavy used in the ISP VPN market. See this link for MPLS security <http://www.nwfusion.com/research/2001/0521feat2.html>

Below are the link that are formation of the ration for this answer of B (MPLS)

Congestion avoidance algorithm in which a small percentage of packets are dropped when congestion is detected and before the queue in question overflows completely

<http://www.cisco.com/univercd/cc/td/doc/cisintwk/ita/r12.htm>

Multiprotocol Label Switching. Switching method that forwards IP traffic using a label. This label instructs the routers and the switches in the network where to forward the packets based on preestablished IP routing information <http://www.cisco.com/univercd/cc/td/doc/cisintwk/ita/m12.htm>

Resource Reservation Protocol. Protocol that supports the reservation of resources across an IP network. Applications running on IP end systems can use RSVP to indicate to other nodes the nature (bandwidth, jitter, maximum burst, and so on) of the packet streams they want to receive. RSVP depends on IPv6. Also known as Resource Reservation Setup Protocol.

<http://www.cisco.com/univercd/cc/td/doc/cisintwk/ita/r12.htm>

Random Early Detection (RED) is the recommended approach for queue congestion management in routers (Braden et al., 1998). Although in its basic form RED can be implemented in a relatively short C program, as the speed of ports and the number of queues per port increase, the implementation moves more and more into hardware. Different vendors choose different ways to implement and support RED in their silicon implementations. The degree of programmability, the number of queues, the granularity among queues, and the calculation methods of the RED parameters all vary from implementation to implementation. Some of these differences are irrelevant to the behavior of the algorithm-and hence to the resulting network behavior. Some of the differences, however, may result in a very different behavior of the RED algorithm-and hence of the network efficiency.

http://www.cisco.com/en/US/products/hw/routers/ps167/products_white_paper09186a0080091fe4.shtml

Based on label swapping, a single forwarding mechanism provides opportunities for new control paradigms and applications. MPLS Label Forwarding is performed with a label lookup for an incoming label, which is then swapped with the outgoing label and finally sent to the next hop. Labels are imposed on the packets only once at the edge of the MPLS network and removed at the other end. These labels are assigned to packets based on groupings or forwarding equivalence classes (FECs). Packets belonging to the same FEC get similar treatment. The label is added between the Layer 2 and the Layer 3 header (in a packet environment) or in the virtual path identifier/virtual channel identifier (VPI/VCI) field (in ATM networks). The core network merely reads labels, applies appropriate services, and forwards packets based on the labels. This MPLS lookup and forwarding scheme offers the ability to explicitly control routing based on destination and source addresses, allowing easier introduction of new IP services.

http://www.cisco.com/warp/public/cc/pd/iosw/prodlit/xlsw_ds.htm

QUESTION NO: 884

How do you distinguish between a bridge and a router?

- A.** The router connects two networks at the data-link layer, while bridge connects two networks at the network layer
- B.** The bridge connects two networks at the data-link layer, while router connects two networks at the network layer
- C.** It is not possible to distinguish them. They have the same functionality.

Answer: B

Explanation:

QUESTION NO: 885

Why should you avoid having two routers connect your trusted internal LAN to your demilitarized zone?

- A.** Network congestion might cause the routers to pass data from your private network through the demilitarized zone
- B.** This provides attackers with multiple paths to access your trusted network
- C.** There is a substantial increase in cost with only a nominal increase in security
- D.** You may overlook an attack on one of your routers because your data still teaches the outside world from your other router

Answer: B

Explanation:

Adding a second router to connect between the LAN and DMZ won't increase security, but will give them a second path to attack (in case the routers aren't kept identically patched & configured)

QUESTION NO: 886

In the days before CIDR (Classless Internet Domain Routing), networks were commonly organized

by classes. Which of the following would have been true of a Class B network?

- A. The first bit of the ip address would be set to zero
- B. The first bit of the ip address would be set to one and the second bit set to zero
- C. The first two bits of an ip address would be set to one, and the third bit set to zero
- D. The first three bits of the ip address would be set to one

Answer: B

Explanation:

QUESTION NO: 887

Which of the following is an ip address that is private (i.e. reserved for internal networks, and not a valid address to use on the internet)?

- A. 172.5.42.5
- B. 172.76.42.5
- C. 172.90.42.5
- D. 172.16.42.5

Answer: D

Explanation: The Internet Assigned Numbers Authority (IANA) has reserved the following three blocks of the IP address space for private Internets – 10.0.0.0 to 10.255.255.255, 172.16.0.0 to 172.31.255.255, and 192.168.0.0 to 192.168.255.255- that are known as “global non-routable addresses.”” Pg. 94 Krutz: The CISSP Prep Guide.

QUESTION NO: 888

Which of the following is an ip address that is private (i.e. reserved for internal networks, and not a valid address to use on the internet)?

- A. 10.0.42.5
- B. 11.0.42.5
- C. 12.0.42.5
- D. 13.0.42.5

Answer: A

Explanation: The Internet Assigned Numbers Authority (IANA) has reserved the following three blocks of the IP address space for private Internets – 10.0.0.0 to 10.255.255.255, 172.16.0.0 to 172.31.255.255, and 192.168.0.0 to 192.168.255.255- that are known as “global non-routable addresses.”” Pg. 94 Krutz: The CISSP Prep Guide.

QUESTION NO: 889

Which of the following is an ip address that is private (i.e. reserved for internal networks, and not a valid address to use on the internet)?

- A. 172.12.42.5
- B. 172.140.42.5
- C. 172.31.42.5
- D. 172.15.45.5

Answer: C

Explanation: The Internet Assigned Numbers Authority (IANA) has reserved the following three blocks of the IP address space for private Internets – 10.0.0.0 to 10.255.255.255, 172.16.0.0 to 172.31.255.255, and 192.168.0.0 to 192.168.255.255- that are known as “global non-routable addresses.”” Pg. 94 Krutz: The CISSP Prep Guide.

QUESTION NO: 890

In the days before CIDR (Classless Internet Domain Routing), networks were commonly organized by classes. Which of the following would have been true of a Class C network?

- A. The first bit of the ip address would be set to zero
- B. The first bit of the ip address would be set to one and the second bit set to zero
- C. The first two bits of the ip address would be set to one, and the third bit set to zero
- D. The first three bits of the ip address would be set to one

Answer: C

Explanation: Pg. 80 Sams Teach Yourself TCP/IP in 24 hrs.

QUESTION NO: 891

Which of the following is an ip address that is private (i.e. reserved for internal networks, and not a valid address to use on the Internet)?

- A. 192.168.42.5
- B. 192.166.42.5
- C. 192.175.42.5
- D. 172.1.42.5

Answer: A

Explanation:

QUESTION NO: 892

How long are IPv4 addresses:

- A. 32 bits long
- B. 64 bits long
- C. 128 bits long
- D. 16 bits long

Answer: A

Explanation: "Ipv4 uses 32 bits for addresses, and Ipv6 uses 128 bits; thus v6 provides more possible addresses to work with." Pg 331 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 893

ARP and RARP map between which of the following?

- A. DNS addresses and IP addresses
- B. 32-bit hardware addresses and 48-bit IPv6 addresses
- C. 32-bit hardware addresses and 48-bit IPv4 addresses
- D. 32-bit addresses in IPv4 and 48-bit hardware addresses

Answer: D

Explanation: An Ethernet address is a 48-bit address that is hard-wired into the NIC of the network node. ARP matches up the 32-bit IP address with this hardware address, which is technically referred to as the Media Access Control (MAC) address or the physical address. Pg. 87 Krutz: The CISSP Prep Guide.

QUESTION NO: 894

Which protocol matches an Ethernet address to an Internet Protocol (IP) address?

- A. Address Resolution Protocol (ARP)
- B. Reverse Address Resolution Protocol (RARP)
- C. Internet Control Message Protocol (ICMP)
- D. User Datagram Protocol (UDP)

Answer: B

Explanation: "As with ARP, Reverse Address Resolution Protocol (RARP) frames go to all systems on the subnet, but only the RARP server responds. Once the RARP server receives this request, it looks in its table to see which IP address matches the broadcast hardware address. The server then sends a message back to the requesting computer that contains its IP address. The system now has an IP address and can function on the network." Pg 357 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 895

In a typical firewall configuration, what is the central host in organization's network security?

- A. Stateful
- B. Screen
- C. Gateway
- D. Bastion

Answer: D

Explanation: Bastion Host: A system that has been hardened to resist attack at some critical point of entry, and which is installed on a network in such a way that it is expected to come under

attack. Bastion hosts are often components of firewalls, or may be 'outside' Web servers or public access systems. Generally, a bastion host is running some form of general purpose operating system (e.g., LINUX, VMS, WNT, etC.) rather than a ROM-based or firmware operating system.
http://www.securesynergy.com/library/articles/it_glossary/glossary_b.php

QUESTION NO: 896

Which one of the following describes a bastion host?

- A. A physically shielded computer located in a data center or vault.
- B. A computer which maintains important data about the network.
- C. A computer which plays a critical role in a firewall configuration.
- D. A computer used to monitor the vulnerability of a network.

Answer: C

Explanation: A bastion host or screened host is just a firewall system logically positioned between a private network and an untrusted network. - Ed Tittle CISSP Study Guide (sybex) pg 93

QUESTION NO: 897

Which of the following statements pertaining to firewalls is incorrect?

- A. Firewalls should not run NIS (Network Information Systems)
- B. Firewalls should mount files systems via NFS
- C. All system logs on the firewall should log to a separate host
- D. Compilers should be deleted from the firewall

Answer: B

Explanation:

QUESTION NO: 898

Which is the MAIN advantage of having an application gateway?

- A. To perform change control procedures for applications.
- B. To provide a means for applications to move into production.
- C. To log and control incoming and outgoing traffic.
- D. To audit and approve changes to applications.

Answer: C

Explanation: "An application-level gateway firewall is also called a proxy firewall. A proxy is a mechanism that copies packets from one network into another; the copy process also changes the source and destination address to protect the identity of the internal or private network. An application-level gateway firewall filters traffic based on the Internet service (i.e., application) used to transmit or receive the data." - Shon Harris All-in-one CISSP Certification Guide pg 92

QUESTION NO: 899

Which process on a firewall makes permit/deny forwarding decisions based solely on address and service port information?

- A. Circuit Proxy
- B. Stateful Packet Inspection Proxy
- C. Application Proxy
- D. Transparency Proxy

Answer: A

Explanation: Circuit-level proxy creates a circuit between the client computer and the server. It does not understand or care about the higher-level issues that an application-level proxy deals with. It knows the source and destinations addresses and makes access decisions based on this information...IT looks at the data within the packet header versus the data within the payload of the packet. It does not know if the contents within the packet are actually safe or not. - Shon Harris All-in-one CISSP Certification Guide pg 419-420

QUESTION NO: 900

A proxy based firewall has which one of the following advantages over a firewall employing stateful packet inspection?

- A. It has a greater throughput.
- B. It detects intrusion faster.
- C. It has greater network isolation.
- D. It automatically configures the rule set.

Answer: C

Explanation:

QUESTION NO: 901

Firewalls filter incoming traffic according to

- A. The packet composition.
- B. A security policy.
- C. Stateful packet rules.
- D. A security process.

Answer: B

Explanation:

QUESTION NO: 902

Application Level Firewalls create:

- A. a real circuit between the workstation client and the server
- B. a virtual circuit between the workstation client and the server
- C. a imaginary circuit between the workstation guest and the server
- D. a temporary circuit between the workstation host and the server

Answer: B

Explanation:

QUESTION NO: 903

Which of the following is the biggest concern with firewall security?

- A. Internal hackers
- B. Complex configuration rules leading to misconfiguration
- C. Buffer overflows
- D. Distributed denial of service (DDOS) attacks

Answer: B

Explanation:

QUESTION NO: 904

Which of the following is true of network security?

- A. A firewall is not a necessity in today's connected world
- B. A firewall is a necessity in today's connected world
- C. A whitewall is a necessity in today's connected world
- D. A black firewall is a necessity in today's connected world

Answer: B

Explanation:

QUESTION NO: 905

Which of the following statements pertaining to firewalls is incorrect?

- A. Firewall create bottlenecks between the internal and external network
- B. Firewalls allow for centralization of security services in machines optimized and dedicated to the task

- C. Strong firewalls can protect a network at all layers of the OSI models
- D. Firewalls are used to create security checkpoints at the boundaries of private networks

Answer: C

Explanation:

QUESTION NO: 906

Which of the following is the least important security service provided by a firewall?

- A. Packet filtering
- B. Encrypted tunnels
- C. Network Address Translation
- D. Proxy services

Answer: B

Explanation:

QUESTION NO: 907

Which of the following firewall rules is less likely to be found on a firewall installed between an organization's internal network and internet?

- A. Permit all traffic to and from local host
- B. Permit all inbound ssh traffic
- C. Permit all inbound tcp connections
- D. Permit all syslog traffic to log-server.abc.org

Answer: C

Explanation:

QUESTION NO: 908

Which of the following packets should NOT be dropped at a firewall protecting an organization's internal network?

- A. Inbound packets with Source Routing option set
- B. Router information exchange protocols
- C. Inbound packets with an internal source IP address
- D. Outbound packets with an external destination IP address

Answer: D

Explanation:

QUESTION NO: 909

By examining the “state” and “context” of the incoming data packets, it helps to track the protocols that are considered “connectionless”, such as UDP-based applications and Remote Procedure Calls (RPC). This type of firewall system is used in:

- A. first generation firewall systems
- B. second generation firewall systems
- C. third generation firewall systems
- D. fourth generation firewall systems

Answer: C

Explanation: “Stateful Inspection Characteristics

The firewall maintains a state table that tracks each and every communication channel.

Frames are analyzed at all communication layers.

It provides a high degree of security and does not introduce the performance hit that proxy firewalls introduce.

It is scaleable and transparent to users

It provides data tracking for tracking connectionless protocols such as UDP and ICMP

The state and context of the data within the packets are stored and updated continuously.

It is considered a third-generation firewall.” Pg. 375 Shon Harris: All-in-One CISSP Certification

Not A:

“Packet filtering is the first generation firewall—that is, it was the first type that was created and used, and other types were developed fall into different generations.” Pg 373 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 910

Which of the following statements pertaining to packet filtering is incorrect?

- A. It is based on ACLs
- B. It is not application dependant
- C. It operates at the network layer
- D. It keeps track of the state of a connection

Answer: D

Explanation:

QUESTION NO: 911

A screening router can perform packet filtering based upon what data?

- A. Translated source destination addresses.
- B. Inverse address resolution.
- C. Source and destination port number.
- D. Source and destination addresses and application data.

Answer: C

Explanation: The original answer was A (translated source destination address). I did not come across this term in my reading.

Screening router

A screening router is one of the simplest firewall strategies to implement. This is a popular design because most companies already have the hardware in place to implement it. A screening router is an excellent first line of defense in the creation of your firewall strategy. It's just a router that has filters associated with it to screen outbound and inbound traffic based on IP address and UDP and TCP ports.

<http://www.zdnet.co.uk/news/specials/2000/10/enterprise/techrepublic/2002/10/article002c.html>

QUESTION NO: 912

Why are hardware security features preferred over software security features?

- A. They lock in a particular implementation.
- B. They have a lower meantime to failure.
- C. Firmware has fewer software bugs.
- D. They permit higher performance.

Answer: D

Explanation: This is a sort of iffy question. Hardware allows faster performance than software and does not need to utilize an underlying OS to make the security software operate. (An example is PIX firewall vs checkpoint). The meantime to failure answer to me is ok but the hardware that the software security also has a MTFF. A few people looked over this question and had no problem with the answer of B (meantime to failure question) but as I looked into it I have picked D. MTTF is typical the time to failure. "MTFF is the expected typical functional lifetime of the device given a specific operating environment" (- Ed Tittle CISSP Study Guide (sybex) pg 657). This leads me to think that this question says hardware has a SHORTER lifespan than software. Thus I am going to have to go with D (higher performance). This can be because of ASICs. As always use your best judgment, knowledge and experience on this question. Below are some points of view.

Few things to consider when deploying software based firewall:

Patching OS or firewall software could bring down firewall or open additional holes

OS Expertise vs. firewall expertise (you may need two administrators).

Support contract (One for hardware, one for OS, one for firewall), who do you call?

Administration (One for OS and one for firewall). If you're not an expert in both then forget it.

High-availability (Stateful failover) (usually requires additional software and costs a lot of money).

As a result it adds to support costs.

Is software firewalls a bad idea it depends. Every situation is different. -Bob

<http://www.securityfocus.com/archive/105/322401/2003-05-22/2003-05-28/2>

A software firewall application is designed to be installed onto an existing operating system running on generic server or desktop hardware. The application may or may not 'harden' the underlying operating system by replacing core components. Typical host operating systems include Windows NT, 2000 server or Solaris.

Software firewall applications all suffer from the following key disadvantages:

They run on a generic operating system that may or may not be hardened by the Firewall installation itself.

A generic operating system is non-specialized and more complex than is necessary to operate the firewall. This leads to reliability problems and hacking opportunities were peripheral/unnecessary services are kept running.

Generic operating systems have their own CPU and memory overheads making software based firewalls slower than their dedicated hardware counterparts.

If the software firewalls use PC hardware as the host platform, then there may be additional reliability problems with the hardware itself. Sub-optimal performance of generic hardware also affects software applications bundled with their own operating systems.

There is no physical or topological separation of the firewalling activity.

A dedicated hardware firewall is a software firewall application and operating system running on dedicated hardware. This means the hardware used is optimized for the task, perhaps including digital signal processors (DSPs) and several network interfaces. There may also be special hardware used to accelerate the encryption/decryption of VPN data. It may be rack mounted for easy installation into a comms' cabinet.

We recommend dedicated hardware firewalls as they offer several key advantages over software applications:

Dedicated hardware is typically more reliable.

Hardware firewalls are simpler, hence more secure.

Hardware firewalls are more efficient and offer superior performance, especially in support of VPNs.

The firewalling activity is physically and topologically distinct.

<http://www.zensecurity.co.uk/default.asp?URL=hardware%20software%20firewall>

QUESTION NO: 913

Firewalls can be used to

- A. Enforce security policy.
- B. Protect data confidentiality.
- C. Protect against protocol redirects.
- D. Enforce Secure Network Interface addressing.

Answer: A

Explanation: A firewall is a device that supports and enforces the company's network security policy. - Shon Harris All-in-one CISSP Certification Guide pg 412

QUESTION NO: 914

Which one of the following operations of a secure communication session cannot be protected?

- A. Session initialization
- B. Session support
- C. Session termination
- D. Session control

Answer: B

Explanation:

Session control is protected (Cisco -

http://www.cisco.com/en/US/prod/collateral/vpndevc/ps5708/ps5710/ps1018/product_data_sheet09186a0080117962.html)

Session initialization is protected (protection against SYN attacks/DoS)

Session termination is protected – they terminate idle connection so they don't consume resources

So, by the process of elimination, the correct answer is 'session support'.

QUESTION NO: 915

The general philosophy for DMZ's are that:

- A. any system on the DMZ can be compromised because it's accessible from the Internet
- B. any system on the DMZ cannot be compromised because it's not accessible from the Internet
- C. some systems on the DMZ can be compromised because they are accessible from the Internet
- D. any system on the DMZ cannot be compromised because it's by definition 100% safe and not accessible from the Internet

Answer: A

Explanation:

QUESTION NO: 916

What is NOT an authentication method within IKE and IPsec:

- A. CHAP
- B. Pre-shared Key
- C. certificate based authentication
- D. Public Key authentication

Answer: A

Explanation:

QUESTION NO: 917

In IPSec, if the communication mode is gateway-gateway or host-gateway:

- A. Only tunnel mode can be used
- B. Only transport mode can be used
- C. Encapsulating Security Payload (ESP) authentication must be used
- D. Both tunnel and transport mode can be used

Answer: D

Explanation:

"IPSec can work in one of two modes: transport mode, where the payload of the message is protected, and tunnel mode, where the payload and the routing and header information is protected." Pg 527 Shon Harris: All-in-One CISSP Certification

Not:" Encapsulating Security Payload (ESP) authentication must be used"

"IPSec is not a strict protocol that dictates the type of algorithm, keys, and authentication method to be used, but it is an open, modular framework that provides a lot of flexibility for companies when they choose to use this type of technology. IPSec uses two basic security protocols: Authentication Header (AH) and the Encapsulating Security Payload (ESP). AH is the authenticating protocol, and ESP is an authenticating and encrypting protocol that uses cryptographic mechanisms to provide source authentication, confidentiality, and message integrity." Pg 527 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 918

Internet Protocol Security (IPSec) provides security service within the Internet Protocol (IP) by doing all of the following EXCEPT

- A. Enabling a system to select required security protocols.
- B. Providing traffic analysis protection.
- C. Determining the algorithm(s) to use for the IPsec services.

D. Putting in place any cryptographic keys required to provide the requested services.

Answer: A

Explanation: Pg 527 Shon Harris CISSP All-In-One Certification Exam Guide

QUESTION NO: 919

Which of the following Internet Protocol (IP) security headers are defined by the Security Architecture for IP (IPSEC)?

- A.** The IPv4 and IPv5 Authentication Headers
- B.** The Authentication Header Encapsulating Security Payload
- C.** The Authentication Header and Digital Signature Tag
- D.** The Authentication Header and Message Authentication Code

Answer: B

Explanation: "IPSec uses two basic security protocols: Authentication Header (AH) and the Encapsulating Security Payload (ESP)." pg 575 Shon Harris CISSP All-In-One Certification Exam Guide

QUESTION NO: 920

Which of the following statements are true of IPSec Transport mode? Select best two.

- A.** It is required for gateways providing access to internal systems
- B.** It can be set-up when end-point is host or communications terminates at end-points
- C.** If used in gateway-to-host communication, gateway must act as host
- D.** Detective/Administrative Pairing

Answer: B,C

Explanation:

QUESTION NO: 921

What is called the standard format that was established to set up and manage Security Associations (SA) on the Internet in IPSec?

- A. Internet Key Exchange
- B. Secure Key Exchange Mechanism
- C. Oakley
- D. Internet Security Association and Key Management Protocol

Answer: D

Reference: pg 221 Krutz

QUESTION NO: 922

What is the purpose of the Encapsulation Security Payload (ESP) in the Internet Protocol (IP) Security Architecture for Internet Protocol Security?

- A. To provide non-repudiation and confidentiality for IP transmission.
- B. To provide integrity and confidentiality for IP transmissions.
- C. To provide integrity and authentication for IP transmissions.
- D. To provide key management and key distribution for IP transmissions.

Answer: B

Explanation: "Encapsulating Security Payload (ESP). AH is the authenticating protocol and ESP is an authenticating and encrypting protocol that uses cryptographic mechanisms to provide source authentication, confidentiality, and message integrity." Pg 575 Shon Harris CISSP All-In-One Certification Exam Guide

QUESTION NO: 923

Which one of the following is a circuit level application gateway and works independent of any supported TCP/IP application protocol?

- A. SOCK-et-S (SOCKS)
- B. Common Information Model (CIM)

- C. Secure Multipurpose Internet Mail Extension (S/MIME)
- D. Generic Security Service Application Programming Interface (GSS-API)

Answer: A

Explanation: "Socks Proxy Server Characteristics

Circuit-level proxy server

Requires clients to be SOCKS-fied with SOCKS client software

Mainly used for outbound Internet access and virtual private network (VPN) functionality

Can be resource-intensive

Provides authentication and encryption features to other VPN protocols, but not considered a traditional VPN protocol"

Pg. 422 Shon Harris CISSP All-In-One Certification Exam Guide

Reference:

The SOCKS is an example of a circuit-level proxy gateway that provides a secure channel between two computers. pg. 379 Shon Harris CISSP

QUESTION NO: 924

How does the SOCKS protocol secure Internet Protocol (IP) connections?

- A. By negotiating encryption keys during the connection setup.
- B. By attaching Authentication Headers (AH) to each packet.
- C. By distributing encryption keys to SOCKS enabled applications.
- D. By acting as a connection proxy.

Answer: D

Explanation: "SOCKS is an example of a circuit-level proxy gateway that provides a secure channel between two computers. When a SOCKS-enabled client sends a request to a computer on the Internet, this request actually goes to the network's SOCKS proxy server..." pg 379 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 925

In the TCP/IP protocol stack, at what level is the SSL (Secure Sockets Layer) protocol provided?

- A. Application
- B. Network
- C. Presentation
- D. Session

Answer: A

Explanation:

The major functional groups of protocols and methods are the Application Layer, the Transport Layer, the Internet Layer, and the Link Layer (RFC 1122). It should be noted that this model was not intended to be a rigid reference model into which new protocols have to fit in order to be accepted as a standard.

The following table provides some examples of the protocols grouped in their respective layers.

Application	DNS, TFTP, TLS/SSL, FTP, Gopher, HTTP, IMAP, IRC, NNTP, POP3, SIP, SMTP, SMPP, SNMP, SSH, Telnet, Echo, RTP, PNRP, rlogin, ENRP Routing protocols like BGP and RIP which run over TCP/UDP, may also be considered part of the Internet Layer.
Transport	TCP, UDP, DCCP, SCTP, IL, RUDP, RSVP
Internet	IP (IPv4, IPv6) ICMP, IGMP, and ICMPv6 OSPF for IPv4 was initially considered IP layer protocol since it runs per IP-subnet, but has been placed on the Link since RFC 2740 d9 .
Link	ARP, RARP, OSPF (IPv4/IPv6), IS-IS, NDP

QUESTION NO: 926

SSL (Secure Sockets Layer) has two possible 'session key' lengths, what are they?

- A. 40 bit & 54 bit
- B. 40 bit & 128 bit
- C. 64 bit & 128 bit
- D. 128 bit & 256 bit

Answer: B

Explanation:

QUESTION NO: 927

Which of the following is NOT true of SSL?

- A. By convention it uses 's-http://' instead of 'http://'.

- B. It stands for Secure Sockets Layer
- C. It was developed by Netscape
- D. IT is used for transmitting private documents over the internet

Answer: A

Explanation:

QUESTION NO: 928

Which SSL version offers client-side authentication

- A. SSL v1
- B. SSL v2
- C. SSL v3
- D. SSL v4

Answer: B

Explanation: "Client Authentication using Digital IDs

Enable access by certificates

http://www.verisign.com/repository/clientauth/ent_ig.htm#clientauth

QUESTION NO: 929

In which way does a Secure Socket Layer (SSL) server prevent a "man-in-the-middle" attack?

- A. It uses signed certificates to authenticate the server's public key.
- B. A 128 bit value is used during the handshake protocol that is unique to the connection.
- C. It uses only 40 bits of secret key within a 128 bit key length.
- D. Every message sent by the SSL includes a sequence number within the message contents.

Answer: A

Explanation: Secure Sockets Layer (SSL). An encryption technology that is used to provide secure transactions such as the exchange of credit card numbers. SSL is a socket layer security protocol and is a two-layered protocol that contains the SSL Record Protocol and the SSL Handshake Protocol. Similiar to SSH, SSL uses symmetric encryption for private connections and asymmetric or public key cryptography (certificates) for peer authentication. It also uses a

Message Authentication Code for message integrity checking.

Krutz: The CISSP Prep Guide pg. 89. It prevents a man in the middle attack by confirming that you are authenticating with the server desired prior entering your user name and password. If the server was not authenticated, a man-in-the-middle could retrieve the username and password then use it to login.

The SSL protocol has been known to be vulnerable to some man-in-the-middle attacks. The attacker injects herself right at the beginning of the authentication phase so that she obtains both parties' keys. This enables her to decrypt and view messages that were not intended for her. Using digital signatures during the session-key exchange can circumvent the man-in-the-middle attack. If using kerberos, when Lance and Tanya obtain each other's public keys from the KDC, the public keys are signed by the KDC. Because Tanya and Lanace have the public key of the KDC, they both can decrypt and verify the signature on each other's public key and be sure that it came from the KDC itself. Because David does not have the private key of the KDC, he cannot substitute his pubic key during this type of transmission. Shon Harris All-In-One CISSP Certification pg. 579.

One of the most important pieces a PKI is its public key certificate. A certificate is the mechanism used to associate a public key with a collection of components sufficient to uniquely authenticate the claimed owner. Shon Harris All-In-One CISSP Certification pg. 540.

QUESTION NO: 930

Secure Shell (SSH) and Secure Sockets Layer (SSL) are very heavily used for protecting

- A. Internet transactions
- B. Ethernet transactions
- C. Telnet transactions
- D. Electronic Payment transactions

Answer: A

Explanation:

QUESTION NO: 931

Which one of the following CANNOT be prevented by the Secure Shell (SSH) program?

- A. Internet Protocol (IP) spoofing.
- B. Data manipulation during transmissions.
- C. Network based birthday attack.
- D. Compromise of the source/destination host.

Answer: D

Explanation: This is a question that I disagreed with. The premises that SSH does use RSA and 3DES, thus susceptible to cryptographic attack (namely birthday attack) has merit but I think the answer is more simple, in that you SSH can't protect against a compromised source/destination. You can safely rule out spoofing and manipulation (that is the job of ssh to protect the transmission). Original answer was C birthday attack. Use your best judgment based on knowledge and experience.

The use of ssh helps to correct these vulnerabilities. Specifically, ssh protects against these attacks: IP spoofing (where the spoofer is on either a remote or local host), IP source routing, DNS spoofing, interception of cleartext passwords/data and attacks based on listening to X authentication data and spoofed connections to an X11 server. http://www-arc.com/sara/cve/SSH_vulnerabilities.html

Birthday attack - Usually applied to the probability of two different messages using the same hash function that produces a common message digest; or given a message and its corresponding message digest, finding another message that when passed through the same hash function generates the same specific message digest. The term "birthday" comes from the fact that in a room with 23 people, the probability of two people having the same birthday is great than 50 percent. -Ronald Krutz The CISSP PREP Guide (gold edition) pg 212

QUESTION NO: 932

Another name for a VPN is a:

- A. tunnel
- B. one-time password
- C. pipeline
- D. bypass

Answer: A

Explanation:

QUESTION NO: 933

Which one of the following attacks is MOST effective against an Internet Protocol Security (IPSEC) based virtual private network (VPN)?

- A. Brute force
- B. Man-in-the-middle
- C. Traffic analysis
- D. Replay

Answer: B

Explanation: Active attacks find identities by being a man-in-the-middle or by replacing the responder in the negotiation. The attacker proceeds through the key negotiation with the attackee until the attackee has revealed its identity. In a well-designed system, the negotiation will fail after the attackee has revealed its identity because the attacker cannot spoof the identity of the originally-intended system.

The attackee might then suspect that there was an attack because the other side failed before it gave its identity. Therefore, an active attack cannot be persistent because it would prevent all legitimate access to the desired IPsec system.

<http://msgs.securepoint.com/cgi-bin/get/ipsec-0201/18.html>

Not C: Traffic analysis is a good attack but not the most effective as it is passive in nature, while Man in the middle is active.

QUESTION NO: 934

Which of the following is NOT an essential component of a VPN?

- A. VPN Server
- B. NAT Server
- C. authentication

D. encryption

Answer: B

Explanation:

QUESTION NO: 935

Virtual Private Network software typically encrypts all of the following EXCEPT

- A. File transfer protocol
- B. Data link messaging
- C. HTTP protocol
- D. Session information

Answer: B

Explanation:

QUESTION NO: 936

Which of the following is less likely to be used in creating a Virtual Private Network?

- A. L2TP
- B. PPTP
- C. IPSec
- D. L2F

Answer: D

Explanation: "The following are the three most common VPN communications protocol standards:

Point-to-Point Tunneling Protocol(PPTP). PPTP works at the Data Link Layer of the OSI model. Designed for individual client to server connections, it enables only a single point-to-point connection per session. This standard is very common with asynchronous connections that use Win9x or NT clients. PPTP uses native Point-to-Point Protocol (PPP) authentication and encryption services.

Layer 2 Tunneling Protocol (L2TP). L2TP is a combination of PPTP and the earlier Layer 2

Forwarding (L2F) Protocol that works at the Data Link Layer like PPTP. It has become an accepted tunneling standard for VPN's. In fact, dial-up VPNs use this standard quite frequently. Like PPTP, this standard was designed for single point-to-point client to server connections. Not that multiple protocols can be encapsulated within the L2TP tunnel, but do not use encryption like PPTP. Also, L2TP supports TACACS+ and RADIUS, but PPTP does not.

IPSEC. IPsec operates at the Network Layer and it enables multiple and simultaneous tunnels, unlike the single connection of the previous standards. IPsec has the functionality to encrypt and authenticate IP data. It is built into the new Ipv6 standard, and is used as an add-on to the current Ipv4. While PPTP and L2TP are aimed more at dial-up VPNs, IPsec focuses more on network-to-network connectivity." Pg. 123-125 Krutz: The CISSP Prep Guide: Gold Edition.

QUESTION NO: 937

Which one of the following instigates a SYN flood attack?

- A. Generating excessive broadcast packets.
- B. Creating a high number of half-open connections.
- C. Inserting repetitive Internet Relay Chat (IRC) messages.
- D. A large number of Internet Control Message Protocol (ICMP) traces.

Answer: B

Explanation: A SYN attack occurs when an attacker exploits the use of the buffer space during a Transmission Control Protocol (TCP) session initialization handshake. The attacker floods the target system's small "in-process" queue with connection requests, but it does not respond when a target system replies to those requests. This causes the target system to time out while waiting for the proper response, which makes the system crash or become unusable. -Ronald Krutz The CISSP PREP Guide (gold edition) pg 103

"In a SYN flood attack, hackers use special software that sends a large number of fake packets with the SYN flag set to the targeted system. The victim then reserves space in memory for the connection and attempts to send the standard SYN/ACK reply but never hears back from the originator. This process repeats hundreds or even thousands of times, and the targeted computer eventually becomes overwhelmed and runs out of available resources for the half-opened connections. At that time, it either crashes or simply ignores all inbound connection requests because it can't possibly handle any more half-open connections." Pg 266 Tittel: CISSP Study

Guide.

QUESTION NO: 938

Which one of the following is defined as the process of distributing incorrect Internet Protocol (IP) addresses/names with the intent of diverting traffic?

- A. Network aliasing
- B. Domain Name Server (DNS) poisoning
- C. Reverse Address Resolution Protocol (ARP)
- D. Port scanning

Answer: B

Explanation: This reference is close to the one listed DNS poisoning is the correct answer however, Harris does not say the name when describing the attack but later on the page she state the following.

This is how DNS DOS attack can occur. If the actual DNS records are unattainable to the attacker for him to alter in this fashion, which they should be, the attacker can insert this data into the cache of there server instead of replacing the actual records, which is referred to as cache poisoning. - Shon Harris All-in-one CISSP Certification Guide pg 795

QUESTION NO: 939

A Packet containing a long string of NOP's followed by a command is usually indicative of what?

- A. A syn scan
- B. A half-port scan
- C. A buffer overflow
- D. A packet destined for the network's broadcast address

Answer: C

Explanation: Reference "This paper is for those who want a practical approach to writing buffer overflow exploits. As the title says, this text will teach you how to write these exploits in Perl.

.....

There are reasons why we construct the buffer this way. First we have a lot of NOPs, then the shellcode (which in this example will execute /bin/sh), and at last the ESP + offset values." <http://hackersplayground.org/papers/perl-buffer.txt>

QUESTION NO: 940

You are running a packet sniffer on a network and see a packet with a long string of long string of "90 90 90 90...." in the middle of it traveling to an x86-based machine. This could be indicative of what?

- A. Over-subscription of the traffic on a backbone
- B. A source quench packet
- C. a FIN scan
- D. A buffer overflow

Answer: D

Reference: "TCP Port 5000 Buffer Overflow Attack

The attack on Port 5000 was part of this scan pattern

```
Mar 14, 2004 15:58:17.837 - (TCP) 68.144.13.102 : 2282 >>> 192.168.1.36 : 2745
Mar 14, 2004 15:58:17.857 - (TCP) 68.144.13.102 : 2283 >>> 68.144.193.246 : 135
Mar 14, 2004 15:58:17.887 - (TCP) 68.144.13.102 : 2284 >>> 192.168.1.38 : 1025
Mar 14, 2004 15:58:17.907 - (TCP) 68.144.13.102 : 2285 >>> 68.144.193.246 : 445
Mar 14, 2004 15:58:17.938 - (TCP) 68.144.13.102 : 2286 >>> 192.168.1.36 : 3127
Mar 14, 2004 15:58:17.958 - (TCP) 68.144.13.102 : 2287 >>> 68.144.193.246 : 6129
Mar 14, 2004 15:58:17.988 - (TCP) 68.144.13.102 : 2288 >>> 68.144.193.246 : 139
Mar 14, 2004 15:58:18.008 - (TCP) 68.144.13.102 : 2289 >>> 192.168.1.36 : 5000
Mar 14, 2004 15:58:29.164 - (TCP) 68.144.13.102 : 1442 >>> 68.144.193.246 : 1981
Mar 14, 2004 15:58:33.470 - (TCP) 68.144.13.102 : 1442 >>> 68.144.193.246 : 1981
Mar 14, 2004 15:58:39.288 - (TCP) 68.144.13.102 : 1442 >>> 68.144.193.246 : 1981
```

The attack appears to be a buffer overflow attack on the Plug and Play service on TCP Port 5000, which likely contains instructions to download and execute the rest of the worm.

TCP Connection Request

---- 14/03/2004 15:40:57.910

68.144.193.124 : 4560 TCP Connected ID = 1

---- 14/03/2004 15:40:57.910

Status Code: 0 OK

68.144.193.124 : 4560 TCP Data In Length 697 bytes

MD5 = 19323C2EA6F5FCEE2382690100455C17

---- 14/03/2004 15:40:57.920

```
0000 90 90 90 90 90 90 90 90 90 90 90 90 90 90 90 .....
0010 90 90 90 90 90 90 90 90 90 90 90 90 90 90 90 .....
0020 90 90 90 90 90 90 90 90 90 90 90 90 90 90 90 .....
0030 90 90 90 90 90 90 90 90 90 90 90 90 90 90 90 .....
0040 90 90 90 90 90 90 90 90 90 90 90 90 90 90 90 .....
0050 90 90 90 90 90 90 90 90 90 90 90 90 90 90 90 .....
0060 90 90 90 90 90 90 90 90 90 90 90 90 90 90 90 .....
0070 90 90 90 90 90 90 90 90 90 90 90 90 90 90 90 .....
0080 90 90 90 90 90 90 90 90 90 90 90 90 90 90 90 .....
0090 90 90 90 90 90 90 90 90 90 90 90 90 90 90 .....
00A0 90 90 90 90 90 90 90 90 90 90 90 90 90 90 .....
00B0 90 90 90 90 90 90 90 90 90 90 90 90 90 90 .....
00C0 90 90 90 90 90 90 90 90 90 90 90 90 90 90 .....
00D0 90 90 90 90 90 90 90 90 90 90 90 90 90 90 .....
00E0 90 90 90 90 90 90 90 90 90 90 90 90 90 90 .....
00F0 90 90 90 90 90 90 90 90 90 90 90 90 90 90 .....
```


02B0 FA FC E9 ED 99 0D 0A 0D 0A "
http://www.linklogger.com/TCP5000_Overflow.htm

QUESTION NO: 941

Which of the following is true related to network sniffing?

- A.** Sniffers allow an attacker to monitor data passing across a network.
- B.** Sniffers alter the source address of a computer to disguise and exploit weak authentication methods.
- C.** Sniffers take over network connections
- D.** Sniffers send IP fragments to a system that overlap with each other.

Answer: A

Explanation: Sniffing is the action of capture / monitor the traffic going over the network.

Because, in a normal networking environment, account and password information is passed along Ethernet in clear-text, it is not hard for an intruder to put a machine into promiscuous mode and by sniffing, compromise all the machines on the net by capturing password in an illegal fashion.

QUESTION NO: 942

Which one of the following threats does NOT rely on packet size or large volumes of data?

- A.** SYN flood
- B.** Spam
- C.** Ping of death
- D.** Macro virus

Answer: D

Explanation: SPAM - The term describing unwanted email, newsgroup, or discussion forum messages. Spam can be innocuous as an advertisement from a well-meaning vendor or as malignant as floods or unrequested messages with viruses or Trojan horses attached

SYN Flood Attack - A type of DoS. A Syn flood attack is waged by not sending the final ACK packet, which breaks the standard three-way handshake used by TCP/IP to initiate communication

sessions.

Ping of death attack - A type of DoS. A ping of death attack employs an oversized ping packet. Using special tools, an attacker can send numerous oversized ping packets to a victim. In many cases, when the victimized system attempts to process the packets, an error occurs causing the system to freeze, crash, or reboot.

Macro Viruses - A virus that utilizes crude technologies to infect documents created in the Microsoft Word environment.

- Ed Tittle CISSP Study Guide (sybex) pg 550 740, 743, 723, 713

QUESTION NO: 943

A TCP SYN Attack:

- A. requires a synchronized effort by multiple attackers
- B. takes advantage of the way a TCP session is established
- C. may result in elevation of privileges.
- D. is not something system users would notice

Answer: B

Explanation: "[SYN Flood] Attackers can take advantage of this design flaw by continually sending the victim SYN messages with spoofed packets. The victim will commit the necessary resources to setup this communication socket, and it will send its SYN/ACK message waiting for the ACK message in return. However, the victim will never receive the ACK message, because the packet is spoofed, and victim system sent the SYN/ACK message to a computer that does not exist. So the victim system receives a SYN message, add it dutifully commits the necessary resources to setup a connection with another computer. This connection is queued waiting for the ACK message, and the attacker sends another SYN message. The victim system does what is supposed to can commits more resources, sends the SYN/ACK message, and queues this connection. This may only need to happen a dozen times before the victim system no longer has the necessary resources to open up another connection. This makes the victim computer unreachable from legitimate computers, denying other systems service from the victim computer." Pg. 735 Shon Harris CISSP All-In-One Exam Guide

QUESTION NO: 944

What attack is typically used for identifying the topology of the target network?

- A. Spoofing
- B. Brute force
- C. Teardrop
- D. Scanning

Answer: D

Explanation:

Flaw exploitation attacks exploit a flaw in the target system's software in order to cause a processing failure or to cause it to exhaust system resources. An example of such a processing failure is the 'ping of death' attack. This attack involved sending an unexpectedly large ping packet to certain Windows systems. The target system could not handle this abnormal packet, and a system crash resulted. With respect to resource exhaustion attacks, the resources targeted include CPU time, memory, disk space, space in a special buffer, or network bandwidth. In many cases, simply patching the software can circumvent this type of DOS attack.

QUESTION NO: 945

Which one of the following is the reason for why hyperlink spoofing attacks are usually successful?

- A. Most users requesting DNS name service do not follow hyperlinks.
- B. The attack performs user authentication with audit logs.
- C. The attack relies on modifications to server software.
- D. Most users do not make a request to connect to a DNS names, they follow hyperlinks.

Answer: D

Explanation:

The problem is that most users do not request to connect to DNS names or even URLs, they follow hyperlinks... But, whereas DNS names are subject to "DNS spoofing" (whereby a DNS server lies about the internet address of a server) so too are URLs subject to what I call "hyperlink spoofing" or "Trojan HTML", whereby a page lies about an URLs DNS name. Both forms of spoofing have the same effect of steering you to the wrong internet site, however hyperlink spoofing is technically much easier than DNS spoofing.

<http://www.brd.ie/papers/sslpaper/sslpaper.html>

QUESTION NO: 946

Which of the following identifies the first phase of a Distributed Denial of Service attack?

- A. Establishing communications between the handler and agent.
- B. Disrupting the normal traffic to the host.
- C. Disabling the router so it cannot filter traffic.
- D. Compromising as many machines as possible.

Answer: D

Explanation: Another form of attack is called the distributed denial of service (DDOS). A distributed denial of service occurs when the attacker compromises several systems and uses them as launching platforms against one or more victims. - Ed Tittle CISSP Study Guide (sybex) pg 51

QUESTION NO: 947

This type of vulnerability enables the intruder to re-route data traffic from a network device to a personal machine? This diversion enables the intruder to capture data traffic to and from the devices for analysis or modification, or to steal the password file from the server and gain access to user accounts.

- A. Network Address Translation
- B. Network Address Hijacking
- C. Network Address Supernetting
- D. Network Address Sniffing

Answer: B

Explanation: "Network Address Hijacking. It might be possible for an intruder to reroute data traffic from a server or network device to a personal machine, either by device address modification or network address "hijacking." This diversion enables the intruder to capture traffic to and from the devices for data analysis or modification or to steal the password file from the server and gain access to user accounts. By rerouting the data output, the intruder can obtain supervisory terminal functions and bypass the system logs."

QUESTION NO: 948

Which one of the following is an example of hyperlink spoofing?

- A. Compromising a web server Domain Name Service reference.
- B. Connecting the user to a different web server.
- C. Executing Hypertext Transport Protocol Secure GET commands.
- D. Starting the user's browser on a secured page.

Answer: B

Explanation: The problem is that most users do not request to connect to DNS names or even URLs, they follow hyperlinks... But, whereas DNS names are subject to "DNS spoofing" (whereby a DNS server lies about the internet address of a server) so too are URLs subject to what I call "hyperlink spoofing" or "Trojan HTML", whereby a page lies about an URLs DNS name. Both forms of spoofing have the same effect of steering you to the wrong internet site, however hyperlink spoofing is technically much easier than DNS spoofing.

<http://www.brd.ie/papers/sslpaper/sslpaper.html>

QUESTION NO: 949

Why are packet filtering routers NOT effective against mail bomb attacks?

- A. The bomb code is obscured by the message encoding algorithm.
- B. Mail bombs are polymorphic and present no consistent signature to filter on.
- C. Filters do not examine the data portion of a packet.
- D. The bomb code is hidden in the header and appears as a normal routing information.

Answer: C

Explanation:

QUESTION NO: 950

Which one of the following correctly identifies the components of a Distributed Denial of Service Attack?

- A. Node, server, hacker, destination
- B. Client, handler, agent, target
- C. Source, destination, client, server
- D. Attacker, proxy, handler, agent

Answer: B

Explanation: Another form of DoS. A distributed denial of service occurs when the attacker compromises several systems to be used as launching platforms against one or more victims. The compromised systems used in the attacks are often called clones or zombies. A DDoS attack results in the victims being flooded with data from numerous sources. - Ed Tittle CISSP Study Guide (sybex) pg 693

QUESTION NO: 951

Which one of the following attacks will pass through a network layer intrusion detection system undetected?

- A. A teardrop attack
- B. A SYN flood attack
- C. A DNS spoofing attack
- D. A test.cgi attack

Answer: D

Explanation:

"Because a network-based IDS reviews packets and headers, it can also detect denial of service (DoS) attacks." Pg. 64 Krutz: The CISSP Prep Guide

Not A or B:

"The following sections discuss some of the possible DoS attacks available.

Smurf

Fraggle
SYN Flood
Teardrop
DNS DoS Attacks”

Pg. 732-737 Shon Harris: All-In-One CISSP Certification Exam Guide

QUESTION NO: 952

Which one of the following is a passive network attack?

- A. Spoofing
- B. Traffic Analysis
- C. Playback
- D. Masquerading

Answer: B

Explanation:

“Traffic analysis and trend analysis are forms of monitoring that examine the flow of packets rather than the actual content of packets. Traffic and trend analysis can be used to infer a large amount of information, such as primary communication routes, sources of encrypted traffic, location of primary servers, primary and backup communication pathways, amount of traffic supported by the network, typical direction of traffic flow, frequency of communications, and much more.” Pg 429
Tittel: CISSP Study Guide

QUESTION NO: 953

Which one of the following can NOT typically be accomplished using a Man-in-the-middle attack?

- A. DNS spoofing
- B. Session hijacking
- C. Denial of service flooding
- D. Digital signature spoofing

Answer: D

Explanation:

QUESTION NO: 954

What is called an attack where the attacker spoofs the source IP address in an ICMP ECHO broadcast packet so it seems to have originated at the victim's system, in order to flood it with REPLY packets?

- A. SYN flood attack
- B. Smurf attack
- C. Ping of Dead Attack
- D. Denial of Service (DOS) Attack

Answer: B

Reference: pg 158 Hansche: Official (ISC)2 Guide to the CISSP Exam

QUESTION NO: 955

Which type of attack involves the alteration of a packet at the IP level to convince a system that it is communicating with a known entity in order to gain access to a system?

- A. TCP sequence number attack
- B. IP spoofing attack
- C. Piggybacking attack
- D. Teardrop attack

Answer: B

Explanation:

QUESTION NO: 956

What attack takes advantage of operating system buffer overflows?

- A. Spoofing
- B. Brute force
- C. DoS
- D. Exhaustive

Answer: C

Explanation:

Denial of Service is an attack on the operating system or software using buffer overflows. The result is that the target is unable to reply to service requests. This is too a large an area of information to try to cover here, so I will limit my discussion to the types of denial of service (DoS) attacks:

QUESTION NO: 957

What attack is primarily based on the fragmentation implementation of IP and large ICMP packet size?

- A. Exhaustive
- B. Brute force
- C. Ping of Death
- D. Spoofing

Answer: C

Explanation:

Ping of Death -- This exploit is based on the fragmentation implementation of IP whereby large packets are reassembled and can cause machines to crash. 'Ping of Death takes advantage of the fact that it is possible to send an illegal ICMP Echo packet with more than the allowable 65, 507 octets of data because of the way fragmentation is performed. A temporary fix is block ping packets. Ideally, an engineer should secure TCP/IP from overflow when reconstructing IP fragments.

QUESTION NO: 958

Land attack attacks a target by:

- A. Producing large volume of ICMP echos.
- B. Producing fragmented IP packets.
- C. Attacking an established TCP connection.
- D. None of the choices.

Answer: C

Explanation:

Land.c. attack -- Attacks an established TCP connection. A program sends a TCP SYN packet giving the target host address as both the sender and destination using the same port causing the OS to hang.

QUESTION NO: 959

What attack is primarily based on the fragmentation implementation of IP?

- A. Teardrop
- B. Exhaustive
- C. Spoofing
- D. Brute force

Answer: A

Explanation:

Teardrop attack - This is based on the fragmentation implementation of IP whereby reassembly problems can cause machines to crash. The attack uses a reassembly bug with overlapping fragments and causes systems to hang or crash. It works for any Internet Protocol type because it hits the IP layer itself. Engineers should turn off directed broadcast capability.

QUESTION NO: 960

What attack floods networks with broadcast traffic so that the network is congested?

- A. Spoofing
- B. Teardrop
- C. Brute force
- D. SMURF

Answer: D

Explanation:

SMURF attack -- This attack floods networks with broadcast traffic so that the network is congested. The perpetrator sends a large number of spoofed ICMP (Internet Control Message Protocol) echo requests to broadcast addresses hoping packets will be sent to the spoofed addresses. You need to understand the OSI model and how protocols are transferred between layer 3 and layer 2 to understand this attack. The layer 2 will respond to the ICMP echo request with an ICMP echo reply each time, multiplying the traffic by the number of hosts involved. Engineers should turn off broadcast capability (if possible in your environment) to deter this kind of attack.

QUESTION NO: 961

What attack involves repeatedly sending identical e-message to a particular address?

- A. SMURF
- B. Brute force
- C. Teardrop
- D. Spamming

Answer: D

Explanation:

Spamming -- Involves repeatedly sending identical e-message to a particular address. It is a variant of bombing, and is made worse when the recipient replies -- i.e. recent cases where viruses or worms were attached to the e-mail message and ran a program that forwarded the message from the reader to any one on the user's distribution lists. This attack cannot be prevented, but you should ensure that entrance and exit of such mail is only through central mail hubs.

QUESTION NO: 962

A stack overflow attack that "crashes" a Transmission Control Protocol/Internet Protocol (TCP/IP) service daemon can result in a serious security breach because the

- A. Process does not implement proper object reuse.
- B. Process is executed by a privileged entity.
- C. Network interface becomes promiscuous.
- D. Daemon can be replaced by a trojan horse.

Answer: B

Explanation:

QUESTION NO: 963

The intrusion detection system at your site has detected Internet Protocol (IP) packets where the IP source address is the same as the destination address.

This situation indicates

- A. Misdirected traffic jammed to the internal network.
- B. A denial of service attack.
- C. An error in the internal address matrix.
- D. A hyper overflow in the IP stack.

Answer: B

Explanation: "The Land denial of service attack causes many older operating systems (such as Windows NT 4, Windows 95, and SunOS 4.1.4) to freeze and behave in an unpredictable manner.

It works by creating an artificial TCP packet that has the SYN flag set. The attacker set the destination IP address to the address of the victim machine and the destination port to an open port on that machine. Next, the attacker set the source IP address and source port to the same values as the destination IP address and port. When the targeted host receives this unusual packet, the operating system doesn't know how to process it and freezes, crashes, or behaves in an unusual manner as a result." Pg 237 Tittel: CISSP Study Guide

QUESTION NO: 964

What type of attacks occurs when a rogue application has been planted on an unsuspecting user's workstation?

- A. Physical attacks
- B. Logical attacks
- C. Trojan Horse attacks
- D. Social Engineering attacks

Answer: C

Explanation:

Trojan Horse attacks - This attack involves a rogue, Trojan horse application that has been planted on an unsuspecting user's workstation. The Trojan horse waits until the user submits a valid PIN from a trusted application, thus enabling usage of the private key, and then asks the smartcard to digitally sign some rogue data. The operation completes but the user never knows that their private key was just used against their will.

QUESTION NO: 965

Man-in-the-middle attacks are a real threat to what type of communication?

- A. Communication based on random challenge.
- B. Communication based on face to face contact.

- C. Communication based on token.
- D. Communication based on asymmetric encryption.

Answer: D

Explanation:

The weakest point in the communication based on asymmetric encryption is the knowledge about the real owners of keys. Somebody evil could generate a key pair, give the public key away and tell everybody, that it belongs to somebody else. Now, everyone believing it will use this key for encryption, resulting in the evil man being able to read the messages. If he encrypts the messages again with the public key of the real recipient, he will not be easily recognized. This sort of attack is called ``man-in-the-middle" attack and can only be prevented by making sure, public keys really belong to the one being designated as owner.

QUESTION NO: 966

Which of the following threats is not addressed by digital signature and token technologies?

- A. Spoofing
- B. replay attacks
- C. password compromise
- D. denial-of-service

Answer: D

Explanation:

QUESTION NO: 967

Which one of the following is concerned with masking the frequency, length, and origin-destination patterns of the communications between protocol entities?

- A. Masking analysis
- B. Protocol analysis
- C. Traffic analysis
- D. Pattern analysis

Answer: C

Explanation: Traffic analysis, which is sometimes called trend analysis, is a technique employed by an intruder that involves analyzing data characteristics (message length, message frequency, and so forth) and the patterns of transmissions (rather than any knowledge of the actual information transmitted) to infer information that is useful to an intruder) . -Ronald Krutz The CISSP PREP Guide (gold edition) pg 323

QUESTION NO: 968

Which of the following would NOT be considered a Denial of Service Attack?

- A. Zone Transfer
- B. Smurf
- C. Syn Flood
- D. TearDrop

Answer: A

Explanation: Zone transfer is method that DNS uses to transfer zone information between servers. In some un-secure DNS installations zone transfers are allowed to un-trusted DNS servers. This allows the hacker to determine internal host names and ip addresses to provide additional information for an attack.

QUESTION NO: 969

The connection using fiber optics from a phone company's branch office to local customers is which of the following?

- A. new loop
- B. local loop
- C. loopback
- D. indigenous loop

Answer: B

Explanation: In telecommunications Telecommunication the local loop is the wiring between the central office and the customer's premises demarcation point. The telephony local loop connection is typically a copper twisted pair carrying current from the central office to the customer premises and back again. Individual local loop telephone lines are connected to the local central office or to

a remote concentrator.

Local loop connections can be used to carry a range of technologies, including:

Analog Voice

ISDN

DSL

QUESTION NO: 970

Which step ensures the confidentiality of a facsimile transmission?

- A. Pre-schedule the transmission of the information.
- B. Locate the facsimile equipment in a private area.
- C. Encrypt the transmission.
- D. Phone ahead to the intended recipient.

Answer: C

Explanation:

QUESTION NO: 971

Which one of the following could a company implement to help reduce PBX fraud?

- A. Call vectoring
- B. Direct Inward System Access (DISA)
- C. Teleconferencing bridges
- D. Remote maintenance ports

Answer: B

Explanation: The potential for fraud to occur in voice telecommunications equipment is a serious threat. PBX's (Private Branch Exchange) are telephone switches used within state agencies to allow employees to make out-going and receive in- coming phone calls. These PBX's can also provide connections for communications between personal computers and local and wide area networks. Security measures must be taken to avoid the possibility of theft of either phone service or information through the telephone systems.

Direct Inward System Access (DISA) is the ability to call into a PBX, either on an 800 number or a local dial-in, and by using an authorization code, gain access to the long distance lines and place long distance calls through the PBX

<http://www.all.net/books/Texas/chap10.html>

QUESTION NO: 972

Phreakers are hackers who specialize in telephone fraud. What type of telephone fraud manipulates the line voltage to receive a toll-free call?

- A. Red boxes
- B. Blue boxes
- C. White boxes
- D. Black boxes

Answer: D

Explanation:

QUESTION NO: 973

Which one of the following devices might be used to commit telecommunications fraud using the "shoulder surfing" technique?

- A. Magnetic stripe copier
- B. Tone generator
- C. Tone recorder
- D. Video recorder

Answer: C

Explanation:

QUESTION NO: 974

What technique is used to prevent eavesdropping of digital cellular telephone conversations?

- A. Encryption
- B. Authentication
- C. Call detail suppression
- D. Time-division multiplexing

Answer: D

Explanation: The name "TDMA"(Time Division Multiple Access) is also used to refer to a specific second generation mobile phone standard - more properly referred to as IS-136, which uses the TDMA technique to timeshare the bandwidth of the carrier wave. It provides between 3 to 6 times the capacity of its predecessor AMPS, and also improved security and privacy. In the United States, for example, AT&T Wireless uses the IS-136 TDMA standard. Prior to the introduction of IS-136, there was another TDMA North American digital cellular standard called IS-54(which was also referred to just as "TDMA").

QUESTION NO: 975

Which of the following is a telecommunication device that translates data from digital to analog form and back to digital?

- A. Multiplexer
- B. Modem
- C. Protocol converter
- D. Concentrator

Answer: B

Topic 9, Business Continuity Planning

QUESTION NO: 976

Which of the following could lead to the conclusion that a disaster recovery plan may not be

operational within the timeframe the business needs to recover?

- A.)The alternate site is a warm site
- B. Critical recovery priority levels are not defined
- C. Offsite backups are located away from the alternate site
- D. The alternate site is located 70 miles away from the primary site

Answer: B

Explanation:

QUESTION NO: 977

What are the four domains of communication in the disaster planning and recovery process?

- A. Plan manual, plan communication, primer for survival, warning and alarms
- B. Plan communication, primer for survival, escalation, declaration
- C. Plan manual, warning and alarm, declaration, primer for survival
- D. Primer for survival, escalation, plan communication, warning and alarm

Answer: C

Explanation:

QUESTION NO: 978

The underlying reason for creating a disaster planning and recover strategy is to

- A. Mitigate risks associated with disaster.
- B. Enable a business to continue functioning without impact.
- C. Protect the organization's people, place and processes.
- D. Minimize financial profile.

Answer: A

Explanation: "Disaster recovery has the goal of minimizing the effects of a disaster and taking the necessary steps to ensure that the resources, personnel, and business processes are able to resume operation in a timely manner." Pg 550 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 979

Which of the following is not a direct benefit of successful Disaster Recovery Planning?

- A. Maintain Nance of Business Continuity
- B. Protection of Critical Data
- C. Increase in IS performance
- D. Minimized Impact of a disaster

Answer: C

Explanation:

QUESTION NO: 980

Organizations should not view disaster recovery as which of the following?

- A. committed expense
- B. discretionary expense
- C. enforcement of legal statues
- D. compliance with regulations

Answer: B

Explanation:

QUESTION NO: 981

Which of the following statements pertaining to disaster recovery is incorrect?

- A. A recovery team's primary task is to get the pre-defined critical business functions at the alternate backup processing site.
- B. A salvage team's task is to ensure that the primary site returns to normal processing conditions
- C. The disaster recovery plan should include how the company will return from the alternate site to the primary site
- D. When returning to the primary site, the most critical applications should be brought back first

Answer: D

Explanation:

QUESTION NO: 982

Which of the following statements pertaining to dealing with the media after a disaster occurred and disturbed the organization's activities is incorrect?

- A. The CEO should always be the spokesperson for the company during a disaster
- B. The disaster recovery plan must include how the media is to be handled during the disaster
- C. The organization's spokesperson should report bad news before the press gets ahold of it through another channel
- D. An emergency press conference site should be planned ahead

Answer: A

Explanation:

QUESTION NO: 983

What is a disaster recovery plan for a company's computer system usually focused on?

- A. Alternative procedures to process transactions
- B. The probability that a disaster will occur
- C. Strategic long-range planning
- D. Availability of compatible equipment at a hot site

Answer: A

Explanation:

QUESTION NO: 984

What is the most critical piece to disaster recovery and continuity planning?

- A. Security Policy
- B. Management Support
- C. Availability of backup information processing facilities

D. Staff training

Answer: B

Explanation:

QUESTION NO: 985

Which of the following is the most important consideration in locating an alternate computing facility during the development of a disaster recovery plan?

- A. it is unlikely to be affected by the same contingency
- B. it is close enough to become operation quickly
- C. is it close enough to serve it's users
- D. it is convenient to airports and hotels

Answer: A

Explanation:

QUESTION NO: 986

Which of the following are PRIMARY elements that are required when designing a Disaster Recovery Plan (DRP)?

- A. Back-up procedures, off-site storage, and data recover.
- B. Steering committee, emergency response team, and reconstruction team.
- C. Impact assessment, recover strategy, and testing.
- D. Insurance coverage, alternate site, and manual procedures.

Answer: C

Explanation: The most critical piece to disaster recovery and continuity planning is management support. They must be convinced of its necessity. Therefore, a business case must be made to obtain this support. The business case can include current vulnerabilities, regulatory and legal obligations, current status of recovery plans, and recommendations. Management will mostly concerned with cost/benefit issues, so several preliminary numbers will need to be gathered and potential losses estimated. - Shon Harris All-in-one CISSP Certification Guide pg 595

There are four major elements of the BCP process

Scope and Plan Initiation - this phase marks the beginning of the BCP process. IT entails creating

the scope and other elements needed to define the parameters of the plan.

Business Impact Assessment - A BIA is a process used to help business units understand the impact of a disruptive event. This phase includes the execution of a vulnerability assessment

Business Continuity Plan Development - This term refers to using the information collection in the BIA to develop the actual business continuity plan. This process includes the areas of plan implementation, plan testing, and ongoing plan maintenance.

Plan Approval and Implementation - This process involves getting the final senior management signoff, creating enterprise-wide awareness of the plan, and implementing a maintenance procedure for updating the plan as needed. -Ronald Krutz The CISSP PREP Guide (gold edition) pg 380-381

QUESTION NO: 987

Emergency actions are taken at the incipient stage of a disaster with the objectives of preventing injuries or loss of life and of:

- A. determining the extent of property damage
- B. protecting evidence
- C. preventing looting and further damage
- D. mitigating the damage to avoid the need for recovery

Answer: D

Explanation:

QUESTION NO: 988

Who should direct short-term recovery actions immediately following a disaster?

- A. Chief Information Officer
- B. Chief Operating Officer
- C. Disaster Recovery Manager
- D. Chief Executive Officer

Answer: C

Explanation:

QUESTION NO: 989

The environment that must be protected includes all personnel, equipment, data, communication devices, power supply and wiring. The necessary level of protection depends on the value of data, the computer systems, and the company assets within the facility. The value of these items can be determined by what type of analysis?

- A. Critical-channel analysis
- B. Critical-route analysis
- C. Critical-path analysis
- D. Critical-conduit analysis

Answer: C

Explanation: "The environment that must be protected through physical security controls includes all personnel, equipment, data, communication devices, power supplies, and wiring. The necessary level of protection depends on the value of the data, the computer systems, and the company assets within the facility. The value of these items can be determined by a critical-path analysis, which lists each piece of the infrastructure and what is necessary to keep those pieces healthy and operational." Pg 255 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 990

Which of the following steps should be performed first in a business impact analysis (BIA)?

- A. Identify all business units within the organization
- B. Evaluate the impact of the disruptive events
- C. Estimate the Recovery Time Objectives (RTO)
- D. Evaluate the criticality of business functions

Answer: A

Explanation:

QUESTION NO: 991

Which of the following steps is NOT one of the four steps of a Business Impact Analysis (BIA)?

- A. Notifying senior management
- B. Gathering the needed assessment materials
- C. Performing the vulnerability assessment
- D. Analyzing the information compiled

Answer: A

Explanation: "A BIA generally takes the form of these four steps:

Pg. 383 Krutz: CISSP Prep Guide: Gold Edition.

QUESTION NO: 992

What methodology is commonly used in Business Continuity Program?

- A. Work Group Recovery
- B. Business Impact Analysis
- C. Qualitative Risk Analysis
- D. Quantitative Risk Analysis

Answer: B

Explanation: A BIA is performed at the beginning of disaster recovery and continuity planning to identify the areas that would suffer the greatest financial or operational loss in the event of a disaster or disruption. It identifies the company's critical systems needed for survival and estimates the outage time that can be tolerated by the company as a result of disaster or disruption. - Shon Harris All-in-one CISSP Certification Guide pg 597

QUESTION NO: 993

Which of the following steps should be performed first in a business impact analysis (BIA)?

- A. Identify all business units within an organization

- B. Evaluate the impact of disruptive events
- C. Estimate the Recovery Time Objectives (RTO)
- D. Evaluate the criticality of business functions

Answer: A

Explanation: "The initial step of the BIA is identifying which business units are critical to continuing an acceptable level of operations." Pg 383 Krutz: CISSP Prep Guide: Gold Edition.

QUESTION NO: 994

Which is not one of the primary goals of BIA?

- A. Criticality Prioritization
- B. Down time estimation
- C. Determining requirements for critical business functions
- D. Deciding on various test to be performed to validate Business Continuity Plan

Answer: D

Explanation:

QUESTION NO: 995

Which of the following is used to help business units understand the impact of a disruptive event?

- A. A risk analysis
- B. A Business Impact assessment
- C. A Vulnerability assessment
- D. A disaster recovery plan

Answer: B

Reference: "The purpose of a BIA is to create a document to be used to help understand what impact a disruptive event would have on the business." Pg 383 Krutz : CISSP Prep Guide: Gold Edition

QUESTION NO: 996

A Business Impact Analysis (BIA) does not:

- A. Recommend the appropriate recovery solution
- B. Determine critical and necessary business functions and their resource dependencies
- C. Identify critical computer applications and the associated outage tolerance
- D. Estimate the financial and operation impact of a disruption

Answer: A

Explanation:

QUESTION NO: 997

What assesses potential loss that could be caused by a disaster?

- A. The Business Assessment (BA)
- B. The Business Impact Analysis (BIA)
- C. The Risk Assessment (RA)
- D. The Business Continuity Plan (BCP)

Answer: B

Explanation:

QUESTION NO: 998

During the course of a Business Impact Analysis (BIA) you will less likely:

- A. Estimate the financial and operational impact of a disruption
- B. Identify regulatory exposure
- C. Determine if functions Recovery Time Objective (RTO)
- D. Determine the impact upon the organizations market share and corporate image

Answer: C

Explanation:

QUESTION NO: 999

Which of the following tasks is not usually part of a Business Impact Analysis (BIA)?

- A. Identify the type and quantity of resources required for recovery
- B. Identify the critical processes and the dependencies between them
- C. Identify organizational risks
- D. Develop a mission statement

Answer: D

Explanation:

QUESTION NO: 1000

Which of the following will a Business Impact Analysis (BIA) NOT identify?

- A. Areas that would suffer the greatest financial or operation loss in the event of a disaster
- B. Systems critical to the survival of the enterprise
- C. The names of individuals to be contacted during a disaster
- D. The outage time that can be tolerated by the enterprise as a result of a disaster

Answer: C

Explanation:

QUESTION NO: 1001

Which one the following is the primary goal of Business Continuity Planning?

- A. Sustain the organization.
- B. Recover from a major data center outage.
- C. Test the ability to prevent major outages.
- D. Satisfy audit requirements.

Answer: A

Explanation: Simply put, business continuity plans are created to prevent interruptions to normal business activity. -Ronald Krutz The CISSP PREP Guide (gold edition) pg 378

QUESTION NO: 1002

Most of unplanned downtime of information systems is attributed to which of the following?

- A. Hardware failure
- B. Natural disaster
- C. Human error
- D. Software failure

Answer: A

Explanation:

QUESTION NO: 1003

System reliability is increased by:

- A. A lower MTBF and a lower MTTR
- B. A higher MTBF and a lower MTTR
- C. A lower MTBF and a higher MTTR
- D. A higher MTBF and a higher MTTR

Answer: B

Explanation: One prefers to have a higher MTBF and a lower MTTR.

“Each device has a mean time between failure (MTBF) and a mean time to repair (MTTR). The MTBF estimate is used to determine the expected lifetime of a device or when an element within that device is expected to give out. The MTTR value is used to estimate the time it will take to repair the device and get it back into production.” Pg 267 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 1004

Which of the following is NOT a major element of Business Continuity Planning?

- A. Creation of a BCP committee
- B. Business Impact Assessment (BIA)
- C. Business Continuity Plan Development
- D. Scope plan initiation

Answer: A

Explanation:**QUESTION NO: 1005**

Which one of the following is a core infrastructure and service element of Business Continuity Planning (BCP) required to effectively support the business processes of an organization?

- A. Internal and external support functions.
- B. The change management process.
- C. The risk management process.
- D. Backup and restoration functions.

Answer: C

Explanation: Pg 383 Krutz Gold Edition. Backup is not BCP.

QUESTION NO: 1006

A business continuity plan should list and prioritize the services that need to be brought back after a disaster strikes. Which of the following services is more likely to be of primary concern?

- A. Marketing/Public relations
- B. Data/Telecomm/IS facilities
- C. IS Operations
- D. Facilities security

Answer: B

Explanation:

QUESTION NO: 1007

When preparing a business continuity plan, who of the following is responsible for identifying and prioritizing time-critical systems?

- A. Executive management staff
- B. Senior business unit management
- C. BCP committee
- D. Functional business units

Answer: B

Explanation:

QUESTION NO: 1008

Classification of information systems is essential in business continuity planning. Which of the following system types can not be replaced by manual methods?

- A. Critical System
- B. Vital System
- C. Sensitive System
- D. Non-critical system

Answer: A

Explanation:

QUESTION NO: 1009

A business continuity plan should list and prioritize the services that need to be brought back after a disaster strikes. Which of the following services is more likely to be of primary concern?

- A. Marketing/Public Relations
- B. Data/Telecomm/IS facilities
- C. IS Operations
- D. Facilities security

Answer: B

Explanation:

QUESTION NO: 1010

Business Continuity Plan development depends most on:

- A. Directives of Senior Management
- B. Business Impact Analysis (BIA)
- C. Scope and Plan Initiation
- D. Skills of BCP committee

Answer: B

Explanation:

QUESTION NO: 1011

Which primary element of BCP includes carrying out vulnerability analysis?

- A. Scope and Plan Initiation
- B. Business Impact Assessment
- C. Business Continuity Plan Development
- D. Plan Approval and Implementation

Answer: B

Explanation:

QUESTION NO: 1012

To mitigate the impact of a software vendor going out of business, a company that uses vendor software should require which one of the following?

- A. Detailed credit investigation prior to acquisition.
- B. Source code held in escrow.
- C. Standby contracts with other vendors.
- D. Substantial penalties for breach of contract.'

Answer: B

Explanation: The original answer was C however this is incorrect for this case. SLA and standby are good ideas but in this case B is right.

"A software escrow arrangement is a unique tool used to protect a company against the failure of a software developer to provide adequate support for its products or against the possibility that the developer will go out of business and no technical support will be available for the product....Under a software escrow agreement, the developer provides copies of the application source code to an

independent third-party organization. The third party then maintains updated backup copies of the source code in a secure fashion. The agreement between the end user and the developer specifies "trigger events", such as the failure of the developer to meet terms of a service level agreement (SLA) or the liquidation of the developer's firm." - Ed Tittle CISSP Study Guide (sybex) pg 550

QUESTION NO: 1013

Similarity between all recovery plans is:

- A. They need extensive testing
- B. They need to be developed by business continuity experts
- C. They become obsolete quickly
- D. They create employment opportunities

Answer: C

Explanation:

QUESTION NO: 1014

Which of the following focuses on sustaining an organizations business functions during and after a disruption?

- A. Business continuity plan
- B. Business recovery plan
- C. Continuity of operations plan
- D. Disaster recovery plan

Answer: A

Explanation:

QUESTION NO: 1015

What is not one of the drawbacks of a hot site?

- A.** Need Security controls, as it usually contain mirror copies of live production data
- B.** Full redundancy in hardware, software, communication lines, and applications lines is very expensive
- C.** The hot sites are available immediately or within maximum allowable downtime (MTD)
- D.** They are administratively resource intensive, as transaction redundancy controls need to be implemented to keep data up-to-date

Answer: C

Explanation:

QUESTION NO: 1016

Which one of the following processing alternatives involves a ready-to-use computing facility with telecommunications equipment, but not computers?

- A.** Company-owned hot site
- B.** Commercial hot site
- C.** Cold site
- D.** Warm site

Answer: D

Explanation: "Warm Site - These facilities are usually partially configured with some equipment, but not the actual computers." - Shon Harris All-in-one CISSP Certification Guide pg 613

QUESTION NO: 1017

What is a hot-site facility?

- A.** A site with pre-installed computers, raised flooring, air conditioning, telecommunications, and networking equipment, and UPS
- B.** A site in which space is reserved with pre-installed wiring and raised floors
- C.** A site with raised flooring, air conditioning, telecommunications, and networking equipment, and UPS
- D.** A site with ready made work space with telecommunications equipment, LANs, PCs, and terminals with work groups

Answer: A

Explanation:

QUESTION NO: 1018

Contracts and agreements are unenforceable in which of the following alternate back facilities?

- A. hot site
- B. warm site
- C. cold site
- D. reciprocal agreement

Answer: D

Explanation:

QUESTION NO: 1019

Which of the following computer recovery sites is the least expensive and the most difficulty to test?

- A. non-mobile hot site
- B. mobile hot site
- C. warm site
- D. cold site

Answer: D

Explanation:

QUESTION NO: 1020

Which of the following is an advantage of the use of hot sites as a backup alternative?

- A. The costs associated with hot sites are low
- B. Hot sites can be made ready for operation within a short period of time

- C. Hot sites can be used for an extended amount of time
- D. Hot sites do not require that equipment and systems software be compatible with the primary installation being backed up

Answer: B

Explanation:

QUESTION NO: 1021

What is not a benefit of Cold Sites?

- A. No resource contention with other organization
- B. Quick Recovery
- C. Geographical location that is not affected by the same disaster
- D. low cost

Answer: B

Explanation:

QUESTION NO: 1022

What is the PRIMARY reason that reciprocal agreements between independent organizations for backup processing capability are seldom used?

- A. Lack of successful recoveries using reciprocal agreements.
- B. Legal liability of the host site in the event that the recovery fails.
- C. Dissimilar equipment used by disaster recovery organization members.
- D. Difficulty in enforcing the reciprocal agreement.

Answer: D

Explanation: "Reciprocal agreements are at best a secondary option for disaster protection. The agreements are not enforceable, so there is no guarantee that this facility will really be available to the company in a time of need." Pg 615 Shon Harris CISSP All-In-One Certification Exam Guide

QUESTION NO: 1023

Which of the following alternative business recovery strategies would be LEAST appropriate in a large database and on-line communications network environment where the critical business continuity period is 7 days?

- A. Hot site
- B. Warm site
- C. Duplicate information processing facilities
- D. Reciprocal agreement

Answer: D

Explanation:

QUESTION NO: 1024

A contingency plan should address:

- A. Potential risks
- B. Residual risks
- C. Identified risks
- D. All of the above

Answer: B

Explanation:

QUESTION NO: 1025

Prior to a live disaster test, which of the following is most important?

- A. Restore all files in preparation for the test
- B. Document expected findings
- C. Arrange physical security for the test site
- D. Conduct a successful structured walk-through

Answer: D

Explanation:

QUESTION NO: 1026

Which of the following business continuity stages ensures the continuity strategy remains visible?

- A. Backup, Recover and Restoration
- B. Testing Strategy Development
- C. Post Recovery Transition Data Development
- D. Implementation, Testing and Maintenance

Answer: D

Explanation: Once the strategies have been decided upon, they need to be documented and put into place. This moves the efforts from a purely planning stage to an actual implementation and action phase...The disaster recovery and continuity plan should be tested periodically because an environment continually changes and each time it is tested, more improvements may be uncovered...The plan's maintenance can be incorporated into change management procedures so that any changes in the environment will be sure to be reflected in the plan itself. - Shon Harris All-in-one CISSP Certification Guide pg 611

QUESTION NO: 1027

During the testing of the business continuity plan (BCP), which of the following methods of results analysis provides the BEST assurance that the plan is workable?

- A. Measurement of accuracy
- B. Elapsed time for completion of critical tasks
- C. Quantitatively measuring the results of the test
- D. Evaluation of the observed test results

Answer: C

Explanation:

QUESTION NO: 1028

Which of the following recovery plan test results would be most useful to management?

- A. elapsed time to perform various activities
- B. list of successful and unsuccessful activities
- C. amount of work completed
- D. description of each activity

Answer: B

Explanation:

QUESTION NO: 1029

Failure of a contingency plan is usually:

- A. A technical failure
- B. A management failure
- C. Because of a lack of awareness
- D. Because of a lack of training

Answer: B

Explanation:

QUESTION NO: 1030

The first step in contingency planning is to perform:

- A. A hardware backup
- B. A data backup
- C. An operating system software backup
- D. An application software backup

Answer: B

Explanation:

QUESTION NO: 1031

Which of the following server contingency solutions offers the highest availability?

- A. System backups

- B. Electronic vaulting/remote journaling
- C. Redundant arrays of independent disks (RAID)
- D. Load balancing/disk replication

Answer: D

Explanation:

QUESTION NO: 1032

Which of the following statement pertaining to the maintenance of an IT contingency plan is incorrect?

- A. The plan should be reviewed at least once a year for accuracy and completeness
- B. The Contingency Planning Coordinator should make sure that every employee gets an up-to-date copy of the plan
- C. Strict version control should be maintained
- D. Copies of the plan should be provided to recovery personnel for storage at home and office

Answer: B

Explanation:

QUESTION NO: 1033

Which disaster recovery plan test involves functional representatives meeting to review the plan in detail?

- A. Simulation test
- B. Checklist test
- C. Parallel test
- D. Structured walkthrough test

Answer: D

Explanation: "Structured walk-through:

Pg 699 Hansche: Official (ISC)2 Guide to the CISSP Exam

QUESTION NO: 1034

What is the MAIN purpose of periodically testing off-site hardware backup facilities?

- A. To eliminate the need to develop detailed contingency plans
- B. To ensure that program and system documentation remains current
- C. To ensure the integrity of the data in the database
- D. To ensure the continued compatibility of the contingency facilities

Answer: D

Explanation:

QUESTION NO: 1035

Scheduled tests of application contingency plans should be based on the

- A. Size and complexity of the application.
- B. Number of changes to the application.
- C. Criticality of the application.
- D. Reliability of the application.

Answer: C

Explanation: Time sensitivity and mission criticality in conjunction with budgetary limitations, level of threat and degree of risk will be major factors in the development of recommended strategies

Reference:

http://csrc.nist.gov/groups/SMA/fasp/documents/contingency_planning/contingencyplan-template.doc

Note:

All though not directly answering the question a little inference lead to this

"Priorities - It is extremely important to know what is critical versus nice to have... It is necessary to know which department must come online first, which second, and so on...It maybe more necessary to ensure that the database is up and running before working to bring the file server online." - Shon Harris All-in-one CISSP Certification Guide pg 604

QUESTION NO: 1036

Which of the following is less likely to accompany a contingency plan, either within the plan itself or in the form of an appendix?

- A. Contact information for all personnel
- B. Vendor contract information, including offsite storage and alternate site
- C. Equipment and system requirements lists of hardware, software, firmware, and other resources required to support system operations
- D. The Business Impact Analysis

Answer: D

Explanation: You use the BIA as a guideline to create the contingency plan.

QUESTION NO: 1037

The first step in contingency planning is to perform:

- A. A hardware backup
- B. A data backup
- C. An operating system software backup
- D. An application software backup

Answer: B

Explanation:

QUESTION NO: 1038

Which of the following teams should not be included in an organization's contingency plan?

- A. Damage assessment team
- B. Hardware salvage team
- C. Tiger team
- D. Legal affairs team

Answer: C

Explanation: Tiger is an algorithm

Excerpt is from CISSP / Shon Harris / 5th edition.

The following are some examples of teams that a company may need to construct:

- Damage assessment team
- Legal team
- Media relations team
- Network recovery team
- Relocation team
- Restoration team
- Salvage team
- Security team
- Telecommunications team

Topic 10, Law, Investigations, and Ethics

QUESTION NO: 1039

In the public sector, as opposed to the private sector, due care is usually determined by

- A. Minimum standard requirements.
- B. Legislative requirements.
- C. Insurance rates.
- D. Potential for litigation.

Answer: B

Explanation:

QUESTION NO: 1040

What is the minimum and customary practice of responsible protection of assets that affects a community or societal norm?

- A. Due diligence

- B. Risk mitigation
- C. Asset protection
- D. Due care

Answer: D

Explanation: "Due care and due diligence are terms that are used throughout this book. Due diligence is the act of investigating and understanding the risks the company faces. A company practices due care by developing security policies, procedures, and standards. Due care shows that a company has taken responsibility for the activities that take place within the corporation and has taken the necessary steps to help protect the company, its resources, and employees from possible risks. So due diligence is understanding the current threats and risks and due care is implementing countermeasures to provide protection from those threats. If a company does not practice due care and due diligence pertaining to the security of its assets, it can be legally charged with negligence and held accountable for any ramifications of that negligence." Pg. 85 Shon Harris: All-in-One CISSP Certification

"The following list describes some of the actions required to show that due care is being properly practiced in a corporation:

Pg. 616 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 1041

Under the standard of due care, failure to achieve the minimum standards would be considered

- A. Negligent
- B. Unethical
- C. Abusive
- D. Illegal

Answer: A

Explanation: Due Care: care which an ordinary prudent person would have exercised under the same or similar circumstances. "Due Care" and "Reasonable Care" are used interchangeably. - Ronald Krutz The CISSP PREP Guide (gold edition) pg 896

QUESTION NO: 1042

Under the principle of culpable negligence, executives can be held liable for losses that result from computer system breaches if:

- A. the company is not a multi-national company
- B. they have not exercised due care protecting computing resources
- C. they have failed to properly insure computer resources against loss
- D. the company does not prosecute the hacker that caused the breach

Answer: B

Explanation:

QUESTION NO: 1043

The criteria for evaluating the legal requirements for implementing safeguards is to evaluate the cost (C) of instituting the protection versus the estimated loss (L) resulting from the exploitation of the corresponding vulnerability. Therefore, a legal liability exists when?

- A. $C < L$
- B. $C < L - (\text{residual risk})$
- C. $C > L$
- D. $C > L - (\text{residual risk})$

Answer: A

Explanation:

QUESTION NO: 1044

When companies come together to work in an integrated manner such as extranets, special care must be taken to ensure that each party promises to provide the necessary level of protection, liability and responsibility. These aspects should be defined in the contracts that each party signs. What describes this type of liability?

- A. Cascade liabilities
- B. Downstream liabilities

- C. Down-flow liabilities
- D. Down-set liabilities

Answer: B

Explanation: "When companies come together to work in an integrated manner, such as extranets and VANs, special care must be taken to ensure that each party promises to provide the necessary level of protection, liability, and responsibility needed, which should be clearly defined in the contracts that each party signs. Auditing and testing should be performed to ensure that each party is indeed holding up its side of the bargain and that its technology integrates properly with all other parties. Interoperability can become a large, frustrating, and expensive issue in these types of arrangements.

If one of the companies does not provide the necessary level of protection and their negligence affects a partner they are working with, the affected company can sue the upstream company. For example, let's say company A and company B have constructed an extranet. Company A does not put in controls to detect and deal with viruses. Company A gets infected with a destructive virus and it is spread to company B through the extranet. The virus corrupts critical data and causes massive disruption to company B's production. Company B can sue company A for being negligent. Both companies need to make sure that they are doing their part to ensure that their activities, or lack of them, will not negatively affect another company, which is referred to as downstream liability." Pg 616 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 1045

The typical computer felons are usually persons with which of the following characteristics?

- A. They have had previous contact with law enforcement
- B. They conspire with others
- C. They hold a position of trust
- D. They deviate from the accepted norms of security

Answer: D

Explanation:

QUESTION NO: 1046

Which of the following is responsible for the most security issues?

- A. Outside espionage
- B. Hackers
- C. Personnel
- D. Equipment Failure

Answer: C

Explanation:

QUESTION NO: 1047

Hackers are most often interested in:

- A. Helping the community in securing their networks
- B. Seeing how far their skills will take them
- C. Getting recognition for their actions
- D. Money

Answer: B

Explanation:

QUESTION NO: 1048

Which of the following categories of hackers poses the greatest threat?

- A. Disgruntled employees
- B. Student hackers
- C. Criminal hackers
- D. Corporate spies

Answer: A

Explanation:

QUESTION NO: 1049

Individuals who have their sole aim as breaking into a computer system are being referred to as:

- A. Crackers
- B. Sniffers
- C. Hackers
- D. None of the choices.

Answer: A

Explanation:

Crackers are individuals who try to break into a computer system. The term was coined in the mid-80s by hackers who wanted to differentiate themselves from individuals whose sole purpose is to sneak through security systems. Whereas crackers sole aim is to break into secure systems, hackers are more interested in gaining knowledge about computer systems and possibly using this knowledge for playful pranks. Although hackers still argue that there's a big difference between what they do and what crackers do, the mass media has failed to understand the distinction, so the two terms -- hack and crack -- are often used interchangeably.

QUESTION NO: 1050

Which of the following tools is less likely to be used by a hacker?

- A. I0phtcrack
- B. Tripwire
- C. Crack
- D. John the ripper

Answer: B

Explanation: "Other security packages, such as the popular Tripwire data integrity assurance packages, also provide a secondary antivirus functionality. Tripwire is designed to alert administrators of unauthorized file modifications. It's often used to detect web server defacements and similar attacks, but it also may provide some warning of virus infections if critical system executable files, such as COMMAND.COM, are modified unexpectedly. These systems work by maintaining a database of hash values for all files stored on the system. These archive hash values are then compared to current computed values to detect any files that were modified between the two periods." Pg. 224 Tittel: CISSP Study Guide

QUESTION NO: 1051

Which of the following tools is not likely to be used by a hacker?

- A. Nessus
- B. Saint
- C. Tripwire
- D. Nmap

Answer: C

Explanation:

Nmap – discovers systems and what services they are offering

Saint – vulnerability scanning and penetration testing

nessus – vulnerability scanner

tripwire – performs validation of system files

QUESTION NO: 1052

Supporting evidence used to help prove an idea of point is described as? It cannot stand on its own, but is used as a supplementary tool to help prove a primary piece of evidence:

- A. Circumstantial evidence
- B. Corroborative evidence
- C. Opinion evidence
- D. Secondary evidence

Answer: B

Explanation:

QUESTION NO: 1053

Which of the following would best describe secondary evidence?

- A. Oral testimony by a non-expert witness
- B. Oral testimony by an expert witness
- C. A copy of a piece of evidence

D. Evidence that proves a specific act

Answer: C

Explanation:

QUESTION NO: 1054

Which of the following exceptions is less likely to make hearsay evidence admissible in court?

- A. Records are collected during the regular conduct of business
- B. Records are collected by senior or executive management
- C. Records are collected at or near the time of occurrence of the act being investigated
- D. Records are in the custody of the witness on a regular basis

Answer: B

Explanation:

QUESTION NO: 1055

Once evidence is seized, a law enforcement officer should emphasize which of the following?

- A. chain of command
- B. chain of custody
- C. chain of control
- D. chain of communications

Answer: B

Explanation:

QUESTION NO: 1056

Which of the following rules is less likely to allow computer evidence to be admissible in court?

- A. It must prove a fact that is material to the case
- B. Its reliability must be proven
- C. The process for producing it must be documented
- D. The chain of custody of evidence must show who collected, security, controlled, handled,

transported, and tampered with the evidence

Answer: C

Explanation:

QUESTION NO: 1057

A copy of evidence or oral description of its contents; not reliable as best evidence is what type of evidence?

- A. Direct evidence
- B. Circumstantial evidence
- C. Hearsay evidence
- D. Secondary evidence

Answer: D

Explanation:

QUESTION NO: 1058

What is defined as inference of information from other, intermediate, relevant facts?

- A. Secondary evidence
- B. Conclusive evidence
- C. Hearsay evidence
- D. Circumstantial evidence

Answer: D

Explanation:

QUESTION NO: 1059

In order to be able to successfully prosecute an intruder:

- A. A point of contact should be designated to be responsible for communicating with law enforcement and other external agencies.
- B. A proper chain of custody of evidence has to be preserved

- C. Collection of evidence has to be done following predefined procedures
- D. Whenever possible, analyze, a replica of the compromised resource, not the original, thereby avoiding inadvertently tampering with evidence

Answer: B

Explanation:

QUESTION NO: 1060

Which of the following proves or disproves a specific act through oral testimony based on information gathered through the witness's five senses?

- A. direct evidence
- B. best evidence
- C. conclusive evidence
- D. hearsay evidence

Answer: A

Explanation: As stated in the CISSP documentation, "If you want to achieve the validation or revalidation of the oral testimony of a witness, you need to provide physical, direct evidence to backup your statements and override the five senses of an oral testimony". Circumstantial or Corroborative evidence is not enough in this case, we need direct, relevant evidence backing up the facts.

QUESTION NO: 1061

In order to preserve a proper chain of custody of evidence?

- A. Evidence has to be collected following predefined procedures in accordance with all laws and legal regulations
- B. Law enforcement officials should be contacted for advice on how and when to collect critical information
- C. Verifiable documentation indicating the sequence of individuals who have handled a piece of evidence should be available.
- D. Log files containing information regarding an intrusion are retained for at least as long as normal business records, and longer in the case of an ongoing investigation.

Answer: A

Explanation:

QUESTION NO: 1062

What is the primary reason for the chain of custody of evidence?

- A. To ensure that no evidence is lost
- B. To ensure that all possible evidence is gathered
- C. To ensure that it will be admissible in court
- D. To ensure that incidents were handled with due care and due diligence

Answer: C

Explanation:

QUESTION NO: 1063

Which element must computer evidence have to be admissible in court?

- A. It must be relevant
- B. It must be annotated
- C. It must be printed
- D. It must contain source code

Answer: A

Explanation:

QUESTION NO: 1064

Which kind of evidence would printed business records, manuals, and, printouts classify as?

- A. Direct evidence
- B. Real evidence
- C. Documentary evidence
- D. Demonstrative evidence

Answer: B

Explanation:

QUESTION NO: 1065

Since disks and other magnetic media are only copies of the actual or original evidence, what type of evidence are they often considered to represent?

- A. Hearsay
- B. Irrelevant
- C. Incomplete
- D. Secondary

Answer: A

Explanation:

QUESTION NO: 1066

Which of the following is LEAST necessary when creating evidence tags detailing the chain of custody for electronic evidence?

- A. The mode and means of transportation.
- B. Notifying the person who owns the information being seized.
- C. Complete description of the evidence, including quality if necessary.
- D. Who received the evidence.

Answer: B

Explanation: The references indicate that transportation is important.

Each piece of evidence should be marked in some way with the date, time, initials of the collector, and a case number if one has been assigned...The pieces of evidence should then be sealed in a container and the container should be marked with the same information. The container should be sealed with evidence tape and if possible, the writing should be on the tape so a broken seal can be detected. - Shon Harris All-in-one CISSP Certification Guide pg 673

In many cases, it is not possible for a witness to uniquely identify an object in court. In those

cases, a chain of evidence must be established. This involves everyone who handles evidence - including the police who originally collect it, the evidence technicians who process it, and the lawyers who use it in court. The location of the evidence must be fully documented from the moment it was collected to the moment it appears in court to ensure that it is indeed the same item. This requires thorough labeling of evidence and comprehensive logs noting who had access to the evidence at specific times and the reasons they required such access." Pg. 593 Tittel: CISSP Study Guide.

The evidence life cycle covers the evidence gathering and application process. This life cycle has the following components:

Discovery and recognition

Protection

Recording

Collection

Collect all relevant storage media

Make image of hard disk before removing power

Print out screen

Avoid degaussing equipment

Identification

Preservation

Protect magnetic media from erasure

Store in proper environment

Transportation

Presentation in a court of law

Return of evidence to owner

Pg. 309 Krutz: The CISSP Prep Guide

The life cycle of evidence includes

- * Collection and identification
- * Storage, preservation, and transportation
- * Presentation in court
- * Being returned to victim or owner

Pg 677 Shon Harris: All-In-One CISSP Certification Exam Guide

QUESTION NO: 1067

To be admissible in court, computer evidence must be which of the following?

- A. relevant
- B. decrypted
- C. edited
- D. incriminating

Answer: A

Explanation:

QUESTION NO: 1068

Computer-generated evidence is considered:

- A. Best evidence
- B. Second hand evidence
- C. Demonstrative evidence
- D. Direct evidence

Answer: B

Explanation: "Most of the time, computer-related documents are considered hearsay, meaning the evidence is secondhand evidence. Hearsay evidence is not normally admissible in court unless it has firsthand evidence that can be used to prove the evidence's accuracy, trustworthiness, and reliability, such as a businessperson who generated the computer logs and collected them." Pg. 630 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 1069

Why would a memory dump be admissible as evidence in court?

- A. Because it is used to demonstrate the truth of the contents
- B. Because it is used to identify the state of the system
- C. Because the state of the memory cannot be used as evidence
- D. Because of the exclusionary rule

Answer: B

Explanation:

QUESTION NO: 1070

Evidence corroboration is achieved by

- A. Creating multiple logs using more than one utility.
- B. Establishing secure procedures for authenticating users.
- C. Maintaining all evidence under the control of an independent source.
- D. Implementing disk mirroring on all devices where log files are stored.

Answer: C

Explanation: Corroborative evidence is supporting evidence used to help prove an idea or point. It cannot stand on its own, but is used as a supplementary tool to help prove a primary piece of evidence. - Shon Harris All-in-one CISSP Certification Guide pg 678

QUESTION NO: 1071

You are documenting a possible computer attack.

Which one of the following methods is NOT appropriate for legal record keeping?

- A. A bound paper notebook.
- B. An electronic mail document.
- C. A personal computer in "capture" mode that prints immediately.
- D. Microcassette recorder for verbal notes

Answer: D

Explanation:

QUESTION NO: 1072

Which one of the following is NOT a requirement before a search warrant can be issued?

- A. There is a probable cause that a crime has been committed.
- B. There is an expectation that evidence exists of the crime.
- C. There is probable cause to enter someone's home or business.
- D. There is a written document detailing the anticipated evidence.

Answer: D

Explanation: "If a computer crime is suspected, it is important not to alert the suspect. A preliminary investigation should be conducted to determine whether a crime has been committed by examining the audit records and system logs, interviewing witnesses, and assessing the damage incurred....Search warrants are issued when there is a probable cause for the search and provide legal authorization to search a location for specific evidence." -Ronald Krutz The CISSP PREP Guide (gold edition) pg 436

QUESTION NO: 1073

Once a decision is made to further investigate a computer crime incident, which one of the following is NOT employed?

- A. Identifying what type of system is to be seized.
- B. Identifying the search and seizure team members.
- C. Identifying the cost of damage and plan for their recover.
- D. Determining the risk that the suspect will destroy evidence.

Answer: C

Explanation: Costs and how to recover are not considered in a computer crime scene incident.

QUESTION NO: 1074

From a legal perspective, which of the following rules must be addressed when investigating a computer crime?

- A. Search and seizure
- B. Data protection
- C. Engagement
- D. Evidence

Answer: D

Explanation: "The gathering, control, storage and preservation of evidence are extremely critical in any legal investigation." Pg 432 Krutz: The CISSP Prep Guide: Gold Edition.

QUESTION NO: 1075

Which of the following is not a problem regarding computer investigation issues?

- A. Information is intangible
- B. Evidence is difficult to gather
- C. Computer-generated records are only considered secondary evidence, thus are no as reliable as best evidence
- D. In many instances, an expert or specialist is required

Answer: D

Explanation:

QUESTION NO: 1076

Why is the investigation of computer crime involving malicious damage especially challenging?

- A. Information stored in a computer is intangible evidence.
- B. Evidence may be destroyed in an attempt to restore the system.
- C. Isolating criminal activity in a detailed audit log is difficult.
- D. Reports resulting from common user error often obscure the actual violation.

Answer: B

Explanation: The gathering, control, storage, and preservation of evidence are extremely critical in any legal investigation. Because evidence involved in a computer crime might be intangible and subject to easy modification without a trace, evidence must be carefully handled and controlled throughout its entire life cycle. -Ronald Krutz The CISSP PREP Guide (gold edition) pg 432

QUESTION NO: 1077

After law enforcement is informed of a computer crime, the organization's investigators constraints are

- A. removed.
- B. reduced.
- C. increased.
- D. unchanged.

Answer: C

Explanation: "On the other hand, there are also two major factors that may cause a company to shy away from calling in the authorities. First, the investigation will more than likely become public and may embarrass the company. Second, law enforcement authorities are bound to conduct an investigation that complies with the Fourth Amendment and other legal requirements that may not apply to a private investigation." Pg. 529 Tittel: CISSP Study Guide

QUESTION NO: 1078

To understand the "whys" in crime, many times it is necessary to understand MOM. Which of the following is not a component of MOM?

- A.)Opportunities
- B. Methods
- C. Motivation
- D. Means

Answer: B

Reference: pg 600 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 1079

What category of law deals with regulatory standards that regulate performance and conduct? Government agencies create these standards, which are usually applied to companies and individuals within those companies.

- A. Standards law
- B. Conduct law
- C. Compliance law
- D. Administrative law

Answer: C

Explanation:

QUESTION NO: 1080

Something that is proprietary to that company and importance for its survival and profitability is what type of intellectual property law?

- A. Trade Property
- B. Trade Asset
- C. Patent
- D. Trade Secret

Answer: D

Explanation:

QUESTION NO: 1081

Which of the following statements regarding trade secrets is false?

- A. For a company to have a resource qualify as a trade secret, it must provide the company with some type of competitive value or advantage
- B. The Trade Secret Law normally protects the expression of the idea of the resource.
- C. Many companies require their employees to sign nondisclosure agreements regarding the protection of their trade secrets
- D. A resource can be protected by law if it is not generally known and if it requires special skill, ingenuity, and/or expenditure of money and effort to develop it

Answer: B

Explanation:

QUESTION NO: 1082

Which category of law is also referenced as a Tort law?

- A. Civil law
- B. Criminal law
- C. Administrative law
- D. Public law

Answer: A

Explanation:

QUESTION NO: 1083

Which of the following European Union (EU) principles pertaining to the protection of information on private individuals is incorrect?

- A. Data collected by an organization can be used for any purpose and for as long as necessary, as long as it is never communicated outside of the organization by which it was collected
- B. Individuals have the right to correct errors contained in their personal data
- C. Transmission of personal information to locations where "equivalent" personal data protection cannot be assured is prohibited.
- D. Records kept on an individual should be accurate and up to date

Answer: A

Explanation:

Directive 95/46/EC

ACCESS

Individuals must have access to personal information about them that an organization holds and be able to correct, amend, or delete that information where it is inaccurate, except where the burden or expense of providing access would be disproportionate to the risks to the individual's privacy in the case in question, or where the rights of persons other than the individual would be violated.

Not B : Legitimate Purpose

Personal data can only be processed for specified, explicit and legitimate purposes and may not be processed further in a way incompatible with those purposes.

QUESTION NO: 1084

A country that fails to legally protect personal data in order to attract companies engaged in collection of such data is referred to as a

- A. data pirate
- B. data haven
- C. country of convenience
- D. sanctional nation

Answer: B

Explanation: Correct answer is B. Data Haven.

Data Haven

A place where data that cannot legally be kept can be stashed for later use; an offshore web host. This is an interesting topic; companies often need information that they are not legally allowed to know. For example, some hospitals are not allowed to mark patients as HIV positive (because it stigmatizes patients); staff members create codes or other ways so they can take the necessary steps to protect themselves.

<http://www.technovelgy.com/ct/content.asp?Bnum=279>

DATA HAVEN

This phrase has been around for at least 15 years, but only in a specialist way. One sense is that of a place of safety and security for electronic information, for example where encrypted copies of crucial data can be stored as a backup away from one's place of business. But it can also mean a site in which data can be stored outside the jurisdiction of regulatory authorities. This sense has come to wider public notice recently as a result of Neal Stephenson's book *Cryptonomicon*, in which the establishment of such a haven in South East Asia is part of the plot. In a classic case of life imitating art, there is now a proposal to set up a data haven on one of the old World War Two

forts off the east coast of Britain, which declared independence under the name of Sealand back in 1967 (it issues its own stamps and money, for example). The idea is to get round a proposed British law-the Regulation of Investigatory Powers Bill (RIP)-that would force firms to hand over decryption keys if a crime is suspected and make Internet providers install equipment to allow interception of e-mails by the security services.

The Privacy Act doesn't protect information from being transferred from New Zealand to data havens-countries that don't have adequate privacy protection.

[Computerworld, May 1999]

The government last night poured cold water on a plan by a group of entrepreneurs to establish a "data haven" on a rusting iron fortress in the North Sea in an attempt to circumvent new anti-cryptography laws.

[Guardian, June 2000]

World Wide Words is copyright © Michael Quinion, 1996-2004.

All rights reserved. Contact the author for reproduction requests.

Comments and feedback are always welcome.

Page created 17 June 2000; last updated 27 October 2002.

<http://www.worldwidewords.org/turnsofphrase/tp-dat2.htm>

Not C: The majority google searches for 'Country of Convenience' relate to those countries supporting terrorism.

Not D: the meaning of sanctioned is listed below. This would mean that countries that DON'T protect privacy are APPROVED

Main Entry: 2sanction

Function: transitive verb

Inflected Form(s): sanc*tioned; sanc*tion*ing

Date: 1778

1 to make valid or binding usually by a formal procedure (as ratification)

2 to give effective or authoritative approval or consent

QUESTION NO: 1085

Which of the following requires all communications carriers to make wiretaps possible?

- A. 1994 US Communications Assistance for Law Enforcement Act
- B. 1996 US Economic and Protection of Property Information Act
- C. 1996 US National Information Infrastructure Protection Act
- D. 1986 US Computer Security Act

Answer: A

Explanation:

QUESTION NO: 1086

Which of the following US federal government laws/regulations was the first to require the development of computer security plan?

- A. Privacy Act of 1974
- B. Computer Security Act of 1987
- C. Federal Information Resources Management Regulations
- D. Office of Management & Budget Circular A-130

Answer: B

Reference: pg 722 Hansche: Official (ISC)2 Guide to the CISSP Exam

QUESTION NO: 1087

Which US act places responsibility on senior organizational management for prevention and detection programs with fines of up to \$290 million for nonperformance?

- A. The 1987 US Computer Security Act
- B. The 1986 US Computer Fraud and Abuse Act
- C. The 1991 US Federal Sentencing Guidelines
- D. The 1996 US National Information Infrastructure Protection Act

Answer: C

Reference: pg 615 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 1088

What document made theft no longer restricted to physical constraints?

- A. The Electronic Espionage Act of 1996
- B. The Gramm Leach Bliley Act of 1999
- C. The Computer Security Act of 1987

D. The Federal Privacy Act of 1974

Answer: A

Explanation:

QUESTION NO: 1089

In the US, HIPAA addresses which of the following?

- A. Availability and Accountability**
- B. Accuracy and Privacy**
- C. Security and Availability**
- D. Security and Privacy**

Answer: D

Explanation:

QUESTION NO: 1090

Which of the following placed requirements of federal government agencies to conduct security-related training, to identify sensitive systems, and to develop a security plan for those sensitive systems?

- A. 1987 US Computer Security Act**
- B. 1996 US Economic and Protection of Proprietary Information Act**
- C. 1994 US Computer Abuse Amendments Act**
- D. 1986 (Amended in 1996) US Computer Fraud and Abuse Act**

Answer: A

Explanation:

QUESTION NO: 1091

Which of the following cannot be undertaken in conjunction with computer incident handling?

- A. system development activity
- B. help-desk function
- C. system backup function
- D. risk management process

Answer: A

Explanation:

QUESTION NO: 1092

What is the primary goal of incident handling?

- A. Successfully retrieve all evidence that can be used to prosecute
- B. Improve the company's ability to be prepared for threats and disasters
- C. Improve the company's disaster recovery plan
- D. Contain and repair any damage caused by an event

Answer: D

Reference: Page 629 of Shon Harris's All in One Exam Guide, Second Ed.

QUESTION NO: 1093

Which one of the following is NOT a factor to consider when establishing a core incident response team?

- A. Technical knowledge
- B. Communication skills
- C. The recovery capability
- D. Understanding business policy

Answer: C

Explanation: The team should have someone from senior management, the network administrator, security officer, possibly a network engineer and /or programmer, and liaison for public affairs...The incident response team should have the following basic items
List of outside agencies and resources to contact or report to
List of computer or forensics experts to contact

Steps on how to secure and preserve evidence

Steps on how to search for evidence

List of items that should be included on the report

A list that indicates how the different systems should be treated in this type of situation (removed from internet, removed from the network, and powered down) - Shon Harris All-in-one CISSP Certification Guide pg 671-672

an investigation should involve management, corporate security, human resources, the legal department, and other appropriate staff members. The act of investigating may also affect critical operations...Thus it is important to prepare a plan beforehand on how to handle reports of suspected computer crimes. A committee of appropriate personnel should be set up beforehand to address the following issues

Establishing a prior liaison with law enforcement

Deciding when and whether to bring in law enforcement...

Setting up means of reporting computer crimes

Establishing procedures for handling and processing reports of computer crime

Planning for and conducting investigations

Involving senior management and the appropriate departments, such as legal, internal audit, information systems, and human resources

Ensuring the proper collection of evidence, which includes identification and protection of the various storage media. -Ronald Krutz The CISSP PREP Guide (gold edition) pg 435-436

QUESTION NO: 1094

Which of the following specifically addresses cyber attacks against an organization's IT systems?

- A. Continuity of support plan
- B. Business continuity plan
- C. Incident response plan
- D. Continuity of operations plan

Answer: C

Explanation:

QUESTION NO: 1095

When should a post-mortem review meeting be held after an intrusion has been properly taken

care of?

- A. Within the first three months after the investigation of the intrusion is completed
- B. Within the first week after prosecution of intruders have taken place, whether successful or not
- C. Within the first month after the investigation of the intrusion is completed
- D. Within the first week of completing the investigation of the intrusion

Answer: D

Explanation:

QUESTION NO: 1096

During a review of system logs of the enterprise, a security manager discovers that a colleague working on an exercise ran a job to collect confidential information on the company's clients. The colleague who ran the job has since left the company to work for a competitor. Based on the (ISC) Code of Ethics, which one of the following statements is MOST correct?

- The manager should call the colleague and explain what has been discovered.
The manager should then ask for the return of the information in exchange for silence.

- A. The manager should warn the competitor that a potential crime has been committed that could put their company at risk.
- B. The manager should inform his or her appropriate company management, and secure the results of the recover exercise for future review.
- C. The manager should call the colleague and ask the purpose of running the job prior to informing his or her company management of the situation.

Answer: C

Explanation: In the references I have not found out anything that directly relates to this but It would be logical to assume the answer of going to necessary management.

"ISC2 Code of Ethics....

Not commit or be party to any unlawful or unethical act that may negatively affect their professional reputation or the reputation of their profession.

Appropriately report activity related to the profession that they believe to be unlawful and shall cooperate with the resulting investigations." -Ronald Krutz The CISSP PREP Guide (gold edition) pg 440

QUESTION NO: 1097

In what way could the use of “cookies” violate a person’s privacy?

- A.** When they are used to tie together a set of unconnected requests for web pages to cause an electronic map of where one has been.
- B.** When they are used to keep logs of who is using an anonymizer to access a site instead of their regular userid.
- C.** When the e-mail addresses of users that have registered to access the web site are sold to marketing firms.

Answer: A

Explanation: Both A and C are correct in that they are true but from a CISSP viewpoint looking into a PC the cookies show a map of where the user has been. Therefore I think A is the better choice.

"Any web site that knows your identity and has cookie for you could set up procedures to exchange their data with the companies that buy advertising space from them, synchronizing the cookies they both have on your computer. This possibility means that once your identity becomes known to a single company listed in your cookies file, any of the others might know who you are every time you visit their sites.

The result is that a web site about gardening that you never told your name could sell not only your name to mail-order companies, but also the fact that you spent a lot of time one Saturday night last June reading about how to fertilize roses. More disturbing scenarios along the same lines could be imagined." <http://www.junkbusters.com/cookies.html>

QUESTION NO: 1098

Which of the following is the BEST way to prevent software license violations?

- A.** Implementing a corporate policy on copyright infringements and software use
- B.** Requiring that all PC's be diskless workstations
- C.** Installing metering software on the LAN so applications can be accessed through the metered software
- D.** Regularly scanning used PC's to ensure that unauthorized copies of software have not been loaded on the PC

Answer: D

Explanation:

QUESTION NO: 1099

The ISC2 Code of Ethics does not include which of the following behaviors for a CISSP:

- A. moral
- B. ethical
- C. legal
- D. control

Answer: D

Explanation:

QUESTION NO: 1100

Where can the phrase "Discourage unsafe practice" be found?

- A. Computer Ethics Institute commandments
- B. (ISC)2 Code of Ethics
- C. Internet Activities Board's Ethics and the Internet (RFC1087)
- D. CIAC Guidelines

Answer: B

Explanation:

QUESTION NO: 1101

One of the offences an individual or company can commit is decompiling vendor code. This is usually done in the hopes of understanding the intricate details of its functionality. What best describes this type of non-ethical engineering?

- A. Inverse Engineering
- B. Backward Engineering
- C. Subvert Engineering
- D. Reverse Engineering

Answer: D

Explanation:

QUESTION NO: 1102

Which one of the following is an ethical consideration of computer technology?

- A. Ownership of proprietary software.
- B. Information resource management.
- C. Service level agreements.
- D. System implementation and design.

Answer: B

Explanation: If going by the Internet Activities Board, then Information resource management would be the answer since you aren't wasting resources.

Note: This question is oddly worded.

QUESTION NO: 1103

The Internet Activities Board characterizes which of the following as unethical behavior for Internet users?

- A. Writing computer viruses
- B. Monitoring data traffic
- C. Wasting computer resources
- D. Concealing unauthorized accesses

Answer: C

Explanation: Explanations:

Wasting resources (people, capacity, and computers) through purposeful actions" is listed as unethical per page 909 of CISSP / Shon Harris / 5th edition.

QUESTION NO: 1104

Which of the following is a potential problem when creating a message digest for forensic purposes?

- A. The process is very slow.
- B. The file's last access time is changed.
- C. The message digest is almost as long as the data string.
- D. One-way hashing technology invalidates message digest processing.
- E. a file could be changed during the process

Answer: E

Explanation:

Not D: does not make much sense. The purpose of the one-way hash is to create a message digest.

Not C.

"To generate a digital signature, the digital signature program passes the file to be sent through a one-way hash function. This hash function produces a fixed size output from a variable size input."

Pg. 208 Krutz: The CISSP Prep Guide: Gold Edition.

QUESTION NO: 1105

A forensic examination should inspect slack space because it

- A. Contains system level access control kernel.
- B. Can contain a hidden file or data.
- C. Can contain vital system information.
- D. Can be defected to avoid detection.

Answer: B

Explanation:

QUESTION NO: 1106

Forensic imaging of a workstation is initiated by

- A. Booting the machine with the installed operating system.
- B. Booting the machine with an operating system diskette.
- C. Removing the hard drive to view the output of the forensic imaging software.
- D. Directing the output of the forensic imaging software to the small computer system interface (SCSI).

Answer: D

Explanation: "It is very important that the person, or people, conducting the forensics investigation is skilled in this trade and knows what to look out for. If a person reboots the attacked system or goes around looking at different files, it could corrupt viable evidence, change timestamps on key files, and erase footprints the criminal may have left. One very good first step is to make a sound image of the attacked system and perform forensic analysis on this copy. This will ensure that the evidence stays unharmed on the original system in case some steps in the investigation actually corrupt or destroy data. Also the memory of the system should be dumped to a file before doing any work on the system or powering it down." - Shon Harris All-in-one CISSP Certification Guide pg 672-673

PCMCIA to SCSI and parallel to SCSI forensic products can be found at the following vendor.
http://www.icsforensic.com/products_cat_fr.cfm

QUESTION NO: 1107

A disk image backup is used for forensic investigation because it

- A. Is based on secured hardware technology.
- B. Creates a bit level copy of the entire disk.
- C. Time stamps the files with the date and time of the copy operation.
- D. Excludes areas that have never been used to store data.

Answer: B

Explanation: Never conduct your investigation on an actual system that was compromised. Take the system offline, make a backup, and use the backup to investigate the incident. - Ed Tittle CISSP Study Guide (sybex) pg 595

QUESTION NO: 1108

When it comes to magnetic media sanitization, what difference can be made between clearing and purging information?

- A.** Clearing completely erases the media whereas purging only removes file headers, allowing the recovery of files
- B.** Clearing renders information unrecoverable by a keyboard attack and purging renders information unrecoverable against laboratory attack
- C.** They both involve rewriting the media
- D.** Clearing renders information unrecoverable against a laboratory attack and purging renders information unrecoverable to a keyboard attack

Answer: B

Reference: pg 405 Tittel: CISSP Study Guide

QUESTION NO: 1109

What is HIPAA?

- A.** The Home Insurance Portability & Accountability Act of 1996 (August 21), Public Law 104-191, which amends the Internal Revenue Service Code of 1986. Also known as the Kennedy-Kassebaum Act.
- B.** The Public Health Insurance Portability & Accountability Act of 1996 (August 21), Public Law 104-191, which amends the Internal Revenue Service Code of 1986. Also known as the Kennedy-Kassebaum Act.
- C.**)The Health Insurance Privacy & Accountability Act of 1996 (August 2), public law 104-191, which amends the Internal Revenue Service Code of 1986. Also known as the Kennedy-Kassebaum Act.
- D.** The Health Insurance Privacy & Accountability Act of 1996 (August 2), Public Law 104-191, which amends the Internal Revenue Service Code of 1986. Also known as the Kennedy-Kassebaum Act.

Answer: B

Explanation:

"The United States Kennedy-Kassebaum Health Insurance Portability and Accountability Act (HIPAA-Public Law 104-191), effective August 21, 1996, addresses the issues of health care

privacy, security, transactions and code sets, unique identifies, electronic signatures, and plan portability in the United States.” Pg 499-500 Krutz: The CISSP Prep Guide: Gold Edition.

QUESTION NO: 1110

The privacy provisions of the federal law, the Health Insurance Portability and Accountability Act of 1996 (HIPAA),

- A.** apply to certain types of critical health information created or maintained by health care providers who engage in certain electronic transactions, health plans, and health care clearinghouses.
- B.** apply to health information created or maintained by health care providers who engage in certain electronic transactions, health plans, and health care clearinghouses.
- C.** apply to health information created or maintained by some large health care providers who engage in certain electronic transactions, health plans, and health care clearinghouses.
- D.** apply to health information created or maintained by health care providers regardless of whether they engage in certain electronic transactions, health plans, and health care clearinghouses.

Answer: B

Explanation:

QUESTION NO: 1111

Gap analysis does not apply to

- A.** Transactions
- B.** availability
- C.** Privacy
- D.** Security

Answer: B

Explanation:

QUESTION NO: 1112

A gap analysis for Privacy refers

- A.** to the practice of identifying the policies and procedures you currently have in place regarding the availability of protected health information.
- B.** to the practice of identifying the policies and procedures you currently have in place regarding the confidentiality of protected health information.
- C.** to the practice of identifying the policies and procedures you currently have in place regarding the authenticity of protected health information.
- D.** to the practices of identifying the legislation you currently have in place regarding the confidentiality of protected health information.

Answer: B

Explanation:

QUESTION NO: 1113

A gap analysis for Privacy

- A.** includes a comparison of your proposed policies and procedures and the requirements established in the Security and Privacy Regulation in order to identify any necessary modifications in existing policies to satisfy HIPAA regulations when they are stricter than state privacy laws.
- B.** includes a comparison of your current policies and procedures and the requirements established in the Security and Privacy Regulation in order to identify any necessary modifications in existing policies to satisfy HIPAA regulations when they are stricter than state privacy laws
- C.** includes a comparison of your ideal policies and procedures and the requirements established in the Security and Privacy Regulation in order to identify any necessary modifications in existing policies to satisfy HIPAA regulations when they are stricter than state privacy laws.
- D.** includes a comparison of your exceptional policies and procedures and the requirements established in the Security and Privacy Regulation in order to identify any necessary modifications in existing policies to satisfy HIPAA regulations when they are stricter than state privacy laws

Answer: B

Explanation:

QUESTION NO: 1114

What is a gap analysis in relationship to HIPAA?

- A.** In terms of HIPAA, a gap analysis cannot be defined.
- B.** In terms of HIPAA, a gap analysis defines what an organization currently is doing in a specific area of their organization and compares current operations to other requirements mandated by ethical standards.
- C.** In terms of HIPAA, a gap analysis defines what an organization currently is doing in a specific area of their organization and compares current operations to other requirements mandated by state or federal law
- D.** In terms of HIPAA, a gap analysis defines what an organization proposes to be doing in a specific area of their organization and compares proposed operations to other requirements mandated by state or federal law.

Answer: C

Explanation:

QUESTION NO: 1115

The privacy provisions of the federal law, the Health Insurance Portability and Accountability Act of 1996 (HIPAA), apply to certain types of health information created or maintained by health care providers

- A.** who engage in certain electronic transactions, health plans, and health care clearinghouses
- B.** who do not engage in certain electronic transactions, health plans, and health care clearinghouses
- C.** regardless of whether they engage in certain electronic transactions, health plans, and health care clearinghouses
- D.** if they engage for a majority of days in a year in certain electronic transactions, health plans, and health care clearinghouses.

Answer: A

Explanation:

QUESTION NO: 1116

HIPAA preempts state laws

- A.** except to the extent that the state law is less stringent
- B.** regardless of the extent that the state law is more stringent
- C.** except to the extent that the state law more stringent
- D.** except to the extent that the state law is legislated later than HIPAA

Answer: C

Explanation:

QUESTION NO: 1117

The Implementation Guides

- A.** are referred to in the Static Rule
- B.** are referred to in the Transaction Rule
- C.** are referred to in the Transitional Rule
- D.** are referred to in the Acquisition Rule

Answer: B

Explanation:

QUESTION NO: 1118

The HIPAA task force must first

- A.** inventory the organization's systems, processes, policies, procedures and data to determine which elements are critical to patient care and central to the organization's business
- B.** inventory the organization's systems, processes, policies, procedures and data to determine which elements are non critical to patient care and central to the organization's business
- C.** inventory the organization's systems, processes, policies, procedures and data to determine which elements are critical to patient complaints and central to the organization's peripheral businesses
- D.** modify the organization's systems, processes, policies, procedures and data to determine which elements are critical to patient care and central to the organization's business

Answer: A

Explanation:

QUESTION NO: 1119

A covered healthcare provider with a direct treatment relationship with an individual need not:

- A. provide the notice no later than the date of the first service delivery, including service delivered electronically
- B. have the notice available at the service delivery site for individuals to request and keep
- C. get a acknowledgement of the notice from each individual on stamped paper
- D. post the notice in a clear and prominent location where it is reasonable to expect individuals seeking service from the covered healthcare provider to be able to read it

Answer: C

Explanation:

Notice Distribution. A covered health care provider with a *direct treatment* relationship with individuals must have delivered a privacy practices notice to patients starting April 14, 2003 as follows:

<http://www.hhs.gov/ocr/privacy/hipaa/understanding/summary/index.html>

QUESTION NO: 1120

A health plan may conduct its covered transactions through a clearinghouse, and may require a provider to conduct covered transactions with it through a clearinghouse. The incremental cost of doing so must be borne

- A. by the HIPAA authorities
- B. by the health plan
- C. by any other entity but the health plan
- D. by insurance companies

Answer: B

Explanation:

QUESTION NO: 1121

Covered entities (certain health care providers, health plans, and health care clearinghouses) are not required to comply with the HIPAA Privacy Rule until the compliance date. Covered entities may, of course, decide to:

- A. unvoluntarily protect patient health information before this date
- B. voluntarily protect patient health information before this date
- C. after taking permission, voluntarily protect patient health information before this date

D. compulsorily protect patient health information before this date

Answer: B

Explanation:

QUESTION NO: 1122

The confidentiality of alcohol and drug abuse patient records maintained by this program is protected by federal law and regulations. Generally, the program may not say to a person outside the program that a patient attends the program, or disclose any information identifying a patient as an alcohol or drug abuser even if:

- A.)The person outside the program gives a written request for the information
- B. the patient consent in writing
- C. the disclosure is allowed by a court order
- D. the disclosure is made to medical personnel in a medical emergency or to qualified personnel for research, audit, or program evaluation.

Answer: D

Explanation:

Incident handling is not related to disaster recovery, it is related to security incidents.

QUESTION NO: 1123

What is a Covered Entity? The term "Covered Entity" is defined in 160.103 of the regulation.

- A. The definition is complicate and long.
- B. The definition is referred to in the Secure Computing Act
- C. The definition is very detailed.
- D. The definition is deceptively simple and short

Answer: D

Explanation:

QUESTION NO: 1124

Are employers required to submit enrollments by the standard transactions?

- A.** Though Employers are not CEs and they have to send enrollment using HIPAA standard transactions. However, the employer health plan IS a CE and must be able to conduct applicable transactions using the HIPAA standards
- B.** Employers are not CEs and do not have to send enrollment using HIPAA standard transactions. However, the employer health plan IS a CE and must be able to conduct applicable transactions using the HIPAA standards.
- C.** Employers are CEs and have to send enrollment using HIPAA standard transactions. However, the employer health plan IS a CE and must be able to conduct applicable transactions using the HIPAA standards.
- D.** Employers are CEs and do not have to send enrollment using HIPAA standard transactions. Further, the employer health plan IS also a CE and must be able to conduct applicable transactions using the HIPAA standards.

Answer: B

Explanation:

QUESTION NO: 1125

Employers

- A.** often advocate on behalf of their employees in benefit disputes and appeals, answer questions with regard to the health plan, and generally help them navigate their health benefits.
- B.** sometimes advocate on behalf of their employees in benefit disputes and appeals, answer questions with regard to the health plan, and generally help them navigate their health benefits.
- C.** never advocate on behalf of their employees in benefit disputes and appeals, answer questions with regard to health plan, and generally help them navigate their health benefits.
- D.** are prohibited by plan sponsors from advocating on behalf of group health plan participants or providing assistance in understanding their health plan.

Answer: A

Explanation:

QUESTION NO: 1126

Employers

- A. are covered entities if they do not use encryption
- B. are covered entities
- C. are not legal entities
- D. are not covered entities

Answer: D

Explanation:

The Administrative Simplification standards adopted by Health and Human Services (HHS) under the Health Insurance Portability and Accountability Act of 1996 (HIPAA) apply to any entity that is An entity that is one or more of these types of entities is referred to as a "covered entity" in the Administrative Simplification regulations

Reference: https://www.cms.gov/HIPAAGenInfo/06_AreYouaCoveredEntity.asp

QUESTION NO: 1127

The HIPAA task force must inventory the organization's systems, processes, policies, procedures and data to determine which elements are critical to patient care and central to the organizations business. All must be inventoried and listed by

- A. by priority as well as encryption levels, authenticity, storage-devices, availability, reliability, access and use. The person responsible for criticality analysis must remain mission-focused and carefully document all the criteria used.
- B. by priority and cost as well as availability, reliability, access and use. The person responsible for criticality analysis must remain mission-focused and carefully document all the criteria used.
- C. by priority as well availability, reliability, access and use. The person responsible for criticality analysis must remain mission-focused but need not document all the criteria used.
- D. by priority as well as availability, reliability, access and use. The person responsible for criticality analysis must remain mission-focused and carefully document all the criteria used.

Answer: D

Explanation:

QUESTION NO: 1128

Are there penalties under HIPAA?

A. No penalties

B. HIPAA calls for severe civil and criminal penalties for noncompliance, including: -- fines up to \$25k for multiple violations of the same standard in a calendar year -- fines up to \$250k and/or imprisonment up to 10 years for knowing misuse of individually identifiable health information.

C. HIPAA calls for severe civil and criminal penalties for noncompliance, includes: -- fines up to 50k for multiple violations of the same standard in a calendar year -- fines up to \$500k and/or imprisonment up to 10 years for knowing misuse of individually identifiable health information

D. HIPAA calls for severe civil and criminal penalties for noncompliance, including: -- fines up to \$100 for multiple violations of the same standard in a calendar year -- fines up to \$750k and/or imprisonment up to 20 years for knowing misuse of individually identifiable health information

E. HIPAA calls for severe civil and criminal penalties for noncompliance, including: -- fines up to \$1.5 million for multiple violations of the same standard in a calendar year -- fines up to \$250k and/or imprisonment up to 10 years for knowing misuse of individually identifiable health information.

Answer: E

Explanation:

QUESTION NO: 1129

HIPAA gave the option to adopt other financial and administrative transactions standards, "consistent with the goals of improving the operation of health care system and reducing administrative costs" to

A. ASCA prohibits HHS from paying Medicare claims that are not submitted electronically after October 16, 2003.

B. ASCA prohibits HHS from paying Medicare claims that are not submitted on paper after October 16, 2003

C. ASCA prohibits HHS from paying Medicare claims that are not submitted electronically after October 16, 2003, unless the Secretary grants a waiver from this requirement

D. No

Answer: C

Explanation:

QUESTION NO: 1130

May a health plan require a provider to use a health care clearinghouse to conduct a HIPAA-covered transaction, or must the health plan acquire the ability to conduct the transaction directly

with those providers capable of conducting direct transactions?

- A.** A health plan may conduct its covered transactions through a clearinghouse, and may require a provider to conduct covered transactions with it through a clearinghouse. But the incremental cost of doing so must be borne by the health plan. It is a cost-benefit decision on the part of the health plan whether to acquire the ability to conduct HIPAA transactions directly with other entities, or to require use of a clearinghouse.
- B.** A health plan may not conduct its covered transactions through a clearinghouse
- C.** A health plan may after taking specific permission from HIPAA authorities conduct its covered transactions through a clearinghouse
- D.** is not as per HIPAA allowed to require provider to conduct covered transactions with it through a clearinghouse

Answer: A

Explanation:

QUESTION NO: 1131

Business Associate Agreements are required by the regulation whenever a business associate relationship exists. This is true even when the business associates are both covered entities.

- A.** There are no specific elements which must be included in a Business Associate Agreement. However some recommended but not compulsory elements are listed in 164.504(e) (2)
- B.** There are specific elements which must be included in a Business Associate Agreement. These elements are listed Privacy Legislation
- C.** There are no specific elements which must be included in a Business Associate Agreement.
- D.** There are specific elements which must be included in a Business Associate Agreement. These elements are listed in 164.504(e) (2)

Answer: D

Explanation:

Business Associate Contracts. A covered entity's contract or other written arrangement with its business associate must contain the elements specified at 45 CFR 164.504(e). For example, the contract must: Describe the permitted and required uses of protected health information by the business associate; Provide that the business associate will not use or further disclose the protected health information other than as permitted or required by the contract or as required by law; and Require the business associate to use appropriate safeguards to prevent a use or disclosure of the protected health information other than as provided for by the contract.

Reference:

<http://www.hhs.gov/ocr/privacy/hipaa/understanding/coveredentities/businessassociates.html>

QUESTION NO: 1132

The implementation Guides

- A.** are referred to in the Transaction Rule
- B.** are not referred to in the Transaction Rule
- C.** are referred to in the Compliance Rules
- D.** are referred to in the Confidentiality Rule

Answer: A

Explanation:

QUESTION NO: 1133

Business Associates

- A.** are entities that perform services that require the use of Protected Health Information on behalf of Covered Entities. One covered entity may be a business partner of another covered entity
- B.** are entities that do not perform services that require the use of Protected Health Information on behalf of Covered Entities. One covered entity may be a business partner of another covered entity
- C.** are entities that perform services that require the use of Encrypted Insurance Information on behalf of Covered Entities. One covered entity may be a business partner of another covered entity
- D.** are entities that perform services that require the use of Protected Health Information on behalf of Covered Entities. One covered entity cannot be a business partner of another covered entity.

Answer: A

Explanation:

QUESTION NO: 1134

Health Care Providers, however,

- A.** become the business associates of health plans even without joining a network
- B.** become the business associates of health plans by simply joining a network

- C. do not become the business associates of health plans by simply joining a network
- D. do not become the HIPAA associates of health plans by simply joining a network

Answer: C

Explanation:

QUESTION NO: 1135

In terms of HIPAA what an organization currently is doing in a specific area of their organization and compared current operations to other requirements mandated by state or federal law is called

- A. HIPAA status analysis
- B. gap analysis
- C. comparison analysis
- D. stop-gap analysis

Answer: B

Explanation:

QUESTION NO: 1136

Group Health Plans sponsored or maintained by employers, however,

- A. ARE SOMETIMES covered entities.
- B. ARE NOT covered entities.
- C. ARE covered entities
- D. ARE called uncovered entities

Answer: C

Explanation:

QUESTION NO: 1137

Employers often advocate on behalf of their employees in benefit disputes and appeals, answer questions with regard to the health plan, and generally help them navigate their health benefits. Is

this type of assistance allowed under the regulation?

- A.** The final rule does nothing to hinder or prohibit plan sponsors from advocating on behalf of group health plan participants or providing assistance in understanding their health plans.
- B.** The final rule prohibits plan sponsors from advocating on behalf of group health plan participants or providing assistance in understanding their health plans
- C.** The final rule does hinder but does not prohibit plan sponsors from advocating on behalf of group health plan participants or providing assistance in understanding their health plans
- D.** The final rule does no advocating on behalf of group health plan participants or provide assistance in understanding their health plan.

Answer: A

Explanation:

QUESTION NO: 1138

HIPAA does not call for:

- A.** Standardization of electronic patient health, administrative and financial data
- B.** Unique health identifiers for individuals, employers, health plans, and health care providers.
- C.** Common health identifiers for individuals, employers, health plans and health care providers.
- D.** Security standards protecting the confidentiality and integrity of "individually identifiable health information," past, present or future.

Answer: C

Explanation:

QUESTION NO: 1139

A gap analysis for the Transactions set refer to the practice of identifying the data content you currently have available

- A.** through your medical software
- B.** through your accounting software
- C.** through competing unit medical software
- D.** based on the statutory authorities report

Answer: A

Explanation:**QUESTION NO: 1140**

A gap analysis for the Transactions set does not refer to

- A.** the practice of identifying the data content you currently have available through your medical software
- B.** the practice of and comparing that content to what is required by HIPAA, and ensuring there is a match.
- C.** and requires that you study the specific format of a regulated transaction to ensure that the order of the information when sent electronically matches the order that is mandated in the Implementation Guides.
- D.** but does not require that you study the specific format of a regulated transaction to ensure that the order of information when sent electronically matches the order that is mandated in the Implementation Guides.

Answer: D

Explanation:**QUESTION NO: 1141**

Health Information Rights although your health record is the physical property of the healthcare practitioner or facility that compiled it, the information belongs to you. You do not have the right to:

- A.** obtain a paper copy of the notice of information practices upon request inspect and obtain a copy of your health record as provided for in 45 CFR 164.524
- B.** request a restriction on certain uses and disclosures of your information outside the terms as provided by 45 CFR 164.522
- C.** amend your health record as provided in 45 CFR 164.528 obtain an accounting of disclosures of your health information as provided in 45 CFR 164.528
- D.** revoke your authorization to use or disclose health information except to the extent that action has already been taken

Answer: B

Explanation:

QUESTION NO: 1142

Employers often advocate on behalf of their employees in benefit disputes and appeals, answer questions with regard to the health plan, and generally help them navigate their health benefits. Is individual consent required?

- A. No
- B. Sometimes
- C. Yes
- D. The answer is indeterminate

Answer: C

Explanation:

QUESTION NO: 1143

Who enforces HIPAA?

- A. The Office of Civil Rights of the Department of Confidentiality Services is responsible for enforcement of these rules
- B. The Office of Civil Rights of the Department of Health and Human Services is responsible for enforcement of these rules
- C. The Office of Health Workers Rights of the Department of Health and Human Services is responsible for enforcement of these rules
- D. The Department of Civil Rights of the Office of Health and Human Services is responsible for enforcement of these rules

Answer: B

Explanation:

QUESTION NO: 1144

Gap analysis does not apply to

- A. Transactions
- B. availability
- C. Privacy
- D. Security

Answer: B

Explanation:

QUESTION NO: 1145

A gap analysis for Security

- A.** refers to the practice of trusting the security policies and practices currently in place in your organization designed to protect all your data from unauthorized access, alteration or inadvertent disclosure.
- B.** refers to the practice of modifying the security policies and practices currently in place in your organization designed to protect all your data from unauthorized access, alteration or inadvertent disclosure.
- C.** refers to the practice of identifying the security policies and practices currently in place in your organization designed to protect all your data from unauthorized access, alteration or inadvertent disclosure.
- D.** refers to the practice of improving the security policies and practices currently in place in your organization designed to protect all your data from unauthorized access alteration or inadvertent disclosure.

Answer: D

Explanation:

http://en.wikipedia.org/wiki/Gap_analysis

Gap analysis identifies gaps between the optimized allocation and integration of the inputs (resources), and the current allocation level. This reveals areas that can be improved.

QUESTION NO: 1146

The Implementation Guides are referred to in the Transaction Rule. The manuals are

- A.** non-technical in nature and do not specifically state what the data content should be for each HIPAA transaction. They also do not state the order in which this data must appear when transmitted electronically.
- B.** theoretical in nature and specifically state what the data content should be for each HIPAA transaction. They also state the order in which this data must appear when transmitted electronically.
- C.** technical in nature and specifically state what the data content should be for each HIPAA transaction. They do not state the order in which this data must appear when transmitted electronically.

D. technical in nature and specifically state what the data content should be for each HIPAA transaction. They also state the order in which this data must appear when transmitted electronically.

Answer: D

Explanation:

QUESTION NO: 1147

Title II of HIPAA includes a section, Administrative Simplification, not requiring:

- A.** Improved efficiency in healthcare delivery by standardizing electronic data interchange
- B.** Protection of confidentiality of health data through setting and enforcing standards
- C.** Protection of security of health data through setting and enforcing standards
- D.** Protection of availability of health data through setting and enforcing standards

Answer: D

Explanation:

QUESTION NO: 1148

Who is not affected by HIPAA?

- A.** clearing houses
- B.** banks
- C.** universities
- D.** billing agencies

Answer: B

Explanation:

University: there are medical universities and thus could be a covered entity and as such, affected by HIPAA.

QUESTION NO: 1149

HIPAA results in

- A. sweeping changed in some healthcare transaction and administrative information systems
- B. sweeping changes in most healthcare transaction and administrative information systems
- C. minor changes in most healthcare transaction and administrative information systems
- D. no changes in most healthcare transaction and minor changes in administrative information systems

Answer: B

Explanation:

Topic 11, Mixed Questions

QUESTION NO: 1150

Which one is an example of a man-in-the-middle attack?

- A. Buffer overflow
- B. DoS attack
- C. All of the above
- D. None of the above

Answer: D

Explanation: Wrong: Both A and B could be the result of a man-in-the-middle attack, but neither are man-in-the-middle attacks. For example someone who uses a packet capturing device, such as a “sniffer” to obtain an unencrypted user ID and password to one or more PCs or servers and then the platforms to launch a DOS attach or create a Buffer Overflow by exploiting an application flaw or OS Vulnerability.

QUESTION NO: 1151

Which one of these is a basic firewall?

- A. Packet Filtering Firewalls
- B. Proxy Firewalls
- C. All of the above
- D. None of the above

Answer: A

Explanation: Packet Filtering Firewall – only examines an IP packet based on Source IP (SIP), Destination IP (DIP), Source Port and Destination Port for both UDP and TCP by subjecting each IP packet to an Access Control List.

QUESTION NO: 1152

Why is there an exception area in a policy?

- A. Policy isn't valid without it
- B. Management has to deal with various issues that may require exceptions
- C. All of the above
- D. None of the above

Answer: B

Explanation: Policies are ever evolving process that requires updating. Policies must change as the goals, functions and responsibilities of a company, government or employee changes. A simple policy exception could be – No unauthorized person or persons can enter the computer room. The Exception would be – Unless cleared by management and escorted by an authorized individual. In some cases there are NO exceptions – An example: Military TOP Secret information can ONLY be handled by someone with a TOP Secret Clearance; thus answer A is incorrect.

QUESTION NO: 1153

Which is a characteristic of IDEA?

- A. 56 bytes
- B. 64 bits
- C. 64 bytes
- D. All of the above
- E. None of the above

Answer: B

Explanation: From Wikipedia: International Data Encryption Algorithm (IDEA) operates on 64-bit blocks using a 128-bit key, and consists of a series of eight identical transformations (a round, see the illustration) and an output transformation (the half-round). The processes for encryption and decryption are similar. IDEA derives much of its security by interleaving operations from different

groups — modular addition and multiplication, and bitwise eXclusive OR (XOR) — which are algebraically "incompatible" in some sense.

QUESTION NO: 1154

Which of the following can be used to raise awareness of the importance of security and risk? Select best two.

- A. Money
- B. Training
- C. Cohersion
- D. Education

Answer: B,D

Explanation: Awareness and the importance of security and risk can not be improved or awareness be increased with only money. Awareness is produced by providing employees with education and training. Reference the Training and Education Triad. Exam Cram 2 CISSP Page 52

QUESTION NO: 1155

Which mechanism complements an IDS?

- A. Activating the built in VPN capabilities
- B. Configuring built in alerts
- C. All of the above
- D. None of the above

Answer: B

Explanation: A network security engineer or other security personal must configure the IDS to detect alerts for specified security events, so the IDS will log the threat event. An IDS can either be a Network or Host based. Both have default settings and allow the administrator to configure triggers for alerts.

QUESTION NO: 1156

A programmer creates a virus producing tool in order to test the performance of a new virus detection product.

- A.** This is ethical because it was created to test and enhance the performance of a virus protection tool
- B.** It's unethical because the virus creating tool may become available to the public.
- C.** All of the above
- D.** None of the above

Answer: B

Explanation: As a CISSP, one needs to discourage unsafe practices and/or bad practices, and preserve and strengthen the integrity of the public infrastructures. See "All-in-One Exam Guide" Third Edition by Shon Harris page 753 or www.isc2.org.

Topic 12, Extra Practice

QUESTION NO: 1157

In a discretionary mode, which of the following entities is authorized to grant information access to other people?

- A. Manager
- B. Group leader
- C. Security manager
- D. User

Answer: D

Explanation: Discretionary control is the most common type of access control mechanism implemented in computer systems today. The basis of this kind of security is that an individual user, or program operating on the user's behalf, is allowed to specify explicitly the types of access other users (or programs executing on their behalf) may have to information under the user's control. Discretionary security differs from mandatory security in that it implements the access control decisions of the user. Mandatory controls are driven by the results of a comparison between the user's trust level or clearance and the sensitivity designation of the information.

QUESTION NO: 1158

Which DES mode of operation is best suited for database encryption?

- A. Cipher Block Chaining (CBC) mode
- B. Cycling Redundancy Checking (CRC) mode
- C. Electronic Code Book (ECB) mode
- D. Cipher Feedback (CFB) mode

Answer: C

Explanation: The DES algorithm in Electronic Codebook (ECB) mode is used for DEK and MIC encryption when symmetric key management is employed. The character string "DES-ECB" within an encapsulated PEM header field indicates use of this algorithm/mode combination.

A compliant PEM implementation supporting symmetric key management shall support this algorithm/mode combination. This mode of DES encryption is the best suited for database encryption because of its low overhead.

ECB Mode has some weakness, here they are:

1. ECB Mode encrypts a 64-bit block independently of all other 64-bit blocks
2. Given the same key, identical plaintext will encrypt the same way
3. Data compression prior to ECB can help (as with any mode)
4. Fixed block size of 64 bits therefore incomplete block must be padded

QUESTION NO: 1159

Within the realm of IT security, which of the following combinations best defines risk?

- A. Threat coupled with a breach.
- B. Threat coupled with a vulnerability.
- C. Vulnerability coupled with an attack.
- D. Threat coupled with a breach of security.

Answer: B

Explanation: This is the main concept, when we talk about a possible risk we always have a possible vulnerability in the system attacked. This vulnerability can make a threat to be successful. We can say that the level of risk can be measures through the level of vulnerabilities in our current systems and the ability of the attackers to exploit them to make a threat successful.

QUESTION NO: 1160

Which of the following would be the best reason for separating the test and development environments?

- A. To restrict access to systems under test.
- B. To control the stability of the test environment.
- C. To segregate user and development staff.
- D. To secure access to systems under development.

Answer: B

Explanation: This is the right answer, with a separation of the two environments (Test and development), we can get a more stable and more "in control" environment, Since we are making tests in the development environment, we don't want our production processes there, we don't want to experiment things in our production processes. With a separation of the environments we can get a more risk free production environment and more control and flexibility over the test

environment for the developers.

QUESTION NO: 1161

Which of the following statements pertaining to dealing with the media after a disaster occurred and disturbed the organizations activities is incorrect?

- A.** The CEO should always be the spokesperson for the company during a disaster.
- B.** The disaster recover plan must include how the media is to be handled during the disaster.
- C.** The organization's spokesperson should report bad news before the press gets a hold of it through another channel.
- D.** An emergency press conference site should be planned ahead.

Answer: A

Explanation: This is not a good practice, we cannot involves the CEO of the company to deal with the media in every case we have a disaster, depending on the severity of the disaster we can make the CEO talk, but the best practice in the real world is to have a well-known person with that role, with special speaking capabilities and knowledge about press methods. In general, the CEO always gets news of what happened, and he decides the company politics, then another designed employee (Usually from the disaster recovery team) deals with the media.

QUESTION NO: 1162

Which Orange book security rating introduces security labels?

- A.** C2
- B.** B1
- C.** B2
- D.** B3

Answer: B

Explanation: Class (B1) or “Labeled Security Protection” systems require all the features required for class (C2). In addition, an informal statement of the security policy model, data labeling, and mandatory access control over named subjects and objects must be present. The capability must exist for accurately labeling exported information. Any flaws identified by testing must be removed.

QUESTION NO: 1163

A Business Impact Analysis (BIA) does not:

- A. Recommend the appropriate recovery solution.
- B. Determine critical and necessary business functions and their resource dependencies.
- C. Identify critical computer applications and the associated outage tolerance.
- D. Estimate the financial impact of a disruption.

Answer: A

Explanation: Remember that when we talk about a BIA (Business Impact Analysis), we are analyzing and identifying possible issues about our infrastructure, in this kind of analysis we don't make suggestions about what to do to recover from them. This is not an action plan, It's an analysis about the business, the process that it relays on, the level of the systems and a estimative of the financial impact, or in other words, how much many we loose with our systems down.

QUESTION NO: 1164

Which access control model enables the owner of the resource to specify what subjects can access specific resources?

- A. Discretionary Access Control
- B. Mandatory Access Control

- C. Sensitive Access Control
- D. Role-based Access Control

Answer: A

Explanation: Discretionary Access Control (DAC) is used to control access by restricting a subject's access to an object. It is generally used to limit a user's access to a file. In this type of access control it is the owner of the file who controls other users' accesses to the file.

Using a DAC mechanism allows users control over access rights to their files. When these rights are managed correctly, only those users specified by the owner may have some combination of read, write, execute, etc. permissions to the file.

QUESTION NO: 1165

What type of cable is used with 100Base-TX Fast Ethernet?

- A. Fiber-optic cable
- B. Four pairs of Category 3, 4 or 5 unshielded twisted-pair (UTP) wires.
- C. Two pairs of Category 5 unshielded twisted-pair (UTP) or Category 1 shielded twisted-pair (STP) wires.
- D. RG.58 cable.

Answer: C

Explanation: 100BaseTX is a 100-Mbps baseband Fast Ethernet specification using two pairs of either UTP or STP wiring. The first pair of wires is used to receive data; the second is used to transmit. To guarantee proper signal timing, a 100BaseTX segment cannot exceed 100 meters in length. This specification of Ethernet is based on the IEEE 802.3 standard.

QUESTION NO: 1166

Which of the following best describes the Secure Electronic Transaction (SET) protocol?

- A. Originated by VISA and MasterCard as an Internet credit card protocol.
- B. Originated by VISA and MasterCard as an Internet credit card protocol using digital signatures.
- C. Originated by VISA and MasterCard as an Internet credit card protocol using the transport layer.
- D. Originated by VISA and MasterCard as an Internet credit card protocol using SSL.

Answer: B

Explanation: This protocol was created by VISA and MasterCard as a common effort to make the buying process over the Internet secure through the distribution line of those companies. It is located in layer 7 of the OSI model.

SET uses a system of locks and keys along with certified account IDs for both consumers and merchants. Then, through a unique process of "encrypting" or scrambling the information exchanged between the shopper and the online store, SET ensures a payment process that is convenient, private and most of all secure. Specifically, SET:

The SET process relies strongly on the use of certificates and digital signatures for the process of authentication and integrity of the information.

QUESTION NO: 1167

At which of the following phases of a software development life cycle are security and access controls normally designed?

- A. Coding
- B. Product design
- C. Software plans and requirements
- D. Detailed design

Answer: D

Explanation: Security controls and access controls are normally designed in the "Detailed" phase of design. In this phase you have the design of many of the security features of your development like authentication, confidentiality functionality, non repudiation capabilities. In this phase you can also define what is going to be the access control method for the software, we can make it discretionary (less restrictive), mandatory (more restrictive), role based and others.

QUESTION NO: 1168

Which type of control would password management classify as?

- A. Compensating control
- B. Detective control
- C. Preventive control
- D. Technical control

Answer: C

Explanation: Preventive technical controls are used to prevent unauthorized personnel or programs from gaining remote access to computing resources. Examples of these controls include:

- Access control software.
- Antivirus software.
- Library control systems.
- Passwords and Password management.
- Smart cards.
- Encryption.
- Dial-up access control and callback systems.

About Passwords: Passwords are used to verify that the user of an ID is the owner of the ID. The ID-password combination is unique to each user and therefore provides a means of holding users accountable for their activity on the system.

Fixed passwords that are used for a defined period of time are often easy for hackers to compromise; therefore, great care must be exercised to ensure that these passwords do not appear in any dictionary. Fixed passwords are often used to control access to specific data bases. In this use, however, all persons who have authorized access to the data base use the same password; therefore, no accountability can be achieved.

Currently, dynamic or one-time passwords, which are different for each log-on, are preferred over fixed passwords. Dynamic passwords are created by a token that is programmed to generate passwords randomly.

The management of those passwords is part of Preventive control.

QUESTION NO: 1169

Due is not related to:

- A. Good faith
- B. Prudent man
- C. Profit
- D. Best interest

Answer: C

Explanation: This is obviously a term not related to Profit, a “due” is not going to give us profit, its going to give us the opposite. Its always a good practice to pay your due. This can be learned in the real life. A Prudent man always pays its due, also a Good faith men pays them. This term is not related to profit.

QUESTION NO: 1170

Which of the following is not an Orange Book-defined life cycle assurance requirement?

- A. Security testing
- B. Design specification and testing
- C. Trusted distribution
- D. System integrity

Answer: D

Explanation: Life cycle assurance is more than configuration management.

Reference: “Operational assurance focuses on the basic features and architecture of a system that lend themselves to supporting security. There are five requirements or elements of operation assurance:

System architecture

System integrity

Covert channel analysis

Trusted facility management

Trusted Recovery

Life cycle assurance focuses on the controls and standards that are necessary for designing, building, and maintaining a system. The following are the four requirements or elements of life cycle assurance:

Security testing

Design specification and testing

Configuration Management

Trusted distribution"

Pg 398 Tittel

QUESTION NO: 1171

What is another name for the Orange Book?

- A. The Trusted Computer System Evaluation Criteria (TCSEC)
- B. The Trusted Computing Base (TCB)
- C. The Information Technology Security Evaluation Criteria (ITSEC)
- D. The Common Criteria

Answer: A

Explanation: The Trusted Computer System Evaluation Criteria (TCSEC) is a collection of criteria used to grade or rate the security offered by a computer system product. The TCSEC is sometimes referred to as "the Orange Book" because of its orange cover. The current version is dated 1985 (DOD 5200.28-STD, Library No.S225,711) The TCSEC, its interpretations and guidelines all have different color covers, and are sometimes known as the "Rainbow Series".

QUESTION NO: 1172

A password that is the same for each log-on session is called a?

- A. "one-time password"
- B. "two-time password"
- C. static password
- D. dynamic password

Answer: C

Explanation: A Static password is one that remains the same until its changed. Its like the password that we use in the operating systems, you set it, and then you always use the same password to logon to the system for the time of the session. This password will give us access to the system and will be the vehicle to create our access token in a successful way to get our privileges. A one-time password is only valid for one use, dynamic ones change every certain condition is met, and two-time passwords can only be used two times. We can provide certain times of access with this kind of passwords.

QUESTION NO: 1173

Which of the following backup methods is most appropriate for off-site archiving?

- A. Incremental backup method.
- B. Off-site backup method.
- C. Full backup method.
- D. Differential backup method.

Answer: C

Explanation: Since we want to maintain the backups offsite, its always better to send FULL-Backups because they contain a consistent base of the system. We perform the beginning of a restore through a full backup. Remember that the backups stored offsite are in most cases in a secure place, full backup in there are a best practice for any network administrator. With incremental or differential backups we don't have all we need to restore a system to a consistent state. We need to start from the full backup. "Offsite Backup" is not a valid backup method.

QUESTION NO: 1174

Which of the following is not a weakness of symmetric cryptography?

- A. Limited security
- B. Key distribution
- C. Speed
- D. Scalability

Answer: C

Explanation: In secret key cryptography, a single key is used for both encryption and decryption. The sender uses the key (or some set of rules) to encrypt the plaintext and sends the cipher text to the receiver. The receiver applies the same key (or rule set) to decrypt the message and recover the plaintext. Because a single key is used for both functions, secret key cryptography is also called symmetric encryption.

With this form of cryptography, it is obvious that the key must be known to both the sender and the receiver; that, in fact, is the secret. The biggest difficulty with this approach, of course, is the distribution of the key.

Symmetric encryption is around 1000 times faster than Asymmetric encryption, the second is commonly used just to encrypt the keys for Symmetric Cryptography.

QUESTION NO: 1175

Which of the following is not a defined layer in the TCP/IP protocol model?

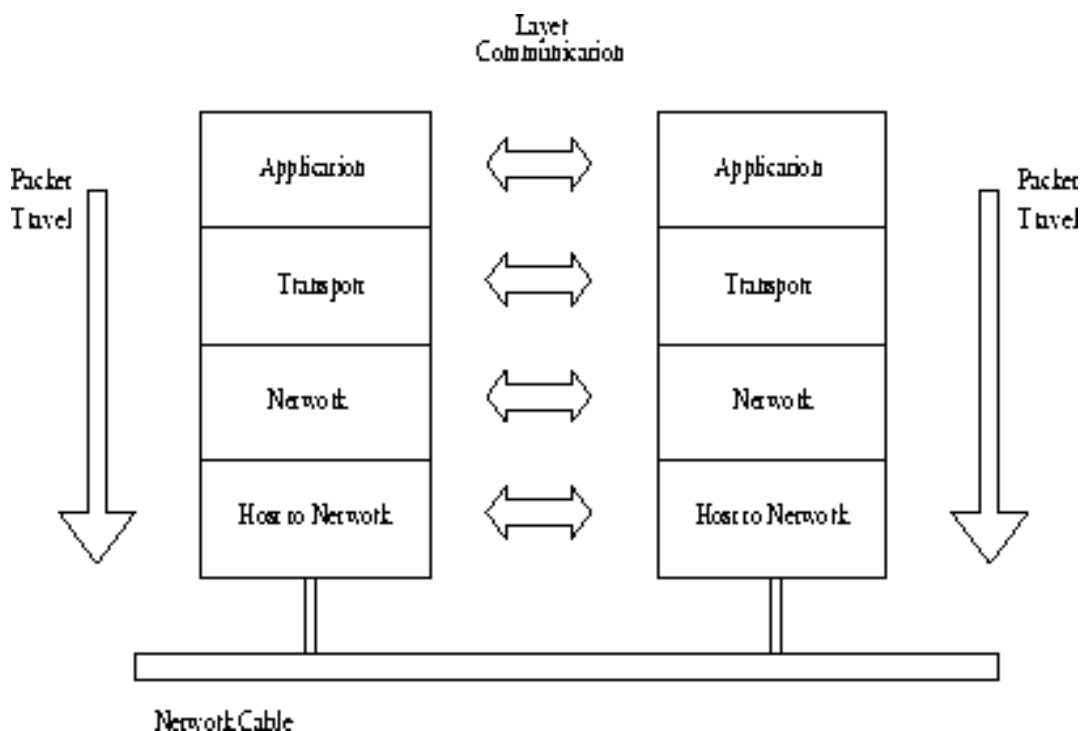
- A. Application layer
- B. Session layer
- C. Internet layer
- D. Network access layer

Answer: B

Explanation: The TCP/IP reference model is the network model used in the current Internet architecture. It has its origins back in the 1960's with the grandfather of the Internet, the ARPANET. This was a research network sponsored by the Department of Defense in the United States.

The reference model was named after two of its main protocols, TCP (Transmission Control

Protocol) and IP (Internet Protocol). They choose to build a packet-switched network based on a connectionless internet layer. Here is a representation of it:



"The TCP/IP Protocol Model is similar to the OSI model, but it defines only the following four layers instead of seven:

Application Layer. Consists of the applications and processes that use the network.

Host-to-Host Transport Layer. Provides end-to-end data delivery service to the Application Layer.

Internet Layer. Defines the IP datagram and handles the routing of data across networks.

Network Access or Link Layer. Consists of routines for accessing physical networks and the electrical connection."

Pg 112 Krutz: The CISSP Prep Guide: Gold Edition.

QUESTION NO: 1176

Rewritable and erasable (CDR/W) optical disk are sometimes used for backups that require short time storage for changeable data, but require?

- A. Faster file access than tape.
- B. Slower file access than tape.
- C. Slower file access than drive.
- D. Slower file access than scale.

Answer: A

Explanation: This is true, when we use optical media like CD's to make our backups we need a constant throughput on the file access and data transfer inside the disk because of the risk to get a buffer overrun error in the CD writer. If the buffer user by the CD burner is empty and the Hard disk does not provide data for that time, the Backup will be unsuccessful. This can be solved with a Technology known as "Burn Proof".

QUESTION NO: 1177

Which one of the following is not a primary component or aspect of firewall systems?

- A. Protocol filtering
- B. Packet switching
- C. Rule enforcement engine
- D. Extended logging capability

Answer: B

Explanation: This is not a main function of a firewall, packet switching is a main feature of a Switch (working only in the layer 2 of the OSI model). Firewall are network security devices that can function through layer 2 to layer 7 of the OSI model. They usually include rule engine that enforce the enterprise security policy of the company. They provide protocol filtering to enforce our requirements through the forwarded or deny of traffic. They also provide logging capabilities so we can analyze what is happening in a very low level in our network.

QUESTION NO: 1178

What are database views used for?

- A. To ensure referential integrity.
- B. To allow easier access to data in a database.
- C. To restrict user access to data in a database.
- D. To provide audit trails.

Answer: C

Explanation: Through the use of a view we can provide security for the organization restricting users access to certain data or to the real tables containing the information in our database. For example, we can create a view that brings data from 3 tables, only showing 2 of the 4 columns in each. Instead of giving access to the tables that contain the information, we give access to the view, so the user can access this fixed information but does not have privileges over the tables containing it. This provides security.

QUESTION NO: 1179

Which of the following Common Data Network Services is used to send and receive email internally or externally through an email gateway device?

- A. File services
- B. Mail services
- C. Print services
- D. Client/Server services

Answer: B

Explanation: This functionality is provided through mail services, this service permits collaboration between users in an internal and external level. We usually use two protocols, "SMTP" in port TCP 25 to send the emails and "POP3" in port TCP 110 to receive them. Currently there is another protocol that is gaining popularity, it is "IMAP4". Print services are used for printing documents and file services are used to share and access files and folders inside the

infrastructure.

QUESTION NO: 1180

Intrusion detection has which of the following sets of characteristics.

- A. It is adaptive rather than preventive.
- B. It is administrative rather than preventive.
- C. It is disruptive rather than preventative.
- D. It is detective rather than preventative.

Answer: D

Explanation: This is one of the features of intrusion detections, instead of being pro-active, it has a reactive behavior. When we set an IDS system inside of our network or hosts, the IDS agent is constantly monitoring in real time what activities are being performed in the infrastructure. If the IDS finds a malicious activity taking place it can take actions against it like disabling interfaces, alerting the administrators or sending network attacks to the source to put it out of service. As a difference to the detective behavior of IDS, we can also increase the security with practices like hardening our systems, this is considered a preventive practice.

QUESTION NO: 1181

Which type of password provides maximum security because a new password is required for each now log-on is defined to as?

- A. One-time or dynamic password
- B. Cognitive password
- C. Static password
- D. Pass phrase

Answer: A

Explanation: "One-time" or "dynamic" password technology concept is having your remote host already know a password that is not going to go over insecure channels and when you connect, you get a challenge. You take the challenge information and password and plug it into an algorithm which generates the response that should get the same answer if the password is the same on the both sides. Therefore the password never goes over the network, nor is the same challenge used twice. Unlike SecurID or SNK, with S/key you do not share a secret with the host. Other one time password technology is card systems where each user gets a card that generates numbers that allow access to their account. Without the card, it is improbable to guess the numbers.

QUESTION NO: 1182

They in form of credit card-size memory cards or smart cards, or those resembling small calculators, are used to supply static and dynamic passwords are called?

- A. Token Ring
- B. Tokens
- C. Token passing networks
- D. Coupons

Answer: B

Explanation: Tokens are usually used to provide authentication through "What we have", is most commonly implemented to provide two-factor authentication. For example, SecurID requires two pieces of information, a password and a token. The token is usually generated by the SecurID token – a small electronic device that users keep with them that display a new number every 60 seconds. Combining this number with the users password allows the SecurID server to determine whatever or not the user should be granted access.

QUESTION NO: 1183

Which of the following uses a directed graph to specify the rights that a subject can transfer to an object, or that a subject can take from another subject?

- A. Take-Grant model
- B. Access Matrix model
- C. Biba model
- D. Bell-Lapadula model

Answer: A

Explanation: The Take-Grant System is a model that helps in determining the protection rights (e.g., read or write) in a computer system. The Take-Grant system was introduced by Jones, Lipton, and Snyder to show that it is possible to decide on the safety of a computer system even when the number of subjects and objects are very large, or unbound. This can be accomplished in linear time based on the initial size of the system. The take-grant system models a protection system which consists of a set of states and state transitions. A directed graph shows the connections between the nodes of this system. These nodes are representative of the subjects or objects of the model. The directed edges between the nodes represent the rights that one node has over the linked node.

QUESTION NO: 1184

Which of the following is the BEST way to prevent software license violations?

- A. Implementing a corporate policy on copyright infringements and software use.
- B. Requiring that all PCs be diskless workstations.
- C. Installing metering software on the LAN so applications can be accessed through the metered software.
- D. Regularly scanning used PCs to ensure that unauthorized copies of software have not been loaded on the PC.

Answer: D

Explanation: Since its impossible to control all the efforts of the users to install software without the proper licenses in their PC's (Specially downloaded from the Internet), the best way to prevent licenses violations is through regular audit to every single user PC to see what's the installed programs are and what's the nature of them (Shareware, freeware, licensed). We cant use LAN

monitoring software because not all the applications are network enabled, also, there is usually a policy about software installation, but the users do not rely on them many times. It also a very nice practice to punish the users making software license violations.

QUESTION NO: 1185

Zip/Jaz drives, SyQuest, and Bemoulli boxes are very transportable and are often the standard for?

- A. Data exchange in many businesses.
- B. Data change in many businesses.
- C. Data compression in many businesses.
- D. Data interchange in many businesses.

Answer: A

Explanation: This is the primary use of this kind of devices, since they are very portable (a medium-size external box) and they provide standard interfaces to the PC, they are usually used in data exchange because of their high capacity in comparison to the 3.5 floppy diskettes. We can make changes in the media used by this devices, but is not their primary use. Compression is not the best feature of this devices, their usually depend on File system compression. Absolutely, the best use of this boxes is for data exchange.

QUESTION NO: 1186

What are two types of system assurance?

- A. Operational Assurance and Architecture Assurance.
- B. Design Assurance and Implementation Assurance.
- C. Architecture Assurance and Implementation Assurance.
- D. Operational Assurance and Life-Cycle Assurance.

Answer: D

Explanation: Software Systems Quality Assurance (SQA) is defined as a planned and systematic approach to the evaluation of the quality of and adherence to software product standards, processes, and procedures. SQA includes the process of assuring that standards and procedures are established and are followed throughout the software acquisition life cycle. Compliance with agreed-upon standards and procedures is evaluated through process monitoring, product evaluation, and audits. Software development and control processes should include quality assurance approval points, where an SQA evaluation of the product may be done in relation to the applicable standards. The 2 types available are : Operational assurance (that specified that the operation compiles with the required) and Life-Cycle assurance (that specifies that the system has passed through all the Software life-cycle).

QUESTION NO: 1187

Why does compiled code pose more risk than interpreted code?

- A. Because malicious code can be embedded in the compiled code and can be difficult to detect.
- B. Because the browser can safely execute all interpreted applets.
- C. Because compilers are not reliable.
- D. It does not. Interpreted code poses more risk than compiled code.

Answer: A

Explanation: Since the compiled code has already been translated to binary language (the language understood natively by the computers), its very difficult for us (the humans) to detect malicious code inside an application, this is because its not apparently visible, you have to find that malicious code through the behavior of the program. Instead, when we talk about Interpreted code, we use a language interpreter, that is a piece of software that allows the end-user to write a program in some human-readable language, and have this program executed directly by the interpreter.

This is in contrast to language compilers, that translate the human-readable code into machine-readable code, so that the end-user can execute the machine-readable code at a later time.

This is far more easier to detect malicious code inside the programs, you just need to see what piece of code produced the undesired action.

QUESTION NO: 1188

Which model, based on the premise that the quality of a software product is a direct function of the quality of its associated software development and maintenance processes, introduced five levels with which the maturity of an organization involved in the software process is evaluated?

- A. The Total Quality Model (TQM)
- B. The IDEAL Model
- C. The Software Capability Maturity Model
- D. The Spiral Model

Answer: C

Explanation: The Capability Maturity Model for Software describes the principles and practices underlying software process maturity and is intended to help software organizations improve the maturity of their software processes in terms of an evolutionary path from ad hoc, chaotic processes to mature, disciplined software processes. The CMM is organized into five maturity levels:

- 1) Initial. The software process is characterized as ad hoc, and occasionally even chaotic. Few processes are defined, and success depends on individual effort and heroics.
- 2) Repeatable. Basic project management processes are established to track cost, schedule, and functionality. The necessary process discipline is in place to repeat earlier successes on projects with similar applications.
- 3) Defined. The software process for both management and engineering activities is documented, standardized, and integrated into a standard software process for the organization. All projects use an approved, tailored version of the organization's standard software process for developing and maintaining software.
- 4) Managed. Detailed measures of the software process and product quality are collected. Both the software process and products are quantitatively understood and controlled.
- 5) Optimizing. Continuous process improvement is enabled by quantitative feedback from the process and from piloting innovative ideas and technologies.

QUESTION NO: 1189

Phreakers are hackers who specialize in telephone fraud. What type of telephone fraud simulates the tones of coins being deposited into a payphone?

- A. Red Boxes
- B. Blue Boxes
- C. White Boxes
- D. Black Boxes

Answer: A

Explanation: The Red box basically simulates the sounds of coins being dropped into the coin slot of a payphone. The traditional Red Box consisting of a pair of Wien-bridge oscillators with the timing controlled by 555 timer chips.

The Blue Box, The mother of all boxes, The first box in history, which started the whole phreaking scene. Invented by John Draper (aka "Captain Crunch") in the early 60s, who discovered that by sending a tone of 2600Hz over the telephone lines of AT&T, it was possible to make free calls.

A Black Box is a device that is hooked up to your phone that fixes your phone so that when you get a call, the caller doesn't get charged for the call. This is good for calls up to 1/2 hour, after 1/2 hour the Phone Co. gets suspicious, and then you can guess what happens.

The White Box turns a normal touch tone keypad into a portable unit. This kind of box can be commonly found in a phone shop.

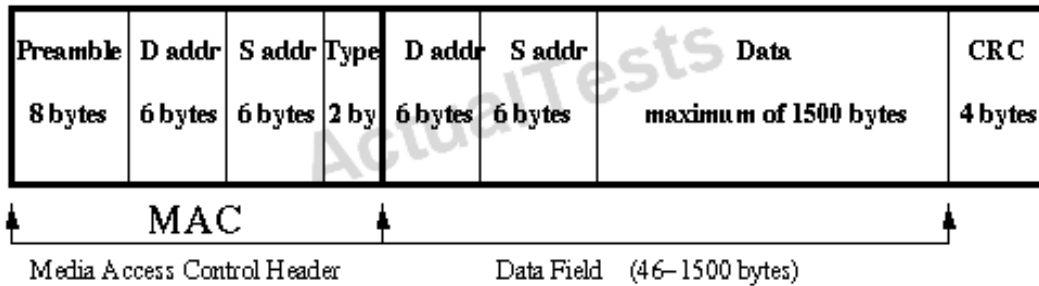
QUESTION NO: 1190

What is the proper term to refer to a single unit of Ethernet data?

- A. Ethernet segment
- B. Ethernet datagram
- C. Ethernet frame
- D. Ethernet packet

Answer: C

Explanation: Ethernet traffic is transported in units of a frame, where each frame has a definite beginning and end. Here is an Ethernet frame:



In this picture we define:

QUESTION NO: 1191

Which of the following represents an ALE calculation?

- A. Single loss expectancy x annualized rate of occurrence.
- B. Gross loss expectancy x loss frequency.
- C. Actual replacement cost – proceeds of salvage.
- D. Asset value x loss expectancy.

Answer: A

Explanation: ALE (Annualized Loss Expectancy) calculations are a component of every risk analysis process. ALE calculations when done properly portray risk accurately. ALE calculations provide meaningful cost/benefit analysis. ALE calculations are used to:

$$\text{SLE} \times \text{ARO} = \text{ALE}$$

QUESTION NO: 1192

IF an operating system permits executable objects to be used simultaneously by multiple users without a refresh of the objects, what security problem is most likely to exist?

- A. Disclosure of residual data.
- B. Unauthorized obtaining of a privileged execution state.
- C. Data leakage through covert channels.
- D. Denial of service through a deadly embrace.

Answer: A

Explanation: This is a well known issue knew by many programmers, since the operating system is allowing the executables to be used by many users in different sessions at the same time, and there is not refreshing every certain time, there will be a disclosure of residual data. To fix this we need to get sure that objects are refreshed frequently, for added security its better an OS that does not allow the use of an executable object by many users at the same time.

QUESTION NO: 1193

Tape arrays use a large device with multiple (sometimes 32 or 64) tapes that are configured as a?

- A. Single array
- B. Dual array
- C. Triple array
- D. Quadruple array

Answer: A

Explanation: This is the function of a tape robot/changer working on a media library / jukebox. We can get as many as 32 / 64 or even more tapes action as a single logical unit. You can have a robot that changes and retrieves the different tapes when they are needed, so you see the whole bunch of tapes as it's a single logical storage solution for you. This kind of solutions are very expensive.

QUESTION NO: 1194

Why would anomaly detection IDSs often generate a large number of false positives?

- A. Because they can only identify correctly attacks they already know about.
- B. Because they are application-based are more subject to attacks.
- C. Because they cant identify abnormal behavior.
- D. Because normal patterns of user and system behavior can vary wildly.

Answer: D

Explanation: One of the most obvious reasons why false alarms occur is because tools are stateless. To detect an intrusion, simple pattern matching of signatures is often insufficient. However, that's what most tools do. Then, if the signature is not carefully designed, there will be lots of matches. For example, tools detect attacks in sendmail by looking for the words "DEBUG" or "WIZARD" as the first word of a line. If this is in the body of the message, it's in fact innocuous, but if the tool doesn't differentiate between the header and the body of the mail, then a false alarm is generated.

Finally, there are many events happening in the course of the normal life of any system or network that can be mistaken for attacks. A lot of sysadmin activity can be catalogued as anomalous.

Therefore, a clear correlation between attack data and administrative data should be established to cross-check that everything happening on a system is actually desired.

Normal patterns and user activities are usually confused with attacks by IDS devices, its expected that the 2nd generations IDS systems will decrease the percent of false positives.

QUESTION NO: 1195

According to private sector data classification levels, how would salary levels and medical information be classified?

- A. Public
- B. Sensitive
- C. Private
- D. Confidential

Answer: C

Explanation: According to the classification levels of the private sector, this information is classified as Private because this information is from a personal nature. There is no need for other employees to see details about your health or you salary range, this can lead to internal problems inside the company, problems like jealous employees.

QUESTION NO: 1196

Which of the following is used in database information security to hide information?

- A. Inheritance
- B. Polyinstantiation
- C. Polymorphism
- D. Delegation

Answer: B

Explanation: Polyinstantiation represents an environment characterized by information stored in more than one location in the database. This permits a security model with multiple levels-of-view and authorization. The current problem with polyinstantiation is ensuring the integrity of the information in the database. Without an effective method for the simultaneous updating of all occurrences of the same data element - integrity cannot be guaranteed.

QUESTION NO: 1197

Which of the following evaluates the product against the specification?

- A. Verification
- B. Validation
- C. Concurrence
- D. Accuracy

Answer: A

Explanation: This is the proper term, "Verification", this term is used when we are making a comparison of a product against a specification. For example, you can have a product that is build on open standards, you can have a proof of that by making a "verification" of it against the standards or specifications included in those.

QUESTION NO: 1198

Application Level Firewalls are commonly a host computer running proxy server software, which makes a?

- A. Proxy Client
- B. Proxy Session
- C. Proxy System
- D. Proxy Server

Answer: D

Explanation: A proxy server is a server that sits between a client and server application, such as a Web browser and a source web server. It intercepts all requests to the real server to see if it can fulfill the requests itself. If not, it forwards the request to the original source web server. Firewalls usually provides this kind of services to have more control over user request and allow / deny the traffic of those through the gateway. At this time the most common Proxy server is for HTTP protocol, we can also have proxies for SMTP and FTP.

QUESTION NO: 1199

What attack involves the perpetrator sending spoofed packet(s) with the SYN flag set to the victim's machine on any open port that is listening?

- A. Bonk attack
- B. Land attack
- C. Teardrop attack
- D. Smurf attack

Answer: B

Explanation: The Land attack involves the perpetrator sending spoofed packet(s) with the SYN

flag set to the victim's machine on any open port that is listening. If the packet(s) contain the same destination and source IP address as the host, the victim's machine could hang or reboot.

In addition, most systems experience a total freeze up, where as CTRL-ALT-DELETE fails to work, the mouse and keyboard become non operational and the only method of correction is to reboot via a reset button on the system or by turning the machine off.

Vulnerable Systems:

This will affect almost all Windows 95, Windows NT, Windows for Workgroups systems that are not properly patched and allow Net Bios over TCP/IP.

In addition, machines running services such as HTTP, FTP, Identd, etc that do not filter packet(s), that contain the same source / destination IP address, can still be vulnerable to attack through those ports.

Prevention:

This attack can be prevented for open / listening ports by filtering inbound packets containing the same source / destination IP address at the router or firewall level.

For most home users not running a lot of services, and for those who use IRC, disabling the Identd server within their client will stop most attacks since the identd service (113) is becoming the most attacked service/port.

QUESTION NO: 1200

The beginning and the end of each transfer during asynchronous communication data transfer are marked by?

- A. Start and Stop bits.
- B. Start and End bits.
- C. Begin and Stop bits.
- D. Start and Finish bits.

Answer: A

Explanation: The ASYNCHRONOUS (ASYNC) format for data transmission is a procedure or protocol in which each information CHARACTER or BYTE is individually synchronized or FRAMED by the use of Start and Stop Elements, also referred to as START BITS and STOP BITS. The Asynchronous Transmission Format is also known as START-STOP mode or CHARACTER mode. Each character or byte is framed as a separate and independent unit of DATA that may be transmitted and received at irregular and independent time intervals. The characters or bytes may also be transmitted as a contiguous stream or series of characters.

QUESTION NO: 1201

Most of unplanned downtime of information systems is attributed to which of the following?

- A. Hardware failure
- B. Natural disaster
- C. Human error
- D. Software failure

Answer: A

Explanation: This is what the static's says. Most of the downtime is cause of unexpected hardware failure. Commonly you just replace the FRU (Field replazable unit) when they fail. Usually a well written software does not fail if the hardware is running correctly. The human errors are controllable and natural disasters are not very often. Hardware failure is very common, it's a good practice to have spare disks, NIC and any other hardware FRU's in your company to minimize the downtime with quick replacements.

QUESTION NO: 1202

Raid that functions as part of the operating system on the file server

- A. Software implementation
- B. Hardware implementation
- C. Network implementation
- D. Netware implementation

Answer: A

Explanation: This kind of RAID is totally depended on the operating system, this is because the server does not have any special hardware - RAID controller in the board. This kind of RAID implementation usually degrades performance because it takes many CPU cycles. A very

common example of software RAID is the support for it on Windows 2000 Server, where you can create RAID 0,1 and 5 through heterogeneous disks, you can even make a RAID between one SCSI and one EIDE disk. The software implementation is hardware independent always that the disks are recognized by the Operating System.

QUESTION NO: 1203

During which phase of an IT system life cycle are security requirements developed?

- A. Operation
- B. Initiation
- C. Development
- D. Implementation

Answer: B

Explanation: In this phase, user needs are identified and the basic security objectives of the product are acknowledged. It must be determined if the product will be processing sensitive data, and if so, the levels of sensitivity involved should be defined. An initial risk analysis should be initiated that evaluates threats and vulnerabilities to estimate the cost/benefit ratios of the different security countermeasures. Issues pertaining to security integrity, confidentiality, and availability need to be addressed. The level of each security attribute should be focused upon so a clear direction of security controls can begin to take shape. A basic security framework is designed for the project to follow, and risk management processes are established. Risk management will continue throughout the lifetime of the project. Risk information may start to be gathered and evaluated in the project initiation phase, but it will become more granular in nature as the phases graduate into the functional design and design-specification phase.

QUESTION NO: 1204

Ensuring that printed reports reach proper users and that receipts are signed before releasing

sensitive documents are examples of?

- A. Deterrent controls
- B. Output controls
- C. Information flow controls
- D. Asset controls

Answer: B

Explanation: Since we want to deal with printer reports, we are talking about output controls, Why, because printer produce output, and we can control it. As a best practice you can have people dedicated in the company to receive the different print jobs in the printing center, and people that takes care of the confidential information requiring a signature from the sender stating that the document was delivered to the owner in a timely and secure fashion.

QUESTION NO: 1205

Non-Discretionary Access Control. A central authority determines what subjects can have access to certain objects based on the organizational security policy. The access controls may be based on?

- A. The societies role in the organization.
- B. The individual's role in the organization.
- C. The group-dynamics as they relate to the individual's role in the organization.
- D. The group-dynamics as they relate to the master-slave role in the organization.

Answer: B

Explanation: An access control model defines a computer and/or network system's rules for user access to information resources. Access control models provide confidentiality, integrity and also provide accountability through audit trails. An audit trail documents the access of an object by a subject with a record of what operations were performed. Operations include: read, write, execute and own.

Non-Discretionary Access Control is usually role-based, centrally administered with authorization decisions based on the roles individuals have within an organization (e.g. bank teller, loan officer, etc. in a banking model). A system's security administrator grants and/or revokes system privileges based on a user's role. This model works well for corporations with a large turnover of

personnel.

QUESTION NO: 1206

An effective information security policy should not have which of the following characteristics?

- A. Include separation of duties.
- B. Be designed with a short-to mid-term focus.
- C. Be understandable and supported by all stakeholders.
- D. Specify areas of responsibility and authority.

Answer: B

Explanation: This is not a very good practice, specially for the CISSP examination, when you plan and develop the security policy for your enterprise you should always plan it with a long term focus. The policy should be created to be there for a long time, and you should only make revisions of it every certain time to comply with changes or things that could have changed. In a security policy the duties should be well specified, be understandable by the people involved in it, and specify areas of responsibility.

QUESTION NO: 1207

Which of the following statements pertaining to secure information processing facilities is incorrect?

- A. Walls should have an acceptable fire rating.
- B. Windows should be protected by bars.
- C. Doors must resist forcible entry.
- D. Location and type of fire suppression systems should be known.

Answer: B

Explanation: The correct answer can be determined through elimination. We need to have an acceptable fire rating for the walls, this is well known for any CISSP aspirant, its like that because we need to contain the fire as much as we can. We also need resistant doors so unauthorized people do not enter easily using the force. The people also need to know about fire suppression systems to be able to deal with a fire situation inside the facilities. As you can see, We should not protect windows with bars, this is a bad practice because, in the case of a fire, the people cannot get out of the building through the windows.

QUESTION NO: 1208

Making sure that the data is accessible when and where it is needed is which of the following?

- A. Confidentiality
- B. Integrity
- C. Acceptability
- D. Availability

Answer: D

Explanation: This is one of the pillars of network security. We can say that the data is available if we can access to it when we need it. This what is referred in the question, Availability refers to get access to data when and where you need it. Confidentiality deals with encryption and data protection against third party interception. Integrity deals with digital signatures and assures that the data has not changed. Acceptability is not a related term.

QUESTION NO: 1209

Business continuity plan development depends most on?

- A. Directives of Senior Management
- B. Business Impact Analysis (BIA)

- C. Scope and Plan Initiation
- D. Skills of BCP committee

Answer: B

Explanation: Business continuity is of course a vital activity. However, prior to the creation of a business continuity plan, it is essential to consider the potential impacts of disaster and to understand the underlying risks. It is now widely accepted that both business impact analysis and risk analysis are vital components of the business continuity process. However, many organizations are unsure of how to approach these important disciplines.

BIA is important because it provides management level analysis by which an organization assesses the quantitative (financial) and qualitative (non-financial) impacts, effects and loss that might result if the organization were to suffer a Business Continuity E/I/C. The findings from a BIA are used to make decisions concerning Business Continuity Management strategy and solutions.

QUESTION NO: 1210

Which layer defines the X.25, V.35, X.21 and HSSI standard interfaces?

- A. Transport layer
- B. Network layer
- C. Data link layer
- D. Physical layer

Answer: D

Explanation: The Physical Layer is the layer that is concerned with the signaling of the message and the interface between the sender or receiver and the medium. The physical layer is generally defined by one of the standards bodies and carries a designation that indicates the characteristics of the connection. Among frequently used physical layers standards are EIA-232-D, ITU V.35, and some of the X series (X.21/X.21bis, for example).

QUESTION NO: 1211

Related to information security, availability is the opposite of which of the following?

- A. Delegation
- B. Distribution
- C. Documentation
- D. Destruction

Answer: D

Explanation: This is the correct term, remember that Availability refers to get access to data when and where you need it. When we talk about destruction, we are saying the opposite, if your information is destroyed, you cant access to it neither when or where you want it. Delegation deals with permissions, distribution deals with deployment and documentation deals with information and how to's. The term we are looking here is definitively "destruction".

QUESTION NO: 1212

Which of the following is a disadvantage of a behavior-based ID system?

- A. The activity and behavior of the users while in the networked system may not be static enough to effectively implement a behavior-based ID system.
- B. The activity and behavior of the users while in the networked system may be dynamic enough to effectively implement a behavior-based ID system.
- C. The activity and behavior of the users while in the networked system may not be dynamic enough to effectively implement a behavior-based ID system.
- D. The system is characterized by high false negative rates where intrusions are missed.

Answer: A

Explanation: Behavior-based intrusion detection techniques assume that an intrusion can be detected by observing a deviation from normal or expected behavior of the system or the users. The model of normal or valid behavior is extracted from reference information collected by various means. The intrusion detection system later compares this model with the current activity. When a deviation is observed, an alarm is generated. In other words, anything that does not correspond to a previously learned behavior is considered intrusive. The high false alarm rate is generally cited as the main drawback of behavior-based techniques because the entire scope of the behavior of an information system may not be covered during the learning phase. Also, behavior can change over time, introducing the need for periodic online retraining of the behavior profile, resulting either in unavailability of the intrusion detection system or in additional false alarms. To get the most out of this kind of IDS you need to have very static behavior on your network and the user actions, this is because any new thing is considered dangerous, providing many false-positives but increased

security. If you are in a very “dynamic” environment these kind of IDS system is not recommended.

QUESTION NO: 1213

Which of the following statements pertaining to VPN protocol standards is false?

- A. L2TP is a combination of PPTP and L2F.
- B. L2TP and PPTP were designed for single point-to-point client to server communication.
- C. L2TP operates at the network layer.
- D. PPTP uses native PPP authentication and encryption services.

Answer: C

Explanation: The Layer 2 Tunnel Protocol (L2TP) is an emerging Internet Engineering Task Force (IETF) standard that combines the best features of two existing tunneling protocols: Cisco's Layer 2 Forwarding (L2F) and Microsoft's Point-to-Point Tunneling Protocol (PPTP). L2TP is an extension to the Point-to-Point Protocol (PPP), which is an important component for VPNs. VPNs allow users and telecommuters to connect to their corporate intranets or extranets. VPNs are cost-effective because users can connect to the Internet locally and tunnel back to connect to corporate resources. This not only reduces overhead costs associated with traditional remote access methods, but also improves flexibility and scalability.

PPTP and L2TP are Layer 2 tunneling protocols; both encapsulate the payload in a Point-to-Point Protocol (PPP) frame to be sent across an intermediate network.

QUESTION NO: 1214

What is the most critical characteristic of a biometric identifying system?

- A. Perceived intrusiveness
- B. Storage requirements

- C. Accuracy
- D. Reliability

Answer: C

Explanation: The principle of biometrics is to use some unique characteristic to identify whether the person is who they say they are. Biometrics works by matching or verifying a person's unique traits with stored data in two categories: physiological characteristics and those that are behavioral. Physical indicators include iris, fingerprint, facial, or hand geometry. Behavior types are usually voiceprints, keystroke dynamics and handwritten signatures. Most biometric technologies require special hardware to convert analog measurements of signatures, voices, or patterns of fingerprints and palm prints, to digital measurement, which computers can read. The biggest characteristic and problem of biometric implementations today is the accuracy, we must see the level of accuracy before buying a solution, because the technology is not perfect at this time and it can be erroneous sometimes.

QUESTION NO: 1215

RAID Software can run faster in the operating system because neither use the hardware-level parity drives by?

- A. Simple striping or mirroring.
- B. Hard striping or mirroring.
- C. Simple hamming code parity or mirroring.
- D. Simple striping or hamming code parity.

Answer: A

Explanation: This is true, if we do not use parity in our RAID implementation, like RAID 1 (Mirroring) or RAID 0 (Stripping) we can improve performance because the CPU does not need waste cycles to make the parity calculations. For example this can be achieved in Windows 2000 server through the use of RAID 0 (No fault tolerance, just stripping in 64kb chunks) or RAID 1 (Mirroring through a file system driver). This is not the case of RAID 5 that actually use parity to provide fault tolerance.

QUESTION NO: 1216

The guarantee that the message sent is the message received, and that the message was not intentionally or unintentionally altered is?

- A. Integrity
- B. Confidentiality
- C. Availability
- D. Identity

Answer: A

Explanation: Here are 2 definitions for Data Integrity:

Availability refers to get access to data when and where you need it. Confidentiality deals with encryption and data protection against third party interception. Identity deals with authentication.

QUESTION NO: 1217

Which of the following is a preventive control?

- A. Motion detectors
- B. Guard dogs
- C. Audit logs
- D. Intrusion detection systems

Answer: B

Explanation: This is very obvious. Since we want to prevent something from happening, we can go out and buy some Guard dogs to make the job. You are buying them because you want to prevent something from happening. The intruder will see the dogs and will maybe go back, this prevents an attack, this dogs are a form of preventive control. Motion Detectors and IDS are real-time, Audit Logs are passive.

QUESTION NO: 1218

What uses a key of the same length as the message?

- A. Running key cipher
- B. One-time pad
- C. Steganography
- D. Cipher block chaining

Answer: B

Explanation: The one time pad is the most secure, and one of the simplest of all cryptographic methods. It was invented and patented just after World War I by Gilbert Vernam (of AT&T) and Joseph Mauborgne (USA, later chief of the Signal Corps). The fundamental features are that the sender and receiver each have a copy of an encryption key, which is as long as the message to be encrypted, and each key is used for only one message and then discarded. That key must be random, that is without pattern, and must remain unknown to any attacker. In addition, the key must never be reused, otherwise the cipher becomes trivially breakable. One of its features it's the key length, it's the same as the message.

QUESTION NO: 1219

Which of the following protocols operates at the session layer (layer 5)?

- A. RPC
- B. IGMP
- C. LDP
- D. SPX

Answer: A

Explanation: The socket method of network use is a message-based system, in which one process writes a message to another. This is a long way from the procedural model. The remote procedure call is intended to act like a procedure call, but to act across the network transparently. The process makes a remote procedure call by pushing its parameters and a return

address onto the stack, and jumping to the start of the procedure. The procedure itself is responsible for accessing and using the network. After the remote execution is over, the procedure jumps back to the return address. The calling process then continues. RPC works at the Session layer of the OSI model.

QUESTION NO: 1220

Which of the following are NOT a countermeasure to traffic analysis?

- A. Padding messages
- B. Eavesdropping
- C. Sending noise
- D. Covert channel analysis

Answer: B

Explanation: Lets do this with a elimination process. With padding messages you can countermeasure traffic analysis because you add garbage information to the message to let in end in a fixed length, this can confuse the analyzer. Sending noise on the communication line could also countermeasure analysis because the analyzer don't now how to differentiate between real information and noise. You can also covert channel analysis. Eavesdropping does not apply in this situation, its not considered a counter measure to traffic analysis.

QUESTION NO: 1221

Which of the following layers of the ISO/OSI model do packet filtering firewalls operate at?

- A. Application layer
- B. Session layer
- C. Network layer
- D. Presentation layer

Answer: C

Explanation: Packet filtering firewalls work at the network level of the OSI model, or the IP layer of TCP/IP. These firewalls are normally part of a router, which is a device that receives and forwards packets to networks. "In a packet filtering firewall each packet is compared to a set of criteria before it is forwarded. Depending on the packet and the criteria, the firewall can drop the packet, forward it, or send a message to the originator." The criteria used to evaluate a packet include source, destination IP address, destination port, and protocol used. These types of firewalls are low in cost and don't have much of an impact on the network's performance.

QUESTION NO: 1222

A prolonged high voltage is?

- A. Spike
- B. Blackout
- C. Surge
- D. Fault

Answer: C

Explanation:

QUESTION NO: 1223

How do the Information Labels of Compartmented Mode Workstation differ from the Sensitivity Levels of B3 evaluated systems?

- A. Information Labels in CMW are homologous to Sensitivity Labels, but a different term was chosen to emphasize that CMW's are not described in the Orange Book.
- B. Information Labels contain more information than Sensitivity Labels, thus allowing more granular access decisions to be made.
- C. Sensitivity Labels contain more information than Information Labels because B3+ systems should store more sensitive data than workstations.

D. Information Labels contain more information than Sensitivity Labels, but are not used by the Reference Monitor to determine access permissions.

Answer: D

Explanation: The primary goal of the compartmented mode workstation (CMW) project was to articulate the security requirements that workstations must meet to process highly classified intelligence data. As a basis for the validity of the requirements developed, a prototype was implemented which demonstrated that workstations could meet the requirements in an operationally useful manner while still remaining binary compatible with off-the-shelf software. The security requirements not only addressed traditional security concerns but also introduced concepts in areas such as labeling and the use of a trusted window management system. The CMW labeling paradigm is based on associating two types of security labels with objects: sensitivity levels and information labels. Sensitivity levels describe the levels at which objects must be protected. Information labels are used to prevent data over classification and also provide a mechanism for associating with data those markings that are required for accurate data labeling, but which play no role in access control decisions. The use of a trusted window manager allows users to easily operate at multiple sensitivity levels and provides a convenient mechanism for communicating security information to users in a relatively unobtrusive manner. Information labels are not used by reference monitor, permissions are referenced in Sensibility labels.

QUESTION NO: 1224

In what security mode can a system be operating if all users have the clearance or authorization and need-to-know to all data processed within the system?

- A.** Dedicated security mode.
- B.** System-high security mode.
- C.** Compartmented security mode.
- D.** Multilevel security mode.

Answer: A

Explanation: An information-system (IS) security mode of operation wherein each user with direct or indirect access to the system, its peripherals, remote terminals, or remote hosts, has all of the following: (a) a valid security clearance for all information within the system; (b) formal access approval and signed nondisclosure agreements for all the information stored and/or processed (including all compartments, sub compartments, and/or special access programs); and (c) a valid

need-to-know for all information contained within the IS. When in the dedicated security mode, a system is specifically and exclusively dedicated to and controlled for the processing of one particular type or classification of information, either for full-time operation or for a specified period of time.

QUESTION NO: 1225

What are the three conditions that must be met by the reference monitor?

- A. Confidentiality, availability and integrity.
- B. Policy, mechanism and assurance.
- C. Isolation, layering and abstraction.
- D. Isolation, completeness and verifiability.

Answer: D

Explanation: These are three of the main characteristics of a Reference Monitor. You need Isolation, because it can't be of public access, the less access the better. It must have a sense of completeness to provide the whole information and process cycles. It must be verifiable, to provide security, audit and accounting functions.

QUESTION NO: 1226

While referring to Physical Security, what does Positive pressurization mean?

- A. The pressure inside your sprinkler system is greater than zero.
- B. The air goes out of a room when a door is opened and outside air does not go into the room.
- C. Causes the sprinkler system to go off.
- D. A series of measures that increase pressure on employees in order to make them more productive.

Answer: B

Explanation: Positive Pressurization is a condition that exists when more air is supplied to a space than is exhausted, so the air pressure within that space is greater than that in surrounding areas. This condition can cause the situation mentioned above in the answer B, you can make air go out of a room but not enter to it from the outside.

QUESTION NO: 1227

The baseline sets certain thresholds for specific errors or mistakes allowed and the amount of these occurrences that can take place before it is considered suspicious?

- A. Checkpoint level
- B. Ceiling level
- C. Clipping level
- D. Threshold level

Answer: C

Explanation: According to CISSP documentation, this is the proper term, The Clipping level is used to determine suspicious occurrences that are a production of errors or mistakes. Checkpoint level is not a related term. Ceiling level is not related to baselines. Threshold level is attractive, but is not the correct term. Take a look at your CISSP documentation.

QUESTION NO: 1228

The most prevalent cause of computer center fires is which of the following?

- A. AC equipment
- B. Electrical distribution systems.
- C. Heating systems
- D. Natural causes

Answer: B

Explanation: According to static's, this is the greatest cause, Electrical distribution systems, specially those not installed through standards are very prone to fail and make fire inside places. AC equipment its not very prone to make fire. Natural causes it's a possibility but is definitively not the most prevalent cause. Heating systems are a very rare case of Fire beginners.

QUESTION NO: 1229

An offsite backup facility intended to operate an information processing facility, having no computer or communications equipment, but having flooring, electrical wiring, air conditioning, etc. Is better known as a?

- A. Hot site
- B. Duplicate processing facility
- C. Cold site
- D. Warm site

Answer: C

Explanation: A cold site has all the appropriate power requirements, and floor space to install the hardware and to enable you to recreate your computer environment, but does not provide the actual equipment. Many of the companies that provide hot sites also provide cold sites. It may be reasonable for your company to consider creating its own cold site if your company has floor space available in another location than the home site. They require much more outage than Hot sites before operations can be restored.

QUESTION NO: 1230

Which of the following are necessary components of a Multi-Level Security Policy?

- A. Sensitivity Labels and a "system high" evaluation.
- B. Sensitivity Labels and Discretionary Access Control.
- C. Sensitivity Labels and Mandatory Access Control.

D. Object Labels and a “system high” evaluation.

Answer: C

Explanation: First implemented in Military organizations (and I think even today it's implemented there only), this model was a significant improvement in terms of security policy implementation. This model made implementation of complex security policies very simple. Its specifications are present in the orange book from DoD. In this model, every object is assigned a sensitivity label. Also, every user is assigned a sensitivity label. If a user's sensitivity label is greater than or equal to the sensitivity label, he is allowed access to the object, otherwise, he is denied access. This methodology is used for creating a hierarchy of access. We can say that this method is used for partitioning the organization hierarchy horizontally.

Multi-Level Security is considered a Mandatory Access Control method.

QUESTION NO: 1231

Which of the following, used to extend a network, has a storage capacity to store frames and act as a store-and-forward device?

- A.** Bridge
- B.** Router
- C.** Repeater
- D.** Gateway

Answer: A

Explanation: A bridge is a network device that connects two similar network segments together. The primary function of a bridge is to keep traffic separated on both sides of the bridge. Traffic is allowed to pass through the bridge only if the transmission is intended for a station in the opposite side. Bridges operate at the data link layer of the OSI model and provides two different collision domains in Ethernet, but they only provide one broadcast domain for layer 3 and up of the OSI model. The bridge can store frames and forward them in many forms like Cut-through and Store and Forward.

QUESTION NO: 1232

Which of the following is addressed by Kerberos?

- A. Authorization and authentication.
- B. Validation and integrity.
- C. Confidentiality and integrity.

Answer: C

Explanation: Kerberos is a network authentication protocol. It is designed to provide strong authentication for client/server applications by using secret-key cryptography. A free implementation of this protocol is available from the Massachusetts Institute of Technology. Kerberos is available in many commercial products as well. Kerberos was created by MIT as a solution to these network security problems. The Kerberos protocol uses strong cryptography so that a client can prove its identity to a server (and vice versa) across an insecure network connection. After a client and server has used Kerberos to prove their identity, they can also encrypt (confidentiality) all of their communications to assure privacy and data integrity as they go about their business.

QUESTION NO: 1233

Access Control techniques do not include which of the following choices?

- A. Relevant Access Controls
- B. Discretionary Access Control
- C. Mandatory Access Control
- D. Lattice Based Access Control

Answer: A

Explanation: Relevant Access Controls are not included as a Access Control Technique. Lattice-based access control models were developed in the early 1970s to deal with the confidentiality of military information. In the late 1970s and early 1980s, researchers applied these models to certain integrity concerns. Later, application of the models to the Chinese Wall policy, a confidentiality policy unique to the commercial sector, was demonstrated. Discretionary control is the most common type of access control mechanism implemented in computer systems today. The basis of this kind of security is that an individual user, or program

operating on the user's behalf, is allowed to specify explicitly the types of access other users (or programs executing on their behalf) may have to information under the user's control. Discretionary Access control security differs from mandatory access control security in that it implements the access control decisions of the user. Mandatory controls are driven by the results of a comparison between the user's trust level or clearance and the sensitivity designation of the information.

QUESTION NO: 1234

Why is public key cryptography recommended for use in the process of securing facsimiles during transmission?

- A. Keys are never transmitted over the network.
- B. Data compression decreases key change frequency.
- C. Key data is not recognizable from facsimile data.
- D. The key is securely passed to the receiving machine.

Answer: D

Explanation: In this method of cryptography we use 2 keys, one to encrypt the data, and another to decrypt it. In Public Key Cryptography, the users have a public and a private key, the public key is of free distribution and is usually published in a directory, while the private keys must be kept secure. This allows the keys to pass in a secure fashion to the receiving machine, its because the public key is not confidential and can be send through a secure channel. You need to use a certification authority to make this kind of cryptography work.

QUESTION NO: 1235

Database views are not used to:

- A. Implement referential integrity.

- B. Implement least privilege.
- C. To implement content-dependent access restrictions.
- D. Implement need-to-know.

Answer: A

Explanation: A View is a display of one or more table shows that shows the table data. You can even retrieve part of the table and display the same to the user. Before a user is able to use a view, they must have both, permission on the view and all dependent objects. Views can also be used to implement security, for example you can create a view that only shows 3 of 5 columns contained in a table. Views are not used to provide integrity you can use constraints, rule or other components of database systems.

QUESTION NO: 1236

Which of the following is most concerned with personnel security?

- A. Management controls
- B. Operational controls
- C. Technical controls
- D. Human resources controls.

Answer: B

Explanation: Personnel security always have to deal more with Operational controls, Operational controls provide the guidelines and the correct procedures to implement the different operations. Management controls are usually used only by managers. Human resources and Technical Controls are not related to personal security as the question states. See the different control definitions in your CISSP documentation.

QUESTION NO: 1237

Which of the following statements pertaining to the Trusted Computer System Evaluation Criteria (TCSEC) is incorrect?

- A. With TCSEC, functionality and assurance are evaluated separately.
- B. TCSEC provides a means to evaluate the trustworthiness of an information system.
- C. The Orange book does not cover networks and communications.
- D. Data base management systems are not covered by the TCSEC.

Answer: A

Explanation: TCSEC does not separate functionality and assurance from evaluation. It makes them a combined criteria. Just to remember, The Trusted Computer System Evaluation Criteria (TCSEC) is a collection of criteria used to grade or rate the security offered by a computer system product. The TCSEC is sometimes referred to as "the Orange Book" because of its orange cover (Orange Book deals with networks and communications). The current version is dated 1985 (DOD 5200.28-STD, Library No.S225,711) The TCSEC, its interpretations and guidelines all have different color covers, and are sometimes known as the "Rainbow Series". Database management is also covered in TCSEC.

The Orange Book is used to evaluate whether a product contains the security properties the vendor claims it does and whether the product is appropriate for a specific application or function. The Orange Book is used to review the functionality, effectiveness, and assurance of a product during its evaluation, and it uses classes that were devised to address typical patterns of security requirements.

– Shon Harris, "CISSP All-in-One Exam Guide", 3rd Ed, p 302.

QUESTION NO: 1238

Which of the following could illegally capture network user passwords?

- A. Data diddling
- B. Sniffing
- C. Spoofing
- D. Smurfing

Answer: B

Explanation: Sniffing is the action of capture the information going over the network. Most popular way of connecting computers is through Ethernet. Ethernet protocol works by sending packet information to all the hosts on the same circuit. The packet header contains the proper address of the destination machine. Only the machine with the matching address is suppose to accept the packet. A machine that is accepting all packets, no matter what the packet header says, is said to be in promiscuous mode. Because, in a normal networking environment,

account and password information is passed along Ethernet in clear-text, it is not hard for an intruder to put a machine into promiscuous mode and by sniffing, compromise all the machines on the net by capturing password in an illegal fashion.

QUESTION NO: 1239

Which trusted facility management concept implies that two operators must review and approve the work of each other?

- A. Two-man control
- B. Dual control
- C. Double control
- D. Segregation control

Answer: A

Explanation: The proper term for this trusted facility management concept is "Two-man Control", it means that two people must work and approve each others work to provide increased security and eliminate the possibility of one of them to hurt the company. For example they can only make changes to the system if both of them authenticate with their retina at the same time at the data center and enter their secret password This kind of work fashion is only used in highly secure environments, its not very common.

QUESTION NO: 1240

There are more than 20 books in the Rainbow Series. Which of the following covers password management guidelines?

- A. Orange Book
- B. Green Book
- C. Red Book

D. Lavender Book

Answer: B

Explanation: The DoD Password Management Guideline was published at 12 April 1985, it is also called the "Green Book" because of the color of its cover. Here is the password definition according to it: "A character string used to authenticate an identity. Knowledge of the password that is associated with a user ID is considered proof of authorization to use the capabilities associated with that user ID."

QUESTION NO: 1241

Which of the following is an ip address that is private? (i.e. reserved for internal networks, and not a valid address to use on the Internet)?

- A.** 172.5.42.5
- B.** 172.76.42.5
- C.** 172.90.42.5
- D.** 172.16.42.5

Answer: D

Explanation: The IP address 172.16.42.5 is contained in a class B reserved network, IANA reserved the 172.16.0.0 through 172.31.255.255 networks for internal use, this network its not routable in Internet and its commonly used in intranets. Class B networks are used in medium-sized networks. In class B networks, the two high order bits are always 10, and then remaining bits are used to define 16.384 networks, each with as many as 65.534 hosts attached. Examples of valid Class B networks include Microsoft and Exxon.

QUESTION NO: 1242

How fast is private key cryptography compared to public key cryptography?

- A. 10 to 100 times faster.
- B. 100 to 1000 times faster.
- C. 1000 to 10000 times faster.
- D. 10000 to 20000 times faster.

Answer: C

Explanation: Since Private Key encryption (Symmetric) only has one key for encrypt-decrypt, you need to use an alternative way to pass the shared secret in a secure manner, in our days, it's usually done by telephone or some secure methods that not involve the channel you are trying to secure. Also, since you need one different key to encrypt-decrypt every connection, the number of keys gets huge in a little time, for example, if we have 10 users trying to communicate between themselves, we have 100 different encryption keys to manage. There is an advantage for Private key encryption, the encryption is very fast, about 1000 / 10000 times faster than asymmetric encryption.

QUESTION NO: 1243

The continual effort of making sure that the correct policies, procedures and standards are in place and being followed is described as what?

- A. Due care
- B. Due concern
- C. Due diligence
- D. Due practice

Answer: A

Explanation: "Due care means that a company did all that it could have reasonable done to try and prevent security breaches, and also took the necessary steps to ensure that if a security breach did take place, the damages were reduced because of the controls or countermeasures that existed. Due care means that a company practiced common sense and prudent management practices with responsible actions. Due diligence means that the company properly investigated all of their possible weaknesses and vulnerabilities before carrying out any due care practices.

The following list describes some of the actions required to show that due care is being properly practiced in a corporation:

Adequate physical and logical access controls

Adequate telecommunication security, which could require encryption
Proper information, application, and hardware backups
Disaster recovery and business continuity plans
Periodic review, drills, tests, and improvement in disaster recovery and business continuity plans
Properly informing employees of expected behavior and ramifications of not following these expectations
Developing a security policy, standards, procedures, and guidelines
Performing security awareness training
Running updated antivirus software
Periodically performing penetration test from outside and inside the network
Implementing dial-back or preset dialing features on remote access applications
Abiding by and updating external service level agreements (SLAs)
Ensuring that downstream security responsibilities are being met
Implementing measure that ensure software piracy is not taking place
Ensuring that proper auditing and reviewing of those audit logs are taking place
Conducting background checks on potential employees”

Pg. 616 Shon Harris: CISSP Certification All-in-One Exam Guide

QUESTION NO: 1244

Which tape format type is mostly used for home/small office backups?

- A. Quarter Inch Cartridge drives (QIC)
- B. Digital Linear Tapes (DLT)
- C. 8mm tape
- D. Digital Audio Tape (DAT)

Answer: A

Explanation: QIC technology utilizes belt-driven dual-hub cartridges containing integral tape motion and guidance mechanisms, providing a rich spectrum of compatible solutions across a wide range of PC system platforms. QIC reliability is unsurpassed by any other removable storage technology. Reliability can be measured both in mean-time-between failure (MTBF) and, more practically, as a function of drive duty cycles. QIC has a worldwide installed base in excess of 15 million drives -- more than twice that of any alternate removable storage technology -- a level of

acceptance that would have been unachievable without rock-solid reliability. QIC is the most common tape solution for SOHO.

QUESTION NO: 1245

In an organization, an Information Technology security function should:

- A. Be a function within the information systems function of an organization.
- B. Report directly to a specialized business unit such as legal, corporate security or insurance.
- C. Be lead by a Chief Security Officer and report directly to the CEO.
- D. Be independent but report to the Information Systems function.

Answer: C

Explanation: This is one of the best practices because its not good to be lead and report to the same person, in that case, that person could take possession of everything that is happening and hurt the enterprise, we can't let that to happen with security concerns. The best practice is to always be lead by a different person that the one you report to, this can be checked in real life. An advice, always try to report to the highest person you can inside the company.

QUESTION NO: 1246

Who of the following is responsible for ensuring that proper controls are in place to address integrity, confidentiality, and availability of IT systems and data?

- A. Business and functional managers.
- B. IT Security practitioners.
- C. System and information owners.
- D. Chief information officer.

Answer: C

Explanation: This is true, the people who own the information and the equipment are the ones who need to ensure they are making everything to get integrity, confidentiality and availability. The security professionals can develop policies and show how to keep the environment secure, but it depends on the owners of the actual data to achieve the security.

QUESTION NO: 1247

The act of requiring two of the three factors to be used in the authentication process refers to?

- A. Two-Factor Authentication
- B. One-Factor Authentication
- C. Bi-Factor Authentication
- D. Double Authentication

Answer: A

Explanation: Two-Factor Authentication is a security process that confirms user identities using two distinctive factors—something you know, such as a Personal Identification Number (PIN), and something you have, such as a smart card or token.

The overall strength of Two-Factor Authentication lies in the combination of both factors, something you know and something you have.

QUESTION NO: 1248

This type of backup management provides a continuous on-line backup by using optical or tape “jukeboxes”, similar to WORMs, (Write Once, Read Many)

- A. Hierarchical Storage Management (HSM).
- B. Hierarchical Resource Management (HRM).
- C. Hierarchical Access Management (HAM).
- D. Hierarchical Instance Management (HIM).

Answer: A

Explanation: Hierarchical Storage Management originated in the mainframe world where it was used to minimize storage costs. The HSM name signifies that the software has the intelligence to move files along a hierarchy of storage devices that are ranked in terms of cost per megabyte of storage, speed of storage and retrieval, and overall capacity limits. Files are migrated along the hierarchy to less expensive forms of storage based on rules tied to the frequency of data access. File migration and retrieval is transparent to users. Two major factors, data access response time and storage costs determine the appropriate combination of storage devices used in HSM. A typical three tier strategy may be composed of hard drives as primary storage on the file servers, rewritable optical as the secondary storage type, and tape as the final tertiary storage location. If faster access is required, a hard drive can be considered as an alternative to optical for secondary storage, and WORM (Write Once, Read Many) optical can also be implemented, in place of tape, as the final storage destination.

QUESTION NO: 1249

Which of the following elements is not included in a Public Key Infrastructure (PKI)?

- A. Timestamping
- B. Lightweight Directory Access Protocol (LDAP)
- C. Certificate revocation
- D. Internet Key Exchange (IKE)

Answer: D

Explanation: Public key cryptography is one mechanism that is often used to fulfill the security requirements necessary to conduct electronic transactions over public networks.

PKI (public key infrastructure) and cryptography based solutions are taking the lead in secure e-commerce. PKI addresses nonrepudiation of identity using a dual-key encryption system that allows users to uniquely sign documents with a digital signature. Public key cryptography uses pairs of keys, each pair consisting of one public key and one private key. Information encrypted with one key in the pair can only be decrypted with the other key. LDAP is issued to bring user information and Timestamping to track changes over time. PKI also relies on certificated and CRL (Certificate Revocation list) to discard compromised, expired digital certificates.

QUESTION NO: 1250

Which of the following best corresponds to the type of memory addressing where the address location that is specified in the program instruction contains the address of the final desired location?

- A. Direct addressing
- B. Indirect addressing
- C. Indexed addressing
- D. Program addressing

Answer: B

Explanation: An addressing mode found in many processors' instruction sets where the instruction contains the address of a memory location which contains the address of the operand (the "effective address") or specifies a register which contains the effective address. Indirect addressing is often combined with pre- or post- increment or decrement addressing, allowing the address of the operand to be increased or decreased by one (or some specified number) either before or after using it.

QUESTION NO: 1251

Creation and maintenance of intrusion detection systems and processes for the following is one of them identify it:

- A. Event nonrepudiation
- B. Event notification
- C. Netware monitoring
- D. Guest access

Answer: B

Explanation: There is not much to explain or comment in here, when you administer an IDS system you have to deal with the maintenance and creation of event notification processes, this have to be reviewed every certain time. This is a well known topic for any Intrusion detection system administrator. This notifications will save your life when your network is being attacked and

you get real time notifications that will allow you to shut down your external interface before the attacker gets what he was looking for.

QUESTION NO: 1252

Which of the following is true related to network sniffing?

- A.** Sniffers allow an attacker to monitor data passing across a network.
- B.** Sniffers alter the source address of a computer to disguise and exploit weak authentication methods,
- C.** Sniffers take over network connections.
- D.** Sniffers send IP fragments to a system that overlap with each other.

Answer: A

Explanation: Sniffing is the action of capture / monitor the traffic going over the network.

Because, in a normal networking environment, account and password information is passed along Ethernet in clear-text, it is not hard for an intruder to put a machine into promiscuous mode and by sniffing, compromise all the machines on the net by capturing password in an illegal fashion.

QUESTION NO: 1253

Which of the following protocols is not implemented at the Internet layer of the TCP/IP protocol model?

- A.** User datagram protocol (UDP)
- B.** Internet protocol (IP)
- C.** Address resolution protocol (ARP)
- D.** Internet control message protocol (ICMP)

Answer: A

Explanation: UDP (User Datagram Protocol) is a communications method (protocol) that offers a limited amount of service when messages are exchanged between computers in a network that uses the Internet Protocol (IP). UDP is an alternative to the Transmission Control Protocol (TCP) and, together with IP, is sometimes referred to as UDP/IP. Like the Transmission Control Protocol, UDP uses the Internet Protocol to actually get a data unit (called a datagram) from one computer to another. Unlike TCP, however, UDP does not provide the service of dividing a message into packets (datagrams) and reassembling it at the other end. Specifically, UDP doesn't provide sequencing of the packets that the data arrives in. UDP is implemented at the Transport layer of the TCP/IP protocol model.

QUESTION NO: 1254

Which of the following is used to help business units understand the impact of a disruptive event?

- A. A risk analysis.
- B. A business impact assessment.
- C. A vulnerability assessment.
- D. A disaster recovery plan.

Answer: B

Explanation: A Business impact assessment can provide information in combination with the BIA to the different business units about how can an attack impact or disrupt the business. Every disaster recovery plan should include an study containing a BIA and a Business impact assessment to better understand how is going to be in the case that a business continuity disruptive event takes place.

QUESTION NO: 1255

A contingency plan should address?

- A. Potential risks
- B. Residual risks
- C. Identified risks
- D. All of the above

Answer: B

Explanation: This is true, as stated in CISSP documentation, you should address any possible "Residual Risk" at your contingency plan to minimize business impact when you are in a downtime situation. The identified Risks and the Potential Risks are not identified there, they are identified earlier.

QUESTION NO: 1256

In the OSI/ISO model, at what level is SET (SECURE ELECTRONIC TRANSACTION PROTOCOL) provided?

- A. Application
- B. Network
- C. Presentation
- D. Session

Answer: A

Explanation: This protocol was created by VISA and MasterCard as a common effort to make the buying process over the Internet secure through the distribution line of those companies. It is located in layer 7 of the OSI model, the application layer. SET uses a system of locks and keys along with certified account IDs for both consumers and merchants. Then, through a unique process of "encrypting" or scrambling the information exchanged between the shopper and the online store, SET ensures a payment process that is convenient, private and most of all secure.

QUESTION NO: 1257

A packet filtering firewall looks at the data packet to get information about the source and destination addresses of an incoming packet, the session's communications protocol (TCP, UDP

or ICMP), and the source destination application port for the?

- A. Desired service
- B. Dedicated service
- C. Delayed service
- D. Distributed service.

Answer: A

Explanation: This is true, the packets filters show the desired service port (Remember that they are layer 3 devices), this is because you can have many different referenced port number in the destination port field of the different packets. You have to look for the well-known port numbers of the service desired. For example, look in port 80 for HTTP and port 21 for FTP. This is the correct terminology, see the features of Packet Filters in your CISSP documentation.

QUESTION NO: 1258

Packet Filtering Firewalls system is considered a?

- A. First generation firewall.
- B. Second generation firewall.
- C. Third generation firewall.
- D. Fourth generation firewall.

Answer: A

Explanation: Firewall technology is a young but quickly maturing industry. The first generation of firewall architectures has been around almost as long as routers, first appearing around 1985 and coming out of Cisco's IOS software division. These firewalls are called packet filter firewalls. However, the first paper describing the screening process used by packet filter firewalls did not appear until 1988, when Jeff Mogul from Digital Equipment Corporation published his studies. At this time we are in the Fourth generation of firewall devices and software.

QUESTION NO: 1259

When should a post-mortem review meeting be held after an intrusion has been properly taken care of?

- A. Within the first three months after the investigation of the intrusion is completed.
- B. Within the first week after prosecution of intruders have taken place, whether successful or not.
- C. Within the first month after the investigation of the intrusion is completed.
- D. Within the first week of completing the investigation of the intrusion.

Answer: D

Explanation: As stated in CISSP documentation, you should make post mortem review meetings after taking care of the intrusion, and no more than one week after the facts. Its not a good practice to wait more than this time, it's a matter of common sense too, three months, one month, 2 weeks, its too much time.

QUESTION NO: 1260

Which of the following can be used as a covert channel?

- A. Storage and timing.
- B. Storage and low bits.
- C. Storage and permissions.
- D. Storage and classification.

Answer: A

Explanation: Those are the proper elements, you can use these two to achieve a covert channel. Low bits is not a term related to covert channels. Permissions are related to authentication, they do not achieve what the question wants. Also, classification is could not selected as a correct choice.

Check your official CISSP documentation to see what can be used as a covert channel.

“An active variation on eavesdropping is called Covert Channel eavesdropping, which consists of using a hidden unauthorized network connection to communicate unauthorized information. A Covert Storage Channel operates by writing information to storage by one process and then

reading by using another process from a different security level. A Covert Timing Channel signals information to another process by modulating its own resource use to affect the response time of another.” Pg. 101 Krutz: The CISSP Prep Guide: Gold Edition

QUESTION NO: 1261

Which software development model is actually a meta-model that incorporates a number of the software development models?

- A. The Waterfall model.
- B. The modified Waterfall model.
- C. The Spiral model.
- D. The Critical Patch Model (CPM).

Answer: C

Explanation: The spiral model for software engineering has evolved to encompass the best features of the classic waterfall model, while at the same time adding an element known as risk analysis. The spiral model is more appropriate for large, industrial software projects and has four main blocks/quadrants. Each release or version of the software requires going through new planning, risk analysis, engineering and customer evaluation phases and this is illustrated in the model by the spiral evolution outwards from the center. For each new release of a software product, a risk analysis audit should be performed to decide whether the new objectives can be completed within budget (time and costs), and decisions have to be made about whether to proceed. The level of planning and customer evaluation is missing from the waterfall model which is mainly concerned with small software programs. The spiral model also illustrated the evolutionary development of software where a solution may be initially proposed which is very basic (first time round the loop) and then later releases add new features and possibly a more elaborate GUI.

QUESTION NO: 1262

What is not true with pre-shared key authentication within IKE / IPsec protocol:

- A. Pre-shared key authentication is normally based on simple passwords.
- B. Needs a PKI to work.
- C. Only one preshared key for all VPN connections is needed.
- D. Costly key management on large user groups.

Answer: B

Explanation: Pre-Shared Secret is usually used when both ends of the VPN lacks access to a compatible certificate server. Once you have defined all the endpoints in your VPN, you can establish a password that is used to authenticate the other end of the connection, this is the Pre-Shared secret. Since you are using Pre-Shared key because you don't have an available / compatible certificate server, IPSEC and IKE do not need to use PKI in this case (that actually provides the certificate server infrastructure).

QUESTION NO: 1263

Which question is NOT true concerning Application Control?

- A. It limits end users of applications in such a way that only particular screens are visible.
- B. Only specific records can be requested choice.
- C. Particular uses of the application can be recorded for audit purposes.
- D. Is non-transparent to the endpoint applications so changes are needed to the applications involved.

Answer: D

Explanation: Application control provides a transparent feeling to endpoint applications when changes are needed, this is one of the features of it. With application control you can audit certain use of the applications involved and only specify record of your choice. There is also the possibility to limit the end users applications to provide access to only certain screens. Check your CISSP documentation about Application Control.

QUESTION NO: 1264

In order to ensure the privacy and integrity of the data, connections between firewalls over public networks should use?

- A. Screened subnets
- B. Digital certificates
- C. Encrypted Virtual Private Networks
- D. Encryption

Answer: C

Explanation: This is the correct answer, since firewall does not mean “VPN” we have to select “Encrypted Virtual Private Networks”. With a VPN and encryption we can provide secure communication in a transparent way for the users between the endpoints achieving “Confidentiality”. This confidentiality is achieved through encryption, and this encryption relies on encryption algorithms like AES, DES, CAST and others. Screened Subnet are not related to secure data over public networks, it's a place to put our network services accessible from the outside. Digital certificates do not provide confidentiality, they only provide integrity.

QUESTION NO: 1265

What is necessary for a subject to have write access to an object in a Multi-Level Security Policy?

- A. The subject's sensitivity label must dominate the object's sensitivity label.
- B. The subject's sensitivity label subordinates the object's sensitivity label.
- C. The subject's sensitivity label is subordinated by the object's sensitivity label.
- D. The subject's sensitivity label is dominated by the object's sensitivity label.

Answer: A

Explanation:

The correct answer is: The subject's sensitivity label must dominate the object's sensitivity label.

With a Multi-level security policy you have information that has different sensitivity labels. In order to read an object the subject's sensitivity label must be equal to or greater than that of the object. So it would be considered to dominate it, no read up.

The following answers are incorrect:

The subject's sensitivity label subordinates the object's sensitivity label. Is incorrect because if the subject's sensitivity label subordinates the object's sensitivity label that would mean it is lower and the subject should not have read access to the object.

The subject's sensitivity label is subordinated by the object's sensitivity label. Is incorrect because the this would not allow for read access if the sensitivity labels were equal. So the subject's sensitivity label is not subordinated by the object's sensitivity label, the subject's label must dominate the object's label. Remember dominate means equal to or greater than where subordinate means less than.

The subject's sensitivity label is dominated by the object's sensitivity label. Is incorrect because if the object's sensitivity label dominates the subject's sensitivity label then the subject should not have access, it is the subject that must dominate the object and not the other way around. Remember dominate means equal to or greater than so this would mean that the object's sensitivity label is equal to or greater than the subject.

According to the OIG, Multi-level security is defined as a class of system-containing information with different sensitivities that simultaneously permits access by users with different security clearances and need-to-know, but prevents users from obtaining access to information for which they lack authorization. The Subject's sensitivity label must be equal to or greater than the object's sensitivity label in order for the subject to have read access to it, no read up.

QUESTION NO: 1266

What best describes a scenario when an employee has been shaving off pennies from multiple accounts and depositing the funds into his own bank account?

- A. Data fiddling
- B. Data diddling
- C. Data hiding
- D. Data masking

Answer: B

Explanation: This kind of an attack involves altering the raw data just before it is processed by a computer and then changing it back after the processing is completed. This kind of attack was used in the past to make what is stated in the question, steal small quantities of money and

transfer them to the attackers account. See "Data deddling crimes" on the Web.

The most correct answer is 'Salami', but since that is not an option the most correct answer is data diddling.

"A salami attack is committing several small crimes with the hope that the overall larger crime will go unnoticed.An example would be if an employee altered a banking software program to subtract 5 cents from each of the bank's customers' accounts once a month and moved this amount to the employee's bank account. If this happened to all of the bank's 50,000 customer accounts, the intruder could make up to \$ 30,000 a year.

Data diddling refers to the alteration of existing data. Many times this modification happens before it is entered into an application or as soon as it completes processing and is outputted from an application.

There was an incident in 1997, in Maryland, where a Taco Bell employee was sentenced to ten years in jail because he reprogrammed the drive-up window cash register to ring up ever 42.99 order as one penny. He collected the full amount from the customer, put the penny in the till, and pocketed the other \$2.98. He made \$3600 before his arrest."

Pg. 602-603 Shon Harris: All-In-One CISSP Certification Exam Guide

QUESTION NO: 1267

Which of the following is unlike the other three?

- A. El Gamal
- B. Teardrop
- C. Buffer Overflow
- D. Smurf

Answer: A

Explanation: Options B, C and D are all Denial of Service attacks. El Gamal is the Diffie-Hellman key exchange algorithm and is usually described as an active exchange of keys by two parties. The buffer overflow attack objective is consume the available memory for the TCP/IP protocol stack to make the machine crash. Teardrop and Smurf are DoS attacks that make use of spoofing.

QUESTION NO: 1268

Phreakers are hackers who specialize in telephone fraud. What type of telephone fraud manipulates the line voltage to receive a toll-free call?

- A. Red Boxes
- B. Blue Boxes
- C. White Boxes
- D. Black Boxes

Answer: D

Explanation: A Black Box is a device that is hooked up to your phone that fixes your phone so that when you get a call, the caller doesn't get charged for the call. This is good for calls up to 1/2 hour, after 1/2 hour the Phone Co. gets suspicious, and then you can guess what happens.

The Red box basically simulates the sounds of coins being dropped into the coin slot of a payphone. The traditional Red Box consisting of a pair of Wien-bridge oscillators with the timing controlled by 555 timer chips. The Blue Box, The mother of all boxes, The first box in history, which started the whole phreaking scene. Invented by John Draper (aka "Captain Crunch") in the early 60s, who discovered that by sending a tone of 2600Hz over the telephone lines of AT&T, it was possible to make free calls.

The White Box turns a normal touch tone keypad into a portable unit. This kind of box can be commonly found in a phone shop.

QUESTION NO: 1269

Which of the following groups represents the leading source of computer crime losses?

- A. Hackers
- B. Industrial saboteurs
- C. Foreign intelligence officers

D. Employees

Answer: D

Explanation: This can be checked at the computer crime static's on the web. Most of the attacks, actually 70% of them, come from inside the company, and 80% of them from employees of it. This is a reality, when we protect our infrastructure be sure to give great importance to internal security, we don't when is one of the company employees going to make a strike. Hackers are also important, but less than our own employees.

QUESTION NO: 1270

Which of the following steps should be performed first in a business impact analysis (BIA)?

- A.** Identify all business units within the organization.
- B.** Evaluate the impact of disruptive events.
- C.** Estimate the Recovery Time Objectives (RTO).
- D.** Evaluate the criticality of business functions.

Answer: A

Explanation: Remember that when we talk about a BIA (Business Impact Analysis), we are analyzing and identifying possible issues about our infrastructure. It's an analysis about the business, the process that it relays on, the level of the systems and a estimative of the financial impact, or in other words, how much many we loose with our systems down. The first step on it should always be the identifying of the business units in the company. You can then go to other requirements like estimate losses and downtime costs.

QUESTION NO: 1271

Which of the following embodies all the detailed actions that personnel are required to follow?

- A. Standards
- B. Guidelines
- C. Procedures
- D. Baselines

Answer: C

Explanation: As stated in the dictionary, here are 3 definitions of procedure:

Its pretty visible that this is the term we are looking for as stated in the questions, you can check your CISSP documentation too.

QUESTION NO: 1272

Immune to the effects of electromagnetic interference (EMI) and therefore has a much longer effective usable length (up to two kilometers in some cases) is?

- A. Coaxial cable
- B. Twisted Pair cable
- C. Axial cable
- D. Fiber Optic cable

Answer: D

Explanation: Since fiber optics does not use electrical signals to transmit the information (it uses lights that goes through the mirrored silvered cable from source to end), its not affected by EMI (Electro Magnetic Interference) like other copper transmission methods like 10base5 and 10base2, therefore EMI does not affect the possible transmission distance. Fiber optics can have a great distance between end points, much greater than the copper transmission methods. Examples of Fiber optics standards are: 100BaseFX and 1000BaseFX.

QUESTION NO: 1273

Which of the following is the most reliable, secure means of removing data from magnetic storage media such as a magnetic tape, or cassette?

- A. Degaussing
- B. Parity Bit Manipulation
- C. Certification
- D. Buffer overflow

Answer: A

Explanation: An alternating current (AC) bulk eraser (degausser) is used for complete erasure of data and other signal on magnetic media. Degaussing is a process where magnetic media is exposed to a powerful, alternating magnetic field. Degaussing removes any previously written data, leaving the media in a magnetically randomized (blank) state. The degausser must subject the media to an alternating magnetic field of sufficient intensity to saturate the media and then by slowly withdrawing or reducing the field leaves the magnetic media in a magnetically neutral state.

QUESTION NO: 1274

Which of the following is an advantage of prototyping?

- A. Prototype systems can provide significant time and cost savings.
- B. Change control is often less complicated with prototype systems.
- C. It ensures that functions or extras are not added to the intended system.
- D. Strong internal controls are easier to implement.

Answer: A

Explanation: The Prototype Phase is also called the "Proof of Concept" Phase. Whether it's called one or the other depends on what the creator is trying to "prove." If the main deliverable of the Phase includes a working version of the product's technical features, it's a "prototype." If the main deliverable just looks like it has the product's technical features, then it's a "proof of concept." Prototypes can save time and money because you can test some functionality earlier in the process. You don't have to make the whole final product to begin testing it.

QUESTION NO: 1275

The IS security analyst's participation in which of the following system development life cycle

phases provides maximum benefit to the organization?

- A. System requirements definition.
- B. System design.
- C. Program development.
- D. Program testing.

Answer: B

Explanation:

QUESTION NO: 1276

Controls are implemented to?

- A. Eliminate risk and reduce the potential for loss.
- B. Mitigate risk and eliminate the potential for loss.
- C. Mitigate risk and reduce the potential for loss.
- D. Eliminate risk and eliminate the potential for loss.

Answer: C

Explanation: That's the essence of Controls, you put them in your environment to minimize the impact of a potential loss, with them you can also mitigate the risk and obtain the first through this. Controls are a very good practice to secure an environment, they should be considered by any security professional, CISSP or not, the risk should be minimized as much as you can.

QUESTION NO: 1277

A circuit level gateway is _____ when compared to an application level firewall.

- A. Easier to maintain.

- B. More difficult to maintain.
- C. More secure.
- D. Slower

Answer: A

Explanation: Since circuit level gateways are not as high in the OSI model for the inspection as Application level firewalls, they are easier to maintain and configure. Application layer firewalls are up to layer 7 of the OSI model and provide a great bunch of options and complex configurations. Application layer firewalls are more secure than circuit level gateway because they can track and analyze information up to layer 7, a drawback to this, is that this functionality makes them slower.

QUESTION NO: 1278

In IPSec, if the communication mode is gateway-gateway or host-gateway:

- A. Only tunnel mode can be used.
- B. Only transport mode can be used.
- C. Encapsulating Security Payload (ESP) authentication must be used.
- D. Both tunnel and transport mode can be used.

Answer: D

Explanation:

"IPSec can work in one of two modes: transport mode, where the payload of the message is protected, and tunnel mode, where the payload and the routing and header information is protected." Pg 527 Shon Harris: All-in-One CISSP Certification

Not:" Encapsulating Security Payload (ESP) authentication must be used"

"IPSec is not a strict protocol that dictates the type of algorithm, keys, and authentication method to be used, but it is an open, modular framework that provides a lot of flexibility for companies when they choose to use this type of technology. IPSec uses two basic security protocols: Authentication Header (AH) and the Encapsulating Security Payload (ESP). AH is the authenticating protocol, and ESP is an authenticating and encrypting protocol that uses cryptographic mechanisms to provide source authentication, confidentiality, and message integrity." Pg 527 Shon Harris: All-in-One CISSP Certification

QUESTION NO: 1279

Which integrity model defines a constrained data item, an integrity verification procedure and a transformation procedure?

- A. The Take-Grant model
- B. The Biba integrity model
- C. The Clark Wilson integrity model
- D. The Bell-LaPadula integrity model

Answer: C

Explanation: The Clark-Wilson model was developed to address security issues in commercial environments. The model uses two categories of mechanisms to realize integrity: well-formed transactions and separation of duty. It defines a constraint data item, a integrity verification and a transformation of that object. A possible way to represent a constraint that only certain trusted programs can modify objects is using application:checksum condition, where the checksum ensures authenticity of the application. Another way is using application:endorser condition, which indicates that a valid certificate, stating that the application has been endorsed by the specified endorser, must be presented. Static separation of duty is enforced by the security administrator when assigning group membership. Dynamic separation of duty enforces control over how permissions are used at the access time

QUESTION NO: 1280

Which of the following rules pertaining to a Business Continuity Plan/Disaster Recovery Plan is incorrect?

- A. In order to facilitate recover, a single plan should cover all locations.
- B. There should be requirements for to form a committee to decide a course of action. These decisions should be made ahead of time and incorporated into the plan.
- C. In its procedures and tasks, the plan should refer to functions, not specific individuals.

D. Critical vendors should be contacted ahead of time to validate equipment can be obtained in a timely manner.

Answer: A

Explanation: This is not the best practice, even more for the CISSP exam. Continuity / recovery plans should be made for every location in separate. This is because when there is a disaster, it's not usually in all the different locations, it's better to have one plan for each of them so you can use and follow only the plan of the affected site and don't bother the other ones.

QUESTION NO: 1281

What are suitable protocols for securing VPN connections?

- A.** S/MIME and SSH
- B.** TLS and SSL
- C.** IPsec and L2TP
- D.** PKCS# and X.509

Answer: C

Explanation: Both of them can be used to create and secure VPN's. The Layer 2 Tunnel Protocol (L2TP) is an emerging Internet Engineering Task Force (IETF) standard that combines the best features of two existing tunneling protocols: Cisco's Layer 2 Forwarding (L2F) and Microsoft's Point-to-Point Tunneling Protocol (PPTP). L2TP is an extension to the Point-to-Point Protocol (PPP), which is an important component for VPNs. VPNs allow users and telecommuters to connect to their corporate intranets or extranets. IPsec is a series of guidelines for the protection of Internet Protocol (IP) communications. It specifies ways for securing private information transmitted over public networks. Services supported by IPsec include confidentiality (encryption), authenticity (proof of sender), integrity (detection of data tampering) and replay protection (defense against unauthorized re-sending of data). It works on layer 3 of the OSI model and is the most common protocol used to create VPNs.

QUESTION NO: 1282

Which of the following questions is less likely to help in assessing identification and authentication controls?

- A. Is a current list maintained and approved of authorized users and their access?
- B. Are passwords changed at least every ninety days or earlier if needed?
- C. Are inactive user identifications disabled after a specified period of time?
- D. Is there a process for reporting incidents?

Answer: D

Explanation: We just some common sense to answer this question correctly, why are we going to ask about process reporting for incidents?, does is help relating to identification and authentication?, I don't think so. There are other more interesting questions, password deal with authentication, inactive user Ids are also related to identification. But the most important to me, know if there is a list with authorized users and their current access, this can help you to identify unauthorized activities.

QUESTION NO: 1283

The primary purpose for using one-way encryption of user passwords within a system is which of the following?

- A. It prevents an unauthorized person from trying multiple passwords in one logon attempt.
- B. It prevents an unauthorized person from reading or modifying the password list.
- C. It minimizes the amount of storage required for user passwords.
- D. It minimizes the amount of processing time used for encrypting passwords.

Answer: B

Explanation: This kind of encryption flavor increases security for passwords, if you use a one way encryption algorithm, you know that the encryption is not reversible, you cannot get the original value that you provided as a password from the resulting hash with any key or algorithm. This increase security in the way that when a person see the password list, it will only see the hash values and cannot read the original password or modify them without getting corruption.

QUESTION NO: 1284

The security of a computer application is most effective and economical in which of the following cases?

- A. The system is optimized prior to the addition of security.
- B. The system is procured off-the-shelf.
- C. The system is customized to meet the specific security threat.
- D. The system is designed originally to provide the necessary security.

Answer: D

Explanation: This is very obvious, if your system is designed from the ground up to provide security, its going to be cheaper and more effective at the end, because you don't need re-analysis, re-coding, and re-structure of the internal code of the computer application. If you don't address security at the beginning you will also need to spend time and money reviewing the code to try to put the security infrastructure in some place of it.

QUESTION NO: 1285

In the following choices there is one that is a typical biometric characteristics that is not used to uniquely authenticate an individual's identity?

- A. Retina scans
- B. Iris scans
- C. Palm scans
- D. Skin scans

Answer: D

Explanation: Answer A, B and C can be used to uniquely identify a person, but in the case of the Skin, there are no unique characteristics that can differentiate two distinct individuals in an acceptable accurate way. In the case of the IRIS and the Retina, there are not two of them equal. In the case of the palm, every person has different marks on it. The skin is common to all and

does not have specific textures or marks to make it unique in comparison to another individual.

QUESTION NO: 1286

Which of the following proves or disproves a specific act through oral testimony based on information gathered through the witness's five senses?

- A. Direct evidence
- B. Circumstantial evidence
- C. Conclusive evidence
- D. Corroborative evidence

Answer: A

Explanation: As stated in the CISSP documentation, "If you want to achieve the validation or revalidation of the oral testimony of a witness, you need to provide physical, direct evidence to backup your statements and override the five senses of an oral testimony". Circumstantial or Corroborative evidence is not enough in this case, we need direct, relevant evidence backing up the facts.

QUESTION NO: 1287

Which of the following would be defined as an absence of safeguard that could be exploited?

- A. A threat
- B. A vulnerability
- C. A risk
- D. An exposure

Answer: B

Explanation: In IT, a vulnerability is the weakness of a System to be exploited and corrupted by a

security hole. There is always a risk that our systems been vulnerable, with security we cannot make the risk to be 0%, but we can decrease the possibility of a threat becoming in a successful attack through one of those vulnerabilities. There is no system without vulnerabilities, we need to patch our systems frequently to reduce the risk of a threat through a vulnerability of one of our systems.

QUESTION NO: 1288

Which of the following is a LAN transmission protocol?

- A. Ethernet
- B. Ring topology
- C. Unicast
- D. Polling

Answer: C

Reference: "LAN Transmission Methods. LAN data is transmitted from the sender to one or more receiving stations using either a unicast, multicast, or broadcast transmission." pg 528 Hansche: Official (ISC)2 Guide to the CISSP Exam

QUESTION NO: 1289

Why would a database be denormalized?

- A. To ensure data integrity.
- B. To increase processing efficiency.
- C. To prevent duplication of data.
- D. To save storage space.

Answer: B

Explanation: Denormalization is the process of attempting to optimize the performance of data storage by adding redundant data. It is necessary because current DBMSs are not fully relational. A fully relational DBMS would be able to preserve full normalization at the logical level, while

allowing it to be mapped to performance-tuned physical level. Database designers often justify denormalization on performance issues, but they should note that logical denormalization can easily break the consistency of the database, one of the all-important ACID properties. However, a designer can achieve the performance benefits while retaining consistency by performing denormalization at a physical level; such denormalization is often called caching.

QUESTION NO: 1290

Under "Named Perils" form of Property insurance

- A. Burden of proof that particular loss is covered is on Insurer.
- B. Burden of proof that particular loss is not covered is on Insurer.
- C. Burden of proof that particular loss is covered is on Insured.
- D. Burden of proof that particular loss is not covered is on Insured.

Answer: B

Explanation: A insurance policy to cover fire damage is said to cover the "named peril" of fire. So, the insurer would need to prove that fire was not covered if the insurer was trying to deny the claim. The insured has no burden of proof other than showing damage was caused by fire.

QUESTION NO: 1291

The following is not true:

- A. Since the early days of mankind humans have struggled with the problems of protecting assets.
- B. The addition of a PIN keypad to the card reader was a solution to unreported card or lost card problem.
- C. There has never been of problem of lost keys.
- D. Human guard is an inefficient and sometimes ineffective method of protecting resources.

Answer: C

Explanation: This is absolutely false, this problem can be seen almost anywhere. There have always been trouble with the lost of keys. Some of those looses are more important than others, its not the same to lost the key of the company safe box, that lost the key of you locker with that contains your shoes.

This is obviously an incorrect statement, answer C is the one in here.

“Unfortunately, using security guards is not a perfect solution. There are numerous disadvantages to deploying, maintaining, and relying upon security guards. Not all environments and facilities support security guards. This may be due actual human incompatibility with the layout, design, location, and construction of the facility. Not all security guards are themselves reliable. Prescreening, bonding, and training does not guarantee that you won’t end up with an ineffective and unreliable security guard.” Pg 646 Tittel: CISSP Guide.

QUESTION NO: 1292

Which of the following statements pertaining to software testing approaches is correct?

- A.** A bottom-up approach allows interface errors to be detected earlier.
- B.** A top-down approach allows errors in critical modules to be detected earlier.
- C.** The test plan and results should be retained as part of the system’s permanent documentation.
- D.** Black box testing is predicted on a close examination of procedural detail.

Answer: C

Explanation: This is an absolute best practice in the software testing field, you should always have to keep all your testing approaches with the results as part of the product documentation. This can help you in the case you have problems with some tasks or components of the software in the future, you can check back your testing and results and see if the system was making the tasks correctly and if anything changed from that environment.

QUESTION NO: 1293

Which Orange Book evaluation level is described as "Structured Protection"?

- A. A1
- B. B3
- C. B2
- D. B1

Answer: C

Explanation: Class B2 corresponds to Structured Protection.

Division B - Mandatory Protection

Mandatory access is enforced by the use of security labels. The architecture is based on the Bell-LaPadula security model and evidence of the reference monitor enforcement must be available.

B1: Labeled Security Each data object must contain a classification label and each subject must have a clearance label. When a subject attempts to access an object, the system must compare the subject and the object's security labels to ensure the requested actions are acceptable. Data leaving the system must also contain an accurate security label. The security policy is based on an informal statement and the design specifications are reviewed and verified. It is intended for environments that handle classified data.

B2: Structured Protection The security policy is clearly defined and documented and the system design and implementation is subjected to more thorough review and testing procedures. This class requires more stringent authentication mechanisms and well-defined interfaces between layers. Subject and devices require labels, and the system must not allow covert channels. A trusted path for logon and authentication processes must be in place, which means there are no trapdoors. There is a separation of operator and administration functions within the system to provide more trusted and protected operational functionality. Distinct address spaces must be provided to isolated processes, and a covert channel analysis is conducted. This class adds assurance by adding requirements to the design of the system. The environment that would require B2 systems could process sensitive data that requires a higher degree of security. This environment would require systems that are relatively resistant to penetration and compromise.

B3 Security Domains In this class, more granularity is provided in each protects mechanism and the programming code that is not necessary to support the security is excluded. The design and implementation should not provide too much complexity because as the complexity of a system increases, the ability of the individuals who need to test, maintain, and configure it reduces; thus, the overall security can be threatened. The reference monitor components must be small enough to test properly and be tamperproof. The security administrator role is clearly defined and the system must be able to recover from failures without its security level being compromised. When

the system starts up and loads its operating system and components, it must be done in an initial secure state to ensure any weakness of the system cannot be taken advantage of in this slice of time. An environment that requires B3 systems is a highly secured environment that processes very sensitive information. It requires systems that are highly resistant to penetration.

Note: In class (B2) systems, the TCB is based on a clearly defined and documented formal security policy model that requires the discretionary and mandatory access control enforcement found in class (B1) systems be extended to all subjects and objects in the ADP system. In addition, covert channels are addressed. The TCB must be carefully structured into protection-critical and non-protection-critical elements. Class B corresponds to "Structured Protection" inside the Orange Book.

QUESTION NO: 1294

Which of the following questions should any user not be able to answer regarding their organization information security policy?

- A. Who is involved in establishing the security policy?
- B. Where is the organization security policy defined?
- C. What are the actions that need to be performed in case of a disaster?
- D. Who is responsible for monitoring compliance to the organization security policy?

Answer: C

Explanation: According to CISSP documentation, the actual definition and procedures defined inside an organization disaster recovery policy are of private nature. Only people working in the company and with a role inside it should know about those procedures. It's not a good practice to be divulging Disaster recovery procedures to external people. Many times external people need to know who is involved in it, and who is responsible. This could be the case of a vendor providing replacement equipment in case of disaster.

QUESTION NO: 1295

RAID Level 1 mirrors the data from one disk to set of disks using which of the following techniques?

- A. Copying the data onto another disk or set of disks.
- B. Moving the data onto another disk or set of disks.
- C. Establishing dual connectivity to another disk or set of disks.
- D. Establishing dual addressing to another disk or set of disks.

Answer: A

Explanation: RAID 1 or Mirroring is a technique in which data is written to two duplicate disks simultaneously through a copy process. This way if one of the disk drives fails, the system can instantly switch to the other disk without any loss of data or service. Disk mirroring is used commonly in on-line database systems where it's critical that the data be accessible at all times. RAID means "Redundant Array of Inexpensive Disks".

QUESTION NO: 1296

Which type of firewall can be used to track connectionless protocols such as UDP and RPC?

- A. Statefull inspection firewalls
- B. Packet filtering firewalls
- C. Application level firewalls
- D. Circuit level firewalls

Answer: A

Explanation: Here are some characteristics of Statefull Inspection technology on Firewalls:

QUESTION NO: 1297

Which of the following items should not be retained in an E-mail directory?

- A. Drafts of documents.
- B. Copies of documents.
- C. Permanent records.
- D. Temporary documents.

Answer: C

Explanation: This is another matter of common sense; the CISSP exam has many situations like this. It is not a good practice to have Permanent documents in your e-mail, this is because you don't know if your e-mail is always backed up, and maybe the document must be available in a corporate repository. There is no problem to have Copies, draft or temporary documents in your e-mail. The important ones for the company are the Permanent documents.

QUESTION NO: 1298

Which of the following department managers would be best suited to oversee the development of an information security policy?

- A. Information systems
- B. Human resources
- C. Business operations
- D. Security administration

Answer: C

Explanation: He is the most appropriate manager, this is because he know the inns and outs of the business processes inside the company. Remember that he manages the business operations, and are those operations the ones that make the company live and generate the revenue. He knows who should access what and when. Security administrators develop the policy with the information provided by persons like the Business operations manager. Human Resources is not appropriate in this case, and the Information systems manager know about the technology, but not the business needs of the company.

QUESTION NO: 1299

Which of the following countermeasures is not appropriate for war dialing attacks?

- A. Monitoring and auditing for such activity.
- B. Disabling call forwarding.
- C. Making sure only necessary phone numbers are made public.
- D. Using completely different numbers for voice and data accesses.

Answer: B

Explanation: War dialing, or scanning, has been a common activity in the computer underground and computer security industry for decades. Hollywood made war dialing popular with the 1983 movie, War Games, in which a teenager searching for a videogame company ultimately uncovers a government nuclear war warning system. The act of war dialing is extremely simple – a host computer dials a given range of telephone numbers using a modem. Every telephone number that answers with a modem and successfully connects to the host is stored in a log. Disabling call forwarding is not a useful countermeasure because it's the attacker machine the one who connects to the attacked system and forwarding is not an issue inside the attack. Answer A, C and D can be used as countermeasures to harder the war dial attack.

QUESTION NO: 1300

Which of the following tools is less likely to be used by a hacker?

- A. L0phtcrack
- B. Tripwire
- C. Crack
- D. John the Ripper

Answer: B

Explanation: Tripwire is a tool that checks to see what has changed on your system. The program monitors key attributes of files that should not change, including binary signature, size, expected change of size, etc. The hard part is doing it the right way, balancing security, maintenance, and functionality. This tool is not usually used by hackers to attack, its usually used to defend against hackers attacks. L0phtcrack is a hacker utility to get passwords, Crack and John the Ripper are also password crackers.

QUESTION NO: 1301

Which of the following logical access exposures involves changing data before, or as it is entered into the computer?

- A. Data diddling
- B. Salami techniques
- C. Trojan horses
- D. Viruses

Answer: A

Explanation: This kind of attack involves altering the raw data just before it is processed by a computer and then changing it back after the processing is completed. This kind of attack was used in the past to steal small quantities of money and transfer them to the attackers account, there are many other uses too. Trojan horses open ports without the user knowledge to permit remote control and a Virus is a malicious piece of code that executed inside your computer.

QUESTION NO: 1302

Which of the following computer aided software engineering (CASE) products is used for developing detailed designs, such as screen and report layouts?

- A. Lower CASE
- B. Middle CASE
- C. Upper CASE
- D. I-CASE

Answer: B

Explanation: This is the proper name, you can search for "Middle CASE" on the Internet. "Middle CASE" its a CASE flavor and UML design tool that provides the required functionality like screen

and report layouts and detailed designs. There are many well known vendors providing this kind of tools for the development process of Software.

QUESTION NO: 1303

What is called the number of columns in a table?

- A. Schema
- B. Relation
- C. Degree
- D. Cardinality

Answer: C

Explanation: In database terminology, is the same to say that the number of Degrees is "X" and that the number of columns is "X" inside a Table. This question is just trying to test our knowledge of rare, difficult to find terminology. You can check this in the knowledgebase of Oracle. When we talk about degrees, we are just talking about columns. The schema is the structure of the database, and the relations are the way each table relates to others.

QUESTION NO: 1304

Which of the following is the most reliable authentication device?

- A. Variable callback system
- B. Smart Card system
- C. Fixed callback system
- D. Combination of variable and fixed callback system.

Answer: B

Explanation: The smart card, an intelligent token, is a credit card sized plastic card embedded with an integrated circuit chip. It provides not only memory capacity, but computational capability

as well. The self-containment of smart card makes it resistant to attack as it does not need to depend upon potentially vulnerable external resources. Because of this characteristic, smart cards are often used in different applications which require strong security protection and authentication. Option B is the most correct option, this is because Callback systems are not considered very reliable in the CISSP examination, Smart cards can also provide 2 mode authentication.

"Caller ID and callback options are great, but they are usually not practical because they require users to call in from a static phone number each time they access the network. Most users are accessing the network remotely because they are on the road and moving from place to place."
Pg. 428 Shon Harris: All-In-One CISSP Certification Guide.

QUESTION NO: 1305

Which of the following firewall rules is less likely to be found on a firewall installed between an organization internal network and the Internet?

- A. Permit all traffic to and from local host.
- B. Permit all inbound ssh traffic
- C. Permit all inbound tcp connections.
- D. Permit all syslog traffic to log-server.abc.org.

Answer: C

Explanation: Option "C" is a very bad practice in a firewall connecting one of its interfaces to a public network like Internet. Since in that rule you are allowing all inbound TCP traffic, the hackers can send all the attacks they want to any TCP port, they can make port scanning, Syn Attacks, and many other dangerous DoS activities to our private network. Permit the traffic from local host is a best practice, our firewall is the local host. Permit SSH (Secure Shell) is also good because this protocol uses cryptography.

QUESTION NO: 1306

The Internet can be utilized by either?

- A. Public or private networks (with a Virtual Private Networks).
- B. Private or public networks (with a Virtual Private Networks).
- C. Home or private networks (with a Virtual Private Networks).
- D. Public or home networks (with a Virtual Private Networks).

Answer: C

Explanation:

QUESTION NO: 1307

This backup method must be made regardless of whether Differential or Incremental methods are used.

- A. Full Backup Method
- B. Incremental backup method
- C. Differential backup method
- D. Tape backup method

Answer: A

Explanation: Since the "Full" backup method provides a baseline for our systems for Restore, the full backup must be done at least once regardless of the method you are using. Its very common to use full backups in combination with incremental or differential ones to decrease the backup time (however you increment the restore time), but there is no way to maintain a system only with incremental or differential backups. You always need to begin from your restore baseline, the Full Backup.

QUESTION NO: 1308

Why do buffer overflows happen?

- A. Because buffers can only hold so much data.
- B. Because input data is not checked for appropriate length at time of input.

- C. Because they are an easy weakness to exploit.
- D. Because of insufficient system memory.

Answer: B

Explanation:

QUESTION NO: 1309

Which of the following should not be performed by an operator?

- A. Mounting disk or tape
- B. Backup and recovery
- C. Data entry
- D. Handling hardware

Answer: B

Explanation:

QUESTION NO: 1310

What security model is dependant on security labels?

- A. Discretionary access control
- B. Label-based access control
- C. Mandatory access control
- D. Non-discretionary access control

Answer: C

Explanation: With mandatory controls, only administrators and not owners of resources may make decisions that bear on or derive from policy. Only an administrator may change the category of a resource, and no one may grant a right of access that is explicitly forbidden in the access control policy. This kind of access control method is based on Security labels. It is important to note that mandatory controls are prohibitive (i.e., all that is not expressly permitted is forbidden).

QUESTION NO: 1311

Detection capabilities of Host-based ID systems are limited by the incompleteness of which of the following?

- A. Audit log capabilities
- B. Event capture capabilities
- C. Event triage capabilities
- D. Audit notification capabilities

Answer: A

Explanation: This is one of the weakest point of IDS systems installed on the individual hosts. Since much of the malicious activity could be circulating through the network, and this kind of IDS usually have small logging capabilities and of local nature. So any activity happening in the network could go unnoticed, and intrusions can't be tracked as in depth as we could with an enterprise IDS solution providing centralized logging capabilities.

QUESTION NO: 1312

Computer crime is generally made possible by which of the following?

- A. The perpetrator obtaining training & special knowledge.
- B. Victim carelessness.
- C. Collusion with others in information processing
- D. System design flaws.

Answer: B

Explanation: This is a real problem, nobody thinks that can be victim of a computer crime until it is. There is a big problem relating to the people thinking about this kind of attacks. Computer crimes can be very important and can make great damage to enterprises. Computer Crime will decrease once people begin to think about the Risks and begin to protect their systems from the

most common attacks.

QUESTION NO: 1313

The structures, transmission methods, transport formats, and security measures that are used to provide integrity, availability, authentication, and confidentiality for transmissions over private and public communications networks and media includes?

- A. The Telecommunications and Network Security domain.
- B. The Telecommunications and Netware Security domain.
- C. The Technical communications and Network Security domain.
- D. The Telnet and Network Security domain.

Answer: A

Explanation: This is pretty straight forward. The four principal pillars of computer security: integrity, authentication, confidentiality and availability are all part of the network security and telecommunication domain. Why? Because those pillars deal with that. We provide integrity through digital signatures, authentication through passwords, confidentiality through encryption and availability by fault tolerance and disaster recovery. All of those are networking and telecommunication components.

QUESTION NO: 1314

Which of the following is the lowest TCSEC class where in the system must protected against covert storage channels (but not necessarily covert timing channels)?

- A. B2
- B. B1
- C. B3
- D. A1

Answer: A

Explanation: The B2 class referenced in the orange book is the formal security policy model based on device labels that can use DAC (Discretionary access controls) and MAC (Mandatory Access Controls). It provides functionality about covert channel control. It does not require covert timing channels. You can review the B2 section of the Orange Book.

QUESTION NO: 1315

Which type of control is concerned with avoiding occurrences of risks?

- A. Deterrent controls
- B. Detective controls
- C. Preventive controls
- D. Compensating controls

Answer: C

Explanation: Preventive controls deals with the avoidance of risk through the diminution of probabilities. Is like the example we read earlier about the dogs. Just to remember, Since we want to prevent something from happening, we can go out and buy some Guard dogs to make the job. You are buying them because you want to prevent something from happening. The intruder will see the dogs and will maybe go back, this prevents an attack, this dogs are a form of preventive control.

QUESTION NO: 1316

The basic function of an FRDS is to?

- A. Protect file servers from data loss and a loss of availability due to disk failure.
- B. Persistent file servers from data gain and a gain of availability due to disk failure.

- C. Prudent file servers from data loss and a loss of acceptability due to disk failure.
- D. Packet file servers from data loss and a loss of accountability due to disk failure.

Answer: A

Explanation: FRDS systems will give us the functionality to protect our servers from disk failure and allow us to have highly available file services in our production servers. FRDS provides high availability against many types of disk failures and well known problems, if one disk goes down, the others still work providing no downtime. FRDS solutions are the preferred way to protect file servers against data corruption and loss. You can see more about FRDS in the Internet, search "FRDS System".

QUESTION NO: 1317

Which of the following protocols does not operate at the data link layer (layer 2)?

- A. PPP
- B. RARP
- C. L2F
- D. ICMP

Answer: D

Explanation: Internet Control Message Protocol. ICMP is used for diagnostics in the network. The Unix program, ping, uses ICMP messages to detect the status of other hosts in the net. ICMP messages can either be queries (in the case of ping) or error reports, such as when a network is unreachable. This protocol resides in layer 3 of the OSI model (Network layer).

QUESTION NO: 1318

This tape format can be used to backup data systems in addition to its original intended audio used by:

- A. Digital Audio tape (DAT)
- B. Digital video tape (DVT)
- C. Digital Casio Tape (DCT)
- D. Digital Voice Tape (DVT)

Answer: A

Explanation: Digital Audio Tape (DAT or R-DAT) is a signal recording and playback medium introduced by Sony in 1987. In appearance it is similar to a compact audio cassette, using 1/8" magnetic tape enclosed in a protective shell, but is roughly half the size at 73 mm x 54 mm x 10.5 mm. As the name suggests the recording is digital rather than analog, DAT converting and recording at the same rate as a CD (44.1 kHz sampling rate and 16 bits quantization) without data compression. This means that the entire input signal is retained. If a digital source is copied then the DAT will produce an exact clone.

The format was designed for audio use, but through an ISO standard it has been adopted for general data storage, storing from 4 to 40 GB on a 120 meter tape depending on the standard and compression (DDS-1 to DDS-4). It is, naturally, sequential-access media and is commonly used for backups. Due to the higher requirements for integrity in data backups a computer-grade DAT was introduced.

QUESTION NO: 1319

By examining the "state" and "context" of the incoming data packets, it helps to track the protocols that are considered "connectionless", such as UDP-based applications and Remote Procedure Calls (RPC). This type of firewall system is used in?

- A. First generation firewall systems.
- B. Second generation firewall systems.
- C. Third generation firewall systems.
- D. Fourth generation firewall systems.

Answer: C

Explanation: Statefull inspection is a third generation firewall technology designed to be aware of, and inspect, not only the information being received, but the dynamic connection and transmission state of the information being received. Control decisions are made by analyzing and utilizing the following: Communication Information, Communication derived state, Application derived state and information manipulation. Here are some characteristics of Statefull Inspection technology on Firewalls:

QUESTION NO: 1320

Guards are appropriate whenever the function required by the security program involves which of the following?

- A. The use of discriminating judgment.
- B. The use of physical force.
- C. The operation of access control devices.
- D. The need to detect unauthorized access.

Answer: A

Explanation: This is the correct answer, we don't have guards only to use physical force, that is not the real functionality of them if your security policy is well oriented. They are not only there to operate control devices and to detect unauthorized access, as stated in CISSP documentation, the appropriate function of a guard inside a security program is the use of discriminating judgment.

QUESTION NO: 1321

A server cluster looks like a?

- A. Single server from the user's point of view.
- B. Dual server from the user's point of view.
- C. Tripe server from the user's point of view.
- D. Quardle server from the user's point of view.

Answer: A

Explanation: A "Cluster" is a grouping of machines running certain services providing high availability and fault tolerance fro them. In other words, they are grouped together as a means of

fail over support. From the users view, a cluster is a single server, but its only a logical one, you can have an array of 4 server in cluster all with the same IP address (/achieving correct resolution through ARP), there is no difference for the client.

QUESTION NO: 1322

Which of the following are functions that are compatible in a properly segregated environment?

- A. Application programming and computer operation.
- B. System programming and job control analysis.
- C. Access authorization and database administration.
- D. System development and systems maintenance.

Answer: D

Explanation: If you think about it, System development and system maintenance are perfectly compatible, you can develop in the systems for certain time, and when it time for a maintenance, you stop the development process an make the maintenance. It's a pretty straight forward process. The other answer do not provide the simplicity and freedom of this option.

Incorrect answer:

Access authorization and database administration are NEVER compatible.

QUESTION NO: 1323

Encryption is applicable to all of the following OSI/ISO layers except:

- A. Network layer
- B. Physical layer
- C. Session layer
- D. Data link layer

Answer: B

Explanation: The Physical Layer describes the physical properties of the various communications media, as well as the electrical properties and interpretation of the exchanged signals. Ex: this layer defines the size of Ethernet coaxial cable, the type of BNC connector used, and the termination method. You cannot encrypt anything at this layer because it is physical, it is not protocol / software based. Network, Data link and transport layer supports encryption.

QUESTION NO: 1324

The Computer Security Policy Model the Orange Book is based on is which of the following?

- A. Bell-LaPadula
- B. Data Encryption Standard
- C. Kerberos
- D. Tempest

Answer: A

Explanation: Following the publication of the Anderson report, considerable research was initiated into formal models of security policy requirements and of the mechanisms that would implement and enforce those policy models as a security kernel. Prominent among these efforts was the ESD-sponsored development of the Bell and LaPadula model, an abstract formal treatment of DoD security policy.[2] Using mathematics and set theory, the model precisely defines the notion of secure state, fundamental modes of access, and the rules for granting subjects specific modes of access to objects. Finally, a theorem is proven to demonstrate that the rules are security-preserving operations, so that the application of any sequence of the rules to a system that is in a secure state will result in the system entering a new state that is also secure. This theorem is known as the Basic Security Theorem.

QUESTION NO: 1325

Which type of attack would a competitive intelligence attack best classify as?

- A. Business attack
- B. Intelligence attack
- C. Financial attack
- D. Grudge attack

Answer: A

Explanation: Since we are talking about a competitive intelligence attack, we can classify it as a Business attack because it is disrupting business activities. Intelligence attacks are one of the most commonly used to hurt a company where more it hurts, in its information. To see more about competitive intelligence attacks you can take a look at some CISSP study guide. It could be the CISSP gold edition guide.

“Military and intelligence attacks are launched primarily to obtain secret and restricted information from law enforcement or military and technological research sources.

Business attacks focus on illegally obtaining an organization’s confidential information.

Financial attacks are carried out to unlawfully obtain money or services.

Grudge attacks are attacks that are carried out to damage an organization or a person.”

Pg. 616 Tittel: CISSP Study Guide

QUESTION NO: 1326

Which of the following is responsible for the most security issues?

- A. Outside espionage
- B. Hackers
- C. Personnel
- D. Equipment failure

Answer: C

Explanation: As I stated earlier in the comments, the great part of the attacks to companies comes from the personnel. Hackers are out there and attack some targets, but should never forget that your worst enemy can be inside of your company. Is for that that we usually implement IDS and profundity security. It’s a very good practice to install Host based IDS to limit the ability of internal attackers through the machines.

Another problem with personal is the ignorance, there are time that they just don't know what they are doing, and certainly are violating the security policy.

QUESTION NO: 1327

Which of the following goals is NOT a goal of Problem Management?

- A. To eliminate all problems.
- B. To reduce failures to a manageable level.
- C. To prevent the occurrence or re-occurrence of a problem.
- D. To mitigate the negative impact of problems on computing services and resources.

Answer: A

Explanation: This is not possible, nobody can eliminate all problems, only god can, this is a reality and Problem Management Gurus know that. With problem management we can reduce failures, prevent reoccurrence of problems and mitigate negative impact as much as we can, but we cannot eliminate all problems, this is not a perfect world.

QUESTION NO: 1328

Examples of types of physical access controls include all except which of the following?

- A. badges
- B. locks
- C. guards
- D. passwords

Answer: D

Explanation: A password is not a physical thing, it's a logical one. You can control physical

access with armed guards, by locking doors and using badges to open doors, but you can't relate password to a physical environment. Just to remember, Passwords are used to verify that the user of an ID is the owner of the ID. The ID-password combination is unique to each user and therefore provides a means of holding users accountable for their activity on the system. They are related to software, not to hardware.

QUESTION NO: 1329

Which of the following statements pertaining to the (ISC)2 Code of Ethics is incorrect?

- A.** All information systems security professionals who are certified by (ISC)2 recognize that such a certification is a privilege that must be both earned and maintained.
- B.** All information systems security professionals who are certified by (ISC)2 shall provide diligent and competent service to principals.
- C.** All information systems security professionals who are certified by (ISC)2 shall discourage such behavior as associating or preparing to associate with criminals or criminal behavior.
- D.** All information systems security professionals who are certified by (ISC)2 shall promote the understanding and acceptance of prudent information security measures.

Answer: C

Explanation: This is not one of the statements of the ISC2 code of Ethics, ISC2 certified people is free to get in association with any person and any party they want. ISC2 thinks that their certified people must have liberty of choice in their associations. However ISC2 ask the certified professionals to promote the certification and the understanding and acceptance of security measures, they also ask the certified people to provide competent services and be proud of their exclusive ISC2 certified professional status.

I think is very fair, you are free to who where you want, with the people you want, but always be proud of your certification and your skills as a security professional.

Code from ISC web site.

"All information systems security professionals who are certified by (ISC)2 recognize that such certification is a privilege that must be both earned and maintained. In support of this principle, all Certified Information Systems Security Professionals (CISSPs) commit to fully support this Code of Ethics. CISSPs who intentionally or knowingly violate any provision of the Code will be subject to action by a peer review panel, which may result in the revocation of certification.

There are only four mandatory canons in the code. By necessity such high-level guidance is not

intended to substitute for the ethical judgment of the professional.

Additional guidance is provided for each of the canons. While this guidance may be considered by the Board in judging behavior, it is advisory rather than mandatory. It is intended to help the professional in identifying and resolving the inevitable ethical dilemmas that will confront him/her.

Code of Ethics Preamble:

- * Safety of the commonwealth, duty to our principals, and to each other requires that we adhere, and be seen to adhere, to the highest ethical standards of behavior.
- * Therefore, strict adherence to this code is a condition of certification.

Code of Ethics Canons:

- * Protect society, the commonwealth, and the infrastructure.
- * Act honorably, honestly, justly, responsibly, and legally.
- * Provide diligent and competent service to principals.
- * Advance and protect the profession.

The following additional guidance is given in furtherance of these goals.

Objectives for Guidance

In arriving at the following guidance, the committee is mindful of its responsibility to:

- * Give guidance for resolving good v. good and bad v. bad dilemmas.
- * To encourage right behavior such as:
 - * Research
 - * Teaching
 - * Identifying, mentoring, and sponsoring candidates for the profession
 - * Valuing the certificate
- * To discourage such behavior as:
 - * Raising unnecessary alarm, fear, uncertainty, or doubt
 - * Giving unwarranted comfort or reassurance
 - * Consenting to bad practice
 - * Attaching weak systems to the public net
 - * Professional association with non-professionals
 - * Professional recognition of or association with amateurs
 - * Associating or appearing to associate with criminals or criminal behavior

However, these objectives are provided for information only; the professional is not required or expected to agree with them.

In resolving the choices that confront him, the professional should keep in mind that the following guidance is advisory only. Compliance with the guidance is neither necessary nor sufficient for ethical conduct.

Compliance with the preamble and canons is mandatory. Conflicts between the canons should be resolved in the order of the canons. The canons are not equal and conflicts between them are not intended to create ethical binds.

Protect society, the commonwealth, and the infrastructure

- * Promote and preserve public trust and confidence in information and systems.

- * Promote the understanding and acceptance of prudent information security measures.
- * Preserve and strengthen the integrity of the public infrastructure.
- * Discourage unsafe practice.

Act honorably, honestly, justly, responsibly, and legally

- * Tell the truth; make all stakeholders aware of your actions on a timely basis.
- * Observe all contracts and agreements, express or implied.
- * Treat all constituents fairly. In resolving conflicts, consider public safety and duties to principals, individuals, and the profession in that order.
- * Give prudent advice; avoid raising unnecessary alarm or giving unwarranted comfort. Take care to be truthful, objective, cautious, and within your competence.
- * When resolving differing laws in different jurisdictions, give preference to the laws of the jurisdiction in which you render your service.

Provide diligent and competent service to principals

- * Preserve the value of their systems, applications, and information.
- * Respect their trust and the privileges that they grant you.
- * Avoid conflicts of interest or the appearance thereof.
- * Render only those services for which you are fully competent and qualified.

Advance and protect the profession

- * Sponsor for professional advancement those best qualified. All other things equal, prefer those who are certified and who adhere to these canons. Avoid professional association with those whose practices or reputation might diminish the profession.
- * Take care not to injure the reputation of other professionals through malice or indifference.
- Maintain your competence; keep your skills and knowledge current. Give generously of your time and knowledge in training others.

QUESTION NO: 1330

Which DES modes can best be used for authentication?

- A. Cipher Block Chaining and Electronic Code Book.
- B. Cipher Block Chaining and Output Feedback.
- C. Cipher Block Chaining and Cipher Feedback.
- D. Output Feedback and Electronic Code Book.

Answer: C

Explanation: Cipher Block Chaining (CBC) uses feedback to feed the result of encryption back into the encryption of the next block. The plain-text is XOR'ed with the previous cipher-text block

before it is encrypted. The encryption of each block depends on all the previous blocks. This requires that the decryption side processes all encrypted blocks sequentially. This mode requires a random initialization vector which is XOR'ed with the first data block before it is encrypted. The initialization vector does not have to be kept secret. The initialization vector should be a random number (or a serial number), to ensure that each message is encrypted uniquely. In the Cipher Feedback Mode (CFB) is data encrypted in units smaller than the block size. This mode can be used to encrypt any number of bits e.g. single bits or single characters (bytes) before sending across an insecure data link.

Both of those method can be best used to provide user authentication capabilities.

QUESTION NO: 1331

In the OSI / ISO model, at what layer are some of the SLIP, CSLIP, PPP control functions are provided?

- A. Data Link
- B. Transport
- C. Presentation
- D. Application

Answer: A

Explanation: The Data Link layer takes raw data from the physical layer and gives it logical structure. This logic includes information about where the data is meant to go, which computer sends the data, and the overall validity of the bytes sent. The Data Link layer also controls functions of logical network topologies and physical addressing as well as data transmission synchronization and corrections. SLIP, CSLIP and PPP provide control functions at the Data Link Layer (layer 2 of the OSI model).

QUESTION NO: 1332

Which of the following best describes the purpose of debugging programs?

- A. To generate random data that can be used to test programs before implementing them
- B. To ensure that program coding flaws are detected and corrected.
- C. To protect, during the programming phase, valid changes from being overwritten by other changes.
- D. To compare source code versions before transferring to the test environment.

Answer: B

Explanation: A bug is a coding error in a computer program. The process of finding bugs before program final users is called debugging. Debugging starts after the code is first written and continues in successive stage as code is combined with other units of programming to form a software product, such as an operating system or application. The main reason to debug is to detect and correct errors in the program.

QUESTION NO: 1333

With RAID Level 5 the spare drives that replace the failed drives are usually hot swappable, meaning they can be replaced on the server while the?

- A. System is up and running.
- B. System is down and running.
- C. System is in-between and running.
- D. System is centre and running.

Answer: A

Explanation: This is true, since RAID 5 uses parity to provide fault tolerance through the array, once one of the disks in it can become corrupted, and you usually can just take it out without turning off the system (Hot SWAP) and plug a spare disk on the bay. Then the array will automatically begin to reconstruct the information in the new disk with the parity contained through the other disks in the array. This Hot Swap capability is usually present in enterprise servers that require high availability.

QUESTION NO: 1334

What is the process that RAID Level 0 uses as it creates one large disk by using several disks?

- A. Striping
- B. Mirroring
- C. Integrating
- D. Clustering

Answer: A

Explanation: This is the correct term, with stripping RAID 0 can evenly distribute the information through the disk that form the array in a transparent way for the final user. With RAID 0 you can be writing to 12 disk simultaneously and you see them as only one large logical partition. This level of RAID does not provide fault tolerance but provides an increase in performance because you are writing and reading from many disks and heads. An example of this stripping is the software version that comes with Windows 2000, it supports up to 32 disks.

QUESTION NO: 1335

Which of the following is used to create and delete views and relations within tables?

- A. SQL Data Definition Language
- B. SQL Data Manipulation Language
- C. SQL Data Relational Language
- D. SQL Data Identification Language

Answer: A

Explanation: SQL supports the data definition language (DDL) for creating, altering, and deleting tables and indexes. SQL does not permit metadata object names to be represented by parameters in DDL statements. With this language you can create many of the objects used in SQL, this language is standard and is supported by most database vendors in its standard form. Many of

them also extends its functionality for proprietary products.

QUESTION NO: 1336

Which division of the Orange Book deals with discretionary protection (need-to-know)?

- A. D
- B. C
- C. B
- D. A

Answer: B

Explanation: The C division of the Orange Book deals discretionary (need-to-know) protection and, through the inclusion of audit capabilities, for accountability of subjects and the actions they initiate.

This information can be checked in the orange book. Just make a search online through it with the words "discretionary protection".

QUESTION NO: 1337

The Diffie-Hellman algorithm is used for?

- A. Encryption
- B. Digital signature
- C. Key exchange
- D. Non-repudiation

Answer: C

Explanation: Diffie Hellman is a Key exchange algorithm, its strength is in the difficulty of computing discrete logarithms in a finite field generated by a large primary number. Although RSA and Diffie Hellman are similar in mathematical theory, their implementation is somewhat different.

This algorithm has been released to the public. It's the primary alternative to the RSA algorithm for key exchange.

QUESTION NO: 1338

Primary run when time and tape space permits, and is used for the system archive or baselined tape sets is the?

- A. Full backup method.
- B. Incremental backup method.
- C. Differential backup method.
- D. Tape backup method.

Answer: A

Explanation: "Full" backup method provides a baseline for our systems for Restore; the full backup must be done at least once regardless of the method you are using to make backups. It's very common to use full backups in combination with incremental or differential ones to decrease the backup time (however you increment the restore time with incremental and differential) because it takes the largest time to complete. You always need to begin a system restoration from your baseline, and this baseline is the Full Backup.

QUESTION NO: 1339

Which of the following teams should not be included in an organization's contingency plan?

- A. Damage assessment team.
- B. Hardware salvage team.
- C. Tiger team.
- D. Legal affairs team.

Answer: C

Explanation: In the computer industry, a tiger team is a group of programmers or users who volunteer or are hired to expose errors or security holes in new software or to find out why a computer network's security is being broken. In hiring or recruiting volunteers for a tiger team, some software developers advise others to be sure that tiger team members don't include crackers, who might use their special knowledge of the software to disable or compromise it in the future. We don't need a tiger team inside our contingency plan, however, we do need someone to assess the damage, the hardware and legal affairs.

QUESTION NO: 1340

When an organization takes reasonable measures to ensure that it took precautions to protect its network and resources is called:

- A. Reasonable Action
- B. Security Mandate
- C. Due Care
- D. Prudent Countermeasures

Answer: C

Explanation: Due care are the steps taken to show it has taken responsibility for its actions.

QUESTION NO: 1341

What two things below are associated with security policy?(Choose Two)

- A. Support of upper management
- B. Support of department managers
- C. Are tactical in nature
- D. Are strategic in nature
- E. Must be developed after procedures
- F. Must be developed after guidelines

Answer: A,D

Explanation: Policies are written as a broad overview and require the support of upper management. After the development and approval of policies, guidelines and procedures may be

written.

QUESTION NO: 1342

Total risk is equal to:(Choose All That Apply)

- A. Threat
- B. Vulnerability
- C. Frequency
- D. Asset value
- E. Asset loss

Answer: A,B,D

Explanation: Total risk = asset value * vulnerability * threats

QUESTION NO: 1343

Government data classifications include which of the following:(Choose four)

- A. Open
- B. Unclassified
- C. Confidential
- D. Private
- E. Secret
- F. Top Secret

Answer: B,C,E,F

Explanation: One of the most common systems used to classify information is the one developed within the US Department of Defense. These include: unclassified, sensitive, confidential, secret, and top secret.

QUESTION NO: 1344

Job rotation is important because:

- A. It insures your employees are cross-trained.
- B. It increases job satisfaction.
- C. It reduces the opportunity for fraud

Answer: C

Explanation: Job rotation is tightly tied to the principle of least privilege. It is an effective security control.

QUESTION NO: 1345

Your co-worker is studying for the CISSP exam and has come to you with a question. What is ARP poisoning?

- A. Flooding of a switched network
- B. A denial of service that uses the DNS death ping
- C. Turning of IP to MAC resolution
- D. Inserting a bogus IP and MAC address in the ARP table
- E. Modifying a DNS record

Answer: D

Explanation: ARP poisoning is a masquerading attack where the attacker inserts a bogus IP and MAC address in a victims ARP table or into the table of a switch. This has the effect of redirecting traffic to the attacker and not to the intended computer.

QUESTION NO: 1346

What is the best description for CHAP Challenge Handshake Authentication Protocol?

- A. Passwords are sent in clear text
- B. Passwords are not sent in clear text
- C. Passwords are not used, a digital signature is sent
- D. It is substandard to PAP

E. It was used with PS2's and has been discontinued

Answer: B

Explanation: Passwords are not sent in clear text. The server performing the authentication sends a challenge value and the user types in the password. The password is used to encrypt the challenge value then is sent back to the authentication server.

QUESTION NO: 1347

CSMA/CD computers cannot communicate without a token.(True/False)

- A. True
- B. False

Answer: B

Explanation: CSMA/CD computers do not use a token. It is the media access method used in Ethernet.

QUESTION NO: 1348

_____ sends out a message to all other computers indicating it is going to send out data.

- A. CSMA/CD
- B. CSMA/CA
- C. CSMA/HB
- D. PPP
- E. SLIP

Answer: B

Explanation: CSMA/CA sends out a message to all other computers indicating it is going to send out data. CSMA/CA or token ring networking uses this approach to reduce the amount of data collisions.

Note: When computers use the carrier sense multiple access with collision detection (CSMA/CD) protocols, they monitor the transmission activity, or carrier activity, on the wire so that they can

determine when would be the best time to transmit data.

Carrier sense multiple access with collision avoidance (CSMA/CA) is an access method where each computer signals its intent to transmit data before it actually does so.

pg 390-391 Shon Harris All-In-One CISSP Certification

QUESTION NO: 1349

Which of the following best describes ISDN BRI(Choose two)

- A. 2 B channels
- B. 4 B channels
- C. 23 B channels
- D. 1 D channel
- E. 2 D channels

Answer: A,D

Explanation: ISDN BRI has 2 B and 1 D channels

QUESTION NO: 1350

The top speed of ISDN BRI is 256 KBS.(True/False)

- A. True
- B. False

Answer: B

Explanation: The top speed of ISDN BRI is 128 KBS. Its two primary channels are each capable of carrying 64 KBS so the combined top speed is 128 KBS.

QUESTION NO: 1351

Which of the following should NOT be implemented to protect PBX's?(Choose all that apply)

- A. Change default passwords and configurations
- B. Make sure that maintenance modems are on 24/7
- C. Review telephone bill regularly
- D. Block remote calling after business hours
- E. Post PBX configuration and specs on the company website

Answer: B,E

Explanation: Many vendors have maintenance modems that vendors can use to troubleshoot systems and provide updates. They should normally be turned off. Also information about the system should not be posted on the website and should be closely guarded.

QUESTION NO: 1352

Which of the following best describes the difference between a circuit based and application based firewall?

- A. Application based is more flexible and handles more protocols
- B. Circuit based provides more security
- C. Application based builds a state table
- D. Circuit based looks at IP addresses and ports
- E. Circuit based firewalls are only found in Cisco routers

Answer: D

Explanation: Circuit based look only at IP address and ports, whereas application based dig much deeper into the packet. This makes it more secure.

QUESTION NO: 1353

_____ is the fraudulent use of telephone services.

- A. Rolling
- B. Warzing
- C. Wardriving
- D. Wardialing

E. Phreaking

Answer: E

Explanation: Phreaking is the fraudulent use of telephone services.

QUESTION NO: 1354

What is another name for a VPN?

- A. Firewall
- B. Tunnel
- C. Packet switching
- D. Pipeline
- E. Circuit switching

Answer: B

Explanation: A VPN creates a secure tunnel through an insecure network.

QUESTION NO: 1355

Which of the following is a connection-orientated protocol?

- A. IP
- B. UDP
- C. TCP
- D. ICMP
- E. SNMP
- F. TFTP

Answer: C

Explanation: TCP is a connection-orientated protocol.

QUESTION NO: 1356

Which of the following is not considered firewall technology?

- A. Screened subnet
- B. Screened host
- C. Dual gateway host
- D. Dual homed host

Answer: C

Explanation: Dual gateway host is not considered firewall technology.

QUESTION NO: 1357

Which type of network topology passes all traffic through all active nodes?

- A. Broadband
- B. Star
- C. Baseband
- D. Token Ring

Answer: D

Explanation: Token ring passes all traffic through nodes.

QUESTION NO: 1358

The act of validating a user with a unique and specific identifier is called what?

- A. Validation
- B. Registration
- C. Authentication
- D. Authorization
- E. Identification

Answer: C

Explanation: Authentication is the act of validating a user with a unique and specific identifier.

..

QUESTION NO: 1359

Why is fiber the most secure means of transmission?

- A. High speed multiplexing
- B. Interception of traffic is more difficult because it is optically based
- C. Higher data rates make it more secure
- D. Multiplexing prevents traffic analysis
- E. Built-in fault tolerance

Answer: B

Explanation: Fiber is more secure because it is hard to tap into and gives off no EMI such as copper cabling.

QUESTION NO: 1360

The IAB defines which of the following as a violation of ethics?

- A. Performing a DoS
- B. Downloading an active control
- C. Performing a penetration test
- D. Creating a virus
- E. Disrupting Internet communications

Answer: E

Explanation: The IAB considers the Internet a privilege, not a right, and as such considers it unethical to purposely disrupt communications.

QUESTION NO: 1361

A chain of custody shows who _____ and _____.(Choose three)

- A. Who controlled the evidence
- B. Who transcribed the evidence
- C. Who validated the evidence
- D. Who presented the evidence
- E. Secured the evidence
- F. Obtained the evidence

Answer: A,E,F

Explanation: The chain of evidence shows who obtained the evidence, who secured the evidence, and who controlled the evidence.

QUESTION NO: 1362

Good forensics requires the use of a bit level copy?(True/False)

- A. True
- B. False

Answer: A

Explanation: Good forensics requires the use of a bit level copy. A bit level copy duplicates all information on the suspect's disk. This includes slack space and free space.

QUESTION NO: 1363

Which agency shares the task of investigating computer crime along with the FBI?

- A. Secret Service
- B. CIA
- C. Department of justice
- D. Police force
- E. NSA

Answer: A

Explanation: Along with the FBI, the Secret Service has been given the authority to investigate computer crime.

QUESTION NO: 1364

This type of password recovery is considered more difficult and must work through all possible combinations of numbers and characters.

- A. Passive
- B. Active
- C. Dictionary
- D. Brute force
- E. Hybrid

Answer: D

Explanation: Brute force cracking is considered more difficult and must work through all possible combinations of numbers and characters.

QUESTION NO: 1365

_____ are added to Linux passwords to increase their randomness.

- A. Salts
- B. Pepper
- C. Grains
- D. MD5 hashes
- E. Asymmetric algorithms

Answer: A

Explanation: Salts are added to Linux passwords to increase their randomness. They are used to help insure that no two users have the same, hashed password.

QUESTION NO: 1366

The Linux root user password is typically kept in where?(Choose two)

- A. etc/shadow
- B. cmd/passwd
- C. etc/passwd
- D. windows/system32
- E. var/sys
- F. var/password

Answer: A,C

Explanation: The Linux root user password is typically kept in /etc/passwd or etc/shadow.

QUESTION NO: 1367

The goal of cryptanalysis is to _____.

- A. Determine the number of encryption permutations required
- B. Reduce the system overhead for a crypto-system
- C. Choose the correct algorithm for a specified purpose
- D. Forge coded signals that will be accepted as authentic
- E. Develop secure crypto-systems

Answer: D

Explanation: The goal of cryptanalysis is to forge coded signals that will be accepted as authentic.

QUESTION NO: 1368

If an employee is suspected of computer crime and evidence need to be collected, which of the following departments must be involved with the procedure?

- A. Public relations
- B. Law enforcement
- C. Computer security
- D. Auditing
- E. HR

Answer: E

Explanation: Human Resources always needs to be involved if an employee is suspected of wrongdoing. They know what rules apply to protect and prosecute employees.

QUESTION NO: 1369

What is it called when a system has apparent flaws that were deliberately available for penetration and exploitation?

- A. A jail
- B. Investigation
- C. Enticement
- D. Data manipulation
- E. Trapping

Answer: C

Explanation: Administrators that leave systems with apparent flaws are performing an act of enticement. This is sometimes called a honeypot.

QUESTION NO: 1370

Why are computer generated documents not considered reliable?

- A. Difficult to detect electron tampering
- B. Stored in volatile media
- C. Unable to capture and reproduce
- D. Too delicate
- E. Because of US law, Section 7 paragraph 154

Answer: A

Explanation: Because it is difficult to detect electron tampering and can be easily modified.

QUESTION NO: 1371

What is the name of the software that prevents users from seeing all items or directories on a computer and is most commonly found in the UNIX/Linux environment?

- A. Shell Kits
- B. Root Kits
- C. Ethereal
- D. Shadow data
- E. Netbus

Answer: D

Explanation:

QUESTION NO: 1372

What is a commercial application of steganography that is used to identify pictures or verify their authenticity?

- A. A MAC
- B. A digital checksum
- C. A MD5 hash
- D. A digital signature
- E. A watermark

Answer: E

Explanation: A watermark is a commercial application of steganography that is used to identify pictures or verify its authenticity.

QUESTION NO: 1373

What are the basic questions that must be asked at the beginning of any investigation?(Choose all that apply)

- A. Who
- B. Cost
- C. What
- D. When

- E. Where
- F. How
- G. Time frame
- H. Budget

Answer: A,C,D,E,F

Explanation: At the beginning of any investigation, an investigator must ask who, what, when, where, and how. Answering the questions will lead to the successful conclusion of the case.

QUESTION NO: 1374

Risk can be eliminated.(True/False)

- A. True
- B. False

Answer: B

Explanation: Risk can never be eliminated. It may be reduced or transferred to a third party through insurance, but will always remain in some form.

QUESTION NO: 1375

Employees are a greater risk to employers than outsiders. T/F(True/False)

- A. True
- B. False

Answer: A

Explanation: Employees are a greater risk to employers than outsiders, because they possess two of the three items required to commit a crime: means and opportunity.

QUESTION NO: 1376

When an organization takes reasonable measures to ensure that it took precautions to protect its network and resources is called:

- A. Reasonable Action
- B. Security Mandate
- C. Due Care
- D. Prudent Countermeasures

Answer: C

Explanation: Due care are the steps taken to show it has taken responsibility for its actions.

QUESTION NO: 1377

What two things below are associated with security policy?(Choose Two)

- A. Support of upper management
- B. Support of department managers
- C. Are tactical in nature
- D. Are strategic in nature
- E. Must be developed after procedures
- F. Must be developed after guidelines

Answer: A,D

Explanation: Policies are written as a broad overview and require the support of upper management. After the development and approval of policies, guidelines and procedures may be written.

QUESTION NO: 1378

Total risk is equal to:(Choose All That Apply)

- A. Threat
- B. Vulnerability
- C. Frequency

- D. Asset value
- E. Asset loss

Answer: A,B,D

Explanation: Total risk = asset value * vulnerability * threats

QUESTION NO: 1379

Government data classifications include which of the following:(Choose four)

- A. Open
- B. Unclassified
- C. Confidential
- D. Private
- E. Secret
- F. Top Secret

Answer: B,C,E,F

Explanation: One of the most common systems used to classify information is the one developed within the US Department of Defense. These include: unclassified, sensitive, confidential, secret, and top secret.

QUESTION NO: 1380

Job rotation is important because:

- A. It insures your employees are cross-trained.
- B. It increases job satisfaction.
- C. It reduces the opportunity for fraud

Answer: C

Explanation: Job rotation is tightly tied to the principle of least privilege. It is an effective security control.

QUESTION NO: 1381

Your co-worker is studying for the CISSP exam and has come to you with a question. What is ARP poisoning?

- A. Flooding of a switched network
- B. A denial of service that uses the DNS death ping
- C. Turning of IP to MAC resolution
- D. Inserting a bogus IP and MAC address in the ARP table
- E. Modifying a DNS record

Answer: D

Explanation: ARP poisoning is a masquerading attack where the attacker inserts a bogus IP and MAC address in a victims ARP table or into the table of a switch. This has the effect of redirecting traffic to the attacker and not to the intended computer.

QUESTION NO: 1382

What is the best description for CHAP Challenge Handshake Authentication Protocol?

- A. Passwords are sent in clear text
- B. Passwords are not sent in clear text
- C. Passwords are not used, a digital signature is sent
- D. It is substandard to PAP
- E. It was used with PS2's and has been discontinued

Answer: B

Explanation: Passwords are not sent in clear text. The server performing the authentication sends a challenge value and the user types in the password. The password is used to encrypt the challenge value then is sent back to the authentication server.

QUESTION NO: 1383

CSMA/CD computers cannot communicate without a token.(True/False)

- A. True
- B. False

Answer: B

Explanation: CSMA/CD computers do not use a token. It is the media access method used in Ethernet.

QUESTION NO: 1384

_____ sends out a message to all other computers indicating it is going to send out data.

- A. CSMA/CD
- B. CSMA/CA
- C. CSMA/HB
- D. PPP
- E. SLIP

Answer: B

Explanation: CSMA/CA sends out a message to all other computers indicating it is going to send out data. CSMA/CA or token ring networking uses this approach to reduce the amount of data collisions.

QUESTION NO: 1385

Which of the following best describes ISDN BRI(Choose two)

- A. 2 B channels
- B. 4 B channels
- C. 23 B channels
- D. 1 D channel
- E. 2 D channels

Answer: A,D

Explanation: ISDN BRI has 2 B and 1 D channels

QUESTION NO: 1386

The top speed of ISDN BRI is 256 KBS.(True/False)

- A. True
- B. False

Answer: B

Explanation: The top speed of ISDN BRI is 128 KBS. Its two primary channels are each capable of carrying 64 KBS so the combined top speed is 128 KBS.

QUESTION NO: 1387

Which of the following should NOT be implemented to protect PBX's?(Choose all that apply)

- A. Change default passwords and configurations
- B. Make sure that maintenance modems are on 24/7
- C. Review telephone bill regularly
- D. Block remote calling after business hours
- E. Post PBX configuration and specs on the company website

Answer: B,E

Explanation: Many vendors have maintenance modems that vendors can use to troubleshoot systems and provide updates. They should normally be turned off. Also information about the system should not be posted on the website and should be closely guarded.

QUESTION NO: 1388

Which of the following best describes the difference between a circuit based and application based firewall?

- A. Application based is more flexible and handles more protocols

- B. Circuit based provides more security
- C. Application based builds a state table
- D. Circuit based looks at IP addresses and ports
- E. Circuit based firewalls are only found in Cisco routers

Answer: D

Explanation: Circuit based look only at IP address and ports, whereas application based dig much deeper into the packet. This makes it more secure.

QUESTION NO: 1389

_____ is the fraudulent use of telephone services.

- A. Rolling
- B. Warzing
- C. Wardriving
- D. Wardialing
- E. Phreaking

Answer: E

Explanation: Phreaking is the fraudulent use of telephone services.

QUESTION NO: 1390

What is another name for a VPN?

- A. Firewall
- B. Tunnel
- C. Packet switching
- D. Pipeline
- E. Circuit switching

Answer: B

Explanation: A VPN creates a secure tunnel through an insecure network.

QUESTION NO: 1391

Which of the following is a connection-orientated protocol?

- A. IP
- B. UDP
- C. TCP
- D. ICMP
- E. SNMP
- F. TFTP

Answer: C

Explanation: TCP is a connection-orientated protocol.

QUESTION NO: 1392

Which of the following is not considered firewall technology?

- A. Screened subnet
- B. Screened host
- C. Dual gateway host
- D. Dual homed host

Answer: C

Explanation: Dual gateway host is not considered firewall technology.

QUESTION NO: 1393

Which of the following can be used to defeat a call-back security system?

- A. Call waiting
- B. Passive wiretapping
- C. Active wiretapping

- D. Brute force password attacks
- E. Call forwarding

Answer: E

Explanation: Call forwarding can be used to bypass the call back feature and is considered a security risk.

QUESTION NO: 1394

Which type of network topology passes all traffic through all active nodes?

- A. Broadband
- B. Star
- C. Baseband
- D. Token Ring

Answer: D

Explanation: Token ring passes all traffic through nodes.

QUESTION NO: 1395

The act of validating a user with a unique and specific identifier is called what?

- A. Validation
- B. Registration
- C. Authentication
- D. Authorization
- E. Identification

Answer: C

Explanation: Authentication is the act of validating a user with a unique and specific identifier.

QUESTION NO: 1396

Why is fiber the most secure means of transmission?

- A. High speed multiplexing
- B. Interception of traffic is more difficult because it is optically based
- C. Higher data rates make it more secure
- D. Multiplexing prevents traffic analysis
- E. Built-in fault tolerance

Answer: B

Explanation: Fiber is more secure because it is hard to tap into and gives off no EMI such as copper cabling.

QUESTION NO: 1397

The IAB defines which of the following as a violation of ethics?

- A. Performing a DoS
- B. Downloading an active control
- C. Performing a penetration test
- D. Creating a virus
- E. Disrupting Internet communications

Answer: E

Explanation: The IAAB considers the Internet a privilege, not a right, and as such considers it unethical to purposely disrupt communications.

QUESTION NO: 1398

A chain of custody shows who _____ and _____.(Choose three)

- A. Who controlled the evidence
- B. Who transcribed the evidence
- C. Who validated the evidence

- D. Who presented the evidence
- E. Secured the evidence
- F. Obtained the evidence

Answer: A,E,F

Explanation: The chain of evidence shows who obtained the evidence, who secured the evidence, and who controlled the evidence.

QUESTION NO: 1399

Good forensics requires the use of a bit level copy?(True/False)

- A. True
- B. False

Answer: A

Explanation: Good forensics requires the use of a bit level copy. A bit level copy duplicates all information on the suspect's disk. This includes slack space and free space.

QUESTION NO: 1400

Which agency shares the task of investigating computer crime along with the FBI?

- A. Secret Service
- B. CIA
- C. Department of justice
- D. Police force
- E. NSA

Answer: A

Explanation: Along with the FBI, the Secret Service has been given the authority to investigate computer crime.

QUESTION NO: 1401

This type of password recovery is considered more difficult and must work through all possible combinations of numbers and characters.

- A. Passive
- B. Active
- C. Dictionary
- D. Brute force
- E. Hybrid

Answer: D

Explanation: Brute force cracking is considered more difficult and must work through all possible combinations of numbers and characters.

QUESTION NO: 1402

_____ are added to Linux passwords to increase their randomness.

- A. Salts
- B. Pepper
- C. Grains
- D. MD5 hashes
- E. Asymmetric algorithms

Answer: A

Explanation: Salts are added to Linux passwords to increase their randomness. They are used to help insure that no two users have the same, hashed password.

QUESTION NO: 1403

The Linux root user password is typically kept in where?(Choose two)

- A. etc/shadow
- B. cmd/passwd
- C. etc/passwd
- D. windows/system32
- E. var/sys
- F. var/password

Answer: A,C

Explanation: The Linux root user password is typically kept in /etc/passwd or etc/shadow.

QUESTION NO: 1404

The goal of cryptanalysis is to _____.

- A. Determine the number of encryption permutations required
- B. Reduce the system overhead for a crypto-system
- C. Choose the correct algorithm for a specified purpose
- D. Forge coded signals that will be accepted as authentic
- E. Develop secure crypto-systems

Answer: D

Explanation: The goal of cryptanalysis is to forge coded signals that will be accepted as authentic.

QUESTION NO: 1405

If an employee is suspected of computer crime and evidence need to be collected, which of the following departments must be involved with the procedure?

- A. Public relations
- B. Law enforcement
- C. Computer security
- D. Auditing
- E. HR

Answer: E

Explanation: Human Resources always needs to be involved if an employee is suspected of wrongdoing. They know what rules apply to protect and prosecute employees.

QUESTION NO: 1406

What is it called when a system has apparent flaws that were deliberately available for penetration and exploitation?

- A. A jail
- B. Investigation
- C. Enticement
- D. Data manipulation
- E. Trapping

Answer: C

Explanation: Administrators that leave systems with apparent flaws are performing an act of enticement. This is sometimes called a honeypot.

QUESTION NO: 1407

Why are computer generated documents not considered reliable?

- A. Difficult to detect electron tampering
- B. Stored in volatile media
- C. Unable to capture and reproduce
- D. Too delicate
- E. Because of US law, Section 7 paragraph 154

Answer: A

Explanation: Because it is difficult to detect electron tampering and can be easily modified.

QUESTION NO: 1408

What is the name of the software that prevents users from seeing all items or directories on a computer and is most commonly found in the UNIX/Linux environment?

- A. Shell Kits
- B. Root Kits
- C. Ethereal
- D. Shadow data
- E. Netbus

Answer: D

Explanation:

QUESTION NO: 1409

What is a commercial application of steganography that is used to identify pictures or verify their authenticity?

- A. A MAC
- B. A digital checksum
- C. A MD5 hash
- D. A digital signature
- E. A watermark

Answer: E

Explanation: A watermark is a commercial application of steganography that is used to identify pictures or verify its authenticity.

QUESTION NO: 1410

What are the basic questions that must be asked at the beginning of any investigation?(Choose all that apply)

- A. Who
- B. Cost
- C. What

- D. When
- E. Where
- F. How
- G. Time frame
- H. Budget

Answer: A,C,D,E,F

Explanation: At the beginning of any investigation, an investigator must ask who, what, when, where, and how. Answering the questions will lead to the successful conclusion of the case.

QUESTION NO: 1411

Risk can be eliminated.(True/False)

- A. True
- B. False

Answer: B

Explanation: Risk can never be eliminated. It may be reduced or transferred to a third party through insurance, but will always remain in some form.

QUESTION NO: 1412

Employees are a greater risk to employers than outsiders. T/F(True/False)

- A. True
- B. False

Answer: A

Explanation: Employees are a greater risk to employers than outsiders, because they possess two of the three items required to commit a crime: means and opportunity.

QUESTION NO: 1413

What does the term "red boxing" mean?

- A. Denial of Service
- B. Telephone voltage manipulation
- C. Sounds of coins dropping
- D. Tone manipulation
- E. A salami attack

Answer: C

Explanation: Red boxing was used by phone phreakers to record the sound of coins dropping in pay phones and play it back to gain free phone access.

QUESTION NO: 1414

Which of the following is the proper lifecycle of evidence?

- A. A Collection, storage, present in court, destroy
- B. Collection, transportation, storage, return to owner
- C. Collection, present in court, transportation, return to owner
- D. Collection, analysis, storage, present in court, return to owner
- E. Collection, storage, transportation, present in court, return to owner

Answer: D

Explanation: The life cycle of evidence includes: collection, analysis, storage, present in court, and return to owner

QUESTION NO: 1415

A copy of a computer disk would be what type of evidence?

- A. Secondary
- B. Best
- C. Hearsay
- D. Direct
- E. Indirect

Answer: C

Explanation: A copy of a computer disk is considered hearsay, because unless it has been copied in a forensically approved manner, it is not credible evidence.

QUESTION NO: 1416

A copyright protects _____.

- A. The trade secrets of a company
- B. A persons private papers
- C. An invention
- D. An expression or an idea
- E. Distinguishing or unique characters, colors, or words

Answer: D

Explanation: A copyright protects the expression of a resource, not the resource directly.

QUESTION NO: 1417

_____ is a _____ attack that eavesdrops on communication. (Choose two)

- A. Passive
- B. Active
- C. Brute force
- D. Wiretapping
- E. Password cracking

Answer: A,D

Explanation: Wiretapping is a passive attack that eavesdrops on communication. It is only legal with prior consent or a warrant.

QUESTION NO: 1418

What types of laws are considered standards of performance or conduct expected by government agencies from companies, industries, and certain officials.(Chose all that apply)

- A. Civil
- B. Criminal
- C. Administrative
- D. Regulatory
- E. Tort

Answer: C,D

Explanation: Administrative or regulatory laws are considered standards of performance or conduct expected by government agencies from companies, industries, and certain officials.

QUESTION NO: 1419

Sandra's employer is considering placing login banners on all company computers to indicate to the users about the permitted use of company computers. What is this called?

- A. Employee privacy law
- B. Employee policies
- C. Employee regulations
- D. User policies
- E. Acceptable use policy

Answer: E

Explanation: Acceptable use policies provide the company with legal protection. Logon banners should be used to inform users what will happen if they do not follow company rules.

QUESTION NO: 1420

_____ deemed proprietary to a company and can be information that provides a competitive edge.

- A. Trade secrets are

- B. Copyrights are
- C. Restricted information is
- D. Information marked strictly private is

Answer: A

Explanation: Trade secrets are deemed proprietary to a company and can be information that provides a competitive edge. This information is protected as long as the owner takes the necessary security actions.

QUESTION NO: 1421

Sandra is studying for her CISSP exam. Sandra has come to you for help and wants to know what the last step in the change control process is?

- A. Validated and approved
- B. Test and implement
- C. Review and approve
- D. Report change to management
- E. Inform user of change

Answer: D

Explanation: Reporting the change to management is the last step in the process.

QUESTION NO: 1422

Who is ultimately responsible for the security of an organization?

- A. Management
- B. Senior management
- C. The chief security officer
- D. Department heads
- E. Employees

Answer: B

Explanation: Senior management is ultimately responsible for the security of an organization. Policy flows from the top down.

QUESTION NO: 1423

Which of the following falls under the categories of configuration management?(Choose three)

- A. Operating system configuration
- B. Software configuration
- C. Hardware configuration
- D. Logical configuration
- E. Physical configuration

Answer: A,B,C

Explanation: Configuration management controls the changes that take place in hardware, software, and operating systems.

QUESTION NO: 1424

Macro viruses infect what type of files.

- A. Microsoft office files
- B. Mail servers
- C. E-mail messages
- D. Web browsers
- E. Linux Kernel files

Answer: A

Explanation: Macro viruses infect Microsoft office files. There are many macro viruses because the macro language is easy to use and because Microsoft Office is prolific.

QUESTION NO: 1425

What is another name for rows and columns within relational databases?(Choose two)

- A. Relations

- B. Keys
- C. Tuples
- D. Views
- E. Attributes

Answer: C,E

Explanation: Within a relational database, the rows of a table are called tuples and the columns are called attributes.

QUESTION NO: 1426

Which of the following can reproduce itself without the help of system applications or resources?

- A. Trojan
- B. Logic bomb
- C. Virus
- D. Worm
- E. Backdoor

Answer: D

Explanation: Worms can reproduce themselves without the help of system applications or resources.

QUESTION NO: 1427

What is the final stage of the system development life cycle?

- A. Certification
- B. Validation
- C. Evaluation
- D. Implementation
- E. Maintenance
- F. Installation

Answer: E

Explanation: Maintenance is the final stage of the system development life cycle.

QUESTION NO: 1428

A polymorphic virus is _____.

- A. A virus that makes copies of itself and then makes changes to those copies
- B. A virus that can make itself stealth
- C. A virus that is written in a macro language
- D. A virus that is written in visual basic
- E. A virus that infects the boot sector of a hard drive

Answer: A

Explanation: A polymorphic virus is a virus that makes copies of itself, then makes changes to those copies. It does this in hopes of avoiding detection of anti-virus software.

QUESTION NO: 1429

Which one of the following is identified by a business impact analysis?(Choose three)

- A. Determining regulatory requirements
- B. Analyzing the threats associated with each functional area
- C. Determining the risk associated with each threat
- D. Identifying the major functional areas of information
- E. Determining the team members that will be associated with disaster planning

Answer: B,C,D

Explanation: The following identifies a business impact analysis: analyzing the threats associated with each functional area, determining the risk associated with each threat, and identifying the major functional areas of information.

QUESTION NO: 1430

_____ are the step-by-step instructions used to satisfy control requirements.

- A. Policy
- B. Procedure
- C. Guideline

- D. Standard
- E. Outline

Answer: B

Explanation: Procedures are the step-by-step instructions used to satisfy control requirements.

QUESTION NO: 1431

Which of the following are controls that can be used to secure faxing of sensitive data?(Choose all that apply)

- A. Disable automatic printing
- B. Print "sensitive document banner" on each page
- C. Fax encryptor
- D. Send to email boxes instead of printing
- E. Restrict the use of fax machines that use a ribbon or duplication cartridge

Answer: A,C,D,E

Explanation: All of the items listed can help secure faxes except printing a sensitive document banner, which actually encourages people to look at the document.

QUESTION NO: 1432

Which of the following are considered administrative controls?(Choose all that apply)

- A. Rotation of duties
- B. Separation of duties
- C. Implementation of WEP keys
- D. Enforcing mandatory vacations

Answer: A,B,D

Explanation: Rotation of duties, separation of duties, and mandatory vacations are all administrative controls, enforcing WEP is a technical control

QUESTION NO: 1433

Why should organizations enforce separation of duties?

- A. It ensures compliance with federal union rules
- B. It helps verify that all employees know their job tasks
- C. It provides for a better work environment
- D. It encourages collusion
- E. It is considered valuable in deterring fraud

Answer: E

Explanation: Separation of duties is considered valuable in deterring fraud since fraud can occur if an opportunity exists for collaboration between various job related capabilities. The most commonly used examples are the separate transactions needed to initiate a payment and to authorize a payment. No single individual should be capable of executing both transactions.

QUESTION NO: 1434

What is the most secure way to dispose of data held on a CD?

- A. Reformatting
- B. Sanitizing
- C. Physical destruction
- D. Degaussing

Answer: C

Explanation: Since CD's cannot be sanitized in a way to remove all data, they should be physically destroyed. There are many products that can do this. Some actually shred the CD!

QUESTION NO: 1435

What is the most accepted way to dispose data held on a floppy disk?

- A. Reformatting
- B. Sanitizing
- C. Physical destruction
- D. Degaussing

Answer: D

Explanation: Degaussing is the most accepted way of disposing data held on a floppy disk.

QUESTION NO: 1436

Which of the following is NOT an attack against operations?

- A. Morris Worm
- B. SYN Denial of Service
- C. Buffer Overflow
- D. Brute force
- E. Known plain text attack

Answer: E

Explanation: A known plain text attack is an attack against the organization's cryptosystem, not a direct attack against operations.

QUESTION NO: 1437

Which one of the following tools can be used to launch a Distributed Denial of service attack against a network?

- A. Satan
- B. Saint
- C. Trinoo
- D. Nmap
- E. Netcat

Answer: C

Explanation: Trinoo and the Tribal Flood Network (TFN) are the two most commonly used distributed denial of service attacks. The other four tools mentioned are reconnaissance techniques used to map networks and scan for known vulnerabilities.

QUESTION NO: 1438

Which one of the following network attacks takes advantages of weaknesses in the fragment reassembly functionality of the TCP/IP protocol stack?

- A. Teardrop
- B. Smurf
- C. Ping of Death
- D. SYN flood
- E. SNMP Attack

Answer: A

Explanation: The teardrop attack uses overlapping packet fragments to confuse a target system and cause the system to reboot or crash.

QUESTION NO: 1439

What are the elements of the CIA triad?(Choose three)

- A. Confidentiality
- B. Accountability
- C. Accessibility
- D. Integrity
- E. Interest
- F. Control
- G. Availability

Answer: A,D,G

Explanation: The essential security principles of confidentiality, integrity, and availability are referred to as the CIA Triad.

QUESTION NO: 1440

_____ is the first step of access control.

- A. Identification
- B. Authorization
- C. Validation

- D. Interrogation
- E. Accountability logging

Answer: A

Explanation: The first step in the access control process is identifying who the subject is.

QUESTION NO: 1441

What is a Type 2 authentication factor?

- A. Something you know
- B. Something you are
- C. Something you have

Answer: C

Explanation: A Type 2 authentication factor is something you have, such as a smart card, ATM card, token device, memory card, etc.

QUESTION NO: 1442

_____ requires that two entities work together to complete a task?

- A. Rotation of duties
- B. Separation of duties
- C. Dual controls
- D. Enforced mandatory vacations
- E. Workplace rules

Answer: C

Explanation: Dual controls require that two entities work together to complete a task. This is used to reduce the possibility of fraud.

QUESTION NO: 1443

PGP provides which of the following?(Choose three)

- A. Confidentiality
- B. Accountability
- C. Accessibility
- D. Integrity
- E. Interest
- F. Non-repudiation
- G. Authenticity

Answer: A,D,G

Explanation: PGP provides confidentiality, integrity, and authenticity.

QUESTION NO: 1444

Computer security is generally considered the responsibility of everyone in the organization.(True/False)

- A. True
- B. False

Answer: A

Explanation: Everyone is responsible for security.

QUESTION NO: 1445

Which aspect of security was the Bell-LaPadula access control model designed to protect?

- A. Authenticity
- B. Accountability
- C. Accessibility
- D. Integrity
- E. Interest
- F. Non-repudiation
- G. Confidentiality

Answer: G

Explanation: The Bell-LaPadula model is focused on maintaining confidentiality.

QUESTION NO: 1446

Which access control method uses security policies and security awareness training to stop or deter an unauthorized activity from occurring?

- A. Administrative
- B. Preventative
- C. Detective
- D. Authoritative
- E. Corrective

Answer: B

Explanation: Preventative access control is deployed to stop an unauthorized activity from occurring.

QUESTION NO: 1447

The Secure Hash Algorithm (SHA) is specified in?

- A. Digital Encryption Standard
- B. Digital Signature Standard
- C. Digital Encryption Standard
- D. Advanced Encryption Standard
- E. NSA 1403

Answer: B

Explanation: SHA is specified in DSS, not DES.

DSS: <http://www.itl.nist.gov/fipspubs/fip186.htm>

DES: <http://www.itl.nist.gov/fipspubs/fip46-2.htm>

QUESTION NO: 1448

Which of the following is an example of a symmetric key algorithm?(Choose all that apply)

- A. Rijndael
- B. RSA
- C. Diffie-Hellman
- D. Knapsack
- E. IDEA

Answer: A,E

Explanation: All the others except Rijndael and IDEA are examples of asymmetric key algorithms.

Topic 13, Exam SET A

QUESTION NO: 1449

Which of the following items is NOT used to determine the types of access controls to be applied in an organization?

- A. Separation of duties
- B. Organizational policies
- C. Least privilege
- D. Relational categories

Answer: D

Explanation:

The item, relational categories, is a distracter. The other options are important determinants of access control implementations in an organization.

QUESTION NO: 1450

Which choice below is NOT a generally accepted benefit of security

awareness, training, and education?

- A.** A security awareness and training program can help an organization reduce the number and severity of errors and omissions.
- B.** A security awareness and training program will help prevent natural disasters from occurring.
- C.** A security awareness program can help operators understand the value of the information.
- D.** A security education program can help system administrators recognize unauthorized intrusion attempts.

Answer: B

Explanation:

An effective computer security awareness and training program requires proper planning, implementation, maintenance, and periodic evaluation.

In general, a computer security awareness and training program should encompass the following seven steps:

1. Identify program scope, goals, and objectives.
2. Identify training staff.
3. Identify target audiences.
4. Motivate management and employees.
5. Administer the program.
6. Maintain the program.
7. Evaluate the program.

Source: NIST Special Publication 800-14, Generally Accepted Principles and Practices for Securing Information Technology Systems.

QUESTION NO: 1451

In biometrics, a one-to-one search to verify an individual's claim of an identity is called:

- A.** Audit trail review.
- B.** Accountability.
- C.** Authentication.
- D.** Aggregation.

Answer: C

Explanation:

The correct answer is Authentication. Answer "Audit trail review." is a review of audit system data, usually done after the fact. Answer "Accountability" is holding individuals responsible for their actions, and answer d is obtaining higher-sensitivity information from a number of pieces of information of lower sensitivity.

QUESTION NO: 1452

Which one of the following statements is TRUE concerning the Terminal Access Controller Access Control System (TACACS) and TACACS+?

- A.** TACACS supports prompting for a password change.
- B.** TACACS+ employs a user ID and static password.
- C.** TACACS+ employs tokens for two-factor, dynamic password authentication.
- D.** TACACS employs tokens for two-factor, dynamic password authentication.

Answer: C

Explanation:

The correct answer is "TACACS+ employs tokens for two-factor, dynamic password authentication".

TACACS employs a user ID and static password and does not support prompting for password change or the use of dynamic password tokens.

QUESTION NO: 1453

Which statement below is NOT correct about safeguard selection in the risk analysis process?

- A.** The most commonly considered criteria is the cost effectiveness of the safeguard.
- B.** The best possible safeguard should always be implemented, regardless of cost.
- C.** Maintenance costs need to be included in determining the total cost of the safeguard.
- D.** Many elements need to be considered in determining the total cost of the safeguard.

Answer: B

Explanation:

The correct answer is "The best possible safeguard should always be implemented, regardless of cost.". Performing a cost-benefit analysis of the proposed safeguard before implementation is vital. The level of security afforded could easily outweigh the value of a proposed safeguard. Other factors need to be considered in the safeguard selection process, such as accountability, auditability, and the level of manual operations needed to maintain or operate the safeguard.

QUESTION NO: 1454

Which answer below is the BEST description of a Single Loss Expectancy (SLE)?

- A.** An algorithm that determines the expected annual loss to an organization from a threat
- B.** An algorithm that represents the magnitude of a loss to an asset from a threat
- C.** An algorithm used to determine the monetary impact of each occurrence of a threat
- D.** An algorithm that expresses the annual frequency with which a threat is expected to occur

Answer: C

Explanation:

The correct answer is "An algorithm used to determine the monetary impact of each occurrence of a threat". The Single Loss Expectancy (or Exposure) figure may be created as a result of a Business Impact Assessment

(BIA). The SLE represents only the estimated monetary loss of a single occurrence of a specified threat event. The SLE is determined by multiplying the value of the asset by its exposure factor. This gives the expected loss the threat will cause for one occurrence.

Answer a describes the Exposure Factor (EF). The EF is expressed as a percentile of the expected value or functionality of the asset to be lost due to the realized threat event. This figure is used to calculate the SLE, above.

Answer "An algorithm that expresses the annual frequency with which a threat is expected to occur" describes the Annualized Rate of Occurrence (ARO). This is an estimate of how often a given threat event may occur annually.

For example, a threat expected to occur weekly would have an ARO of 52. A threat expected to occur once every five years has an ARO of 1/5 or .2. This figure is used to determine the ALE.

Answer d describes the Annualized Loss Expectancy (ALE). The ALE is derived by multiplying the SLE by its ARO. This value represents the expected risk factor of an annual threat event. This figure is then integrated into the risk management process.

QUESTION NO: 1455

Which of the following is NOT a type of data network?

- A.** WAN
- B.** MAN
- C.** LAN
- D.** GAN

Answer: D

Explanation:

The correct answer is d. GAN does not exist. LAN stands for Local Area Network, WAN stands for Wide Area Network, and MAN stands for Metropolitan Area Network.

QUESTION NO: 1456

Which choice below is NOT a concern of policy development at the high level?

- A. Identifying the key business resources
- B. Defining roles in the organization
- C. Determining the capability and functionality of each role
- D. Identifying the type of firewalls to be used for perimeter security

Answer: D

Explanation:

The other options are elements of policy development at the highest level. Key business resources would have been identified during the risk assessment process. The various roles are then defined to determine the various levels of access to those resources.

Answer "Determining the capability and functionality of each role" is the final step in the policy creation process and combines steps a and "Defining roles in the organization". It determines which group gets access to each resource

and what access privileges its members are assigned. Access to resources should be based on roles, not on individual identity.

Source: Surviving Security: How to Integrate People, Process, and Technology by Mandy Andress (Sams Publishing, 2001).

QUESTION NO: 1457

Which is NOT a standard type of DSL?

- A. HDSL
- B. FDSL
- C. ADSL
- D. VDSL

Answer: B

Explanation:

The correct answer is FDSL. FDSL does not exist.

QUESTION NO: 1458

A back door into a network refers to what?

- A.** Mechanisms created by hackers to gain network access at a later time
- B.** Monitoring programs implemented on dummy applications to lure intruders
- C.** Undocumented instructions used by programmers to debug applications
- D.** Socially engineering passwords from a subject

Answer: A

Explanation:

Back doors are very hard to trace, as an intruder will often create several avenues into a network to be exploited later. The only real way to be sure these avenues are closed after an attack is to restore the operating system from the original media, apply the patches, and restore all data and applications.

* social engineering is a technique used to manipulate users into revealing information like passwords.

* Answer "Undocumented instructions used by programmers to debug applications" refers to a trap door, which are undocumented hooks into an application to assist programmers with debugging. Although intended innocently, these can be exploited by intruders.

* "Monitoring programs implemented on dummy applications to lure intruders" is a honey pot or padded cell.

A honey pot uses a dummy server with bogus applications as a decoy for intruders. Source: Fighting Computer Crime by Donn B. Parker (Wiley, 1998).

QUESTION NO: 1459

A type of access control that supports the management of access rights for groups of subjects is:

- A. Discretionary
- B. Rule-based
- C. Role-based
- D. Mandatory

Answer: C

Explanation:

Role-based access control assigns identical privileges to groups of users. This approach simplifies the management of access rights, particularly when members of the group change. Thus, access rights are assigned to a role, not to an individual. Individuals are entered as members of specific groups and are assigned the access privileges of that group.

In answer Discretionary, the access rights to an object are assigned by the owner at the owner's discretion. For large numbers of people whose duties and participation may change frequently, this type of access control can become unwieldy. Mandatory access control, answer c, uses security labels or classifications assigned to data items and clearances assigned to users. A user has access rights to data items with a classification equal to or less than the user's clearance. Another restriction is that the user has to have a need-to-know the information; this requirement is identical to the principle of least privilege.

Answer 'rule-based access control' assigns access rights based on stated rules. An example of a rule is Access to trade-secret data is restricted to corporate officers, the data owner and the legal department.

QUESTION NO: 1460

Which of the following is NOT a property of CSMA?

- A. The workstation continuously monitors the line.
- B. Workstations are not permitted to transmit until they are given permission from the primary host.
- C. It does not have a feature to avoid the problem of one workstation dominating the conversation.
- D. The workstation transmits the data packet when it thinks that the line is free.

Answer: B

Explanation:

The correct answer is "Workstations are not permitted to transmit until they are given permission from the primary host". The polling transmission type uses primary and secondary hosts, and the secondary must wait for permission from the primary before transmitting.

QUESTION NO: 1461

Which choice below is NOT one of NIST's 33 IT security principles?

- A. Assume that external systems are insecure.
- B. Minimize the system elements to be trusted.
- C. Implement least privilege.
- D. Totally eliminate any level of risk.

Answer: D

Explanation:

Risk can never be totally eliminated. NIST IT security principle #4 states: Reduce risk to an acceptable level. The National Institute of Standards and Technology's (NIST) Information Technology Laboratory (ITL) released NIST Special Publication (SP) 800-27, Engineering Principles for Information Technology Security (EP-ITS) in June 2001 to assist in the secure design, development, deployment, and life-cycle of information systems. It presents 33 security principles which start at the design phase of the information system or application and continue until the system's retirement and secure disposal.

Some of the other 33 principles are:

Principle 1. Establish a sound security policy as the foundation for design.

Principle 2. Treat security as an integral part of the overall system design.

Principle 5. Assume that external systems are insecure.

Principle 6. Identify potential trade-offs between reducing risk and increased costs and decrease in other aspects of operational effectiveness.

Principle 7. Implement layered security (ensure no single point of vulnerability).

Principle 11. Minimize the system elements to be trusted.

Principle 16. Isolate public access systems from mission critical resources (e.g., data, processes, etc.).

Principle 17. Use boundary mechanisms to separate computing systems and network infrastructures.

Principle 22. Authenticate users and processes to ensure appropriate access control decisions both within and across domains.

Principle 23. Use unique identities to ensure accountability.

Principle 24. Implement least privilege.

Source: NIST Special Publication 800-27, Engineering Principles for Information Technology Security (A Baseline for Achieving Security), and Federal Systems Level Guidance for Securing Information Systems, James Corrie, August 16, 2001 .

QUESTION NO: 1462

What is probing used for?

- A. To induce a user into taking an incorrect action
- B. To use up all of a target's resources
- C. To covertly listen to transmissions
- D. To give an attacker a road map of the network

Answer: D

Explanation:

The correct answer is "To give an attacker a road map of the network". Probing is a procedure whereby the intruder runs programs that scan the network to create a network map for later intrusion.

Answer "To induce a user into taking an incorrect action" is spoofing, c is the objective of a DoS attack, and d is passive eavesdropping.

QUESTION NO: 1463

Clipping levels are used to:

- A. Reduce the amount of data to be evaluated in audit logs.
- B. Limit errors in callback systems.
- C. Limit the number of letters in a password.
- D. Set thresholds for voltage variations.

Answer: A

Explanation:

The correct answer is reducing the amount of data to be evaluated by definition. Answer "Limit the number of letters in a password" is incorrect because clipping levels do not relate to letters in a password.

Answer "Set thresholds for voltage variations" is incorrect because clipping levels in this context have nothing to do with controlling voltage levels. Answer "Limit errors in callback system" is incorrect because they are not used to limit callback errors.

QUESTION NO: 1464

An attack that can be perpetrated against a remote user's callback access control is:

- A. Redialing.
- B. Call forwarding.
- C. A maintenance hook.
- D. A Trojan horse.

Answer: B

Explanation:

The correct answer is Call forwarding. A cracker can have a person's call forwarded to another number to foil the callback system. Answer "A Trojan horse" is incorrect because it is an example of malicious code embedded in useful code. Answer "A maintenance hook" is incorrect because it might enable bypassing controls of a system through a means used for debugging or maintenance. Answer Redialing is incorrect because it is a distracter.

QUESTION NO: 1465

The definition of CHAP is:

- A. Confidential Hash Authentication Protocol.
- B. Challenge Handshake Approval Protocol.
- C. Confidential Handshake Approval Protocol.
- D. Challenge Handshake Authentication Protocol.

Answer: D

Explanation:

QUESTION NO: 1466

Which of the following is NOT a remote computing technology?

- A. xDSL
- B. ISDN
- C. Wireless
- D. PGP

Answer: D

Explanation:

The correct answer is PGP. PGP stands for Pretty Good Privacy, an email encryption technology.

QUESTION NO: 1467

A relational database can provide security through view relations. Views enforce what information security principle?

- A.** Least privilege
- B.** Inference
- C.** Aggregation
- D.** Separation of duties

Answer: A

Explanation:

The principle of least privilege states that a subject is permitted to have access to the minimum amount of information required to perform an authorized task. When related to government security clearances, it is referred to as need-to-know.

* aggregation, is defined as assembling or compiling units of information at one sensitivity level and having the resultant totality of data being of a higher sensitivity level than the individual components.

*Separation of duties requires that two or more subjects are necessary to authorize an activity or task.

*inference, refers to the ability of a subject to deduce information that is not authorized to be accessed by that subject from information that is authorized to that subject.

QUESTION NO: 1468

Which statement below is accurate about the reasons to implement a layered security architecture?

- A.** A layered approach doesn't really improve the security posture of the organization.
- B.** A layered security approach is intended to increase the work-factor for an attacker.
- C.** A good packet-filtering router will eliminate the need to implement

a layered security architecture.

D. A layered security approach is not necessary when using COTS products.

Answer: B

Explanation:

Security designs should consider a layered approach to address or protect against a specific threat or to reduce a vulnerability. For example, the use of a packet-filtering router in conjunction with an application gateway and an intrusion detection system combine to increase the work-factor an attacker must expend to successfully attack the system. The need for layered protections is important when commercial off-the-shelf (COTS) products are used. The current state-of-the-art for security quality in COTS products do not provide a high degree of protection against sophisticated attacks. It is possible to help mitigate this situation by placing several controls in levels, requiring additional work by attackers to accomplish their goals.

Source: NIST Special Publication 800-27, Engineering Principles for Information Technology Security (A Baseline for Achieving Security).

QUESTION NO: 1469

Which of the choices below is NOT an OSI reference model Session Layer protocol, standard, or interface?

- A.** SQL
- B.** DNA SCP
- C.** RPC
- D.** MIDI
- E.** ASP

Answer: D

Explanation:

The Musical Instrument Digital Interface (MIDI) standard is a Presentation Layer standard for digitized music. The other answers are all Session layer protocols or standards. SQL refers to the Structured Query Language database standard originally developed by IBM.

Answer RPC refers to the Remote Procedure Call redirection mechanism for remote clients.

ASP is the AppleTalk Session Protocol.

DNA SCP refers to DECnet's Digital Network Architecture Session Control Protocol. Source: Introduction to Cisco Router Configuration edited by Laura Chappell (Cisco Press, 1999).

QUESTION NO: 1470

An acceptable biometric throughput rate is:

- A. One subject per two minutes.
- B. Five subjects per minute.
- C. Ten subjects per minute.
- D. Two subjects per minute.

Answer: C

Explanation:

QUESTION NO: 1471

Authentication is:

- A. Not accomplished through the use of a password.
- B. The presentation of a user's ID to the system.
- C. The verification that the claimed identity is valid.
- D. Only applied to remote users.

Answer: C

Explanation:

The correct answer is "The verification that the claimed identity is valid.". Answer "The presentation of a user's ID to the system" is incorrect because it is an identification act. Answer c is incorrect because authentication can be accomplished through the use of a password. Answer "Only applied to remote users" is incorrect because authentication is applied to local and remote users.

QUESTION NO: 1472

Which statement about a VPN tunnel below is incorrect?

- A.** It can be created by implementing node authentication systems.
- B.** It can be created by implementing IPSec devices only.
- C.** It can be created by implementing key and certificate exchange systems.
- D.** It can be created by installing software or hardware agents on the client or network.

Answer: B

Explanation:

The correct answer is "It can be created by implementing IPSec devices only". IPSec-compatible and non-IPSec compatible devices are used to create VPNs. The other three answers are all ways in which VPNs can be created.

QUESTION NO: 1473

What is NOT true of a star-wired topology?

- A.** It has more resiliency than a BUS topology.
- B.** 10BaseT Ethernet is star-wired.
- C.** Cabling termination errors can crash the entire network.
- D.** The network nodes are connected to a central LAN device.

Answer: C

Explanation:

The correct answer is "Cabling termination errors can crash the entire network". Cabling termination errors are an inherent issue with bus topology networks.

QUESTION NO: 1474

What are the detailed instructions on how to perform or implement a control called?

- A. Guidelines
- B. Standards
- C. Policies
- D. Procedures

Answer: D

Explanation:

QUESTION NO: 1475

Which category of UTP wiring is rated for 100BaseT Ethernet networks?

- A. Category 5
- B. Category 1
- C. Category 2
- D. Category 3
- E. Category 4

Answer: A

Explanation:

Category 5 unshielded twisted-pair (UTP) wire is rated for transmissions of up to 100 Mbps and can be used in 100BaseT Ethernet networks. It is the most commonly installed type of UTP at this time. See Table.

Category 1 twisted-pair wire was used for early analog telephone communications and is not suitable for data.

Category 2 twisted-pair wire, was used in AS/400 and IBM 3270 networks. Derived from IBM Type 3 cable specification.

Category 3 twisted-pair wire, is rated for 10 Mbps and was used in 802.3 10Base-T Ethernet

networks, and 4 Mbps Token Ring networks.

Category 4 twisted-pair wire, is rated for 16 Mbps and is used in 4/16 Mbps Token Ring LANs.

Source: The Electrical Industry Alliance (EIA/TIA-568).

UTP Categories of Performance		
UTP CAT	RATED PERFORMANCE IN MHZ	COMMON APPLICATIONS
Cat1	Under 1 MHz	Analog voice, ISDN BRI
Cat2	1 MHz	IBM 3270, AS/400, Apple LocalTalk
Cat3	16 MHz	10BaseT, 4 Mbps Token Ring
Cat4	20 MHz	16 Mbps Token Ring
Cat5	100 MHz	10/100BaseT

QUESTION NO: 1476

How is an SLE derived?

- A. $ARO \times EF$
- B. $AV \times EF$
- C. $(\text{Cost} - \text{benefit}) \times (\% \text{ of Asset Value})$
- D. $\% \text{ of AV} - \text{implementation cost}$

Answer: B

Explanation:

The correct answer is $AV \times Ef$. A Single Loss Expectancy is derived by multiplying the Asset Value with its Exposure Factor. The other answers do not exist.

QUESTION NO: 1477

The Simple Security Property and the Star Property are key principles in

which type of access control?

- A. Mandatory
- B. Discretionary
- C. Rule-based
- D. Role-based

Answer: A

Explanation:

Two properties define fundamental principles of mandatory access control. These properties are:

Simple Security Property. A user at one clearance level cannot read data from a higher classification level.

Star Property. A user at one clearance level cannot write data to a lower classification level

QUESTION NO: 1478

A token that generates a unique password at fixed time intervals is called:

- A. A synchronous dynamic password token.
- B. A challenge-response token.
- C. A time-sensitive token.
- D. An asynchronous dynamic password token.

Answer: A

Explanation:

The correct answer is "A synchronous dynamic password token".

QUESTION NO: 1479

A statistical anomaly-based intrusion detection system:

- A. Acquires data to establish a normal system operating profile.
- B. Will detect an attack that does not significantly change the system's operating characteristics.
- C. Does not report an event that caused a momentary anomaly in the

system.

D. Refers to a database of known attack signatures.

Answer: A

Explanation:

The correct answer is "Acquires data to establish a normal system operating profile". A statistical anomaly-based intrusion detection

system acquires data to establish a normal system operating profile.

Answer "Refers to a database of known attack signatures" is incorrect because it is used in signature-based intrusion

detection. Answer "Will detect an attack that does not significantly change the system's operating characteristics." is incorrect because a statistical anomaly-based

intrusion detection system will not detect an attack that does not significantly

change the system operating characteristics. Similarly, answer "Does not report an event that caused a momentary anomaly in the system."

is incorrect because the statistical anomaly-based IDS is susceptible to reporting an event that caused a momentary anomaly in the system.

QUESTION NO: 1480

When logging on to a workstation, the log-on process should:

A. Provide a Help mechanism that provides log-on assistance.

B. Not provide information on the previous successful log-on and on previous unsuccessful log-on attempts.

C. Place no limits on the time allotted for log-on or on the number of unsuccessful log-on attempts.

D. Validate the log-on only after all input data has been supplied.

Answer: D

Explanation:

This approach is necessary to ensure that all the information required for a log-on has been submitted and to avoid providing information that would aid a cracker in trying to gain unauthorized access to the workstation or network. If a log-on attempt fails, information as to which part of the requested log-on information was incorrect should not be supplied to the user.

Answer "Provide a Help mechanism that provides log-on assistance" is incorrect since a Help utility would provide help to a cracker trying to gain unauthorized access to the network.

For answer "Place no limits on the time allotted for log-on or on the number of unsuccessful log-on attempts", maximum and minimum time limits should be placed on the log-on process. Also, the log-on process should limit the number of unsuccessful log-on attempts and temporarily suspend the log-on capability if that number is exceeded. One approach is to progressively increase the time interval allowed between unsuccessful log-on attempts.

Answer "Not provide information on the previous successful log-on and on previous unsuccessful log-on attempts" is incorrect since providing such information will alert an authorized user if someone has been attempting to gain unauthorized access to the network from the user's workstation.

QUESTION NO: 1481

Which choice below BEST describes the difference between the System Owner and the Information Owner?

- A.** The System Owner is responsible for establishing the rules for appropriate use of the information.
- B.** The Information Owner is responsible for defining the system's operating parameters.
- C.** One system could have multiple information owners.
- D.** There is a one-to-one relationship between system owners and information owners.

Answer: C

Explanation:

The System Owner is responsible for ensuring that the security plan is prepared and for implementing the plan and monitoring its effectiveness. The System Owner is responsible for defining the system's operating parameters, authorized functions, and security

requirements. The information owner for information stored within, processed by, or transmitted by a system may or may not be the same as the System Owner. Also, a single system may utilize information from multiple Information Owners.

The Information Owner is responsible for establishing the rules for appropriate use and protection of the subject data/information (rules of behavior). The Information Owner retains that responsibility even when the data/information are shared with other organizations.

Source: NIST Special Publication 800-18, Guide for Developing Security Plans for Information Technology Systems.

QUESTION NO: 1482

Which choice below is NOT an accurate statement about the visibility of IT security policy?

- A.** Include the IT security policy as a regular topic at staff meetings at all levels of the organization.
- B.** The IT security policy should not be afforded high visibility.
- C.** The IT security policy could be visible through panel discussions with guest speakers.
- D.** The IT security policy should be afforded high visibility.

Answer: B

Explanation:

Especially high visibility should be afforded the formal issuance of IT security policy. This is because nearly all employees at all levels will in some way be affected, major organizational resources are being addressed, and many new terms, procedures, and activities will be introduced.

Including IT security as a regular topic at staff meetings at all levels of the organization can be helpful. Also, providing visibility through such avenues as management presentations, panel discussions, guest speakers, question/answer forums, and newsletters can be beneficial.

QUESTION NO: 1483

Which choice below does NOT relate to analog dial-up hacking?

- A. War Walking
- B. War Dialing
- C. Demon Dialing
- D. ToneLoc

Answer: A

Explanation:

War Walking (or War Driving) refers to scanning for 802.11-based wireless network information, by either driving or walking with a laptop, a wireless adapter in promiscuous mode, some type of scanning software such as NetStumbler or AiroPeek, and a Global Positioning System (GPS).

* War Dialing, is a method used to hack into computers by using a software program to automatically call a large pool of telephone numbers to search for those that have a modem attached.

* Demon Dialing, similar to War Dialing, is a tool used to attack one modem using brute force to guess the password and gain access.

* ToneLoc, was one of the first war-dialing tools used by phone phreakers. Sources: Hacking Exposed by Stuart McClure, Joel Scambray, and George Kurtz (Osborne, 1999) and War Driving by the Bay by Kevin Poulsen, The Register, April 13, 2001.

QUESTION NO: 1484

Which is NOT a property of or issue with tape backup?

- A. One large disk created by using several disks
- B. Slow data transfer during backups and restores
- C. Server disk space utilization expands

D. The possibility that some data re-entry might need to be performed after a crash

Answer: A

Explanation:

The correct answer is "One large disk created by using several disks". RAID level 0 striping is the process of creating a large disk out of several smaller disks.

QUESTION NO: 1485

In mandatory access control, the authorization of a subject to have access to an object is dependent upon:

- A.** Roles.
- B.** Labels.
- C.** Tasks.
- D.** Identity.

Answer: B

Explanation:

The correct answer is Labels. Mandatory access controls use labels to determine whether subjects can have access to objects, depending on the subjects' clearances. Answer roles is applied in non-discretionary access control as is tasks. Identity, is used in discretionary access control.

QUESTION NO: 1486

In a relational database, the domain of a relation is the set of allowable values:

- A.** That tuples can take.
- B.** Of the primary key.
- C.** That an attribute can take.

D. That a record can take.

Answer: C

Explanation:

QUESTION NO: 1487

In addition to accuracy, a biometric system has additional factors that determine its effectiveness. Which one of the following listed items is NOT one of these additional factors?

- A. Corpus
- B. Throughput rate
- C. Enrollment time
- D. Acceptability

Answer: A

Explanation:

A corpus is a biometric term that refers to collected biometric images. The corpus is stored in a database of images. Potential sources of error are the corruption of images during collection and mislabeling or other transcription problems associated with the database. Therefore, the image collection, process and storage must be performed carefully with constant checking. These images are collected during the enrollment process and thus, are critical to the correct operation of the biometric device. In enrollment, images are collected and features are extracted, but no comparison occurs. The information is stored for use in future comparison steps. Answer a, the throughput rate, refers to the rate at which individuals, once enrolled, can be processed by a biometric system. If an individual is being authenticated, the biometric system will take a sample of the individual's characteristic to be evaluated and compare it to a template. A metric called distance is used to determine if the sample matches the template. Distance is the difference between the quantitative measure of the sample and the template. If the distance falls within a threshold value, a match is declared. If not, there is no match.

* Answer "acceptability" is determined by privacy issues, invasiveness, and psychological and physical comfort when using the

biometric system.

*"Enrollment time" is the time it takes to initially register with a system by providing samples of the biometric characteristic to be evaluated.

QUESTION NO: 1488

Which choice below is NOT a way to get Windows NT passwords?

- A.** Obtain root access to the /etc/passwd file.
- B.** Use pwdump2 to dump the password hashes directly from the registry.
- C.** Obtain the backup SAM from the repair directory.
- D.** Boot the NT server with a floppy containing an alternate operating system.

Answer: A

Explanation:

The /etc/passwd file is a Unix system file. The NT Security Accounts Manager, SAM, contains the usernames and encrypted passwords of all local (and domain, if the server is a domain controller) users. The SAM uses an older, weaker LanManager hash that can be broken easily by tools like L0phtcrack. Physical access to the NT server and the rdisk must be controlled. The Sam._ file in the repair directory must be deleted after creation of an rdisk. Pwdump and pwdump2 are utilities that allow someone with Administrator rights to target the Local Security Authority Subsystem, lsass.exe, from a remote system. Source: Hacking Exposed by Stuart McClure, Joel Scambray, and George Kurtz (Osborne, 1999).

QUESTION NO: 1489

Which choice below is usually the number one used criterion to determine the classification of an information object?

- A. Age
- B. Personal association
- C. Useful life
- D. Value

Answer: D

Explanation:

The correct answer is Value. Value of the information asset to the organization is usually the first and foremost criteria used in determining its classification. Answer Useful life refers to declassification of an information object due to some change in situation.

QUESTION NO: 1490

To what does logon abuse refer?

- A. Legitimate users accessing networked services that would normally be restricted to them
- B. Nonbusiness or personal use of the Internet
- C. Intrusions via dial-up or asynchronous external network connections
- D. Breaking into a network primarily from an external source

Answer: A

Explanation:

The correct answer is "Legitimate users accessing networked services that would normally be restricted to them". Logon abuse entails an otherwise proper user attempting to access areas of the network that are deemed offlimits.

Answer "Breaking into a network primarily from an external source" is called network intrusion, and d refers to backdoor remote access.

QUESTION NO: 1491

How often should an independent review of the security controls be performed, according to OMB Circular A-130?

- A. Never
- B. Every five years
- C. Every three years
- D. Every year

Answer: C

Explanation:

The correct answer is "Every three years". OMB Circular A-130 requires that a review of the security controls for each major government application be performed at least every three years. For general support systems, OMB Circular A-130 requires that the security controls be reviewed either by an independent audit or self review. Audits can be selfadministered or independent (either internal or external). The essential difference between a self-audit and an independent audit is objectivity; however, some systems may require a fully independent review. Source: Office of Management and Budget Circular A-130, revised November 30, 2000 .

QUESTION NO: 1492

Kerberos is an authentication scheme that can be used to implement:

- A. Hash functions.
- B. Single Sign-On (SSO).
- C. Public key cryptography.
- D. Digital signatures.

Answer: B

Explanation:

The correct answer is "Single Sign-On (SSO)". Kerberos is a third-party authentication

protocol that can be used to implement SSO. Answer "Public key cryptography" is incorrect because public key cryptography is not used in the basic Kerberos protocol. Answer "Digital signatures" is a public key-based capability, and answer "Hash functions" is a one-way transformation used to disguise passwords or to implement digital signatures.

QUESTION NO: 1493

The concept of limiting the routes that can be taken between a workstation and a computer resource on a network is called:

- A. Path limitation
- B. A trusted path
- C. An enforced path
- D. A security perimeter

Answer: C

Explanation:

Individuals are authorized access to resources on a network through specific paths and the enforced path prohibits the user from accessing a resource through a different route than is authorized to that particular user. This prevents the individual from having unauthorized access to sensitive information in areas off limits to that individual. Examples of controls to implement an enforced path include establishing virtual private networks (VPNs) for specific groups within an organization, using firewalls with access control lists, restricting user menu options, and providing specific phone numbers or dedicated lines for remote access. Answer a is a distracter. Answer c, security perimeter, refers to the boundary where security controls are in effect to protect assets.

This is a general definition and can apply to physical and technical (logical) access controls. In physical security, a fence may define the security perimeter. In technical access control, a security perimeter can be defined in terms of a Trusted Computing Base (TCB). A TCB is the total combination of protection mechanisms within a computer system. These mechanisms include the firmware, hardware, and software that enforce the system security policy. The security perimeter is the boundary that separates the TCB from the remainder of the system. In

answer "A trusted path" a trusted path is a path that exists to permit the user to access the TCB without being compromised by other processes or users.

QUESTION NO: 1494

The data transmission method in which data is sent continuously and doesn't use either an internal clocking source or start/stop bits for timing is known as:

- A. Asynchronous
- B. Pleisiochronous
- C. Synchronous
- D. Isochronous

Answer: D

Explanation:

Isochronous data is synchronous data transmitting without a clocking source, with the bits sent continuously and no start or stop bits. All bits are of equal importance and are anticipated to occur at regular time intervals.

* asynchronous, is a data transmission method using a start bit at the beginning of the data value, and a stop bit at the end of the value.

* synchronous, is a messageframed transmission method that uses clocking pulses to match the speed of the data transmission.

* pleisiochronous, is a transmission method that uses more than one timing source, sometimes running at different speeds. This method may require master and slave clock devices. Source: Communications Systems and Networks by Ray Horak (M&T Books, 2000).

QUESTION NO: 1495

What is a server cluster?

- A. A tape array backup implementation
- B. A group of WORM optical jukeboxes
- C. A primary server that mirrors its data to a secondary server
- D. A group of independent servers that are managed as a single system

Answer: D

Explanation:

The correct answer is "A group of independent servers that are managed as a single system". A server cluster is a group of servers that appears to be a single server to the user.

Answer "A primary server that mirrors its data to a secondary server" refers to redundant servers.

QUESTION NO: 1496

Which choice MOST closely depicts the difference between qualitative and quantitative risk analysis?

- A. Aquantitative RAdoes not use the hard costs of losses, and a qualitative RAdoes.
- B. Aquantitative RAcannot be automated.
- C. Aqualitative RAuses many complex calculations.
- D. Aquantitative RAuses less guesswork than a qualitative RA.

Answer: D

Explanation:

The correct answer is "Aquantitative RAuses less guesswork than a qualitative RA". The other answers are incorrect.

QUESTION NO: 1497

Identity-based access control is a subset of which one of the following

access control categories?

- A. Discretionary access control
- B. Lattice-based access control
- C. Non-discretionary access control
- D. Mandatory access control

Answer: A

Explanation:

The correct answer is "Discretionary access control". Identity-based access control is a type of discretionary access control that grants access privileges based on the user's identity. A related type of discretionary access control is user-directed access control that gives the user, with certain limitations, the right to alter the access control to certain objects.

QUESTION NO: 1498

What is the Network Layer of the OSI reference model primarily responsible for?

- A. SMTP Gateway services
- B. LAN bridging
- C. Internetwork packet routing
- D. Signal regeneration and repeating

Answer: C

Explanation:

Although many routers can perform most of the functions above, the OSI Network layer is primarily responsible for routing.

* LAN bridging, is a Data Link Layer function.

* gateways, most commonly function at the higher layers.

* signal regeneration and repeating, is primarily a Physical layer function. Source: CCNA Study Guide by Todd Lammle, Donald Porter, and James Chellis (Sybex, 1999).

QUESTION NO: 1499

Which level of RAID is commonly referred to as disk mirroring?

- A. RAID 5
- B. RAID 1
- C. RAID 3
- D. RAID 0

Answer: B

Explanation:

Redundant Array of Inexpensive Disks (RAID) is a method of enhancing hard disk fault tolerance, which can improve performance (see Table A.8). RAID 1 maintains a complete copy of all data by duplicating each hard drive. Performance can suffer in some implementations of RAID 1, and twice as many drives are required. Novell developed a type of disk mirroring called disk duplexing, which uses

Commonly Used RAID Types

RAID LEVEL	DESCRIPTION
RAID 0	Multiple Drive Striping
RAID 1	Disk Mirroring
RAID 3	Single Parity Drive
RAID 5	Distributed Parity Information

multiple disk controller cards increasing both performance and reliability.

*RAID 0, gives some performance gains by striping

the data across multiple drives, but reduces fault tolerance, as the failure of any single drive disables the whole volume.

* RAID 3, uses a dedicated error-correction disk called a parity drive, and stripes the data across the other data drives.

* RAID 5 uses all disks in the array for both data and error correction, increasing both storage capacity and performance.

QUESTION NO: 1500

In biometrics, a good measure of performance of a system is the:

- A. False detection.
- B. Positive acceptance rate.
- C. Sensitivity.
- D. Crossover Error Rate (CER).

Answer: D

Explanation:

The correct answer is "Crossover Error Rate (CER)". The other items are made-up distracters.

QUESTION NO: 1501

Which is a property of a circuit-switched network as opposed to a packet-switched network?

- A. Physical, permanent connections exist from one point to another in a circuit-switched network.
- B. The data is broken up into packets.
- C. Packets are reassembled according to their originally assigned sequence numbers.
- D. The data is sent to the next destination, which is based on the router's understanding of the best available route.

Answer: A

Explanation:

The correct answer is "Physical, permanent connections exist from one point to another in a circuit-switched network". Permanent connections are a feature of circuit-switched networks.

Note: strictly speaking they aren't physical and they aren't permanent.

A phone call is circuit-switched (well, historically). The circuit wasn't permanent, just for the duration of the call.

QUESTION NO: 1502

Which answer below is true about the difference between TCP and UDP?

- A. UDP is considered a connectionless protocol and TCP is connectionoriented.
- B. TCP is considered a connectionless protocol, and UDP is connectionoriented.
- C. TCP is sometimes referred to as an unreliable protocol.
- D. UDP acknowledges the receipt of packets, and TCP does not.

Answer: A

Explanation:

The correct answer is "UDP is considered a connectionless protocol and TCP is connectionoriented". As opposed to the Transmission Control Protocol (TCP), the User Datagram Protocol (UDP) is a connectionless protocol. It does not sequence the packets, acknowledge the receipt of packets, and is referred to as an unreliable protocol.

QUESTION NO: 1503

In a Kerberos exchange involving a message with an authenticator, the authenticator contains the client ID and which of the following?

- A. Client network address
- B. Ticket Granting Ticket (TGT)
- C. Timestamp
- D. Client/TGS session key

Answer: C

Explanation:

A timestamp, t , is used to check the validity of the accompanying request since a Kerberos ticket is valid for some time window, v , after it is issued. The timestamp indicates when the ticket was issued.

* The TGT, is comprised of the client ID, the client network address, the

starting and ending time the ticket is valid (v), and the client/TGS session key. This ticket is used by the client to request the service of a resource on the network from the TGS.

* The client/TGS session key, K_c , tgs, is the symmetric key used for encrypted communication between the client and TGS for this particular session.

* the client network address is included in the TGT and not in the authenticator.

QUESTION NO: 1504

Which of the following is NOT a valid database model?

- A. Hierarchical
- B. Relational
- C. Object-relational
- D. Relational-rational

Answer: D

Explanation:

The correct answer is "Relational-rational", a distracter. The other answers are valid database models. Additional valid models include network and object-oriented databases.

QUESTION NO: 1505

Which statement is correct about ISDN Basic Rate Interface?

- A. It offers 30 B channels and 1 D channel.
- B. It offers 23 B channels and 1 D channel.
- C. It offers 2 B channels and 1 D channel.
- D. It offers 1 B channel and 2 D channels.

Answer: C

Explanation:

Integrated Services Digital Network (ISDN) Basic Rate Interface (BRI) offers two B channels which carry user data at 64 Kbps each, and one control and signaling D channel operating at 16 Kbps.

Answer "It offers 23 B channels and 1 D channel." describes ISDN Primary Rate Interface (PRI) for North America and Japan, with 23 B channels at 64 Kbps and one 64 Kbps D channel, for a total throughput of 1.544 Mbps.

Answer "It offers 30 B channels and 1 D channel." Describes ISDN PRI for Europe, Australia, and other parts of the world, with 30 64 Kbps B channels and one D channel, for a total throughput of 2.048 Mbps.

Answer "It offers 1 B channel and 2 D channels." is a distracter. Source: Internetworking Technologies Handbook, Second Edition (Cisco Press, 1998).

QUESTION NO: 1506

A persistent collection of data items that form relations among each other is called a:

- A.** Schema
- B.** Database management system (DBMS)
- C.** Database
- D.** Data description language (DDL)

Answer: C

Explanation:

For a database to be viable, the data items must be stored on nonvolatile media and be protected from unauthorized modification. For answer a, a DBMS provides access to the items in the database and maintains the information in the database.

*The Data description language (DDL) provides the means to define the database and schema is the description of the database.

QUESTION NO: 1507

Which of the following is NOT a network cabling type?

- A. Coaxial
- B. Token Ring
- C. Twisted Pair
- D. Fiber Optic

Answer: B

Explanation:

The correct answer Token Ring. Token Ring is a LAN media access method, not a cabling type.

QUESTION NO: 1508

Which choice below is the BEST definition of advisory policies?

- A. Non-mandated policies, but strongly suggested
- B. Mandatory policies implemented as a consequence of legal action
- C. Policies implemented due to public regulation
- D. Policies implemented for compliance reasons

Answer: A

Explanation:

The correct answer is "Non-mandated policies, but strongly suggested". Advisory policies might have consequences of failure attached to them, but they are still considered nonmandatory. The other three answers are examples of mandatory, regulatory policies.

QUESTION NO: 1509

Which of the following is NOT a true statement about Network Address

Translation (NAT)?

- A.** Private addresses can easily be routed globally.
- B.** NAT is used when corporations want to use private addressing ranges for internal networks.
- C.** NAT is designed to mask the true IP addresses of internal systems.
- D.** NAT translates private IP addresses to registered real IP addresses.

Answer: A

Explanation:

The correct answer is "Private addresses can easily be routed globally" Private addresses are not easily routable; hence the reason for using NAT.

QUESTION NO: 1510

Which choice MOST accurately describes the differences between standards, guidelines, and procedures?

- A.** Procedures are the general recommendations for compliance with mandatory guidelines.
- B.** Standards are recommended policies, and guidelines are mandatory policies.
- C.** Procedures are step-by-step recommendations for complying with mandatory guidelines.
- D.** Procedures are step-by-step instructions for compliance with mandatory standards.

Answer: D

Explanation:

The correct answer is "Procedures are step-by-step instructions for compliance with mandatory standards". The other answers are incorrect.

QUESTION NO: 1511

In a biometric system, the time it takes to register with the system by providing samples of a biometric characteristic is called:

- A. Set-up time.
- B. Enrollment time.
- C. Log-in time.
- D. Throughput time.

Answer: B

Explanation:

The correct answer is "Enrollment time".

Answers Set-up time and Log-in time are distracters.

Answer throughput, refers to the rate at which individuals once enrolled can be processed and identified or authenticated by a biometric system.

QUESTION NO: 1512

Identification is:

- A. Auser providing a shared secret to the system.
- B. Auser professing an identity to the system.
- C. Auser providing a password to the system.
- D. Auser being authenticated by the system.

Answer: B

Explanation:

The correct answer is "Auser professing an identity to the system". A user presents an ID to the system as identification. Answer a is incorrect because presenting an ID is not an authentication act. Answer "Auser providing a password to the system" is incorrect because a password is an authentication mechanism. Answer "Auser providing a shared secret to the system" is incorrect because it refers to cryptography or authentication.

QUESTION NO: 1513

Who has the final responsibility for the preservation of the organization's information?

- A. Application owners
- B. Senior management
- C. Users
- D. Technology providers

Answer: B

Explanation:

Various officials and organizational offices are typically involved with computer security. They include the following groups:

Senior management

Program/functional managers/application owners

Computer security management

Technology providers

Supporting organizations

Users

Senior management has the final responsibility through due care and due diligence to preserve the capital of the organization and further its business model through the implementation of a security program. While senior management does not have the functional role of managing security procedures, it has the ultimate responsibility to see that business continuity is preserved.

QUESTION NO: 1514

Which statement below BEST describes the primary purpose of risk analysis?

- A. To quantify the impact of potential threats
- B. To create a clear cost-to-value ratio for implementing security controls
- C. To influence site selection decisions
- D. To influence the system design process

Answer: A

Explanation:

The correct answer is "To quantify the impact of potential threats". The main purpose of performing a risk analysis is to put a hard cost or value onto the loss of a business function. The other answers are benefits of risk management but not its main purpose.

QUESTION NO: 1515

Kerberos provides an integrity check service for messages between two entities through the use of:

- A. A trusted, third-party authentication server
- B. A checksum
- C. Credentials
- D. Tickets

Answer: B

Explanation:

A checksum that is derived from a Kerberos message is used to verify the integrity of the message. This checksum may be a message digest resulting from the application of a hash function to the message. At the receiving end of the transmission, the receiving party can calculate the message digest of the received message using the identical hash algorithm as the sender. Then the message digest calculated by the receiver can be compared with the message digest appended to the message by the sender. If the two message digests match, the message has not been modified en route, and its integrity has been preserved.

For answers Credentials and Tickets are authenticators used in the process of granting user access to services on the network. Answer "A trusted, third-party authentication server" is the AS or authentication server that conducts the ticket-granting process.

QUESTION NO: 1516

Which is NOT a packet-switched technology?

- A. Frame Relay
- B. SMDS
- C. X.25
- D. T1

Answer: D

Explanation:

The correct answer is T1. A T1 line is a type of leased line, which uses a dedicated, point-to-point technology.

QUESTION NO: 1517

According to NIST, which choice below is not an accepted security selftesting technique?

- A. Password Cracking
- B. Virus Detection
- C. War Dialing
- D. Virus Distribution

Answer: D

Explanation:

Common types of self-testing techniques include:

Network Mapping
Vulnerability Scanning
Penetration Testing
Password Cracking

Log Review

Virus Detection

War Dialing

Some testing techniques are predominantly human-initiated and conducted, while other tests are highly automated and require less human involvement. The staff that initiates and implements in-house security testing should have significant security and networking knowledge. These testing techniques are often combined to gain a more comprehensive assessment of the overall network security posture. For example, penetration testing almost always includes network mapping and vulnerability scanning to identify vulnerable hosts and services that may be targeted for later penetration. None of these tests by themselves will provide a complete picture of the network or its security posture. Source: NIST Special Publication 800-42, DRAFT Guideline on Network Security Testing.

QUESTION NO: 1518

Role-based access control is useful when:

- A. Access must be determined by the labels on the data.
- B. Rules are needed to determine clearances.
- C. There are frequent personnel changes in an organization.
- D. Security clearances must be used.

Answer: C

Explanation:

The correct answer is "There are frequent personnel changes in an organization.". Role-based access control is part of nondiscretionary access control. The other options relate to mandatory access control.

QUESTION NO: 1519

Which choice is the BEST description of authentication as opposed to authorization?

- A.** A system's capability to determine the actions and behavior of a single individual within a system
- B.** The testing or reconciliation of evidence of a user's identity
- C.** The means by which a user provides a claim of his or her identity to a system
- D.** The rights and permissions granted to an individual to access a computer resource

Answer: B

Explanation:

The correct answer is "The testing or reconciliation of evidence of a user's identity". Answer "The means by which a user provides a claim of his or her identity to a system" is identification, "A system's capability to determine the actions and behavior of a single individual within a system" is accountability, and "The rights and permissions granted to an individual to access a computer resource" is authorization.

QUESTION NO: 1520

Which TCP/IP protocol operates at the OSI Network layer?

- A.** FTP
- B.** IP
- C.** UDP
- D.** TCP

Answer: B

Explanation:

The correct answer is IP. IP operates at the network layer of the OSI model and at the Internet layer of the TCP/IP model. FTP operates at the application layer of the TCP/IP model, which is roughly similar to the top three layers of the OSI model: the Application, Presentation, and Session layers. TCP and UDP both operate at the OSI Transport

layer, which is similar to the TCP/IP Host-to-host layer.

QUESTION NO: 1521

Which choice below BEST describes coaxial cable?

- A.** Coax consists of a hollow outer cylindrical conductor surrounding a single, inner conductor.
- B.** Coax does not require a fixed spacing between connections that UTP requires.
- C.** Coax consists of two insulated wires wrapped around each other in a regular spiral pattern.
- D.** Coax carries signals as light waves.

Answer: A

Explanation:

The correct answer is "Coax consists of a hollow outer cylindrical conductor surrounding a single, inner conductor". Coax consists of a hollow outer cylindrical conductor surrounding a single, inner wire conductor.

Answer "Coax consists of two insulated wires wrapped around each other in a regular spiral pattern" describes UTP. Coax requires fixed spacing between connections, and answer "Coax carries signals as light waves" describes fiber-optic cable.

QUESTION NO: 1522

Which choice below is NOT one of the legal IP address ranges specified by RFC1976 and reserved by the Internet Assigned Numbers Authority (IANA) for nonroutable private addresses?

- A.** 192.168.0.0 - 192.168.255.255
- B.** 127.0.0.0 - 127.0.255.255
- C.** 10.0.0.0 - 10.255.255.255
- D.** 172.16.0.0 - 172.31.255.255

Answer: B

Explanation:

The other three address ranges can be used for Network Address Translation (NAT). While NAT is, in itself, not a very effective security measure, a large network can benefit from using NAT with Dynamic Host Configuration Protocol (DHCP) to help prevent certain internal routing information from being exposed. The address 127.0.0.1 is called the loopback address. Source: Designing Network Security by Merike Kaeo (Cisco Press, 1999).

QUESTION NO: 1523

What does LAN stand for?

- A. Local Adaptive Network
- B. Local Arena News
- C. Layered Addressed Network
- D. Local Area Network

Answer: D

Explanation:

QUESTION NO: 1524

Which statement below about the difference between analog and digital signals is incorrect?

- A. Adigital signal produces a saw-tooth wave form.
- B. Analog signals cannot be used for data communications.
- C. An analog signal produces an infinite waveform.
- D. An analog signal can be varied by amplification.

Answer: B

Explanation:

The correct answer is "Analog signals cannot be used for data communications". The other

answers are all properties of analog or digital signals.

QUESTION NO: 1525

What does the protocol ARP do?

- A. Takes a MAC address and finds an IP address to match
- B. Sends messages to the devices regarding the health of the network
- C. Takes an IP address and finds out the MAC address to which it belongs
- D. Facilitates file transfers

Answer: C

Explanation:

The correct answer is "Takes an IP address and finds out the MAC address to which it belongs". ARP starts with an IP address, then queries the network to find the MAC or hardware address of the workstation to which it belongs.

ICMP performs "Sends messages to the devices regarding the health of the network".

RARP performs "Takes a MAC address and finds an IP address to match".

FTP performs "Facilitates file transfers".

QUESTION NO: 1526

A group of processes that share access to the same resources is called:

- A. A Trusted Computing Base (TCB)
- B. A protection domain
- C. An access control triple
- D. An access control list

Answer: B

Explanation:

In answer a, an access control list (ACL) is a list denoting which users have what privileges to a particular resource. Table illustrates an ACL. The table shows the subjects or users that have access to the object, FILE X and what privileges they have with respect to that file.

For answer "An access control triple", an access control triple consists of the user, program, and file with the corresponding access privileges noted for each user.

The TCB, of answer "A Trusted Computing Base (TCB", is defined in the answers as the total combination of protection mechanisms within a computer system. These mechanisms include the firmware, hardware, and software that enforce the system security policy.

Access Control List	
USER	FILE X
JIM	READ
PROGRAM Y	READ/WRITE
GAIL	READ/WRITE

QUESTION NO: 1527

A database View operation implements the principle of:

- A. Entity integrity.
- B. Separation of duties.
- C. Referential integrity.
- D. Least privilege.

Answer: D

Explanation:

The correct answer is "Least privilege". Least privilege, in the database context, requires that subjects be granted the most restricted set of access privileges to the data in the database that are consistent with the performance

of their tasks.

Separation of duties, assigns parts of security-sensitive tasks to several individuals.

Entity integrity requires that each row in the relation table must have a non-NULL attribute. Relational integrity, answer d, refers to the requirement that for any foreign key attribute, the referenced relation must have the same value for its primary key.

QUESTION NO: 1528

Which choice below is NOT a common information-gathering technique when performing a risk analysis?

- A.** Employing automated risk assessment tools
- B.** Interviewing terminated employees
- C.** Reviewing existing policy documents
- D.** Distributing a questionnaire

Answer: B

Explanation:

Any combination of the following techniques can be used in gathering information relevant to the IT system within its operational boundary:

Questionnaire. The questionnaire should be distributed to the applicable technical and nontechnical management personnel who are designing or supporting the IT system.

On-site Interviews. On-site visits also allow risk assessment personnel to observe and gather information about the physical, environmental, and operational security of the IT system.

Document Review. Policy documents, system documentation, and security-related documentation can provide good information about the security controls used by and planned for the IT system.

Use of Automated Scanning Tools. Proactive technical methods can be used to collect system information efficiently.

Source: NIST Special Publication 800-30, Risk Management Guide for

QUESTION NO: 1529

What is the BEST description of risk reduction?

- A.** Assuming all costs associated with the risk internally
- B.** Assigning any costs associated with risk to a third party
- C.** Removing all risk to the enterprise at any cost
- D.** Altering elements of the enterprise in response to a risk analysis

Answer: D

Explanation:

The correct answer is "Altering elements of the enterprise in response to a risk analysis". Answer "Removing all risk to the enterprise at any cost" is not possible or desirable, "Assigning any costs associated with risk to a third party" is risk transference, and "Assuming all costs associated with the risk internally" is risk acceptance.

QUESTION NO: 1530

What are high-level policies?

- A.** They are step-by-step procedures to implement a safeguard.
- B.** They are the instructions on how to perform a Quantitative Risk Analysis.
- C.** They are recommendations for procedural controls.
- D.** They are statements that indicate a senior management's intention to support InfoSec.

Answer: D

Explanation:

The correct answer is "They are statements that indicate a senior management's intention to support InfoSec". High-level policies are senior management

statements of recognition of the importance of InfoSec controls.

QUESTION NO: 1531

What is the MOST accurate definition of a safeguard?

- A. A control designed to counteract a threat
- B. A guideline for policy recommendations
- C. A step-by-step instructional procedure
- D. A control designed to counteract an asset

Answer: A

Explanation:

The correct answer is "A control designed to counteract a threat". Answer "A guideline for policy recommendations" is a guideline, "A step-by-step instructional procedure" is a procedure, and "A control designed to counteract an asset" is a distracter.

QUESTION NO: 1532

What does the protocol RARP do?

- A. Sends messages to the devices regarding the health of the network
- B. Facilitates file transfers
- C. Takes an IP address and finds out the MAC address to which it belongs
- D. Takes a MAC address and finds an IP address to match

Answer: D

Explanation:

The correct answer is "Takes a MAC address and finds an IP address to match", the reverse of ARP. The Reverse Address Resolution Protocol knows a MAC (Media Access Control) address and asks the RARP server to match it with an IP address.

QUESTION NO: 1533

Which is NOT a property of a bridge?

- A. Operates at Layer 2, the Data Link Layer
- B. Operates at Layer 3, the Network Layer
- C. Forwards the data to all other segments if the destination is not on the local segment
- D. Can create a broadcast storm

Answer: B

Explanation:

The correct answer is "Operates at Layer 3, the Network Layer". A bridge operates at Layer 2 and therefore does not use IP addressing to make routing decisions.

QUESTION NO: 1534

A type of preventive/physical access control is:

- A. Biometrics for identification
- B. An intrusion detection system
- C. Biometrics for authentication
- D. Motion detectors

Answer: A

Explanation:

Biometrics applied to identification of an individual is a one-to-many search where an individual's physiological or behavioral characteristics are compared to a database of stored information. An example would be trying to match a person's fingerprints to a set in a national database of fingerprints. This search differs from the biometrics search for authentication in answer "Biometrics for authentication". That search would be a one-to-one comparison of a person's physiological or behavioral

characteristics with their corresponding entry in an authentication database. Answer "motion detectors" is a type of detective physical control and answer d is a detective/technical control.

QUESTION NO: 1535

What does an Exposure Factor (EF) describe?

- A.** The annual expected financial loss to an organization from a threat
- B.** The percentage of loss that a realized threat event would have on a specific asset
- C.** A number that represents the estimated frequency of the occurrence of an expected threat
- D.** A dollar figure that is assigned to a single event

Answer: B

Explanation:

The correct answer is "The percentage of loss that a realized threat event would have on a specific asset". Answer "A dollar figure that is assigned to a single event" is an SLE, "A number that represents the estimated frequency of the occurrence of an expected threat" is an ARO, and "The annual expected financial loss to an organization from a threat" is an ALE.

QUESTION NO: 1536

A firewall that performs stateful inspection of the data packet across all layers is considered a:

- A.** Fourth-generation firewall.
- B.** Second-generation firewall.
- C.** Third-generation firewall.
- D.** First-generation firewall.

Answer: C

Explanation:

The correct answer is Third-generation firewall. A stateful inspection firewall is considered a third-generation firewall.

QUESTION NO: 1537

Which is NOT a backup method type?

- A. Incremental
- B. Reactive
- C. Full
- D. Differential

Answer: B

Explanation:

The correct answer is Reactive. Reactive is not a backup method.

QUESTION NO: 1538

What part of an access control matrix shows capabilities that one user has to multiple resources?

- A. Rows
- B. Columns
- C. Rows and columns
- D. Access control list

Answer: A

Explanation:

The rows of an access control matrix indicate the capabilities that users have to a number of resources. An example of a row in the

access control matrix showing the capabilities of user JIM is given in Table.

Answer columns, columns in the access control matrix, define the access control list.

Answer "Rows and columns" is incorrect since capabilities involve only the rows of the access control matrix.

Answer "Access control list"

Capabilities			
USER	PROGRAM X	FILE X	FILE Y
JIM	EXECUTE	READ	READ/ WRITE

is incorrect since an ACL, again, is a column in the access control matrix.

QUESTION NO: 1539

Which policy type is MOST likely to contain mandatory or compulsory standards?

- A. Regulatory
- B. Guidelines
- C. Advisory
- D. Informative

Answer: A

Explanation:

The correct answer is Regulatory. Answer Advisory, advisory policies, might specify penalties for non-compliance, but regulatory policies are required to be followed by the organization. Answers Guidelines and Informative are informational or recommended policies only.

QUESTION NO: 1540

Which formula accurately represents an Annualized Loss Expectancy (ALE) calculation?

- A. $SLE \times ARO$
- B. $\text{Asset Value (AV)} \times EF$
- C. $ARO \times EF - SLE$
- D. $\% \text{ of } ARO \times AV$

Answer: A

Explanation:

The correct answer is $SLE \times ARO$. Answer Asset Value (AV) $\times EF$ is the formula for an SLE, and answers $ARO \times EF - SLE$ and $\% \text{ of } ARO \times AV$ are nonsense.

QUESTION NO: 1541

A purpose of a security awareness program is to improve:

- A. The security of vendor relations.
- B. The possibility for career advancement of the IT staff.
- C. The company's attitude about safeguarding data.
- D. The performance of a company's intranet.

Answer: C

Explanation:

QUESTION NO: 1542

Which choice below is NOT an accurate description of an information policy?

- A. Information policy is senior management's directive to create a computer security program.
- B. Information policy is a documentation of computer security

decisions.

C. An information policy could be a decision pertaining to use of the organization's fax.

D. Information policies are created after the system's infrastructure has been designed and built.

Answer: D

Explanation:

Computer security policy is often defined as the documentation of computer security decisions. The term policy has more than one meaning. Policy is senior management's directives to create a computer security program, establish its goals, and assign responsibilities. The term policy is also used to refer to the specific security rules for particular systems. Additionally, policy may refer to entirely different matters, such as the specific managerial decisions setting an organization's e-mail privacy policy or fax security policy.

A security policy is an important document to develop while designing an information system, early in the System Development Life Cycle (SDLC). The security policy begins with the organization's basic commitment to information security formulated as a general policy statement. The policy is then applied to all aspects of the system design or security solution. Source: NIST Special Publication 800-27, Engineering Principles for Information Technology Security (A Baseline for Achieving Security).

QUESTION NO: 1543

Which part of the 48-bit, 12-digit hexadecimal number known as the

Media Access Control (MAC) address identifies the manufacturer of the network device?

A. The last three bytes

B. The first two bytes

C. The first three bytes

D. The second half of the MAC address

Answer: C

Explanation:

The first three bytes (or first half) of the six-byte MAC address is the manufacturer's identifier (see Table). This can be a good troubleshooting aid if a network device is acting up, as it will isolate the brand of the failing device. The other answers are distracters. Source: Mastering Network Security by Chris Brenton (Sybex, 1999).

Common Vendors' MAC Addresses	
FIRST THREE BYTES	VENDOR
00000C	Cisco
0000A2	Bay Networks
0080D3	Shiva
00AA00	Intel
02608C	3COM
080007	Apple
080009	Hewlett-Packard
080020	Sun
08005A	IBM

QUESTION NO: 1544

Windows 2000 uses which of the following as the primary mechanism for authenticating users requesting access to a network?

- A. Kerberos
- B. Hash functions
- C. Public key certificates
- D. SESAME

Answer: A

Explanation:

While Kerberos is the primary mechanism, system administrators may also use alternative authentication services running under the Security Support Provider Interface (SSPI). Answer hash

functions, are used for digital signature implementations. Answer SESAME is incorrect. It is the Secure European System for Applications in a Multivendor Environment. SESAME performs similar functions to Kerberos, but uses public key cryptography to distribute the secret keys. Answer "Public key certificates" is incorrect, since public key certificates are not used in the Windows 2000 primary authentication approach.

QUESTION NO: 1545

Procedures that ensure that the access control mechanisms correctly implement the security policy for the entire life cycle of an information system are known as:

- A. Accountability procedures.
- B. Authentication procedures.
- C. Assurance procedures.
- D. Trustworthy procedures.

Answer: C

Explanation:

The correct answer is "Assurance procedures".

Accountability, answer a, refers to the ability to determine the actions and behaviors of a single individual within a system and to identify that individual. Answer "Authentication procedures" involves testing or reconciling of evidence of a user's identity in order to establish that identity. Answer "Trustworthy procedures" is a distracter.

QUESTION NO: 1546

Which choice would be an example of a cost-effective way to enhance

security awareness in an organization?

- A. Train only managers in implementing InfoSec controls.
- B. Calculate the cost-benefit ratio of the asset valuations for a risk analysis.
- C. Train every employee in advanced InfoSec.
- D. Create an award or recognition program for employees.

Answer: D

Explanation:

QUESTION NO: 1547

In a relational database, security is provided to the access of data through:

- A. Candidate keys.
- B. Views.
- C. Joins.
- D. Attributes.

Answer: B

Explanation:

The correct answer is Views. Candidate keys, are the set of unique keys from which the primary key is selected. Answer joins indicates operations that can be performed on the database, and the attributes denote the columns in the relational table.

QUESTION NO: 1548

The Open Group has defined functional objectives in support of a user single sign-on (SSO) interface. Which of the following is NOT one of those objectives and would possibly represent a vulnerability?

- A. Provision for user-initiated change of nonuser-configured authentication information.

- B.** Support shall be provided for a subject to establish a default user profile.
- C.** The interface shall be independent of the type of authentication information handled.
- D.** It shall not predefine the timing of secondary sign-on operations.

Answer: A

Explanation:

User configuration of nonuser-configured authentication mechanisms is not supported by the Open Group SSO interface objectives. Authentication mechanisms include items such as smart cards and magnetic badges. Strict controls must be placed to prevent a user from changing configurations that are set by another authority. Objective a supports the incorporation of a variety of authentication schemes and technologies. Answer c states that the interface functional objectives do not require that all sign-on operations be performed at the same time as the primary sign on. This prevents the creation of user sessions with all the available services even though these services are not needed by the user.

The creation of a default user profile will make the sign-on more efficient and less time-consuming.

In summary, the scope of the Open Group Single Sign-On Standards is to define services in support of:

The development of applications to provide a common, single end-user sign-on interface for an enterprise.

The development of applications for the coordinated management of multiple user account management information bases maintained by an enterprise.

QUESTION NO: 1549

Which choice below is NOT an accurate statement about an organization's incident-handling capability?

- A.** The organization's incident-handling capability should be used to contain and repair damage done from incidents.

- B.** It should be used to prevent future damage from incidents.
- C.** The organization's incident-handling capability should be used to detect and punish senior-level executive wrong-doing.
- D.** It should be used to provide the ability to respond quickly and effectively to an incident.

Answer: C

Explanation:

An organization should address computer security incidents by developing an incident-handling capability. The incident-handling capability should be used to:

Provide the ability to respond quickly and effectively.

Contain and repair the damage from incidents. When left unchecked, malicious software can significantly harm an organization's computing, depending on the technology and its connectivity.

Containing the incident should include an assessment of whether the incident is part of a targeted attack on the organization or an isolated incident.

Prevent future damage. An incident-handling capability should assist an organization in preventing (or at least minimizing) damage from future incidents. Incidents can be studied internally to gain a better understanding of the organization's threats and vulnerabilities.

Source: NIST Special Publication 800-14, Generally Accepted Principles and Practices for Securing Information Technology Systems.

QUESTION NO: 1550

Which is NOT a layer in the OSI architecture model?

- A.** Data Link
- B.** Internet
- C.** Transport
- D.** Session

Answer: B

Explanation:

The correct answer is Internet. The Internet Layer is a TCP/IP architecture model layer.

QUESTION NO: 1551

A standard data manipulation and relational database definition language is:

- A. OOD
- B. SQL
- C. Script
- D. SLL

Answer: B

Explanation:

The correct answer is SQL. All other answers do not apply.

QUESTION NO: 1552

The main approach to obtaining the true biometric information from a collected sample of an individual's physiological or behavioral characteristics is:

- A. False rejection
- B. Enrollment
- C. Digraphs
- D. Feature extraction

Answer: D

Explanation:

Feature extraction algorithms are a subset of signal/image processing

and are used to extract the key biometric information from a sample that has been taken from an individual. Usually, the sample is taken in an environment that may have noise and other conditions that may affect the raw sample image. Neural networks are an example of a feature extraction approach.

Answer "enrollment" refers to the process of collecting samples that are averaged and then stored to use as a reference base against which future samples are compared.

Answer "False rejection" refers to the false rejection in biometrics. False rejection is the rejection of an authorized user because of a mismatch between the sample and the reference template. Conversely, false acceptance is the acceptance of an unauthorized user because of an incorrect match to the template of an authorized user. The corresponding measures in percentage are the False Rejection Rate (FRR) and False Acceptance Rate (FAR).

For answer diagraphs refer to sets of average values compiled in the biometrics area of keystroke dynamics. Keystroke dynamics involves analyzing the characteristics of a user typing on a keyboard. Keystroke duration samples as well as measures of the latency between keystrokes are taken and averaged. These averages for all pairs of keys are called diagraphs. Tri-graphs, sample sets for all key triples, can also be used as biometric samples.

QUESTION NO: 1553

The Secure European System for Applications in a Multivendor Environment (SESAME) implements a Kerberos-like distribution of secret keys. Which of the following is NOT a characteristic of SESAME?

- A.** Uses a trusted authentication server at each host
- B.** Incorporates two certificates or tickets, one for authentication and one defining access privileges
- C.** Uses secret key cryptography for the distribution of secret keys

D. Uses public key cryptography for the distribution of secret keys

Answer: C

Explanation:

SESAME uses public key cryptography for the distribution of secret keys. In addition, SESAME employs the MD5 and crc32 oneway hash functions. A weakness in SESAME is that, similar to Kerberos, it is subject to password guessing.

QUESTION NO: 1554

Using symmetric key cryptography, Kerberos authenticates clients to other entities on a network and facilitates communications through the assignment of:

- A.** Tokens.
- B.** Passwords.
- C.** Public keys.
- D.** Session keys.

Answer: D

Explanation:

The correct answer is "Session keys". Session keys are temporary keys assigned by the KDC and used for an allotted period of time as the secret key between two entities. Answer a is incorrect because it refers to asymmetric encryption that is not used in the basic Kerberos protocol. Answer Passwords is incorrect because it is not a key, and answer Tokens is incorrect because a token generates dynamic passwords.

QUESTION NO: 1555

Which group represents the MOST likely source of an asset loss through

inappropriate computer use?

- A. Saboteurs
- B. Hackers
- C. Crackers
- D. Employees

Answer: D

Explanation:

The correct answer is Employees. Internal personnel far and away constitute the largest amount of dollar loss due to unauthorized or inappropriate computer use.

QUESTION NO: 1556

A reference monitor is a system component that enforces access controls on an object. Specifically, the reference monitor concept is an abstract machine that mediates all access of subjects to objects. The hardware, firmware, and software elements of a trusted computing base that implement the reference monitor concept are called:

- A. Identification and authentication (I & A) mechanisms
- B. The auditing subsystem
- C. The security kernel
- D. The authorization database

Answer: C

Explanation:

The security kernel implements the reference model concept. The reference model must have the following characteristics:

It must mediate all accesses.

It must be protected from modification.

It must be verifiable as correct.

Answer "the authorization database" is used by the reference monitor to mediate accesses by subjects to objects. When a request for access

is received, the reference monitor refers to entries in the authorization database to verify that the operation requested by a subject for application to an object is permitted. The authorization database has entries or authorizations of the form subject, object, access mode.

In answer "Identification and authentication (I & A) mechanisms", the I & A operation is separate from the reference monitor. The user enters his/her identification to the I & A function. Then the user must be authenticated. Authentication is verification that the user's claimed identity is valid. Authentication is based on the following three factor types:

Type 1. Something you know, such as a PIN or password

Type 2. Something you have, such as an ATM card or smart card

Type 3. Something you are (physically), such as a fingerprint or retina scan

Answer "The auditing subsystem" is a key complement to the reference monitor. The auditing subsystem is used by the reference monitor to keep track of the reference monitor's activities. Examples of such activities include the date and time of an access request, identification of the subject and objects involved, the access privileges requested and the result of the request.

QUESTION NO: 1557

Which choice below is NOT an element of IPSec?

- A. Encapsulating Security Payload
- B. Authentication Header
- C. Layer Two Tunneling Protocol
- D. Security Association

Answer: C

Explanation:

The Layer Two Tunneling Protocol (L2TP) is a layer two tunneling protocol that allows a host to establish a virtual connection. Although L2TP, an enhancement to Layer Two Forwarding Protocol (L2F) and

supporting some features of Point to Point Tunneling Protocol (PPTP), may coexist with IPSec, it is not natively an IPSec component. Answer a, the Authentication Header (AH), is an authenticating protocol that uses a hash signature in the packet header to validate the integrity of the packet data and the authenticity of the sender.

* the Security Association (SA), is a component of the IPSec architecture that contains the information the IPSec device needs to process incoming and outbound IPSec packets. IPSec devices embed a value called the Security Parameter Index (SPI) in the header to associate a datagram with its SA, and store SAs in a Security Association Database (SAD).

* the Encapsulating Security Payload (ESP), is an authenticating and encrypting protocol that provides integrity, source authentication, and confidentiality services. Source: Implementing IPSec by Elizabeth Kaufman and Andrew Newman (Wiley, 1999).

QUESTION NO: 1558

Which choice below is an accurate statement about the difference between monitoring and auditing?

- A. A system audit is an ongoing real-time activity that examines a system.
- B. A system audit cannot be automated.
- C. Monitoring is an ongoing activity that examines either the system or the users.
- D. Monitoring is a one-time event to evaluate security.

Answer: C

Explanation:

System audits and monitoring are the two methods organizations use to maintain operational assurance. Although the terms are used loosely within the computer security community, a system audit is a one-time or periodic event to evaluate security, whereas monitoring refers to an ongoing activity that examines either the system or the users. In general, the more real-time an activity is, the more it falls into the category of monitoring. Source: NIST Special Publication 800-14, Generally Accepted Principles and Practices for Securing Information Technology Systems.

QUESTION NO: 1559

The type of access control that is used in local, dynamic situations where subjects have the ability to specify what resources certain users can access is called:

- A. Mandatory access control.
- B. Rule-based access control.
- C. Discretionary access control.
- D. Sensitivity-based access control.

Answer: C

Explanation:

The correct answer is "Discretionary access control". Answers "Mandatory access control" and "Rule-based access control." require strict adherence to labels and clearances. Answer "Sensitivity-based access control." is a made-up distracter.

QUESTION NO: 1560

The number of times a password should be changed is NOT a function of:

- A. The responsibilities and clearance of the user.
- B. The criticality of the information to be protected.
- C. The type of workstation used.
- D. The frequency of the password's use.

Answer: C

Explanation:

The correct answer is "The type of workstation used.". The type of workstation used as the platform is not the determining factor. The other options are determining factors.

QUESTION NO: 1561

Three things that must be considered for the planning and implementation of access control mechanisms are:

- A. Threats, assets, and objectives.
- B. Threats, vulnerabilities, and risks.
- C. Vulnerabilities, secret keys, and exposures.
- D. Exposures, threats, and countermeasures.

Answer: B

Explanation:

The correct answer is "Threats, vulnerabilities, and risks". Threats define the possible source of security policy violations; vulnerabilities describe weaknesses in the system that might be exploited by the threats; and the risk determines the probability of threats being realized. All three items must be present to meaningfully apply access control. Therefore, the other answers are incorrect.

QUESTION NO: 1562

Access control that is a function of factors such as location, time of day, and previous access history is called:

- A. Information flow
- B. Context-dependent
- C. Positive
- D. Content-dependent

Answer: B

Explanation:

In answer "Context-dependent", access is determined by the context of the decision as opposed to the information contained in the item being accessed. The latter is referred to as content-dependent access control. In content-dependent access control, for example, the manager of a department may be authorized to access employment records of a department employee, but may not be permitted to view the health records of the employee.

* The term positive in access control refers to positive access rights, such as read or write. Denial rights, such as denial to write to a file, can also be conferred upon a subject.

* Information flow describes a class of access control models. An information flow model is described by the set consisting of object, flow policy, states, and rules describing the transitions among states.

QUESTION NO: 1563

To what does covert channel eavesdropping refer?

- A. Using a hidden, unauthorized network connection to communicate unauthorized information
- B. The use of two-factor passwords
- C. Nonbusiness or personal use of the Internet
- D. Socially engineering passwords from an ISP

Answer: A

Explanation:

The correct answer is "Using a hidden, unauthorized network connection to communicate unauthorized information". A Covert Channel is a connection intentionally created to transmit unauthorized information from inside a trusted network to a partner at an outside, untrusted node.

Answer "Socially engineering passwords from an ISP" is called masquerading.

QUESTION NO: 1564

In a relational database system, a primary key is chosen from a set of:

- A. Candidate keys.
- B. Foreign keys.
- C. Secondary keys.
- D. Cryptographic keys.

Answer: A

Explanation:

The correct answer is candidate keys by definition. Answer Foreign keys is incorrect because a foreign key in one table refers to a primary key in another. Answer Secondary keys is a made-up distracter, and answer Cryptographic key refers to keys used in encipherment and decipherment.

QUESTION NO: 1565

Controlling access to information systems and associated networks is necessary for the preservation of their confidentiality, integrity, and availability. Which of the following is NOT a goal of integrity?

- A. Preservation of the internal and external consistency of the information
- B. Prevention of the modification of information by unauthorized users
- C. Prevention of the unauthorized or unintentional modification of information by authorized users
- D. Prevention of authorized modifications by unauthorized users

Answer: D

Explanation:

The other options are the three principles of integrity. Answer "Prevention of authorized modifications by unauthorized users" is a distracter and does not make sense.

* Internal consistency ensures that internal data correlate. For example, the total number

of a particular data item in the database should be the sum of all the individual, non-identical occurrences of that data item in the database. External consistency requires that the database content be consistent with the real world items that it represents.

QUESTION NO: 1566

To what does 10Base-5 refer?

- A. 100 Mbps unshielded twisted pair cabling
- B. 10 Mbps thinnet coax cabling rated to 185 meters maximum length
- C. 10 Mbps thicknet coax cabling rated to 500 meters maximum length
- D. 10 Mbps baseband optical fiber

Answer: C

Explanation:

The correct answer is "10 Mbps thicknet coax cabling rated to 500 meters maximum length". Answer "10 Mbps thinnet coax cabling rated to 185 meters maximum length" refers to 10Base-2. 10 Mbps baseband optical fiber refers to 10Base-F. 100 Mbps unshielded twisted pair cabling to 100Base-T.

QUESTION NO: 1567

Which choice below is the BEST description of an Annualized Loss Expectancy (ALE)?

- A. The expected risk factor of an annual threat event, derived by multiplying the SLE by its ARO
- B. The percentile of the value of the asset expected to be lost, used to calculate the SLE
- C. A value determined by multiplying the value of the asset by its exposure factor

D. An estimate of how often a given threat event may occur annually

Answer: A

Explanation:

Answer "An estimate of how often a given threat event may occur annually" describes the Annualized Rate of Occurrence (ARO).

Answer "The percentile of the value of the asset expected to be lost, used to calculate the SLE" describes the Exposure Factor (EF).

Answer "A value determined by multiplying the value of the asset by its exposure factor" describes the algorithm to determine the Single Loss Expectancy (SLE) of a threat.

QUESTION NO: 1568

Which statement below is accurate about the difference between issuespecific and system-specific policies?

- A.** Issue-specific policy commonly addresses only one system.
- B.** Issue-specific policy is much more technically focused.
- C.** System-specific policy is much more technically focused.
- D.** System-specific policy is similar to program policy.

Answer: C

Explanation:

Often, managerial computer system security policies are categorized into three basic types:

Program policy used to create an organization's computer security program

Issue-specific policies used to address specific issues of concern to the organization

System-specific policies technical directives taken by management to protect a particular system

Program policy and issue-specific policy both address policy from a broad level, usually encompassing the entire organization. However, they do not provide sufficient information or direction, for example, to be used in establishing an access control list or in training users on what actions are permitted. System-specific policy fills this

need. System-specific policy is much more focused, since it addresses only one system.

Table A.1 helps illustrate the difference between these three types of policies. Source: National Institute of Standards and Technology, An Introduction to Computer Security: The NIST Handbook Special Publication 800-12.

Security Policy Types

POLICY TYPE	DESCRIPTION	EXAMPLE
Program policy	High-level program policy	Senior-level Management Statement
Issue-specific policy	Addresses single issue	Email privacy policy
System-specific policy	Single-system directives	Router Access Control Lists

QUESTION NO: 1569

Which protocol below does NOT pertain to e-mail?

- A. SMTP
- B. CHAP
- C. POP
- D. IMAP

Answer: B

Explanation:

The Challenge Handshake Authentication Protocol (CHAP) is used at the startup of a remote link to verify the identity of a remote node.

* The Simple Mail Transfer Protocol (RFCs 821 and

1869), is used by a server to deliver e-mail over the Internet.

* the Post Office Protocol (RFC 1939), enables users to read their email by downloading it from a remote server on to their local computer.

* the Internet Message Access Protocol (RFC 2060), allows users to read their e-mail on a remote server, without downloading the mail locally. Source: Handbook of Computer Crime Investigation Edited by Eoghan Casey (Academic Press, 2002).

QUESTION NO: 1570

Which one of the following security areas is directly addressed by Kerberos?

- A. Confidentiality
- B. Frequency analysis
- C. Availability
- D. Physical attacks

Answer: A

Explanation:

Kerberos directly addresses the confidentiality and also the integrity of information.

* attacks such as frequency analysis are not considered in the basic Kerberos implementation. In addition, the Kerberos protocol does not directly address availability issues. (Answer Availability.)

For answer "Physical attack", since the Kerberos TGS and the authentication servers hold all the secret keys, these servers are vulnerable to both physical attacks and attacks from malicious code. In the Kerberos exchange, the client workstation temporarily holds the client's secret key, and this key is vulnerable to compromise at the workstation.

QUESTION NO: 1571

In finger scan technology,

- A. More storage is required than in fingerprint technology.
- B. The full fingerprint is stored.
- C. The technology is applicable to large, one-to-many database searches.
- D. Features extracted from the fingerprint are stored.

Answer: D

Explanation:

The correct answer is "Features extracted from the fingerprint are store". The features extracted from the fingerprint are stored. Answer "The full fingerprint is stored" is incorrect because the equivalent of the full fingerprint is not stored in finger scan technology. Answers "More storage is required than in fingerprint technology" and "The technology is applicable to large, one-to-many database searches" are incorrect because the opposite is true of finger scan technology.

QUESTION NO: 1572

Which of the following is NOT a VPN remote computing protocol?

- A. PPTP
- B. L2F
- C. L2TP
- D. UTP

Answer: D

Explanation:

The correct answer is UTP. UTP stands for unshielded twisted pair wiring.

QUESTION NO: 1573

What does CSMA stand for?

- A. Common Systems Methodology Applications
- B. Carrier Sense Multiple Access

- C. Carrier Sense Multiple Attenuation
- D. Carrier Station Multi-port Actuator

Answer: B

Explanation:

The correct answer is "Carrier Sense Multiple Access". The other acronyms do not exist.

QUESTION NO: 1574

What is the protocol that supports sending and receiving email?

- A. SNMP
- B. RARP
- C. SMTP
- D. ICMP

Answer: C

Explanation:

The correct answer is SNMP, Simple Mail Transport Protocol. It queues and transfers email. SNMP stands for Simple Network Management Protocol. ICMP stands for Internet Control Message Protocol. RARP stands for Reverse Address Resolution Protocol

QUESTION NO: 1575

The fundamental entity in a relational database is the:

- A. Cost.
- B. Pointer.
- C. Relation.
- D. Domain.

Answer: C

Explanation:

The correct answer is Relation. The fundamental entity in a relational database is the relation in the form of a table. Answer Domain is the set of allowable attribute values, and answers Pointer and Cost are distracters.

QUESTION NO: 1576

Which is NOT a property of a packet-switched network?

- A. Connectionless network
- B. Packets are assigned sequence numbers
- C. Connection-oriented network
- D. Characterized by bursty traffic

Answer: C

Explanation:

The correct answer is "Connection-oriented network". Packet-switched networks are considered connectionless networks; circuit-switched networks are considered connection-oriented.

QUESTION NO: 1577

Which choice is NOT an accurate description of C.I.A.?

- A. A stands for authorization.
- B. I stands for integrity.
- C. A stands for availability.
- D. C stands for confidentiality.

Answer: A

Explanation:

QUESTION NO: 1578

In a wireless General Packet Radio Services (GPRS) Virtual Private Network (VPN) application, which of the following security protocols is commonly used?

- A. SSL**
- B. IPSEC**
- C. TLS**
- D. WTP**

Answer: B

Explanation:

An example is the use of a GPRS-enabled laptop that connects to a corporate intranet via a VPN. The laptop is given an IP address and a RADIUS server authenticates the user. IPSEC is used to create the VPN. As background, GPRS is a second-generation (2G) packet data technology that is overlaid on existing Global System for Mobile communications (GSM). GSM is the wireless analog of the ISDN landline system. The key features of GPRS are that it is always on line (no dial-up needed), existing GSM networks can be upgraded with GPRS, and it can serve as the packet data core of third generation (3G) systems.

Answers SSL and TLS are similar security protocols that are used on the Internet side of the Wireless Application Protocol (WAP) Gateway.

For answer WTP is the Wireless Transaction Protocol that is part of the WAP suite of protocols. WTP is a lightweight, message-oriented, transaction protocol that provides more reliable connections than UDP, but does not have the robustness of TCP.

QUESTION NO: 1579

Which choice below is NOT an example of appropriate security management practice?

- A. Reviewing access logs for unauthorized behavior
- B. Monitoring employee performance in the workplace
- C. Promoting and implementing security awareness programs
- D. Researching information on new intrusion exploits

Answer: B

Explanation:

Monitoring employee performance is not an example of security management, or a job function of the Information Security Officer. Employee performance issues are the domain of human resources and the employee's manager. The other three choices are appropriate practice for the information security area.

QUESTION NO: 1580

Which choice below is the BEST description of a vulnerability?

- A. Apotential incident that could cause harm
- B. The minimization of loss associated with an incident
- C. Aweakness in a system that could be exploited
- D. Acompany resource that could be lost due to an incident

Answer: C

Explanation:

The correct answer is "Aweakness in a system that could be exploited". Answer "Acompany resource that could be lost due to an incident" describes an asset, answer "The minimization of loss associated with an incide" describes risk management, and answer "Apotential incident that could cause harm"describes a threat.

QUESTION NO: 1581

The description of a relational database is called the:

- A.** Schema
- B.** Record
- C.** Attribute
- D.** Domain

Answer: A

Explanation:

The correct answer is Schema. The other answers are portions of a relation or table.

QUESTION NO: 1582

Which choice below would NOT be considered an element of proper user account management?

- A.** A process for tracking access authorizations should be implemented.
- B.** Periodically re-screen personnel in sensitive positions.
- C.** The users' accounts should be reviewed periodically.
- D.** Users should never be rotated out of their current duties.

Answer: D

Explanation:

Organizations should ensure effective administration of users' computer access to maintain system security, including user account management, auditing, and the timely modification or removal of access. This includes:

User Account Management. Organizations should have a process for requesting, establishing, issuing, and closing user accounts, tracking users and their respective access authorizations, and managing these functions.

Management Reviews. It is necessary to periodically review user

accounts. Reviews should examine the levels of access each individual has, conformity with the concept of least privilege, whether all accounts are still active, whether management authorizations are up-to-date, and whether required training has been completed.

Detecting Unauthorized/Illegal Activities. Mechanisms besides auditing and analysis of audit trails should be used to detect unauthorized and illegal acts, such as rotating employees in sensitive positions, which could expose a scam that required an employee's presence, or periodic re-screening of personnel.

Source: NIST Special Publication 800-14, Generally Accepted Principles and Practices for Securing Information Technology Systems.

QUESTION NO: 1583

FDDI uses what type of network topology?

- A. MESH
- B. RING
- C. STAR
- D. BUS

Answer: B

Explanation:

The correct answer is RING. FDDI is a RING topology, like Token Ring.

QUESTION NO: 1584

Which network attack below would NOT be considered a Denial of Service attack?

- A. Ping of Death

- B. SMURF
- C. TCP SYN
- D. Brute Force

Answer: D

Explanation:

A brute force attack is an attempt to use all combinations of key patterns to decipher a message. The other three attacks are commonly used to create a Denial of Service (DoS).

* Ping of Death, exploits ICMP by sending an illegal ECHO packet of >65K octets of data, which can cause an overflow of system variables and lead to a system crash.

* SMURF, is a type of attack using spoofed ICMP ECHO requests to broadcast addresses, which the routers attempt to propagate, congesting the network. Three participants are required for a SMURF attack: the attacker, the amplifying network, and the victim.

* a TCP SYN flood attack, generates phony TCP SYN packets from random IP addresses at a rapid rate to fill up the connection queue and stop the system from accepting legitimate users.

Source: Hacking Exposed by Stuart McClure, Joel Scambray, and George Kurtz (Osborne, 1999).

QUESTION NO: 1585

There are some correlations between relational data base terminology and object-oriented database terminology. Which of the following relational model terms, respectively, correspond to the object model terms of class, attribute and instance object?

- A. Relation, column, and tuple
- B. Relation, domain, and column
- C. Domain, relation, and column
- D. Relation, tuple, and column

Answer: A

Explanation:

Table shows the correspondence between the two models.

In comparing the two models, a class is similar to a relation; however, a relation does not have the inheritance property of a class. An attribute in the object model is similar to the column of a relational table. The column has limitations on the data types it can hold while an attribute in the object model can use all data types that are supported by the Java and C++ languages. An instance object in the object model corresponds to a tuple in the relational model. Again

Object and Relational Model Correspondence

OBJECT MODEL	RELATIONAL MODEL
CLASS	RELATION
ATTRIBUTE	COLUMN
INSTANCE OBJECT	TUPLE

the data structures of the tuple are limited while those of the instance object can use data structures of Java and C++.

QUESTION NO: 1586

Which IEEE protocol defines the Spanning Tree protocol?

- A. IEEE 802.1D
- B. IEEE 802.11
- C. IEEE 802.5
- D. IEEE 802.3

Answer: A

Explanation:

The 802.1D spanning tree protocol is an Ethernet link-management protocol that provides link redundancy while preventing routing loops. Since only one active path can exist for an Ethernet network to route properly, the STP algorithm calculates and manages the best loop-free path through the network.

IEEE 802.5 specifies a token-passing ring access method for LANs.

IEEE 802.3 specifies an Ethernet bus topology using Carrier Sense Multiple Access Control/Carrier Detect (CSMA/CD).

IEEE 802.11 is the IEEE standard that specifies 1 Mbps and 2 Mbps wireless connectivity in the 2.4 MHz ISM (Industrial, Scientific, Medical) band.

Source: Designing Network Security by Merike Kaeo (Cisco Press, 1999).

QUESTION NO: 1587

What does the Data Encapsulation in the OSI model do?

- A.** Provides best effort delivery of a data packet
- B.** Creates seven distinct layers
- C.** Wraps data from one layer around a data packet from an adjoining layer
- D.** Makes the network transmission deterministic

Answer: C

Explanation:

The correct answer is "Wraps data from one layer around a data packet from an adjoining layer". Data Encapsulation attaches information from one layer to the packet as it travels from an adjoining layer. The OSI-layered architecture model creates seven layers. The TCP/IP protocol UDP provides best effort packet delivery, and a tokenpassing transmission scheme creates a deterministic network because it is possible to compute the maximum predictable delay.

QUESTION NO: 1588

Object-Oriented Database (OODB) systems:

- A.** Are useful in storing and manipulating complex data, such as images and graphics.
- B.** Consume minimal system resources.

- C. Are ideally suited for text-only information.
- D. Require minimal learning time for programmers.

Answer: A

Explanation:

The correct answer is "Are useful in storing and manipulating complex data, such as images and graphics". The other answers are false, because for answer "Are ideally suited for text-only information" relational databases are ideally suited to text-only information, "Require minimal learning time for programmers" and "Consume minimal system resources". OODB systems have a steep learning curve and consume a large amount of system resources.

QUESTION NO: 1589

The goals of integrity do NOT include:

- A. Accountability of responsible individuals
- B. Prevention of the unauthorized or unintentional modification of information by authorized users
- C. Preservation of internal and external consistency
- D. Prevention of the modification of information by unauthorized users

Answer: A

Explanation:

The correct answer is "Accountability of responsible individuals". Accountability is holding individuals responsible for their actions. The other options are the three goals of integrity.

QUESTION NO: 1590

Which choice below most accurately reflects the goals of risk mitigation?

- A. Analyzing the effects of a business disruption and preparing the company's response
- B. Analyzing and removing all vulnerabilities and threats to security within the organization
- C. Defining the acceptable level of risk the organization can tolerate, and reducing risk to that level
- D. Defining the acceptable level of risk the organization can tolerate, and assigning any costs associated with loss or disruption to a third party, such as an insurance carrier

Answer: C

Explanation:

The correct answer is "Defining the acceptable level of risk the organization can tolerate, and reducing risk to that level ". The goal of risk mitigation is to reduce risk to a level acceptable to the organization. Therefore risk needs to be defined for the organization through risk analysis, business impact assessment, and/or vulnerability assessment.

Answer "Analyzing and removing all vulnerabilities and threats to security within the organization" is not possible. Answer "Defining the acceptable level of risk the organization can tolerate, and assigning any costs associated with loss or disruption to a third party, such as an insurance carrier" is called risk transference.

Answer "Analyzing the effects of a business disruption and preparing the company's response " is a distracter.

QUESTION NO: 1591

In SQL, a relation that is actually existent in the database is called a(n):

- A. Base relation
- B. Domain
- C. View
- D. Attribute

Answer: A

Explanation:

A base relation exists in the database while a view is a virtual relation that is not stored in the database. A view is derived by the SQL definition and is developed from base relations or, possibly, other views. An attribute, is a column in a relation table and a domain is the set of permissible values of an attribute.

QUESTION NO: 1592

Which choice is NOT a good criterion for selecting a safeguard?

- A. The ability to recover from a reset without damaging the asset
- B. Accountability features for tracking and identifying operators
- C. The ability to recover from a reset with the permissions set to allow all
- D. Comparing the potential dollar loss of an asset to the cost of a safeguard

Answer: C

Explanation:

The correct answer is "The ability to recover from a reset with the permissions set to allow all". Permissions should be set to deny all during reset.

QUESTION NO: 1593

Which UTP cable category is rated for 16 Mbps?

- A. Category 6
- B. Category 5
- C. Category 7
- D. Category 4

Answer: D

Explanation:

The correct answer is a. UTP Category 4 cabling is common in later Token Ring networks and is rated for up to 16 Mbps. Answer b, category 5, is rated for 100Mbps; answer c is rated for 155 Mbps; and answer d is rated for 1Gbps.

QUESTION NO: 1594

A protection mechanism to limit inferencing of information in statistical database queries is:

- A.** Specifying a maximum query set size
- B.** Specifying a minimum query set size, but prohibiting the querying of all but one of the records in the database
- C.** Specifying a minimum query set size
- D.** Specifying a maximum query set size, but prohibiting the querying of all but one of the records in the database

Answer: B

Explanation:

When querying a database for statistical information, individually identifiable information should be protected. Thus, requiring a minimum size for the query set (greater than one) offers protection against gathering information on one individual. However, an attack may consist of gathering statistics on a query set size M , equal to or greater than the minimum query set size, and then requesting the same statistics on a query set size of $M + 1$. The second query set would be designed to include the individual whose information is being sought surreptitiously.

*Thus with answer "Specifying a minimum query set size, but prohibiting the querying of all but one of the records in the database", this type of attack could not take place.

* Answer "Specifying a minimum query set size" is, therefore, incorrect since it leaves open the loophole of the $M+1$ set size query. Answers "Specifying a maximum query set size" and "Specifying a maximum query set size, but prohibiting the querying of all but one of the records in the database" are incorrect since the critical metric is the minimum

query set size and not the maximum size. Obviously, the maximum query set size cannot be set to a value less than the minimum set size.

QUESTION NO: 1595

Which choice below MOST accurately describes the organization's responsibilities during an unfriendly termination?

- A.** The employee should be given time to remove whatever files he needs from the network.
- B.** Cryptographic keys can remain the employee's property.
- C.** System access should be removed as quickly as possible after termination.
- D.** Physical removal from the offices would never be necessary.

Answer: C

Explanation:

Friendly terminations should be accomplished by implementing a standard set of procedures for outgoing or transferring employees.

This normally includes:

Removal of access privileges, computer accounts, authentication tokens.

The control of keys.

The briefing on the continuing responsibilities for confidentiality and privacy.

Return of property.

Continued availability of data. In both the manual and the electronic worlds this may involve documenting procedures or filing schemes, such as how documents are stored on the hard disk, and how they are backed up. Employees should be instructed whether or not to clean up their PC before leaving.

If cryptography is used to protect data, the availability of cryptographic keys to management personnel must be ensured.

Given the potential for adverse consequences during an unfriendly termination, organizations should do the following:

System access should be terminated as quickly as possible when an employee is leaving a position under less-than-friendly terms.

If employees are to be fired, system access should be removed at the same time (or just before) the employees are notified of their dismissal.

When an employee notifies an organization of the resignation and it can be reasonably expected that it is on unfriendly terms, system access should be immediately terminated.

During the notice of termination period, it may be necessary to assign the individual to a restricted area and function. This may be particularly true for employees capable of changing programs or modifying the system or applications.

In some cases, physical removal from the offices may be necessary.

Source: NIST Special Publication 800-14 Generally Accepted Principles and Practices for Securing Information Technology Systems.

QUESTION NO: 1596

Which choice below is an accurate statement about standards?

- A.** Standards are senior management's directives to create a computer security program.
- B.** Standards are used to describe how policies will be implemented within an organization.
- C.** Standards are the high-level statements made by senior management in support of information systems security.
- D.** Standards are the first element created in an effective security policy program.

Answer: B

Explanation:

The other options describe policies. Guidelines, standards, and procedures often accompany policy, but always follow the senior level management's statement of policy. Procedures, standards, and guidelines are used to describe how these policies will be implemented within an organization. Simply put, the three break down as follows: Standards specify the use of specific technologies in a uniform way (for example, the standardization of operating procedures). Guidelines are similar to standards but are recommended actions. Procedures are the detailed steps that must be performed for any

task.

QUESTION NO: 1597

Which choice below is NOT a common result of a risk analysis?

- A. Valuations of critical assets
- B. Definition of business recovery roles
- C. Likelihood of a potential threat
- D. Adetailed listing of relevant threats

Answer: B

Explanation:

The correct answer is "Definition of business recovery roles". The first three answers are common results

of a risk analysis to determine the probability and effect of threats to company assets. Answer "Definition of business recovery roles" is a distracter.

QUESTION NO: 1598

Which of the following is NOT a criterion for access control?

- A. Role
- B. Identity
- C. Keystroke monitoring
- D. Transactions

Answer: C

Explanation:

Keystroke monitoring is associated with the auditing function and not access control. For answer a, the identity of the user is a criterion for access control. The identity must be authenticated as part of the I & A process.

Answer Role refers to role-based access control where access to information is determined by the user's job function or role in the organization.

Transactions refer to access control through entering an account number or a transaction number, as may be required for bill payments by telephone, for example.

QUESTION NO: 1599

Which question below is NOT accurate regarding the process of risk assessment?

- A.** Risk assessment is the final result of the risk management methodology.
- B.** The likelihood of a threat must be determined as an element of the risk assessment.
- C.** Risk assessment is the first process in the risk management methodology
- D.** The level of impact of a threat must be determined as an element of the risk assessment.

Answer: A

Explanation:

Risk is a function of the likelihood of a given threat-source's exercising a particular potential vulnerability, and the resulting impact of that adverse event on the organization. Risk assessment is the first process in the risk management methodology. The risk assessment process helps organizations identify appropriate controls for reducing or eliminating risk during the risk mitigation process.

To determine the likelihood of a future adverse event, threats to an IT system must be analyzed in conjunction with the potential vulnerabilities and the controls in place for the IT system. The likelihood that a potential vulnerability could be exercised by a given threatsource can be described as high, medium, or low. Impact refers to the magnitude of harm that could be caused by a threat's exploitation of a vulnerability. The determination of the level of impact produces a relative value for the IT assets and resources affected. Source: NIST

Special Publication 800-30, Risk Management Guide for Information Technology Systems.

QUESTION NO: 1600

Which LAN transmission method below describes a packet sent from a single source to multiple specific destinations?

- A. Multicast
- B. Unicast
- C. Anycast
- D. Broadcast

Answer: A

Explanation:

The correct answer is multicast.

Unicast describes a packet sent from a single source to a single destination.

Broadcast describes a packet sent to all nodes on the network segment.

Anycast, refers to communication between any sender and the nearest of a group of receivers in a network.

QUESTION NO: 1601

Which choice below is NOT considered an information classification role?

- A. Data custodian
- B. Data alterer
- C. Data user
- D. Data owner

Answer: B

Explanation:

The correct answer is "Data alterer". Data owners, custodians, and users all have defined roles in the process of information classification.

Answer "Data alterer" is a distracter.

QUESTION NO: 1602

An example of two-factor authentication is:

- A.** An ID and a PIN.
- B.** A PIN and an ATM card.
- C.** A finger print.
- D.** A password and an ID.

Answer: B

Explanation:

The correct answer is "A PIN and an ATM card". These items are something you know and something you have. Answer "A password and an ID" is incorrect because essentially, only one factor is being used: something you know (password.).

Answer "An ID and a PIN" is incorrect for the same reason. Answer "A finger print" is incorrect because only one biometric factor is being used.

QUESTION NO: 1603

Which statement below is NOT true about the difference between cutthrough and store-and-forward switching?

- A.** Both methods operate at layer two of the OSI reference model.
- B.** A cut-through switch introduces more latency than a store-and-forward switch.
- C.** A store-and-forward switch reads the whole packet and checks its validity before sending it to the next destination.

D. A cut-through switch reads only the header on the incoming data packet.

Answer: B

Explanation:

A cut-through switch provides less latency than a store-and-forward switch, as it forwards the frame before it has received the complete frame. However, cut-through switches may also forward defective or empty packets. Source: Virtual LANs by Mariana Smith (McGraw-Hill, 1998).

QUESTION NO: 1604

Which choice below is a role of the Information Systems Security Officer?

- A.** The ISO is responsible for examining systems to see whether they are meeting stated security requirements.
- B.** The ISO is responsible for day-to-day security administration.
- C.** The ISO is responsible for following security procedures and reporting security problems.
- D.** The ISO establishes the overall goals of the organization's computer security program.

Answer: B

Explanation:

Answer "The ISO establishes the overall goals of the organization's computer security program" is a responsibility of senior management. Answer "The ISO is responsible for examining systems to see whether they are meeting stated security requirements" is a description of the role of auditing. Answer "The ISO is responsible for following security procedures and reporting security problems" is the role of the user, or consumer, of security in an organization.

QUESTION NO: 1605

A password that is the same for each logon is called a:

- A. Dynamic password.
- B. Static password.
- C. One-time pad.
- D. Passphrase.

Answer: B

Explanation:

The correct answer is "Static password.". In answer a, the password changes at each logon. For answer Passphrase, a passphrase is a long word or phrase that is converted by the system to a password. In answer "One-time pad", a one-time pad refers to a using a random key only once when sending a cryptographic message.

QUESTION NO: 1606

RAID refers to the:

- A. Rapid And Inexpensive Digital tape backup.
- B. Remote Administration of Internet Domains.
- C. Redundant Arrays of Intelligent Disks.
- D. Redundant And fault tolerant Internetworking Devices.

Answer: C

Explanation:

The correct answer is Redundant Arrays of Intelligent Disks. The other acronyms do not exist.

QUESTION NO: 1607

Enterprise Access Management (EAM) provides access control management services to Web-based enterprise systems. Which of the following functions is NOT normally provided by extant EAM approaches?

- A. Accommodation of a variety of authentication mechanisms
- B. Interoperability among EAM implementations
- C. Role-based access control
- D. Single sign-on

Answer: B

Explanation:

In general, security credentials produced by one EAM solution are not recognized by another implementation. Thus, reauthentication is required when linking from one Web site to another related Web site if the sites have different EAM implementations.

Answer "Single sign-on" (SSO) is approached in a number of ways. For example, SSO can be implemented on Web applications in the same domain residing on different servers by using nonpersistent, encrypted cookies on the client interface. This is accomplished by providing a cookie to each application that the user wishes to access. Another solution is to build a secure credential for each user on a reverse proxy that is situated in front of the Web server. The credential is, then, presented at each instance of a user attempting to access protected Web applications. For answer b, most EAM solutions accommodate a variety of authentication technologies, including tokens, ID/passwords and digital certificates. Similarly, for answer c, EAM solutions support role-based access controls, albeit they may be implemented in different fashions. Enterprise-level roles should be defined in terms that are universally accepted across most ecommerce applications.

QUESTION NO: 1608

Which is NOT a remote security method?

- A. Caller ID
- B. Callback
- C. VoIP
- D. Restricted Address

Answer: C

Explanation:

The correct answer is VoIP. VoIP stands for Voice-Over-IP, a digital telephony technology.

QUESTION NO: 1609

What is the prime directive of Risk Management?

- A. Reduce all risks regardless of cost.
- B. Transfer any risk to external third parties.
- C. Reduce the risk to a tolerable level.
- D. Prosecute any employees that are violating published security policies.

Answer: C

Explanation:

The correct answer is "Reduce the risk to a tolerable level. Risk can never be eliminated, and Risk Management must find the level of risk the organization can tolerate and still function effectively.

QUESTION NO: 1610

What is NOT a feature of TACACS+?

- A. Replaces older Frame Relay-switched networks
- B. Enables a user to change passwords
- C. Enables two-factor authentication
- D. Resynchronizes security tokens

Answer: A

Explanation:

The correct answer is "Replaces older Frame Relay-switched networks". TACACS+ has nothing to do with Frame Relay networks.

QUESTION NO: 1611

Which choice below is the earliest and the most commonly found Interior Gateway Protocol?

- A. OSPF**
- B. RIP**
- C. IGRP**
- D. EAP**

Answer: B

Explanation:

The Routing Information Protocol (RIP) bases its routing path on the distance (number of hops) to the destination. RIP maintains optimum routing paths by sending out routing update messages if the network topology changes. For example, if a router finds that a particular link is faulty, it will update its routing table, then send a copy of the modified table to each of its neighbors.

* the Open Shortest Path First (OSPF) is a link-state hierarchical routing algorithm intended as a successor to RIP. It features least-cost routing, multipath routing, and load balancing.

* the Internet Gateway Routing Protocol (IGRP) is a Cisco protocol that uses a composite metric as its routing metric, including bandwidth, delay, reliability, loading, and maximum transmission unit.

* the Extensible Authentication Protocol (EAP), is a general protocol for PPP authentication that supports multiple remote authentication mechanisms. Source: Introduction to Cisco Router Configuration edited by Laura Chappell (Cisco Press, 1999).

QUESTION NO: 1612

What does TFTP stand for?

- A. Trivial File Transport Protocol
- B. Transport File Transfer Protocol
- C. Transport for TCP/IP
- D. Trivial File Transfer Protocol

Answer: D

Explanation:

The correct answer is "Trivial File Transfer Protocol". The other acronyms do not exist.

QUESTION NO: 1613

An important control that should be in place for external connections to a network that uses call-back schemes is:

- A. Call enhancement
- B. Breaking of a dial-up connection at the organization's computing resource side of the line
- C. Breaking of a dial-up connection at the remote user's side of the line
- D. Call forwarding

Answer: B

Explanation:

One attack that can be applied when call back is used for remote, dial-up connections is that the caller may not hang up. If the caller had been previously authenticated and has completed his/her session, a live connection into the remote network will still be maintained.

Also, an unauthenticated remote user may hold the line open, acting as if call-back authentication has taken place. Thus, an active disconnect should be effected at the computing resource's side of the

line.

Answer "Breaking of a dial-up connection at the remote user's side of the line" is not correct since it involves the caller hanging up.

Answer "call forwarding" is a feature that should be disabled, if possible, when used with call-back schemes. With call back, a cracker can have a call forwarded from a valid phone number to an invalid phone number during the call-back process. Answer "Call enhancement" is a distracter.

QUESTION NO: 1614

An important element of database design that ensures that the attributes in a table depend only on the primary key is:

- A.** Data reuse.
- B.** Data integrity.
- C.** Data normalization.
- D.** Database management.

Answer: C

Explanation:

The correct answer is "Data normalization". Normalization includes eliminating redundant data and eliminating attributes in a table that are not dependent on the primary key of that table. In answer a, a database management system (DBMS) provides access to the database and is used for maintaining the database. Answers "Data integrity" and "Data reuse" are distracters.

QUESTION NO: 1615

Which IEEE standard defines wireless networking in the 5GHz band with speeds of up to 54 Mbps?

- A. 802.3
- B. 802.11b
- C. 802.5
- D. 802.11a

Answer: D

Explanation:

The correct answer is 802.11a.

Answer . 802.5 defines a token-passing ring access method.

Answer 802.11b defines a wireless LAN in the 2.4 GHz band with speeds up to 11 Mbps.

Answer 802.3 describes a bus topology using CSMA/CD at 10 Mbps.

QUESTION NO: 1616

Which choice below is an incorrect description of a control?

- A. Controls are the countermeasures for vulnerabilities.
- B. Corrective controls reduce the likelihood of a deliberate attack.
- C. Detective controls discover attacks and trigger preventative or corrective controls.
- D. Corrective controls reduce the effect of an attack.

Answer: B

Explanation:

Controls are the countermeasures for vulnerabilities. There are many kinds, but generally they are categorized into four types:

Deterrent controls reduce the likelihood of a deliberate attack.

Preventative controls protect vulnerabilities and make an attack unsuccessful or reduce its impact. Preventative controls inhibit attempts to violate security policy.

Corrective controls reduce the effect of an attack.

Detective controls discover attacks and trigger preventative or corrective controls. Detective controls warn of violations or attempted violations of security policy and include such controls as audit trails, intrusion detection methods, and checksums.

Source: Introduction to Risk Analysis, "Corrective controls reduce the effect of an attack" & "Detective controls discover attacks and trigger preventative or corrective controls" Security Risk Analysis

Group and NIST Special Publication 800-30, Risk Management Guide for Information Technology Systems.

QUESTION NO: 1617

Which statement below most accurately describes the difference between security awareness, security training, and security education?

- A. Security education is required for all system operators.
- B. Security training is more in depth than security education.
- C. Security training teaches the skills that will help employees to perform their jobs more securely.
- D. Security awareness is not necessary for high-level senior executives.

Answer: C

Explanation:

Awareness is used to reinforce the fact that security supports the mission of the organization by protecting valuable resources. The purpose of training is to teach people the skills that will enable them to perform their jobs more securely. Security education is more in depth than security training and is targeted for security professionals and those whose jobs require expertise in security. Management commitment is necessary because of the resources used in developing and implementing the program and also because the program affects their staff. Source: National Institute of Standards and Technology, An Introduction to Computer Security: The NIST Handbook Special Publication 800-12.

QUESTION NO: 1618

Which choice MOST accurately describes the difference between the role of a data owner versus the role of a data custodian?

- A.** The custodian implements the information classification scheme after the initial assignment by the owner.
- B.** The data owner implements the information classification scheme after the initial assignment by the custodian.
- C.** The custodian makes the initial information classification assignments, and the operations manager implements the scheme.
- D.** The custodian implements the information classification scheme after the initial assignment by the operations manager.

Answer: A

Explanation:

QUESTION NO: 1619

Intrusion detection systems can be all of the following types EXCEPT:

- A.** Signature-based.
- B.** Statistical anomaly-based.
- C.** Network-based.
- D.** Defined-based.

Answer: D

Explanation:

The correct answer is Defined-based. All the other answers are types of IDSs.

QUESTION NO: 1620

In which OSI layer does the MIDI digital music protocol standard reside?

- A.** Session Layer
- B.** Application Layer
- C.** Transport Layer
- D.** Presentation Layer

Answer: D

Explanation:

The correct answer is Presentation Layer. MIDI is a Presentation layer protocol.

QUESTION NO: 1621

Which choice below is NOT an example of the appropriate external distribution of classified information?

- A. Upon senior-level approval after a confidentiality agreement
- B. Compliance with a court order
- C. IAW contract procurement agreements for a government project
- D. To influence the value of the company's stock price

Answer: D

Explanation:

The correct answer is "To influence the value of the company's stock price". Answers "Compliance with a court order", "Upon senior-level approval after a confidentiality agreement", and "IAW contract procurement agreements for a government project" are all examples of the need for possible external distribution of internal classified information.

QUESTION NO: 1622

Which is NOT a layer in the TCP/IP architecture model?

- A. Internet
- B. Host-to-host
- C. Application
- D. Session

Answer: D

Explanation:

The correct answer is Session. The Session Layer is an OSI model layer.

QUESTION NO: 1623

Which choice below is NOT an example of an issue-specific policy?

- A. Virus-checking disk policy
- B. Defined router ACLs
- C. Unfriendly employee termination policy
- D. E-mail privacy policy

Answer: B

Explanation:

Answer c is an example of a system-specific policy, in this case the router's access control lists. The other three answers are examples of issue-specific policy, as defined by NIST. Issue-specific policies are similar to program policies, in that they are not technically focused. While program policy is traditionally more general and strategic (the organization's computer security program, for example), issue-specific policy is a nontechnical policy addressing a single or specific issue of concern to the organization, such as the procedural guidelines for checking disks brought to work or e-mail privacy concerns. System-specific policy is technically focused and addresses only one computer system or device type. Source: National Institute of Standards and Technology, An Introduction to Computer Security: The NIST Handbook Special Publication 800-12.

QUESTION NO: 1624

A software interface to the operating system that implements access control by limiting the system commands that are available to a user is called a(n):

- A. Physically constrained user interface
- B. Restricted shell
- C. Interrupt
- D. View

Answer: B

Explanation:

Answer Interrupt refers to a software or hardware interrupt to a processor that causes the program to jump to another program to handle the interrupt request. Before leaving the program that was being executed at the time of the interrupt, the CPU must save the state of the computer so that the original program can continue after the interrupt has been serviced.

*A physically constrained user interface is one in which a user's operations are limited by the physical characteristics of the interface device. An example would be a keypad with the choices limited to the operations permitted by each key.

*View refers to database views, which restrict access to information contained in a database through content-dependent access control.

QUESTION NO: 1625

Which IEEE protocol defines wireless transmission in the 5 GHz band with data rates up to 54 Mbps?

- A. IEEE 802.11b
- B. IEEE 802.11g
- C. IEEE 802.11a
- D. IEEE 802.15

Answer: C

Explanation:

IEEE 802.11a specifies high-speed wireless connectivity in the 5 GHz band using Orthogonal Frequency Division Multiplexing with data rates up to 54 Mbps.

IEEE 802.11b specifies highspeed wireless connectivity in the 2.4 GHz ISM band up to 11 Mbps.

IEEE 802.11g is a proposed standard that offers wireless transmission over relatively short distances at speeds from 20 Mbps up to 54 Mbps and operates in the 2.4 GHz range (and is therefore expected to be backward-compatible with existing 802.11b-based networks).

IEEE 802.15, defines Wireless Personal Area Networks (WPAN), such as Bluetooth, in the 2.4-2.5 GHz band. Source: IEEE Wireless Working Groups (grouper.ieee.org).

QUESTION NO: 1626

How is authentication implemented in GSM?

- A.** Using public key cryptography
- B.** It is not implemented in GSM
- C.** Using secret key cryptography
- D.** Out-of-band verification

Answer: C

Explanation:

Authentication is effected in GSM through the use of a common secret key, K_s , that is stored in the network operator's Authentication Center (AuC) and in the subscriber's SIM card. The SIM card may be in the subscriber's laptop, and the subscriber is not privy to K_s . To begin the authentication exchange, the home location of the subscriber's mobile station, (MS), generates a 128-bit random number (RAND) and sends it to the MS. Using an algorithm that is known to both the AuC and MS, the RAND is encrypted by both parties using the secret key, K_s . The ciphertext generated at the MS is then sent to the AuC and compared with the ciphertext generated by the Auc. If the two results match, the MS is authenticated and the access request is granted. If they do not match, the access request is denied. The other answers are, therefore, incorrect.

QUESTION NO: 1627

Biometrics is used for identification in the physical controls and for authentication in the:

- A. Detective controls.
- B. Corrective controls.
- C. Logical controls.
- D. Preventive controls.

Answer: C

Explanation:

The correct answer is "Logical controls". The other answers are different categories of controls where preventive controls attempt to eliminate or reduce vulnerabilities before an attack occurs; detective controls attempt to determine that an attack is taking place or has taken place; and corrective controls involve taking action to restore the system to normal operation after a successful attack.

QUESTION NO: 1628

Authentication in which a random value is presented to a user, who then returns a calculated number based on that random value is called:

- A. Man-in-the-middle
- B. Personal identification number (PIN) protocol
- C. One-time password
- D. Challenge-response

Answer: D

Explanation:

In challenge-response authentication, the user enters a random value (challenge) sent by the authentication server into a token device. The token device shares knowledge of a cryptographic secret key with the

authentication server and calculates a response based on the challenge value and the secret key. This response is entered into the authentication server, which uses the response to authenticate the identity of the user by performing the same calculation and comparing results.

Answer "man-in-the-middle" is a type of attack in which a cracker is interposed between the user and authentication server and attempts to gain access to packets for replay in order to impersonate a valid user.

A "one-time password" is a password that is used only once to gain access to a network or computer system. A typical implementation is through the use of a token that generates a number based on the time of day. The user reads this number and enters it into the authenticating device. The authenticating device calculates the same number based on the time of day and uses the same algorithm used by the token. If the token's number matches that of the authentication server, the identity of the user is validated. Obviously, the token and the authentication server must be time-synchronized for this approach to work. Also, there is allowance for small values of time skew between the authorization device and the token. Answer d refers to a PIN number that is something you know used with something you have, such as an ATM card.

QUESTION NO: 1629

What is a noncompulsory recommendation on how to achieve compliance with published standards called?

- A.** Policies
- B.** Guidelines
- C.** Procedures
- D.** Standards

Answer: B

Explanation:

QUESTION NO: 1630

Which statement below is NOT true about security awareness, training, and educational programs?

- A.** Security education assists management in determining who should be promoted.
- B.** Security improves the users' awareness of the need to protect information resources.
- C.** Awareness and training help users become more accountable for their actions.
- D.** Security education assists management in developing the in-house expertise to manage security programs.

Answer: A

Explanation:

The purpose of computer security awareness, training, and education is to enhance security by:

Improving awareness of the need to protect system resources

Developing skills and knowledge so computer users can perform their jobs more securely

Building in-depth knowledge, as needed, to design, implement, or operate security programs for organizations and systems

Making computer system users aware of their security responsibilities and teaching them correct practices helps users change their behavior. It also supports individual accountability because without the knowledge of the necessary security measures and to how to use them, users cannot be truly accountable for their actions. Source:

National Institute of Standards and Technology, An Introduction to Computer Security: The NIST Handbook Special Publication 800-12.

QUESTION NO: 1631

Which statement is NOT true about the SOCKS protocol?

- A.** It operates in the transport layer of the OSI model.

- B.** It uses an ESP for authentication and encryption.
- C.** It is sometimes referred to as an application-level proxy.
- D.** Network applications need to be SOCKS-ified to operate.

Answer: B

Explanation:

The correct answer is "It uses an ESP for authentication and encryption". The Encapsulating Security Payload, (ESP) is a component of IPSec. Socket Security (SOCKS) is a transport layer, secure networking proxy protocol. SOCKS replaces the standard network systems calls with its own calls. These calls open connections to a SOCKS proxy server for client authentication, transparently to the user. Common network utilities, like TELNET or FTP, need to be SOCKSified, or have their network calls altered to recognize SOCKS proxy calls. Source: Designing Network Security by Merike Kaeo (Cisco Press, 1999).

QUESTION NO: 1632

In the DoD reference model, which layer conforms to the OSI transport layer?

- A.** Process/Application Layer
- B.** Internet Layer
- C.** Host-to-Host Layer
- D.** Network Access Layer

Answer: C

Explanation:

In the DoD reference model, the Host-to-Host layer parallels the function of the OSI's transport layer. This layer contains the Transmission Control Protocol (TCP), and the User Datagram Protocol (UDP).

* the DoD Process/Application layer, corresponds to the OSI's top three layers, the Application, Presentation, and Session layers.

*The DoD Internet layer corresponds to the OSI's Network layer.

* the DoD Network Access Layer, is the equivalent of the Data Link and Physical layers of the OSI model. Source: MCSE:TCP/IP Study Guide by Todd Lammle, Monica Lammle, and John Chellis (Sybex, 1997) and Handbook of Information Security Management 1999 by Micki Krause and Harold f. Tipton (Auerbach, 1999).

QUESTION NO: 1633

Which of the following is NOT an assumption of the basic Kerberos paradigm?

- A. Specific servers and locations cannot be secured.
- B. Messages are not secure from interception.
- C. Cabling is not secure.
- D. Client computers are not secured and are easily accessible.

Answer: A

Explanation:

The correct answer is "Specific servers and locations cannot be secured". Kerberos requires that centralized servers implementing the trusted authentication mechanism must be secured.

QUESTION NO: 1634

Referential integrity requires that for any foreign key attribute, the referenced relation must have:

- A. An attribute with the same value for its secondary key.
- B. A tuple with the same value for its secondary key.
- C. A tuple with the same value for its primary key.
- D. An attribute with the same value for its other foreign key.

Answer: C

Explanation:

The correct answer is "A tuple with the same value for its primary key". Answers "A tuple with the same value for its secondary key." and "An attribute with the same value for its secondary key." are incorrect because a secondary key is not a valid term. Answer "An attribute with the same value for its other foreign key." is a distracter, because referential integrity has a foreign key referring to a primary key in another relation.

QUESTION NO: 1635

Which of the following is NOT a technical (logical) mechanism for protecting information from unauthorized disclosure?

- A. Encryption
- B. Labeling (of sensitive materials)
- C. Protocols
- D. Smart cards

Answer: B

Explanation:

The correct answer is "Labeling (of sensitive materials)". Labeling is an administrative control mechanism.

QUESTION NO: 1636

A distributed system using passwords as the authentication means can use a number of techniques to make the password system stronger.

Which of the following is NOT one of these techniques?

- A. Regular password reuse
- B. Password generators
- C. Limiting the number or frequency of log-on attempts
- D. Password file protection

Answer: A

Explanation:

Passwords should never be reused after the time limit on their use has expired.

Answer "password generators" supply passwords upon request. These passwords are usually comprised of numbers, characters, and sometimes symbols. Passwords provided by password generators are, usually, not easy to remember.

For answer "password file protection" may consist of encrypting the password with a one-way hash function and storing it in a password file. A typical brute force attack against this type of protection is to encrypt trial password guesses using the same hash function and to compare the encrypted results with the encrypted passwords stored in the password file.

Answer "Limiting the number or frequency of log-on attempts" provides protection in that, after a specified number of unsuccessful log-on attempts, a user may be locked out of trying to log on for a period of time. An alternative is to progressively increase the time between permitted log-on tries after each unsuccessful log-on attempt.

QUESTION NO: 1637

Which of the following is NOT a property of a Packet Filtering Firewall?

- A.** Uses ACLs
- B.** Operates at the Application Layer
- C.** Considered a first-generation firewall
- D.** Examines the source and destination addresses of the incoming packet

Answer: B

Explanation:

The correct answer is Operates at the Application Layer. A packet-filtering firewall can operate at the network or transport layers.

QUESTION NO: 1638

Which of the following is NOT a property of Token Ring networks?

- A. All end stations are attached to a MSAU.
- B. These networks were originally designed to serve sporadic and only occasionally heavy traffic.
- C. These networks were originally designed to serve large, bandwidthconsuming applications.
- D. Workstations cannot transmit until they receive a token.

Answer: B

Explanation:

The correct answer is "These networks were originally designed to serve sporadic and only occasionally heavy traffic". Ethernet networks were originally designed to work with more sporadic traffic than Token Ring networks.

QUESTION NO: 1639

Which is NOT a property of Fiber Optic cabling?

- A. Carries signals as light waves
- B. Transmits at higher speeds than copper cable
- C. Very resistant to interference
- D. Easier to tap than copper cabling

Answer: D

Explanation:

The correct answer is "Easier to tap than copper cabling". Fiber Optic cable is much harder to tap than copper cable.

QUESTION NO: 1640

What is an ARO?

- A.** A dollar figure assigned to a single event
- B.** The percentage of loss that a realized threat event would have on a specific asset
- C.** The annual expected financial loss to an organization from a threat
- D.** A number that represents the estimated frequency of an occurrence of an expected threat

Answer: D

Explanation:

The correct answer is "A number that represents the estimated frequency of an occurrence of an expected threat". Answer "A dollar figure assigned to a single event" is the definition of SLE, "The annual expected financial loss to an organization from a threat" is an ALE, and "The percentage of loss that a realized threat event would have on a specific asset" is an EF.

QUESTION NO: 1641

Which choice below represents an application or system demonstrating a need for a high level of confidentiality protection and controls?

- A.** The mission of this system is to produce local weather forecast information that is made available to the news media forecasters and the general public at all times. None of the information requires protection against disclosure.
- B.** Destruction of the information would require significant expenditures of time and effort to replace. Although corrupted information would present an inconvenience to the staff, most information, and all vital information, is backed up by either paper documentation or on disk.
- C.** The application contains proprietary business information and other financial information, which if disclosed to unauthorized sources, could cause an unfair advantage for vendors, contractors, or individuals and could result in financial loss or adverse legal action to user organizations.
- D.** Unavailability of the system could result in inability to meet payroll obligations and could cause work stoppage and failure of user organizations to meet critical mission requirements. The system requires 24-hour access.

Answer: C

Explanation:

Although elements of all of the systems described could require specific controls for confidentiality, given the descriptions above, system b fits the definition most closely of a system requiring a very high level of confidentiality. Answer a is an example of a system requiring high availability. Answer c is an example of a system that requires medium integrity controls. Answer d is a system that requires only a low level of confidentiality.

A system may need protection for one or more of the following reasons:

Confidentiality. The system contains information that requires protection from unauthorized disclosure.

Integrity. The system contains information that must be protected from unauthorized, unanticipated, or unintentional modification.

Availability. The system contains information or provides services which must be available on a timely basis to meet mission requirements or to avoid substantial losses.

Source: NIST Special Publication 800-18, Guide for Developing Security Plans for Information Technology Systems

QUESTION NO: 1642

Which answer below is true about the difference between FTP and TFTP?

- A.** FTP enables print job spooling, whereas TFTP does not.
- B.** FTP does not have a directory-browsing capability, whereas TFTP does.
- C.** FTP is less secure because session authentication does not occur.
- D.** TFTP is less secure because session authentication does not occur.

Answer: D

Explanation:

The correct answer is "TFTP is less secure because session authentication does not occur". The Trivial File Transfer Protocol (TFTP) is considered less secure than the File Transfer Protocol (FTP) because authentication does not occur during session establishment (although FTP is very insecure in its own right).

QUESTION NO: 1643

Which of the following is typically NOT a consideration in the design of passwords?

- A. Lifetime
- B. Electronic monitoring
- C. Authentication period
- D. Composition

Answer: B

Explanation:

Electronic monitoring is the eavesdropping on passwords that are being transmitted to the authenticating device. This issue is a technical one and is not a consideration in designing passwords. The other answers relate to very important password characteristics that must be taken into account when developing passwords. Password lifetime, in answer a, refers to the maximum period of time that a password is valid. Ideally, a password should be used only once. This approach can be implemented by token password generators and challenge response schemes. However, as a practical matter, passwords on most PC's and workstations are used repeatedly. The time period after which passwords should be changed is a function of the level of protection required for the information being accessed. In typical organizations, passwords may be changed every three to six months. Obviously, passwords should be changed when employees leave an organization or in a situation where a password may have been compromised.

Answer "the composition of a password" defines the characters that can be used in the password. The characters may be letters, numbers, or special symbols.

" The authentication period" defines the maximum acceptable period between the initial authentication of a user and any subsequent reauthorization process. For example, users may be asked to authenticate themselves again after a specified period of time of being logged on to a server containing critical information.

Topic 14, Exam SET B**QUESTION NO: 1644**

For fault-tolerance to operate, a system must be:

- A. Capable of a cold start.
- B. Capable of terminating operations in a safe mode.
- C. Capable of detecting and correcting the fault.
- D. Capable of only detecting the fault.

Answer: C

Explanation:

The correct answer is "Capable of detecting and correcting the fault". The two conditions required for a faulttolerant system.

Answer "Capable of only detecting the fault" is a distracter.

Answer "Capable of terminating operations in a safe mode" is the definition of fail safe and answer "Capable of a cold start" refers to starting after a system shutdown.

QUESTION NO: 1645

The classic Caesar cipher is a:

- A. Code group.
- B. Transposition cipher.
- C. Monoalphabetic cipher.
- D. Polyalphabetic cipher.

Answer: C

Explanation:

The correct answer is Monoalphabetic cipher. It uses one alphabet shifted three places.

Answers Polyalphabetic cipher and Transposition cipher are incorrect because in answer a, multiple alphabets

are used and in answer Transposition cipher, the letters of the message are transposed.

Answer Code group is incorrect because code groups deal with words and phrases and ciphers deal with bits or letters.

QUESTION NO: 1646

Apolyalphabetic cipher is also known as:

- A. One-time pad.
- B. Steganography.
- C. Vernam cipher.
- D. Vigen re cipher.

Answer: D

Explanation:

The correct answer is Vigen re cipher.

* Answer "One-time pad" is incorrect because a one-time pad uses a random key with length equal to the plaintext message and is used only once.

* Answer "Steganography" is the process of sending a message with no indication that a message even exists.

* Answer "Vernam cipher" is incorrect because it applies to stream ciphers that are XORed with a random key string.

QUESTION NO: 1647

Superscalar computer architecture is characterized by a:

- A. Computer using instructions that are simpler and require less clock cycles to execute.
- B. Computer using instructions that perform many operations per instruction.
- C. Processor that executes one instruction at a time.
- D. Processor that enables concurrent execution of multiple instructions in the same pipeline stage.

Answer: D

Explanation:

- * Answer "Computer using instructions that perform many operations per instruction" is the definition of a complex instruction set computer.
- * Answer "Computer using instructions that are simpler and require less clock cycles to execute" is the definition of a reduced instruction set computer.
- * Answer "Processor that executes one instruction at a time" is the definition of a scalar processor.

QUESTION NO: 1648

Which of the following is NOT a characteristic of the ElGamal public key cryptosystem?

- A.** It is based on the discrete logarithm problem.
- B.** It can be used to generate digital signatures.
- C.** It can perform encryption, but not digital signatures.
- D.** It can perform encryption.

Answer: C

Explanation:

The ElGamal public key cryptosystem can perform both encryption and digital signatures based on the discrete logarithm problem.

These three characteristics are shown in the examples that follow.

To generate a key pair in the ElGamal system:

- A. Choose a prime number, p .
- B. Choose two random numbers, g and x (g and x must both be less than p).
- C. Calculate $y = g^x \bmod p$.
- D. The private key is x and the public key is y , g , and p .

To encrypt a message, M , in the ElGamal system:

- A. Select a random number, j , such that j is relatively prime to $p-1$. Recall that two numbers are relatively prime if they have no common factors other than 1.
- B. Generate $w = g^j \bmod p$ and $z = y^j M \bmod p$.
- C. w and z comprise the ciphertext.

To decrypt the message, M , in the ElGamal system, calculate $M = z/w \bmod p$. This can be shown by substituting the values of z and w

in the equation as follows:

$$M = y^j M \bmod p / g^{jx} \bmod p$$

$$\text{Since } y^j = g^{xj} \bmod p$$

$$M = (g^{xj} M / g^{jx}) \bmod p$$

To sign a message, M, in the ElGamal system:

- A. Select a random number, j, such that j is relatively prime to p-1. The value of j must not be disclosed. Generate $w = g^j \bmod p$.
- B. Solve for z in the equation $M = (xw + jz) \bmod (p-1)$. The solution to this equation is beyond the scope of this coverage. Suffice to say that an algorithm exists to solve for the variable z.
- C. w and z comprise the signature.
- D. Verification of the signature is accomplished if $g^{M \bmod p} = y^w w^z \bmod p$.

QUESTION NO: 1649

Which is NOT true about Covert Channel Analysis?

- A. It is required for B2 class systems in order to protect against covert storage channels.
- B. It is an operational assurance requirement that is specified in the Orange Book.
- C. It is required for B3 class systems to protect against both covert storage and covert timing channels.
- D. It is required for B2 class systems to protect against covert timing channels.

Answer: D

Explanation:

The correct answer is "It is required for B2 class systems to protect against covert timing channels". Orange Book B2 class systems do not need to be protected from covert timing channels. Covert channel analysis must be performed for B2-level class systems to protect against covert storage channels only. B3 class systems need to be protected against both covert storage channels and covert timing channels.

QUESTION NO: 1650

In public key cryptography,

- A. The public key is used to encrypt and decrypt.
- B. Only the private key can encrypt and only the public key can decrypt.
- C. If the public key encrypts, then only the private key can decrypt.
- D. Only the public key can encrypt and only the private key can decrypt.

Answer: C

Explanation:

The correct answer is "If the public key encrypts, then only the private key can decrypt".

Answers "Only the private key can encrypt and only the public key can decrypt" and "Only the public key can encrypt and only the private key can decrypt" are incorrect because if one key encrypts, the other can decrypt.

Answer "The public key is used to encrypt and decrypt" is incorrect because if the public key encrypts, it cannot decrypt.

QUESTION NO: 1651

When two different keys encrypt a plaintext message into the same ciphertext, this situation is known as:

- A. Cryptanalysis.
- B. Public key cryptography.
- C. Hashing.
- D. Key clustering.

Answer: D

Explanation:

The correct answer is "Key clustering"

Answer "Public key cryptography" describes a type of cryptographic system using a public and a private key; answer Cryptanalysis is the art/science

of breaking ciphers; answer Hashing is the conversion of a message of variable length into a fixed-length message digest.

QUESTION NO: 1652

Which attack type below does NOT exploit TCP vulnerabilities?

- A. Sequence Number attack
- B. Ping of Death
- C. SYN attack
- D. land.c attack

Answer: B

Explanation:

The Ping of Death exploits the fragmentation vulnerability of large ICMP ECHO request packets by sending an illegal packet with more than 65K of data, creating a buffer overflow.

* a TCP sequence number attack, which exploits the nonrandom predictable pattern of TCP connection sequence numbers to spoof a session.

* a TCP SYN attack, is a DoS attack that exploits the TCP three-way handshake. The attacker rapidly generates randomly sourced SYN packets filling the target's connection queue before the connection can timeout.

* land.c attack, is also a DoS attack that exploits TCP SYN packets. The attacker sends a packet that gives both the source and destination as the target's address, and uses the same source and destination port. Sources: Designing Network Security by Merike Kaeo (Cisco Press, 1999) and Mastering Network Security by Chris Brenton (Sybex, 1999).

QUESTION NO: 1653

The Biba model addresses:

- A. Unauthorized modification of data.
- B. Transformation procedures.
- C. Constrained data items.
- D. Data disclosure.

Answer: A

Explanation:

The correct answer is "Unauthorized modification of data". The Biba model is an integrity model. Answer "Data disclosure" is associated with confidentiality. Answers "Transformation procedures" and "Constrained data items" are specific to the Clark-Wilson model.

QUESTION NO: 1654

Ablock cipher:

- A. Converts a variable-length of plaintext into a fixed length ciphertext.
- B. Is an asymmetric key algorithm.
- C. Encrypts by operating on a continuous data stream.
- D. Breaks a message into fixed length units for encryption.

Answer: D

Explanation:

The correct answer is "Breaks a message into fixed length units for encryption". Answer "Encrypts by operating on a continuous data stream" describes a stream cipher. Answer "Is an asymmetric key algorithm" is incorrect because a block cipher applies to symmetric key algorithms; and answer "Converts a variable-length of plaintext into a fixed length ciphertext" describes a hashing operation.

QUESTION NO: 1655

What do the message digest algorithms MD2, MD4 and MD5 have in common?

- A. They are all used in the Secure Hash Algorithm (SHA).
- B. They all take a message of arbitrary length and produce a message digest of 128-bits.
- C. They all take a message of arbitrary length and produce a message digest of 160-bits.
- D. They are all optimized for 32-bit machines.

Answer: B

Explanation:

* Answer "They all take a message of arbitrary length and produce a message digest of 160-bits" is obviously, then, incorrect.

* Answer "They are all optimized for 32-bit machines" is incorrect since MD2 (B.S. Kaliski, The MD2 Message Digest Algorithm, RFC 1319, April 1992) is targeted for 8-bit machines. It is used in Privacy Enhanced Mail (PEM). MD4 (R.L. Rivest, The MD4 Message Digest Algorithm, RFC 1186, Oct 1990) and MD5 (R.L. Rivest, The MD5 Message Digest Algorithm, RFC 1321, April 1992) are designed for 32-bit machines. MD5 is considered more secure than MD4, and MD5 is also used in PEM. Answer d is incorrect since the SHA is a separate algorithm from MD2, MD4, and MD5, but is modeled after MD4. SHA produces a 160-bit message digest.

QUESTION NO: 1656

The addressing mode in which an instruction accesses a memory location whose contents are the address of the desired data is called:

- A. Implied addressing.
- B. Direct addressing.
- C. Indirect addressing.
- D. Indexed addressing.

Answer: C

Explanation:

QUESTION NO: 1657

Which of the following would NOT be an example of compensating controls being implemented?

- A.** Modifying the timing of a system resource in some measurable way to covertly transmit information
- B.** Sensitive information requiring two authorized signatures to release
- C.** A safety deposit box needing two keys to open
- D.** Signing in or out of a traffic log and using a magnetic card to access to an operations center

Answer: A

Explanation:

The correct answer is "Modifying the timing of a system resource in some measurable way to covertly transmit information". This is the definition for a covert timing channel. The other three are examples of compensating controls, which are a combination of technical, administrative, or physical controls to enhance security.

QUESTION NO: 1658

Which of the following is an example of a symmetric key algorithm?

- A.** Rijndael
- B.** Knapsack
- C.** RSA
- D.** Diffie-Hellman

Answer: A

Explanation:

The correct answer is Rijndael. The other answers are examples of asymmetric key systems.

QUESTION NO: 1659

Elliptic curves, which are applied to public key cryptography, employ modular exponentiation that characterizes the:

- A. Knapsack problem.
- B. Elliptic curve modular addition.
- C. Elliptic curve discrete logarithm problem.
- D. Prime factors of very large numbers.

Answer: C

Explanation:

The correct answer is "Elliptic curve discrete logarithm problem". Modular exponentiation in elliptic curves is the analog of the modular discrete logarithm problem.

* Answer "Prime factors of very large numbers" is incorrect because prime factors are involved with RSA public key systems; answer c is incorrect because modular addition in elliptic curves is the analog of modular multiplication; and answer "Knapsack problem" is incorrect because the knapsack problem is not an elliptic curve problem.

QUESTION NO: 1660

Which of the following items BEST describes the standards addressed by Title II, Administrative Simplification, of the Health Insurance Portability and Accountability Act (US Kennedy-Kassebaum Health Insurance and Portability Accountability Act -HIPAA-Public Law 104-19)?

- A. Transaction Standards, to include Code Sets; Security and Electronic Signatures and Privacy
- B. Security and Electronic Signatures and Privacy
- C. Transaction Standards, to include Code Sets; Unique Health Identifiers; Security and Electronic Signatures and Privacy
- D. Unique Health Identifiers; Security and Electronic Signatures and Privacy

Answer: C

Explanation:

HIPAA was designed to provide for greater access to personal health care information, enable portability of health care insurance, establish strong penalties for health care fraud, and streamline the health care claims process through administrative simplification. To accomplish the latter, Title II of the HIPAA law, Administrative Simplification, requires standardizing the formats for the electronic transmission of health care information. The transactions and code sets portion includes standards for submitting claims, enrollment information, premium payments, and others as adopted by HHS. The standard for transactions is the ANSI ASC X12N version 4010 EDI Standard. Standard code sets are required for diagnoses and inpatient services, professional services, dental services (replaces D' codes), and drugs (instead of J' codes). Also, local codes are not to be used. Unique health identifiers are required to identify health care providers, health plans, employers, and individuals. Security and electronic signatures are specified to protect health care information. Privacy protections are required to ensure that there is no unauthorized disclosure of individually identifiable health care information. The other answers are incorrect since they do not include all four major standards. Additional information can be found at <http://aspe.hhs.gov/adminsimp>.

QUESTION NO: 1661

Which protocol is used to resolve a known IP address to an unknown MAC address?

- A. ICMP
- B. RARP
- C. ARP
- D. TFTP

Answer: C

Explanation:

The Address Resolution Protocol (ARP) sends a broadcast asking

for the host with a specified IP address to reply with its MAC, or hardware address. This information is kept in the ARP Cache.

* the Reverse Address Resolution Protocol (RARP) is commonly used on diskless machines, when the MAC is known, but not the IP address. It asks a RARP server to provide a valid IP address, which is somewhat the reverse of ARP.

* the Internet Control Message Protocol (ICMP) is a management protocol for IP.

* the Trivial File Transfer Protocol (TFTP), is a stripped-down version of the File Transfer Protocol (FTP).

Source:

CCNA Study Guide by Todd Lammle, Donald Porter, and James Chellis (Sybex, 1999).

QUESTION NO: 1662

Which of the following BEST describes a block cipher?

- A.** An asymmetric key algorithm that operates on a variable-length block of plaintext and transforms it into a fixed-length block of ciphertext
- B.** A symmetric key algorithm that operates on a fixed-length block of plaintext and transforms it into a fixed-length block of ciphertext
- C.** An asymmetric key algorithm that operates on a fixed-length block of plaintext and transforms it into a fixed-length block of ciphertext
- D.** A symmetric key algorithm that operates on a variable-length block of plaintext and transforms it into a fixed-length block of ciphertext

Answer: B

Explanation:

A block cipher breaks the plaintext into fixed-length blocks, commonly 64-bits, and encrypts the blocks into fixed-length blocks of ciphertext. Another characteristic of the block cipher is that, if the same key is used, a particular plaintext block will be transformed into the same ciphertext block. Examples of block ciphers are DES, Skipjack, IDEA, RC5 and AES. An example of a block cipher in a symmetric key cryptosystem is the Electronic Code Book (ECB) mode of

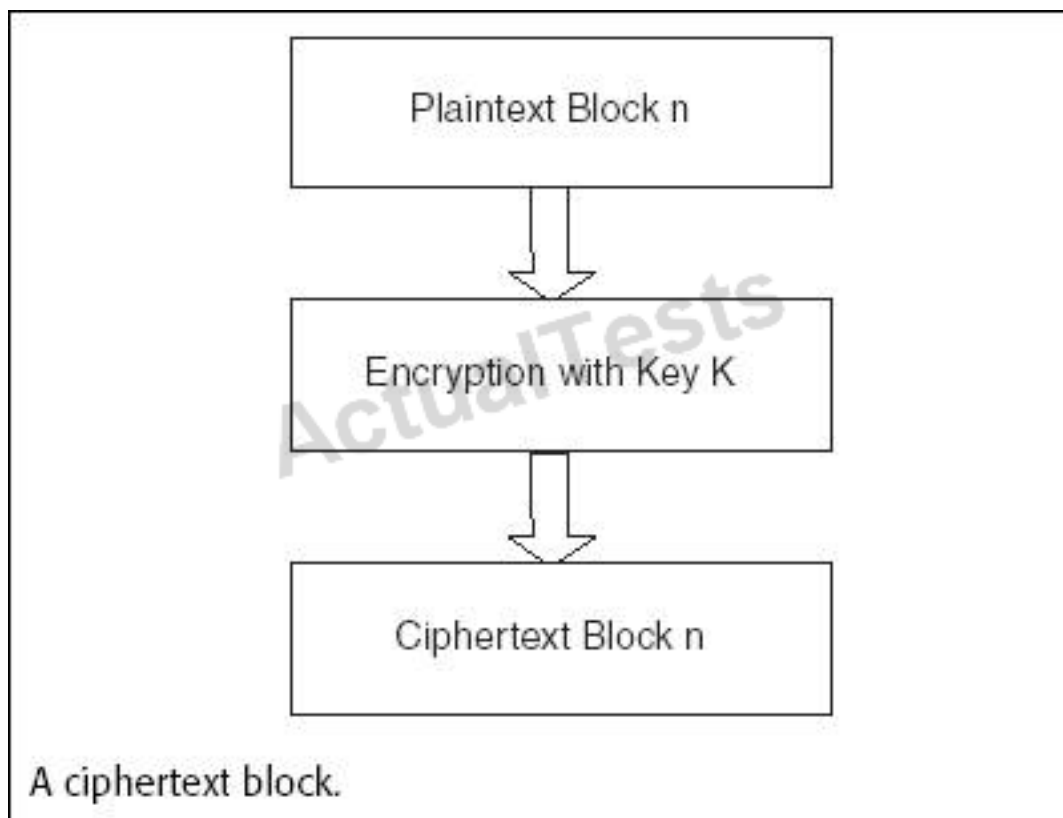
operation. In the ECB mode, a plaintext block is transformed into a ciphertext block as shown in Figure. If the same key is used for each transformation, then a Code Book can be compiled for each plaintext block and corresponding ciphertext block.

Answer a is incorrect since it refers to a variable-length block of plaintext being transformed into a fixed-length block of ciphertext.

Recall that this operation has some similarity to a hash function, which takes a message of arbitrary length and converts it into a fixedlength message digest.

* Answers "An asymmetric key algorithm that operates on a variable-length block of plaintext and transforms it into a fixed-length block of ciphertext" and "An asymmetric key algorithm that operates on a fixed-length block of plaintext and transforms it into a fixed-length block of ciphertext"are incorrect because they involve asymmetric key algorithms, and the block cipher is used with symmetric key algorithms.

Exhibit:



In other cryptographic modes of operation, such as Cipher Block Chaining (CBC), the result of the encryption of the plaintext block, P_n , is fed into the encryption process of plaintext block P_{n+1} . Thus, the result of the encryption of one block affects the result of the encryption

of the next block in the sequence.

QUESTION NO: 1663

In the discretionary portion of the Bell-LaPadula mode that is based on the access matrix, how the access rights are defined and evaluated is called:

- A. Validation.
- B. Identification.
- C. Authorization.
- D. Authentication.

Answer: C

Explanation:

The correct answer is Authorization, since authorization is concerned with how access rights are defined and how they are evaluated.

QUESTION NO: 1664

Which of the following processes establish the minimum national standards for certifying and accrediting national security systems?

- A. DITSCAP
- B. NIACAP
- C. CIAP
- D. Defense audit

Answer: B

Explanation:

The NIACAP provides a standard set of activities, general tasks, and

a management structure to certify and accredit systems that will maintain the information assurance and security posture of a system or site.

The NIACAP is designed to certify that the information system meets documented accreditation requirements and will continue to maintain the accredited security posture throughout the system life cycle.

* Answer CIAP is being developed for the evaluation of critical commercial systems and uses the NIACAP methodology.

* DITSCAP establishes for the defense entities a standard process, set of activities, general task descriptions, and a management structure to certify and accredit IT systems that will maintain the required security posture. The process is designed to certify that the IT system meets the accreditation requirements and that the system will maintain the accredited security posture throughout the system life cycle. The four phases to the DITSCAP are Definition, Verification, Validation, and Post Accreditation.

* Answer "Defense audit" is a distracter.

QUESTION NO: 1665

The primary goal of the TLS Protocol is to provide:

- A.** Privacy and data integrity between two communicating applications
- B.** Authentication and data integrity between two communicating applications
- C.** Privacy and authentication between two communicating applications
- D.** Privacy, authentication and data integrity between two communicating applications

Answer: A

Explanation:

The TLS Protocol is comprised of the TLS Record and Handshake Protocols. The TLS Record Protocol is layered on top of a transport protocol such as TCP and provides privacy and reliability to the communications. The privacy is implemented by encryption using symmetric key cryptography such as DES or RC4. The secret key is generated anew for each connection; however, the Record Protocol

can be used without encryption. Integrity is provided through the use of a keyed Message Authentication Code (MAC) using hash algorithms such as SHA or MD5.

The TLS Record Protocol is also used to encapsulate a higher-level protocol such as the TLS Handshake Protocol. This Handshake Protocol is used by the server and client to authenticate each other. The authentication can be accomplished using asymmetric key cryptography such as RSA or DSS. The Handshake Protocol also sets up the encryption algorithm and cryptographic keys to enable the application protocol to transmit and receive information.

QUESTION NO: 1666

The Rijndael cipher employs a round transformation that is itself comprised of three layers of transformations. Which of the following is NOT one of these layers?

- A. Non-linear mixing layer
- B. Non-linear layer
- C. Key addition layer
- D. Linear mixing layer

Answer: A

Explanation:

The correct answer is Non-linear mixing layer, a distracter.

QUESTION NO: 1667

Context-dependent control uses which of the following to make decisions?

- A. Subject or object attributes or environmental characteristics

- B. Data
- C. Formal models
- D. Operating system characteristics

Answer: A

Explanation:

The correct answer is Subject or object attributes or environmental characteristics. Answer Data refers to content-dependent characteristics, and answers Formal models and "Operating system characteristics" are distracters.

QUESTION NO: 1668

The Number Field Sieve (NFS) is a:

- A. General purpose factoring algorithm that can be used to factor large numbers
- B. General purpose algorithm used for brute force attacks on secret key cryptosystems
- C. General purpose hash algorithm
- D. General purpose algorithm to calculate discrete logarithms

Answer: A

Explanation:

The NFS has been successful in efficiently factoring numbers larger than 115 digits and a version of NFS has successfully factored a 155-digit number. Clearly, factoring is an attack that can be used against the RSA cryptosystem in which the public and private keys are calculated based on the product of two large prime numbers. The other answers are distracters.

QUESTION NO: 1669

The following compilation represents what facet of cryptanalysis?

A 8.2

B 1.5

C 2.8

D 4.3

E 12.7

F 2.2

G 2.0

H 6.1

I 7.0

J 0.2

K 0.8

L 4.0

M 2.4

N 6.7

O 7.5

P 1.9

Q 0.1

R 6.0

S 6.3

T 9.1

U 2.8

V 1.0

W 2.4

X 0.2

Y 2.0

Z 0.1

- A. Frequency analysis
- B. Cilly analysis
- C. Cartouche analysis
- D. Period analysis

Answer: A

Explanation:

The compilation is from a study by h. Becker and f. Piper that was originally published in Cipher Systems: The Protection of Communication.

The listing shows the relative frequency in percent of the appearance of the letters of the English alphabet in large numbers of passages taken from newspapers and novels. Thus, in a substitution cipher, an analysis of the frequency of appearance of certain letters may give clues to the actual letter before transformation. Note that the letters E, A, and T have relatively high percentages of appearance in English text.

*Answer "Period analysis" refers to a cryptanalysis that is looking for sequences that repeat themselves and for the spacing between repetitions. This approach is used to break the Vigenère cipher.

* Answer "Cilly analysis" is a reference to a cilly, which was a three-character message key used in the German Enigma machine.

* In answer "Cartouche analysis", a cartouche is a set of hieroglyphs surrounded by a loop. A cartouche referring to King Ptolemy was found on the Rosetta Stone.

QUESTION NO: 1670

In Part 3 of the Common Criteria, Security Assurance Requirements, seven predefined Packages of assurance components that make up the CC scale for rating confidence in the security of IT products and systems are called:

- A. Protection Assurance Levels (PALs).
- B. Security Target Assurance Levels (STALs).
- C. Assurance Levels (ALs).
- D. Evaluation Assurance Levels (EALs).

Answer: D

Explanation:

The correct answer is "Evaluation Assurance Levels (EALs)". The other answers are distracters.

QUESTION NO: 1671

The principles of Notice, Choice, Access, Security, and Enforcement refer to which of the following?

- A. Nonrepudiaton
- B. Privacy
- C. Authorization
- D. Authentication

Answer: B

Explanation:

These items are privacy principles. Notice refers to the collection, use, and disclosure of personally identifiable information (PII). Choice is the choice to opt out or opt in regarding the disclosure of PII to third parties; Access is access by consumers to their PII to permit review and correction of information. Security is the obligation to protect PII from unauthorized disclosure. Enforcement is the enforcement of applicable privacy policies and obligations. The other answers are distracters.

QUESTION NO: 1672

Which statement below is correct regarding VLANs?

- A. A closed VLAN configuration is the least secure VLAN configuration.
- B. A VLAN is less secure when implemented in conjunction with private port switching.
- C. A VLAN is a network segmented physically, not logically.

D. A VLAN restricts flooding to only those ports included in the VLAN.

Answer: D

Explanation:

A virtual local area network (VLAN) allows ports on the same or different switches to be grouped so that traffic is confined to members of that group only, and restricts broadcast, unicast, and multicast traffic.

Answer "A VLAN is a network segmented physically, not logically" is incorrect, because a VLAN is segmented logically, rather than physically.

Answer "A VLAN is less secure when implemented in conjunction with private port switching" is incorrect.

When a VLAN is implemented with private port, or single-user, switching, it provides fairly stringent security because broadcast vulnerabilities are minimized.

Answer "A closed VLAN configuration is the least secure VLAN configuration" is incorrect, as a closed VLAN authenticates a user to an access control list on a central authentication server, where they are assigned authorization parameters to determine their level of network access. Sources:

Catalyst 5000 Series Installation Guide (Cisco Systems) and Virtual LANs by Mariana Smith (McGraw-Hill, 1998).

QUESTION NO: 1673

The protocol of the Wireless Application Protocol (WAP), which performs functions similar to SSL in the TCP/IP protocol, is called the:

- A.** Wireless Transport Layer Security Protocol (WTLS).
- B.** Wireless Transaction Protocol (WTP).
- C.** Wireless Session Protocol (WSP).
- D.** Wireless Application Environment (WAE).

Answer: A

Explanation:

The correct answer is "Wireless Transport Layer Security Protocol (WTLS)". SSL performs security functions in TCP/IP.

The other answers refer to protocols in the WAP protocol stack also, but their primary functions are not security.

QUESTION NO: 1674

The property that states, Reading or writing is permitted at a particular level of sensitivity, but not to either higher or lower levels of sensitivity is called the:

- A. Strong * (star) Property.
- B. Simple * (star) Property.
- C. * (star) Security Property.
- D. Discretionary Security Property.

Answer: A

Explanation:

The correct answer is "Strong * (star) Property".

* Answer "the Discretionary Security Property" specifies discretionary access control in the Bell-LaPadula model by the use of an access matrix.

* Answer "Simple * (star) Property" is distracter.

* Answer "* (star) Security Property", in the Bell-LaPadula model, states, The writing of information by a subject at a higher level of sensitivity to an object at a lower level of sensitivity is not permitted (no write down).

QUESTION NO: 1675

In a refinement of the Bell-LaPadula model, the strong tranquility property states that:

- A. Objects never change their security level.
- B. Objects can change their security level in an unconstrained fashion.

- C. Objects never change their security level in a way that would violate the system security policy.
- D. Subjects can read up.

Answer: A

Explanation:

Answer "Objects never change their security level in a way that would violate the system security policy" is known as the weak tranquility property. The two other answers are distracters.

QUESTION NO: 1676

The secure path between a user and the Trusted Computing Base (TCB) is called:

- A. Trusted facility management
- B. Trusted distribution
- C. Trusted path
- D. The security perimeter

Answer: C

Explanation:

Answer trusted distribution ensures that valid and secure versions of software have been received correctly. Trusted facility management, answer "Trusted facility management", is concerned with the proper operation of trusted facilities as well as system administration and configuration.

Answer "The security perimeter", the security perimeter, is the boundary that separates the TCB from the remainder of the system. Recall that the TCB is the totality of protection mechanisms within a computer system that are trusted to enforce a security policy.

QUESTION NO: 1677

Which standard below does NOT specify fiber optic cabling as its physical media?

- A. 1000BaseSX
- B. 100BaseFX
- C. 1000BaseCX
- D. 1000BaseLX

Answer: C

Explanation:

1000BaseCX refers to 1000Mbps baseband copper cable, using two pairs of 150 ohm balanced cable for CSMA/CD LANs.

* 100BaseFX, specifies a 100 Mbps baseband fiber optic CSMA/CD LAN. Answer c, 1000BaseLX, specifies a 1000Mbps CSMA/CD LAN over long wavelength fiber optics.

* 1000BaseSX, specifies a 1000Mbps CSMA/CD LAN over short wavelength fiber optics.

QUESTION NO: 1678

A portion of a Vigenère cipher square is given below using five (1, 2, 14, 16, 22) of the possible 26 alphabets. Using the key word bow, which of the following is the encryption of the word advance using the Vigenère cipher?

Exhibit:

Vigenère Cipher																										
PLAINTEXT	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
1	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a
2	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z	a	b
14	o	p	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n
16	q	r	s	t	u	v	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p
22	w	x	y	z	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v

- A. b r r b b y f
- B. b r r b b y h
- C. b r r b c y f
- D. b r r b j y f

Answer: A

Explanation:

The Vigenère cipher is a polyalphabetic substitution cipher. The key word bow indicates which alphabets to use. The letter b indicates the alphabet of row 1, the letter o indicates the alphabet of row 14, and the letter w indicates the alphabet of row 22. To encrypt, arrange the key word, repetitively over the plaintext as shown in Table.

Exhibit:

Encryption of Key Word <i>bow</i>							
Key word	b	o	w	b	o	w	b
Plaintext	a	d	v	a	n	c	e
Ciphertext	b	r	r	b	b	y	f

Thus, the letter a of the plaintext is transformed into b of alphabet in row 1, the letter d is transformed into r of row 14, the letter v is transformed into r of row 22 and so on.

QUESTION NO: 1679

A secret mechanism that enables the implementation of the reverse function in a one-way function is called a:

- A. View.
- B. Open door.
- C. Trap door.
- D. Data diode.

Answer: C

Explanation:

The correct answer is Trap door. Answer view refers to a mechanism in a database system that restricts access to certain information within the database. The view implements the principle of least privilege.

Answer Open door is a distracter, and answer Data diode refers to a mechanism usually in multilevel security systems that limits the flow of classified information to one direction.

QUESTION NO: 1680

The Clark-Wilson Integrity Model (d. Clark, d. Wilson, A Comparison of Commercial and Military Computer Security Policies, Proceedings of the 1987 IEEE Computer Society Symposium on Research in Security and Privacy, Los Alamitos, CA, IEEE Computer Society Press, 1987) focuses on what two concepts?

- A. Capability lists and domains
- B. Least privilege and well-formed transactions
- C. Separation of duty and well-formed transactions
- D. Well-formed transactions and denial of service

Answer: C

Explanation:

The Clark-Wilson Model is a model focused on the needs of the commercial world and is based on the theory that integrity is more important than confidentiality for commercial organizations. Further, the model incorporates the commercial concepts of separation of duty and wellformed transactions. The well-formed transaction of the model is implemented by the transformation procedure (TP.) ATP is defined in the model as the mechanism for transforming the set of constrained data items (CDIs) from one valid state of integrity to another valid state of integrity. The Clark-Wilson Model defines rules for separation of duty that denote the relations between a user, TPs, and the CDIs that can be operated upon by those TPs. The model talks about the access triple that is the user, the program that is permitted to operate on the data, and the data. The other answers are distracters.

QUESTION NO: 1681

An associative memory operates in which one of the following ways?

- A. Searches for a specific data value in memory
- B. Uses indirect addressing only
- C. Returns values stored in a memory address location specified in the CPU address register
- D. Searches for values in memory exceeding a specified value

Answer: A

Explanation:

Answer a refers to an addressing mode used in computers where the address location that is specified in the program instruction contains the address of the final desired location.

* Answer "Searches for values in memory exceeding a specified value" is a distracter and answer "Returns values stored in a memory address location specified in the CPU address register" is the description of the direct or absolute addressing mode.

QUESTION NO: 1682

The British Standard 7799/ISO Standard 17799 discusses cryptographic policies. It states, An organization should develop a policy on its use of cryptographic controls for protection of its information When developing a policy, the following should be considered: (Which of the following items would most likely NOT be listed?)

- A. The approach to key management, including methods to deal with the recovery of encrypted information in the case of lost, compromised or damaged keys
- B. Roles and responsibilities
- C. The management approach toward the use of cryptographic controls across the organization
- D. The encryption schemes to be used

Answer: D

Explanation:

A policy is a general statement of management's intent, and therefore, a policy would not specify the encryption scheme to be

used. The other answers are appropriate for a cryptographic policy.

The general standards document is BSI ISO/IEC 17799:2000, BS 7799-1: 2000, Information technology-Code of practice for information security management, British Standards Institution, London, UK. The standard is intended to provide a comprehensive set of controls comprising best practices in information security. ISO refers to the International Organization for Standardization and IEC is the International Electrotechnical Commission. These two entities form the system for worldwide standardization.

The main chapter headings of the standard are:

Security Policy

Organizational Security

Asset Classification and Control

Personnel Security

Physical and Environmental Security

Communications and Operations Management

Access Control

Systems Development and Maintenance

Business Continuity Management

Compliance

QUESTION NO: 1683

The Common Criteria terminology for the degree of examination of the product to be tested is:

- A.** Functionality (F)
- B.** Target of Evaluation (TOE)
- C.** Evaluation Assurance Level (EAL)
- D.** Protection Profile (PP)

Answer: C

Explanation:

The Evaluation Assurance Levels range from EA1 (functional testing) to EA7 (detailed testing and formal design verification). The Target of Evaluation (TOE), answer a, refers to the product to be tested. Answer b, Protection Profile (PP), is an implementation independent

specification of the security requirements and protections of a product that could be built. A Security Target (ST) is a listing of the security claims for a particular IT security product. Also, the Common Criteria describes an intermediate grouping of security requirement components as a package. Functionality, answer c, refers to Part 2 of the Common Criteria that contains standard and well-understood functional security requirements for IT systems.

QUESTION NO: 1684

A form of digital signature where the signer is not privy to the content of the message is called a:

- A. Encrypted signature
- B. Zero knowledge proof
- C. Masked signature
- D. Blind signature

Answer: D

Explanation:

A blind signature algorithm for the message M uses a blinding factor, f ; a modulus m ; the private key, s , of the signer and the public key, q , of the signer. The sender, who generates f and knows q , presents the message to the signer in the form:

$Mf \cdot q \pmod{m}$

Thus, the message is not in a form readable by the signer since the signer does not know f . The signer signs $Mf \cdot q \pmod{m}$ with his/her private key, returning

$(Mf \cdot q)^s \pmod{m}$

This factor can be reduced to $fM \pmod{m}$ since s and q are inverses of each other. The sender then divides $fM \pmod{m}$ by the blinding factor, f , to obtain

$M \pmod{m}$

$M \pmod{m}$ is, therefore, the message, M , signed with the private key, s , of the signer.

Answer Zero knowledge proof refers to a zero knowledge proof. In general, a zero

knowledge proof involves a person, A, trying to prove that he/she knows something, S, to another person, B, without revealing S or anything about S. Answers Masked signature and Encrypted signature are distracters.

QUESTION NO: 1685

The Platform for Privacy Preferences (P3P) was developed by the World Wide Web Consortium (W3C) for what purpose?

- A.** To monitor users
- B.** To implement public key cryptography for transactions
- C.** To evaluate a client's privacy practices
- D.** To implement privacy practices on Web sites

Answer: D

Explanation:

As of this writing, the latest W3C working draft of P3P is P3P 1.0, 28 January, 2002 (www.w3.org/TR). An excerpt of the W3C P3P Specification states P3P enables Web sites to express their privacy practices in a standard format that can be retrieved automatically and interpreted easily by user agents. P3P user agents will allow users to be informed of site practices (in both machine- and human-readable formats) and to automate decision-making based on these practices when appropriate. Thus users need not read the privacy policies at every site they visit.

With P3, an organization can post its privacy policy in machinereadable form (XML) on its Web site. This policy statement includes:

Who has access to collected information

The type of information collected

How the information is used

The legal entity making the privacy statement

P3P also supports user agents that allow a user to configure a P3P-enabled Web browser with the user's privacy preferences. Then, when the user attempts to access a Web site, the user agent compares the user's stated preferences with the privacy policy in machine-readable form at the Web site. Access will be granted if the preferences match the policy. Otherwise, either access to the Web site

will be blocked or a pop-up window will appear notifying the user that he/she must change their privacy preferences. Usually, this means that the user has to lower his/her privacy threshold. The other answers are distracters.

QUESTION NO: 1686

Configuration management control best refers to:

- A. The use of privileged-entity controls for system administrator functions.
- B. Implementing resource protection schemes for hardware control.
- C. The concept of least control in operations.
- D. Ensuring that changes to the system do not unintentionally diminish security.

Answer: D

Explanation:

The correct answer is "Ensuring that changes to the system do not unintentionally diminish security". Configuration Management Control (and Change Control) are processes to ensure that any changes to the system are managed properly and do not inordinately affect either the availability or security of the system.

QUESTION NO: 1687

The following elements comprise a portion of what services?

Digital certification

Certification authority

Timestamping

Lightweight Directory Access Protocol (LDAP)

Non-repudiation support

- A. Public Key Infrastructure (PKI)

- B. Wireless Application Protocol (WAP)
- C. IPSec
- D. Transaction Layer Security (TLS)

Answer: A

Explanation:

The correct answer is PKI, which describes the integration of digital certificates, digital signatures, and other services necessary to support e-commerce. The other answers are distracters.

QUESTION NO: 1688

Theoretically, quantum computing offers the possibility of factoring the products of large prime numbers and calculating discrete logarithms in polynomial time. These calculations can be accomplished in such a compressed time frame because:

- A.** A quantum computer takes advantage of quantum tunneling in molecular scale transistors. This mode permits ultra high-speed switching to take place, thus, exponentially increasing the speed of computations.
- B.** Information can be transformed into quantum light waves that travel through fiber optic channels. Computations can be performed on the associated data by passing the light waves through various types of optical filters and solid-state materials with varying indices of refraction, thus drastically increasing the throughput over conventional computations.
- C.** A quantum computer exploits the time-space relationship that changes as particles approach the speed of light. At that interface, the resistance of conducting materials effectively is zero and exponential speed computations are possible.
- D.** A quantum bit in a quantum computer is actually a linear superposition of both the one and zero states and, therefore, can theoretically represent both values in parallel. This phenomenon allows computation that usually takes exponential time to be accomplished in polynomial time since different values of the binary pattern of the solution can be calculated simultaneously.

Answer: D

Explanation:

In digital computers, a bit is in either a one or zero state. In a quantum computer, through linear superposition, a quantum bit can be in both states, essentially simultaneously. Thus, computations consisting of trail evaluations of binary patterns can take place simultaneously in exponential time. The probability of obtaining a correct result is increased through a phenomenon called constructive interference of light while the probability of obtaining an incorrect result is decreased through destructive interference. Answer a describes optical computing that is effective in applying Fourier and other transformations to data to perform high-speed computations. Light representing large volumes of data passing through properly shaped physical objects can be subjected to mathematical transformations and recombined to provide the appropriate results. However, this mode of computation is not defined as quantum computing. Answers c and d are diversionary answers that do not describe quantum computing.

QUESTION NO: 1689

What is the result of the Exclusive Or operation, 1XOR 0?

- A. 1
- B. Indeterminate
- C. 10
- D. 0

Answer: A

Explanation:

The correct answer is a. An XOR operation results in a 0 if the two input bits are identical and a 1 if one of the bits is a 1 and the other is a 0.

QUESTION NO: 1690

What information security model formalizes the US Department of Defense multi-level security policy?

- A. Stark-Wilson
- B. Clark-Wilson
- C. Bell-LaPadula
- D. Biba

Answer: C

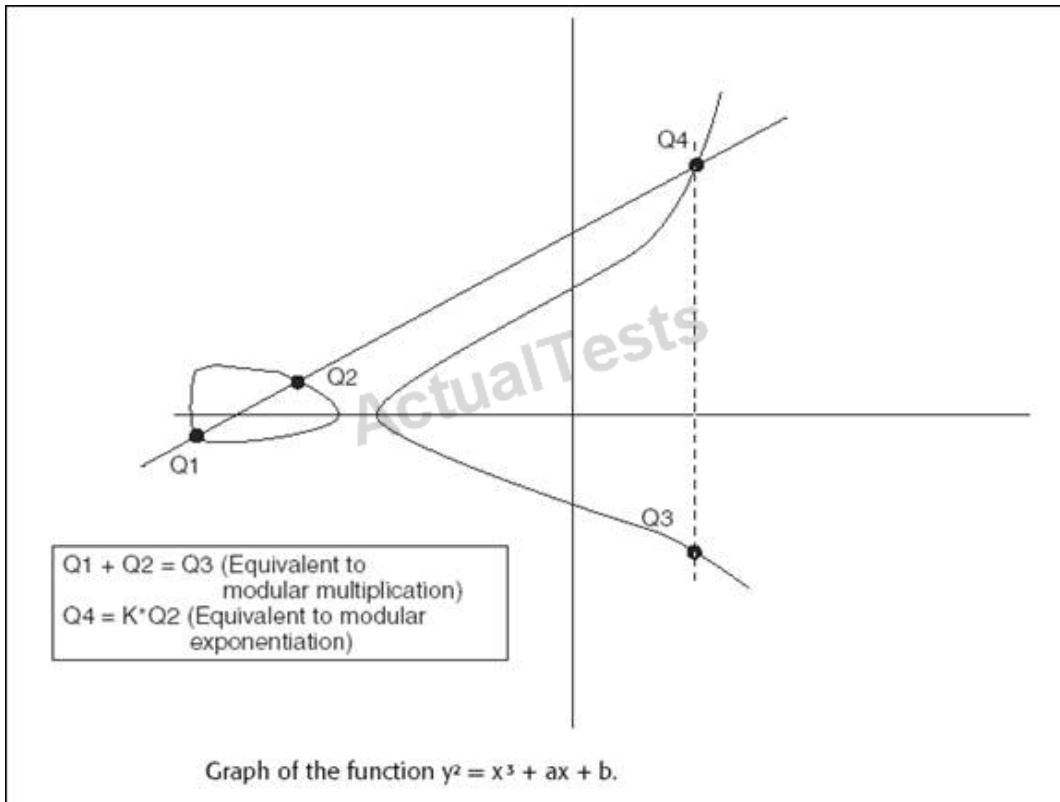
Explanation:

The correct answer is Bell-LaPadula. The Bell-LaPadula model addresses the confidentiality of classified material. Answers . Clark-Wilson and Biba are integrity models, and answer Stark-Wils is a distracter.

QUESTION NO: 1691

The graph in Figure, which depicts the equation $y^2 = x^3 + ax + b$, denotes the:

Exhibit:



- A. RSA Factoring problem
- B. Elliptic curve and the elliptic curve discrete logarithm problem
- C. ElGamal discrete logarithm problem
- D. Knapsack problem

Answer: B

Explanation:

The elliptic curve is defined over a finite field comprised of real, complex or rational numbers. The points on an elliptic curve form a Group under addition. Multiplication (or multiple additions) in an elliptic curve system is equivalent to modular exponentiation; thus, defining a discrete logarithm problem.

QUESTION NO: 1692

Which one of the following is generally NOT considered a covered entity under Title II, Administrative Simplification, of the HIPAA law?

- A. Employers
- B. Health care providers who transmit health information electronically in connection with standard transactions
- C. Health plans
- D. Health care clearinghouses

Answer: A

Explanation:

Employers are not specifically covered under HIPAA. HIPAA applies to health care providers that transmit health care information in electronic form, health care clearinghouses, and health plans. However, some employers may be covered under the Gramm-Leach-Bliley Act. The Gramm-Leach-Bliley (GLB) Act was enacted on November 12, 1999, to remove Depression era restrictions on banks that limited certain business activities, mergers, and affiliations. It repeals the restrictions on banks affiliating with securities firms contained in sections 20 and 32 of the Glass-Steagall Act. GLB became effective on November 13, 2001. GLB also requires health plans and insurers to protect member and subscriber data in electronic and other formats. These health plans and insurers will fall under new state laws and regulations that are being passed to implement GLB, since GLB explicitly assigns enforcement of the health plan and insurer regulations to state insurance authorities (15 USC. §6805). Some of the privacy and security requirements of Gramm-Leach-Bliley are similar to those of HIPAA. Most states required that health plans and insurers comply with the GLB requirements by July 1, 2001, and financial institutions were required to be in full compliance with Gramm-Leach-Bliley by this date. The other answers are incorrect since they are covered by the HIPAA regulations.

QUESTION NO: 1693

The hashing algorithm in the Digital Signature Standard (DSS) generates a message digest of:

- A. 130 bit
- B. 56 bits

- C. 120 bits
- D. 160 bits

Answer: D

Explanation:

QUESTION NO: 1694

In the * (star) property of the Bell-LaPadula model,

- A. Subjects cannot read from their same level of security.
- B. Subjects cannot read from a higher level of security relative to their level of security.
- C. Subjects cannot read from a lower level of security relative to their level of security.
- D. Subjects cannot write to a lower level of security relative to their level of security.

Answer: D

Explanation:

The correct answer by definition of the star property.

QUESTION NO: 1695

The memory hierarchy in a typical digital computer, in order, is:

- A. CPU, cache, primary memory, secondary memory.
- B. CPU, cache, secondary memory, primary memory.
- C. CPU, secondary memory, cache, primary memory.
- D. CPU, primary memory, secondary memory, cache.

Answer: A

Explanation:

The correct answer is "CPU, cache, primary memory, secondary memory". In this architecture, the CPU sees the high-speed cache, which holds the instructions and data from primary memory that have a high probability of being executed by the program. In order of speed of access, the order in the correct answer goes from the fastest to the slowest access time.

QUESTION NO: 1696

Which of the following examples is the best definition of Fail Secure?

- A.** The operating system is started without the security front-end loaded.
- B.** The system preserves a secure state during and after a system crash.
- C.** Access personnel have security clearance, but they do not have a need-to-know.
- D.** The system fails to preserve a secure state during and after a system crash.

Answer: B

Explanation:

The correct answer is "The system preserves a secure state during and after a system crash". Based on the Common Criteria, a system can be evaluated as fail secure if it preserves a secure state during and after identified failures occur.

QUESTION NO: 1697

A cryptographic algorithm is also known as:

- A.** A key
- B.** Cryptanalysis
- C.** A cipher
- D.** A cryptosystem

Answer: C

Explanation:

A cipher is a cryptographic transformation that operates on characters or bits. In different words, a cipher is defined as a cryptographic algorithm or mathematical function that operates on characters or bits and implements encryption or decryption. In contrast, a code

operates with words, phrases and sentences. In a code, a word may be the encipherment of a sentence or phrase. For example, the word SCARF may be the code for the term BEWARE OF DUTCH TRAITOR IN YOUR MIDST.

* a cryptosystem is a set of transformations from a message space to a ciphertext space. This system includes all cryptovariables (keys), plaintexts and ciphertexts associated with the transformation algorithm. The difference between answers a and c is that answer c, the correct answer, refers to the algorithm alone and answer a refers to the algorithm and all plaintexts, ciphertexts and cryptovariables associated with this algorithm.

* cryptanalysis, refers to being able to break the cipher so that the encrypted message can be read. Cryptanalysis may be accomplished by exploiting weaknesses in the cipher or, in some fashion, determining the key. This act of obtaining the plaintext or key from the ciphertext can be used to recover sensitive or classified information and, perhaps, to pass on altered or fake messages in order to deceive the original intended recipient.

* the key or cryptovariable, is used with a particular algorithm to encipher or decipher the plaintext message. By using the key, the algorithm can be publicly known and evaluated for its strength against attack. The key associated with a particular transformation or algorithm can take on many values and the range of all of these possible values is called the keyspace. Ideally, an enciphered plaintext message using a specific algorithm will produce a unique ciphertext message for each different key that is used with that algorithm. The situation in which a plaintext message generates identical ciphertext messages using the same transformation algorithm, but with different cryptovariables, is called key clustering. Obviously, this is not a desirable situation, since it effectively reduces the number of keys that have to be tried by an attacker in order to recover the plaintext.

QUESTION NO: 1698

The ANSI X9.52 standard defines a variant of DES encryption with keys k1, k2, and k3 as:

$C = Ek_3 [Dk_2 [Ek_1 [M]]]$

What is this DES variant?

- A. Double DES with an encryption and decryption with different keys
- B. Triple DES in the EEE mode
- C. Triple DES in the EDE mode
- D. DESX

Answer: C

Explanation:

This version of triple DES performs an encryption (E) of plaintext message M with key k1, a decryption (D) with key k2 (essentially, another encryption), and a third encryption with key k3. Another implementation of DES EDE is accomplished with keys k1 and k2 being independent, but with keys k1 and k3 being identical. This implementation of triple DES is written as:

$C = Ek_1 [Dk_2 [Ek_1 [M]]]$

Answer a is incorrect since, in DESX, input plaintext is bitwise XORed with 64 bits of additional key material before encryption with DES, and the output of DES is also bitwise XORed with another 64 bits of key material. Answer b, DES in the EEE, mode is written as:

$C = Ek_3 [Ek_2 [Ek_1 [M]]]$

where three consecutive encryptions are performed on plaintext message, M, with three independent keys, k1, k2, k3.

Answer c is incorrect since the question contains three encryptions.

Implementing two DES encryptions does not provide the additional security anticipated over a single DES encryption because of the meet-in-the-middle attack. Consider a DES cipher with a key size of p. A double encryption will result in an effective key size of 2p and yield the final result R. Thus, one would anticipate that one would have to search a key space of 2^{2p} in an exhaustive search of the keys. However, it can be shown that a search of the key space on the order of 2^p is all that is necessary. This search is the same size as required for a single DES encryption. This situation is illustrated as follows:

The sequences shown illustrate the first DES encryption of a plaintext message M with all keys k1 through k2p yielding the intermediate encrypted results C1 through C2p.

$Ek_1 [M] \text{ C1}$

$Ek_2 [M] \text{ C2}$

$E_{k2p}[M] = C_{2p}$

If we have available ciphertext R where $R = E_{k2}[E_{k1}[M]]$ for a pair of secret keys $k1$ and $k2$, for each key m there is only one key k such that $D_m[R] = E_k[M]$ where D is the decipherment of R back from the second DES encipherment. In other words, there are 2^p possible keys that will result in the pair $[M,R]$ and, thus, can be found in a search of order 2^p .

QUESTION NO: 1699

Primary storage is the:

- A.** Memory used in conjunction with real memory to present a CPU with a larger, apparent address space.
- B.** Memory directly addressable by the CPU, which is for the storage of instructions and data that are associated with the program being executed.
- C.** Memory, such as magnetic disks, that provide non-volatile storage.
- D.** Memory where information must be obtained by sequentially searching from the beginning of the memory space.

Answer: B

Explanation:

* Answer "Memory, such as magnetic disks, that provide non-volatile storage" refers to secondary storage.

* Answer "Memory used in conjunction with real memory to present a CPU with a larger, apparent address space" refers to virtual memory, and answer "Memory where information must be obtained by sequentially searching from the beginning of the memory space" refers to sequential memory.

QUESTION NO: 1700

In a hybrid cryptographic system, usually:

- A. Digital certificates cannot be used.
- B. Neither public key nor private key cryptography is used.
- C. Public key cryptography is used for the encryption of the message.
- D. Private key cryptography is used for the encryption of the message.

Answer: D

Explanation:

QUESTION NO: 1701

The organization that establishes a collaborative partnership of computer incident response, security and law enforcement professionals who work together to handle computer security incidents and to provide both proactive and reactive security services for the

- A. Federal CIO Council
- B. Federal Computer Incident Response Center
- C. CERT/CC
- D. Center for Infrastructure Protection

Answer: B

Explanation:

To again quote the FedCIRC charter, FedCIRC provides assistance and guidance in incident response and provides a centralized approach to incident handling across agency boundaries. Specifically, the mission of FedCIRC is to:

Provide civil agencies with technical information, tools, methods, assistance, and guidance

Be proactive and provide liaison activities and analytical support

Encourage the development of quality products and services through collaborative relationships with Federal civil agencies, the Department of Defense, academia, and private industry

Promote the highest security profile for government information technology (IT) resources

Promote incident response and handling procedural awareness with the federal government

* Answer CERT Coordination Center (CERT/CC), is a unit of the Carnegie Mellon University Software Engineering Institute (SEI). SEI is a Federally funded R&D Center . CERT's mission is to alert the Internet community to vulnerabilities and attacks and to conduct

research and training in the areas of computer security, including incident response.

* Answer "Center for Infrastructure Protection" is a distracter and answer "Federal CIO Council", the Federal Chief Information Officers' Council, is the sponsor of FedCIRC.

QUESTION NO: 1702

What type of firewall architecture employs two network cards and a single screening router?

- A. A dual-homed host firewall
- B. An application-level proxy server
- C. A screened-subnet firewall
- D. A screened-host firewall

Answer: D

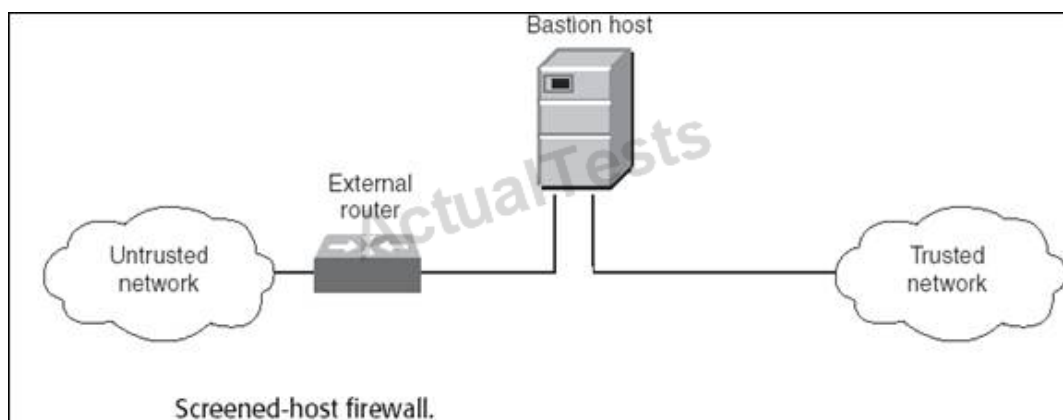
Explanation:

Like a dual-homed host, a screened-host firewall uses two network cards to connect to the trusted and untrusted networks, but adds a screening router between the host and the untrusted network.

* dual-homed host has two NICs but not necessarily a screening router.

* screened-subnet firewall uses two NICs also, but has two screening routers with the host

Exhibit:



acting as a proxy server on its own network segment. One screening router controls traffic local to the network while the second monitors and controls incoming and outgoing Internet traffic,

* application-level proxy, is unrelated to this question. Source: Hacker Proof by Lars Klander (Jamsa Press, 1997).

QUESTION NO: 1703

The National Computer Security Center (NCSC) is:

- A.** An activity within the US Department of Commerce that provides information security awareness training and develops standards for protecting sensitive but unclassified information
- B.** A joint enterprise between the NSA and NIST for developing cryptographic algorithms and standards
- C.** A division of the National Institute of Standards and Technology (NIST) that issues standards for cryptographic functions and publishes them as Federal Information Processing Standards (FIPS)
- D.** A branch of the National Security Agency (NSA) that initiates research and develops and publishes standards and criteria for trusted information systems

Answer: D

Explanation:

The NCSC promotes information systems security awareness and technology transfer through many channels, including the annual National Information Systems Security Conference. It was founded in 1981 as the Department of Defense Computer Security Center , and its name was change in 1985 to NCSc. It developed the Trusted Computer Evaluation Program Rainbow series for evaluating commercial products against information system security criteria. All the other answers are, therefore incorrect since they refer to NIST, which is under the US Department of Commerce.

QUESTION NO: 1704

What does IPL stand for?

- A. Internet Police League
- B. Initial Program Life Cycle
- C. Initial Program Load
- D. Initial Post-Transaction Logging

Answer: C

Explanation:

The correct answer is "Initial Program Load". The IPL is a task performed by the operator to boot up the system. The other terms do not exist.

QUESTION NO: 1705

Which of the following choices describes the four phases of the National Information Assurance Certification and Accreditation Process (NIACAP)?

- A. Definition, Verification, Validation, and Post Accreditation
- B. Definition, Authentication, Verification, and Post Accreditation
- C. Definition, Verification, Validation, and Confirmation
- D. Verification, Validation, Authentication, and Post Accreditation

Answer: A

Explanation:

QUESTION NO: 1706

What is the key length of the Rijndael Block Cipher?

- A. 56 or 64 bits
- B. 128, 192, or 256 bits
- C. 512 or 1024 bits
- D. 512 bits

Answer: B

Explanation:

QUESTION NO: 1707

The Clark-Wilson model focuses on data's:

- A. Availability.
- B. Confidentiality.
- C. Format.
- D. Integrity.

Answer: D

Explanation:

The correct answer is Integrity. The Clark-Wilson model is an integrity model.

QUESTION NO: 1708

Using pre-numbered forms to initiate a transaction is an example of what type of control?

- A. Preventative control
- B. Deterrent control
- C. Detective control
- D. Application control

Answer: A

Explanation:

The correct answer is "Preventative control". Pre-numbered forms are an example of preventative controls. They can also be considered a transaction control and input control.

QUESTION NO: 1709

The ANSI ASC X12 (American National Standards Institute Accredited Standards Committee X12) Standard version 4010 applies to which one of the following HIPAA categories?

- A. Security
- B. Privacy
- C. Transactions
- D. Code sets

Answer: C

Explanation:

The transactions addressed by HIPAA are:

Health claims or similar encounter information

Health care payment and remittance advice

Coordination of Benefits

Health claim status

Enrollment and disenrollment in a health plan

Eligibility for a health plan

Health plan premium payments

Referral certification and authorization

The HIPAA EDI transaction standards to address these HIPAA transactions include the following:

Health care claims or coordination of benefits

Retail drug NCPDP (National Council for Prescription Drug Programs) v. 32

Dental claim ASC X12N 837: dental

Professional claim ASC X12N 837: professional

Institutional claim ASC X12N 837: institutional

Payment and remittance advice ASC X12N 835

Health claim status ASC X12N 276/277

Plan enrollment ASC X12 834

Plan eligibility ASC X12 270/271

Plan premium payments ASC X12 820

Referral certification ASC X12 N 278

The American National Standards Institute was founded in 1917

and is the only source of American Standards. The ANSI Accredited

Standards Committee X12 was chartered in 1979 and is responsible for

cross-industry standards for electronic documents. The HIPAA privacy

standards, answer a, were finalized in April, 2001, and implementation

must be accomplished by April 14, 2003. The privacy rule covers individually identifiable health care information transmitted, stored in electronic or paper form, or communicated orally. Protected health information (PHI) may not be disclosed unless disclosure is approved by the individual, permitted by the legislation, required for treatment, part of health care operations, required by law, or necessary for payment. PHI is defined as individually identifiable health information that is transmitted by electronic media, maintained in any medium described in the definition of electronic media under HIPAA, or is transmitted or maintained in any other form or medium. Answer b, code sets, refers to the codes that are used to fill in the data elements of the HIPAA transaction standards. Examples of these codes are: ICD-9-CM (vols. 1 and 2) International Classification of Diseases, 9th Ed., Clinical Modification Diseases, injuries, impairments, other health related problems, their manifestations, and causes of injury, disease, impairment, or other health-related problems CPT (Current Procedural Terminology, 4th Ed. [CPT-4]), CDT (Code on Dental Procedures and Nomenclature, 2nd Ed. [CDT-2]) or ICD-9-CM (vol. 3) Procedures or other actions taken to prevent, diagnose, treat, or manage diseases, injuries, and impairments NDC (National Drug Codes) drugs HCPCS (Health Care Financing Administration Common Procedure Coding System) Other health-related services, other substances, equipment, supplies, or other items used in health care services The proposed HIPAA Security Rule, answer d, mandates the protection of the confidentiality, integrity, and availability of protected health information (PHI) through:

- Administrative procedures
- Physical safeguards
- Technical services and mechanisms

The rule also addresses electronic signatures, but the final rule will depend on industry progress on reaching a standard. In addition, the proposed security rule requires the appointment of a security officer.

QUESTION NO: 1710

The strength of RSA public key encryption is based on the:

- A. Difficulty of multiplying two large prime numbers.
- B. Difficulty in finding logarithms in a finite field.
- C. Fact that only one key is used.
- D. Difficulty in finding the prime factors of very large numbers.

Answer: D

Explanation:

The correct answer is "Difficulty in finding the prime factors of very large numbers".

Answer "Difficulty in finding the prime factors of very large numbers" applies to public key algorithms such as Diffie-Hellman and Elliptic Curve.

Answer "Difficulty of multiplying two large prime numbers" is incorrect because it is easy to multiply two large prime numbers.

Answer "Fact that only one key is used" refers to symmetric key encryption.

QUESTION NO: 1711

What is one of the most common drawbacks to using a dual-homed host firewall?

- A. The examination of the packet at the Network layer introduces latency.
- B. The examination of the packet at the Application layer introduces latency.
- C. The ACLs must be manually maintained on the host.
- D. Internal routing may accidentally become enabled.

Answer: D

Explanation:

A dual-homed host uses two NICs to attach to two separate networks, commonly a trusted network and an untrusted network. It's important that the internal routing function of the host be disabled to create an application-layer chokepoint and filter packets. Many systems come with routing enabled by default, such as IP forwarding, which

makes the firewall useless. The other answers are distracters. Source: Hacker Proof by Lars Klander (Jamsa Press, 1997).

QUESTION NO: 1712

Using a modulo 26 substitution cipher where the letters A to Z of the alphabet are given a value of 0 to 25, respectively, encrypt the message OVERLORD BEGINS. Use the key K =NEW and D =3 where D is the number of repeating letters representing the key. The encrypted message is:

- A. BFAEPKEH XRKFAW
- B. BFAEPKEH XRKEAW
- C. BFAERKEH XRKEAW
- D. BFAEQKEH XRKFAW
- E. BZAEPKEH XRKFAW
- F. BZAEPKEH XRKEAW
- G. BZAERKEH XRKEAW
- H. BZAEQKEH XRKFAW

Answer: F

Explanation:

The solution is as follows:

OVERLORD becomes 14 21 4 17 11 14 17 3

BEGINS becomes 1 4 6 8 13 18

The key NEW becomes 13 4 22

Adding the key repetitively to OVERLORD BEGINS modulo 26

yields 1 5 0 4 15 10 4 7 23 17 10 4 0 22, which translates to BZAEPKEH XRKEAW

More in detail:

	A	B	C	D	E	F	G
	Phrase	Value	Key	Key Value	Added	Mod 26	CipherText
	O	14	N	13	27	1	B
	V	21	E	4	25	25	Z
	E	4	W	22	26	0	A
	R	17	N	13	30	4	E
	L	11	E	4	15	15	P
	O	14	W	22	36	10	K
	R	17	N	13	30	4	E
	D	3	E	4	7	7	H
	B	1	W	22	23	23	X
	E	4	N	13	17	17	R
	G	6	E	4	10	10	K
	I	8	W	22	30	4	E
	N	13	N	13	26	0	A
	S	18	E	4	22	22	W

QUESTION NO: 1713

The Wireless Transport Layer Security (WTLS) Protocol in the Wireless Application Protocol (WAP) stack is based on which Internet Security Protocol?

- A. TLS
- B. SET
- C. S-HTTP
- D. IPSEC

Answer: A

Explanation:

TLS is discussed in the answer to question 5. WTLS has to incorporate functionality that is provided for in TLS by TCP in the TCP/IP Protocol suite in that WTLS can operate over UDP. WTLS supports data privacy, authentication and integrity. Because WTLS has to incorporate a large number of handshakes when security is implemented, significant delays may occur. During a WTLS handshake session, WTLS can set up the following security classes:

Class 1. No certificates

Class 2. The client does not have a certificate; the server has a certificate

Class 3. The client and server have certificates

QUESTION NO: 1714

A difference between the Information Technology Security Evaluation Criteria (ITSEC) and the Trusted Computer System Evaluation Criteria (TCSEC) is:

- A.** TCSEC addresses availability as well as confidentiality
- B.** ITSEC addresses confidentiality only
- C.** ITSEC addresses integrity and availability as well as confidentiality
- D.** TCSEC separates functionality and assurance

Answer: C

Explanation:

TCSEC addresses confidentiality only and bundles functionality and assurance. Thus, the other answers are incorrect. By separating functionality and assurance as in ITSEC, one could specify fewer security functions that have a high level of assurance. This separation carried over into the Common Criteria.

QUESTION NO: 1715

Which of the following is NOT a property of a public key cryptosystem?

(Let P represent the private key, Q represent the public key and M the plaintext message.)

- A. P and Q are difficult to generate from a particular key value.
- B. $P[Q(M)] = M$
- C. $Q[P(M)] = M$
- D. It is computationally infeasible to derive P from Q.

Answer: A

Explanation:

The answer refers to the initial computation wherein the private and public keys are computed. The computation in this direction is relatively straightforward. Answers " $Q[P(M)] = M$ " and " $P[Q(M)] = M$ " state the true property of public key cryptography which is that a plaintext message encrypted with the private key can be decrypted by the public key and vice versa. Answer "It is computationally infeasible to derive P from Q" states that it is computationally infeasible to derive the private key from the public key. Obviously, this is a critical property of public key cryptography.

QUESTION NO: 1716

In the National Information Assurance Certification and Accreditation

Process (NIACAP), a type accreditation performs which one of the following functions?

- A. Evaluates the applications and systems at a specific, self-contained location
- B. Evaluates a major application or general support system
- C. Verifies the evolving or modified system's compliance with the information agreed on in the System Security Authorization Agreement (SSAA)
- D. Evaluates an application or system that is distributed to a number of different locations

Answer: D

Explanation:

* Answer "Evaluates a major application or general support system" is the NIACAP system accreditation.

* Answer "Verifies the evolving or modified system's compliance with the information agreed on in the System Security Authorization Agreement (SSAA)" is the Phase 2 or Verification phase of the Defense Information Technology Security Certification and Accreditation Process (DITSCAP). The objective is to use the SSAA to establish an evolving yet binding agreement on the level of security required before the system development begins or changes to a system are made. After

accreditation, the SSAA becomes the baseline security configuration document.

* Answer "Evaluates the applications and systems at a specific, self-contained location" is the NIACAP site accreditation.

QUESTION NO: 1717

Random access memory is:

- A. Volatile.
- B. Non-volatile.
- C. Sequentially addressable.
- D. Programmed by using fusible links.

Answer: A

Explanation:

The correct answer is Volatile. RAM is volatile. The other answers are incorrect because RAM is volatile, randomly accessible, and not programmed by fusible links.

QUESTION NO: 1718

The model that addresses the situation wherein one group is not affected by another group using specific commands is called the:

- A. Information flow model
- B. Non-interference model
- C. Composition model
- D. Clark-Wilson model

Answer: B

Explanation:

In the non-interference model, security policy assertions are defined

in the abstract. The process of moving from the abstract to developing conditions that can be applied to the transition functions that operate on the objects is called unwinding.

* Answer "Information flow model" refers to the information flow model in which information is categorized into classes, and rules define how information can flow between the classes. The model can be defined as $[O, P, S, T]$ where O is the set of objects, P is the flow policy, S represents the valid states, and T represents the state transitions. The flow policy is usually implemented as a lattice structure.

* The composition model, answer Composition model, investigates the resultant security properties when subsystems are combined.

QUESTION NO: 1719

The modes of DES do NOT include:

- A. Output Feedback.
- B. Variable Block Feedback.
- C. Electronic Code Book.
- D. Cipher Block Chaining.

Answer: B

Explanation:

The correct answer is Variable Block Feedback. There is no such encipherment mode.

QUESTION NO: 1720

A computer system that employs the necessary hardware and software assurance measures to enable it to process multiple levels of classified or sensitive information is called a:

- A. Trusted system.
- B. Open system.
- C. Closed system.
- D. Safe system.

Answer: A

Explanation:

The correct answer is Trusted system, by definition of a trusted system.

Answers Closed system and Open system refer to open, standard information on a product as opposed to a closed or proprietary product. Answer Safe system is a distracter.

QUESTION NO: 1721

In most security protocols that support authentication, integrity and confidentiality,

- A. Public key cryptography is used to create digital signatures.
- B. Private key cryptography is used to create digital signatures.
- C. Digital signatures are not implemented.
- D. DES is used to create digital signatures.

Answer: A

Explanation:

The correct answer is "Public key cryptography is used to create digital signatures."

Answer "Private key cryptography is used to create digital signatures" is incorrect because private key cryptography does not create digital signatures.

Answer "DES is used to create digital signatures" is incorrect because DES is a private key system and, therefore, follows the same logic as in "Private key cryptography is used to create digital signatures"; and answer "Digital signatures are not implemented" is incorrect because digital signatures are implemented to obtain authentication and integrity.

QUESTION NO: 1722

An iterated block cipher encrypts by breaking the plaintext block into two halves and, with a subkey, applying a round transformation to one of the halves. Then, the output of this transformation is XORed with the remaining half. The round is completed by swapping the two halves. This type of cipher is known as:

- A. RC6
- B. Diffie-Hellman
- C. RC4
- D. Feistel

Answer: D

Explanation:

The question stem describes one round of a Feistel cipher. This algorithm was developed by an IBM team led by Horst Feistel. (h. Feistel, Cryptography and Computer Privacy, Scientific American, v.228, n.5, May 1973) The algorithm was called Lucifer and was the basis for the Data Encryption Standard (DES). In answer a, RC4 is a variable keysize stream cipher developed by Ronald Rivest. In this type of cipher, a sequence of bits that are the key is bit-wise XORed with the plaintext.

* Diffie-Hellman describes the first public key algorithm and is based on the difficulty of calculating discrete logarithms in a finite field. (W. Diffie and M.e. Hellman, New Directions in Cryptography, IEEE Transactions on Information Theory, v. IT-22, n. 6, Nov 1976). It is used for exchanging keys. RC6, in answer c, is a fast block cipher designed by Rivest, Sidney and Yin. In RC6, the block size, the key size and the number of rounds are variable. The key size can be no larger than 2040 bits. RC6 was one of the five finalists in the Advanced Encryption Standard (AES) competition.

QUESTION NO: 1723

Which one of the following statements BEST describes the operation of the Digital Signature Algorithm (DSA) (National Institute of Standards

and Technology, NIST FIPS PUB 186, Digital Signature Standard,

- A.** A message of < 264 bits is input to the DSA, and the resultant message digest of 160 bits is fed into the Secure Hash Algorithm (SHA), which generates the digital signature of the message.
- B.** A message of < 264 bits is input to the Secure Hash Algorithm (SHA), and the resultant message digest of 160 bits is used as the digital signature of the message.
- C.** A message of < 264 bits is input to the Secure Hash Algorithm (SHA), and the resultant message digest of 160 bits is fed into the DSA, which generates the digital signature of the message.
- D.** A message of < 264 bits is input to the Secure Hash Algorithm (SHA), and the resultant message digest of 128 bits is fed into the DSA, which generates the digital signature of the message.

Answer: C

Explanation:

The correct answer describes the proper sequence of operating on the message and has the correct value of 160 bits for the SHA message digest.

At the receiving end, the message is fed into the SHA, and the result is compared to the received message digest to verify the signature.

*Answer "A message of < 264 bits is input to the DSA, and the resultant message digest of 160 bits is fed into the Secure Hash Algorithm (SHA), which generates the digital signature of the message" is incorrect since the order of the DSA and SHA are in reverse sequence from the correct order of their application.

* Answer "A message of < 264 bits is input to the Secure Hash Algorithm (SHA), and the resultant message digest of 128 bits is fed into the DSA, which generates the digital signature of the message." is incorrect since it has the incorrect value of 128 bits for the message digest produced by the SHA.

* Answer "A message of < 264 bits is input to the Secure Hash Algorithm (SHA), and the resultant message digest of 160 bits is used as the digital signature of the message" is incorrect since the message digest has to be fed into the DSA to generate the digital signature of the message.

QUESTION NO: 1724

The Wireless Transport Layer Security Protocol (WTLS) in the Wireless

Application Protocol (WAP) stack provides for security:

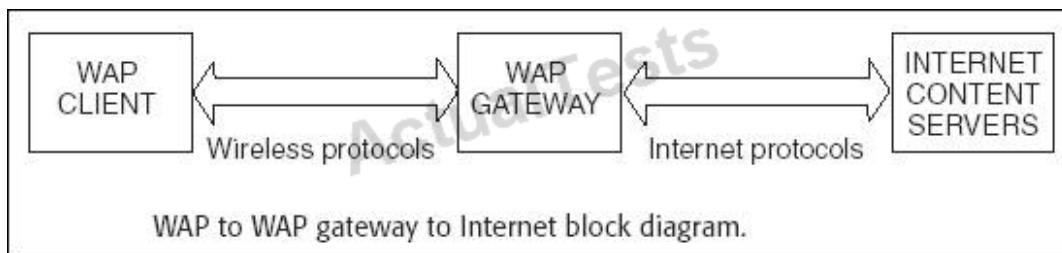
- A. Between the Internet and the content server
- B. Between the WAP content server and the WAP client
- C. Between the WAP gateway and the content server
- D. Between the WAP client and the gateway

Answer: D

Explanation:

Transport Layer Security (TLS) provides for security between the content server on the Internet and the WAP gateway. (Answer "Between the WAP gateway and the content server" is, thus, incorrect.) Similarly, WTLS provides security between the WAP mobile device (client software) and the WAP gateway. Since WAP cannot interface directly with the Internet, all WAP information has to be converted to HTTP in the WAP gateway to enable it to exchange information with the Internet content servers. The simple block diagram illustrates these concepts.

Exhibit:



A vulnerability occurs since data encrypted with wireless protocols has to be decrypted in the WAP gateway and then re-encrypted with the Internet protocols. This process is reversed when data flows from the Internet content servers to the WAP client. Thus, the information is vulnerable while it is in the decrypted state on the WAP gateway. This condition is known as the WAP Gap. In order to address this issue, the WAP Forum has put forth specifications that will reduce this vulnerability and, thus, support e-commerce applications. These specifications are defined in WAP 1.2 as WMLScript Crypto Library and the WAP Identity Module (WIM). The WMLScript Crypto Library supports end-to-end security by providing for cryptographic functions to be initiated on the WAP client from the Internet content server. These functions include digital signatures originating with the WAP client and encryption and decryption of data. The WIM is a tamper-resistant device, such as a smart card, that

cooperates with WTLS and provides cryptographic operations during the handshake phase.

The WAP Forum is also considering another alternative to providing the end-to-end encryption for WAP. This alternative, described in WAP specification 1.3, is the use of a client proxy server that communicates authentication and authorization information to the wireless network server.

*Answer "Between the Internet and the content server" is incorrect since the content server is on the Internet side of the communication and answer "Between the WAP content server and the WAP client" assumes a direct interface between the content server and the client without going through the necessary Internet and wireless protocols.

QUESTION NO: 1725

The NIST Advanced Encryption Standard uses the:

- A. DES algorithm.
- B. IDEA algorithm.
- C. Rijndael algorithm.
- D. 3 DES algorithm.

Answer: C

Explanation:

The correct answer is Rijndael algorithm. By definition, the others are incorrect.

QUESTION NO: 1726

DESX is a variant of DES in which:

- A. The output of DES is bitwise XORed with 64 bits of key material.
- B. Input plaintext is bitwise XORed with 64 bits of additional key material before encryption with DES, and the output of DES is also bitwise XORed with another 64 bits of key material.

- C. The input plaintext is encrypted X times with the DES algorithm using different keys for each encryption.
- D. Input plaintext is bitwise XORed with 64 bits of additional key material before encryption with DES.

Answer: B

Explanation:

DESX was developed by Ron Rivest to increase the resistance of DES to brute force key search attacks; however, the resistance of DESX to differential and linear attacks is equivalent to that of DES with independent subkeys.

QUESTION NO: 1727

The Take-Grant model:

- A. Specifies the rights that a subject can transfer to an object.
- B. Specifies the levels of availability.
- C. Specifies the levels of integrity.
- D. Focuses on confidentiality.

Answer: A

Explanation:

QUESTION NO: 1728

The system component that enforces access controls on an object is the:

- A. Trusted domain.
- B. Reference monitor.
- C. Access control matrix.
- D. Security perimeter.

Answer: B

Explanation:

QUESTION NO: 1729

In order to recognize the practical aspects of multilevel security in which, for example, an unclassified paragraph in a Secret document has to be moved to an Unclassified document, the Bell-LaPadula model introduces the concept of a:

- A. Data flow
- B. Simple security property
- C. Trusted subject
- D. Secure exchange

Answer: C

Explanation:

The model permits a trusted subject to violate the *-property but to comply with the intent of the *-property. Thus, a person who is a trusted subject could move unclassified data from a classified document to an unclassified document without violating the intent of the *-property. Another example would be for a trusted subject to downgrade the classification of material when it has been determined that the downgrade would not harm national or organizational security and would not violate the intent of the *-property. The simple security property (ss-property), answer "Simple security property", states that a subject cleared for one classification cannot read data from a higher classification. This property is also known as the no read up property. Answers Secure exchange and Data flow are distracters.

QUESTION NO: 1730

What are the hardware, firmware, and software elements of a Trusted Computing Base (TCB) that implement the reference monitor concept called?

- A. An Operating System (OS)
- B. A trusted computing system

- C. A security kernel
- D. The trusted path

Answer: C

Explanation:

QUESTION NO: 1731

Which of the following would be the BEST description of clipping levels?

- A. Variance detection of too many people with unrestricted access
- B. Changes a system's stored data characteristics
- C. A baseline of user errors above which violations will be recorded
- D. A listing of every error made by users to initiate violation processing

Answer: C

Explanation:

The correct answer is "A baseline of user errors above which violations will be recorded". This description of a clipping level is the best.

* It is not "A listing of every error made by users to initiate violation processing", because the reason for creating a clipping level is to prevent auditors from having to examine every error.

* The answer "Variance detection of too many people with unrestricted access" is a common use for clipping levels but is not a definition.

* Answer "Changes a system's stored data characteristics" is a distracter.

QUESTION NO: 1732

Which choice below is NOT an element of a fiber optic cable?

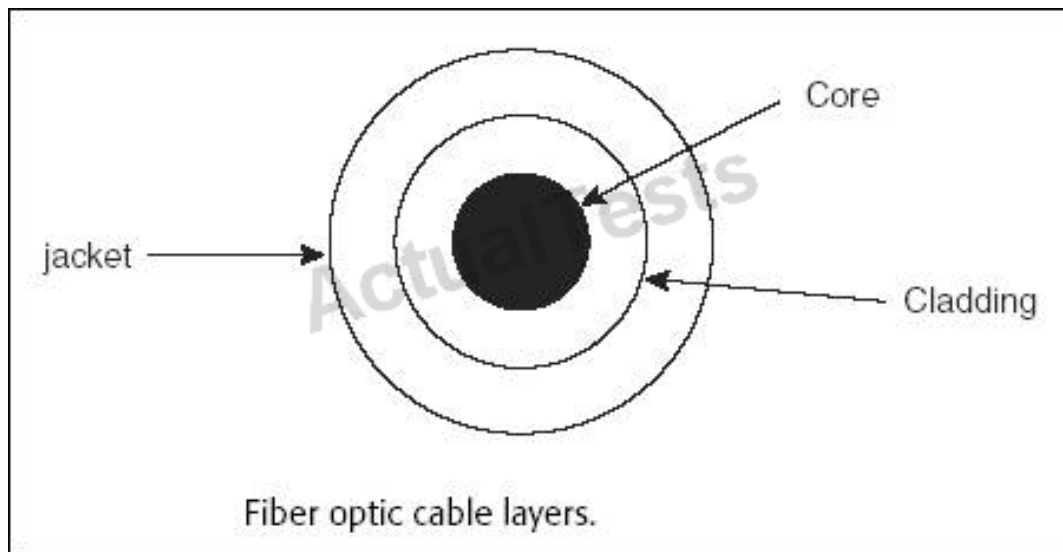
- A. BNC
- B. Jacket
- C. Core
- D. Cladding

Answer: A

Explanation:

A BNC refers to a Bayonet Neil Concelman RG58 connector for 10Base2. Fiber optic cable has three basic physical elements, the core, the cladding, and the jacket. The core is the innermost transmission medium, which can be glass or plastic. The next outer layer, the cladding is also made of glass or plastic, but has different properties, and helps to reflect the light back into the core. The outermost layer, the jacket, provides protection from heat, moisture, and other environmental elements. Source: Gigabit Ethernet by Jayant Kadambi, Ian Crayford, and Mohan Kalkunte (Prentice Hall PTR, 1998). Figure shows a cross-section of a fiber optic cable.

Exhibit:



QUESTION NO: 1733

In a block cipher, diffusion can be accomplished through:

- A. Nonlinear S-boxes
- B. Substitution
- C. Permutation
- D. XORing

Answer: C

Explanation:

Diffusion is aimed at obscuring redundancy in the plaintext by spreading the effect of the transformation over the ciphertext. Permutation is also known as transposition and operates by rearranging the letters of the plaintext.

*Answer substitution is used to implement confusion in a block cipher. Confusion tries to hide the relationship between the plaintext and the ciphertext. The Caesar cipher is an example of a substitution cipher.

* XORing is incorrect since XORing, for example, as used in a stream cipher, implements confusion and not diffusion. Similarly, nonlinear S-boxes implement substitution. In DES, for example, there are eight different S-boxes that each has an input of 6 bits and an output of 4 bits. Thus, nonlinear substitution is effected.

QUESTION NO: 1734

What are MD4 and MD5?

- A. Symmetric encryption algorithms
- B. Digital certificates
- C. Hashing algorithms
- D. Asymmetric encryption algorithms

Answer: C

Explanation:

The correct answer is "Hashing algorithms". Answers "Symmetric encryption algorithms" and "Asymmetric encryption algorithms" are incorrect because they are general types of encryption systems, and answer "Digital certificates" is incorrect because hashing algorithms are not digital certificates.

QUESTION NO: 1735

The IP address, 178.22.90.1, is considered to be in which class of address?

- A. Class D
- B. Class C
- C. Class A
- D. Class B

Answer: D

Explanation:

The class A address range is 1.0.0.0 to 126.255.255.255. The class B address range is 128.0.0.0 to 191.255.255.255. The class C address range is from 192.0.0.0 to 223.255.255.255. The class D address range is 244.0.0.0 to 239.255.255.255, and is used for multicast packets.

Sources: Designing Network Security by Merike Kaeo (Cisco Press, 1999) and CCNA Study Guide by Todd Lammle, Donald Porter, and James Chellis (Sybex, 1999).

QUESTION NO: 1736

An interface to a library of software functions that provide security and cryptography services is called:

- A. A security application programming interface (SAPI)
- B. A confidentiality, integrity and availability application programming interface (CIAAPI)
- C. An assurance application programming interface (AAPI)
- D. A cryptographic application programming interface (CAPI)

Answer: D

Explanation:

CAPI is designed for software developers to call functions from the library and, thus, make it easier to implement security services.

An example of a CAPI is the Generic Security Service API (GSSAPI.)

The GSS-API provides data confidentiality, authentication, and data integrity services and supports the use of both public and secret key mechanisms. The GSS-API is described in the Internet Proposed

Standard RFC 2078. The other answers are made-up distracters.

QUESTION NO: 1737

The Bell-LaPadula model addresses which one of the following items?

- A. Covert channels
- B. Definition of a secure state transition
- C. Information flow from high to low
- D. The creation and destruction of subjects and objects

Answer: C

Explanation:

Information flow from high to low is addressed by the * -property of the Bell-LaPadula model, which states that a subject cannot write data from a higher level of classification to a lower level of classification. This property is also known as the confinement property or the no write down property.

* In answer "Covert channels", covert channels are not addressed by the model. The Bell-LaPadula model deals with information flow through normal channels and does not address the covert passing of information through unintended paths.

The creation and destruction of subjects and objects, answer "The creation and destruction of subjects and objects", is not addressed by the model.

* Answer "Definition of a secure state transition" refers to the fact that the model discusses a secure transition from one secure state to another, but it never provides a definition of a secure transition.

QUESTION NO: 1738

As an analog of confidentiality labels, integrity labels in the Biba model

are assigned according to which of the following rules?

- A.** Objects are assigned integrity labels according to their trustworthiness; subjects are assigned classes according to the harm that would be done if the data were modified improperly.
- B.** Objects are assigned integrity labels identical to the corresponding confidentiality labels.
- C.** Integrity labels are assigned according to the harm that would occur from unauthorized disclosure of the information.
- D.** Subjects are assigned classes according to their trustworthiness; objects are assigned integrity labels according to the harm that would be done if the data were modified improperly.

Answer: D

Explanation:

As subjects in the world of confidentiality are assigned clearances related to their trustworthiness, subjects in the Biba model are assigned to integrity classes that are indicative of their trustworthiness.

Also, in the context of confidentiality, objects are assigned classifications related to the amount of harm that would be caused by unauthorized disclosure of the object. Similarly, in the integrity model, objects are assigned to classes related to the amount of harm that would be caused by the improper modification of the object. Answer a is incorrect since integrity properties and confidentiality properties are opposites. For example, in the Bell-LaPadula model, there is no prohibition against a subject at one classification reading information from a lower level of confidentiality. However, when maintenance of the integrity of data is the objective, reading of information from a lower level of integrity by a subject at a higher level of integrity risks contaminating data at the higher level of integrity. Thus, the simple and * -properties in the Biba model are complements of the corresponding properties in the Bell-LaPadula model. Recall that the Simple Integrity Property states that a subject at one level of integrity is not permitted to observe (read) an object of a lower integrity (no read down). Also, the *- Integrity Property states that an object at one level of integrity is not permitted to modify (write to) an object of a higher level of integrity (no write up).

* Answer "Objects are assigned integrity labels according to their trustworthiness; subjects are assigned classes according to the harm that would be done if the data were modified improperly" is incorrect since the words object and subject are interchanged.

* In answer "Integrity labels are assigned according to the harm that would occur from unauthorized disclosure of the information", unauthorized disclosure refers to confidentiality and not to integrity.

QUESTION NO: 1739

The Transport Layer Security (TLS) 1.0 protocol is based on which Protocol Specification?

- A.** SSL-3.0
- B.** IPSEC
- C.** TCP/IP
- D.** SSH-2

Answer: A

Explanation:

The differences between TLS and SSL are not great, but there is enough of a difference such that TLS 1.0 and SSL 3.0 are not operationally compatible. If interoperability is desired, there is a capability in TLS that allows it to function as SSL. Question 5 provides additional discussion of the TLS protocol.

QUESTION NO: 1740

Which of the following is NOT a symmetric key algorithm?

- A.** Data Encryption Standard (DES)
- B.** Advanced Encryption Standard (AES)
- C.** International Data Encryption Algorithm (IDEA)
- D.** MD5

Answer: D

Explanation:

The correct answer is MD5. MD5 is a message digest algorithm.

QUESTION NO: 1741

What does the Bell-LaPadula model NOT allow?

- A. Subjects to write to a higher level of security relative to their level of security
- B. Subjects to read from a higher level of security relative to their level of security
- C. Subjects to read at their same level of security
- D. Subjects to read from a lower level of security relative to their level of security

Answer: B

Explanation:

The other options are not prohibited by the model.

QUESTION NO: 1742

In a ring protection system, where is the security kernel usually located?

- A. Highest ring number
- B. Middle ring number
- C. Lowest ring number
- D. Arbitrarily placed

Answer: C

Explanation:

QUESTION NO: 1743

If the application of a hash function results in an m-bit fixed length output, an attack on the hash function that attempts to achieve a

collision after $2^{m/2}$ possible trial input values is called a(n):

- A. Birthday attack
- B. Meet-in-the-middle attack
- C. Chosen-ciphertext attack
- D. Adaptive-chosen-plaintext attack

Answer: A

Explanation:

This problem is analogous to asking the question How many people must be in a room for the probability of two people having the same birthday to be equal to 50%? The answer is 23. Thus, trying $2^{m/2}$ possible trial inputs to a hash function gives a 50% chance of finding two inputs that have the same hash value. Answer a, describes an attack in which the attacker can choose the plaintext to be encrypted and can modify his/her choice based on the results of a previous encryption.

* Answer the chosen-cipher text attack is where the attacker can select different ciphertexts to be decrypted and has the decrypted plaintext available. This attack is used to determine the key or keys being used. Answer d is an attack against double encryption. This approach shows that for a key length of k bits, a chosen-plaintext attack could find the key after 2^{k+1} trials instead of 2^{2k} attempts. In this attack on double encryption, one encrypts from one end, decrypts from the other and compares the results in-the-middle.

QUESTION NO: 1744

Which of the following is NOT a key recovery method?

- A. A secret key or a private key is broken into a number of parts and each part is deposited with a trustee agent. The agents can then provide their parts of the key to a central authority, when presented with appropriate authorization. The key can then be reconstructed and used to decrypt messages encrypted with that key.
- B. A message is encrypted with a session key and the session key is, in turn, encrypted with the private key of a trustee agent. The encrypted session key is sent along with the encrypted message. The

trustee, when authorized, can then decrypt the message by recovering the session key with the trustee's public key.

C. A message is encrypted with a session key. The session key, in turn, is broken into parts and each part is encrypted with the public key of a different trustee agent. The encrypted parts of the session key are sent along with the encrypted message. The trustees, when authorized, can then decrypt their portion of the session key and provide their respective parts of the session key to a central agent. The central agent can then decrypt the message by reconstructing the session key from the individual components.

D. A message is encrypted with a session key and the session key is, in turn, encrypted with the public key of a trustee agent. The encrypted session key is sent along with the encrypted message. The trustee, when authorized, can then decrypt the message by recovering the session key with the trustee's private key.

Answer: B

Explanation:

Encrypting parts of the session key with the private keys of the trustee agents provides no security for the message since the message can be decrypted by recovering the key components of the session key using the public keys of the respective agents. These public keys are available to anyone.

The other answers are valid means of recovering keys, since key recovery refers to permitting access to encrypted messages under predefined circumstances.

Two of these answers are also called key encapsulation since the session key is encapsulated in the public keys of the trustee agents and, therefore, can be decrypted only by these trustee agents with their private keys.

QUESTION NO: 1745

What is a computer bus?

- A.** A group of conductors for the addressing of data and control
- B.** A message in object-oriented programming
- C.** A message sent around a Token Ring network
- D.** Secondary storage

Answer: A

Explanation:

- * Answer "A message sent around a Token Ring network" is a token.
- * Answer Secondary stora refers to disk storage.
- * Answer "A message in object-oriented programming" is a distracter.

QUESTION NO: 1746

In the Common Criteria, an implementation-independent statement of security needs for a set of IT security products that could be built is called a:

- A.** Package.
- B.** Security Target (ST).
- C.** Target of Evaluation (TOE).
- D.** Protection Profile (PP).

Answer: D

Explanation:

The correct answer is "Protection Profile (PP)". Answer a, ST, is a statement of security claims for a particular IT product or system.

- * A Package is defined in the CC as an intermediate combination of security requirement components.
- * ATOE is an IT product or system to be evaluated.

QUESTION NO: 1747

Content-dependent control makes access decisions based on:

- A.** The object's environment.
- B.** The object's view.
- C.** The object's owner.
- D.** The object's data.

Answer: D

Explanation:

The correct answer is "The object's data". Answer "The object's environment" is context-dependent control. Answers The object's owner and The object's view are distracters.

QUESTION NO: 1748

In a block cipher, diffusion:

- A. Conceals the connection between the ciphertext and plaintext
- B. Is usually implemented by non-linear S-boxes
- C. Spreads the influence of a plaintext character over many ciphertext characters
- D. Cannot be accomplished

Answer: C

Explanation:

QUESTION NO: 1749

The Rijndael Cipher employs a round transformation that is comprised of three layers of distinct, invertible transformations. These transformations are also defined as uniform, which means that every bit of the State is treated the same. Which of the following is NOT one of these layers?

- A. The key inversion layer, which provides confusion through the multiple rounds
- B. The non-linear layer, which is the parallel application of S-boxes that have the optimum worst-case non-linearity properties
- C. The linear mixing layer, which provides a guarantee of the high diffusion of multiple rounds
- D. The key addition layer, which is an Exclusive Or of the Round Key to the intermediate State

Answer: A

Explanation:

This answer is a distracter and does not exist.

QUESTION NO: 1750

The Biba model axiom An object at one level of integrity is not permitted to modify (write to) an object of a higher level of integrity (no write up) is called:

- A. The Constrained Integrity Axiom
- B. The Discretionary Integrity Axiom
- C. The Simple Integrity Axiom
- D. The * (star) Integrity Axiom

Answer: D

Explanation:

The correct answer is "The * (star) Integrity Axiom".

Answers a and d are distracters. Answer the Simple Integrity Axiom states, A subject at one level of integrity is not permitted to observe (read) an object of lower integrity (no read down).

QUESTION NO: 1751

Which choice below denotes a packet-switched connectionless wide area network (WAN) technology?

- A. ATM
- B. SMDS
- C. X.25
- D. Frame Relay

Answer: B

Explanation:

Switched Multimegabit Data Service (SMDS) is a high-speed, connectionless, packet-switching public network service that extends LAN-like performance to a metropolitan area network (MAN) or a wide area network (WAN). It's generally delivered over a SONET ring with a maximum effective service radius of around 30 miles.

* X.25, defines an interface to the first commercially successful connection-oriented packet-switching network, in which the packets travel over virtual circuits.

* Frame Relay, was a successor to X.25, and offers a connection-oriented packet-switching network.

* Asynchronous Transfer Mode (ATM), was developed from an outgrowth of ISDN standards, and is fast-packet, connection-oriented, cell-switching technology.

Source: Communications Systems and Networks by Ray Horak (M&T Books, 2000).

QUESTION NO: 1752

Which of the following is a reason to institute output controls?

- A. To preserve the integrity of the data in the system while changes are being made to the configuration
- B. To protect the output's confidentiality
- C. To recover damage after an identified system failure
- D. To detect irregularities in the software's operation

Answer: B

Explanation:

The correct answer is "To protect the output's confidentiality". In addition to being used as a transaction control verification mechanism, output controls are used to ensure that output, such as printed reports, is distributed securely.

* Answer "To preserve the integrity of the data in the system while changes are being made to the configuration" is an example of Configuration or Change control.

* "To detect irregularities in the software's operation" is an example of Application controls, and d is an example of Recovery controls.

QUESTION NO: 1753

In a multilevel security system (MLS), the Pump is:

- A.** A one-way information flow device
- B.** A two-way information flow device
- C.** A device that implements role-based access control
- D.** Compartmented Mode Workstation (CMW)

Answer: A

Explanation:

The Pump (M.h. Kang, I.S. Moskowitz, APump for Rapid, Reliable, Secure Communications, The 1st ACM Conference on Computer and Communications Security, Fairfax, VA, 1993) was developed at the US Naval Research Laboratory (NRL). It permits information flow in one direction only, from a lower level of security classification or sensitivity to a higher level. It is a convenient approach to multilevel security in that it can be used to put together systems with different security levels.

* Answer "A two-way information flow device" is a distracter.

* Answer "Compartmented Mode Workstation (CMW)", the CMW, refers to windows-based workstations that require users to work with information at different classification levels. Thus, users may work with multiple windows with different classification levels on their workstations. When data is attempted to be moved from one window to another, mandatory access control policies are enforced. This prevents information of a higher classification from being deposited to a location of lower classification.

* Answer "A device that implements role-based access control", role-based access control, is an access control mechanism and is now being considered for mandatory access control based on users' roles in their organizations.

QUESTION NO: 1754

In the access control matrix, the rows are:

- A. Capability lists.
- B. Tuples.
- C. Access Control Lists (ACLs).
- D. Domains.

Answer: A

Explanation:

The correct answer is Capability lists.

* Answer "Access Control Lists (ACLs)" is incorrect because the access control list is not a row in the access control matrix.

* Answer Tuples is incorrect because a tuple is a row in the table of a relational database.

* Answer Domains is incorrect because a domain is the set of allowable values a column or attribute can take in a relational database.

QUESTION NO: 1755

The vulnerability associated with the requirement to change security protocols at a carriers' Wireless Application Protocol (WAP) gateway from the Wireless Transport Layer Security Protocol (WTLS) to SSL or TLS over the wired network is called:

- A. Wired Equivalency Privacy (WEP) Gap.
- B. Wireless Application Protocol (WAP) Gap.
- C. Wireless Transaction Protocol (WTP) Gap.
- D. Wireless Transport Layer Security Protocol (WTLS) Gap.

Answer: B

Explanation:

The correct answer is the WAP Gap. The other answers are distracters.

QUESTION NO: 1756

What is a protocol that adds digital signatures and encryption to Internet MIME (Multipurpose Internet Mail Extensions)?

- A. S/MIME
- B. PGP
- C. SET/MIME
- D. IPSEC

Answer: A

Explanation:

The MIME protocol specifies a structure for the body of an email message. MIME supports a number of formats in the email body, including graphic, enhanced text and audio, but does not provide security services for these messages. S/MIME defines such services for MIME as digital signatures and encryption based on a standard syntax.

*Answer IPSEC is incorrect since IPSEC is not an email protocol but is a standard that provides encryption, access control, nonrepudiation, and authentication of messages over IP. It is designed to be functionally compatible with IPv6.

Answer b is incorrect because PGP,

Pretty Good Privacy, brings security to email through the use of a symmetric cipher, such as IDEA, to encipher the message. RSA is used for symmetric key exchange and for digital signatures. PGP is not an augmentation of MIME. RFC 2440 permits other algorithms to be used in PGP. In order of preference, they are ElGamal and RSA for key distribution; triple DES, IDEA and CAST5 for encryption of messages; DSA and RSA for digital signatures and SHA-1 or MD5 for generating hashes of the messages. Answer d is incorrect because there is no such protocol. There is a protocol called SET for Secure Electronic Transaction. It was developed by Visa and MasterCard to secure electronic bankcard transactions. SET requests authorization for payment and requires certificates binding a person's public key to their identity.

QUESTION NO: 1757

The minimum information necessary on a digital certificate is:

- A. Name, public key, digital signature of the certifier
- B. Name, expiration date, public key
- C. Name, expiration date, digital signature of the certifier
- D. Name, serial number, private key

Answer: A

Explanation:

The correct answer is "Name, public key, digital signature of the certifier", where the name of the individual is certified and bound to his/her public key. This certification is validated by the digital signature of the certifying agent. In answer a, the public key is not present to be bound to the person's name.

* In answer "Name, public key, digital signature of the certifier" the public key and name are present, but there is no digital signature verifying that the public key belongs to the name.

* Answer "Name, serial number, private key" is incorrect on a number of counts. First, the private key is never disclosed to the public and secondly, there is no digital signature.

QUESTION NO: 1758

Which backup method listed below will probably require the backup operator to use the most number of tapes for a complete system restoration, if a different tape is used every night in a five-day rotation?

- A. Incremental Backup Method
- B. Ad Hoc Backup Method
- C. Full Backup Method
- D. Differential Backup Method

Answer: A

Explanation:

Most backup methods use the Archive file attribute to determine whether the file should be backed up or not. The backup software

determines which files need to be backed up by checking to see if the Archive file attribute has been set, and then resets the Archive bit value to null after the backup procedure. The Incremental Backup Method backs up only files that have been created or modified since the last backup was made, because the Archive file attribute is reset. This can result in the backup operator needing several tapes to do a complete restoration, as every tape with changed files as well as the last full backup tape will need to be restored.

* a Full or Complete backup backs up all files in all directories stored on the server regardless of when the last backup was made and whether the files have already been backed up. The Archive file attribute is changed to mark that the files have been backed up, and the tapes or tapes will have all data and applications on it. It's an incorrect answer for this question, however, as it's assumed answers Differential Backup Method and Incremental Backup Method will additionally require differential or incremental tapes.

* the Differential Backup Method, backs up only files that have been created or modified since the last backup was made, like an incremental backup. However, the difference between an incremental backup and a differential backup is that the Archive file attribute is not reset after the differential backup is completed, therefore the changed file is backed up every time the differential backup is run. The backup set grows in size until the next full backup as these files continue to be backed up during each subsequent differential backup, until the next complete backup occurs. The advantage of this backup method is that the backup operator should only need the full backup and the one differential backup to restore the system.

Table shows these three backup methods.

Exhibit:

Differential versus Incremental Backup Tape Contents					
BACKUP METHOD	MONDAY	TUESDAY	WEDNESDAY	THURSDAY	FRIDAY
Differential	Changed File A	Changed Files A & B	Files A, B, & C	Files A, B, C, & D	
Incremental	Changed File A	Changed File B	Changed File C	Changed File D	
Full Backup					All Files

Answer "Ad Hoc Backup Method" is a distracter.

QUESTION NO: 1759

Memory space insulated from other running processes in a multiprocessing system is part of a:

- A. Least upper bound.
- B. Protection domain.
- C. Constrained data item.
- D. Security perimeter.

Answer: B

Explanation:

QUESTION NO: 1760

Which one the following is NOT one of the three major parts of the Common Criteria (CC)?

- A. Introduction and General Model
- B. Security Assurance Requirements
- C. Security Functional Requirements
- D. Security Evaluation Requirements

Answer: D

Explanation:

The correct answer is "Security Evaluation Requirements", a distracter.

* Answer "Introduction and General Model" is Part 1 of the Cc. It defines general concepts and principles of information security and defines the contents of the Protection Profile (PP), Security Target (ST), and the Package.

* The Security Functional Requirements are Part 2 of the CC, which contains a catalog of well-defined standard means of expressing security requirements of IT products and systems.

* Answer "Security Assurance Requirements" is Part 3 of the CC and comprises a catalog of a set of standard assurance components.

QUESTION NO: 1761

A Security Parameter Index (SPI) and the identity of the security protocol (AH or ESP) are the components of:

- A. SSL
- B. IPSec
- C. S-HTTP
- D. SSH-2

Answer: B

Explanation:

The correct answer is IPSec. The SPI, AH and/or ESP and the destination IP address are components of an IPSec Security Association (SA.)

The other answers describe protocols other than IPSec.

QUESTION NO: 1762

The technique of confusion, proposed by Claude Shannon, is used in block ciphers to:

- A. Conceal the statistical connection between ciphertext and plaintext.
- B. Implement transposition to obtain the ciphertext.
- C. Spread the influence of a plaintext character over many ciphertext characters.
- D. Limit the influence of a plaintext character across ciphertext characters.

Answer: A

Explanation:

QUESTION NO: 1763

The two categories of the policy of separation of duty are:

- A. Dual control and aggregation control
- B. Dual control and functional separation
- C. Span of control and functional separation
- D. Inference control and functional separation

Answer: B

Explanation:

Dual control requires that two or more subjects act together simultaneously to authorize an operation. A common example is the requirement that two individuals turn their keys simultaneously in two physically separated areas to arm a weapon. Functional separation implies a sequential approval process such as requiring the approval of a manager to send a check generated by a subordinate.

* Answer "Span of control and functional separation" is incorrect. Span of control refers to the number of subordinates that can be optimally managed by a superior.

* Answer "Inference control and functional separation" is incorrect. Inference control is implementing protections that prevent the inference of information not authorized to a user from information that is authorized to be accessed by a user.

* Answer "Dual control and aggregation control" is incorrect, but aggregation refers to the acquisition of large numbers of data items to obtain information that would not be available by analyzing a small number of the data items.

QUESTION NO: 1764

Convert Channel Analysis, Trusted Facility Management, and Trusted

Recovery are parts of which book in the TCSEC Rainbow Series?

- A. Red Book
- B. Dark Green Book
- C. Orange Book
- D. Green Book

Answer: C

Explanation:

The correct answer is Orange Book.

* Answer the Red Book is the Trusted Network

Interpretation (TNI) summary of network requirements (described in the Telecommunications and Network Security domain).

* The Green Book, is the Department of Defense (DoD) Password Management Guide-line;

* The Dark Green Book, is The Guide to Understanding Data Remanence in Automated Information Systems.

QUESTION NO: 1765

Which of the following is an example of an asymmetric key algorithm?

- A. IDEA
- B. 3 DES
- C. ELLIPTIC CURVE
- D. DES

Answer: C

Explanation:

The correct answer is ELLIPTIC CURVE. All the other answers refer to symmetric key algorithms.

QUESTION NO: 1766

Which of the following would NOT be a component of a general enterprise security architecture model for an organization?

- A. IT system auditing
- B. Consideration of all the items that comprise information security, including distributed systems, software, hardware, communications systems, and networks
- C. Information and resources to ensure the appropriate level of risk management

D. A systematic and unified approach for evaluating the organization's information systems security infrastructure and defining approaches to implementation and deployment of information security controls

Answer: A

Explanation:

The auditing component of the IT system should be independent and distinct from the information system security architecture for a system.

* In answer "Information and resources to ensure the appropriate level of risk management", the resources to support intelligent risk management decisions include technical expertise, applicable evaluation processes, refinement of business objectives, and delivery plans.

* Answer "Consideration of all the items that comprise information security, including distributed systems, software, hardware, communications systems, and networks" promotes an enterprise-wide view of information system security issues.

* For answer "A systematic and unified approach for evaluating the organization's information systems security infrastructure and defining approaches to implementation and deployment of information security controls", the intent is to show that a comprehensive security architecture model includes all phases involved in information system security including planning, design, integrating, testing, and production.

QUESTION NO: 1767

Which of the following is a problem with symmetric key encryption?

- A.** Work factor is not a function of the key size.
- B.** Most algorithms are kept proprietary.
- C.** Secure distribution of the secret key.
- D.** It is slower than asymmetric key encryption.

Answer: C

Explanation:

The correct answer is "Secure distribution of the secret key".

Answer "It is slower than asymmetric key encryption" is incorrect because the opposite is true; answer "Most algorithms are kept proprietary" is incorrect because most symmetric key algorithms are published; and answer "Work factor is not a function of the key size" is incorrect because work factor is a function of key size. The larger the key is, the larger the work factor.

QUESTION NO: 1768

In the Common Criteria, a Protection Profile:

- A.** Specifies the security requirements and protections of the products to be evaluated.
- B.** Is also known as the Orange Book.
- C.** Is also known as the Target of Evaluation (TOE).
- D.** Specifies the mandatory protection in the product to be evaluated.

Answer: A

Explanation:

Answer "Specifies the mandatory protection in the product to be evaluated" is a distracter.

* Answer "Is also known as the Target of Evaluation (TOE)" is the product to be evaluated.

* Answer "Is also known as the Orange Book" refers to TCSEC.

QUESTION NO: 1769

Given an IP address of 172.16.0.0, which subnet mask below would allow us to divide the network into the maximum number of subnets with at least 600 host addresses per subnet?

- A.** 255.255.240.0
- B.** 255.255.224.0
- C.** 255.255.248.0
- D.** 255.255.252.0

Answer: D

Explanation:

The last two octets of this class B address, 252.0, gives us binary:

11111100.00000000. The six subnet bits give us 62 ($2^6 - 2$) subnets, each with 1022 ($2^{10} - 2$) hosts, which allows us to have the maximum number of subnets with almost double the required host addresses.

* 224.0, is 11100000.00000000 binary, which gives us six ($2^3 - 2$) subnets with 8190 ($2^{13} - 2$) hosts each.

* 240.0, is 11110000.00000000 binary, and gives us 14 ($2^4 - 2$) subnets each with 4094 ($2^{12} - 2$) hosts.

* 248.0, is 11111000.00000000 binary, which creates 30 ($2^5 - 2$) subnets with 2046 ($2^{11} - 2$) hosts. Many books give detailed descriptions of IP subnetting.

QUESTION NO: 1770

What does Secure Sockets Layer (SSL)/Transaction Security Layer (TLS) do?

- A.** Implements confidentiality, authentication, and integrity below the Transport Layer
- B.** Implements only confidentiality below the Transport Layer
- C.** Implements confidentiality, authentication, and integrity above the Transport Layer
- D.** Implements only confidentiality above the Transport Layer

Answer: C

Explanation:

The correct answer is a by definition.

Answer "Implements confidentiality, authentication, and integrity below the Transport Layer" is incorrect because SSL/TLS operates above the Transport Layer.

Answer "Implements only confidentiality above the Transport Layer" is incorrect because authentication and integrity are provided also.

Answer "Implements only confidentiality below the Transport Layer" is incorrect because it cites only confidentiality and SSL/TLS operates above the Transport Layer.

QUESTION NO: 1771

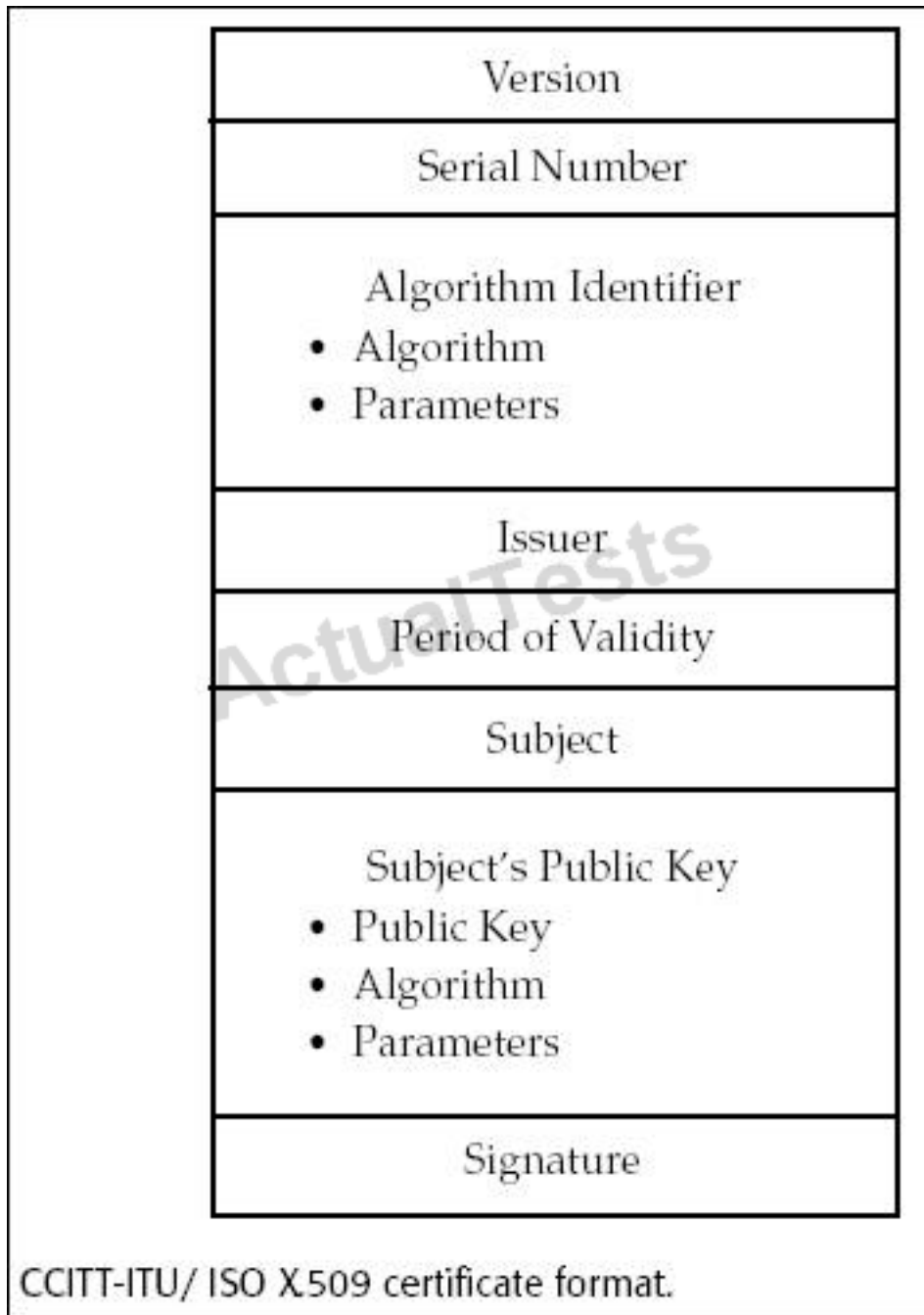
Which of the following is NOT an issue with secret key cryptography?

- A.** Compromise of the keys can enable the attacker to impersonate the key owners and, therefore, read and send false messages.
- B.** A networked group of m users with separate keys for each pair of users will require $m(m-1)/2$ keys.
- C.** Security of the certification authority.
- D.** Secure distribution of the keys.

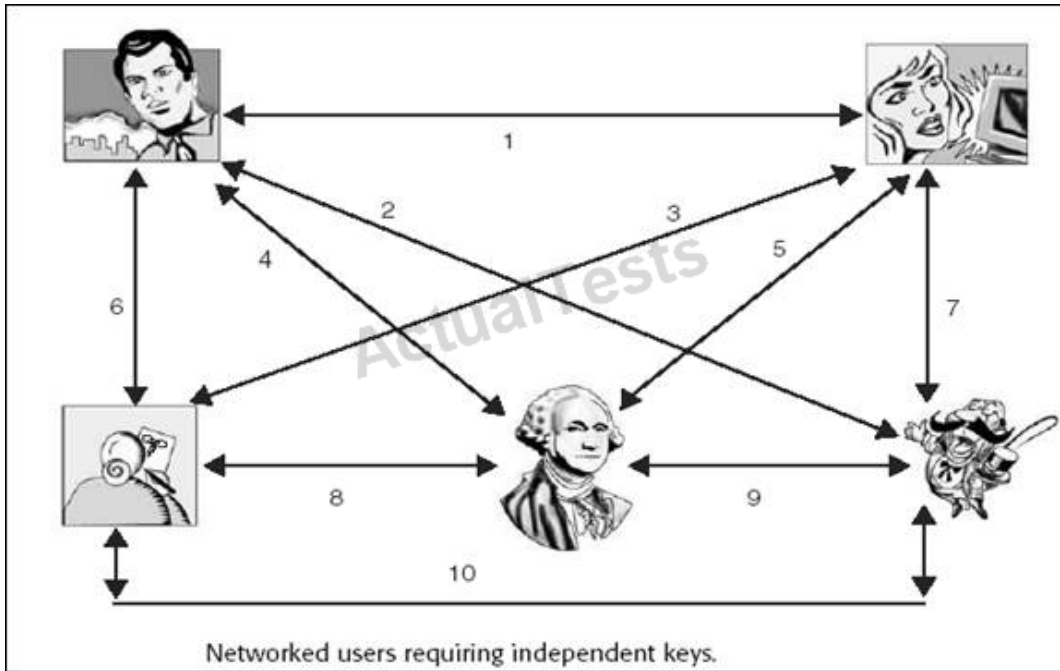
Answer: C

Explanation:

The CAs used in public key cryptography, not secret key cryptography. A CA will certify that a public key actually belongs to a specific individual and that the information associated with the individual's key is valid and correct. The CA accomplishes this certification by digitally signing the individual's public key and associated information. The certification professes to another person who wants to send a message to this individual using public key encryption that the public key actually belongs to the intended individual. The Consultation Committee, International Telephone and Telegraph, International Telecommunications Union (CCITT-ITU)/ International Organization for Standardization (ISO) X.509 Authentication framework defines a format for public key certificates. This structure is outlined in Figure.



Answer "A networked group of m users with separate keys for each pair of users will require $m(m-1)/2$ keys" is an important issue in secret key cryptography; therefore it is not the correct answer. If, among a network of m users, each user wants to have secure communications with every other user on the network, then there must be a secret key for each pair of potential users. This concept can be illustrated with five users as shown in Figure.



Thus, with five users, the number of independent keys is equal to $(5 \times 4)/2$ or 10 as depicted by the ten connecting lines in Figure A.6.

*answer "Secure distribution of the keys" is incorrect since securely distributing the keys to all users is, obviously, a very important requirement.

Answer d is incorrect since a compromise of the keys can, indeed, enable the attacker to impersonate the key owners and, therefore, read and send false messages.

QUESTION NO: 1772

Which algorithm is used in the Clipper Chip?

- A. IDEA
- B. SKIPJACK
- C. 3 DES
- D. DES

Answer: B

Explanation:

The correct answer is SKIPJACK. The other options are other symmetric

key algorithms.

QUESTION NO: 1773

Which statement accurately describes the difference between 802.11b WLAN ad hoc and infrastructure modes?

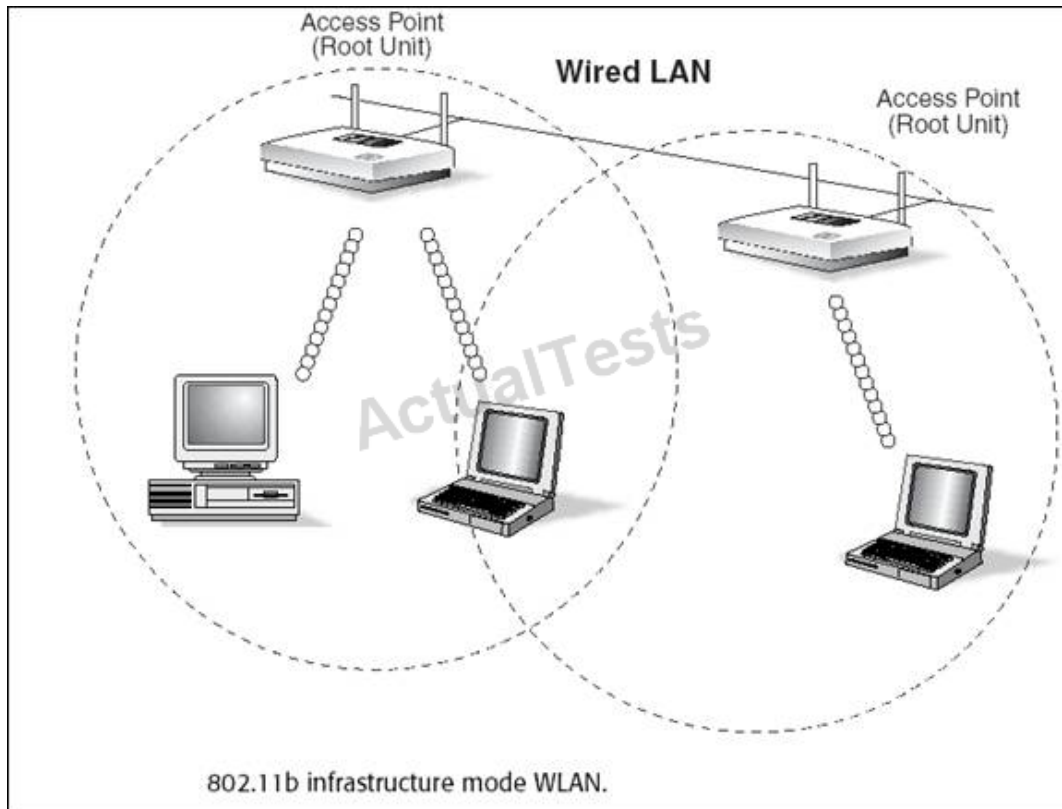
- A.** Access points are rarely used in 802.11b WLANs.
- B.** The ad hoc mode requires an Access Point to communicate to the wired network.
- C.** Wireless nodes can communicate peer-to-peer in the infrastructure mode.
- D.** Wireless nodes can communicate peer-to-peer in the ad hoc mode.

Answer: D

Explanation:

Nodes on an IEEE 802.11b wireless LANs can communicate in one of two modes: ad hoc or infrastructure. In ad hoc mode, the wireless nodes communicate directly with each other, without establishing a connection to an access point on a wired LAN. In infrastructure mode, the wireless nodes communicate to an access point, which operates similarly to a bridge or router and manages traffic between the wireless network and the wired network. Source: Wireless Security Essentials by Russell Dean Vines (Wiley, 2002).

Figure A.3 shows access points attached to a wired LAN to create an Infrastructure Mode 802.11b WLAN.

**QUESTION NO: 1774**

Which of the following is NOT a proper media control?

- A. A proper storage environment should be provided for the media.
- B. The data media should be logged to provide a physical inventory control.
- C. All data storage media should be accurately marked.
- D. The media that is reused in a sensitive environment does not need sanitization.

Answer: D

Explanation:

The correct answer is "The media that is reused in a sensitive environment does not need sanitization". Sanitization is the process of removing information from used data media to prevent data remanence. Different media require different types of sanitation. All the others are examples of proper media controls.

QUESTION NO: 1775

The boundary separating the TCB from the remainder of the system is called the:

- A. Star property.
- B. Discretionary control boundary.
- C. Security perimeter.
- D. Simple security property.

Answer: C

Explanation:

The correct answer is Security perimeter. Answers Star property and Simple security property deal with security models and answer Discretionary control boundary is a distracter.

QUESTION NO: 1776

The DES key size is:

- A. 128 bits.
- B. 56 bits.
- C. 512 bits.
- D. 64 bits.

Answer: D

Explanation:

It is 64-bits, but 8 bits are used for parity, so it is 56 bits in effective for the key length. Might be good to note the clarification (page 703 of CISSP book from Shon Harris – revision 5)

The NSA modified this algorithm to use a key size of 64 bits (with eight bits used for parity, resulting in an effective key length of 56 bits) instead of the original 128 bits, and named it the *Data Encryption Algorithm (DEA)*.

QUESTION NO: 1777

When microcomputers were first developed, the instruction fetch time was much longer than the instruction execution time because of the relatively slow speed of memory accesses. This situation led to the design of the:

- A.** Very-Long-Instruction-Word (VLIW) processor
- B.** Superscalar processor
- C.** Reduced Instruction Set Computer (RISC)
- D.** Complex Instruction Set Computer (CISC)

Answer: D

Explanation:

The logic was that since it took a long time to fetch an instruction from memory relative to the time required to execute that instruction in the CPU, then the number of instructions required to implement a program should be reduced. This reasoning naturally resulted in densely coded instructions with more decode and execution cycles in the processor. This situation was ameliorated by pipelining the instructions wherein the decode and execution cycles of one instruction would be overlapped in time with the fetch cycle of the next instruction.

* Answer "Reduced Instruction Set Computer (RISC)", RISC, evolved when packaging and memory technology advanced to the point where there was not much difference in memory access times and processor execution times. Thus, the objective of the RISC architecture was to reduce the number of cycles required to execute an instruction. Accordingly, this increased the number of instructions in the average program by approximately 30%, but it reduced the number of cycles per instruction on the average by a factor of four. Essentially, the RISC architecture uses simpler instructions but makes use of other features such as optimizing compilers to reduce the number of instructions required and large numbers of general purpose registers in the processor and data caches.

* The superscalar processor, answer "Superscalar processor",

allows concurrent execution of instructions in the same pipelined stage. A scalar processor is defined as a processor that executes one instruction at a time. The term superscalar denotes multiple, concurrent operations performed on scalar values as opposed to vectors or arrays that are used as objects of computation in array processors.

* For answer "Very-Long-Instruction-Word (VLIW) processor" multiple, concurrent operations are performed in a single instruction. Because multiple operations are performed in one instruction rather than using multiple instructions, the number of instructions is reduced relative to those in a scalar processor. However, for this approach to be feasible, the operations in each VLIW instruction must be independent of each other.

QUESTION NO: 1778

A key schedule is:

- A.** A set of subkeys derived from a secret key
- B.** A method of generating keys by the use of random numbers
- C.** Using distributed computing resources to conduct a brute force attack on a symmetric algorithm
- D.** A list of cryptographic keys to be used at specified dates and times

Answer: A

Explanation:

The subkeys are typically used in iterated block ciphers. In this type of cipher, the plaintext is broken into fixed-length blocks and enciphered in rounds. In a round, the same transformation is applied using one of the subkeys of the key schedule.

QUESTION NO: 1779

Which choice below does NOT accurately describe the difference between multi-mode and single-mode fiber optic cabling?

- A.** Multi-mode fiber propagates light waves through many paths, single-mode fiber propagates a single light ray only.
- B.** Both types have a longer allowable maximum transmission distance than UTP Cat 5.
- C.** Multi-mode fiber has a longer allowable maximum transmission distance than single-mode fiber.
- D.** Single-mode fiber has a longer allowable maximum transmission distance than multi-mode fiber.

Answer: C

Explanation:

Multi-mode fiber has a shorter allowable maximum transmission distance than single-mode fiber (2km vs. 10km). Multi-mode transmits the light through several different paths in the cable, whereas single-mode uses one light path, making single mode perform better. However, multi-mode is less expensive to install and is used more often in short-to-medium haul networks. Category 5 unshielded twisted pair (UTP) has a maximum transmission distance of 100 meters. Sources: Catalyst 5000 Series Installation Guide (Cisco Systems, 1996) and Gigabit Ethernet by Jayant Kadambi, Ian Crayford, and Mohan Kalkunte (Prentice Hall PTR, 1998).

QUESTION NO: 1780

The algorithm of the 802.11 Wireless LAN Standard that is used to protect transmitted information from disclosure is called:

- A.** Wired Equivalency Privacy (WEP)
- B.** Wireless Transaction Protocol (WTP)
- C.** Wireless Application Environment (WAE)
- D.** Wireless Transport Layer Security Protocol (WTLS)

Answer: A

Explanation:

WEP is designed to prevent the violation of the confidentiality of data transmitted over the wireless LAN. Another feature of WEP is to prevent unauthorized access to the network. The other answers are protocols in the Wireless Application Protocol, the security.

QUESTION NO: 1781

Enigma was:

- A. The German rotor machine used in WWII.
- B. Probably the first programmable digital computer.
- C. An English project created to break German ciphers.
- D. The Japanese rotor machine used in WWII.

Answer: A

Explanation:

Answer "An English project created to break German ciphers" describes the Ultra Project based in Bletchley Park , England.

Answer "The Japanese rotor machine used in WWII" describes the Japanese Purple Machine.

Answer "Probably the first programmable digital computer" refers to Collossus.

QUESTION NO: 1782

Which of the following are the three types of NIACAP accreditation?

- A. Site, type, and general
- B. Type, system, and location
- C. Site, type, and system
- D. Site, type, and location

Answer: C

Explanation:

QUESTION NO: 1783

Which of the following does the Clark-Wilson model NOT involve?

- A. Well-formed transactions
- B. Confidentiality items
- C. Transformational procedures
- D. Constrained data items

Answer: B

Explanation:

The correct answer is Confidentiality items. The other answers are parts of the Clark- Wilson model.

QUESTION NO: 1784

Which of the following is true?

- A. No successful attacks have been reported against double DES.
- B. The work factor of single DES is the same as for triple DES.
- C. The work factor of double DES is the same as for single DES.
- D. The work factor of triple DES is the same as for double DES.

Answer: C

Explanation:

The Meet-in-the-Middle attack has been successfully applied to double DES, and the work factor is equivalent to that of single DES. Thus, answer "No successful attacks have been reported against double DES" is incorrect.

Answer "The work factor of triple DES is the same as for double DES" is false because the work factor of triple DES is greater than that for double DES. In triple DES, three levels of encryption and/or decryption are applied to the message. The work factor of double DES is equivalent to the work factor of single DES.

Answer "The work factor of single DES is the same as for triple DES" is false because the work

factor of single

DES is less than for triple DES. In triple DES, three levels of encryption and/or decryption are applied to the message in triple DES.

QUESTION NO: 1785

In steganography,

- A. Public key algorithms are used.
- B. Private key algorithms are used.
- C. Both public and private key algorithms are used.
- D. The fact that the message exists is not known.

Answer: D

Explanation:

The other answers are incorrect because neither algorithm is used.

QUESTION NO: 1786

What process is used to accomplish high-speed data transfer between a peripheral device and computer memory, bypassing the Central Processing Unit (CPU)?

- A. Direct memory access
- B. Interrupt processing
- C. Transfer under program control
- D. Direct access control

Answer: A

Explanation:

With DMA, a DMA controller essentially takes control of the memory busses and manages the data transfer directly. Answer interrupt

processing involves an external signal interrupting the normal CPU program flow. This interrupt causes the CPU to halt processing and jump to another program that services the interrupt. When the interrupt has been serviced, the CPU returns to continue executing the original program. Program control transfer, answer c, is accomplished by the processor executing input/output (I/O) instructions. Answer Direct access control is a distracter.

QUESTION NO: 1787

Which type of cabling below is the most common type for recent Ethernet installations?

- A. Twinax
- B. Twisted Pair
- C. ThickNet
- D. ThinNet

Answer: B

Explanation:

Category 5 Unshielded Twisted Pair (UTP) is rated for very high data throughput (100 Mbps) at short distances (up to 100 meters), and is the standard cable type for Ethernet installations.

* ThickNet, also known as 10Base5, uses traditional thick coaxial (coax) cable at data rates of up to 10 Mbps.

* ThinNet, uses a thinner gauge coax, and is known as 10Base2. It has a shorter maximum segment distance than ThickNet, but is less expensive to install (also known as CheaperNet).

* Twinax, is like ThinNet, but has two conductors, and was used in IBM Systems 36 and earlier AS/400 installations.

Source: Communications Systems and Networks by Ray Horak (M&T Books, 2000).

QUESTION NO: 1788

For a given hash function H, to prevent substitution of a message M1 for a message M2, it is necessary that:

- A. $H(M1) = H(M2)$
- B. $H(M1) \neq H(M2)$
- C. $H(M1) < H(M2)$
- D. $H(M1) > H(M2)$

Answer: B

Explanation:

The correct answer is $H(M1) \neq H(M2)$.

If $H(M1) = H(M2)$ then the message digests of both M1 and M2 would be equal, and one would not know that one message was substituted for the other. The other answers are distracters.

QUESTION NO: 1789

What is the correct sequence which enables an authorized agency to use the Law Enforcement Access Field (LEAF) to decrypt a message sent by using the Clipper Chip? The following designations are used for the respective keys involved Kf, the family key; Ks, the session key; U, a unique identifier for each Clipper Chip and Ku, the unit key that is unique to each Clipper Chip.

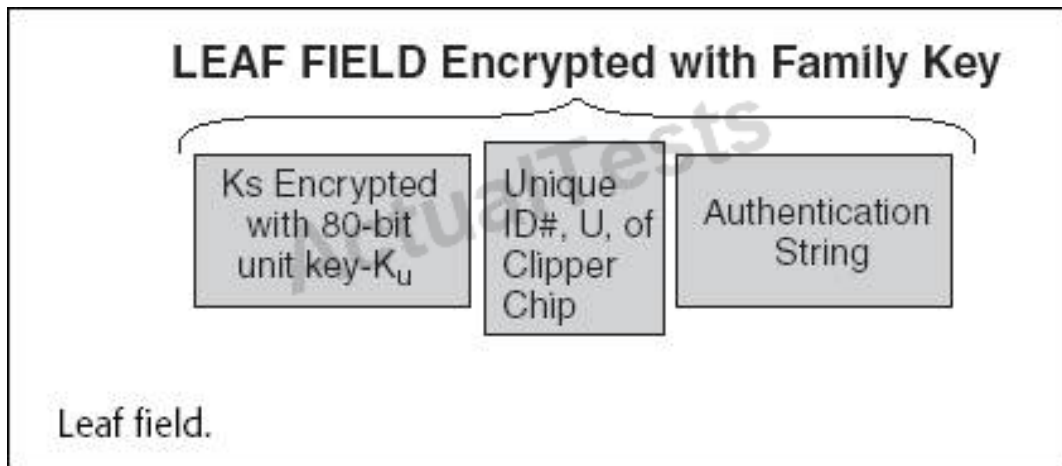
- A. Decrypt the LEAF with the family key, Kf; recover U; obtain a court order to obtain Ks, the session key. Use the session key to decrypt the message.
- B. Decrypt the LEAF with the family key, Kf; recover U; obtain a court order to obtain the two halves of Ku; recover Ku; and then recover Ks, the session key. Use the session key to decrypt the message.
- C. Obtain a court order to acquire the family key, Kf; recover U and Ku; then recover Ks, the session key. Use the session key to decrypt the message.
- D. Obtain a court order to acquire the two halves of Ku, the unit key. Recover Ku. Decrypt the LEAF with Ku and then recover Ks, the

session key. Use the session key to decrypt the message.

Answer: B

Explanation:

The explanation is based on the LEAF as shown in the Figure.



The message is encrypted with the symmetric session key, K_s . In order to decrypt the message, then, K_s must be recovered. The LEAF contains the session key, but the LEAF is encrypted with the family key, K_f , that is common to all Clipper Chips. The authorized agency has access to K_f and decrypts the LEAF. However, the session key is still encrypted by the 80-bit unit key, K_u , that is unique to each Clipper Chip and is identified by the unique identifier, U. K_u is divided into two halves, and each half is deposited with an escrow agency. The law enforcement agency obtains the two halves of K_u by presenting the escrow agencies with a court order for the key identified by U. The two halves of the key obtained by the court order are XORed together to obtain K_u . Then, K_u is used to recover the session key, K_s , and K_s is used to decrypt the message.

The decryption sequence to obtain K_s can be summarized as:

$$K_f \rightarrow U \rightarrow [1/2 K_u \text{ XOR } 1/2 K_u] \rightarrow K_u \rightarrow K_s$$

This is the sequence described in answer "Decrypt the LEAF with the family key, K_f ; recover U; obtain a court order to obtain the two halves of K_u ; recover K_u ; and then recover K_s , the session key. Use the session key to decrypt the message". The sequences described in the other answers are incorrect.

QUESTION NO: 1790

Which of the following is NOT a key management issue?

- A. Key storage
- B. Key exchange
- C. Key change
- D. Key recovery

Answer: B

Explanation:

The correct answer is Key exchange. The other answers are key management issues, but key exchange is a function of the encryption system.

QUESTION NO: 1791

The following concerns usually apply to what type of architecture?

Desktop systems can contain sensitive information that may be at risk of being exposed.

Users may generally lack security awareness.

Modems present a vulnerability to dial-in attacks.

Lack of proper backup may exist.

- A. Centralized
- B. Open system
- C. Distributed
- D. Symmetric

Answer: C

Explanation:

Additional concerns associated with distributed systems include:

A desktop PC or workstation can provide an avenue of access into critical information systems of an organization.

Downloading data from the Internet increases the risk of infecting corporate systems with a malicious code or an unintentional modification of the databases.

A desktop system and its associated disks may not be protected from physical intrusion or theft.

* For answer centralized system all the characteristics cited do not apply to a central host with no PCs or workstations with large amounts of memory attached. Also, the vulnerability presented by a modem attached to a PC or workstation would not exist.

* An open system or architecture is comprised of vendor-independent subsystems that have published specifications and interfaces in order to permit operations with the products of other suppliers. One advantage of an open system is that it is subject to review and evaluation by independent parties.

* Answer Symmetric is a distracter.

QUESTION NO: 1792

Which of the following characteristics does a one-time pad have if used properly?

- A. The key has to be of greater length than the message to be encrypted.
- B. The key does not have to be random.
- C. It can be used more than once.
- D. It is unbreakable.

Answer: D

Explanation:

The correct answer is "It is unbreakable". If the one-time-pad is used only once and its corresponding key is truly random and does not have repeating characters, it is unbreakable.

Answer "It can be used more than once" is incorrect because if used properly, the one-time-pad should be used only once.

Answer "The key does not have to be random" is incorrect because the key should be random.

Answer "The key has to be of greater length than the message to be encrypted" is incorrect

because the key has to be of the same length as the message.

QUESTION NO: 1793

Which of the following is NOT a use of an audit trail?

- A. Collects information such as passwords or infrastructure configurations
- B. Enables the security practitioner to trace a transaction's history
- C. Provides information about additions, deletions, or modifications to the data
- D. Assists the monitoring function by helping to recognize patterns of abnormal user behavior

Answer: A

Explanation:

The correct answer is "Collects information such as passwords or infrastructure configurations". Auditing should not be used to collect user's passwords. It is used for the other three examples, however.

QUESTION NO: 1794

Why is security an issue when a system is booted into single-user mode?

- A. The operating system is started without the security front-end loaded.
- B. The users cannot log in to the system, and they will complain.
- C. Backup tapes cannot be restored while in single-user mode.
- D. Proper forensics cannot be executed while in single-user mode.

Answer: A

Explanation:

The correct answer is "The operating system is started without the security front-end loaded". When the operator boots the system in single-user mode, the user front-end security controls are

not loaded. This mode should be used for recovery and maintenance procedures only, and all operations should be logged and audited.

QUESTION NO: 1795

The addressing mode in a digital computer in which the address location that is specified in the program instructions contains the address of the final desired location is called:

- A. Indexed addressing.
- B. Absolute addressing.
- C. Indirect addressing.
- D. Implied addressing.

Answer: C

Explanation:

The correct answer is Indirect addressing.

- * Answer indexed addressing determines the desired memory address by adding the contents of the address defined in the program's instruction to that of an index register.
- * Implied addressing refers to registers usually contained inside the CPU.
- * Answer absolute addressing addresses the entire primary memory space.

QUESTION NO: 1796

The term failover refers to:

- A. A fail-soft system.
- B. Terminating processing in a controlled fashion.
- C. Resiliency.
- D. Switching to a duplicate, hot backup component.

Answer: D

Explanation:

The correct answer is "Switching to a duplicate, hot backup component". Failover means switching to a hot backup system that maintains duplicate states with the primary system.

Answer "Terminating processing in a controlled fashion" refers to fail safe, and answers Resiliency and A fail-soft system refer to fail soft.

QUESTION NO: 1797

Digital cash refers to the electronic transfer of funds from one party to another. When digital cash is referred to as anonymous or identified, it means that:

- A.** Anonymous the identity of the bank is withheld; Identified the identity of the bank is not withheld
- B.** Anonymous the identity of the cash holder is not known; Identified the identity of the cash holder is known
- C.** Anonymous the identity of the cash holder is not known; Identified the identity of the merchant is known
- D.** Anonymous the identity of merchant is withheld; Identified the identity of the merchant is not withheld

Answer: B

Explanation:

Anonymous implementations of digital cash do not identify the cash holder and use blind signature schemes; identified implementations use conventional digital signatures to identify the cash holder.

In looking at these two approaches, anonymous schemes are analogous to cash since cash does not allow tracing of the person who made the cash payment while identified approaches are the analog of credit or debit card transactions.

QUESTION NO: 1798

The main objective of the Java Security Model (JSM) is to:

- A. Provide accountability for events
- B. Protect the user from hostile, network mobile code
- C. Protect the local client from user-input hostile code
- D. Protect a web server from hostile, client code

Answer: B

Explanation:

When a user accesses a Web page through a browser, class files for an applet are downloaded automatically, even from untrusted sources. To counter this possible threat, Java provides a customizable sandbox to which the applets' execution is confined. This sandbox provides such protections as preventing reading and writing to a local disk, prohibiting the creation of a new process, prevention of making a network connection to a new host and preventing the loading of a new dynamic library and directly calling a native method. The sandbox security features are designed into the Java Virtual Machine (JVM). These features are implemented through array bounds checking, structured memory access, type-safe reference cast checking to ensure that casting to an object of a different type is valid, and checking for null references and automatic garbage collection. These checks are designed to limit memory accesses to safe, structured operations.

The other answers are distracters.

QUESTION NO: 1799

An audit trail is an example of what type of control?

- A. Application control
- B. Detective control
- C. Deterrent control
- D. Preventative control

Answer: B

Explanation:

The correct answer is Detective control. An audit trail is a record of events to piece together what has happened and allow enforcement of individual accountability by creating a reconstruction of events. They can be used to assist in the proper implementation of the other controls, however.

QUESTION NO: 1800

In a digitally-signed message transmission using a hash function,

- A. The message digest is encrypted in the public key of the sender.
- B. The message digest is encrypted in the private key of the sender.
- C. The message is encrypted in the private key of the sender.
- D. The message is encrypted in the public key of the sender.

Answer: B**Explanation:**

The hash function generates a message digest. The message digest is encrypted with the private key of the sender. Thus, if the message can be opened with the sender's public key that is known to all, the message must have come from the sender. The message is not encrypted with the public key because the message is usually longer than the message digest and would take more computing resources to encrypt and decrypt. Because the message digest uniquely characterizes the message, it can be used to verify the identity of the sender.

Answers "The message digest is encrypted in the public key of the sender" and "The message is encrypted in the public key of the sender" will not work because a message encrypted in the public key of the sender can only be read by using the private key of the sender. Because the sender is the only one who knows this key, no one else can read the message.

Answer "The message is encrypted in the private key of the sender" is incorrect because the message is not encrypted, but the message digest is encrypted.

QUESTION NO: 1801

The MULTICS operating system is a classic example of:

- A. Ring protection system.
- B. Object orientation.
- C. An open system.
- D. Database security.

Answer: A

Explanation:

The correct answer is "Ring protection system". Multics is based on the ring protection architecture.

QUESTION NO: 1802

Which of the following is NOT an advantage of a stream cipher?

- A. The same equipment can be used for encryption and decryption.
- B. It is amenable to hardware implementations that result in higher speeds.
- C. Since encryption takes place bit by bit, there is no error propagation.
- D. The receiver and transmitter must be synchronized.

Answer: D

Explanation:

The transmitter and receiver must be synchronized since they must use the same keystream bits for the same bits of the text that are to be enciphered and deciphered. Usually, synchronizing frames must be sent to effect the synchronization and, thus, additional overhead is required for the transmissions.

* Answer "The same equipment can be used for encryption and decryption" describes an

advantage since stream ciphers commonly use Linear Feedback Shift Registers (LFSRs) to generate the keystream and use XORs to operate on the plaintext input stream.

Because of the characteristics of the XOR, the same XOR gates and LFSRs can also decrypt the message. Since LFSRs and XORs are used in a stream cipher to encrypt and decrypt, these components are amenable to hardware implementation, which means higher speeds of operation. Thus, answer "It is amenable to hardware implementations that result in higher speeds" describes an advantage.

For answer "Since encryption takes place bit by bit, there is no error propagation", stream ciphers encrypt individual bits with no feedback of the generated ciphertext bits and, therefore, errors do not propagate.

QUESTION NO: 1803

The * (star) property of the Biba model states that:

- A.** Subjects cannot read from a higher level of integrity relative to their level of integrity.
- B.** Subjects cannot write to a higher level of integrity relative to their level of integrity.
- C.** Subjects cannot read from a lower level of integrity relative to their level of integrity.
- D.** Subjects cannot write to a lower level of integrity relative to their level of integrity.

Answer: B

Explanation:

QUESTION NO: 1804

The Escrowed Encryption Standard describes the:

- A.** Rijndael Cipher.
- B.** Fair Public Key Cryptosystem.
- C.** Clipper Chip.
- D.** Digital certificates.

Answer: C

Explanation:

QUESTION NO: 1805

Which one of the following is NOT a component of a CC Protection Profile?

- A. Product-specific security requirements
- B. Threats against the product that must be addressed
- C. Security objectives
- D. Target of Evaluation (TOE) description

Answer: A

Explanation:

The correct answer is "Product-specific security requirements". Product-specific security requirements for the product or system are contained in the Security Target (ST). Additional items in the PP are:

TOE security environment description
Assumptions about the security aspects of the product's expected use
Organizational security policies or rules
Application notes
Rationale

QUESTION NO: 1806

What is a programmable logic device (PLD)?

- A. Random Access Memory (RAM) that contains the software to perform specific tasks
- B. An integrated circuit with connections or internal logic gates that can be changed through a programming process
- C. A volatile device
- D. A program resident on disk memory that executes a specific function

Answer: B

Explanation:

- * Answer A volatile device is incorrect because a PLD is non-volatile.
- * Answer "Random Access Memory (RAM) that contains the software to perform specific tasks" is incorrect because random access memory is volatile memory that is not a non-volatile logic device.
- * Answer "A program resident on disk memory that executes a specific function" is a distracter.

QUESTION NO: 1807

Which choice below most accurately describes SSL?

- A.** It's a widely used standard of securing e-mail at the Application level.
- B.** It gives a user remote access to a command prompt across a secure, encrypted session.
- C.** It uses two protocols, the Authentication Header and the Encapsulating Security Payload.
- D.** It allows an application to have authenticated, encrypted communications across a network.

Answer: D

Explanation:

The Secure Socket Layer (SSL) sits between higher-level application functions and the TCP/IP stack and provides security to applications. It includes a variety of encryption algorithms to secure transmitted data, but the functionality must be integrated into the application.

Answer "It's a widely used standard of securing e-mail at the Application level." refers to the Secure/Multipurpose Internet Mail Extension (S/MIME). Most major e-mail clients support S/MIME today.

Answer "It gives a user remote access to a command prompt across a secure, encrypted session." describes Secure Shell (SSH).

Answer "It uses two protocols, the Authentication Header and the Encapsulating Security Payload." refers to IPSec. IPSec enables security to be built directly into the TCP/IP stack, without requiring application modification. Source: Counter Hack by Ed Skoudis (Prentice Hall PTR, 2002).

QUESTION NO: 1808

Processes are placed in a ring structure according to:

- A. Least privilege.
- B. Separation of duty.
- C. First in, first out.
- D. Owner classification.

Answer: A

Explanation:

The correct answer is Least privilege. A process is placed in the ring that gives it the minimum privileges necessary to perform its functions.

QUESTION NO: 1809

Which one of the following is NOT a security mode of operation in an information system?

- A. Contained
- B. System high
- C. Multilevel
- D. Dedicated

Answer: A

Explanation:

The correct answer is Contained, a distracter.

* In the system high mode the information system operates at the highest level of information classification. In this mode, all users must have security clearances for the highest level of classified information.

* Answer the dedicated mode requires that all users must have a clearance or an authorization and a need-to-know for all information that is produced by the information system.

* The multi-level mode of operation, answer c, supports users with different clearances and data at multiple classification levels.

QUESTION NO: 1810

Which of the following is the best example of need-to-know?

- A.** An operator does not know more about the system than the minimum required to do the job.
- B.** An operator cannot generate and verify transactions alone.
- C.** The operators' duties are frequently rotated.
- D.** Two operators are required to work together to perform a task.

Answer: A

Explanation:

The correct answer is "An operator does not know more about the system than the minimum required to do the job". Need-to-know means the operators are working in an environment that limits their knowledge of the system, applications, or data to the minimum elements that they require to perform their job.

* Answer "Two operators are required to work together to perform a task" is dual-control

* "The operators' duties are frequently rotated" is job rotation

* answer "An operator cannot generate and verify transactions alone" is separation of duties.

QUESTION NO: 1811

Which of the following terms is NOT associated with a Read Only

Memory (ROM)?

- A.** Field Programmable Gate Array (FPGA)
- B.** Flash memory
- C.** Firmware
- D.** Static RAM (SRAM)

Answer: D

Explanation:

Static Random Access Memory (SRAM) is volatile and, therefore,

loses its data if power is removed from the system. Conversely, a ROM is nonvolatile in that it does not lose its content when power is removed.

* Flash memories are a type of electrically programmable ROM.

* Answer FPGA is a type of Programmable Logic Device (PLD) that is programmed by blowing fuse connections on the chip or using an antifuse that makes a connection when a high voltage is applied to the junction.

* For answer firmware is a program that is stored on ROMs.

QUESTION NO: 1812

Which one of the following is NOT a typical bus designation in a digital computer?

- A. Control
- B. Address
- C. Data
- D. Secondary

Answer: D

Explanation:

The correct answer is Secondary, a distracter.

QUESTION NO: 1813

Which type of routing below commonly broadcasts its routing table information to all other routers every minute?

- A. Dynamic Control Protocol Routing
- B. Static Routing
- C. Distance Vector Routing
- D. Link State Routing

Answer: C

Explanation:

Distance vector routing uses the routing information protocol (RIP) to maintain a dynamic table of routing information that is updated regularly. It is the oldest and most common type of dynamic routing.

* static routing, defines a specific route in a configuration file on the router and does not require the routers to exchange route information dynamically.

* link state routers, functions like distance vector routers, but only use firsthand information when building routing tables by maintaining a copy of every other router's Link State Protocol (LSP) frame. This helps to eliminate routing errors and considerably lessens convergence time.

*Answer Dynamic Control Protocol Routing is a distracter.

Source: Mastering Network Security by Chris Brenton (Sybex, 1999).

QUESTION NO: 1814

The standard process to certify and accredit

- A. DIACAP
- B. DITSCAP
- C. CIAP
- D. NIACAP
- E. Defense audit

Answer: D

Explanation:

The NIACAP provides a standard set of activities, general tasks, and a management structure to certify and accredit systems that will maintain the information assurance and security posture of a system or site.

The NIACAP is designed to certify that the information system meets documented accreditation requirements and will continue to maintain the accredited security posture throughout the system life cycle.

* Answer CIAP is being developed for the evaluation of critical commercial systems and uses the NIACAP methodology.

* DITSCAP establishes for the defense entities a standard process, set of activities, general task descriptions, and a management structure to

certify and accredit IT systems that will maintain the required security posture. The process is designed to certify that the IT system meets the accreditation requirements and that the system will maintain the accredited security posture throughout the system life cycle. The four phases to the DITSCAP are Definition, Verification, Validation, and Post Accreditation.

* Answer "Defense audit" is a distracter.

* Answer DIACAP is a distracter.

QUESTION NO: 1815

Which LAN topology below is MOST vulnerable to a single point of failure?

- A. FDDI
- B. Physical Star
- C. Logical Ring
- D. Ethernet Bus

Answer: D

Explanation:

Ethernet bus topology was the first commercially viable network topology, and consists of all workstations connected to a single coaxial cable. Since the cable must be properly terminated on both ends, a break in the cable stops all communications on the bus.

* the physical star topology acts like a logical bus, but provides better fault tolerance, as a cable break only disconnects the workstation or hub directly affected.

* logical ring topology, is used by Token Ring and FDDI and is highly resilient. Token Ring employs a beacon frame, which, in case of a cable break, initiates auto reconfiguration and attempts to reroute the network around the failed node. Also, the Token Ring active monitor station performs ring maintenance functions, like removing continuously circulating frames from the ring. FDDI employs a second ring to provide redundancy. Sources: Virtual LANs by Mariana Smith (McGraw-Hill, 1998) and Internetworking Technologies Handbook, Second Edition (Cisco Press, 1998).

QUESTION NO: 1816

Acryptographic attack in which portions of the ciphertext are selected for trial decryption while having access to the corresponding decrypted plaintext is known as what type of attack?

- A. Chosen ciphertext
- B. Adaptive chosen plaintext
- C. Known plaintext
- D. Chosen plaintext

Answer: A

Explanation:

The correct answer is "Chosen ciphertext.

In answer Known plaintext, the attacker has a copy of the plaintext corresponding to the ciphertext.

Answer Chosen plaintext describes the situation where selected plaintext is encrypted and the output ciphertext is obtained. The adaptive chosen plaintext attack, answer "Adaptive chosen plaintext, is a form of chosen plaintext attack where the selection of the plaintext is altered according to previous results.

QUESTION NO: 1817

In communications between two parties, encrypting the hash function of a message with a symmetric key algorithm is equivalent to:

- A. Providing for secrecy of the message
- B. Generating a keyed Message Authentication Code (MAC)
- C. Generating a digital signature
- D. Generating a one-way function

Answer: B

Explanation:

A MAC is used to authenticate files between users. If the sender and receiver both have the secret key, they are the only ones that can verify the hash function. If a symmetric key algorithm is used to encrypt the one-way hash function, then the one-way hash function becomes a keyed MAC.

Answer "Generating a digital signature" is incorrect because a digital signature between two parties

uses an asymmetric key algorithm. If a message is encrypted with the sender's private key, then only the sender's public key can decrypt the message. This proves that the message was sent by the sender since only the sender knows the private key.

In practice, asymmetric key encryption is very slow, especially for long messages. Therefore, a one-way hash of the message is encrypted with the sender's private key instead of encrypting the complete message. Then, the message and the encrypted hash are sent to a second party. The receiver takes the encrypted hash and decrypts it with the sender's public key. Then, the receiver takes the hash of the message, using the same one-way hash algorithm as the sender. The hash generated by the receiver is compared with the decrypted hash sent with the message. If the two hashes are identical, the digital signature is validated. Note that this method also will reveal if the message was changed en route, since the hash calculated by the receiver will, then, be different from the encrypted hash sent along with the message.

Answer "Providing for secrecy of the message" is incorrect since encrypting the hash of the message and sending the message in the clear does nothing to protect the confidentiality of the message. Since the hash function is a one-way function, the message cannot be recovered from its hash.

Answer "Generating a one-way function" is incorrect since encrypting a hash of a message is not a one-way function. If it were, it would be of no use since no one would be able to reverse the process and decrypt it.

QUESTION NO: 1818

Mandatory access controls first appear in the Trusted Computer System

Evaluation Criteria (TCSEC) at the rating of:

- A. D
- B. B
- C. C
- D. A

Answer: B

Explanation:

QUESTION NO: 1819

What is the simple security property of which one of the following models is described as:

A user has access to a client company's information, c, if and only if for all other information, o, that the user can read, either $x(c) \leq z(o)$ or $x(c) = x(o)$, where $x(c)$ is the client's company and $z(o)$ is the competitors of $x(c)$.

- A. Bell-LaPadula
- B. Lattice
- C. Chinese wall
- D. Biba

Answer: C

Explanation:

This model, (D.C. Brewer and M.J. Nash, Chinese Wall Model, Proceedings of the 1989 IEEE Computer Society Symposium on Security and Privacy, 1989), defines rules that prevent conflicts of interest in organizations that may have access to information from companies that are competitors of each other. Essentially, the model states that a user working on one account cannot work on a competitor's account for a designated period of time. Answer the Biba model is an integrity model that is an analog of the Bell-LaPadula confidentiality model of answer Bell-LaPadula.

Answer the lattice refers to the general

information flow model where security levels are represented by a lattice structure. The model defines a transitive ordering relation, , on security classes. Thus, for security classes X, Y, and Z, the ordering relation $X \leq Y \leq Z$ describes the situation where Z is the highest security class and X is the lowest security class, and there is an ordering among the three classes.

QUESTION NO: 1820

Separation of duties embodies what principle?

- A. The operators' duties are frequently rotated.
- B. Two operators are required to work in tandem to perform a task.
- C. The operators have different duties to prevent one person from compromising the system.
- D. An operator does not know more about the system than the minimum required to do the job.

Answer: C

Explanation:

The correct answer is "The operators have different duties to prevent one person from compromising the system". Separation of duties means that the operators are prevented from generating and verifying transactions alone, for example. A task might be divided into different smaller tasks to accomplish this, or in the case of an operator with multiple duties, the operator makes a logical, functional job change when performing such conflicting duties. Answer "An operator does not know more about the system than the minimum required to do the job" is need-to-know, answer "Two operators are required to work in tandem to perform a task" is dual-control, and c is job rotation.

QUESTION NO: 1821

Which firewall type below uses a dynamic state table to inspect the content of packets?

- A. An application-level firewall
- B. A stateful-inspection firewall
- C. A circuit-level firewall
- D. A packet-filtering firewall

Answer: B

Explanation:

A stateful-inspection firewall intercepts incoming packets at the Network level, then uses an Inspection Engine to extract state-related information from upper layers. It maintains the information in a dynamic state table and evaluates subsequent connection attempts.

* packet-filtering firewall is the simplest type of firewall commonly implemented on routers. It operates at the Network layer and offers good performance but is the least secure.

* application-level firewall or application-layer gateway, is more secure because it examines the packet at the application layer, but at the expense of performance.

* circuit-level firewall, is similar to the application-level firewall in that it functions as a proxy server, but differs in that special proxy application software is not needed. Sources: Hacker Proof by Lars Klander (Jamsa Press, 1997) and Checkpoint Firewall-1 Stateful Inspection Technology (www.checkpoint.com).

QUESTION NO: 1822

A 1999 law that addresses privacy issues related to health care, insurance and finance and that will be implemented by the states is:

- A. Kennedy-Kassebaum
- B. Gramm-Leach-Bliley (GLB)
- C. Insurance Reform Act
- D. Medical Action Bill

Answer: B

Explanation:

QUESTION NO: 1823

The termination of selected, non-critical processing when a hardware or software failure occurs and is detected is referred to as:

- A. Fault tolerant.
- B. Fail safe.
- C. An exception.
- D. Fail soft.

Answer: D

Explanation:

QUESTION NO: 1824

How do covert timing channels convey information?

- A. By generating noise and traffic with the data
- B. By modifying the timing of a system resource in some measurable way
- C. By changing a system's stored data characteristics
- D. By performing a covert channel analysis

Answer: B

Explanation:

The correct answer is "By modifying the timing of a system resource in some measurable way". A covert timing channel alters the timing of parts of the system to enable it to be used to communicate information covertly (outside the normal security function).

* Answer "By changing a system's stored data characteristics" is the description of the use of a covert storage channel.

* "By generating noise and traffic with the data" is a technique to combat the use of covert channels.

* Answer "By performing a covert channel analysis" is the Orange Book requirement for B3, B2, and A1 evaluated systems.

QUESTION NO: 1825

A processor in which a single instruction specifies more than one CONCURRENT operation is called:

- A. Pipelined processor.
- B. Very Long Instruction Word processor.
- C. Scalar processor.
- D. Superscalar processor.

Answer: B

Explanation:

The correct answer is Very Long Instruction Word processor.

- * A pipelined processor overlaps the steps of different instructions.
- * Answer a superscalar processor performs a concurrent execution of multiple instructions in the same pipeline stage.
- * A scalar processor executes one instruction at a time.

QUESTION NO: 1826

The definition A relatively small amount (when compared to primary memory) of very high speed RAM, which holds the instructions and data from primary memory, that has a high probability of being accessed during the currently executing portion of a program refers to what category of computer memory?

- A. Secondary
- B. Virtual
- C. Real
- D. Cache

Answer: D

Explanation:

Cache logic attempts to predict which instructions and data in main (primary) memory will be used by a currently executing

program. It then moves these items to the higher speed cache in anticipation of the CPU requiring these programs and data. Properly designed caches can significantly reduce the apparent main memory access time and thus increase the speed of program execution.

* Answer secondary memory is a slower memory (such as a magnetic disk) that provides non-volatile storage.

* Real or primary memory is directly addressable by the CPU and is used for the storage of instructions and data associated with the program that is being executed. This memory is usually high-speed, Random Access Memory (RAM).

* Answer virtual memory uses secondary memory in conjunction with primary memory to present the CPU with a larger, apparent address space of the real memory locations.

QUESTION NO: 1827

A Trusted Computing Base (TCB) is defined as:

- A.** The total combination of protection mechanisms within a computer system that are trusted to enforce a security policy.
- B.** A system that employs the necessary hardware and software assurance measures to enable processing multiple levels of classified or sensitive information to occur.
- C.** The boundary separating the trusted mechanisms from the remainder of the system.
- D.** A trusted path that permits a user to access resources.

Answer: A

Explanation:

* Answer "The boundary separating the trusted mechanisms from the remainder of the system" is the security perimeter.

* Answer "A trusted path that permits a user to access resources" is the definition of a trusted path.

* Answer "A system that employs the necessary hardware and software assurance measures to enable processing multiple levels of classified or sensitive information to occur" is the definition of a trusted computer system.

QUESTION NO: 1828

Increasing performance in a computer by overlapping the steps of different instructions is called:

- A. A reduced instruction set computer.
- B. Pipelining.
- C. A complex instruction set computer.
- D. Vector processing.

Answer: B

Explanation:

QUESTION NO: 1829

The Wired Equivalency Privacy algorithm (WEP) of the 802.11 Wireless LAN Standard uses which of the following to protect the confidentiality of information being transmitted on the LAN?

- A. A digital signature that is sent between a mobile station (e.g., a laptop with a wireless Ethernet card) and a base station access point
- B. A public/private key pair that is shared between a mobile station (e.g., a laptop with a wireless Ethernet card) and a base station access point
- C. A secret key that is shared between a mobile station (e.g., a laptop with a wireless Ethernet card) and a base station access point
- D. Frequency shift keying (FSK) of the message that is sent between a mobile station (e.g., a laptop with a wireless Ethernet card) and a base station access point

Answer: C

Explanation:

The transmitted packets are encrypted with a secret key and an Integrity Check (IC) field comprised of a CRC-32 check sum that is attached to the message. WEP uses the RC4 variable key-size stream cipher encryption algorithm. RC4 was developed in 1987 by Ron Rivest and operates in output feedback mode. Researchers at

the University of California at Berkely (wep@isaac.cs.berkeley.edu)

have found that the security of the WEP algorithm can be compromised, particularly with the following attacks:

Passive attacks to decrypt traffic based on statistical analysis

Active attack to inject new traffic from unauthorized mobile stations, based on known plaintext

Active attacks to decrypt traffic, based on tricking the access point

Dictionary-building attack that, after analysis of about a day's worth of traffic, allows real-time automated decryption of all traffic

The Berkeley researchers have found that these attacks are effective against both the 40-bit and the so-called 128-bit versions of WEP using inexpensive off-the-shelf equipment. These attacks can also be used against networks that use the 802.11b Standard, which is the extension to 802.11 to support higher data rates, but does not change the WEP algorithm.

The weaknesses in WEP and 802.11 are being addressed by the IEEE 802.11i Working Group. WEP will be upgraded to WEP2 with the following proposed changes:

Modifying the method of creating the initialization vector (IV)

Modifying the method of creating the encryption key

Protection against replays

Protection against IV collision attacks

Protection against forged packets

In the longer term, it is expected that the Advanced Encryption Standard (AES) will replace the RC4 encryption algorithm currently used in WEP.

QUESTION NO: 1830

There are two fundamental security protocols in IPSEC. These are the

Authentication Header (AH) and the Encapsulating Security Payload

(ESP). Which of the following correctly describes the functions of each?

- A.** ESP-data encrypting and source authenticating protocol that also validates the integrity of the transmitted data; AH-source authenticating protocol
- B.** ESP-data encrypting and source authenticating protocol; AH-source authenticating protocol that also validates the integrity of the transmitted data
- C.** ESP-data encrypting protocol that also validates the integrity of the transmitted data; AH-source authenticating protocol that also validates the integrity of the transmitted data
- D.** ESP-data encrypting and source authenticating protocol that also validates the integrity of the transmitted data; AH-source authenticating protocol that also validates the integrity of the transmitted data

Answer: D

Explanation:

ESP does have a source authentication and integrity capability through the use of a hash algorithm and a secret key. It provides confidentiality by means of secret key cryptography. DES and triple DES secret key block ciphers are supported by IPSEC and other algorithms will also be supported in the future. AH uses a hash algorithm in the packet header to authenticate the sender and validate the integrity of the transmitted data.

QUESTION NO: 1831

The Secure Hash Algorithm (SHA) is specified in the:

- A.** Data Encryption Standard.
- B.** Advanced Encryption Standard.
- C.** Digital Signature Standard.
- D.** Digital Encryption Standard.

Answer: C

Explanation:

The correct answer is "Digital Signature Standard".

*Answer "Data Encryption Standard" refers to DES, a symmetric encryption algorithm.

* answer "Digital Encryption Standa" is a distracter there is no such term;

* answer "Advanced Encryption Standard" is the Advanced Encryption Standard, which has replaced DES and is now the Rijndael algorithm.

QUESTION NO: 1832

Which of the following is an example of least privilege?

- A. An operator cannot generate and verify transactions alone.
- B. An operator does not have more system rights than the minimum required to do the job.
- C. An operator does not know more about the system than the minimum required to do the job.
- D. The operators' duties are frequently rotated.

Answer: B

Explanation:

Least Privilege embodies the concept that users or operators should be granted the lowest level of system access or system rights that allows them to perform their job.

- * Answer "An operator does not know more about the system than the minimum required to do the job" is need-to-know
- * "The operators' duties are frequently rotated" is job rotation
- * "An operator cannot generate and verify transactions alone" is separation of duties.

QUESTION NO: 1833

What BEST describes the National Security Agency-developed Capstone?

- A. A one-way function for implementation of public key encryption
- B. A device for intercepting electromagnetic emissions
- C. A chip that implements the US Escrowed Encryption Standard
- D. The PC Card implementation of the Clipper Chip system

Answer: C

Explanation:

Capstone is a Very Large Scale Integration (VLSI) chip that employs the Escrowed Encryption Standard and incorporates the Skipjack algorithm, similar to the Clipper Chip. As such, it has a LEAF. Capstone also supports public key exchange and digital signatures. At this time, Capstone products have their LEAF function suppressed and a Certifying Authority provides for key recovery.

*Answer "A device for intercepting electromagnetic emissions" is then, obviously, incorrect. For information purposes, though, the US Government program to study and control the interception of electromagnetic emissions that may compromise classified information is called TEMPEST.

* Answer "The PC Card implementation of the Clipper Chip system" is also, obviously, incorrect. However, Capstone was first implemented on a PC card called Fortezza.

* Answer "A one-way function for implementation of public key encryption" is incorrect since Capstone is not a mathematical function, but it incorporates mathematical functions for key exchange, authentication and encryption.

QUESTION NO: 1834

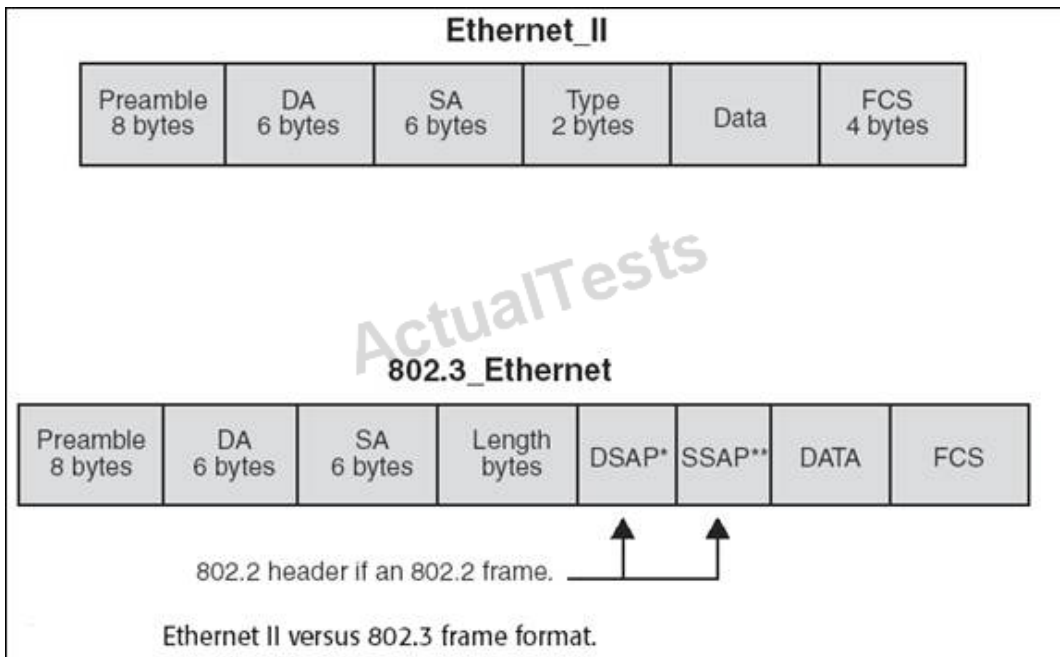
Which statement below is accurate about the difference between Ethernet II and 802.3 frame formats?

- A. 802.3 uses a Length field, whereas Ethernet II uses a Type field.
- B. Ethernet II uses an 8-byte Preamble field, whereas 802.3 uses a 4-byte FCS field.
- C. 802.3 uses a Type field, whereas Ethernet II uses a Length field.
- D. Ethernet II uses a 4-byte FCS field, whereas 802.3 uses an 8-byte Preamble field.

Answer: A

Explanation:

802.3 uses a Length field which indicates the number of data bytes that are in the data field. Ethernet II uses a Type field in the same 2 bytes to identify the message protocol type. Both frame formats use a 8-byte Preamble field at the start of the packet, and a 4-byte Frame Check Sequence (FCS) field at the end of the packet, so



those choices would be incorrect as to a difference in the frame formats.

Sources: Gigabit Ethernet by Jayant Kadambi, Ian Crayford, and Mohan Kalkunte (Prentice Hall PTR, 1998) and CCNA Study Guide by Todd Lammle, Donald Porter, and James Chellis (Sybex, 1999).

QUESTION NO: 1835

The Advanced Encryption Standard (Rijndael) block cipher requirements regarding keys and block sizes have now evolved to which configuration?

- A. Both the key and block sizes can be 128, 192, and 256 bits each.
- B. The block size is 128 bits, and the key size is 128 bits.
- C. The key size is 128 bits, and the block size can be 128, 192, or 256 bits.
- D. The block size is 128 bits, and the key can be 128, 192, or 256 bits.

Answer: D

Explanation:

AES is comprised of the three key sizes, 128, 192, and 256 bits with a fixed block size of 128 bits. The Advanced Encryption Standard

(AES) was announced on November 26, 2001, as Federal Information Processing Standard Publication (FIPS PUB 197). FIPS PUB 197 states that This standard may be used by Federal departments and agencies when an agency determines that sensitive (unclassified) information (as defined in P.L. 100-235) requires cryptographic protection.

Other FIPS-approved cryptographic algorithms may be used in addition to, or in lieu of, this standard. Depending upon which of the three keys is used, the standard may be referred to as AES-128, AES-192 or AES-256.

The number of rounds used in the Rijndael cipher is a function of the key size as follows:

256-bit key 14 rounds

192-bit key 12 rounds

128-bit key 10 rounds

Rijndael has a symmetric and parallel structure that provides for flexibility of implementation and resistance to cryptanalytic attacks.

Attacks on Rijndael would involve the use of differential and linear cryptanalysis.

QUESTION NO: 1836

Which of the following is NOT a characteristic of a cryptographic hash function, $H(m)$, where m denotes the message being hashed by the function H ?

- A. $H(m)$ is a one-way function.
- B. $H(m)$ is difficult to compute for any given m .
- C. The output is of fixed length.
- D. $H(m)$ is collision free.

Answer: B

Explanation:

For a cryptographic hash function, $H(m)$ is relatively easy to compute for a given m .

* Answer " $H(m)$ is collision free" is a characteristic of a good cryptographic

hash function, in that collision free means that for a given message, M , that produces $H(M) = Z$, it is computationally infeasible to find another message, M_1 , such that $H(M_1) = Z$.

* Answer "The output is of fixed length" is part of the definition of a hash function since it generates a fixed-length result that is independent of the length of the input message. This characteristic is useful for generating digital signatures since the signature can be applied to the fixed-length hash that is uniquely characteristic of the message instead of to the entire message, which is usually much longer than the hash.

* Answer "H (m) is a one-way function" relates to answer "H (m) is difficult to compute for any given m" in that a one-way function is difficult or impossible to invert. This means that for a hash function $H(M) = Z$, it is computationally infeasible to reverse the process and find M given the hash Z and the function H .

QUESTION NO: 1837

Elliptic curve cryptosystems:

- A. Cannot be used to implement digital signatures.
- B. Have a higher strength per bit than an RSA.
- C. Cannot be used to implement encryption.
- D. Have a lower strength per bit than an RSA.

Answer: B

Explanation:

The correct answer is "Have a higher strength per bit than an RSA". It is more difficult to compute Elliptic Curve discrete logarithms than conventional discrete logarithms or factoring. Smaller key sizes in the elliptic curve implementation can yield higher levels of security. Therefore, answer "Have a lower strength per bit than an RSA" is incorrect.

Answers "Cannot be used to implement digital signatures" and "Cannot be used to implement encryption" are incorrect because elliptic curve cryptosystems can be used for digital signatures and encryption.

QUESTION NO: 1838

Serial data transmission in which information can be transmitted in two directions, but only one direction at a time, is called:

- A. Synchronized
- B. Full-duplex
- C. Simplex
- D. Half-duplex

Answer: D

Explanation:

The time required to switch transmission directions in a half-duplex line is called the turnaround time.

* Answer simplex refers to communication that takes place in one direction only.

* Answer Synchronized is a distracter.

* Full-duplex can transmit and receive information in both directions simultaneously. The transmissions can be asynchronous or synchronous. In asynchronous transmission, a start bit is used to indicate the beginning of transmission. The start bit is followed by data bits and, then, by one or two stop bits to indicate the end of the transmission. Since start and stop bits are sent with every unit of data, the actual data transmission rate is lower since these overhead bits are used for synchronization and do not carry information. In this mode, data is sent only when it is available and the data is not transmitted continuously. In synchronous transmission, the transmitter and receiver have synchronized clocks and the data is sent in a continuous stream. The clocks are synchronized by using transitions in the data and, therefore, start and stop bits are not required for each unit of data sent.

QUESTION NO: 1839

Which utility below can create a server-spoofing attack?

- A. DNS poisoning
- B. C2MYAZZ
- C. BO2K
- D. Snort

Answer: B

Explanation:

C2MYAZZ is a utility that enables server spoofing to implement a session hijacking or man-in-the-middle exploit. It intercepts a client LANMAN authentication logon and obtains the session's logon credentials and password combination, transparently to the user.

* DNS poisoning is also known as cache poisoning. It is the process of distributing incorrect IP address information for a specific host with the intent to divert traffic from its true destination.

* Snort, is a utility used for network sniffing. Network sniffing is the process of gathering traffic from a network by capturing the data as it passes and storing it to analyze later.

* Back Orifice 2000 (BO2K), is an application-level Trojan Horse used to give an attacker backdoor network access. Source: Security Complete, edited by Mark Lierley (Sybex, 2001).

QUESTION NO: 1840

The Advanced Encryption Standard, the Rijndael cipher, can be described as:

- A. A recursive, sequential cipher
- B. An iterated block cipher
- C. As treaming block cipher
- D. A Feistel network

Answer: B

Explanation:

The correct answer is "An iterated block cipher". Answers A recursive, sequential cipher, A Feistel network, and As treaming block cipher are distracters; however, answer A Feistel network characterizes the Data Encryption Standard (DES) cipher.

QUESTION NO: 1841

The Secure Hash Algorithm (SHA-1) of the Secure Hash Standard (NIST FIPS PUB 180) processes data in block lengths of:

- A. 128 bits.
- B. 256 bits.
- C. 512 bits.
- D. 1024 bits.

Answer: C

Explanation:

The correct answer is 512 bits. If a block length is fewer than 512 bits, padding bits are added to make the block length equal to 512 bits. The other answers are distracters.

QUESTION NO: 1842

What is the block length of the Rijndael Cipher?

- A. 64 bits
- B. 128 bits
- C. 256 bits
- D. Variable

Answer: D

Explanation:

The correct answer is Variable. The other answers with fixed numbers are incorrect.

QUESTION NO: 1843

Which of the following statements BEST describes the Public Key Cryptography Standards (PKCS)?

- A.** A set of public-key cryptography standards that support only standard algorithms such as Diffie-Hellman and RSA
- B.** A set of public-key cryptography standards that support only algorithm-independent implementations
- C.** A set of public-key cryptography standards that support algorithms such as Diffie-Hellman and RSA as well as algorithm independent standards
- D.** A set of public-key cryptography standards that support encryption algorithms such as Diffie-Hellman and RSA, but does not address digital signatures

Answer: C

Explanation:

PKCS supports algorithm-independent and algorithm-specific implementations as well as digital signatures and certificates. It was developed by a consortium including RSA Laboratories, Apple, DEC, Lotus, Sun, Microsoft and MIT. At this writing, there are 15 PKCS standards. Examples of these standards are:

PKCS #1. Defines mechanisms for encrypting and signing data using the RSA public-key system

PKCS #3. Defines the Diffie-Hellman key agreement protocol

PKCS #10. Describes a syntax for certification requests

PKCS #15. Defines a standard format for cryptographic credentials stored on cryptographic tokens

Topic 15, Exam SET C**QUESTION NO: 1844**

Which of the following languages is NOT an object-oriented language?

- A. Lisp
- B. C++
- C. Simula 67
- D. Smalltalk

Answer: A

Explanation:

Lisp, for list processing, is a functional language that processes symbolic expressions rather than numbers. It is used in the artificial intelligence field. The languages cited in the other answers are object-oriented languages.

QUESTION NO: 1845

What does the prudent man rule require?

- A. Senior officials to guarantee that all precautions have been taken and that no breaches of security can occur
- B. Senior officials to post performance bonds for their actions
- C. Senior officials to perform their duties with the care that ordinary, prudent people would exercise under similar circumstances
- D. Senior officials to follow specified government standards

Answer: C

Explanation:

*Answer "Senior officials to post performance bonds for their actions" is a distracter and is not part of the prudent man rule.

* Answer "Senior officials to guarantee that all precautions have been taken and that no breaches of security can occur" is incorrect because it is not possible to guarantee that breaches of security can never occur.

* Answer "Senior officials to follow specified government standards" is incorrect because the prudent man rule does not refer to a specific government standard but relates to what other prudent persons would do.

QUESTION NO: 1846

A standard that uses the Object Request Broker (ORB) to implement exchanges among objects in a heterogeneous, distributed environment is called:

- A.** An Interface Definition Language (IDL)
- B.** Open Architecture
- C.** The Object Management Group (OMG) Object Model
- D.** A Common Object Request Broker Architecture (CORBA)

Answer: D

Explanation:

* the OMG Object Model provides standard means for describing the externally visible characteristics of objects.

*Answer Open Architecture is a distracter.

*IDL is a standard interface language that is used by clients to request services from objects.

QUESTION NO: 1847

Which choice below is the BEST description of the criticality prioritization goal of the Business Impact Assessment (BIA) process?

- A.** The identification and prioritization of every critical business unit process
- B.** The estimation of the maximum down time the business can tolerate
- C.** The presentation of the documentation of the results of the BIA
- D.** The identification of the resource requirements of the critical business unit processes

Answer: A

Explanation:

The correct answer is "The identification and prioritization of every critical business unit process". The three primary goals of a BIA are criticality

prioritization, maximum down time estimation, and identification of critical resource requirements.

*Answer "The presentation of the documentation of the results of the BIA" is a distracter.

QUESTION NO: 1848

Conducting a search without the delay of obtaining a warrant if destruction of evidence seems imminent is possible under:

- A. Exigent Circumstances.
- B. Proximate Causation.
- C. Prudent Man Rule.
- D. Federal Sentencing Guidelines.

Answer: A

Explanation:

The other answers refer to other principles, guidelines, or rules.

QUESTION NO: 1849

Which TCSEC security class category below specifies trusted recovery controls?

- A. B3
- B. C2
- C. B2
- D. B1

Answer: A

Explanation:

TCSEC security categories B3 and A1 require the implementation of trusted recovery. Trusted recovery is the procedures and/or

mechanisms provided to assure that, after an ADP system failure or other discontinuity, recovery without a protection compromise is obtained. A system failure represents a serious security risk because security controls may be bypassed when the system is not functioning normally. Trusted recovery has two primary activities: preparing for a system failure (backup) and recovering the system.
Source: DoD 5200.28-STD Department of Defense Trusted Computer System Evaluation Criteria.

QUESTION NO: 1850

Which of the following would NOT be considered a penetration testing technique?

- A. Sniffing
- B. Scanning
- C. War dialing
- D. Data manipulation

Answer: D

Explanation:

The correct answer is Data manipulation. Data manipulation describes the corruption of data integrity to perform fraud for personal gain or other reasons. External penetration testing should not alter the data in any way. The other three are common penetration techniques.

QUESTION NO: 1851

Which choice below is the BEST description of an audit trail?

- A. Audit trails are used to detect penetration of a computer system and to reveal usage that identifies misuse.

- B.** An audit trail is a device that permits simultaneous data processing of two or more security levels without risk of compromise.
- C.** An audit trail mediates all access to objects within the network by subjects within the network.
- D.** Audit trails are used to prevent access to sensitive systems by unauthorized personnel.

Answer: A

Explanation:

An audit trail is a set of records that collectively provide documentary evidence of processing used to aid in tracing from original transactions forward to related records and reports, and/or backward from records and reports to their component source transactions. Audit trails may be limited to specific events or may encompass all of the activities on a system.

User audit trails can usually log:

All commands directly initiated by the user

All identification and authentication attempts

Files and resources accessed

It is most useful if options and parameters are also recorded from commands. It is much more useful to know that a user tried to delete a log file (e.g., to hide unauthorized actions) than to know the user merely issued the delete command, possibly for a personal data file.

*Answer "An audit trail is a device that permits simultaneous data processing of two or more security levels without risk of compromise." is a description of a multilevel device. A multilevel device is a device that is used in a manner that permits it to process data of two or more security levels simultaneously without risk of compromise. To accomplish this, sensitivity labels are normally

stored on the same physical medium and in the same form (i.e., machine-readable or human-readable) as the data being processed.

*Answer "An audit trail mediates all access to objects within the network by subjects within the network." refers to a network reference monitor, an access control concept that refers to an abstract machine that mediates all access to objects within the network by subjects within the network.

* Answer "Audit trails are used to prevent access to sensitive systems by unauthorized personnel." is incorrect, because audit trails are detective, and the answer describes a preventative process, access control. Source:

NCSC-TG-001 A Guide to Understanding Audit in Trusted Systems
and DoD 5200.28-STD Department of Defense Trusted Computer
System Evaluation Criteria.

QUESTION NO: 1852

In object-oriented programming, when all the methods of one class are passed on to a subclass, this is called:

- A. Delegation
- B. Inheritance
- C. Multiple Inheritance
- D. Forward chaining

Answer: B

Explanation:

In inheritance, all the methods of one class, called a superclass, are inherited by a subclass. Thus, all messages understood by the superclass are understood by the subclass. In other words, the subclass inherits the behavior of the superclass.

*Answer Forward chaining is a distracter and describes data-driven reasoning used in expert systems.

*Multiple inheritance describes the situation where a subclass inherits the behavior of multiple superclasses.

*Answer delegation, is an alternative to inheritance in an object-oriented system. With delegation, if an object does not have a method to satisfy a request it has received, it can delegate the request to another object.

QUESTION NO: 1853

What type of security controls operate on the input to a computing system, on the data being processed, and the output of the system?

- A. Numerical controls
- B. Data controls
- C. Normative controls
- D. Application controls

Answer: D

Explanation:

The correct answer is Application controls. The other answers are distracters.

QUESTION NO: 1854

Which choice below refers to a business asset?

- A. Protection devices or procedures in place that reduce the effects of threats
- B. Events or situations that could cause a financial or operational impact to the organization
- C. Competitive advantage, credibility, or good will
- D. Personnel compensation and retirement programs

Answer: C

Explanation:

Assets are considered the physical and financial assets that are owned by the company. Examples of business assets that could be lost or damaged during a disaster are:

Revenues lost during the incident

On-going recovery costs

Fines and penalties incurred by the event.

Competitive advantage, credibility, or good will damaged by the incident

*Answer "Events or situations that could cause a financial or operational impact to the organization" is a definition for a threat.

*Answer "Protection devices or procedures in place that reduce the effects of threats" is a description of mitigating factors that reduce the effect of a threat, such as a UPS, sprinkler systems, or generators.

*Answer "Personnel compensation and retirement programs" is a distracter. Source: Contingency Planning and Management, Contingency Planning 101 by Kelley Goggins, March, 1999.

QUESTION NO: 1855

A distributed object model that has similarities to the Common Object Request Broker Architecture (CORBA) is:

- A. Distributed Data Model
- B. Inference Model
- C. Distributed Component Object Model (DCOM)
- D. The Chinese Wall Model

Answer: C

Explanation:

DCOM is the distributed version of COM that supports remote objects as if the objects reside in the clients address space. ACOM client can access a COM object through the use of a pointer to one of the objects interfaces and, then, invoking methods through that pointer. As discussed in Question 24, CORBA is a distributed object framework developed by the Object Management Group.

* the Chinese Wall Model (D.C. Brewer & M.J. Nash, Chinese Wall Model, Proceedings of the 1989 IEEE Computer Society Symposium on Security and Privacy, pp. 215-228, 1989), uses internal rules to compartmentalize areas in which individuals may work to prevent disclosure of proprietary information and to avoid conflicts of interest. The Chinese Wall model also incorporates the principle of separation of duty.

* Answers Inference Model and Distributed Data Model are distracters.

QUESTION NO: 1856

The process of analyzing large data sets in a data warehouse to find non-obvious patterns is called:

- A. Data scanning
- B. Data administration
- C. Derived data
- D. Data mining

Answer: D

Explanation:

For example, mining of consumer-related data may show a correlation between the number of children under four years old in a household and the fathers preferences in aftershave lotion.

*Answer Data scanning is a distracter.

*Data administration describes the degree of managements dedication to the data warehouse concept.

*Answer derived data, is data that is obtained through the processing of raw data.

QUESTION NO: 1857

In an expert system, the process of beginning with a possible solution and using the knowledge in the knowledge base to justify the solution based on the raw input data is called:

- A. Forward chaining
- B. Dynamic reasoning
- C. A blackboard solution
- D. Backward chaining

Answer: D

Explanation:

Backward chaining is generally used when there are a large number of possible solutions relative to the number of inputs.

*Answer Dynamic reasoning is a distracter.

Answer forward chaining, is the reasoning approach that can be used when there is a small number of solutions relative to the number of inputs. The input data is used to reason forward to prove that one of the possible solutions in a small solution set is the correct one.

*The blackboard is an expert system reasoning methodology in which a solution is generated by the use of a virtual blackboard wherein information or potential solutions are placed on the blackboard by a plurality of individuals or expert knowledge sources. As more information is placed on the blackboard in an

iterative process, a solution is generated.

QUESTION NO: 1858

Which of the following are valid legal issues associated with computer crime? Select three

- A. It may be difficult to prove criminal intent.
- B. It may be difficult to obtain a trail of evidence of activities performed on the computer.
- C. It may be difficult to show causation.
- D. Electronic Data Interchange (EDI) makes it easier to relate a crime to an individual.

Answer: A,B,C

Explanation:

EDI makes it more difficult to tie an individual to transactions since EDI involves computer-to-computer data interchanges and this makes it more difficult to trace the originator of some transactions.

*Answer "It may be difficult to prove criminal intent" is a valid legal issue since it may be very difficult to prove

criminal intent by a person perusing computer files and then causing damage to the files. The damage may have not been intentional.

*Answer "It may be difficult to obtain a trail of evidence of activities performed on the computer" describes the situation of trying to track activities on a computer where the information is volatile and may have been destroyed.

* In answer "It may be difficult to show causation", common law refers to causation of the criminal act. Causation is particularly difficult to show in instances where a virus or other malicious code erases itself after causing damage to vital information.

QUESTION NO: 1859

The Kennedy-Kassebaum Act is also known as:

- A. HIPAA
- B. RICO
- C. EU Directive
- D. OECD

Answer: A

Explanation:

The others refer to other laws or guidelines.

QUESTION NO: 1860

Which choice below is NOT an element of BCP plan approval and implementation?

- A. Executing a disaster scenario and documenting the results
- B. Obtaining senior management approval of the results
- C. Creating an awareness of the plan
- D. Updating the plan regularly and as needed

Answer: A

Explanation:

Answer "Executing a disaster scenario and documenting the results" is a distracter, although it could be considered a loose description of disaster recovery plan testing.

The other three choices are primary elements of BCP approval, implementation, and maintenance.

QUESTION NO: 1861

Which statement below MOST accurately describes configuration control?

- A. Assuring that only the proposed and approved system changes are implemented
- B. Tracking the status of current changes as they move through the configuration control process
- C. Verifying that all configuration management policies are being followed

D. The decomposition process of a verification system into CIs

Answer: A

Explanation:

Configuration control is a means of assuring that system changes are approved before being implemented, only the proposed and approved changes are implemented, and the implementation is complete and accurate. This involves strict procedures for proposing, monitoring, and approving system changes and their implementation. Configuration control entails central direction of the change process by personnel who coordinate analytical tasks, approve system changes, review the implementation of changes, and supervise other tasks such as documentation.

*Answer "The decomposition process of a verification system into CIs" is configuration identification. The decomposition process of a verification system into Configuration Items (CIs) is called configuration identification. A CI is a uniquely identifiable subset of the system that represents the smallest portion to be subject to independent configuration control procedures.

Answer "Tracking the status of current changes as they move through the configuration control process" is configuration accounting. Configuration accounting documents the status of configuration control activities and, in general, provides the information needed to manage a configuration effectively. It allows managers to trace system changes and establish the history of any developmental problems and associated fixes. Configuration accounting also tracks the status of current changes as they move through the configuration control process. Configuration accounting establishes the granularity of recorded information and thus shapes the accuracy and usefulness of the audit function.

*Answer "Verifying that all configuration management policies are being followed" is configuration audit. Configuration audit is the quality assurance component of configuration management. It involves periodic checks to determine the consistency and completeness of accounting information and to verify that all configuration management policies are being followed. A vendor's configuration management program must be able to sustain a complete configuration audit by an NCSC review team.

Source: NCSC-TG-014, Guidelines for Formal Verification Systems.

QUESTION NO: 1862

Which of the following best defines social engineering?

- A. Gathering information from discarded manuals and printouts
- B. Illegal copying of software
- C. Destruction or alteration of data
- D. Using people skills to obtain proprietary information

Answer: D

Explanation:

Using people skills to obtain proprietary information.

*Answer "Illegal copying of software" is software piracy

* answer "Gathering information from discarded manuals and printouts" is dumpster diving;

*answer "Destruction or alteration of data" is a violation of integrity.

QUESTION NO: 1863

18 USC. §2001 (1994) refers to:

- A. Article 18, US Code, Section 2001, 1994 edition.
- B. Title 18, University of Southern California, Article 2001, 1994 edition.
- C. Title 2001 of the US Code, Section 18, 1994 edition.
- D. Title 18, Section 2001 of the US Code, 1994 edition.

Answer: D

Explanation:

QUESTION NO: 1864

A system that exhibits reasoning similar to that of humans knowledgeable in a particular field to solve a problem in that field is called:

- A. An expert system.

- B. A data warehouse.
- C. A neural network.
- D. A smart system.

Answer: A

Explanation:

Answer a smart system is a distracter.

A data warehouse, is a repository of information from heterogeneous databases that is available to users for making queries.

A neural network is a self-learning system that bases its operation on the model of the functioning of biological neurons.

QUESTION NO: 1865

Which choice below is NOT a recommended step to take when resuming normal operations after an emergency?

- A. Conduct an investigation.
- B. Re-occupy the damaged building as soon as possible.
- C. Account for all damage-related costs.
- D. Protect undamaged property.

Answer: B

Explanation:

Re-occupying the site of a disaster or emergency should not be undertaken until a full safety inspection has been done, an investigation into the cause of the emergency has been completed, and all damaged property has been salvaged and restored. During and after an emergency, the safety of personnel must be monitored, any remaining hazards must be assessed, and security must be maintained at the scene. After all safety precautions have been taken, an inventory of damaged and undamaged property must be done to begin salvage and restoration tasks. Also, the site must not be re-occupied until all investigative processes have been completed. Detailed records must be kept of all disaster-related costs and valuations must be made of the effect of the business interruption. Source: Emergency Management Guide for Business and Industry, Federal Emergency Management Agency,

August 1998.

QUESTION NO: 1866

In the software life cycle, validation:

- A. Refers to the work product satisfying software maturity levels.
- B. Refers to the work product satisfying the real-world requirements and concepts.
- C. Refers to the work product satisfying generally accepted principles.
- D. Refers to the work product satisfying derived specifications.

Answer: B

Explanation:

In the software life cycle, validation is the work product satisfying the real-world requirements and concepts. The other answers are distracters.

QUESTION NO: 1867

What is the responsibility of the contingency planner regarding LAN backup and recovery if the LAN is part of a building server environment?

- A. Recovering client/server systems owned and supported by internal staff
- B. Identifying essential business functions
- C. Classifying the recovery time frame of the business unit LAN
- D. Getting a copy of the recovery procedures from the building server administrator

Answer: D

Explanation:

When any part of the LAN is not hosted internally, and is part of a building server environment, it is the responsibility of the contingency

planner to identify the building server administrator, identify for him the recovery time frame required for your business applications, obtain a copy of the recovery procedures, and participate in the validation of the buildings server testing. If all or part of the business is not in the building server environment, then the other three choices are also the responsibility of the contingency planner. Source: Contingency Planning and Management, Contingency Planning 101, by Kelley Goggins, March 1999.

QUESTION NO: 1868

Which standard defines the International Standard for the Common Criteria?

- A. CSC-STD-002-85
- B. IS15408
- C. BS7799
- D. DoD 5200.28-STD

Answer: B

Explanation:

ISO/IEC 15408-1 is the International Standards version of the Common Criteria. The ISO approved and published the CC text as the new International Standard (IS) 15408 on December 1, 1994. As of this writing the Common Criteria version is 2.1.

Answer b is the Code of Practice for Information Security Management (BS7799) developed by the British Standards Institute.

The BS7799 standard effectively comes in two parts:

ISO/IEC 17799:2000 (Part 1) is the standard code of practice and can be regarded as a comprehensive catalogue of recommended security policy.

BS7799-2:1999 (Part 2) is a standard specification for an Information Security Management System (ISMS). An ISMS is the means by which Senior Management monitors and controls their security, minimizing the residual business risk and ensuring that security continues to fulfill corporate, customer, and legal requirements.⁵

*Answer DoD 5200.28-STD is the Orange Book, the DoD Trusted Computer System Evaluation Criteria.

*Answer CSC-STD-002-85 is the Green Book, the DoD Password Management Guidelines.

Source: The Common Criteria Project.

QUESTION NO: 1869

Which task below would normally be a function of the security administrator, not the system administrator?

- A. Reviewing audit data
- B. Managing print queues
- C. Adding and removing system users
- D. Installing system software

Answer: A

Explanation:

Reviewing audit data should be a function separate from the day-to-day administration of the system.

QUESTION NO: 1870

Which statement below is accurate about the concept of Object Reuse?

- A. Object reuse protects against physical attacks on the storage medium.
- B. Object reuse applies to removable media only.
- C. Object reuse controls the granting of access rights to objects.
- D. Object reuse ensures that users do not obtain residual information from system resources.

Answer: D

Explanation:

Object reuse mechanisms ensure system resources are allocated and reassigned among authorized users in a way that prevents the leak of sensitive information, and ensure that the authorized user of the system does not obtain residual information from system resources. Object reuse is defined as The reassignment to some subject of a storage medium (e.g., page frame, disk sector, magnetic tape) that contained one or more objects. To be securely reassigned, no residual data can be available to the new subject through standard system mechanisms.⁷ The object reuse requirement of the TCSEC is intended to assure that system resources, in particular storage media, are allocated and reassigned among system users in a manner which prevents the disclosure of sensitive information. Answer a is incorrect. Object reuse does not necessarily protect against physical attacks on the storage medium. Answer c is also incorrect, as object reuse applies to all primary and secondary storage media, such as removable media, fixed media, real and virtual main memory (including registers), and cache memory. Answer d refers to authorization, the granting of access rights to a user, program, or process. Source: NCSC-TG-018, A Guide To Understanding Object Reuse in Trusted Systems [Light Blue Book].

QUESTION NO: 1871

Relative to legal evidence, which one of the following correctly describes the difference between an expert and a nonexpert in delivering an opinion?

- A.** An expert can offer an opinion based on personal expertise and facts, but a nonexpert can testify only as to facts.
- B.** A nonexpert can offer an opinion based on personal expertise and facts, but an expert can testify only as to facts.
- C.** An expert can offer an opinion based on personal expertise and facts, but a nonexpert can testify only as to personal opinion.
- D.** An expert can offer an opinion based on facts only, but a nonexpert can testify only as to personal opinion.

Answer: A

Explanation:

The other answers are distracters.

QUESTION NO: 1872

Which choices below are commonly accepted definitions for a disaster? Select three.

- A.** A suddenly occurring event that has a long-term negative impact on social life
- B.** An emergency that is beyond the normal response resources of the entity
- C.** An occurrence or imminent threat to the entity of widespread or severe damage, injury, loss of life, or loss of property
- D.** An occurrence that is outside the normal computing function

Answer: A,B,C

Explanation:

The disaster/emergency management and business continuity community consists of many different types of entities, such as governmental (federal, state, and local), nongovernmental (business and industry), and individuals. Each entity has its own focus and its own definition of a disaster.

The correct answers are examples of these various definitions of disasters.

A very common definition of a disaster is a suddenly occurring or unstoppable developing event that:

Claims loss of life, suffering, loss of valuables, or damage to the environment.

Overwhelms local resources or efforts.

Has a long-term impact on social or natural life that is always negative in the beginning.

Source: NFPA 1600 Standard on Disaster/Emergency Management and Business Continuity, National Fire Protection Association, 2000 edition.

QUESTION NO: 1873

What principle requires corporate officers to institute appropriate protections regarding the corporate intellectual property?

- A. Least privilege
- B. Need-to-know
- C. Separation of duties
- D. Due care

Answer: C

Explanation:

The correct answer is Separation of duties. The Federal Sentencing Guidelines state, The officers must exercise due care or reasonable care to carry out their responsibilities to the organization. The other answers are information security principles but are distracters in this instance.

QUESTION NO: 1874

Which choice below is an example of a potential hazard due to a technological event, rather than a human event?

- A. Enemy attack
- B. Financial collapse
- C. Sabotage
- D. Mass hysteria

Answer: B

Explanation:

A financial collapse is considered a technological potential hazard, the other three are human events. Of the three categories of potential hazards (natural, technological, and human), technological events could include:

Hazard material release (HazMat)

Explosion or fire (non-arson)

Fuel shortage

Structure collapse

Utility failure

Severe air pollution

Source: NFPA 1600 Standard on Disaster/Emergency Management and Business Continuity, National Fire Protection Association, 2000 edition.

QUESTION NO: 1875

In a distributed environment, a surrogate program that performs services in one environment on behalf of a principal in another environment is called:

- A.** A proxy.
- B.** A slave.
- C.** An agent.
- D.** A virtual processor.

Answer: C

Explanation:

The correct answer is An agent.

* Proxy is similar in nature but might hide the characteristics of the principal it is representing.

Answers A slave and A virtual processor are distracters.

QUESTION NO: 1876

When is the disaster considered to be officially over?

- A. When the organization has processing up and running at the alternate site
- B. When all of the elements of the business have returned to normal functioning at the original site
- C. When the danger has passed and the disaster has been contained
- D. When all employees have been financially reimbursed for their expenses

Answer: B

Explanation:

The correct answer is: when all of the elements of the business have returned to normal functioning at the original site. Its important to remember that a threat to continuity exists when processing is being returned to its original site after salvage and cleanup has been done.

QUESTION NO: 1877

What could be a major disadvantage to a mutual aid or reciprocal type of backup service agreement?

- A. The use of prefabricated buildings makes recovery easier.
- B. It is free or at a low cost to the organization.
- C. Annual testing by the Info Tech department is required to maintain the site.
- D. In a major emergency, the site might not have the capacity to handle the operations required.

Answer: D

Explanation:

The site might not have the capacity to handle the operations required during a major disruptive event. While mutual aid might be a good system for sharing resources during a small or isolated outage, a major natural or other type of disaster can create serious resource contention between the two organizations.

QUESTION NO: 1878

Which of the following are computer investigation issues? S

- A. The time frame for investigation is compressed.
- B. An expert may be required to assist.
- C. The information is intangible.
- D. Evidence is easy to obtain.

Answer: A,B,C

Explanation:

In many instances, evidence is difficult to obtain in computer crime investigations.

QUESTION NO: 1879

Which choice below BEST describes a threat as defined in the Operations Security domain?

- A. A potential incident that could cause harm
- B. A weakness in a system that could be exploited
- C. A company resource that could be lost due to an incident
- D. The minimization of loss associated with an incident

Answer: A

Explanation:

Incorrect answer:

- * "A weakness in a system that could be exploited" describes a vulnerability
- * "A company resource that could be lost due to an incident" describes an asset
- * "The minimization of loss associated with an incident" describes risk management.

QUESTION NO: 1880

What key professional or professionals are required to develop an expert system?

- A. Domain expert and object designer
- B. Knowledge engineer and object designer
- C. Knowledge engineer and domain expert
- D. Domain expert

Answer: C

Explanation:

The knowledge engineer usually has a computer-related and expert system background, but does not have the knowledge of the specific discipline or domain being addressed by the expert system. For example, the expert system being developed may be a medical diagnostic system requiring input from diagnostic specialists and other types of physicians. These individuals are the domain experts. It is the job of the knowledge engineer to elicit the critical knowledge from the domain expert and incorporate it into the expert system knowledge base. The term object designer in the answers is a distracter.

QUESTION NO: 1881

Which choice below is NOT a common element of user account administration?

- A. Establishing, issuing, and closing user accounts
- B. Authorizing the request for a users system account
- C. Tracking users and their respective access authorizations
- D. Periodically verifying the legitimacy of current accounts and access authorizations

Answer: B

Explanation:

For proper separation of duties, the function of user account establishment and maintenance should be separated from the function of initiating and authorizing the creation of the account. User account management focuses on identification, authentication, and access authorizations. This is augmented by the process of auditing and otherwise periodically verifying the legitimacy of current accounts and access authorizations. Also, there are considerations involved in the timely modification or removal of access and associated issues for employees who are reassigned, promoted, or terminated, or who retire. Source: National Institute of Standards and Technology, An Introduction to Computer Security: The NIST Handbook Special Publication 800-12.

QUESTION NO: 1882

Which choice does NOT describe an element of configuration management?

- A.** Configuration management reports the status of change processing.
- B.** Configuration management is the decomposition process of a verification system into Configuration Items (CIs).
- C.** Configuration management documents the functional and physical characteristics of each configuration item.
- D.** Configuration management involves information capture and version control.

Answer: B

Explanation:

Configuration management is a discipline applying technical and administrative direction to:

Identify and document the functional and physical characteristics of each configuration item for the system

Manage all changes to these characteristics

Record and report the status of change processing and implementation

Configuration management involves process monitoring, version control, information capture, quality control, bookkeeping, and an organizational framework to support these activities. The configuration

being managed is the verification system plus all tools and documentation related to the configuration process.

Source: NCSC-TG-014-89, Guidelines for Formal Verification Systems [Purple Book].

QUESTION NO: 1883

A database management system (DBMS) is useful in situations where:

- A.** Rapid development of applications is required and preprogrammed functions can be used to provide those applications along with other support features such as security, error recovery, and access control.
- B.** The operations to be performed on the data are modified infrequently and the operations are relatively straightforward.
- C.** Data are processed infrequently and results are not urgently needed.
- D.** Large amounts of data are to be processed in time-critical situations.

Answer: A

Explanation:

A DBMS is called for when the required skilled programming resources are not available, information to be stored and accessed is common to many organizational business units, the processing requirements change frequently and timely responses are required for queries on the data.

QUESTION NO: 1884

In an object-oriented system, the situation wherein objects with a common name respond differently to a common set of operations is called:

- A.** Polyinstantiation.

- B. Delegation.
- C. Polyresponse.
- D. Polymorphism.

Answer: D

Explanation:

Delegation is the forwarding of a request by one object to another object.

Answer Polyresponse is a distracter.

Polyinstantiation is the development of a detailed version of an object from another object. The new object uses values that are different from those in the original object.

QUESTION NO: 1885

The simplistic model of software life cycle development assumes that:

- A. Each phase is identical to a completed milestone.
- B. Iteration will be required among the steps in the process.
- C. Software development requires reworking and repeating some of the phases.
- D. Each step can be completed and finalized without any effect from the later stages that might require rework.

Answer: D

Explanation:

Each step can be completed and finalized without any effect from the later stages that might require rework.

*Answer "Iteration will be required among the steps in the process" is incorrect because no iteration is allowed for in the model.

*Answer "Each phase is identical to a completed milestone" is incorrect because it applies to the modified Waterfall model.

*Answer "Software development requires reworking and repeating some of the phase" is incorrect because no iteration or reworking is considered in the model.

QUESTION NO: 1886

Why are maintenance accounts a threat to operations controls?

- A.** Maintenance might require physical access to the system by vendors or service providers.
- B.** Maintenance accounts are commonly used by hackers to access network devices.
- C.** Maintenance personnel could slip and fall and sue the organization.
- D.** Maintenance account information could be compromised if printed reports are left out in the open.

Answer: B

Explanation:

Maintenance accounts are login accounts to systems resources, primarily networked devices. They often have the factory-set passwords that are frequently distributed through the hacker community.

QUESTION NO: 1887

The security term that is concerned with the same primary key existing at different classification levels in the same database is:

- A.** Polymorphism.
- B.** Inheritance.
- C.** Polyinstantiation.
- D.** Normalization.

Answer: C

Explanation:

The security term that is concerned with the same primary key existing at different classification levels in the same database is polyinstantiation.

Answer Polymorphism is incorrect because polymorphism is defined as objects of many different classes that are related by some common superclass; thus, any object denoted by this name is able to respond to some common set of operations in a different

way.

Answer Normalization is incorrect because normalization refers to removing redundant or incorrect data from a database.

Answer Inheritance is incorrect because inheritance refers to methods from a class inherited by another subclass.

QUESTION NO: 1888

Which general TCSEC security class category describes that mandatory access policies be enforced in the TCB?

Exhibit:

TCSEC Security Evaluation Categories	
CLASS	DESCRIPTION
D:	minimal protection
C:	discretionary protection
C1:	discretionary security protection
C2:	controlled access protection
B:	mandatory protection
B1:	labeled security protection
B2:	structured protection
B3:	security domains
A1:	verified protection

- A. A
- B. B
- C. C
- D. D

Answer: B

Explanation:

The Trusted Computer System Evaluation Criteria [Orange Book] defines major hierarchical classes of security by the letters D (least

secure) through A (most secure):

- D. Minimal protection
- C. Discretionary protection (C1&C2)
- B. Mandatory protection (B1, B2, B3)
- A. Verified protection; formal methods (A1)

Source: DoD 5200.28-STD Department of Defense Trusted Computer System Evaluation Criteria.

QUESTION NO: 1889

What does the Spiral Model depict?

- A.** A spiral that incorporates various phases of software development
- B.** A spiral that models the behavior of biological neurons
- C.** The operation of expert systems
- D.** Information security checklists

Answer: A

Explanation:

The correct answer is a spiral that incorporates various phases of software development. The other answers are distracters.

QUESTION NO: 1890

Which choice describes the Forest Green Book?

- A.** It is a Rainbow series book that defines the secure handling of storage media.
- B.** It is a Rainbow series book that defines guidelines for implementing access control lists.
- C.** It does not exist; there is no Forest Green Book.
- D.** It is a tool that assists vendors in data gathering for certifiers.

Answer: A

Explanation:

The Forest Green book is a Rainbow series book that defines the secure handling of sensitive or classified automated information system memory and secondary storage media, such as degaussers, magnetic tapes, hard disks, floppy disks, and cards. The Forest Green book details procedures for clearing, purging, declassifying, or destroying automated information system (AIS) storage media to prevent data remanence. Data remanence is the residual physical representation of data that has been erased in some way. After storage media is erased there may be some physical characteristics that allow data to be reconstructed.

* Answer "It is a tool that assists vendors in data gathering for certifiers." is the Blue Book, NCSC-TG-019 Trusted Product Evaluation Questionnaire Version-2. The Blue book is a tool to assist system developers and vendors in gathering data to assist evaluators and certifiers assessing trusted computer systems.

* Answer "It is a Rainbow series book that defines guidelines for implementing access control lists." is the Grey/Silver Book, NCSC-TG-020A, the Trusted UNIX Working Group (TRUSIX) Rationale for Selecting Access Control.

The Grey/Silver book defines guidelines for implementing access control lists (ACLs) in the UNIX system. Source: NCSC-TG-025 A Guide to Understanding Data Remanence in Automated Information Systems, NCSC-TG-020A Trusted UNIX Working Group (TRUSIX) Rationale for Selecting Access Control, and NCSC-TG-019 Trusted Product Evaluation Questionnaire Version-2.

QUESTION NO: 1891

Which choice below is incorrect regarding when a BCP, DRP, or emergency management plan should be evaluated and modified?

- A. Annually, in a scheduled review.
- B. Never; once it has been tested it should not be changed.
- C. After an emergency or disaster response.
- D. After training drills, tests, or exercises.

Answer: B

Explanation:

Emergency management plans, business continuity plans, and disaster recovery plans should be regularly reviewed, evaluated, modified, and updated. At a minimum, the plan should be reviewed at an annual audit. It should also be re-evaluated:

After tests or training exercises, to adjust any discrepancies between the test results and the plan

After a disaster response or an emergency recovery, as this is an excellent time to amend the parts of the plan that were not effective

When personnel, their responsibilities, their resources, or organizational structures change, to familiarize new or reorganized personnel with procedures

When policies, procedures, or infrastructures change

Source: Emergency Management Guide for Business and Industry
Federal Emergency Management Agency, August, 1998 and NFPA
1600 Standard on Disaster/Emergency Management and Business
Continuity National Fire Protection Association, 2000 edition.

QUESTION NO: 1892

Which one of the following are recommended practices regarding electronic monitoring of employees email? Select three.

- A.** Inform all that e-mail is being monitored by means of a prominent log-in banner.
- B.** Explain who is authorized to read monitored email.
- C.** Provide individuals being monitored with a guarantee of email privacy.
- D.** Apply monitoring in a consistent fashion.

Answer: A,B,D

Explanation:

No guarantee of e-mail privacy should be provided or implied by the employer.

QUESTION NO: 1893

What is configuration control?

- A.** Identifying and documenting the functional and physical characteristics of each configuration item
- B.** Recording the processing of changes
- C.** Controlling the quality of the configuration management procedures
- D.** Controlling changes to the configuration items and issuing versions of configuration items from the software library

Answer: D

Explanation:

Configuration control is controlling changes to the configuration items and issuing versions of configuration items from the software library.

Answer "Identifying and documenting the functional and physical characteristics of each configuration item" is the definition of configuration identification.

Answer "Recording the processing of changes" is the definition of configuration status accounting, and answer "Controlling the quality of the configuration management procedures" is the definition of configuration audit.

QUESTION NO: 1894

Which statement below is NOT true about the post-disaster salvage team?

- A.** The salvage team identifies sources of expertise to employ in the recovery of equipment or supplies.
- B.** The salvage team may be given the authority to declare when operations can resume at the disaster site.
- C.** The salvage team must return to the site as soon as possible regardless of the residual physical danger.
- D.** The salvage team manages the cleaning of equipment after smoke damage.

Answer: C

Explanation:

Salvage cannot begin until all physical danger has been removed or mitigated and emergency personnel have returned control of the site to the organization.

QUESTION NO: 1895

Which statement is true regarding the disbursement of funds during and after a disruptive event?

- A.** Authorized, signed checks should be stored securely off-site for access by lower-level managers in the event senior-level or financial management is unable to disburse funds normally.
- B.** In the event senior-level or financial management is unable to disburse funds normally, the company will need to file for bankruptcy.
- C.** No one but the finance department should ever disburse funds during or after a disruptive event.
- D.** Because access to funds is rarely an issue during a disaster, no special arrangements need to be made.

Answer: A

Explanation:

QUESTION NO: 1896

When should security isolation of the incident scene start?

- A.** As soon as the disaster plan is implemented
- B.** Immediately after the emergency is discovered
- C.** After all personnel have been evacuated
- D.** When hazardous materials have been discovered at the site

Answer: B

Explanation:

Isolation of the incident scene should begin as soon as the emergency has been discovered. Authorized personnel should attempt

to secure the scene and control access; however, no one should be placed in physical danger to perform these functions. Its important for life safety that access be controlled immediately at the scene, and only by trained personnel directly involved in the disaster response. Additional injury or exposure to recovery personnel after the initial incident must be tightly controlled. Source: Emergency Management Guide for Business and Industry, Federal Emergency Management Agency, August, 1998.

QUESTION NO: 1897

Which choice below is NOT a common example of exercising due care or due diligence in security practices?

- A. Implementing employee casual Friday
- B. Implementing security awareness and training programs
- C. Implementing controls on printed documentation
- D. Implementing employee compliance statements

Answer: A

Explanation:

The correct answer is "Implementing employee casual Friday". The concepts of due care and due diligence require that an organization engage in good security practices relative to industry standards.

QUESTION NO: 1898

Another model that allows two software components to communicate with each other independent of their platforms operating systems and languages of implementation is:

- A. Basic Object Model (BOM)
- B. Sandbox
- C. Common Object Model (COM)
- D. Spiral Model

Answer: C

Explanation:

As in the object-oriented paradigm, COM works with encapsulated objects. Communications with a COM object are through an interface contract between an object and its clients that defines the functions that are available in the object and the behavior of the object when the functions are called.

*Answer a sandbox, is an access control-based protection mechanism. It is commonly applied to restrict the access rights of mobile code that is downloaded from a Web site as an applet. The code is set up to run in a sandbox that blocks its access to the local workstations hard disk, thus preventing the code from malicious activity. The sandbox is usually interpreted by a virtual machine such as the Java Virtual Machine.

*Answer BOM is a distracter.

* Spiral Model refers to the software development life cycle.

QUESTION NO: 1899

Which choice below would NOT be a good reason to test the disaster recovery plan?

- A. Testing allows processing to continue at the database shadowing facility.
- B. Testing prepares and trains the personnel to execute their emergency duties.
- C. Testing identifies deficiencies in the recovery procedures.
- D. Testing verifies the processing capability of the alternate backup site.

Answer: A

Explanation:

The correct answer is "Testing allows processing to continue at the database shadowing facility." It is a distracter. The other three answers are good reasons to test the disaster recovery plan.

QUESTION NO: 1900

In general, computer-based evidence is considered:

- A. Secondary.
- B. Conclusive.
- C. Hearsay.
- D. Circumstantial.

Answer: C

Explanation:

The correct answer is Hearsay. Answer Conclusive refers to incontrovertible evidence; answer Circumstantial refers to inference from other, intermediate facts; and answer Secondary refers to a copy of evidence or oral description of its content.

QUESTION NO: 1901

In general, computer crimes fall into two major categories and two additional related categories. Which of the following categories are of these four? Select three.

- A. Crimes using the computer
- B. Crimes associated with the prevalence of computers
- C. The computer as a target of the crime
- D. Malfeasance by computer

Answer: A,B,C

Explanation:

Malfeasance by computer is an act involving a computer that is technically and ethically improper, but may or may not be illegal. Some of these activities may not be considered illegal by the user and

may be unintentional. Examples of such behavior are:

Using a password that you have been given by someone else to have access to their computer and using that password to view files that were not intended for your perusal

Giving a copy of a software package that you purchased to a member of your family for personal use (In most instances, this is illegal based on software licenses.)

Using the computer at your place of employment to store some information related to an outside business activity

Answers a, b, and d are valid categories of computer crime. The fourth category is a crime where the computer is incidental to other crimes. Examples in these four categories are:

The computer is a target of the crime. Sabotage or theft of intellectual property, disruption of business operations, illegal access to government and personal information, and falsifying or changing records.

Crimes using the computer. Theft of money from financial accounts, credit card fraud, fraud involving stock transfers, billing charges illegally to another party, and telecommunications fraud.

Crimes associated with the prevalence of computers. Violation of copyright restrictions on commercial software packages, software piracy and software counterfeiting.

The computer is incidental to other crimes. (In this category, the crime could be committed without the computer, but the computer permits the crime to be committed more efficiently and in higher volume.) Money laundering, keeping records and books of illegal activity and illegal gambling.

QUESTION NO: 1902

Which choice below most accurately describes a business impact analysis (BIA)?

A. Activities designed to return an organization to an acceptable operating condition

- B.** A management-level analysis that identifies the impact of losing an entity's resources
- C.** A prearranged agreement between two or more entities to provide assistance
- D.** A program that implements the strategic goals of the organization

Answer: B

Explanation:

A business impact analysis (BIA) measures the effect of resource loss and escalating losses over time in order to provide the entity with reliable data upon which to base decisions on hazard mitigation and continuity planning. A BIA is performed as one step during the creation of a Business Continuity Plan (BCP). A common five-step approach to a BCP could consist of:

BCP project scope creation

Business impact assessment

Recovery strategy development

Recovery plan development

Implementation, testing, and maintenance.

Answer a is a definition of a disaster/emergency management program. Answer c describes a mutual aid agreement. Answer d is the definition of a recovery program. Source: NFPA 1600 Standard on Disaster/Emergency Management and Business Continuity, National Fire Protection Association, 2000 edition and Handbook of Information Security Management, by Micki Krause and Harold F. Tipton, Auerback, 1999 edition.

QUESTION NO: 1903

Which statement is accurate about trusted facility management?

- A.** The TCB shall support separate operator and administrator functions for B2 systems and above.
- B.** The role of a security administrator shall be identified and auditable in B2 systems and above.
- C.** The TCB shall support separate operator and administrator functions for C2 systems and above.

D. The role of a security administrator shall be identified and auditable in C2 systems and above.

Answer: A

Explanation:

Trusted Facility Management has two different requirements, one for B2 systems and another for B3 systems. The B2 requirements state: the TCB shall support separate operator and administrator functions.

The B3 requirements are as follows: The functions performed in the role of a security administrator shall be identified. System administrative personnel shall only be able to perform security administrator functions after taking a distinct auditable action to assume the security administrator role on the system. Non-security functions that can be performed in the security administration role shall be limited strictly to those essential to performing the security role effectively.⁶

Source: NCSC-TG-O15, Guide To Understanding Trusted Facility Management [Brown Book].

QUESTION NO: 1904

Which one of the following is NOT one of the maturity levels of the Software Capability Maturity Model (CMM)?

- A.** Fundamental
- B.** Managed
- C.** Defined
- D.** Repeatable

Answer: A

Explanation:

The correct answer is Fundamental, a distracter. The first level of the Software CMM is the Initiating level. At this level, processes are performed on an ad hoc basis.

Answer the Repeatable level is the second maturity level in the model. In the third level, Defined, management practices are institutionalized and technical procedures are integrated into the organizational structure. The Managed level

has both product and processes quantitatively controlled.

The fifth level of the Software CMM is the Optimized level, where continuous process improvement is institutionalized.

QUESTION NO: 1905

Which statement is true regarding company/employee relations during and after a disaster?

- A.** Senior-level executives are the only employees who should receive continuing salaries during the disruptive event.
- B.** The organizations responsibility to the employees families ends when the disaster stops the business from functioning.
- C.** The organization has a responsibility to continue salaries or other funding to the employees and/or families affected by the disaster.
- D.** Employees should seek any means of obtaining compensation after a disaster, including fraudulent ones.

Answer: C

Explanation:

The organization has an inherent responsibility to its employees and their families during and after a disaster or other disruptive event. The company must be insured to the extent it can properly compensate its employees and families. Alternatively, employees do not have the right to obtain compensatory damages fraudulently if the organization cannot compensate.

QUESTION NO: 1906

Which of the following is a key principle in the evolution of computer crime laws in many countries?

- A. The definition of property was extended to include electronic information.
- B. Unauthorized acquisition of computer-based information without the intent to resell is not a crime.
- C. All members of the United Nations have agreed to uniformly define and prosecute computer crime.
- D. Existing laws against embezzlement, fraud, and wiretapping cannot be applied to computer crime.

Answer: A

Explanation:

* Answer "All members of the United Nations have agreed to uniformly define and prosecute computer crime" is incorrect because all nations do not agree on the definition of computer crime and corresponding punishments.

* Answer "Existing laws against embezzlement, fraud, and wiretapping cannot be applied to computer crime" is incorrect because the existing laws can be applied against computer crime.

* Answer "Unauthorized acquisition of computer-based information without the intent to resell is not a crime" is incorrect because in some countries, possession without intent to sell is considered a crime.

QUESTION NO: 1907

An off-the-shelf software package that implements an inference engine, a mechanism for entering knowledge, a user interface, and a system to provide explanations of the reasoning used to generate a solution is called:

- A. A knowledge base
- B. A knowledge acquisition system
- C. An expert system shell
- D. A neural network

Answer: C

Explanation:

An expert system shell provides the fundamental building blocks of an expert system and supports the entering of domain knowledge. Thus, for an application that is not complex and does not require the custom development of the components of an expert system, an

expert system shell is a useful tool that will save development time.

*A knowledge base is a component of an expert system.

*. A neural network is another type of artificial intelligence system that uses the neurons of the brain as a model and solves problems using nonlinear pattern-matching techniques and learning approaches.

*A knowledge acquisition system refers to the means of identifying and acquiring the knowledge to be entered into the knowledge base. In simple terms, it is trying to determine how an expert thinks when developing a solution to a problem.

QUESTION NO: 1908

Which of the following criteria are used to evaluate suspects in the commission of a crime?

- A. Means, Object, and Motive
- B. Motive, Intent, and Ability
- C. Motive, Means, and Opportunity
- D. Means, Intent, and Motive

Answer: C

Explanation:

QUESTION NO: 1909

Which choice below is the correct definition of a Mutual Aid Agreement?

- A. A management-level analysis that identifies the impact of losing an entity's resources
- B. An appraisal or determination of the effects of a disaster on human, physical, economic, and natural resources
- C. Activities taken to eliminate or reduce the degree of risk to life and property
- D. A prearranged agreement to render assistance to the parties of the agreement

Answer: D

Explanation:

A mutual aid agreement is used by two or more parties to provide for assistance if one of the parties experiences an emergency. It is expected that the other parties will assist the affected party in various ways, perhaps by making office space available, or computing time or resources, or supplying manpower if needed. While mutual aid agreements may be a very cost-effective solution for disaster recovery, it does not provide for full operations redundancy. An example of a problem with a total reliance on mutual aid would be the event that affects all parties to the agreement, thereby rendering the agreement useless. While they are an effective means to provide some resources to the organization in an emergency, they in themselves are not a replacement for a full disaster recovery plan, including alternate computer processing sites.

*Answer "A management-level analysis that identifies the impact of losing an entity's resources" describes a business continuity plan.

*Answer "An appraisal or determination of the effects of a disaster on human, physical, economic, and natural resources" describes a damage assessment

*answer "Activities taken to eliminate or reduce the degree of risk to life and property" describes risk mitigation.

Source: NFPA 1600 Standard on Disaster/Emergency Management and Business Continuity, National Fire Protection Association, 2000 edition, and Emergency Management Guide for Business and Industry, Federal Emergency Management Agency, August 1998.

QUESTION NO: 1910

Which of the following would best describe a cold backup site?

- A.** A computer facility available with electrical power and HVAC and some file/print servers, although the applications are not installed or configured and all of the needed workstations may not be on site or ready to begin processing
- B.** A computer facility with no electrical power or HVAC
- C.** A computer facility with electrical power and HVAC but with no workstations or servers on-site prior to the event and no applications

installed

D. A computer facility with electrical power and HVAC, all needed applications installed and configured on the file/print servers, and enough workstations present to begin processing

Answer: C

Explanation:

A computer facility with electrical power and HVAC, with workstations and servers available to be brought on-site when the event begins and no applications installed, is a cold site.

* Answer "A computer facility with electrical power and HVAC, all needed applications installed and configured on the file/print servers, and enough workstations present to begin processing" is a hot site

*answer "A computer facility available with electrical power and HVAC and some file/print servers, although the applications are not installed or configured and all of the needed workstations may not be on site or ready to begin processing" is a warm site. *Answer "A computer facility with no electrical power or HVAC" is just an empty room.

QUESTION NO: 1911

According to the Internet Activities Board (IAB), an activity that causes which of the following is considered a violation of ethical behavior on the Internet?

- A.** Wasting resources
- B.** Using a computer to bear false witness
- C.** Using a computer to steal
- D.** Appropriating other peoples intellectual output

Answer: A

Explanation:

The correct answer is Wasting resources.

The other answers are ethical considerations of other organizations.

QUESTION NO: 1912

Which choices below are roles or responsibility of the person designated to manage the contingency planning process? Select three

- A. Providing direction to senior management
- B. Ensuring the identification of all critical business functions
- C. Integrating the planning process across business units
- D. Providing stress reduction programs to employees after an event

Answer: A,B,C

Explanation:

Contingency planners have many roles and responsibilities when planning business continuity, disaster recovery, emergency management, or business resumption processes. In addition to correct answers some of these roles and responsibilities can include:

Ensuring executive management compliance with the contingency plan program

Providing periodic management reports and status

Coordinating and integrating the activation of emergency response organizations

Answer "Providing stress reduction programs to employees after an event", providing stress reduction programs to employees after an event, is a responsibility of the human resources area.

Source: Contingency

Planning and Management, Contingency Planning 101, by Kelley Goggins, March 1999.

QUESTION NO: 1913

Which of the following is NOT considered a natural disaster?

- A. Flood
- B. Tsunami
- C. Earthquake

D. Sabotage

Answer: D

Explanation:

QUESTION NO: 1914

Which choice below is the BEST description of a Protection Profile (PP), as defined by the Common Criteria (CC)?

- A.** A reusable definition of product security requirements
- B.** An intermediate combination of security requirement components
- C.** A statement of security claims for a particular IT security product
- D.** The IT product or system to be evaluated

Answer: A

Explanation:

The Common Criteria (CC) is used in two ways:

As a standardized way to describe security requirements for IT products and systems

As a sound technical basis for evaluating the security features of these products and systems

The CC defines three useful constructs for building IT security requirements: the Protection Profile (PP), the Security Target (ST), and the Package. The PP is an implementation-independent statement of security needs for a set of IT security products. The PP contains a set of security requirements and is intended to be a reusable definition of product security requirements that are known to be useful and effective. APP gives consumers a means of referring to a specific set of security needs and communicating them to manufacturers and helps future product evaluation against those needs.

Answer a defines the Security Target (ST). The ST is a statement of security claims for a particular IT security product or system. The ST parallels the structure of the PP, though it has additional elements that include product-specific detailed information. An ST is the basis for agreement among all parties as to what security the product or system offers, and therefore the basis for its security evaluation.

*Answer "An intermediate combination of security requirement components" describes the Package. The Package is an intermediate

combination of security requirements components. The package permits the expression of a set of either functional or assurance requirements that meet some particular need, expressed as a set of security objectives.

*Answer "The IT product or system to be evaluated" describes the Target of Evaluation (TOE).

The TOE is an IT product or system to be evaluated, the security characteristics of which are described in specific terms by a corresponding ST, or in more general terms by a PP. This evaluation consists of rigorous analysis and testing performed by an accredited, independent laboratory. The scope of a TOE evaluation is set by the Evaluation Assurance Level (EAL) and other requirements specified in the ST. Part of this process is an evaluation of the ST itself, to ensure that it is correct, complete, and internally consistent and can be used as the baseline for the TOE evaluation.

Source: Common Criteria Project.

QUESTION NO: 1915

Which choice below best describes the function of change control?

- A. To assign parts of security-sensitive tasks to more than one individual
- B. To ensure that system changes are implemented in an orderly manner
- C. To guarantee that an operator is only given the privileges needed for the task
- D. To guarantee that transaction records are retained IAW compliance requirements

Answer: B

Explanation:

The correct answer is "To ensure that system changes are implemented in an orderly manner".

Answer "To guarantee that an operator is only given the privileges needed for the task" describes least privilege.

Answer "To guarantee that transaction records are retained IAW compliance requirements" describes record retention.

Answer "To assign parts of security-sensitive tasks to more than one individual" describes separation on duties.

QUESTION NO: 1916

Which choice below represents the most important first step in creating a business resumption plan?

- A. Analyzing the business impact
- B. Obtaining senior management support
- C. Performing a risk analysis
- D. Planning recovery strategies

Answer: B

Explanation:

The business resumption, or business continuity plan, must have total, highly visible senior management support. Senior management must agree on the scope of the project, delegate resources for the success of the project, and support the timeline and training efforts.

Source: Contingency Planning and Management, Contingency Planning 101, by Kelley Goggins, March 1999.

QUESTION NO: 1917

A pen register is a:

- A. Device that records the caller-ID of incoming calls
- B. Device that records the URLs accessed by an individual
- C. Device that identifies the cell in which a mobile phone is operating
- D. Device that records all the numbers dialed from a specific telephone line

Answer: D

Explanation:

(Electronic Privacy Information Center, Approvals for Federal Pen Registers and Trap and Trace Devices 1987-1998, www.epic.org). Gathering information as to which numbers are dialed from a

specific telephone line is less costly and time-consuming than installing a wiretap and recording the information.

* There is also equipment that can record the information listed in answers "Device that identifies the cell in which a mobile phone is operating" and "Device that records the URLs accessed by an individual".

* The device referred to in answer "Device that records the caller-ID of incoming calls" is called a trap-and-trace device.

All of the answers in this question are a subset of the category of traffic analysis wherein patterns and frequency associated with communications are studied instead of the content of the communications.

QUESTION NO: 1918

In an object-oriented system, polymorphism denotes:

- A.** Objects of many different classes that are unrelated but respond to some common set of operations in the same way.
- B.** Objects of many different classes that are related by some common superclass; thus, all objects denoted by this name can respond to some common set of operations in identical fashion.
- C.** Objects of many different classes that are related by some common superclass; thus, any object denoted by this name can respond to some common set of operations in a different way.
- D.** Objects of the same class; thus, any object denoted by this name can respond to some common set of operations in the same way.

Answer: C

Explanation:

Objects of many different classes that are related by some common superclass that are able to respond to some common set of operations in a different way.

The other answers are incorrect by the definition of polymorphism.

QUESTION NO: 1919

Because the development of new technology usually outpaces the law, law enforcement uses which traditional laws to prosecute computer criminals?

- A. Conspiracy and elimination of competition
- B. Immigration
- C. Embezzlement, fraud, and wiretapping
- D. Malicious mischief

Answer: C

Explanation:

*Answer Malicious mischief is not a law

*answer Immigration is not applicable because it applies to obtaining visas and so on

*answer Conspiracy and elimination of competition is not correct because the crimes in answer "Embezzlement, fraud, and wiretapping" are more commonly used to prosecute computer crimes.

QUESTION NO: 1920

Which statement below is NOT correct about reviewing user accounts?

- A. User account reviews can examine conformity with the concept of least privilege.
- B. User account reviews cannot be conducted by outside auditors.
- C. User account reviews may be conducted on a system-wide basis.
- D. User account reviews may be conducted on an application-byapplication basis.

Answer: B

Explanation:

It is necessary to regularly review user accounts on a system. Such reviews may examine the levels of access each individual has, conformity with the concept of least privilege, whether all accounts are still active, whether management authorizations are up-to-date, or whether required training has been completed, for example. These reviews can be conducted on at least two levels: on an application-byapplication basis or on a systemwide basis. Both kinds of reviews can be conducted by, among others, in-house systems personnel (a selfaudit),

the organizations internal audit staff, or external auditors.

Source: National Institute of Standards and Technology, An Introduction to Computer Security: The NIST Handbook Special Publication 800-12.

QUESTION NO: 1921

The Federal Sentencing Guidelines:

- A.** Established a category of sensitive information called Sensitive But Unclassified (SBU).
- B.** Prohibit altering, damaging, or destroying information in a federal interest computer.
- C.** Hold senior corporate officers personally liable if their organizations do not comply with the law.
- D.** Prohibit eavesdropping or the interception of message contents.

Answer: C

Explanation:

*Answer "Prohibit altering, damaging, or destroying information in a federal interest computer" is part of the US Computer Fraud and Abuse Act.

* Answer "Prohibit eavesdropping or the interception of message contents" is part of the US Electronic Communications Privacy Act.

Answer "Established a category of sensitive information called Sensitive But Unclassified (SBU)" is part of the US Computer Security Act.

QUESTION NO: 1922

In the software life cycle, verification:

- A.** Evaluates the product in development against the specification.
- B.** Evaluates the product in development against real-world requirements.
- C.** Evaluates the product in development against similar products.
- D.** Evaluates the product in development against general baselines.

Answer: A

Explanation:

In the software life cycle, verification evaluates the product in development against the specification.

Answer "Evaluates the product in development against real-world requirements" defines validation.

QUESTION NO: 1923

Inappropriate computer activities could be described as:

- A.** Data scavenging through the resources available to normal system users.
- B.** Theft of information or trade secrets for profit or unauthorized disclosure.
- C.** Computer behavior that might be grounds for a job action or dismissal.
- D.** Loss incurred unintentionally though the lack of operator training.

Answer: C

Explanation:

The correct answer is "Computer behavior that might be grounds for a job action or dismissal".

While all of the activities described are considered in the broad category of inappropriate activities, this description is used to define a narrower category of inappropriate activities.

Answer "Loss incurred unintentionally though the lack of operator training." is defined as accidental loss.

Answer "Theft of information or trade secrets for profit or unauthorized disclosure." is considered intentionally illegal computer activity.

Answer "Data scavenging through the resources available to normal system users." is a keyboard attack, a type of data scavenging attack using common tools or utilities available to the user.

QUESTION NO: 1924

What does normalizing data in a data warehouse mean?

- A. Data is restricted to a range of values.
- B. Numerical data is divided by a common factor.
- C. Data is converted to a symbolic representation.
- D. Redundant data is removed.

Answer: D

Explanation:

The correct answer is removing redundant data.

QUESTION NO: 1925

Which of the following is NOT a component of configuration management?

- A. Configuration control
- B. Configuration status accounting
- C. Configuration review
- D. Configuration audit

Answer: C

Explanation:

The correct answer is "Configuration review", a distracter.

*Answer configuration control involves controlling changes to configuration items and issuing versions of configuration items from the software library.

*Configuration status accounting is the processing of changes.

* Configuration audit is the process of controlling the quality of configuration management procedures.

QUESTION NO: 1926

The Common Object Model (COM) that supports the exchange of objects among programs was formerly known as:

- A. An Object Request Broker (ORB).
- B. The Distributed Common Object Model (DCOM).
- C. Object Rationalization and Linking (ORL).
- D. Object Linking and Embedding (OLE).

Answer: D

Explanation:

The correct answer is OLE. Answer DCOM defines the standard for sharing objects in a networked environment. Answer ORL is a distracter. An ORB is a locator and distributor of objects across networks.

QUESTION NO: 1927

What is a neural network?

- A. A series of networked PCs performing artificial intelligence tasks
- B. A hardware or software system that emulates the functioning of biological neurons
- C. A collection of computers that are focused on medical applications
- D. A hardware or software system that emulates the reasoning of a human expert

Answer: B

Explanation:

A neural network is a hardware or software system that emulates the functioning of biological neurons.

Answer "A hardware or software system that emulates the reasoning of a human expert" refers to an expert system. The other answers are distracters.

QUESTION NO: 1928

Why is it so important to test disaster recovery plans frequently?

- A. Natural disasters can change frequently.

- B. The businesses that provide subscription services might have changed ownership.
- C. Employees might get bored with the planning process.
- D. A plan is not considered viable until a test has been performed.

Answer: D

Explanation:

A plan is not considered functioning and viable until a test has been performed. An untested plan sitting on a shelf is useless and might even have the reverse effect of creating a false sense of security. While the other answers are good reasons to test, they are not the primary reason.

QUESTION NO: 1929

The Object Request Architecture (ORA) is a high-level framework for a distributed environment. It consists of four components. Which of the following items is NOT one of those components?

- A. Object Services
- B. Application Objects
- C. Application Services
- D. Object Request Brokers (ORBs)

Answer: C

Explanation:

The other answers plus Common Facilities comprise the ORA. The ORA is a product of the Object Management Group (OMG), which is a nonprofit consortium in Framingham, Massachusetts that was put together in 1989 to promote the use of object technology in distributed computing systems (www.omg.org).

*The ORB is the fundamental building block of ORA and manages the communications between the ORA entities. The purpose of the ORB is to support the interaction of objects in heterogeneous, distributed environments.

The objects may be on different types of computing platforms.

*Object Services, supports the ORB in creating and tracking objects as well as performing access control functions.

*Application Objects and Common Facilities support the end user and use the system services to perform their functions.

QUESTION NO: 1930

Which of the following is NOT a Software CMM maturity level?

- A. Initial
- B. Behavioral
- C. Managed
- D. Repeatable

Answer: B

Explanation:

The word behavioral is a distracter. The five software process maturity levels are:

Initial the software process is ad hoc and most processes are undefined.

Repeatable fundamental project management processes are in place.

Defined the software process for both management and engineering functions is documented, standardized, and integrated into the organization.

Managed the software process and product quality are measured, understood, and controlled.

Optimizing continuous process improvement is being performed.

QUESTION NO: 1931

If C represents the cost of instituting safeguards in an information system and L is the estimated loss resulting from exploitation of the

corresponding vulnerability, a legal liability exists if the safeguards are not implemented when:

- A. $C/L = \text{a constant}$
- B. $C > L$
- C. $C < L$
- D. $C = 2L$

Answer: C

Explanation:

The correct answer is $C < L$. If the cost to implement the safeguards is less than the estimated loss that would occur if the corresponding vulnerability were successfully exploited, then a legal liability exists. The other answers are distracters.

QUESTION NO: 1932

Which of the following is NOT considered an element of a backup alternative?

- A. Remote journaling
- B. Warm site
- C. Electronic vaulting
- D. Checklist

Answer: D

Explanation:

The correct answer is Checklist. A checklist is a type of disaster recovery plan test. Electronic vaulting is the batch transfer of backup data to an off-site location. Remote journaling is the parallel processing of transactions to an alternate site. A warm site is a backup processing alternative.

QUESTION NO: 1933

In configuration management, what is a software library?

- A.** A controlled area accessible only to approved users who are restricted to the use of an approved procedure
- B.** A set of versions of the component configuration items
- C.** A collection of software build lists
- D.** A repository of backup tapes

Answer: A

Explanation:

In configuration management, a software library is a controlled area accessible only to approved users who are restricted to the use of approved procedure.

Answer "A set of versions of the component configuration items" is incorrect because it defines a build list.

Answer "A repository of backup tapes" is incorrect because it defines a backup storage facility.

Answer "A collection of software build lists" is a distracter.

QUESTION NO: 1934

The European Union (EU) has enacted a Conditional Access Directive (CAD) that addresses which of the following?

- A.** Access to and use of copyrighted material
- B.** Unauthorized access to Internet subscription sites and pay TV services
- C.** Reverse engineering
- D.** Use of copyrighted material by libraries

Answer: B

Explanation:

The focus of the CAD is on access to services as opposed to access to works. As of this writing, the EU is discussing a directive focusing on copyrights, but it has not been finalized. It is anticipated that this directive will be similar to the US DMCA (Question 7).

The other answers are copyright issues that will be addressed by the EU Copyright Directive or by other related directives.

QUESTION NO: 1935

Which choice below is NOT considered an appropriate role for senior management in the business continuity and disaster recovery process?

- A. Delegate recovery roles
- B. Closely control media and analyst communications
- C. Publicly praise successes
- D. Assess the adequacy of information security during the disaster recovery

Answer: D

Explanation:

The tactical assessment of information security is a role of information management or technology management, not senior management. In addition to the elements of answers a, b, and c above, senior management has many very important roles in the process of disaster recovery, including:

Remaining visible to employees and stakeholders

Directing, managing, and monitoring the recovery

Rationally amending business plans and projections

Clearly communicating new roles and responsibilities

Senior management must resist the temptation to participate handson in the recovery effort, as these efforts should be delegated.

Information or technology management has more tactical roles to play, such as:

Identifying and prioritizing mission-critical applications

Continuously reassessing the recovery sites stability

Recovering and constructing all critical data

Source: Business Recovery Checklist, KPMG LLP 2001.

QUESTION NO: 1936

Cyclic redundancy checks, structured walkthroughs, and hash totals are examples of what type of application controls?

- A. Corrective consistency controls
- B. Preventive security controls
- C. Preventive consistency controls
- D. Detective accuracy controls

Answer: D

Explanation:

Cyclic redundancy checks, structured walkthroughs, and hash totals are examples of detective accuracy controls. The other answers do not apply by the definition of the types of controls.

QUESTION NO: 1937

Which choice below is NOT an example of intentionally inappropriate operator activity?

- A. Using unauthorized access levels to violate information confidentiality
- B. Making errors when manually inputting transactions
- C. Using the companys system to store pornography
- D. Conducting private business on the company system

Answer: B

Explanation:

While "Making errors when manually inputting transactions" is most certainly an example of a threat to a systems integrity, it is considered unintentional loss, not an intentional activity.

QUESTION NO: 1938

Which choices below are considered an appropriate roles for Financial Management in the business continuity and disaster recovery process? Select three

- A.** Tracking the recovery costs
- B.** Monitoring employee morale and guarding against employee burnout
- C.** Reassessing cash flow projections
- D.** Formally notifying insurers of claims

Answer: A,C,D

Explanation:

Monitoring employee morale and guarding against employee burnout during a disaster recovery event is the proper role of human resources. Other emergency recovery tasks associated with human resources could include:

Providing appropriate retraining

Monitoring productivity of personnel

Providing employees and family with counseling and support

In addition to the correct answers above, during an emergency, the financial area is responsible for:

Re-establishing accounting processes, such as payroll, benefits, and accounts payable

Re-establishing transaction controls and approval limits

Source: Business Recovery Checklist, KPMG LLP 2001, and Contingency Planning and Management, Contingency Planning 101, by Kelley Goggins, March 1999.

QUESTION NO: 1939

Which statement below is the most accurate about the results of the disaster recovery plan test?

- A.** The plan should not be changed no matter what the results of the test.
- B.** If no deficiencies were found during the test, then the plan is probably perfect.

- C. The results of the test should be kept secret.
- D. If no deficiencies were found during the test, then the test was probably flawed.

Answer: D

Explanation:

The purpose of the test is to find weaknesses in the plan. Every plan has weaknesses. After the test, all parties should be advised of the results and the plan updated to reflect the new information.

QUESTION NO: 1940

Which choice below would NOT be a common element of a transaction trail?

- A. Why the transaction was processed
- B. The date and time of the transaction
- C. Who processed the transaction
- D. At which terminal the transaction was processed

Answer: A

Explanation:

Why the transaction was processed is not initially a concern of the audit log, but we will investigate it later. The other three elements are all important information that the audit log of the transaction should record.

QUESTION NO: 1941

In 1996, the World Intellectual Property Organization (WIPO) sponsored

a treaty under which participating countries would standardize treatment of digital copyrights. One of the items of standardization was the prohibition of altering copyright management information (CMI) that is included with the copyrighted material. CMI is:

- A. Licensing and ownership information
- B. A listing of Public keys
- C. An encryption algorithm
- D. Product description information

Answer: A

Explanation:

The other answers are distracters. The WIPO digital copyright legislation that resulted in the US was the 1998 Digital Millennium Copyright Act (DMCA). In addition to addressing answer d, the DMCA prohibits trading, manufacturing, or selling in any way that is intended to bypass copyright protection mechanisms. It also addresses Internet Service Providers (ISPs) that unknowingly support the posting of copyrighted material by subscribers. If the ISP is notified that the material is copyrighted, the ISP must remove the material. Additionally, if the posting party proves that the removed material was of lawful use, the ISP must restore the material and notify the copyright owner within 14 business days.

Two important rulings regarding the DMCA were made in 2001. The rulings involved DeCSS, which is a program that bypasses the Content Scrambling System (CSS) software used to prevent viewing of DVD movie disks on unlicensed platforms. In a trade secrecy case [DVD-CCA v. Banner], the California Appellate Court overturned a lower court ruling that an individual who posted DeCSS on the Internet had revealed the trade secret of CSS. The appeals court has reversed an injunction on the posting of DeCSS, stating that the code is speech-protected by the First Amendment.

The second case [Universal City v. Reimerdes] was the first constitutional challenge to DMCA anti-circumvention rules. The case involved Eric Corley, the publisher of the hacker magazine 2600 Magazine. Corley was covering the DeCSS situation and, as part of that coverage, posted DeCSS on his publications Web site. The trial and appellate courts both ruled that the posting violated the DMCA and was, therefore, illegal. This ruling upheld the DMCA. It appears that there will be more challenges to DMCA in the future.

QUESTION NO: 1942

When should the public and media be informed about a disaster?

- A.** When any emergency occurs at the facility, internally or externally
- B.** When the public's health or safety is in danger
- C.** When the disaster has been contained
- D.** Whenever site emergencies extend beyond the facility

Answer: D

Explanation:

When an emergency occurs that could potentially have an impact outside the facility, the public must be informed, regardless of whether there is any immediate threat to public safety. The disaster recovery plan should include determinations of the audiences that may be affected by an emergency, and procedures to communicate with them. Information the public will want to know could include public safety or health concerns, the nature of the incident, the remediation effort, and future prevention steps. Common audiences for information could include:

The media

Unions and contractors

Shareholders

Neighbors

Employees families and retirees

Since the media is such an important link to the public, disaster plans and tests must contain procedures for addressing the media and communicating important information. A trained spokesperson should be designated, and established communications procedures should be prepared. Accurate and approved information should be released in a timely manner, without speculation, blame, or obfuscation. Source: Emergency Management Guide for Business and Industry, Federal Emergency Management Agency, August, 1998.

QUESTION NO: 1943

Which choices below are valid reasons for testing the disaster recovery plan? Select three

- A.** Testing verifies the accuracy of the recovery procedures.
- B.** Testing identifies deficiencies within the recovery procedures.
- C.** Testing provides the contingency planner with recent documentation.
- D.** Testing prepares the personnel to properly execute their emergency duties.

Answer: A,B,D

Explanation:

The correct answers are all excellent reasons for testing a disaster recovery plan. Until a disaster recovery plan has been tested thoroughly, no plan can be considered complete. Since the functionality of the plan directly determines the ability of an organization to survive a business interrupting event, testing is the only way to have some degree of confidence that the plan will work.

*Answer "Testing provides the contingency planner with recent documentation" is a distracter.
Source: The International Handbook of Computer Security, by Jae K. Shim, Anique A. Qureshi, and Joel G. Siegel (The Glenlake Publishing Co. Ltd, 2000).

QUESTION NO: 1944

The definition the science and art of specifying, designing, implementing and evolving programs, documentation and operating procedures whereby computers can be made useful to man is that of:

- A.** Functional programming
- B.** Software engineering
- C.** Structured analysis/structured design (SA/SD)
- D.** An object-oriented system

Answer: B

Explanation:

This definition of software engineering is a combination of popular definitions of engineering and software. One definition of engineering is the application of science and mathematics to the design and construction of artifacts which are useful to man. A definition of software is that it consists of the programs, documentation and operating procedures by which computers can be made useful to man.

*Answer SA/SD deals with developing specifications that are abstractions of the problem to be solved and not tied to any specific programming languages.

Thus, SA/SD, through data flow diagrams (DFDs), shows the main processing entities and the data flow between them without any connection to a specific programming language implementation.

*An object-oriented system is a group of independent objects that can be requested to perform certain operations or exhibit specific behaviors. These objects cooperate to provide the systems required functionality. The objects have an identity and can be created as the program executes (dynamic lifetime). To provide the desired characteristics of object-oriented systems, the objects are encapsulated, i.e., they can only be accessed through messages sent to them to request performance of their defined operations. The object can be viewed as a black box whose internal details are hidden from outside observation and cannot normally be modified. Objects also exhibit the substitution property, which means that objects providing compatible operations can be substituted for each other. In summary, an object-oriented system contains objects that exhibit the following properties:

Identity each object has a name that is used to designate that object.

Encapsulation an object can only be accessed through messages to perform its defined operations.

Substitution objects that perform compatible operations can be substituted for each other.

Dynamic lifetimes objects can be created as the program executes.

*Answer functional programming uses only mathematical functions to perform computations and solve problems. This approach is based on the assumption that any algorithm can be described as a mathematical function. Functional languages have the characteristics that:

They support functions and allow them to be manipulated by being passed as arguments and stored in data structures.

Functional abstraction is the only method of procedural abstraction.

QUESTION NO: 1945

Discovery, recording, collection, and preservation are part of what process related to the gathering of evidence?

- A. The chain of evidence
- B. Admissibility of evidence
- C. Relevance of evidence
- D. The evidence life cycle

Answer: D

Explanation:

The correct answer is The evidence life cycle. The evidence life cycle covers the evidence gathering and application process.

* Answer "Admissibility of evidence" refers to certain requirements that evidence must meet to be admissible in court.

* Answer "The chain of evidence" the chain of evidence, is comprised of steps that must be followed to protect the evidence.

* Relevance of evidence is one of the requirements of evidence admissibility.

QUESTION NO: 1946

A device that is used to monitor Internet Service Provider (ISP) data traffic is called:

- A. Carnivore
- B. Escrowed encryption
- C. Echelon
- D. Key manager

Answer: A

Explanation:

Carnivore is a device used by the US FBI to monitor ISP traffic. (S.P. Smith, et. al., Independent Technical Review of the Carnivore System Draft report, US Department of Justice Contract # 00-C-328 IITRI, CR-022-216, Nov 17, 2000). Answer b, Echelon, refers to a cooperative, worldwide signal intelligence system that is run by the NSA of the United States, the Government Communications Head Quarters (GCHQ) of England, the Communications Security Establishment (CSE) of Canada, the Australian Defense Security Directorate (DSD), and the General Communications Security Bureau (GCSB) of New Zealand. These organizations are bound together under a secret 1948 agreement, UKUSA, [European Parliament, Development of Surveillance Technology and the Risk of Abuse of Economic Information, Luxembourg (April 1999), PE 166.184/Part 3 /4]. Answer c is a distracter and is discussed in the questions and answers of Chapter 4, Cryptography. Answer d is a distracter.

QUESTION NO: 1947

Which of the following is an example of mobile code?

- A. Embedded code in control systems
- B. Code derived following the spiral model
- C. Embedded code in PCs
- D. Java and ActiveX code downloaded into a Web browser from the World Wide Web (WWW)

Answer: D

Explanation:

An example of mobile code is Java and ActiveX code downloaded into a Web browser from the World Wide Web. The other answers are incorrect because they are types of code that are not related to mobile code.

QUESTION NO: 1948

Which type of backup subscription service will allow a business to recover quickest?

- A. A mobile or rolling backup service
- B. A warm site
- C. A cold site
- D. A hot site

Answer: D

Explanation:

The correct answer is "A hot sit". Warm and cold sites require more work after the event occurs to get them to full operating functionality. A mobile backup site might be useful for specific types of minor outages, but a hot site is still the main choice of backup processing site.

QUESTION NO: 1949

Which statement below is the BEST example of separation of duties?

- A. Getting users to divulge their passwords.
- B. An activity that checks on the system, its users, or the environment.
- C. One person initiates a request for a payment and another authorizes that same payment.
- D. A data entry clerk may not have access to run database analysis reports.

Answer: C

Explanation:

Separation of duties refers to dividing roles and responsibilities so that a single individual cannot subvert a critical process. In financial systems, no single individual should normally be given the authority to issue checks. Checks and balances need to be designed into both the process as well as the specific, individual positions of

personnel who will implement the process.

*Answer "An activity that checks on the system, its users, or the environment" describes system monitoring.

*Answer "Getting users to divulge their passwords" is social engineering, a method of subverting system

controls by getting users or administrators to divulge information about systems, including their passwords.

*Answer "A data entry clerk may not have access to run database analysis reports" describes least privilege. Least privilege refers to the

security objective of granting users only those accesses they need to perform their official duties. Least privilege does not mean that all users will have extremely little functional access; some employees will have significant access if it is required for their position. It is important to make certain that the implementation of least privilege does not interfere with the ability to have personnel substitute for each other without undue delay. Without careful planning, access control can interfere with contingency plans.

Source: National Institute of Standards and Technology, An Introduction to Computer Security: The NIST Handbook Special Publication 800-12.

QUESTION NO: 1950

In the legal field, there is a term that is used to describe a computer system so that everyone can agree on a common definition. The term describes a computer for the purposes of computer security as any assembly of electronic equipment, hardware, software and firmware configured to collect, create, communicate, disseminate, process, store and control data or information. This definition includes peripheral items such as keyboards, printers, and additional memory. The term that corresponds to this definition is:

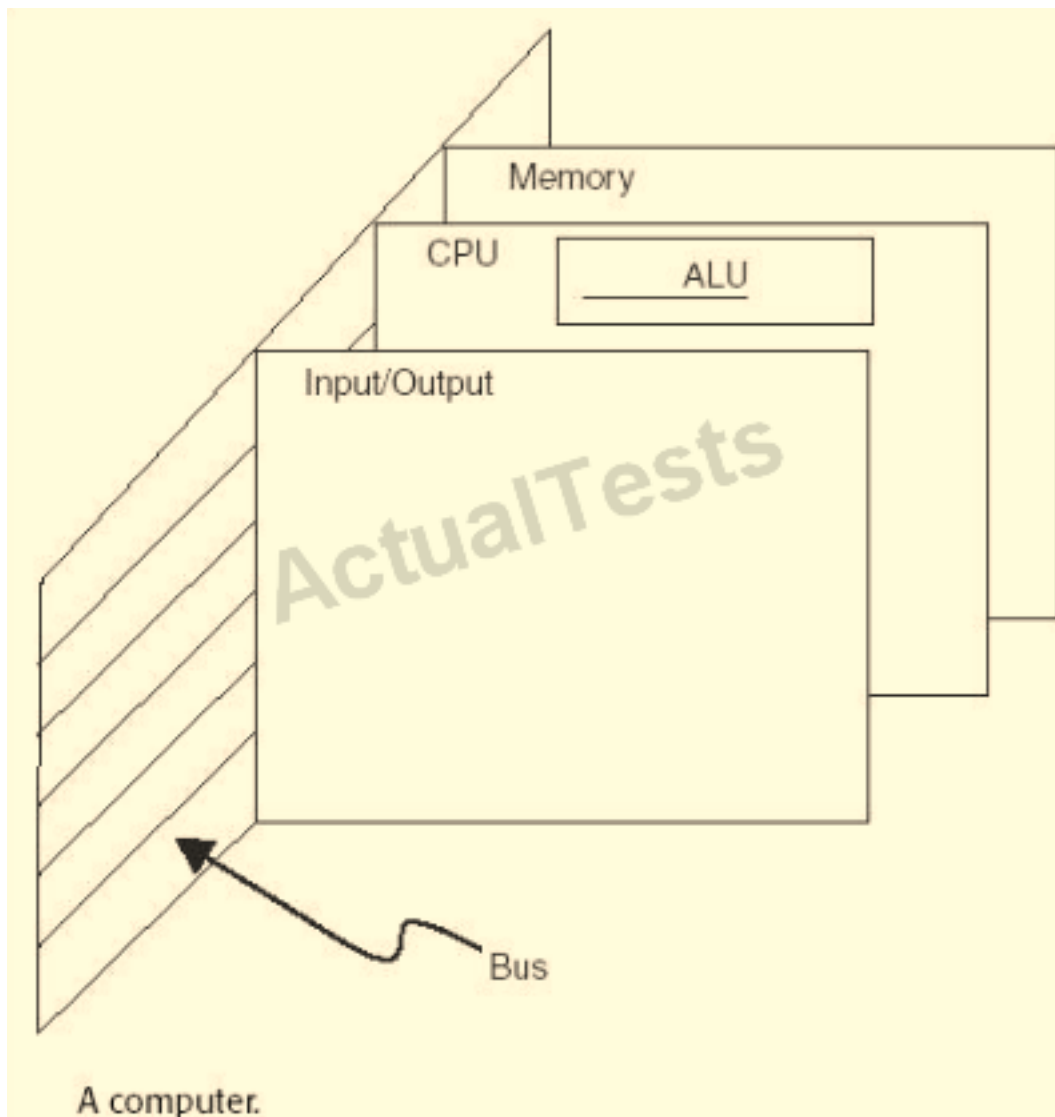
- A.** An automated information system (AIS)
- B.** A microprocessor

- C. A central processing unit (CPU)
- D. An arithmetic logic unit (ALU)

Answer: A

Explanation:

In some ways, this terminology harkens back to the days of large mainframe computers, but the term AIS is used in the legal community to refer to a computer system. Answer a, CPU, refers to the portion of a computer that performs arithmetic and logical operations on data. To support these operations, the CPU incorporates a hardware arithmetic logic unit or ALU (answer c). The CPU is synonymous with the word processor. If the CPU is integrated onto a silicon chip, it is called a microprocessor (answer b). If the CPU is connected with memory and Input/Output (I/O) through a set of wires called a bus, the resulting combination is called a computer. This concept is shown in Figure.



b

QUESTION NO: 1951

The communication to an object to carry out an operation in an objectoriented system is called a:

- A. Note.
- B. Method.
- C. Message.
- D. Behavior.

Answer: C

Explanation:

Answer Note is a distracter.

A method is the code that defines the actions an object performs in response to a message.

Behavior is the result exhibited by an object upon receipt of a message.

QUESTION NO: 1952

Which media control below is the BEST choice to prevent data remanence on magnetic tapes or floppy disks?

- A. Applying a concentration of hydriodic acid (55% to 58% solution) to the gamma ferric oxide disk surface
- B. Overwriting the media with new application data
- C. Degaussing the media
- D. Making sure the disk is re-circulated as quickly as possible to prevent object reuse

Answer: C

Explanation:

Degaussing is recommended as the best method for purging most magnetic media. Degaussing is a process whereby the magnetic

media is erased, i.e., returned to its initial virgin state. Erasure via degaussing may be accomplished in two ways:

In AC erasure, the media is degaussed by applying an alternating field that is reduced in amplitude over time from an initial high value (i.e., AC-powered)

In DC erasure, the media is saturated by applying a unidirectional field (i.e., DC-powered or by employing a permanent magnet)

Another point about degaussing: Degaussed magnetic hard drives will generally require restoration of factory-installed timing tracks, so data purging is recommended. Also, physical destruction of CDROM or WORM media is required.

*Answer "Overwriting the media with new application data" is not recommended because the application may not completely overwrite the old data properly, and strict configuration controls must be in place on both the operating system and the software itself. Also, bad sectors on the media may not permit the software to overwrite old data properly. To satisfy the DoD clearing requirement, it is sufficient to write any character to all data locations in question (purging).

To purge the media, the DoD requires overwriting with a pattern, then its complement, and finally with another pattern; e.g., overwrite first with 0011 0101, followed by 1100 1010, then 1001 0111. The number of times an overwrite must be accomplished depends on the storage media, sometimes on its sensitivity, and sometimes on differing DoD component requirements, but seven times is often recommended.

*Answer "Applying a concentration of hydriodic acid (55% to 58% solution) to the gamma ferric oxide disk surface" is a rarely used method of media destruction, and acid solutions should be used in a well-ventilated area only by qualified personnel.

*Answer "Making sure the disk is re-circulated as quickly as possible to prevent object reuse" is wrong. Source: NCSC-TG-025 A Guide to Understanding Data Remanence in Automated Information Systems.

QUESTION NO: 1953

A client/server implementation approach in which any platform may act as a client or server or both is called:

- A. Peer-to-peer
- B. Simple file transfer
- C. Graphical User Interface (GUI)
- D. Application Programming Interface (API)

Answer: A

Explanation:

In answer Simple file transfer, a workstation or PC uses terminal emulation software and a client application program to receive data from a host machine.

For answer API, an API defines how the client and server appear to each other and supports the exchange of information without either entity knowing the details of a particular resource that is accessed using the API. One example is the Generalized Security Application Programming Interface (GSAPI) that applications can use to access security services.

Answer GUI, the GUI approach, is similar to the API implementation and employs a user interface such as SQL to access a server database.

QUESTION NO: 1954

Which of the following is NOT a European Union (EU) principle?

- A. Data should be collected in accordance with the law.
- B. Information collected about an individual cannot be disclosed to other organizations or individuals unless authorized by law or by consent of the individual.
- C. Transmission of personal information to locations where equivalent personal data protection cannot be assured is permissible.
- D. Data should be used only for the purposes for which it was collected and should be used only for reasonable period of time.

Answer: C

Explanation:

The transmission of data to locations where equivalent personal data protection cannot be assured is NOT permissible. The other answers are EU principles.

QUESTION NO: 1955

Which term below MOST accurately describes the Trusted Computing Base (TCB)?

- A.** A piece of information that represents the security level of an object
- B.** A computer that controls all access to objects by subjects
- C.** Formal proofs used to demonstrate the consistency between a systems specification and a security model
- D.** The totality of protection mechanisms within a computer system

Answer: D

Explanation:

The Trusted Computing Base (TCB) The totality of protection mechanisms within a computer system, including hardware, firmware, and software, the combination of which is responsible for enforcing a security policy. A TCB consists of one or more components that together enforce a unified security policy over a product or system. The ability of a trusted computing base to correctly enforce a security policy depends solely on the mechanisms within the TCB and on the correct input by system administrative personnel of parameters (e.g., a users clearance) related to the security policy.

*Answer "A computer that controls all access to objects by subjects" describes the reference monitor concept. The reference

monitor is an access control concept that refers to an abstract machine that mediates all accesses to objects by subjects. The Security Kernel consists of the hardware, firmware, and software elements of a Trusted Computing Base (or Network Trusted Computing Base partition) that implement the reference monitor concept. It must mediate all accesses, be protected from modification, and be verifiable as correct.

*Answer "A piece of information that represents the security level of an object" refers to a sensitivity label. A sensitivity label is a piece of information that represents the extra security level of an object and describes the sensitivity (e.g., classification) of the data in the object. Sensitivity labels are used by the TCB as the basis for mandatory access control decisions.

*Answer "Formal proofs used to demonstrate the consistency between a systems specification

and a security model" describes formal verification. This is the process of using formal proofs to demonstrate the consistency (design verification) between a formal specification of a system and a formal security policy model or (implementation verification) between the formal specification and its program implementation. Source: DoD 5200.28-STD
Department of Defense Trusted Computer System Evaluation Criteria

QUESTION NO: 1956

What is considered the major disadvantage to employing a hot site for disaster recovery?

- A. The site is immediately available for recovery.
- B. Maintaining the site is expensive.
- C. Annual testing is required to maintain the site.
- D. Exclusivity is assured for processing at the site.

Answer: B

Explanation:

The correct answer is the expense of maintaining the site. A hot site is commonly used for those extremely time-critical functions that the business must have up and running to continue operating, but the expense of duplicating and maintaining all of the hardware, software, and application elements is a serious resource drain to most organizations.

QUESTION NO: 1957

What is a subject-oriented, integrated, time-variant, non-volatile collection of data in support of managements decision-making process?

- A. Data mart
- B. Data model
- C. Data warehouse
- D. Data model

Answer: C

Explanation:

This definition of a data warehouse is that of Bill Inmon, a pioneer in the field. To create a data warehouse, data is taken from an operational database, redundancies are removed, and the data is cleaned up in general. This activity is referred to as normalizing the data. Then the data is placed into a relational database and can be analyzed using On-Line Analytical Processing (OLAP) and statistical modeling tools. The data warehouse can be used as a Decision Support System (DSS), for example, by performing a time series analysis of the data. The data in the data warehouse must be maintained to ensure that it is timely and valid. The term data scrubbing refers to maintenance of the data warehouse by deleting information that is unreliable or no longer relevant.

*A data mart, answer a, is a database that is comprised of data or relations that have been extracted from the data warehouse. Information in the data mart is usually of interest to a particular group of people. For example, a data mart may be developed for all health care-related data.

*Answers Data model and Data model are distracters, although a data model, in this context, sometimes refers to the result of analyzing relationships among enterprise-wide data items.

QUESTION NO: 1958

Which choice below does NOT accurately describe a task of the Configuration Control Board?

- A. The CCB assures that the changes made are approved, tested, documented, and implemented correctly.
- B. The CCB should meet periodically to discuss configuration status accounting reports.

C. The CCB is responsible for documenting the status of configuration control activities.

D. The CCB is responsible for assuring that changes made do not jeopardize the soundness of the verification system.

Answer: C

Explanation:

All analytical and design tasks are conducted under the direction of the vendors corporate entity called the Configuration Control Board (CCB). The CCB is headed by a chairperson who is responsible for assuring that changes made do not jeopardize the soundness of the verification system and assures that the changes made are approved, tested, documented, and implemented correctly.

The members of the CCB should interact periodically, either through formal meetings or other available means, to discuss configuration management topics such as proposed changes, configuration status accounting reports, and other topics that may be of interest to the different areas of the system development. These interactions should be held to keep the entire system team updated on all advancements or alterations in the verification system.

Answer b describes configuration accounting. Configuration accounting documents the status of configuration control activities and, in general, provides the information needed to manage a configuration effectively. The configuration accounting reports are reviewed by the CCB. Source: NCSC-TG-014-89, Guidelines for Formal Verification Systems.

QUESTION NO: 1959

Which choice below MOST accurately describes partitioned security mode?

A. The only state in which certain privileged instructions may be executed.

B. A system containing information accessed by personnel with different security clearances.

C. All personnel have the clearance but not necessarily formal access approval.

D. All personnel have the clearance and formal access approval.

Answer: C

Explanation:

A partitioned security mode is a mode of operation wherein all personnel have the clearance but not necessarily formal access approval and need-to-know for all information contained in the system.

*Answer "All personnel have the clearance and formal access approval" is a compartmented security mode. A compartmented security mode is a mode of operation wherein all personnel have a valid personnel clearance, formal access approval and signed nondisclosure agreements, and valid need-to-know for that information to which he/she is to have access.

*Answer "The only state in which certain privileged instructions may be executed" is executive state. Executive state is one of several states

in which a system may operate and the only one in which certain privileged instructions may be executed. Such instructions cannot be executed when the system is operating in other (e.g., user) states.

Synonymous with supervisor state.

*Answer "A system containing information accessed by personnel with different security clearances" is multilevel secure. Multilevel secure is a class of system containing information with different sensitivities that simultaneously permits access by users with different security clearances and needs-to-know, but prevents users from obtaining access to information for which they lack authorization.

Source: DoD 5200.28-STD Department of Defense Trusted Computer System Evaluation Criteria.

QUESTION NO: 1960

The SEI Software Capability Maturity Model is based on the premise that:

- A.** The quality of a software product is a direct function of the quality of its associated software development and maintenance processes.
- B.** The maturity of an organizations software processes cannot be measured.
- C.** Software development is an art that cannot be measured by conventional means.
- D.** Good software development is a function of the number of expert programmers in the organization.

Answer: A

Explanation:

The quality of a software product is a direct function of the quality of its associated software development and maintenance processes.

*Answer "Good software development is a function of the number of expert programmers in the organization" is false because the SEI Software CMM relates the production of good software to having the proper processes in place in an organization and not to expert programs or heroes.

*Answer "The maturity of an organizations software processes cannot be measured" is false because the Software CMM provides means to measure the maturity of an organizations software processes.

*Answer " Software development is an art that cannot be measured by conventional means" is false because the Software CMM provides means to measure the maturity of an organizations software processes.

QUESTION NO: 1961

The main differences between a software process assessment and a software capability evaluation are:

- A.** Software process assessments and software capability evaluations are essentially identical, and there are no major differences between the two.
- B.** Software capability evaluations determine the state of an organizations current software process and are used to gain support from within the organization for a software process improvement program; software process assessments are used to identify contractors who are qualified to develop software or to monitor the state of the software process in a current software project.
- C.** Software process assessments are used to develop a risk profile for source selection; software capability evaluations are used to develop an action plan for continuous process improvement.
- D.** Software process assessments determine the state of an organizations current software process and are used to gain support from within the organization for a software process improvement program; software capability evaluations are used to identify contractors who are qualified to develop software or to monitor the

state of the software process in a current software project.

Answer: D

Explanation:

The other answers are distracters. If, in answer "Software process assessments are used..." the terms software process assessments and software capability evaluations were interchanged, that result would also be correct. It would then read, Software capability evaluations are used to develop a risk profile for source selection; software process assessments are used to develop an action plan for continuous process improvement.

QUESTION NO: 1962

Which minimum TCSEC security class category specifies trusted distribution controls?

- A. B2
- B. B3
- C. C2
- D. A1

Answer: D

Explanation:

Trusted distribution is defined by the Orange Book as a requirement of A1 TCB assurance. Trusted distribution includes procedures to ensure that all of the TCB configuration items, such as the TCB software, firmware, hardware, and updates, distributed to a customer site arrive exactly as intended by the vendor without any alterations. Any alteration to the TCB at any time during the system life cycle could result in a violation of the system security policy. Assurance that the system security policy is correctly implemented and operational throughout the system life cycle is provided by different TCSEC requirements. At TCSEC class A1, trusted distribution, in conjunction with configuration management, provides assurance that the TCB software, firmware, and hardware, both original and updates, are received by a customer site exactly as specified by the

vendors master copy. Trusted distribution also ensures that TCB copies sent from other than legitimate parties are detected. Source: NCSC-TG-008 A Guide to Understanding Trusted Distribution in Trusted Systems [Lavender Book].

QUESTION NO: 1963

A trade secret:

- A.** Provides the owner with a legally enforceable right to exclude others from practicing the art covered for a specified time period.
- B.** Is a word, name, symbol, color, sound, product shape, or device used to identify goods and to distinguish them from those made or sold by others.
- C.** Protects original works of authorship.
- D.** Secures and maintains the confidentiality of proprietary technical or business-related information that is adequately protected from disclosure by the owner.

Answer: D

Explanation:

This defines a trade secret.

*Answer "Provides the owner with a legally enforceable right to exclude others from practicing the art covered for a specified time period" refers to a patent.

*Answer "Protects original works of authorship" refers to a copyright.

*Answer "Is a word, name, symbol, color, sound, product shape, or device used to identify goods and to distinguish them from those made or sold by others" refers to a trademark.

QUESTION NO: 1964

Which choice below is NOT a security goal of an audit mechanism?

- A.** Review employee production output records
- B.** Deter perpetrators attempts to bypass the system protection

mechanisms

C. Review patterns of access to individual objects

D. Discover when a user assumes a functionality with privileges greater than his own

Answer: A

Explanation:

The audit mechanism of a computer system has five important security goals:

1. The audit mechanism must allow the review of patterns of access to individual objects, access histories of specific processes and individuals, and the use of the various protection mechanisms supported by the system and their effectiveness.²
2. Allow discovery of both users and outsiders repeated attempts to bypass the protection mechanisms.
3. Allow discovery of any use of privileges that may occur when a user assumes a functionality with privileges greater than his or her own, i.e., programmer to administrator. In this case, there may be no bypass of security controls, but nevertheless, a violation is made possible.
4. Act as a deterrent against perpetrators habitual attempts to bypass the system protection mechanisms. However, to act as a deterrent, the perpetrator must be aware of the audit mechanisms existence and its active use to detect any attempts to bypass system protection mechanisms.
5. Supply an additional form of user assurance that attempts to bypass the protection mechanisms that are recorded and discovered.³ Even if the attempt to bypass the protection mechanism is successful, the audit trail will still provide assurance by its ability to aid in assessing the damage done by the violation, thus improving the systems ability to control the damage.

Source: NCSC-TG-001 A Guide to Understanding Audit in Trusted Systems [Tan Book], and Gligor, Virgil D., Guidelines for Trusted Facility Management and Audit, University of Maryland, 1985.

QUESTION NO: 1965

Investigating and prosecuting computer crimes is made more difficult because:

- A. Evidence cannot be preserved.
- B. Evidence is mostly intangible.
- C. Evidence is hearsay and can never be introduced into a court of law.
- D. Backups may be difficult to find.

Answer: B

Explanation:

The correct answer is "Evidence is mostly intangible".

* Answer "Backups may be difficult to find" is incorrect because if backups are done, they usually can be located.

* Answer "Evidence cannot be preserved" is incorrect because evidence can be preserved using the proper procedures.

* Answer "Evidence is hearsay and can never be introduced into a court of law" is incorrect because there are exceptions to the hearsay rule.

QUESTION NO: 1966

The discipline of identifying the components of a continually evolving system for the purposes of controlling changes to those components and maintaining integrity and traceability throughout the life cycle is called:

- A. Configuration management
- B. Request control
- C. Change control
- D. Release control

Answer: A

Explanation:

This is demonstrated in Configuration management of computer-based

systems, British Standards Institution, 1984.

The other answers are components of the maintenance activity of software life cycle models. In general, one can look at the maintenance phase as the progression from request control, to change control, to release control.

*Answer request control is involved with the users requests for changes to the software.

*Change control involves the analysis and understanding of the existing code, and the design of changes, and corresponding test procedures.

*Answer release control involves deciding which requests are to be implemented in the new release, performing the changes and conducting testing.

QUESTION NO: 1967

Imprisonment is a possible sentence under:

- A.** Neither civil nor criminal law
- B.** Both civil and criminal law
- C.** Civil (tort) law
- D.** Criminal law

Answer: D

Explanation:

The correct answer is Criminal law. It is the only one of the choices where imprisonment is possible.

QUESTION NO: 1968

According to FEMA, which choice below is NOT a recommended way to purify water after a disaster?

- A. Distilling the water for twenty minutes
- B. Adding 16 drops per gallon of household liquid bleach to the water
- C. Adding water treatment tablets to the water
- D. Boiling from 3 to 5 minutes

Answer: C

Explanation:

FEMA recommends that water treatment products sold in camping or surplus stores should not be used, unless the only active ingredient is 5.25 percent hypochlorite. When adding liquid bleach, it should contain 5.25 percent hypochlorite and no other added cleaners or scents. Distilling the water is the most highly recommended method, as it also removes other chemicals and heavy metals, as well as most microbes. Source: Emergency Water and Food Procedures, Federal Emergency Management Agency, April, 1997.

QUESTION NO: 1969

Which element of Configuration Management listed below involves the use of Configuration Items (CIs)?

- A. Configuration Identification
- B. Configuration Control
- C. Configuration Audit
- D. Configuration Accounting

Answer: A

Explanation:

Configuration management entails decomposing the verification system into identifiable, understandable, manageable, trackable units known as Configuration Items (CIs). A CI is a uniquely identifiable subset of the system that represents the smallest portion to be subject to independent configuration control procedures. The decomposition process of a verification system into CIs is called configuration identification. CIs can vary widely in size, type, and complexity. Although there are no hard-and-fast rules for decomposition, the granularity of CIs can have great practical

importance. A favorable strategy is to designate relatively large CIs for elements that are not expected to change over the life of the system, and small CIs for elements likely to change more frequently.

*Answer "Configuration Accounting", configuration accounting, documents the status of configuration

control activities and in general provides the information needed to manage a configuration effectively. It allows managers to trace system changes and establish the history of any developmental problems and associated fixes.

Answer "Configuration Audit", configuration audit, is the quality assurance component of configuration management. It involves periodic checks to determine the consistency and completeness of accounting information and to verify that all configuration management policies are being followed.

Answer "Configuration Control", configuration control, is a means of assuring that system changes are approved before being implemented, only the proposed and approved changes are implemented, and the implementation is complete and accurate.

Source: NCSC-TG-014-89, Guidelines for Formal Verification Systems.

QUESTION NO: 1970

Which of the following is NOT a characteristic of a client in the client/server model?

- A. May be diskless
- B. Systems backup and database protection
- C. Extensive user interface
- D. Data entry screens

Answer: B

Explanation:

In the client/server model, the server is the data storage resource and is responsible for data backups and protection/maintenance of the database.

Answer "May be diskless" refers to a diskless workstation or PC at the client side. By not providing local data storage capabilities at the client side, security is increased since the data is less vulnerable at a

protected server location. Also, because the client is the users path into the network, the client must have extensive, user friendly interfaces such as described in answers Extensive user interface and Data entry screens.

QUESTION NO: 1971

Which of the following is NOT one of the five disaster recovery plan testing types?

- A. Mobile
- B. Checklist
- C. Full Interruption
- D. Simulation

Answer: A

Explanation:

The correct answer is mobile. The other three are proper examples of elements of the five disaster recovery plan testing types.

QUESTION NO: 1972

Which statement below is NOT correct regarding the role of the recovery team during the disaster?

- A. The recovery team must be the same as the salvage team as they perform the same function.
- B. The recovery team is often separate from the salvage team as they perform different duties.
- C. The recovery team will need full access to all backup media.
- D. The recovery teams primary task is to get predefined critical business functions operating at the alternate processing site.

Answer: A

Explanation:

The recovery team performs different functions from the salvage team. The recovery teams primary mandate is to get critical processing re-established at an alternate site. The salvage teams primary mandate is to return the original processing site to normal processing environmental conditions.

QUESTION NO: 1973

Information Warfare is:

- A.** Developing weapons systems based on artificial intelligence technology.
- B.** Signal intelligence.
- C.** Attacking the information infrastructure of a nation to gain military and/or economic advantages.
- D.** Generating and disseminating propaganda material.

Answer: C

Explanation:

* Answer "Developing weapons systems based on artificial intelligence technology" is a distracter and has to do with weapon systems development.

* Answer "Generating and disseminating propaganda material" is not applicable.

Answer "Signal intelligence" is the conventional acquisition of information from radio signals.

QUESTION NO: 1974

A neural network learns by using various algorithms to:

- A.** Fire the rules in knowledge base.
- B.** Adjust the weights applied to the data.
- C.** Emulate the thinking of an expert.
- D.** Emulate an inference engine.

Answer: B

Explanation:

The correct answer is A neural network learns by using various algorithms to adjust the weights applied to the data.

The other answers are terminology referenced in expert systems.

QUESTION NO: 1975

In the Capability Maturity Model (CMM) for software, the definition describes the range of expected results that can be achieved by following a software process is that of:

- A. Software process capability
- B. Structured analysis/structured design (SA/SD)
- C. Software process maturity
- D. Software process performance

Answer: A

Explanation:

A software process is a set of activities, methods, and practices that are used to develop and maintain software and associated products.

Software process capability is a means of predicting the outcome of the next software project conducted by an organization.

* Answer software process performance, is the result achieved by following a software process.

Thus, software capability is aimed at expected results while software performance is focused on results that have been achieved.

*Software process maturity is the extent to which a software process is:

Defined

Managed

Measured

Controlled

Effective

Software process maturity, then, provides for the potential for growth in capability of an organization. An immature organization develops software in a crisis mode, usually exceeds budgets and time schedules, and software processes are developed in an ad hoc

fashion during the project. In a mature organization, the software process is effectively communicated to staff, the required processes are documented and consistent, software quality is evaluated, and roles and responsibilities are understood for the project.

Answer SA/SD is a distracter.

QUESTION NO: 1976

What is the number one priority of disaster response?

- A.** Protecting the hardware
- B.** Protecting the software
- C.** Transaction processing
- D.** Personnel safety

Answer: D

Explanation:

The correct answer is Personnel safety. The number one function of all disaster response and recovery is the protection of the safety of people; all other concerns are vital to business continuity but are secondary to personnel safety.

QUESTION NO: 1977

Which task below would normally be considered a BCP task, rather than a DRP task?

- A.** Recovery procedures

- B. Life safety processes
- C. Project scoping
- D. Restoration procedures

Answer: C

Explanation:

Although many processes in making business continuity plans are similar to processes in creating disaster recovery plans, several differences exist. Business continuity planning processes that are unique to BCP could include:

Project scoping and assigning roles

Creating business impact and vulnerability assessments

Choosing alternate processing sites

whereas unique disaster recovery/emergency management processes could include:

Implementing relocation procedures to the alternate site

Plan testing and training

Recovering data

Salvaging damaged equipment

Source: CISSP Examination Textbooks, Volume One: Theory, by S. Rao Vallabhaneni, SRV Professional Publications first edition 2000 and Handbook of Information Security Management, by Micki Krause and Harold F. Tipton, Auerback, 1999 edition.

QUESTION NO: 1978

In configuration management, a configuration item is:

- A. A component whose state is to be recorded and against which changes are to be progressed.
- B. The version of the operating system that is operating on the workstation that provides information security services.
- C. A series of files that contains sensitive information.
- D. The network architecture used by the organization.

Answer: A

Explanation:

A component whose state is to be recorded and against which changes are to be progressed.

The other answers are incorrect by the definition of a configuration item.

QUESTION NO: 1979

Which one of the following conditions must be met if legal electronic monitoring of employees is conducted by an organization?

- A. Employees must be unaware of the monitoring activity.
- B. All employees must agree with the monitoring policy.
- C. The organization must have a policy stating that all employees are regularly notified that monitoring is being conducted.
- D. Results of the monitoring cannot be used against the employee.

Answer: C

Explanation:

- * Answer "Employees must be unaware of the monitoring activity" is incorrect because employees must be made aware of the monitoring if it is to be legal
- * answer "All employees must agree with the monitoring policy" is incorrect because employees do not have to agree with the policy
- * answer "Results of the monitoring cannot be used against the employee" is incorrect because the results of monitoring might be used against the employee if the corporate policy is violated.

QUESTION NO: 1980

Which book of the Rainbow series addresses the Trusted Network Interpretation (TNI)?

- A. Red Book
- B. Purple Book
- C. Orange Book

D. Green Book**Answer: A****Explanation:**

The Red Book is one book of the Rainbow Series, a six-foot-tall stack of books on evaluating Trusted Computer Systems according to the National Security Agency. The term Rainbow Series comes from the fact that each book is a different color. The Trusted Network Interpretation (TNI) extends the evaluation classes of the Trusted Systems Evaluation Criteria (DOD 5200.28-STD) to trusted network systems and components.

- * the Orange Book, is the main book of the Rainbow Series and most of the other books elaborate on the information contained in this book. The Orange Book is the DoD Trusted Computer System Evaluation Criteria [DOD 5200.28]1.
- * the Green Book, is CSC-STD-002-85, the DoD Password Management Guidelines.
- * the Purple Book, is NCSC-TG-014, Guidelines for Formal Verification Systems. Source: NCSC-TG-005 Trusted Network Interpretation [Red Book] and DoD Trusted Computer System Evaluation Criteria [DOD 5200.28-Orange Book.]

QUESTION NO: 1981

Which statement below is the BEST definition of need-to-know?

- A.** Need-to-know requires that the operator have the minimum knowledge of the system necessary to perform his task.
- B.** Need-to-know ensures that no single individual (acting alone) can compromise security controls.
- C.** Need-to-know grants each user the lowest clearance required for their tasks.
- D.** Need-to-know limits the time an operator performs a task.

Answer: A**Explanation:**

The concept of need-to-know means that, in addition to whatever specific object or role rights a user may have on the system, the user has also the minimum amount of information necessary to perform his job function.

* Answer "Need-to-know ensures that no single individual (acting alone) can compromise security controls." is separation of duties, assigning parts of tasks to different personnel.

*Answer "Need-to-know grants each user the lowest clearance required for their tasks." is least privilege, the user has the minimum security level required to perform his job function.

*Answer "Need-to-know limits the time an operator performs a task." is rotation of duties, wherein the amount of time an operator is assigned a security-sensitive task is limited before being moved to a different task with a different security classification.

QUESTION NO: 1982

The US Government Tempest program was established to thwart which one of the following types of attacks?

- A. Emanation Eavesdropping
- B. Denial of Service
- C. Software Piracy
- D. Dumpster Diving

Answer: A

Explanation:

The correct answer is Emanation Eavesdropping. The Tempest program required shielding and other emanation reducing safeguards to be employed on computers processing classified data. The other answers are types of attacks against computers, but are not the focus of the Tempest program.

QUESTION NO: 1983

The concept of Due Care states that senior organizational management must ensure that:

- A. Certain requirements must be fulfilled in carrying out their responsibilities

to the organization.

B. Other management personnel are delegated the responsibility for information system security.

C. All risks to an information system are eliminated.

D. The cost of implementing safeguards is greater than the potential resultant losses resulting from information security breaches.

Answer: A

Explanation:

* Answer "All risks to an information system are eliminated" is incorrect because all risks to information systems cannot be eliminated

* answer "Other management personnel are delegated the responsibility for information system security" is incorrect because senior management cannot delegate its responsibility for information system security under due care

* answer "The cost of implementing safeguards is greater than the potential resultant losses resulting from information security breaches" is incorrect because the cost of implementing safeguards should be less than or equal to the potential resulting losses relative to the exercise of due care.

QUESTION NO: 1984

What is the purpose of the Business Impact Assessment (BIA)?

A. To define a strategy to minimize the effect of disturbances and to allow for the resumption of business processes

B. To emphasize the organizations commitment to its employees and vendors

C. To create a document to be used to help understand what impact a disruptive event would have on the business

D. To work with executive management to establish a DRP policy

Answer: C

Explanation:

The correct answer is: to create a document to be used to help understand what impact a disruptive event would have on the business.

Answer "To define a strategy to minimize the effect of disturbances and to allow for the resumption of business processes" is the definition of business continuity planning.

QUESTION NO: 1985

In software engineering, the term verification is defined as:

- A.** To establish the fitness or worth of a software product for its operational mission
- B.** A complete, validated specification of the required functions, interfaces, and performance for the software product
- C.** A complete, verified specification of the overall hardware-software architecture, control structure, and data structure for the product
- D.** To establish the truth of correspondence between a software product and its specification

Answer: D

Explanation:

In the Waterfall model (W.W. Royce, Managing the Development of Large Software Systems: Concepts and Techniques, Proceedings, WESCON, August 1970).

* answer "A complete, validated specification of the required functions, interfaces, and performance for the software product" defines the term requirements.

*Similarly, answer "To establish the fitness or worth of a software product for its operational mission", defines the term validation, and answer d is the definition of product design. In summary, the steps of the Waterfall model are:

System feasibility

Software plans and requirements

Product design

Detailed design

Code

Integration

Implementation

Operations and maintenance

In this model, each phase finishes with a verification and validation (V&V) task that is designed to eliminate as many problems as possible in the results of that phase.

QUESTION NO: 1986

Which choice below is NOT one of the four major aspects of configuration management?

- A. Configuration auditing
- B. Configuration product evaluation
- C. Configuration identification
- D. Configuration status accounting

Answer: B

Explanation:

The four major aspects of configuration management are:

Configuration identification

Configuration control

Configuration status accounting

Configuration auditing

These aspects are described earlier in this chapter. Answer " Configuration product evaluation" is a distracter. Source: NCSC-TG-014-89, Guidelines for Formal Verification Systems [Purple Book].

QUESTION NO: 1987

Which of the following is NOT one of the primary goals of a BIA?

- A. Downtime estimation
- B. Criticality prioritization
- C. Personnel safety
- D. Resource requirements

Answer: C

Explanation:

The correct answer is Personnel safety. Personnel safety is the primary priority of BCP and DRP, not BIA.

QUESTION NO: 1988

Which choice below most accurately describes a business continuity program?

- A.** A standard that allows for rapid recovery during system interruption and data loss
- B.** A determination of the effects of a disaster on human, physical, economic, and natural resources
- C.** A program that implements the mission, vision, and strategic goals of the organization
- D.** Ongoing process to ensure that the necessary steps are taken to identify the impact of potential losses and maintain viable recovery

Answer: D

Explanation:

A business continuity program is an ongoing process supported by senior management and funded to ensure that the necessary steps are taken to identify the impact of potential losses, maintain viable recovery strategies and recovery plans, and ensure continuity of services through personnel training, plan testing, and maintenance.

Answer "A program that implements the mission, vision, and strategic goals of the organization" describes a disaster/emergency management program. A disaster/emergency management program, like a disaster recovery program, is a program that implements the mission, vision, and strategic goals and objectives as well as the management framework of the program and organization.

*Answer "A determination of the effects of a disaster on human, physical, economic, and natural resources" describes a damage assessment. A damage assessment is an appraisal or determination of the effects of a disaster on human, physical, economic, and natural resources.

*Answer "A standard that allows for rapid recovery during system interruption and data loss" is a distracter. Source: NFPA1600 Standard on Disaster/Emergency Management and Business Continuity, National Fire Protection Association, 2000 edition.

QUESTION NO: 1989

What is a data dictionary?

- A. A validation reference source
- B. A database for system developers
- C. A library of objects
- D. A database of security terms

Answer: B

Explanation:

A data dictionary is a database for system developers. The other answers are distracters.

QUESTION NO: 1990

Which choice below is NOT considered a potential hazard resulting from natural events?

- A. Forest fire
- B. Urban fire
- C. Arson
- D. Earthquake/land shift

Answer: C

Explanation:

According to the NFPA, arson is an example of a potential hazard caused by a human event. Fires, in themselves, are considered natural events, like forest fires, range fires, urban or city fires, unless arson is thought to be the source of the blaze. Of the three categories of potential hazards (natural, technological, and human), human events could include:

General strikes
Terrorism
Sabotage
Mass hysteria
Civil unrest

Source: NFPA 1600 Standard on Disaster/Emergency Management and Business Continuity, National Fire Protection Association, 2000

edition.

QUESTION NO: 1991

Which choice below is NOT an example of a software control?

- A. Routinely testing the backup data for accuracy
- B. Implementing a formal application upgrade process
- C. Controlling diagnostic ports on networked equipment
- D. Employing anti-virus management and tools

Answer: C

Explanation:

The correct answer is "Controlling diagnostic ports on networked equipment". This is an example of a hardware control.

The other three are examples of software controls.

QUESTION NO: 1992

Which choices below are emergency management procedure directly related to financial decision making? Select three.

- A. Establishing procedures for the continuance of payroll
- B. Establishing program procurement procedures
- C. Establishing critical incident stress procedures
- D. Establishing accounting procedures to track the costs of emergencies

Answer: A,B,D

Explanation:

The correct answers are all examples of emergency management procedures which must be established by the financial department to ensure that fiscal decisions are executed in accordance with

authority levels and accounting practices.

*Answer "Establishing critical incident stress procedures" is an example of a procedure that should be developed by the human resources department. The quality of employee morale and well-being can include psychological needs as well as physical needs, and the role of the human resources department is critical in monitoring and managing immediate, short-term, and long-term employee stress.

Source: NFPA 1600 Standard on Disaster/Emergency Management and Business Continuity, National Fire Protection Association, 2000 edition.

QUESTION NO: 1993

Which statement below is accurate about Evaluation Assurance Levels (EALs) in the Common Criteria (CC)?

- A.** A security level equal to the security level of the objects to which the subject has both read and write access
- B.** Requirements that specify the security behavior of an IT product or system
- C.** A statement of intent to counter specified threats
- D.** Predefined packages of assurance components that make up security confidence rating scale

Answer: D

Explanation:

An Evaluation Assurance Level (EAL) is one of seven increasingly rigorous packages of assurance requirements from CC Part 3. Each numbered package represents a point on the CCs predefined assurance scale. An EAL can be considered a level of confidence in the security functions of an IT product or system. The EALs have been developed with the goal of preserving the concepts of assurance drawn from the source criteria, such as the Trusted Computer System Evaluation Criteria (TCSEC), Information Technology Security Evaluation Criteria (ITSEC), or Canadian Trusted Computer Evaluation Criteria (CTCPEC), so that results of previous evaluations remain relevant. EAL levels 2-7 are generally equivalent to the assurance portions of the TCSEC C2-A1 scale, although exact TCSEC mappings do not exist.

*Answer "A security level equal to the security level of the objects to which the subject has both

read and write access" is the definition of Subject Security Level. A subject's security level is equal to the security level of the objects to which it has both read and write access. A subject's security level must always be dominated by the clearance of the user with which the subject is associated.

* Answer "A statement of intent to counter specified threats" describes a Security Objective, which is a statement of

intent to counter specified threats and/or satisfy specified organizational security policies and assumptions.

* Answer "Requirements that specify the security behavior of an IT product or system" describes Security Functional Requirements. These are requirements, preferably from CC Part 2, that when taken together specify the security behavior of an IT product or system.

Source: CC Project and DoD 5200.28-STD.

QUESTION NO: 1994

Which disaster recovery/emergency management plan testing type

below is considered the most cost-effective and efficient way to identify

areas of overlap in the plan before conducting more demanding training

exercises?

- A. Evacuation drill
- B. Table-top exercise test
- C. Full-scale exercise
- D. Walk-through drill

Answer: B

Explanation:

In a table-top exercise, members of the emergency management group meet in a conference room setting to discuss their responsibilities and how they would react to emergency scenarios. Disaster recovery/emergency management plan testing scenarios have several levels, and can be called different things. The primary hierarchy of disaster/emergency testing plan types is shown below.

Checklist review. Plan is distributed and reviewed by business

units for its thoroughness and effectiveness.

Table-top exercise or structured walk-through test. Members of the emergency management group meet in a conference room setting to discuss their responsibilities and how they would react to emergency scenarios by stepping through the plan.

Walk-through drill or simulation test. The emergency management group and response teams actually perform their emergency response functions by walking through the test, without actually initiating recovery procedures. More thorough than the table-top exercise.

Functional drills. Test specific functions such as medical response, emergency notifications, warning and communications procedures, and equipment, although not necessarily all at once. Also includes evacuation drills, where personnel walk the evacuation route to a designated area where procedures for accounting for the personnel are tested.

Parallel test or full-scale exercise. A real-life emergency situation is simulated as closely as possible. Involves all of the participants that would be responding to the real emergency, including community and external organizations. The test may involve ceasing some real production processing.

Source: Emergency Management Guide for Business and Industry, Federal Emergency Management Agency, August 1998 and Computer Security Basics, by Deborah Russell and G.T. Gangemi, Sr. (O'Reilly, 1992).

QUESTION NO: 1995

In a system life cycle, information security controls should be:

- A.** Designed during the product implementation phase.
- B.** Specified after the coding phase.
- C.** Part of the feasibility phase.
- D.** Implemented prior to validation.

Answer: C

Explanation:

In the system life cycle, information security controls should be part of the feasibility phase. The other answers are incorrect because the basic premise of information system security is that controls should be included in the earliest phases of the software life cycle and not added later in the cycle or as an afterthought.

QUESTION NO: 1996

Which of the following is NOT true regarding software unit testing?

- A.** The test data is part of the specifications.
- B.** Testing should check for out-of-range values and other bounds conditions.
- C.** Correct test output results should be developed and known beforehand.
- D.** Live or actual field data is recommended for use in the testing procedures.

Answer: D

Explanation:

Live or actual field data are NOT recommended for use in testing because they do not thoroughly test all normal and abnormal situations and the test results are not known beforehand. The other answers are true of testing.

QUESTION NO: 1997

Which of the following actions by the US government are NOT permitted or required by the US Patriot Act, signed into law on October 26, 2001?

- A.** Search and seizure of information on live systems (including routers and servers), backups, and archives

- B. Monitoring of Internet communications
- C. Reporting of cash and wire transfers of \$5,000 or more
- D. Subpoena of electronic records

Answer: C

Explanation:

Wire and cash transfers of \$10,000 or more in a single transaction must be reported to government officials.

Actions in answers "Subpoena of electronic records", "Monitoring of Internet communications", and c are permitted under the Patriot Act.

In answers "Subpoena of electronic records" and "Monitoring of Internet communications", the government has new powers to subpoena electronic records and to monitor Internet traffic. In monitoring information, the government can require the assistance of ISPs and network operators. This monitoring can even extend into individual organizations. In the Patriot Act, Congress permits investigators to gather information about electronic mail without having to show probable cause that the person to be monitored had committed a crime or was intending to commit a crime. In answer c, the items cited now fall under existing search and seizure laws. A new twist is delayed notification of a search warrant. Under the Patriot Act, if it suspected that notification of a search warrant would cause a suspect to flee, a search can be conducted before notification of a search warrant is given.

In a related matter, the US and numerous other nations have signed the Council of Europes Cybercrime Convention. In the US, participation in the Convention has to be ratified by the Senate. In essence, the Convention requires the signatory nations to spy on their own residents, even if the action being monitored is illegal in the country in which the monitoring is taking place.

QUESTION NO: 1998

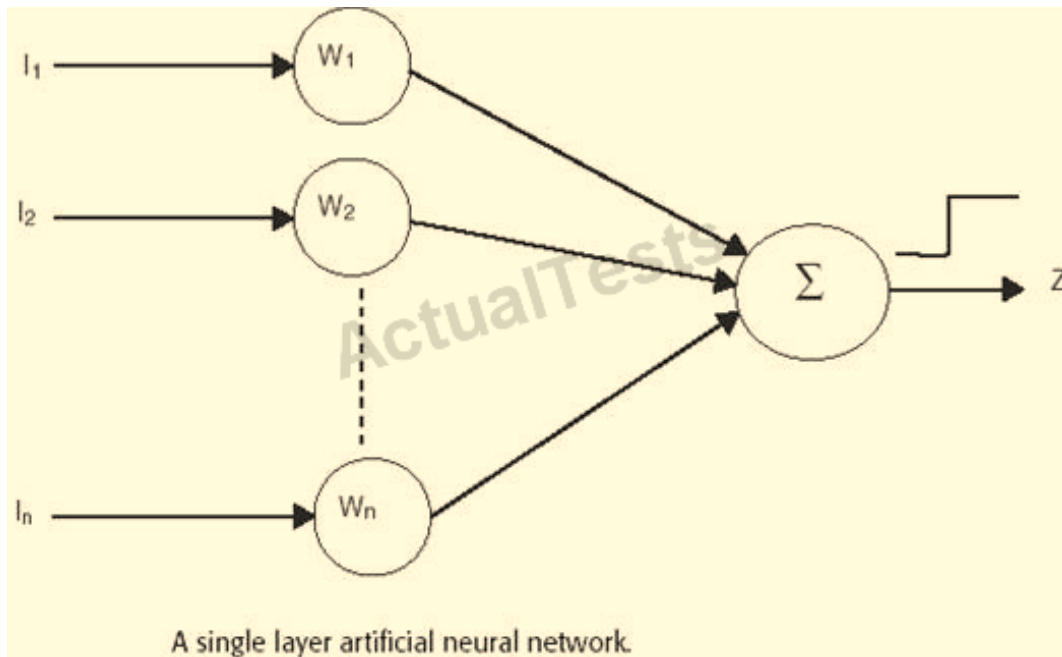
The equation $Z = f[wn \text{ in }]$, where Z is the output, wn are weighting functions, and in is a set of inputs describes:

- A. An artificial neural network (ANN)
- B. A knowledge-based system
- C. An expert system
- D. A knowledge acquisition system

Answer: A

Explanation:

The equation defines a single layer ANN as shown in Figure.



Each input, I_n , is multiplied by a weight, W_n , and these products are fed into a summation transfer function, Σ , that generates an output, Z . Most neural networks have multiple layers of summation and weighting functions, whose interconnections can also be changed. There are a number of different learning paradigms for neural networks, including reinforcement learning and back propagation. In reinforcement learning a training set of inputs is provided to the ANN along with a measure of how close the network is coming to a solution. Then, the weights and connections are readjusted. In back propagation, information is fed back inside the neural network from the output and is used by the ANN to make weight and connection adjustments.

*Answers An expert system and A knowledge-based system are distracters that describe systems that use knowledge-based rules of experts to solve problems using an inferencing mechanism.

*A knowledge acquisition system refers to the means of identifying and acquiring the knowledge to be entered into the knowledge base of an expert system.

QUESTION NO: 1999

Which choice below is NOT an example of a media control?

- A. Printing to a printer in a secured room
- B. Conducting background checks on individuals
- C. Sanitizing the media before disposition
- D. Physically protecting copies of backup media

Answer: B

Explanation:

The answer is a personnel control. Most support and operations staff have special access to the system. Some organizations conduct background checks on individuals filling these positions to screen out possibly untrustworthy individuals.

*Answer "Sanitizing the media before disposition": The process of removing information from media before

disposition is called sanitization. Three techniques are commonly used for media sanitization: overwriting, degaussing, and destruction.

*Answer "Printing to a printer in a secured room": It may be necessary to actually output data to the media

in a secure location, such as printing to a printer in a locked room instead of to a general-purpose printer in a common area.

*Answer "Physically protecting copies of backup media": Physical protection of copies of backup media stored

offsite should be accorded a level of protection equivalent to media containing the same information stored onsite.

Source: National Institute of Standards and Technology, An Introduction to Computer Security: The NIST Handbook Special Publication 800-12.

QUESTION NO: 2000

The chain of evidence relates to:

- A. Handling and controlling evidence.
- B. Making a disk image.
- C. DNA testing.
- D. Securing laptops to desks during an investigation.

Answer: A

Explanation:

- * Answer "Securing laptops to desks during an investigation" relates to physical security
- * answer "DNA testing" is a type of biological testing
- * answer "Signal intelligence" is part of the act of gathering evidence.

QUESTION NO: 2001

Which of the following is NOT a category of law under the Common Law System?

- A. Administrative/Regulatory law
- B. Criminal law
- C. Civil law
- D. Derived law

Answer: D

Explanation:

The correct answer is Derived law. It is a distracter, and all of the other answers are categories under common law.

QUESTION NO: 2002

Which choice below is considered the HIGHEST level of operator privilege?

- A. Read/Write
- B. Read Only
- C. Access Change

D. Write Only

Answer: C

Explanation:

The correct answer is Access Change.

The three common levels of operator privileges, based on the concept of least privilege, are:

Read Only Lowest level, view data only

Read/Write View and modify data

Access Change Highest level, right to change data/operator permissions

Answer d is a distracter.

QUESTION NO: 2003

In the modified Waterfall Model:

- A.** Product verification and validation are not included.
- B.** The model was reinterpreted to have phases begin at project milestones.
- C.** The model was reinterpreted to have phases end at project milestones.
- D.** Unlimited backward iteration is permitted.

Answer: C

Explanation:

The modified Waterfall model was reinterpreted to have phases end at project milestones.

Answer "Unlimited backward iteration is permitted" is false because unlimited backward iteration is not permitted in the modified Waterfall model.

Answer "The model was reinterpreted to have phases begin at project milestones" is a distracter.

Answer "Product verification and validation are not included" is false because verification and validation are included.

QUESTION NO: 2004

Which choice below is the MOST accurate description of a warm site?

- A.** A backup processing facility with adequate electrical wiring and air conditioning, but no hardware or software installed
- B.** A backup processing facility with all hardware and software installed and 100% compatible with the original site, operational within hours
- C.** A mobile trailer with portable generators and air conditioning
- D.** A backup processing facility with most hardware and software installed, which can be operational within a matter of days

Answer: D

Explanation:

The three most common types of remote off-site backup processing facilities are hot sites, warm sites, and cold sites. They are primarily differentiated by how much preparation is devoted to the site, and therefore how quickly the site can be used as an alternate processing site.

QUESTION NO: 2005

What phase of the object-oriented software development life cycle is described as emphasizing the employment of objects and methods rather than types or transformations as in other software approaches?

- A.** Object-oriented requirements analysis
- B.** Object-oriented programming
- C.** Object-oriented design
- D.** Object-oriented analysis

Answer: B

Explanation:

Answer "Object-oriented requirements analysis" defines classes of objects and their interactions.

Answer "Object-oriented analysis", object-oriented analysis, is the process of understanding and

modeling of a specific problem within a problem domain.

Object-oriented design is design in which the object is the basic unit of modularity and objects are instantiations of a class.

QUESTION NO: 2006

Responsibility for handling computer crimes in the United States is assigned to:

- A.** The Federal Bureau of Investigation (FBI) and the Secret Service.
- B.** The Central Intelligence Agency (CIA).
- C.** The National Security Agency (NSA).
- D.** The FBI only.

Answer: A

Explanation:

The correct answer is "The Federal Bureau of Investigation (FBI) and the Secret Service", making the other answers incorrect.

QUESTION NO: 2007

What is the difference between a parallel disaster recovery plan test and a full interruption disaster recovery plan test?

- A.** There is no difference; both terms mean the same thing.
- B.** Functional business unit representatives meet to review the plan to ensure it accurately reflects the organizations recovery strategy.
- C.** While a parallel test tests the processing functionality of the alternate site, the full-interruption test actually replicates a disaster by halting production.
- D.** While a full-interruption test tests the processing functionality of the alternate site, the parallel test actually replicates a disaster by halting

production.

Answer: C

Explanation:

parallel test tests the processing functionality of the alternate site, whereas the full-interruption test actually replicates a disaster by halting production.

*Answer "Functional business unit representatives meet to review the plan to ensure it accurately reflects the organizations recovery strategy" is the definition of a checklist test type.

QUESTION NO: 2008

Which choice below MOST accurately describes a Covert Storage Channel?

- A. A process that manipulates observable system resources in a way that affects response time
- B. An information transfer that involves the direct or indirect writing of a storage location by one process and the direct or indirect reading of the storage location by another process
- C. A communication channel that allows a process to transfer information in a manner that violates the systems security policy
- D. An information transfer path within a system

Answer: B

Explanation:

A covert storage channel typically involves a finite resource (e.g., sectors on a disk) that is shared by two subjects at different security levels. One way to think of the difference between covert timing channels and covert storage channels is that covert timing channels are essentially memoryless, whereas covert storage channels are not. With a timing channel, the information transmitted from the sender must be sensed by the receiver immediately, or it will be lost. However, an error code indicating a full disk which is exploited to create a storage channel may stay constant for an indefinite amount of time, so a receiving process is not as constrained by time.

*Answer "A process that manipulates observable system resources in a way that affects response time" is a partial description of a covert timing channel. A covert timing channel is a covert channel in which one process signals

information to another by modulating its own use of system resources (e.g., CPU time) in such a way that this manipulation affects the real response time observed by the second process.

*Answer "An information transfer path within a system" is a generic definition of a channel. A channel may also refer to the mechanism by which the path is effected.

*Answer "A communication channel that allows a process to transfer information in a manner that violates the systems security policy" is a higher-level definition of a covert channel. While a covert storage channel fits this definition generically.

Source: DoD 5200.28-STD Department of Defense Trusted Computer System Evaluation Criteria and NCSC-TG-030, A Guide To Understanding Covert Channel Analysis of Trusted Systems [Light Pink Book].

QUESTION NO: 2009

The Spiral Model of the software development process (B.W. Boehm, A Spiral Model of Software Development and Enhancement, IEEE Computer, May, 1988) uses the following metric relative to the spiral:

- A.** The angular dimension represents cumulative cost
- B.** The radial dimension represents cumulative cost
- C.** The radial dimension represents progress made in completing each cycle
- D.** The radial dimension represents the cost of each phase

Answer: B

Explanation:

The radial dimension represents cumulative cost and the angular dimension represents progress made in completing each cycle of the spiral. The spiral model is actually a meta-model for software development processes. A summary of the stages in the spiral is as follows:

The spiral begins in the top, left-hand quadrant by determining the objectives of the portion of the product being developed, the alternative means of implementing this portion of the product, and the constraints imposed on the application of the alternatives.

Next, the risks of the alternatives are evaluated based on the objectives and constraints. Following this step, the relative balances of the perceived risks are determined.

The spiral then proceeds to the lower right-hand quadrant where the development phases of the projects begin. A major review completes each cycle and then the process begins anew for succeeding phases of the project. Typical succeeding phases are software product design, integration and test plan development, additional risk analyses, operational prototype, detailed design, code, unit test, acceptance test, and implementation.

The other answers are distracters.

QUESTION NO: 2010

Another type of artificial intelligence technology involves genetic algorithms. Genetic algorithms are part of the general class known as:

- A.** Suboptimal computing
- B.** Biological computing
- C.** Evolutionary computing
- D.** Neural networks

Answer: C

Explanation:

Evolutionary computing uses the Darwinian principles of survival of the fittest, mutation, and the adaptation of successive generations of populations to their environment. The genetic algorithm implements this process through iteration of generations of a constant-size population of items or individuals. Each individual is characterized by a finite string of symbols called genomes. The genomes are used to represent possible solutions to a problem in a fixed search space. For example, if the fixed population of the first generation of individuals consists of random binary numbers, and the problem is to find the minimum binary number that can be represented by an individual, each binary number is assigned a fitness value based on the individuals binary number value. The smaller the binary number represented by a parent individual, the higher level of fitness that is

assigned to it. Through cross breeding among the numbers (known as crossover), mutations of the numbers, and pairing of numbers with high fitness ratings, the smallest value that can be represented by the number of bits in the binary number will emerge in later generations.

*Answer neural networks, is incorrect and has been discussed extensively in previous questions in this chapter.

*Answer Suboptimal computing is a distracter and answer biological computing, refers to computation performed by using certain characteristics of living organisms.

QUESTION NO: 2011

Which choice below would NOT be considered a benefit of employing incident-handling capability?

- A. An individual acting alone would not be able to subvert a security process or control.
- B. It enhances internal communications and the readiness of the organization to respond to incidents.
- C. Security training personnel would have a better understanding of users knowledge of security issues.
- D. It assists an organization in preventing damage from future incidents.

Answer: A

Explanation:

The primary benefits of employing an incident-handling capability are containing and repairing damage from incidents and preventing future damage. Additional benefits related to establishing an incident handling capability are:

Enhancement of the risk assessment process. An incident handling capability will allow organizations to collect threat data that may be useful in their risk assessment and safeguard selection processes (e.g., in designing new systems). Statistics on the numbers and types of incidents in the organization can be used in the risk-assessment process as an indication of vulnerabilities and threats.

Enhancement of internal communications and the readiness of the organization to respond to any type of incident, not just

computer security incidents. Internal communications will be improved, management will be better organized to receive communications, and contacts within public affairs, legal staff, law enforcement, and other groups will have been preestablished. Security training personnel will have a better understanding of users knowledge of security issues. Trainers can use actual incidents to vividly illustrate the importance of computer security. Training that is based on current threats and controls recommended by incident-handling staff provides users with information more specifically directed to their current needs, thereby reducing the risks to the organization from incidents.

*Answer "An individual acting alone would not be able to subvert a security process or control" is a benefit of employing separation of duties controls.

Source: National Institute of Standards and Technology, An Introduction to Computer Security: The NIST Handbook Special Publication 800-12.

QUESTION NO: 2012

What is searching for data correlations in the data warehouse called?

- A. Configuration management
- B. Data warehousing
- C. A data dictionary
- D. Data mining

Answer: D

Explanation:

Searching for data correlations in the data warehouse is called data mining.

Answer Data warehousing is incorrect because data warehousing is creating a repository of information from heterogeneous databases that is available to users for making queries.

Answer A data dictionary is incorrect because a data dictionary is a database for system developers.

Answer Configuration management is incorrect because configuration management is the discipline of identifying the components of a continually evolving system for the purposes of controlling changes to those components and

maintaining integrity and traceability throughout the life cycle.

QUESTION NO: 2013

Which choice below is NOT an accurate description or element of remote sensing technology?

- A.** RS intelligence may be integrated into geographic information systems (GIS) to produce map-based products
- B.** Photographic, radar, infrared, or multi-spectral imagery from landbased tracking stations
- C.** Photographic, radar, infrared, or multi-spectral imagery from geostationary or orbiting satellites
- D.** Photographic, radar, infrared, or multi-spectral imagery from manned or unmanned aircraft

Answer: B

Explanation:

Remote sensing is the acquisition of information via aerial or satellite sensors. The most critical category of information to capture immediately following a disaster is accurate and timely intelligence about the scope, extent, and impact of the event. Intelligent and effective decisions hinge on the credible characterization of the situation. If the disaster is extensive enough, it may cause serious damage to the telephone or wireless infrastructure and ground communications may be unusable to accurately assess the situation. Remote sensing systems can provide a highly effective alternative means of gathering intelligence about the event.

*Answer "Photographic, radar, infrared, or multi-spectral imagery from manned or unmanned aircraft" describes remote sensing using aerial-derived information.

*Answer "Photographic, radar, infrared, or multi-spectral imagery from geostationary or orbiting satellites" describes satellite-derived remote sensing.

*Answer "RS intelligence may be integrated into geographic information systems (GIS) to produce map-based products" describes a common use of the remote sensing data. Source: Remote Sensing

in Federal Disaster Areas, Standard Operating Procedures, FEMA 9321.1-PR, June 1999

QUESTION NO: 2014

The Federal Intelligence Surveillance Act (FISA) of 1978, the Electronic Communications Privacy Act (ECPA) of 1986, and the Communications Assistance for Law Enforcement Act (CALEA) of 1994 are legislative acts passed by the United States Congress. These acts all address what major information security issue?

- A. Computer fraud
- B. Wiretapping
- C. Unlawful use of and access to government computers and networks
- D. Malicious code

Answer: B

Explanation:

These laws reflected different views concerning wiretapping as technology progressed. The Federal Intelligence Surveillance Act (FISA) of 1978 limited wiretapping for national security purposes as a result of the record of the Nixon Administration in using illegal wiretaps. The Electronic Communications Privacy Act (ECPA) of 1986 prohibited eavesdropping or the interception of message contents without distinguishing between private or public systems. The Communications Assistance for Law Enforcement Act (CALEA) of 1994 required all communications carriers to make wiretaps possible in ways approved by the FBI.

QUESTION NO: 2015

Which of the following is NOT a common term in object-oriented systems?

- A. Method

- B. Behavior
- C. Function
- D. Message

Answer: C

Explanation:

*Answer behavior, is a characteristic of an object. The object is defined as a collection of operations that, when selected, reveal or manipulate the state of the object. Thus, consecutive invocations of an object may result in different behaviors, based on the last operations selected.

*Answer message, is a request sent to an object to carry out a particular operation.

*A method is the code that describes what the object will do when sent a message.

QUESTION NO: 2016

Which choices below are most accurate regarding the information needed to define the continuity strategy? Select all that apply.

- A. The strategy needs to define personnel roles in implementing continuity.
- B. A strategy needs to be defined to preserve computing elements, such as hardware, software, and networking elements.
- C. The strategy needs to address facility use during a disruptive event.
- D. None of the other alternatives apply.

Answer: A,B,C

Explanation:

QUESTION NO: 2017

Which of the following items is NOT a component of a knowledgebased system (KBS)?

- A. Knowledge base

- B. Procedural code
- C. Interface between the user and the system
- D. Inference Engine

Answer: B

Explanation:

Procedural code in a procedural language implies sequential execution of instructions based on the von Neumann architecture of a CPU, Memory, and Input/Output device. Variables are part of the sets of instructions used to solve a particular problem and, thus, the data are not separate from the statements. Such languages have control statements such as goto, ifthenelse and so on. The program execution is iterative and corresponds to a sequence of state changes in a state machine.

*Answer knowledge base, refers to the rules and facts of the particular problem domain.

*The inference engine takes the inputs to the KBS and uses the knowledge base to infer new facts and to solve the problem.

*Answer "Interface between the user and the system" refers to the interface between the user and the system through which the data are entered, displayed, and output.

QUESTION NO: 2018

A database that comprises tools to support the analysis, design, and development of software and support good software engineering practices is called a:

- A. Database management system (DBMS)
- B. Data model
- C. Data dictionary
- D. Data type dictionary

Answer: C

Explanation:

Computer Aided Software Engineering (CASE) tools and an Integrated Project Support Environment (IPSE) are terms used to describe similar

software engineering support environments.

*Answer data model, is a basic system of constructs used in describing reality, (Kent, W., Data and Reality, North Holland, 1978).

*A DBMS is a system that supports the creation, use, and administration of a database system.

* Answer a data type dictionary, refers to a collection of items on which certain operations, such as insert, delete, and search, are to be performed.

This arrangement of items is in contrast to a priority queue, in which the collection of items is arranged in order of priority and the relevant operations to be performed are insert, find-max, and delete-max.

QUESTION NO: 2019

Which one of the following items are true concerning the Platform for Privacy Preferences (P3P) developed by the World Wide Web Consortium (W3C)? Select three.

- A.** It does not provide the site privacy practices to users in machine-readable format.
- B.** It allows Web sites to express their privacy practices in a standard format that can be retrieved automatically and interpreted easily by user agents.
- C.** It allows users to be informed of site practices in human-readable format.
- D.** It automates decision-making based on the sites privacy practices when appropriate.

Answer: B,C,D

Explanation:

In addition to the capabilities in the correct answers, P3P does provide the site privacy practices to users in machine-readable format.

QUESTION NO: 2020

Which choice below is NOT an element of proper media control?

- A. Accurately and promptly marking all data storage media
- B. Assuring the accuracy of the backup data
- C. The proper environmental storage of the media
- D. The safe and clean handling of the media

Answer: B

Explanation:

"Assuring the accuracy of the backup data" is an example of a software integrity control, although the other three elements of media control listed apply to the backup tapes themselves.

QUESTION NO: 2021

What is a data warehouse?

- A. A repository of information from heterogeneous databases
- B. A remote facility used for storing backup tapes
- C. A hot backup building
- D. A table in a relational database system

Answer: A

Explanation:

The correct answer is a repository of information from heterogeneous databases.

Answers "A remote facility used for storing backup tapes" and "A hot backup building" describe physical facilities for backup and recovery of information systems, and answer "A table in a relational database system" describes a relation in a relational database.

QUESTION NO: 2022

Which term below BEST describes the concept of least privilege?

- A. Active monitoring of facility entry access points.

- B. Each user is granted the lowest clearance required for their tasks.
- C. A formal separation of command, program, and interface functions.
- D. A combination of classification and categories that represents the sensitivity of information.

Answer: B

Explanation:

The least privilege principle requires that each subject in a system be granted the most restrictive set of privileges (or lowest clearance) needed for the performance of authorized tasks. The application of this principle limits the damage that can result from accident, error, or unauthorized use. Applying this principle may limit the damage resulting from accidents, errors, or unauthorized use of system resources.

*Answer "A formal separation of command, program, and interface functions." describes separation of privilege, which is the separation of functions, namely between the commands, programs, and interfaces implementing those functions, such that malicious or erroneous code in one function is prevented from affecting the code or data of another function.

*Answer "A combination of classification and categories that represents the sensitivity of information." is a security level. A security level is the combination of hierarchical classification and a set of non-hierarchical categories that represents the sensitivity of information.

*Answer "Active monitoring of facility entry access points." is a distracter. Source: DoD 5200.28-STD Department of Defense Trusted Computer System Evaluation Criteria.

QUESTION NO: 2023

What is a method in an object-oriented system?

- A. The code defining the actions that the object performs in response to a message
- B. A guide to the programming of objects
- C. The means of communication among objects
- D. The situation where a class inherits the behavioral characteristics of more than one parent class

Answer: A

Explanation:

method in an object-oriented system is
the code that defines the actions that the object performs in response
to a message.

Answer "The means of communication among objects" is incorrect because it defines a message.

Answer "A guide to the programming of objects" is a distracter.

Answer "The situation where a class inherits the behavioral characteristics of more than one parent class" refers to multiple inheritance.

QUESTION NO: 2024

Which of the following refers to a US Government program that reduces
or eliminates emanations from electronic equipment?

- A. ECHELON
- B. TEMPEST
- C. ECHO
- D. CLIPPER

Answer: B

Explanation:

Answer CLIPPER refers to the US government Escrowed Encryption Standard.

Answer ECHELON refers to the large-scale monitoring of RF transmissions.

Answer ECHO is a distracter.

QUESTION NO: 2025

Which choice below is the first priority in an emergency?

- A. Notifying external support resources for recovery and restoration
- B. Warning customers and contractors of a potential interruption of service
- C. Communicating with employees families the status of the

emergency

D. Protecting the health and safety of everyone in the facility

Answer: D

Explanation:

Life safety, or protecting the health and safety of everyone in the facility is the first priority in an emergency or disaster. Evacuation routes, assembly areas, and accounting for personnel (head counts and last-known locations) are the most important function of emergency procedures, before anything else. Once all personnel have been accounted for and emergency teams have arrived to prevent further damage or hazard, family members should be notified of the status of the event. Providing restoration and recovery, and implementing alternative production methods also comes later. Source: Emergency Management Guide for Business and Industry, Federal Emergency Management Agency, August, 1998.

QUESTION NO: 2026

Which choice below BEST describes the type of control that a firewall exerts on a network infrastructure?

- A.** Detective control
- B.** Preventative control
- C.** Corrective control
- D.** Application control

Answer: B

Explanation:

A firewall is primarily intended to prevent unauthorized access.

QUESTION NO: 2027

Which of the following is NOT a characteristic of a distributed data processing (DDP) approach?

- A.** Consists of multiple processing locations that can provide alternatives for computing in the event of a site becoming inoperative.
- B.** Data stored at multiple, geographically separate locations is easily available to the user.
- C.** Distances from user to processing resource are transparent to the user.
- D.** Security is enhanced because of networked systems.

Answer: D

Explanation:

Security is more of a concern in distributed systems since there are vulnerabilities associated with the network and the many locations from which unauthorized access to the computing resources can occur. The other answers are characteristics of a DDP architecture.

QUESTION NO: 2028

A refinement to the basic Waterfall Model that states that software should be developed in increments of functional capability is called:

- A.** Functional development
- B.** Incremental development
- C.** Functional refinement
- D.** Incremental refinement

Answer: B

Explanation:

The advantages of incremental development include the ease of testing increments of functional capability and the opportunity to incorporate user experience into a successively refined product. The other answers are distracters.

QUESTION NO: 2029

Which statement below is NOT true regarding the relationship of the organization with the media during and after a disaster?

- A.** The company should be honest and accurate about what they know about the event and its effects.
- B.** The organization must avoid dealing with the media at all costs during and after the disruptive event.
- C.** The companys response should be delivered by a credible, informed spokesperson.
- D.** The organization should establish a unified organizational response to the media during and after the disruptive event.

Answer: B

Explanation:

QUESTION NO: 2030

An expert system that has rules of the form If w is low and x is high then y is intermediate, where w and x are input variables and y is the output variable, is called a:

- A.** Fuzzy expert system
- B.** Realistic expert system
- C.** Neural network
- D.** Boolean expert system

Answer: A

Explanation:

A fuzzy expert system is an expert system that uses fuzzy membership functions and rules, instead of Boolean logic, to reason about data. Thus, fuzzy variables can have an approximate range of values instead of the binary True or False used in conventional expert systems. When it is desired to convert the fuzzy output to a single value, defuzzification is used. One approach to defuzzification is the CENTROID method. With

this method, a value of the output variable is computed by finding the variable value of the center of gravity of the membership function for the fuzzy output value.

Answers Neural network and Realistic expert system are distracters, and answer Boolean expert system is incorrect since it refers to Boolean values of one or zero.

QUESTION NO: 2031

Which entity of the US legal system makes common laws?

- A. Judicial branch
- B. Administrative agencies
- C. Executive branch
- D. Legislative branch

Answer: A

Explanation:

The correct answer is Judicial branch. The judicial decisions made in the courts generate common law. Answer a, administrative agencies, create administrative laws and the legislative branch, answer b, generates statutory laws. The executive branch, answer c, does not make laws.

QUESTION NO: 2032

Which choice below is the BEST description of operational assurance?

- A. Operational assurance has the benefit of containing and repairing damage from incidents.
- B. Operational assurance is the process of performing pre-employment background screening.
- C. Operational assurance is the process of examining audit logs to reveal usage that identifies misuse.
- D. Operational assurance is the process of reviewing an operational system to see that security controls are functioning correctly.

Answer: D

Explanation:

Operational assurance is the process of reviewing an operational system to see that security controls, both automated and manual, are functioning correctly and effectively. Operational assurance addresses whether the systems technical features are being bypassed or have vulnerabilities and whether required procedures are being followed.

To maintain operational assurance, organizations use two basic methods: system audits and monitoring. A system audit is a one-time or periodic event to evaluate security. Monitoring refers to an ongoing activity that examines either the system or the users.

*Answer "Operational assurance is the process of examining audit logs to reveal usage that identifies misuse" is a description of an audit trail review.

Answer "Operational assurance has the benefit of containing and repairing damage from incidents" is a description of a benefit of incident handling. The main benefits of proper incident handling are containing and repairing damage from incidents, and preventing future damage.

*Answer "Operational assurance is the process of performing pre-employment background screening" describes a personnel control.

Source: National Institute of Standards and Technology, An Introduction to Computer Security: The NIST Handbook Special Publication 800-12.

QUESTION NO: 2033

The basic version of the Construction Cost Model (COCOMO), which proposes quantitative, life-cycle relationships, performs what function?

- A.** Estimates software development effort and cost as a function of the size of the software product in source instructions modified by manpower buildup and productivity factors
- B.** Estimates software development effort and cost as a function of the size of the software product in source instructions modified by hardware and input functions
- C.** Estimates software development effort based on user function categories
- D.** Estimates software development effort and cost as a function of the

size of the software product in source instructions

Answer: D

Explanation:

The Basic COCOMO Model (B.W. Boehm, Software Engineering Economics, Prentice-Hall, Englewood Cliffs, New Jersey, 1981) proposes the following equations:

The number of man-months (MM) required to develop the most common type of software product, in terms of the number of thousands of delivered source instructions (KDSI) in the software product

$$MM = 2.4 (KDSI)^{1.05}$$

The development schedule (TDEV) in months

$$TDEV = 2.5(MM)^{0.38}$$

In addition, Boehm has developed an intermediate COCOMO Model that also takes into account hardware constraints, personnel quality, use of modern tools, and other attributes and their aggregate impact on overall project costs. A detailed COCOMO Model, by Boehm, accounts for the effects of the additional factors used in the intermediate model on the costs of individual project phases.

QUESTION NO: 2034

In developing an emergency or recovery plan, which choice below would NOT be considered a short-term objective?

- A.** Minimum resources needed to accomplish the restoration
- B.** The organizations strategic plan
- C.** Priorities for restoration
- D.** Acceptable downtime before restoration

Answer: B

Explanation:

The organizations strategic plan is considered a long-term goal. In developing plans, consideration should be given to both shortterm and long-term goals and objectives. Short-term goals can include:

Vital personnel, systems, operations, and equipment

Priorities for restoration and mitigation

Acceptable downtime before restoration to a minimum level of operations

Minimum resources needed to accomplish the restoration

Long-term goals and objectives can include:

The organizations strategic plan

Management and coordination of activities

Funding and fiscal management

Management of volunteer, contractual, and entity resources

Source: NFPA 1600 Standard on Disaster/Emergency Management and Business Continuity, National Fire Protection Association, 2000 edition.

QUESTION NO: 2035

What is enticement?

- A.** Encouraging the commission of a crime when there was initially no intent to commit a crime
- B.** Luring the perpetrator to an attractive area or presenting the perpetrator with a lucrative target after the crime has already been initiated
- C.** Assisting in the commission of a crime
- D.** Encouraging the commission of one crime over another

Answer: B

Explanation:

The correct answer is "Luring the perpetrator to an attractive area or presenting the perpetrator with a lucrative target after the crime has already been initiated", the definition of enticement.

*Answer "Encouraging the commission of a crime when there was initially no intent to commit a crime" is the definition of entrapment.

The other answers are distracters.

QUESTION NO: 2036

Liability of senior organizational officials relative to the protection of the organizations information systems is prosecutable under:

- A. Criminal law.
- B. Civil law.
- C. Financial law.
- D. International law.

Answer: B

Explanation:

QUESTION NO: 2037

The software maintenance phase controls consist of:

- A. Request control, configuration control, and change control.
- B. Request control, release control, and access control.
- C. Request control, change control, and release control.
- D. Change control, security control, and access control.

Answer: C

Explanation:

The software maintenance phase controls consist of request control, change control, and release control by definition. The other answers are, therefore, incorrect.

Topic 16, Exam SET D

QUESTION NO: 2038

One important tool of computer forensics is the disk image backup. The disk image backup is:

- A. Copying the system files

- B. Conducting a bit-level copy, sector by sector
- C. Copying and authenticating the system files
- D. Copying the disk directory

Answer: B

Explanation:

Copying sector by sector at the bit level provides the capability to examine slack space, undeleted clusters and possibly, deleted files.

With answer a, only the system files are copied and the other information recovered in answer b would not be captured.

Answer "Copying the disk directory" does not capture the data on the disk, and answer "Copying and authenticating the system files

" has the same problem as answer "Copying the system files". Actually, authenticating the system files is another step in the computer forensics process wherein a message digest is generated for all system directories and files to be able to validate the integrity of the information at a later time. This authentication should be conducted using a backup copy of the disk and not the original to avoid modifying information on the original. For review purposes, computer forensics is the collecting of information from and about computer systems that is admissible in a court of law.

QUESTION NO: 2039

In the U.S. Federal Rules of Evidence, Rule 803 (6) permits an exception to the Hearsay Rule regarding business records and computer records.

Which one of the following is NOT a requirement for business or computer records exception under Rule 803 (6)?

- A. Relied upon in the regular course of business
- B. Made by a person with information transmitted by a person with knowledge
- C. Made only by a person with knowledge of the records
- D. Made during the regular conduct of business and authenticated by witnesses familiar with their use

Answer: C

Explanation:

The business or computer records may be made by a person with information transmitted by a person with knowledge, also. The other answers are requirements for exceptions to the Hearsay Rule.

QUESTION NO: 2040

How many times should a diskette be formatted to comply with TCSEC

Orange Book object reuse recommendations?

- A. Five
- B. Nine
- C. Three
- D. Seven

Answer: D

Explanation:

The correct answer is 7. Most computer certification and accreditation standards recommend that diskettes be formatted seven times to prevent any possibility of data remanence .

QUESTION NO: 2041

Individual privacy rights as defined in the HIPAA Privacy Rule include

consent and authorization by the patient for the release of PHI. The

difference between consent and authorization as used in the Privacy Rule is:

- A. Consent grants general permission to use or disclose PHI, and authorization limits permission to the purposes and the parties specified in the authorization.

- B.** Consent grants general permission to use or disclose PHI, and authorization limits permission to the purposes specified in the authorization.
- C.** Authorization grants general permission to use or disclose PHI, and consent limits permission to the purposes and the parties specified in the consent.
- D.** Consent grants general permission to use or disclose PHI, and authorization limits permission to the parties specified in the authorization.

Answer: A

Explanation:

Answer b is therefore incorrect. Answer c is incorrect since the limits to authorization do not include the parties concerned. Answer d is incorrect since the limits to authorization do not include the specified purposes. The other individual privacy rights listed in the HIPAA Privacy Rule are:

Notice (of the covered entities privacy practices)

Right to request restriction

Right of access

Right to amend

Right to an accounting

In August of 2002, the U.S. Department of Health and Human Services (HHS) modified the Privacy Rule to ease the requirements of consent and allow the covered entities to use notice. The changes are summarized as follows:

Covered entities must provide patients with notice of the patients privacy rights and the privacy practices of the covered entity.

Direct treatment providers must make a good faith effort to obtain patients written acknowledgement of the notice of privacy rights and practices. (The Rule does not prescribe a form of written acknowledgement; the patient may sign a separate sheet or initial a cover sheet of the notice.)

Mandatory consent requirements are removed that would inhibit patient access to health care while providing covered entities with the option of developing a consent process that works for that entity. If the provider cannot obtain a written acknowledgement, it must document its good faith efforts to obtain one and the reason for its inability to obtain the acknowledgement.

Consent requirements already in place may continue.

QUESTION NO: 2042

Which type of fire detectors sends an alarm when the temperature of the room rises dramatically?

- A. Odor-sensing
- B. Heat-sensing
- C. Smoke-actuated
- D. Flame-actuated

Answer: B

Explanation:

A rate-of-rise detector triggers an alarm when the ambient temperature of a room increases rapidly. Another type of heat-sensing detector, a fixed temperature device, sends an alarm when the temperature passes a predetermined level.

QUESTION NO: 2043

Which of the following is NOT one of the European Union (EU) privacy principles?

- A. Individuals have the right to correct errors contained in their personal data.
- B. Information collected about an individual can be disclosed to other organizations or individuals unless specifically prohibited by the individual.
- C. Individuals are entitled to receive a report on the information that is held about them.
- D. Data transmission of personal information to locations where equivalent personal data protection cannot be assured is prohibited.

Answer: B

Explanation:

This principle is stated as an opt-out principle in which the individual has to take action to prevent information from being circulated to other organizations. The correct corresponding European Union principle states that information collected about an individual cannot be disclosed to other organizations or individuals unless authorized by law or by consent of the individual. Thus, the individual would have to take an active role or opt-in to authorize the disclosure of information to other organizations. The other principles are valid EU privacy principles.

QUESTION NO: 2044

Which of the following more closely describes the combustibles in a Class

B-rated fire?

- A. Gas
- B. Paper
- C. Liquid
- D. Electrical

Answer: C

Explanation:

The correct answer is C. Paper is described as a common combustible and is therefore rated a class A fire. An electrical fire is rated Class C. Gas is not defined as a combustible.

QUESTION NO: 2045

Which of the following is NOT a form of data erasure?

- A. Remanence

- B. Purging
- C. Clearing
- D. Destruction

Answer: A

Explanation:

Clearing refers to the overwriting of data media intended to be reused in same organization. Purging refers to degaussing or overwriting media intended to be removed from the organization. Destruction refers to completely destroying the media.

QUESTION NO: 2046

During the investigation of a computer crime, audit trails can be very useful. To ensure that the audit information can be used as evidence, certain procedures must be followed. Which of the following is NOT one of these procedures?

- A. Mechanisms should be in place to protect the integrity of the audit trail information.
- B. The audit trail information must be used during the normal course of business.
- C. There must be a valid organizational security policy in place and in use that defines the use of the audit information.
- D. Audit trails should be viewed prior to the image backup.

Answer: D

Explanation:

The image backup should be done first in order not to modify any information on the hard disk. For example, the authentication process applied to a hard disk can change the time of last access information on files. Thus, authentication should be applied to a disk image copy.

QUESTION NO: 2047

What does an audit trail or access log usually NOT record?

- A.** How often a diskette was formatted
- B.** Whether the attempt was successful
- C.** The date and time of the access attempt
- D.** Who attempted access

Answer: A

Explanation:

The correct answer is how often a diskette was formatted. The other three answers are common elements of an access log or audit trail.

QUESTION NO: 2048

Under Civil Law, the victim is NOT entitled to which of the following types of damages?

- A.** Compensatory
- B.** Punitive
- C.** Statutory
- D.** Imprisonment of the offender

Answer: D

Explanation:

Imprisonment or probation is not a type of punishment available for conviction of a civil crime. Answer a refers to awards set by law. Answer b, punitive damages, are usually determined by the jury and are intended to punish the offender. Compensatory awards are used to provide restitution and compensate the victim for such items as costs of investigations and attorneys fees.

QUESTION NO: 2049

Which of the following is NOT the proper suppression medium for a Class B fire?

- A. Halon
- B. Water
- C. Soda Acid
- D. CO2

Answer: B

Explanation:

The correct answer is Water. Water is not a proper suppression medium for a class B fire. The other three are commonly used.

QUESTION NO: 2050

A surge can be defined as a(n):

- A. Momentary power loss
- B. Steady interfering disturbance
- C. Prolonged high voltage
- D. Initial surge of power at start

Answer: C

Explanation:

The correct answer is "Prolonged high voltage".

Answer "initial surge of power at start" or power on, is called an inrush.

Momentary power loss is a fault.

A steady interfering disturbance, is called noise.

QUESTION NO: 2051

In order for evidence to be admissible in a court of law, it must be relevant, legally permissible, reliable, properly identified, and properly preserved. Reliability of evidence means that:

- A.** It must tend to prove a material fact; the evidence is related to the crime in that it shows that the crime has been committed, can provide information describing the crime, can provide information as to the perpetrators motives, can verify what had occurred, and so on.
- B.** The evidence is identified without changing or damaging the evidence.
- C.** The evidence is not subject to damage or destruction.
- D.** The evidence has not been tampered with or modified.

Answer: D

Explanation:

This requirement is a critical issue with computer evidence since computer data may be easily modified without having an indication that a change has taken place. Answer a defines the relevancy of evidence, answer b describes the identification of evidence, and answer d describes the preservation of evidence.

QUESTION NO: 2052

Because of the nature of information that is stored on the computer, the investigation and prosecution of computer criminal cases have specific characteristics, one of which is:

- A.** The information is intangible.
- B.** The investigation does not usually interfere with the normal conduct of the business of an organization.

- C.** Evidence is usually easy to gather.
- D.** Investigators and prosecutors have a longer time frame for the investigation.

Answer: A

Explanation:

The information is stored in memory on the computer and is intangible as opposed to a physical object. Answer a is incorrect since investigators and prosecutors are under time pressure to gather evidence and proceed to prosecution. If the suspect is alerted, he or she may do damage to the system or destroy important evidence. Search warrants may have to be obtained by law enforcement to search the suspects home and workplace and seize computers and disks. Answer c is incorrect since an investigation will interfere with the normal conduct of business. Some of the ways in which an investigation may affect an organization are:

The organization will have to provide experts to work with law enforcement.

Information key to the criminal investigation may be co-resident on the same computer system as information critical to the day-to-day operation of the organization.

Proprietary data may be subject to disclosure.

Management may be exposed if they have not exercised Due Care to protect information resources.

There may be negative publicity that will be harmful to the organization.

Answer d is incorrect. Evidence is difficult to gather since it is intangible and easily subject to modification or destruction.

QUESTION NO: 2053

It is estimated that the Asia/Pacific region accounts for about \$4 billion worth of loss of income to software publishers due to software piracy.

As with the Internet, cross-jurisdictional law enforcement issues make investigating and prosecuting such crime difficult. Which of the

following items is NOT an issue in stopping overseas software piracy?

- A.** Lack of a central, nongovernmental organization to address the issue of software piracy.
- B.** Obtaining the cooperation of foreign law enforcement agencies and foreign governments.
- C.** The producers of the illegal copies of software are dealing in larger and larger quantities, resulting in faster deliveries of illicit software.
- D.** The quality of the illegal copies of the software is improving, making it more difficult for purchasers to differentiate between legal and illegal products.

Answer: A

Explanation:

The Business Software Alliance (BSA) is a nongovernmental antisoftware piracy organization (www.bsa.org). The mission statement of the BSA is:

The Business Software Alliance is an international organization representing leading software and e-commerce developers in 65 countries around the world . Established in 1988, BSA has offices in the United States , Europe , and Asia Our efforts include educating computer users about software copyrights; advocating public policy that fosters innovation and expands trade opportunities; and fighting software piracy.

QUESTION NO: 2054

The proposed HIPAA Security Rule mandates the protection of the confidentiality, integrity, and availability of protected health information (PHI) through three of the following activities. Which of the activities is NOT included under the proposed HIPAA Security Rule?

- A.** Technical services and mechanisms
- B.** Physical safeguards
- C.** Administrative procedures
- D.** Appointment of a Privacy Officer

Answer: D

Explanation:

HIPAA separates the activities of Security and Privacy. HIPAA Security is mandated under the main categories listed in answers a, b, and C. The proposed HIPAA Security Rule mandates the appointment of a Security Officer. The HIPAA Privacy Rule mandates the appointment of a Privacy Officer. HIPAA Privacy covers individually identifiable health care information transmitted, stored in electronic or paper or oral form. PHI may not be disclosed except for the following reasons:

Disclosure is approved by the individual

Permitted by the legislation

For treatment

Payment

Health care operations

As required by law

Protected Health Information (PHI) is individually identifiable health information that is:

Transmitted by electronic media

Maintained in any medium described in the definition of electronic media [under HIPAA]

Transmitted or maintained in any other form or medium

QUESTION NO: 2055

Which is NOT considered a physical intrusion detection method?

A. Wave pattern motion detector

B. Audio motion detector

C. Photoelectric sensor

D. Line supervision

Answer: D

Explanation:

Line supervision is the monitoring of the alarm signaling transmission medium to detect tampering. Audio detectors monitor a room for any abnormal sound wave generation.

Photoelectric sensors receive a beam of light from a light-emitting device. Wave pattern motion detectors generate a wave pattern and send an alarm if the pattern is disturbed.

QUESTION NO: 2056

The definition A mark used in the sale or advertising of services to identify the services of one person and distinguish them from the services of others refers to a:

- A. Trade name
- B. Trademark
- C. Service mark
- D. Copyright

Answer: C

Explanation:

For answer "a trademark" is a distinctive mark of authenticity, through which the products of particular manufacturers or the vendible commodities of particular merchants may be distinguished from those of others.

Answer "a trade name" is any designation which is adopted and used by a person to denominate goods which he markets, or services which he renders or business which he conducts. A trade name is descriptive of a manufacturer or dealer and applies to business and goodwill. A trademark is applicable only to vendible commodities.

In answer "a copyright "is an intangible, incorporeal right granted by statute to the author or originator of certain literary or artistic productions, whereby he is invested, for a statutorily prescribed period, with the sole and exclusive privilege of multiplying copies of the same and publishing and selling them. (These definitions were also taken from Blacks Law Dictionary, Abridged Fifth Edition, West Publishing Company, St. Paul Minnesota , 1983.)

QUESTION NO: 2057

In the context of legal proceedings and trial practice, discovery refers to:

- A.** The process in which the prosecution presents information it has uncovered to the defense, including potential witnesses, reports resulting from the investigation, evidence, and so on
- B.** The process undertaken by the investigators to acquire evidence needed for prosecution of a case
- C.** The process of obtaining information on potential and existing employees using background checks
- D.** A step in the computer forensic process

Answer: A

Explanation:

The key words are legal proceedings and trial practice. Information and property obtained in the investigation by law enforcement officials must be turned over to the defense. For some information that is proprietary to an organization, restrictions can be placed on who has access to the data. The other answers are forms of the investigative process. During an investigation, answers "The process undertaken by the investigators to acquire evidence needed for prosecution of a case" and "A step in the computer forensic process" are appropriate definitions of discovery.

QUESTION NO: 2058

Which of the following is NOT a goal of the Kennedy-Kassebaum

Health Insurance Portability and Accountability Act (HIPAA)

of 1996?

- A.** Provide for restricted access by the patient to personal healthcare information

- B. Enable the portability of health insurance
- C. Establish strong penalties for healthcare fraud
- D. Administrative simplification

Answer: A

Explanation:

HIPAA is designed to provide for greater access by the patient to personal healthcare information. In answer b, administrative simplification, the goal is to improve the efficiency and effectiveness of the healthcare system by:

Standardizing the exchange of administrative and financial data

Protecting the security and privacy of individually identifiable health information

Answers c and d are self-explanatory.

QUESTION NO: 2059

Which medium below is the most sensitive to damage from temperature?

- A. Computer hardware
- B. Sheet rock
- C. Floppy diskettes
- D. Paper products

Answer: C

Explanation:

Of the four choices, magnetic media is the most sensitive to damage from heat, smoke, water, and humidity.

QUESTION NO: 2060

Which of the following is an example of a smart card?

- A. A bank ATM card
- B. A library card
- C. An employee photo ID
- D. A drivers license

Answer: A

Explanation:

The correct answer is "A bank ATM card". The other three cards are dumb cards because it is assumed that they contain no electronics, magnetic stripes, or integrated circuits.

QUESTION NO: 2061

Which is NOT an element of two-factor authentication?

- A. Something you are
- B. Something you have
- C. Something you know
- D. Something you ate

Answer: D

Explanation:

QUESTION NO: 2062

Which of the following is NOT a definition or characteristic of Due Care?

- A. It may and often does require extraordinary care.
- B. Implies that a party has been guilty of a violation of the law in relation to the subject-matter or transaction.
- C. That care which an ordinary prudent person would have exercised under the same or similar circumstances.
- D. Just, proper, and sufficient care, so far as the circumstances demand it.

Answer: B

Explanation:

Due Care implies that not only has a party not been negligent or careless, but also that he/she has been guilty of no violation of law in relation to the subject matter or transaction which constitutes the cause of action. Due Care and Reasonable Care are used interchangeably. The definitions of Due Care given in the other answers are from Black's Law Dictionary, Abridged Fifth Edition, West Publishing Company, St. Paul Minnesota, 1983.

QUESTION NO: 2063

Which of the following is NOT considered an acceptable replacement for Halon discharge systems?

- A. Halon 1301
- B. Argon (IG55)
- C. FA200
- D. Inergen (IG541)

Answer: A

Explanation:

Existing installations are encouraged to replace Halon 1301 with one of the substitutes listed.

QUESTION NO: 2064

The U.S. Uniform Computer Information Transactions Act (UCITA) is a:

- A. Model act that is intended to apply uniform legislation to electronic credit transactions
- B. Model act that is intended to apply uniform legislation to software

licensing

C. Model act that addresses electronic transactions conducted by financial institutions

D. Model act that addresses digital signatures

Answer: B

Explanation:

The National Commissioners on Uniform State Laws (NCUSL) voted to approve the Uniform Computers Information Transactions Act (UCITA) on July 29, 1999. This legislation, which will have to be enacted state-by-state, will greatly affect libraries access to and use of software packages. It also will keep in place the current licensing practices of software vendors. At the present time, shrink-wrap or click-wrap licenses limit rights that are normally granted under copyright law. Under Section 109 of the U.S. 1976 Copyright Act, the first sale provision permits the owner of a particular copy without the authority of the copyright owner, to sell or otherwise dispose of the possession of that copy. However, the software manufacturers use the term license in their transactions. As opposed to the word sale, the term license denotes that the software manufacturers are permitting users to use a copy of their software. Thus, the software vendor still owns the software. Until each state enacts the legislation, it is not clear if shrink-wrap licenses that restrict users rights under copyright law are legally enforceable. For clarification, shrink-wrap licenses physically accompany a disk while click-on and active clickwrap licenses are usually transmitted electronically. Sometimes, the term shrink-wrap is interpreted to mean both physical and electronic licenses to use software. The focus of the UCITA legislation is not on the physical media, but on the information contained on the media.

QUESTION NO: 2065

The theft of a laptop poses a threat to which tenet of the C.I.A. triad?

A. All of the above

B. Availability

C. Integrity

D. Confidentiality

Answer: A

Explanation:

The correct answer is confidentiality, because the data can now be read by someone outside of a monitored environment; availability, because the user has lost the computing ability provided by the unit; and integrity, because the data residing on and any telecommunications from the portable are now suspect.

QUESTION NO: 2066

Which choice below BEST describes the process of data purging?

- A.** Complete physical destruction of the media
- B.** Reusing data storage media after its initial use
- C.** Overwriting of data media intended to be reused in the same organization or area
- D.** Degaussing or thoroughly overwriting media intended to be removed the control of the organization or area

Answer: D

Explanation:

Answer "Overwriting of data media intended to be reused in the same organization or area" refers to data clearing.

Answer "Complete physical destruction of the media" describes data destruction.

Answer "Reusing data storage media after its initial use" describes object reuse.

QUESTION NO: 2067

Law enforcement officials in the United States, up until passage of the Patriot Act (see Question 9), had extensive restrictions on search and seizure as established in the Fourth Amendment to the U.S. Constitution. These restrictions are still, essentially, more severe than those on private

citizens, who are not agents of a government entity. Thus, internal investigators in an organization or private investigators are not subject to the same restrictions as government officials. Private individuals are not normally held to the same standards regarding search and seizure since they are not conducting an unconstitutional government search.

However, there are certain exceptions where the Fourth Amendment applies to private citizens if they act as agents of the government/police.

Which of the following is NOT one of these exceptions?

- A.** The private individual conducts a warrantless search of company property for the company.
- B.** The private individual conducts a search that would require a search warrant if conducted by a government entity.
- C.** The government is aware of the intent to search or is aware of a search conducted by the private individual and does not object to these actions.
- D.** The private individual performs the search to aid the government.

Answer: A

Explanation:

Since the private individual, say an employee of the company, conducts a search for evidence on property that is owned by the company and is not acting as an agent of the government, a warrantless search is permitted. The Fourth Amendment does not apply. For review, the Fourth Amendment guarantees:

The right of the people to be secure in their persons, houses, papers, and effects, against unreasonable searches and seizures, shall not be violated, and no Warrants shall issue, but upon probable cause, supported by oath or affirmation, and particularly describing the place to be searched, and the persons or things to be seized.

The exigent circumstances doctrine provides an exception to these guarantees if destruction of evidence is imminent. Then, a warrantless search and seizure of evidence can be conducted if there is probable cause to suspect criminal activity. The other answers describe exceptions where the private individual is subject to the Fourth Amendment guarantees.

QUESTION NO: 2068

Which of the following is NOT a form of computer/network surveillance?

- A. Use of CCTV cameras
- B. Use of network sniffers
- C. Keyboard monitoring
- D. Review of audit logs

Answer: A

Explanation:

CCTV cameras fall under the category of physical surveillance.

Answers a and b are forms of active surveillance. These types of surveillance require an organizational policy informing the employees that the surveillance is being conducted. Additionally, warning banners describing the surveillance at log-on to a computer or network should be prominently displayed. These banners usually state that by logging on, the user acknowledges the warning and agrees to the monitoring.

Answer "Review of audit logs" is a passive form of computer/network surveillance.

QUESTION NO: 2069

The Internet Activities Board (IAB) considers which of the following behaviors relative to the Internet as unethical?

- A. Negligence in the conduct of Internet experiments
- B. Recordkeeping in which an individual cannot find out what information concerning that individual is in the record
- C. Improper dissemination and use of identifiable personal data
- D. Recordkeeping whose very existence is secret

Answer: A

Explanation:

The IAB document, Ethics and the Internet (RFC 1087) listed behaviors as unethical that:

Seek to gain unauthorized access to the resources of the Internet

Destroy the integrity of computer-based information

Disrupt the intended use of the Internet

Waste resources such as people, capacity and computers through such actions

Compromise the privacy of users

Involve negligence in the conduct of Internetwide experiments

The other answers are taken from the Code of Fair Information

Practices of the U.S. Department of Health, Education of Welfare.

QUESTION NO: 2070

Which of the following alternatives should NOT be used by law enforcement to gain access to a password?

A. Contacting the developer of the software for information to gain access to the computer or network through a back door

B. Compelling the suspect to provide the password

C. Data manipulation and trial procedures applied to the original version of the system hard disk

D. Using password cracker software

Answer: C**Explanation:**

The original disk of a computer involved in a criminal investigation should not be used for any experimental purposes since data may be modified or destroyed. Any operations should be conducted on a copy of the system disk. However, the other answers are the preferred methods of gaining access to a password-protected system. Interestingly, in answer b, there is legal precedent to order a suspect to provide the password of a computer that is in the custody of law enforcement.

QUESTION NO: 2071

Which is NOT a recommended way to dispose of unwanted used data media?

- A. Copying new data over existing data on diskettes
- B. Formatting diskettes seven or more times
- C. Shredding paper reports by cleared personnel
- D. Destroying CD-ROMs

Answer: A

Explanation:

The correct answer is copying new data over existing data on diskettes. While this method might overwrite the older files, if the new data file is smaller than the older data file, recoverable data might exist past the file end marker of the new file.

QUESTION NO: 2072

The recommended optimal relative humidity range for computer operations is:

- A. 40% to 60%
- B. 10% to 30%
- C. 30% to 40%
- D. 60% to 80%

Answer: A

Explanation:

The correct answer is C. 40% to 60% relative humidity is recommended for safe computer operations. Too low humidity can create static discharge problems, and too high humidity can create condensation and electrical contact problems.

QUESTION NO: 2073

Which is NOT a type of a fire detector?

- A. Smoke-actuated
- B. Flame-actuated
- C. Gas-discharge
- D. Heat-sensing

Answer: C

Explanation:

The correct answer is Gas-discharge. Gas-discharge is a type of fire extinguishing system, not a fire detection system.

QUESTION NO: 2074

Which type of fire extinguishing method contains standing water in the pipe, and therefore generally does not enable a manual shutdown of systems before discharge?

- A. Dry Pipe
- B. Deluge
- C. Wet pipe
- D. Preaction

Answer: C

Explanation:

The other three are variations on a dry pipe discharge method with the water not standing in the pipe until a fire is detected.

QUESTION NO: 2075

Which type of control below is NOT an example of a physical security access control?

- A. Guard dog
- B. Audit trail
- C. Retinal scanner
- D. Five-key programmable lock

Answer: B

Explanation:

QUESTION NO: 2076

A brownout can be defined as a:

- A. Prolonged low voltage.
- B. Prolonged power loss.
- C. Momentary high voltage.
- D. Momentary low voltage.

Answer: A

Explanation:

The correct answer is "Prolonged low voltage".

Answer "prolonged power loss" is a blackout.

Answer "momentary low voltage" is a sag.

Answer "momentary high voltage" is a spike.

QUESTION NO: 2077

Why should extensive exterior perimeter lighting of entrances or parking areas be installed?

- A. To enable programmable locks to be used
- B. To create two-factor authentication
- C. To discourage prowlers or casual intruders
- D. To prevent data remanence

Answer: C

Explanation:

The other answers have nothing to do with lighting.

QUESTION NO: 2078

Which choice below is the BEST description of a Central Station Alarm System?

- A. Also rings an alarm in the local fire or police station
- B. Rings an alarm in the office of the customer
- C. Rings an alarm in a central monitoring office of a third-party monitoring firm
- D. Rings an audible alarm on the local premises that it protects

Answer: C

Explanation:

Answer "Rings an audible alarm on the local premises that it protects" describes a Local Alarm System.

Answer "Rings an alarm in the office of the customer" describes a Proprietary System.

Answer "Also rings an alarm in the local fire or police station" describes an Auxiliary Station System.

QUESTION NO: 2079

Which choice below is NOT a type of motion detector?

- A. Audio detection
- B. Wave pattern detection
- C. Smoke detection
- D. Capacitance detection

Answer: C

Explanation:

The other three are examples of intrusion detectors designed to sense unusual movement within a defined interior security area.

QUESTION NO: 2080

What is the recommended height of perimeter fencing to keep out casual trespassers?

- A. 8 to 12 high
- B. 6 to 7 high
- C. 3 to 4 high
- D. 1 to 2 high

Answer: C

Explanation:

3 to 4 high fencing is considered minimal protection, only for restricting casual trespassers. Answers "6 to 7 high" and "8 to 12 high" are better protection against intentional intruders.

QUESTION NO: 2081

Which is a benefit of a guard over an automated control?

- A. Guards are cheaper.
- B. Guards do not need pre-employment screening.
- C. Guards do not need training.
- D. Guards can use discriminating judgment.

Answer: D

Explanation:

Guards can use discriminating judgment.

Guards are typically more expensive than automated controls, need training as to the protection requirements of the specific site, and need to be screened and bonded.

QUESTION NO: 2082

The European Union Electronic Signature Directive of January, 2000, defines an advanced electronic signature. This signature must meet all of the following requirements except that:

- A. It must be created using means that are generally accessible and available.
- B. It must be uniquely linked to the signatory.
- C. It must be linked to the data to which it relates in such a manner that any subsequent change of the data is detectable.
- D. It must be capable of identifying the signatory.

Answer: A

Explanation:

The Directive requires that the means be maintained under the sole control of the signatory. This requirement is a particularly difficult one to achieve. One approach is to use different tokens or smart cards for the different transactions involved. The other answers are typical characteristics of digital signatures that can be implemented with public key cryptography.

QUESTION NO: 2083

Which choice below BEST describes a power sag?

- A. Complete loss of power
- B. Momentary low voltage
- C. Prolonged high voltage
- D. Momentary high voltage

Answer: B

Explanation:

Answer "Complete loss of power" is a blackout, answer "Momentary high volta " is a spike, and answer "Prolonged high voltage" is a surge.

QUESTION NO: 2084

Which type of fire extinguisher below should be used on an electrical fire?

- A. Soda Acid
- B. CO2
- C. Kerosene
- D. Water

Answer: B

Explanation:

The most common electrical fire suppression mediums for an electrical or electronic fire are CO2, Halon , and its substitutes, including several inert gas agents.

QUESTION NO: 2085

On June 30, 2000, the U.S. Congress enacted the Electronic Signatures in Global and National Commerce Act (ESIGN) to facilitate the use of electronic records and signatures in interstate and foreign commerce by ensuring the validity and legal effect of contracts entered into electronically. An important provision of the Act requires that:

- A.** The e-commerce businesses do not have to determine whether the consumer has the ability to receive an electronic notice before transmitting the legally required notices to the consumer.
- B.** Businesses have the ability to use product price to persuade consumers to accept electronic records instead of paper.
- C.** Specific technologies be used to ensure technical compatibility.
- D.** Businesses obtain electronic consent or confirmation from consumers to receive information electronically that a law normally requires to be in writing.

Answer: D

Explanation:

The legislation is intent on preserving the consumers rights under consumer protection laws and went to extraordinary measures to meet this goal. Thus, a business must receive confirmation from the consumer in electronic format that the consumer consents to receiving information electronically that used to be in written form. This provision ensures that the consumer has access to the Internet and is familiar with the basics of electronic communications. Answer b is, therefore, incorrect. Answer c is also incorrect since the legislation reduces the ability of businesses to use product price unfairly to persuade consumers to accept electronic records. Answer d is incorrect since the legislation is specifically technology-neutral to permit the use of the best technology for the application.

QUESTION NO: 2086

Which is NOT considered a preventative security measure?

- A. Preset locks
- B. Guards
- C. Fences
- D. Audit trails

Answer: D

Explanation:

Audit trails are detective, rather than preventative, because they are used to piece together the information of an intrusion or intrusion attempt after the fact.

QUESTION NO: 2087

Which is NOT a PC security control device?

- A. A cable lock
- B. A switch control
- C. A port control
- D. A file cabinet lock

Answer: D

Explanation:

A cable lock is used to attach the PC to a desk; a switch control is used to prevent powering off of a unit; and a port control (such as a diskette drive lock) is used to prevent data from being downloaded from the PC.

QUESTION NO: 2088

One important tool of computer forensics is the disk image backup. The disk image backup is:

- A. Copying the system files
- B. Conducting a bit-level copy, sector by sector
- C. Copying and authenticating the system files

D. Copying the disk directory**Answer: B****Explanation:**

Copying sector by sector at the bit level provides the capability to examine slack space, undeleted clusters and possibly, deleted files.

With answer a, only the system files are copied and the other information recovered in answer b would not be captured.

Answer "Copying the disk directory" does not capture the data on the disk, and answer "Copying and authenticating the system files

" has the same problem as answer "Copying the system files". Actually, authenticating the system files is another step in the computer forensics process wherein a message digest is generated for all system directories and files to be able to validate the integrity of the information at a later time. This authentication should be conducted using a backup copy of the disk and not the original to avoid modifying information on the original.

For review purposes, computer forensics is the collecting of information from and about computer systems that is admissible in a court of law.

QUESTION NO: 2089

In the U.S. Federal Rules of Evidence, Rule 803 (6) permits an exception to the Hearsay Rule regarding business records and computer records.

Which one of the following is NOT a requirement for business or computer records exception under Rule 803 (6)?

- A.** Relied upon in the regular course of business
- B.** Made by a person with information transmitted by a person with knowledge
- C.** Made only by a person with knowledge of the records
- D.** Made during the regular conduct of business and authenticated by witnesses familiar with their use

Answer: C**Explanation:**

The business or computer records may be made by a person with information transmitted by a person with knowledge, also. The other answers are requirements for exceptions to the Hearsay Rule.

QUESTION NO: 2090

How many times should a diskette be formatted to comply with TCSEC

Orange Book object reuse recommendations?

- A. Five
- B. Nine
- C. Three
- D. Seven

Answer: D

Explanation:

The correct answer is 7. Most computer certification and accreditation standards recommend that diskettes be formatted seven times to prevent any possibility of data remanence .

QUESTION NO: 2091

Individual privacy rights as defined in the HIPAA Privacy Rule include

consent and authorization by the patient for the release of PHI. The

difference between consent and authorization as used in the Privacy Rule is:

- A. Consent grants general permission to use or disclose PHI, and authorization limits permission to the purposes and the parties specified in the authorization.
- B. Consent grants general permission to use or disclose PHI, and authorization limits permission to the purposes specified in the

authorization.

C. Authorization grants general permission to use or disclose PHI, and consent limits permission to the purposes and the parties specified in the consent.

D. Consent grants general permission to use or disclose PHI, and authorization limits permission to the parties specified in the authorization.

Answer: A

Explanation:

Answer b is therefore incorrect. Answer c is incorrect since the limits to authorization do not include the parties concerned. Answer d is incorrect since the limits to authorization do not include the specified purposes. The other individual privacy rights listed in the HIPAA Privacy Rule are:

Notice (of the covered entities privacy practices)

Right to request restriction

Right of access

Right to amend

Right to an accounting

In August of 2002, the U.S. Department of Health and Human Services (HHS) modified the Privacy Rule to ease the requirements of consent and allow the covered entities to use notice. The changes are summarized as follows:

Covered entities must provide patients with notice of the patients privacy rights and the privacy practices of the covered entity.

Direct treatment providers must make a good faith effort to obtain patients written acknowledgement of the notice of privacy rights and practices. (The Rule does not prescribe a form of written acknowledgement; the patient may sign a separate sheet or initial a cover sheet of the notice.)

Mandatory consent requirements are removed that would inhibit patient access to health care while providing covered entities with the option of developing a consent process that works for that entity. If the provider cannot obtain a written acknowledgement, it must document its good faith efforts to obtain one and the reason for its inability to obtain the acknowledgement.

Consent requirements already in place may continue.

QUESTION NO: 2092

Which type of fire detectors sends an alarm when the temperature of the room rises dramatically?

- A. Odor-sensing
- B. Heat-sensing
- C. Smoke-actuated
- D. Flame-actuated

Answer: B

Explanation:

A rate-of-rise detector triggers an alarm when the ambient temperature of a room increases rapidly. Another type of heat-sensing detector, a fixed temperature device, sends an alarm when the temperature passes a predetermined level.

QUESTION NO: 2093

Which of the following is NOT one of the European Union (EU) privacy principles?

- A. Individuals have the right to correct errors contained in their personal data.
- B. Information collected about an individual can be disclosed to other organizations or individuals unless specifically prohibited by the individual.
- C. Individuals are entitled to receive a report on the information that is held about them.
- D. Data transmission of personal information to locations where equivalent personal data protection cannot be assured is prohibited.

Answer: B

Explanation:

This principle is stated as an opt-out principle in which the individual has to take action to prevent information from being circulated to other organizations. The correct corresponding European Union principle states that information collected about an individual cannot be disclosed to other organizations or individuals unless authorized by law or by consent of the individual. Thus, the individual would have to take an active role or opt-in to authorize the disclosure of information to other organizations. The other principles are valid EU privacy principles.

QUESTION NO: 2094

Which of the following more closely describes the combustibles in a Class

B-rated fire?

- A. Gas
- B. Paper
- C. Liquid
- D. Electrical

Answer: C

Explanation:

The correct answer is C. Paper is described as a common combustible and is therefore rated a class A fire. An electrical fire is rated Class C. Gas is not defined as a combustible.

QUESTION NO: 2095

Which of the following is NOT a form of data erasure?

- A. Remanence
- B. Purging

- C. Clearing
- D. Destruction

Answer: A

Explanation:

Clearing refers to the overwriting of data media intended to be reused in same organization. Purging refers to degaussing or overwriting media intended to be removed from the organization. Destruction refers to completely destroying the media.

QUESTION NO: 2096

During the investigation of a computer crime, audit trails can be very useful. To ensure that the audit information can be used as evidence, certain procedures must be followed. Which of the following is NOT one of these procedures?

- A. Mechanisms should be in place to protect the integrity of the audit trail information.
- B. The audit trail information must be used during the normal course of business.
- C. There must be a valid organizational security policy in place and in use that defines the use of the audit information.
- D. Audit trails should be viewed prior to the image backup.

Answer: D

Explanation:

The image backup should be done first in order not to modify any information on the hard disk. For example, the authentication process applied to a hard disk can change the time of last access information on files. Thus, authentication should be applied to a disk image copy.

QUESTION NO: 2097

What does an audit trail or access log usually NOT record?

- A. How often a diskette was formatted
- B. Whether the attempt was successful
- C. The date and time of the access attempt
- D. Who attempted access

Answer: A

Explanation:

The correct answer is how often a diskette was formatted. The other three answers are common elements of an access log or audit trail.

QUESTION NO: 2098

Under Civil Law, the victim is NOT entitled to which of the following types of damages?

- A. Compensatory
- B. Punitive
- C. Statutory
- D. Imprisonment of the offender

Answer: D

Explanation:

Imprisonment or probation is not a type of punishment available for conviction of a civil crime. Answer a refers to awards set by law. Answer b, punitive damages, are usually determined by the jury and are intended to punish the offender. Compensatory awards are used to provide restitution and compensate the victim for such items as costs of investigations and attorneys fees.

QUESTION NO: 2099

Which of the following is NOT the proper suppression medium for a Class B fire?

- A. Halon
- B. Water
- C. Soda Acid
- D. CO2

Answer: B

Explanation:

The correct answer is Water. Water is not a proper suppression medium for a class B fire. The other three are commonly used.

QUESTION NO: 2100

A surge can be defined as a(n):

- A. Momentary power loss
- B. Steady interfering disturbance
- C. Prolonged high voltage
- D. Initial surge of power at start

Answer: C

Explanation:

The correct answer is "Prolonged high voltage".

Answer "initial surge of power at start" or power on, is called an inrush.

Momentary power loss is a fault.

A steady interfering disturbance, is called noise.

QUESTION NO: 2101

In order for evidence to be admissible in a court of law, it must be relevant, legally permissible, reliable, properly identified, and properly preserved. Reliability of evidence means that:

- A.** It must tend to prove a material fact; the evidence is related to the crime in that it shows that the crime has been committed, can provide information describing the crime, can provide information as to the perpetrators motives, can verify what had occurred, and so on.
- B.** The evidence is identified without changing or damaging the evidence.
- C.** The evidence is not subject to damage or destruction.
- D.** The evidence has not been tampered with or modified.

Answer: D

Explanation:

This requirement is a critical issue with computer evidence since computer data may be easily modified without having an indication that a change has taken place. Answer a defines the relevancy of evidence, answer b describes the identification of evidence, and answer d describes the preservation of evidence.

QUESTION NO: 2102

Because of the nature of information that is stored on the computer, the investigation and prosecution of computer criminal cases have specific characteristics, one of which is:

- A.** The information is intangible.
- B.** The investigation does not usually interfere with the normal conduct of the business of an organization.
- C.** Evidence is usually easy to gather.

D. Investigators and prosecutors have a longer time frame for the investigation.

Answer: A

Explanation:

The information is stored in memory on the computer and is intangible as opposed to a physical object. Answer a is incorrect since investigators and prosecutors are under time pressure to gather evidence and proceed to prosecution. If the suspect is alerted, he or she may do damage to the system or destroy important evidence. Search warrants may have to be obtained by law enforcement to search the suspects home and workplace and seize computers and disks. Answer c is incorrect since an investigation will interfere with the normal conduct of business. Some of the ways in which an investigation may affect an organization are:

The organization will have to provide experts to work with law enforcement.

Information key to the criminal investigation may be co-resident on the same computer system as information critical to the day-to-day operation of the organization.

Proprietary data may be subject to disclosure.

Management may be exposed if they have not exercised Due Care to protect information resources.

There may be negative publicity that will be harmful to the organization.

Answer d is incorrect. Evidence is difficult to gather since it is intangible and easily subject to modification or destruction.

QUESTION NO: 2103

It is estimated that the Asia/Pacific region accounts for about \$4 billion worth of loss of income to software publishers due to software piracy.

As with the Internet, cross-jurisdictional law enforcement issues make investigating and prosecuting such crime difficult. Which of the following items is NOT an issue in stopping overseas software piracy?

- A.** Lack of a central, nongovernmental organization to address the issue of software piracy.
- B.** Obtaining the cooperation of foreign law enforcement agencies and foreign governments.
- C.** The producers of the illegal copies of software are dealing in larger and larger quantities, resulting in faster deliveries of illicit software.
- D.** The quality of the illegal copies of the software is improving, making it more difficult for purchasers to differentiate between legal and illegal products.

Answer: A

Explanation:

The Business Software Alliance (BSA) is a nongovernmental antisoftware piracy organization (www.bsa.org). The mission statement of the BSA is:

The Business Software Alliance is an international organization representing leading software and e-commerce developers in 65 countries around the world . Established in 1988, BSA has offices in the United States , Europe , and Asia Our efforts include educating computer users about software copyrights; advocating public policy that fosters innovation and expands trade opportunities; and fighting software piracy.

QUESTION NO: 2104

The proposed HIPAA Security Rule mandates the protection of the confidentiality, integrity, and availability of protected health information (PHI) through three of the following activities. Which of the activities is NOT included under the proposed HIPAA Security Rule?

- A.** Technical services and mechanisms
- B.** Physical safeguards
- C.** Administrative procedures
- D.** Appointment of a Privacy Officer

Answer: D

Explanation:

HIPAA separates the activities of Security and Privacy. HIPAA Security is mandated under the main categories listed in answers a, b, and C. The proposed HIPAA Security Rule mandates the appointment of a Security Officer. The HIPAA Privacy Rule mandates the appointment of a Privacy Officer. HIPAA Privacy covers individually identifiable health care information transmitted, stored in electronic or paper or oral form. PHI may not be disclosed except for the following reasons:

Disclosure is approved by the individual

Permitted by the legislation

For treatment

Payment

Health care operations

As required by law

Protected Health Information (PHI) is individually identifiable health information that is:

Transmitted by electronic media

Maintained in any medium described in the definition of electronic media [under HIPAA]

Transmitted or maintained in any other form or medium

QUESTION NO: 2105

Which is NOT considered a physical intrusion detection method?

- A. Wave pattern motion detector
- B. Audio motion detector
- C. Photoelectric sensor
- D. Line supervision

Answer: D

Explanation:

Line supervision is the monitoring of the alarm signaling transmission medium to detect tampering. Audio detectors monitor a room for any abnormal sound wave generation. Photoelectric sensors receive a beam of light from a light-emitting device. Wave pattern motion detectors generate a wave pattern and

send an alarm if the pattern is disturbed.

QUESTION NO: 2106

The definition A mark used in the sale or advertising of services to identify the services of one person and distinguish them from the services of others refers to a:

- A. Trade name
- B. Trademark
- C. Service mark
- D. Copyright

Answer: C

Explanation:

For answer "a trademark" is a distinctive mark of authenticity, through which the products of particular manufacturers or the vendible commodities of particular merchants may be distinguished from those of others.

Answer "a trade name" is any designation which is adopted and used by a person to denominate goods which he markets, or services which he renders or business which he conducts. A trade name is descriptive of a manufacturer or dealer and applies to business and goodwill. A trademark is applicable only to vendible commodities.

In answer "a copyright "is an intangible, incorporeal right granted by statute to the author or originator of certain literary or artistic productions, whereby he is invested, for a statutorily prescribed period, with the sole and exclusive privilege of multiplying copies of the same and publishing and selling them. (These definitions were also taken from Blacks Law Dictionary, Abridged Fifth Edition, West Publishing Company, St. Paul Minnesota , 1983.)

QUESTION NO: 2107

In the context of legal proceedings and trial practice, discovery refers to:

- A.** The process in which the prosecution presents information it has uncovered to the defense, including potential witnesses, reports resulting from the investigation, evidence, and so on
- B.** The process undertaken by the investigators to acquire evidence needed for prosecution of a case
- C.** The process of obtaining information on potential and existing employees using background checks
- D.** A step in the computer forensic process

Answer: A

Explanation:

The key words are legal proceedings and trial practice. Information and property obtained in the investigation by law enforcement officials must be turned over to the defense. For some information that is proprietary to an organization, restrictions can be placed on who has access to the data. The other answers are forms of the investigative process. During an investigation, answers "The process undertaken by the investigators to acquire evidence needed for prosecution of a case" and "A step in the computer forensic process" are appropriate definitions of discovery.

QUESTION NO: 2108

Which of the following is NOT a goal of the Kennedy-Kassebaum Health Insurance Portability and Accountability Act (HIPAA) of 1996?

- A.** Provide for restricted access by the patient to personal healthcare information
- B.** Enable the portability of health insurance
- C.** Establish strong penalties for healthcare fraud

D. Administrative simplification

Answer: A

Explanation:

HIPAA is designed to provide for greater access by the patient to personal healthcare information. In answer b, administrative simplification, the goal is to improve the efficiency and effectiveness of the healthcare system by:

Standardizing the exchange of administrative and financial data

Protecting the security and privacy of individually identifiable health information

Answers c and d are self-explanatory.

QUESTION NO: 2109

Which medium below is the most sensitive to damage from temperature?

- A. Computer hardware**
- B. Sheet rock**
- C. Floppy diskettes**
- D. Paper products**

Answer: C

Explanation:

Of the four choices, magnetic media is the most sensitive to damage from heat, smoke, water, and humidity.

QUESTION NO: 2110

Which of the following is an example of a smart card?

- A. A bank ATM card**
- B. A library card**

- C. An employee photo ID
- D. A drivers license

Answer: A

Explanation:

The correct answer is "A bank ATM card". The other three cards are dumb cards because it is assumed that they contain no electronics, magnetic stripes, or integrated circuits.

QUESTION NO: 2111

Which is NOT an element of two-factor authentication?

- A. Something you are
- B. Something you have
- C. Something you know
- D. Something you ate

Answer: D

Explanation:

QUESTION NO: 2112

Which of the following is NOT a definition or characteristic of Due Care?

- A. It may and often does require extraordinary care.
- B. Implies that a party has been guilty of a violation of the law in relation to the subject-matter or transaction.
- C. That care which an ordinary prudent person would have exercised under the same or similar circumstances.
- D. Just, proper, and sufficient care, so far as the circumstances demand it.

Answer: B

Explanation:

Due Care implies that not only has a party not been negligent or careless, but also that he/she has been guilty of no violation of law in relation to the subject matter or transaction which constitutes the cause of action. Due Care and Reasonable Care are used interchangeably. The definitions of Due Care given in the other answers are from Blacks Law Dictionary, Abridged Fifth Edition, West Publishing Company, St. Paul Minnesota, 1983.

QUESTION NO: 2113

Which of the following is NOT considered an acceptable replacement for Halon discharge systems?

- A. Halon 1301
- B. Argon (IG55)
- C. FA200
- D. Inergen (IG541)

Answer: A

Explanation:

Existing installations are encouraged to replace Halon 1301 with one of the substitutes listed.

QUESTION NO: 2114

The U.S. Uniform Computer Information Transactions Act (UCITA) is a:

- A. Model act that is intended to apply uniform legislation to electronic credit transactions
- B. Model act that is intended to apply uniform legislation to software licensing
- C. Model act that addresses electronic transactions conducted by financial

institutions

D. Model act that addresses digital signatures

Answer: B

Explanation:

The National Commissioners on Uniform State Laws (NCUSL) voted to approve the Uniform Computers Information Transactions Act (UCITA) on July 29, 1999. This legislation, which will have to be enacted state-by-state, will greatly affect libraries access to and use of software packages. It also will keep in place the current licensing practices of software vendors. At the present time, shrink-wrap or click-wrap licenses limit rights that are normally granted under copyright law. Under Section 109 of the U.S. 1976 Copyright Act, the first sale provision permits the owner of a particular copy without the authority of the copyright owner, to sell or otherwise dispose of the possession of that copy. However, the software manufacturers use the term license in their transactions. As opposed to the word sale, the term license denotes that the software manufacturers are permitting users to use a copy of their software. Thus, the software vendor still owns the software. Until each state enacts the legislation, it is not clear if shrink-wrap licenses that restrict users rights under copyright law are legally enforceable. For clarification, shrink-wrap licenses physically accompany a disk while click-on and active clickwrap licenses are usually transmitted electronically. Sometimes, the term shrink-wrap is interpreted to mean both physical and electronic licenses to use software. The focus of the UCITA legislation is not on the physical media, but on the information contained on the media.

QUESTION NO: 2115

The theft of a laptop poses a threat to which tenet of the C.I.A. triad?

- A.** All of the above
- B.** Availability
- C.** Integrity
- D.** Confidentiality

Answer: A

Explanation:

The correct answer is confidentiality, because the data can now be read by someone outside of a monitored environment; availability, because the user has lost the computing ability provided by the unit; and integrity, because the data residing on and any telecommunications from the portable are now suspect.

QUESTION NO: 2116

Which choice below BEST describes the process of data purging?

- A.** Complete physical destruction of the media
- B.** Reusing data storage media after its initial use
- C.** Overwriting of data media intended to be reused in the same organization or area
- D.** Degaussing or thoroughly overwriting media intended to be removed the control of the organization or area

Answer: D

Explanation:

Answer "Overwriting of data media intended to be reused in the same organization or area" refers to data clearing.

Answer "Complete physical destruction of the media" describes data destruction.

Answer "Reusing data storage media after its initial use" describes object reuse.

QUESTION NO: 2117

Law enforcement officials in the United States, up until passage of the Patriot Act (see Question 9), had extensive restrictions on search and seizure as established in the Fourth Amendment to the U.S. Constitution. These restrictions are still, essentially, more severe than those on private

citizens, who are not agents of a government entity. Thus, internal investigators in an organization or private investigators are not subject to the same restrictions as government officials. Private individuals are not normally held to the same standards regarding search and seizure since they are not conducting an unconstitutional government search.

However, there are certain exceptions where the Fourth Amendment applies to private citizens if they act as agents of the government/police.

Which of the following is NOT one of these exceptions?

- A.** The private individual conducts a warrantless search of company property for the company.
- B.** The private individual conducts a search that would require a search warrant if conducted by a government entity.
- C.** The government is aware of the intent to search or is aware of a search conducted by the private individual and does not object to these actions.
- D.** The private individual performs the search to aid the government.

Answer: A

Explanation:

Since the private individual, say an employee of the company, conducts a search for evidence on property that is owned by the company and is not acting as an agent of the government, a warrantless search is permitted. The Fourth Amendment does not apply. For review, the Fourth Amendment guarantees:

The right of the people to be secure in their persons, houses, papers, and effects, against unreasonable searches and seizures, shall not be violated, and no Warrants shall issue, but upon probable cause, supported by oath or affirmation, and particularly describing the place to be searched, and the persons or things to be seized.

The exigent circumstances doctrine provides an exception to these guarantees if destruction of evidence is imminent. Then, a warrantless search and seizure of evidence can be conducted if there is probable cause to suspect criminal activity. The other answers describe exceptions where the private individual is subject to the Fourth Amendment guarantees.

QUESTION NO: 2118

Which of the following is NOT a form of computer/network surveillance?

- A. Use of CCTV cameras
- B. Use of network sniffers
- C. Keyboard monitoring
- D. Review of audit logs

Answer: A

Explanation:

CCTV cameras fall under the category of physical surveillance.

Answers a and b are forms of active surveillance. These types of surveillance require an organizational policy informing the employees that the surveillance is being conducted. Additionally, warning banners describing the surveillance at log-on to a computer or network should be prominently displayed. These banners usually state that by logging on, the user acknowledges the warning and agrees to the monitoring.

Answer "Review of audit logs" is a passive form of computer/network surveillance.

QUESTION NO: 2119

The Internet Activities Board (IAB) considers which of the following behaviors relative to the Internet as unethical?

- A. Negligence in the conduct of Internet experiments
- B. Recordkeeping in which an individual cannot find out what information concerning that individual is in the record
- C. Improper dissemination and use of identifiable personal data
- D. Recordkeeping whose very existence is secret

Answer: A

Explanation:

The IAB document, Ethics and the Internet (RFC 1087) listed behaviors as unethical that:

Seek to gain unauthorized access to the resources of the Internet

Destroy the integrity of computer-based information

Disrupt the intended use of the Internet

Waste resources such as people, capacity and computers through such actions

Compromise the privacy of users

Involve negligence in the conduct of Internetwide experiments

The other answers are taken from the Code of Fair Information

Practices of the U.S. Department of Health, Education of Welfare.

QUESTION NO: 2120

Which of the following alternatives should NOT be used by law enforcement to gain access to a password?

A. Contacting the developer of the software for information to gain access to the computer or network through a back door

B. Compelling the suspect to provide the password

C. Data manipulation and trial procedures applied to the original version of the system hard disk

D. Using password cracker software

Answer: C

Explanation:

The original disk of a computer involved in a criminal investigation should not be used for any experimental purposes since data may be modified or destroyed. Any operations should be conducted on a copy of the system disk. However, the other answers are the preferred methods of gaining access to a password-protected system. Interestingly, in answer b, there is legal precedent to order a suspect to provide the password of a computer that is in the custody of law enforcement.

QUESTION NO: 2121

Which is NOT a recommended way to dispose of unwanted used data media?

- A. Copying new data over existing data on diskettes
- B. Formatting diskettes seven or more times
- C. Shredding paper reports by cleared personnel
- D. Destroying CD-ROMs

Answer: A

Explanation:

The correct answer is copying new data over existing data on diskettes. While this method might overwrite the older files, if the new data file is smaller than the older data file, recoverable data might exist past the file end marker of the new file.

QUESTION NO: 2122

The recommended optimal relative humidity range for computer operations is:

- A. 40% to 60%
- B. 10% to 30%
- C. 30% to 40%
- D. 60% to 80%

Answer: A

Explanation:

The correct answer is C. 40% to 60% relative humidity is recommended for safe computer operations. Too low humidity can create static discharge problems, and too high humidity can create condensation and electrical contact problems.

QUESTION NO: 2123

Which is NOT a type of a fire detector?

- A. Smoke-actuated
- B. Flame-actuated
- C. Gas-discharge
- D. Heat-sensing

Answer: C

Explanation:

The correct answer is Gas-discharge. Gas-discharge is a type of fire extinguishing system, not a fire detection system.

QUESTION NO: 2124

Which type of fire extinguishing method contains standing water in the pipe, and therefore generally does not enable a manual shutdown of systems before discharge?

- A. Dry Pipe
- B. Deluge
- C. Wet pipe
- D. Preaction

Answer: C

Explanation:

The other three are variations on a dry pipe discharge method with the water not standing in the pipe until a fire is detected.

QUESTION NO: 2125

Which type of control below is NOT an example of a physical security access control?

- A. Guard dog
- B. Audit trail
- C. Retinal scanner
- D. Five-key programmable lock

Answer: B

Explanation:

QUESTION NO: 2126

A brownout can be defined as a:

- A. Prolonged low voltage.
- B. Prolonged power loss.
- C. Momentary high voltage.
- D. Momentary low voltage.

Answer: A

Explanation:

The correct answer is "Prolonged low voltage".

Answer "prolonged power loss" is a blackout.

Answer "momentary low voltage" is a sag.

Answer "momentary high voltage" is a spike.

QUESTION NO: 2127

Why should extensive exterior perimeter lighting of entrances or parking areas be installed?

- A. To enable programmable locks to be used
- B. To create two-factor authentication
- C. To discourage prowlers or casual intruders
- D. To prevent data remanence

Answer: C

Explanation:

The other answers have nothing to do with lighting.

QUESTION NO: 2128

Which choice below is the BEST description of a Central Station Alarm System?

- A. Also rings an alarm in the local fire or police station
- B. Rings an alarm in the office of the customer
- C. Rings an alarm in a central monitoring office of a third-party monitoring firm
- D. Rings an audible alarm on the local premises that it protects

Answer: C

Explanation:

Answer "Rings an audible alarm on the local premises that it protects" describes a Local Alarm System.

Answer "Rings an alarm in the office of the customer" describes a Proprietary System.

Answer "Also rings an alarm in the local fire or police station" describes an Auxiliary Station System.

QUESTION NO: 2129

Which choice below is NOT a type of motion detector?

- A. Audio detection
- B. Wave pattern detection
- C. Smoke detection
- D. Capacitance detection

Answer: C

Explanation:

The other three are examples of intrusion detectors designed to sense unusual movement within a defined interior security area.

QUESTION NO: 2130

What is the recommended height of perimeter fencing to keep out casual trespassers?

- A. 8 to 12 high
- B. 6 to 7 high
- C. 3 to 4 high
- D. 1 to 2 high

Answer: C

Explanation:

3 to 4 high fencing is considered minimal protection, only for restricting casual trespassers. Answers "6 to 7 high" and "8 to 12 high" are better protection against intentional intruders.

QUESTION NO: 2131

Which is a benefit of a guard over an automated control?

- A. Guards are cheaper.
- B. Guards do not need pre-employment screening.
- C. Guards do not need training.
- D. Guards can use discriminating judgment.

Answer: D

Explanation:

Guards can use discriminating judgment.

Guards are typically more expensive than automated controls, need training as to the protection requirements of the specific site, and need to be screened and bonded.

QUESTION NO: 2132

The European Union Electronic Signature Directive of January, 2000, defines an advanced electronic signature. This signature must meet all of the following requirements except that:

- A. It must be created using means that are generally accessible and available.
- B. It must be uniquely linked to the signatory.
- C. It must be linked to the data to which it relates in such a manner that any subsequent change of the data is detectable.
- D. It must be capable of identifying the signatory.

Answer: A

Explanation:

The Directive requires that the means be maintained under the sole control of the signatory. This requirement is a particularly difficult one to achieve. One approach is to use different tokens or smart cards for the different transactions involved. The other answers are typical characteristics of digital signatures that can be implemented with public key cryptography.

QUESTION NO: 2133

Which choice below BEST describes a power sag?

- A. Complete loss of power
- B. Momentary low voltage
- C. Prolonged high voltage
- D. Momentary high voltage

Answer: B

Explanation:

Answer "Complete loss of power" is a blackout, answer "Momentary high volta " is a spike, and answer "Prolonged high voltage" is a surge.

QUESTION NO: 2134

Which type of fire extinguisher below should be used on an electrical fire?

- A. Soda Acid
- B. CO2
- C. Kerosene
- D. Water

Answer: B

Explanation:

The most common electrical fire suppression mediums for an electrical or electronic fire are CO2, Halon , and its substitutes, including several inert gas agents.

QUESTION NO: 2135

On June 30, 2000, the U.S. Congress enacted the Electronic Signatures in Global and National Commerce Act (ESIGN) to facilitate the use of electronic records and signatures in interstate and foreign commerce by ensuring the validity and legal effect of contracts entered into electronically. An important provision of the Act requires that:

- A.** The e-commerce businesses do not have to determine whether the consumer has the ability to receive an electronic notice before transmitting the legally required notices to the consumer.
- B.** Businesses have the ability to use product price to persuade consumers to accept electronic records instead of paper.
- C.** Specific technologies be used to ensure technical compatibility.
- D.** Businesses obtain electronic consent or confirmation from consumers to receive information electronically that a law normally requires to be in writing.

Answer: D

Explanation:

The legislation is intent on preserving the consumers rights under consumer protection laws and went to extraordinary measures to meet this goal. Thus, a business must receive confirmation from the consumer in electronic format that the consumer consents to receiving information electronically that used to be in written form. This provision ensures that the consumer has access to the Internet and is familiar with the basics of electronic communications. Answer b is, therefore, incorrect. Answer c is also incorrect since the legislation reduces the ability of businesses to use product price unfairly to persuade consumers to accept electronic records. Answer d is incorrect since the legislation is specifically technology-neutral to permit the use of the best technology for the application.

QUESTION NO: 2136

Which is NOT considered a preventative security measure?

- A. Preset locks
- B. Guards
- C. Fences
- D. Audit trails

Answer: D

Explanation:

Audit trails are detective, rather than preventative, because they are used to piece together the information of an intrusion or intrusion attempt after the fact.

QUESTION NO: 2137

Which is NOT a PC security control device?

- A. A cable lock
- B. A switch control
- C. A port control
- D. A file cabinet lock

Answer: D

Explanation:

A cable lock is used to attach the PC to a desk; a switch control is used to prevent powering off of a unit; and a port control (such as a diskette drive lock) is used to prevent data from being downloaded from the PC.